Análisis Forense Informático

Guía para Peritos e Ingenieros

Juan Gualberto Gutiérrez Marín

Nota para la edición digital. Este libro contiene numerosos enlaces y referencias web pensados para consultarse desde un lector de PDF. En la versión impresa, los enlaces siguen apareciendo como referencia y se complementan con la bibliografía incluida en los capítulos.

Licencia

© 2026 Juan Gualberto Gutiérrez Marín.

Tras la Brecha. Primera edición, 2026.

Obra autopublicada mediante Amazon Kindle Direct Publishing (KDP).

El contenido original de esta obra se distribuye bajo la licencia **Creative Commons Atribución-NoComercial-CompartirIgual 4.0 Internacional (CC BY-NC-SA 4.0)**.

Se permite copiar, compartir, redistribuir y adaptar el contenido con fines no comerciales, siempre que se reconozca adecuadamente la autoría, se indiquen las modificaciones realizadas y las adaptaciones se distribuyan bajo la misma licencia.

Los derechos de explotación comercial quedan reservados al autor. La reproducción, distribución, venta o explotación comercial de esta obra por terceros requiere autorización previa y expresa de su titular.

La edición comercial disponible mediante Amazon Kindle Direct Publishing (KDP) se publica por autorización del propio autor, titular de los derechos.

Licencia completa: https://creativecommons.org/licenses/by-nc-sa/4.0/deed.es

Las marcas, logotipos, capturas, citas y demás materiales pertenecientes a terceros conservan sus correspondientes derechos y condiciones de uso.

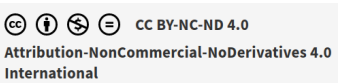


Figura 1: Atribución-CompartirIgual (CC BY-SA 4.0)

Página del autor: https://juangualberto.github.io.

Sobre el autor

Juan Gualberto Gutiérrez Marín es profesor de Informática y cuenta con **más de veintidós años de experiencia docente**. Su trayectoria se ha desarrollado principalmente en la enseñanza de tecnologías de la información, programación, sistemas, redes y ciberseguridad, combinando la docencia técnica con el diseño de materiales y laboratorios orientados a situaciones reales.

Ha desarrollado también parte de su experiencia profesional en **Estados Unidos**, lo que ha contribuido a una visión de la tecnología y de la formación técnica conectada con distintos entornos profesionales y educativos.

Además de su actividad en Formación Profesional, ha impartido docencia universitaria en la **Universidad de Jaén**, tanto en titulaciones del ámbito de la Ingeniería Informática como en formación de posgrado. En el **Máster de Seguridad Informática de la Universidad de Jaén** ha impartido la asignatura **Análisis de Software**, vinculada al estudio técnico del comportamiento de programas y a la seguridad.

Su trabajo docente actual presta especial atención a la **ciberseguridad defensiva, DFIR, respuesta a incidentes, análisis forense, administración de sistemas, redes, cloud y automatización**. En sus materiales intenta conectar los fundamentos con la práctica profesional: entender qué ocurre en un sistema, qué evidencias deja una acción, cómo detectarla y cómo responder de manera proporcionada.

Este libro nace de ese enfoque. No pretende presentar la ciberseguridad como una colección de herramientas aisladas, sino como un proceso en el que tecnología, procedimientos, investigación y toma de decisiones deben funcionar conjuntamente.

”In mathematics, all can be found in the computer; everything we know or have found out in twenty thousand years. In history, that’s not so. Historians pick and choose and every one of them picks and chooses the same thing.”

Hari Seldon

Isaac Asimov, Prelude to Foundation (1988)

Índice

1 Introducción al análisis forense digital **9**

1.1 Concepto, objetivos y aplicaciones de la informática forense 10
1.2 Investigación judicial, corporativa y respuesta a incidentes 19
1.3 Evidencias digitales: características, valor y limitaciones 29
1.4 Fuentes de evidencia y responsabilidades del analista 42
1.5 De las huellas digitales a los hechos demostrables 57
Referencias del capítulo 58

2 Metodologías y estándares de investigación **61**

2.1 Planificación y alcance de una investigación 62
2.2 Fases del proceso forense 70
2.3 Normas ISO/IEC, recomendaciones NIST y buenas prácticas SWGDE 79
2.4 Hipótesis, reproducibilidad y validación de resultados 90
2.5 Preparación forense (*forensic readiness*) 99
2.6 Conclusión: la investigación como proceso auditable 111
2.7 Referencias y lecturas recomendadas 112

3 Marco legal, responsabilidad y ética profesional **115**

3.1 Autorización y legitimidad de una investigación 116
3.2 Tratamiento de evidencias en investigaciones judiciales y corporativas 122
3.3 Protección de datos y privacidad 129
3.4 Jurisdicción y obtención de evidencias 138
3.5 Ética, imparcialidad y responsabilidad profesional 144
3.6 Caso integrador: una investigación con límites jurídicos y técnicos 153
3.7 Conclusión 156
3.8 Referencias jurídicas y lecturas recomendadas 158

4 La escena digital y la cadena de custodia **161**

4.1 Identificación y aseguramiento de la escena 162
4.2 Inventario y documentación de dispositivos 167
4.3 Intervención sobre equipos encendidos y apagados 173
4.4 Orden de volatilidad y conservación de evidencias 183
4.5 Cadena de custodia, embalaje y almacenamiento 191
4.6 Caso integrador: aseguramiento de una escena híbrida tras una extracción de documentos 200
4.7 Conclusión 205
4.8 Referencias técnicas y lecturas recomendadas 206

5 Adquisición de evidencias y verificación de integridad **209**
5.1 Adquisición física, lógica y remota . . . 210
5.2 Bloqueadores de escritura . . . 217
5.3 Imágenes forenses y sus formatos . . . 222
5.4 Hashes y comprobación de integridad . . . 229
5.5 Particularidades de HDD, SSD, cifrado y sistemas dañados . . . 235
5.6 Documentación del procedimiento de adquisición . . . 245
5.7 Caso integrador: reconstrucción de una adquisición compleja . . . 253
5.8 Conclusiones . . . 256
5.9 Referencias y lecturas recomendadas . . . 257

6 Preparación del laboratorio forense **259**
6.1 Equipamiento físico y virtual . . . 260
6.2 Estaciones de trabajo y almacenamiento de evidencias . . . 267
6.3 Herramientas forenses libres y comerciales . . . 275
6.4 Validación de herramientas . . . 282
6.5 Automatización, trazabilidad y reproducción de análisis . . . 291
6.6 Preparación de escenarios prácticos . . . 299
6.7 El laboratorio como sistema de confianza verificable . . . 310
6.8 Referencias y lecturas recomendadas . . . 310

7 Discos, particiones y sistemas de archivos **313**
7.1 Introducción . . . 313
7.2 Estructura de los soportes de almacenamiento . . . 314
7.3 Particiones MBR y GPT . . . 321
7.4 Sistemas de archivos: FAT, exFAT, NTFS, ext4 y APFS . . . 328
7.5 Metadatos y marcas temporales . . . 341
7.6 Análisis de archivos eliminados y espacio no asignado . . . 348
7.7 Recuperación y limitaciones de los resultados . . . 356
7.8 Conclusiones . . . 364
7.9 Referencias técnicas y lecturas recomendadas . . . 365

8 Análisis forense de Windows **367**
8.1 Introducción . . . 367
8.2 1. Principales fuentes de evidencia . . . 368
8.3 2. Registro de Windows y perfiles de usuario . . . 374
8.4 3. Registros de eventos y mecanismos de persistencia . . . 381
8.5 4. Artefactos de ejecución: Prefetch, Amcache, Shimcache y otros . . . 391
8.6 5. Actividad del usuario, archivos y dispositivos USB . . . 400
8.7 6. Investigación práctica de un equipo Windows . . . 407

8.8 Conclusiones 420
8.9 Referencias técnicas y lecturas recomendadas 421

9 Análisis forense de Linux **423**
9.1 Introducción 423
9.2 1. Estructura y fuentes de información 425
9.3 2. Logs del sistema y autenticación 431
9.4 3. Usuarios, permisos, sesiones SSH y privilegios 440
9.5 4. Historial de comandos y actividad de procesos 448
9.6 5. Servicios, tareas programadas y persistencia 455
9.7 6. Investigación práctica de un servidor Linux 464
9.8 Conclusiones 477
9.9 Referencias técnicas y lecturas recomendadas 478

10 Bibliografía **481**
10.1 Referencias técnicas 481

“PARTE I. FUNDAMENTOS, METODOLOGÍA Y ADQUISICIÓN DE EVIDENCIAS”

Análisis Forense Informático

JG Gutierrez

1. Introducción al análisis forense digital

> "No señor, la verdad científica está más allá de la lealtad o de la deslealtad."
>
> ("No Sir, scientific truth is beyond loyalty and disloyalty.")
>
> — Isaac Asimov, Fundación (Hari Seldon ante la Comisión de Seguridad Imperial).
>
> Fundación (1951). Parte I: Los Psicohistoriadores

Una investigación informática suele comenzar con una anomalía aparentemente sencilla: un documento que desaparece, un acceso realizado fuera del horario habitual, una transferencia de archivos que nadie reconoce o un mensaje de correo que parece proceder de una persona conocida. Lo que a primera vista es un problema técnico puede terminar convirtiéndose en un incidente de seguridad, un conflicto laboral, una reclamación contractual o una investigación judicial. En todos esos escenarios surge una pregunta común: **¿qué ocurrió realmente y qué datos permiten sostener una explicación verificable?**

Los sistemas informáticos registran una parte considerable de su actividad. Almacenan archivos, metadatos, historiales, identificadores, registros de autenticación, comunicaciones y numerosas estructuras internas que no suelen resultar visibles para el usuario. Esas huellas pueden ayudar a reconstruir acontecimientos pasados, pero no hablan por sí solas. Hay que encontrarlas, preservarlas, comprender cómo se originaron y determinar qué interpretaciones admiten. También hay que reconocer lo que no permiten afirmar.

El análisis forense digital aborda ese problema mediante procedimientos técnicos controlados y documentados. Su propósito no consiste en obtener la mayor cantidad posible de información ni en encontrar a toda costa un culpable, sino en examinar evidencias digitales y producir conclusiones cuya base pueda ser revisada por otras personas competentes. Una investigación rigurosa exige tanto conocimientos tecnológicos como disciplina metodológica, sentido crítico y respeto por los límites jurídicos y profesionales de la actuación.

Este primer capítulo establece el marco conceptual del libro. Presenta la disciplina, sus objetivos y sus principales aplicaciones; distingue los requisitos propios de las investigaciones judiciales, corporativas y de respuesta a incidentes; analiza las propiedades y las limitaciones de la evidencia digital; y describe las fuentes de información y las responsabilidades de quienes participan en una investigación. Las técnicas concretas de adquisición y análisis se desarrollarán en los capítulos posteriores. Aquí interesa comprender **por qué** se aplican, **qué problema resuelven** y **cuándo** sus resultados merecen confianza.

> Una conclusión forense debe ser tan firme como lo permita la evidencia, pero nunca más firme que ella.

1.1. Concepto, objetivos y aplicaciones de la informática forense

1.1.1. De resolver averías a investigar hechos

La administración de sistemas y el análisis forense comparten herramientas y conocimientos, pero no persiguen exactamente el mismo fin. Cuando un servidor deja de prestar servicio, el administrador procura identificar la causa, recuperar la operatividad y reducir el tiempo de interrupción. Si sospecha que el fallo se debe a una intrusión, tal vez deba investigar además qué usuario inició sesión, qué procesos se ejecutaron, qué archivos cambiaron y si existió una extracción de información.

La primera tarea se orienta al restablecimiento del servicio; la segunda, a la reconstrucción de acontecimientos. Esta diferencia altera las decisiones prácticas. Reiniciar una máquina puede resolver una avería y, al mismo tiempo, hacer desaparecer conexiones activas, procesos maliciosos residentes en memoria y claves de cifrado que solo estaban disponibles durante la ejecución. Actualizar un sistema comprometido puede cerrar una vulnerabilidad, pero también modificar cientos de archivos, registros y marcas de tiempo. La medida más conveniente desde la perspectiva operativa no siempre es la más conveniente desde la perspectiva probatoria.

En una situación real, ambas necesidades pueden coexistir. El responsable de seguridad quiere detener un ataque antes de que afecte a más equipos; el investigador necesita conservar información suficiente para comprenderlo. La solución no es elegir de manera automática una prioridad absoluta, sino tomar decisiones conscientes, proporcionadas y documentadas. Cuando la continuidad del negocio o la seguridad de las personas exige intervenir de inmediato, se interviene; cuando existe margen para preservar primero los datos más frágiles, se aprovecha ese margen. En ambos casos se registra lo sucedido.

El análisis forense digital —también denominado informática forense o *digital forensics*— puede definirse como el conjunto de métodos técnicos y científicos utilizados para identificar, obtener, preservar, examinar, analizar e interpretar información digital potencialmente relevante para una investigación, con el fin de comunicar resultados verificables. El término *forense* alude a su relación histórica con la presentación y evaluación de pruebas ante órganos judiciales, pero su aplicación actual va mucho más allá de los tribunales.

Es importante distinguir el **objeto de la investigación** de sus **herramientas**. Analizar una imagen de disco con una aplicación especializada no convierte por sí solo una actuación en

una investigación forense. Si se desconoce la procedencia de la imagen, no se documentaron las operaciones y los resultados se interpretan sin contrastarlos, se habrá realizado un análisis técnico de utilidad limitada. Por el contrario, una investigación basada en registros de autenticación correctamente conservados y correlacionados puede ofrecer conclusiones sólidas aunque emplee herramientas relativamente sencillas.

La informática forense no se define por una marca comercial, por el empleo de programas costosos o por el tamaño del laboratorio. Se define, ante todo, por el método y por la calidad de las inferencias que permite formular.

1.1.2. Una disciplina técnica con exigencias científicas

Una investigación forense aspira a describir hechos observables y a evaluar explicaciones alternativas. Para hacerlo necesita conocimientos de sistemas operativos, estructuras de almacenamiento, redes, aplicaciones, seguridad, programación y arquitectura de servicios. También requiere comprender cómo se crean los artefactos que se examinan y qué operaciones pueden alterarlos.

No basta, por ejemplo, con saber que Windows almacena información sobre programas ejecutados. Es necesario distinguir los artefactos que reflejan una instalación, una referencia al programa, su carga o una ejecución efectiva, y conocer qué versiones del sistema generan cada rastro. Tampoco basta con encontrar una dirección IP en un registro: hay que determinar si representa el origen de una conexión, un intermediario, una asignación temporal o un valor incorporado por una aplicación. La interpretación depende siempre del mecanismo técnico que produjo el dato.

Este enfoque exige formular preguntas susceptibles de comprobación. Ante una sospecha de extracción de información, una pregunta útil sería: «¿Se observan operaciones de lectura, empaquetado o transferencia de los documentos investigados durante el intervalo indicado?». Es bastante menos útil comenzar con una afirmación como «el empleado robó los documentos» e intentar seleccionar después los indicios que parezcan confirmarla.

El proceso debe dejar abierta la posibilidad de refutar la hipótesis inicial. Si una cuenta de usuario aparece vinculada con una acción, habrá que valorar la autenticación utilizada, la posibilidad de sesiones compartidas, la automatización, el acceso remoto o el compromiso de credenciales. El investigador no debe confundir la explicación más cómoda con la única explicación plausible.

La serie de normas ISO/IEC 27037, 27041 y 27042 constituye una referencia para comprender este enfoque: la primera se ocupa de la identificación, recogida, adquisición y preservación de evidencia digital; la segunda trata la adecuación de los métodos de investigación; y la

tercera se centra en el análisis y la interpretación, con atención a la continuidad, validez y posibilidad de revisión de los resultados [1]–[3]. Estas normas no sustituyen a la legislación aplicable ni garantizan automáticamente que una prueba sea admitida en un procedimiento concreto, pero proporcionan un marco de buenas prácticas.

FIGURA 1.1. Esquema conceptual de una investigación digital

Figura 2: El proceso de la Inverstigación Digital

1.1.3. Los objetivos de una investigación forense

La investigación forense no tiene un único objetivo universal. Este depende del encargo, de la naturaleza del incidente y de la autoridad que lo promueve. Sin embargo, es posible reconocer varias finalidades recurrentes.

Establecer qué sucedió. Es el objetivo central. El investigador trata de describir una secuencia de acontecimientos apoyada en datos observables: accesos, modificaciones, ejecuciones, comunicaciones o cambios de configuración. No todas las preguntas tendrán respuesta, pero las que se respondan deben vincularse a evidencias identificables.

Determinar cuándo ocurrió. La cronología permite distinguir actividades legítimas de acciones potencialmente relacionadas con un hecho investigado. Puede ser necesario resolver diferencias entre zonas horarias, relojes desajustados, marcas de tiempo procedentes de sistemas distintos y periodos en los que no se conservaron registros.

Identificar los recursos afectados. Un incidente puede comenzar en una estación de trabajo y extenderse a un servidor, una cuenta de identidad, un servicio en la nube y un dispositivo personal. Delimitar los activos involucrados ayuda a comprender el alcance del hecho y a evitar conclusiones basadas en una observación aislada.

Explicar cómo pudo producirse. En algunos casos habrá que investigar una vulnerabilidad explotada, una credencial comprometida, un abuso de privilegios o un error operativo. La relación entre mecanismo y resultado debe comprobarse; una vulnerabilidad presente en un sistema no demuestra por sí misma que haya sido utilizada.

Evaluar las consecuencias. Puede ser necesario establecer qué archivos se modificaron, qué información resultó accesible, qué sistemas quedaron afectados y cuáles son las limitaciones para cuantificar el daño. En una fuga de datos, «el atacante pudo acceder» y «el atacante descargó» expresan afirmaciones distintas y exigen diferentes apoyos probatorios.

Conservar información para futuras actuaciones. La investigación puede servir a un proceso judicial, una reclamación, una auditoría, una investigación interna o una revisión técnica posterior. La capacidad de explicar de dónde proceden los datos y cómo se trataron condiciona su utilidad futura.

Orientar decisiones. Las conclusiones pueden apoyar medidas de contención, recuperación, mejora de controles, comunicación a personas afectadas o presentación de una denuncia. El analista aporta elementos técnicos; la decisión jurídica, disciplinaria o empresarial corresponde a quien tenga competencia para adoptarla.

Una investigación bien delimitada no pretende responder todas las preguntas imaginables. Define cuáles son pertinentes, qué recursos están disponibles y qué grado de certeza es razonable alcanzar. Ampliar indiscriminadamente el alcance incrementa el coste, la exposición de información personal y el riesgo de introducir datos irrelevantes.

1.1.4. Del dato al conocimiento: observación, hallazgo e inferencia

Uno de los errores más frecuentes en los informes técnicos consiste en presentar una interpretación como si fuera una observación directa. Conviene separar tres niveles.

El **dato observado** es el contenido verificable de una fuente: una entrada de registro, un archivo, una marca temporal o una conexión capturada. El **hallazgo** relaciona ese dato con

un hecho técnicamente significativo: una cuenta autenticó correctamente, un archivo fue escrito en un volumen o una aplicación estableció una conexión con determinado destino. La **inferencia** propone una explicación más amplia: la cuenta pudo utilizarse para acceder sin autorización o la conexión pudo formar parte de una transferencia de información.

Consideremos un servidor que registra un inicio de sesión correcto a las 02:17 desde una dirección externa. El dato observado es el registro correspondiente. El hallazgo puede ser que se produjo una autenticación satisfactoria de la cuenta indicada desde la dirección registrada, siempre que se haya comprendido correctamente el formato del log y la configuración del servicio. La conclusión «el titular de la cuenta accedió desde su domicilio» no se desprende automáticamente de ello. Sería necesario verificar a quién estaba asignada la dirección IP en ese momento, si existía una VPN, si las credenciales pudieron verse comprometidas y si otras evidencias confirman la identidad de la persona.

En el trabajo forense, **cuenta, equipo, sesión y persona no son sinónimos**. Un nombre de usuario identifica habitualmente un principal lógico dentro de un sistema, no necesariamente a quien estaba físicamente utilizando el teclado. Incluso una autenticación multifactor satisfactoria reduce determinadas incertidumbres, pero no elimina todas las posibilidades de acceso delegado, secuestro de sesión, ingeniería social o compromiso del dispositivo.

Este principio debe acompañar al analista desde la primera inspección hasta la redacción final. Cuanto mayor sea la distancia entre la observación y la afirmación, más corroboración necesita la conclusión.

1.1.5. Reproducibilidad, repetibilidad y trazabilidad

La solidez de una investigación no depende únicamente de que sus conclusiones parezcan razonables. Otro profesional debe poder examinar las evidencias y evaluar cómo se obtuvo cada resultado. Para ello son esenciales la documentación y el control de los procedimientos.

La **repetibilidad** se refiere, en términos generales, a la capacidad de obtener resultados consistentes al repetir una operación bajo condiciones equivalentes. La **reproducibilidad** se relaciona con la obtención de resultados concordantes cuando intervienen condiciones o examinadores diferentes, dentro de los límites establecidos por el método utilizado. Estas nociones requieren matices según el procedimiento, pero ambas recuerdan que un resultado forense no debería depender de operaciones inexplicables o de decisiones que únicamente conoce su autor.

La **trazabilidad** permite seguir el recorrido de un dato desde su origen hasta su incorporación a un informe. Es necesario identificar la evidencia, la operación realizada, la herramienta y su versión cuando sea relevante, los parámetros empleados, los resultados intermedios y las decisiones adoptadas. Si una herramienta genera un listado de archivos borrados, el informe debe permitir localizar el origen de ese listado y conocer los criterios utilizados para clasificar los archivos como eliminados.

No siempre es posible repetir literalmente una adquisición. Un servidor en producción cambia de estado de forma constante y una captura de memoria recoge una situación irrepetible en sentido estricto. Precisamente por eso cobran importancia la documentación de la adquisición, la integridad del material obtenido y la capacidad de reproducir el análisis sobre esa captura. Se distingue así entre volver a observar el mismo sistema vivo —que quizá ya no existe en el mismo estado— y repetir un examen sobre los datos que se conservaron.

También hay que reconocer que las herramientas pueden cometer errores. Un resultado coherente con la hipótesis del investigador no constituye una validación del software. Siempre que el hallazgo sea importante, conviene contrastar métodos, revisar los datos subyacentes y entender las limitaciones de la herramienta. La confianza no nace de un botón que muestre «análisis completado», sino de la concordancia entre evidencias, método y explicación técnica.

1.1.6. Diferencias entre informática forense, ciberseguridad y análisis de malware

La ciberseguridad reúne medidas para prevenir, detectar y responder frente a amenazas que afectan a sistemas e información. El análisis forense digital tiene una finalidad más específica: reconstruir hechos a partir de evidencias. Ambas disciplinas se solapan ampliamente, pero sus objetivos inmediatos pueden diferir.

Un equipo de monitorización puede detectar cientos de conexiones sospechosas y bloquearlas automáticamente. La investigación forense intentará establecer cuáles se produjeron realmente, qué sistemas participaron, qué procesos las originaron y qué significado tienen en el contexto del incidente. Las alertas de un sistema de detección constituyen pistas valiosas, aunque no sustituyen la comprobación de los eventos subyacentes.

El análisis de malware estudia el comportamiento, la estructura y las capacidades de programas potencialmente maliciosos. Puede formar parte de una investigación forense, pero identificar una familia de código dañino no basta para reconstruir un incidente concreto. Se necesita relacionar la muestra con su presencia o ejecución en los equipos investigados, las comunicaciones observadas y los efectos registrados.

La auditoría de seguridad busca habitualmente valorar controles, configuraciones o cumplimiento respecto de un criterio establecido. Una auditoría puede encontrar que un sistema permite autenticaciones sin segundo factor; una investigación forense necesita establecer si se produjo un acceso concreto y qué evidencia existe. La primera puede demostrar exposición al riesgo; la segunda trata de esclarecer acontecimientos.

Tampoco debe confundirse el análisis forense con una prueba de penetración. La prueba de penetración simula o ejecuta acciones autorizadas para evaluar la seguridad de un entorno. Una investigación forense examina rastros de hechos pasados. En ocasiones los resultados de una prueba de penetración ayudan a entender la plausibilidad técnica de una hipótesis, pero **demostrar que un ataque sería posible no equivale a demostrar que ocurrió**.

1.1.7. Aplicaciones más allá de la ciberdelincuencia

La informática forense adquirió notoriedad por su empleo en investigaciones relacionadas con intrusiones, fraudes y delitos cometidos mediante sistemas informáticos. Sin embargo, su campo de aplicación es mucho más amplio.

En una controversia empresarial puede servir para analizar modificaciones de documentos, accesos a repositorios o transferencias realizadas antes de la salida de un trabajador. En una investigación de fraude interno ayuda a correlacionar operaciones de una aplicación de negocio con autenticaciones, aprobaciones y comunicaciones. En una reclamación contractual puede esclarecer cuándo se recibió un archivo, qué versión se utilizó o si un cambio de configuración precedió a una interrupción de servicio.

En el ámbito de la propiedad intelectual, una investigación puede examinar la creación, copia, modificación y circulación de determinados materiales, siempre dentro de las autorizaciones legales aplicables. En un entorno industrial, puede reconstruirse una modificación no prevista de parámetros o la secuencia de acceso a un dispositivo de supervisión. En un servicio en la nube, pueden estudiarse cambios de permisos, accesos mediante API y operaciones sobre almacenamiento remoto. Los teléfonos móviles, sistemas domésticos conectados y vehículos incorporan además fuentes de datos que pueden resultar relevantes en investigaciones de otra naturaleza.

El denominador común no es la existencia de un delito. Es la necesidad de responder a preguntas sobre hechos digitales mediante un procedimiento verificable. La dimensión técnica debe adecuarse siempre al objeto de la investigación: no sería proporcionado extraer todo el contenido de un teléfono personal para comprobar un único evento empresarial si existen alternativas menos intrusivas y suficientes.

1.1.8. Un primer caso: el documento que desapareció

Imaginemos una empresa de ingeniería que descubre la desaparición de varios planos de un repositorio compartido. Un responsable sostiene que un exempleado los eliminó antes de abandonar la organización. La sospecha se basa en dos observaciones: el empleado tuvo acceso a la carpeta durante su última semana y los archivos dejaron de aparecer poco después.

La conclusión parece intuitiva, pero la información inicial admite diversas explicaciones. Tal vez existió una eliminación deliberada. También es posible que una sincronización defectuosa desplazara los archivos, que otro usuario los reorganizara, que cambiase la política de permisos o que el repositorio mostrara una vista incompleta por un error de indexación. La ausencia de los documentos en la interfaz no prueba, por sí sola, su eliminación física ni identifica al responsable.

Una investigación razonable comenzaría delimitando el hecho: qué documentos faltan, cuándo se comprobó por última vez su presencia, qué sistema los almacenaba y qué registros conserva. Se examinarían, conforme al alcance autorizado, los eventos del repositorio, el historial de versiones, las operaciones de borrado o movimiento, los permisos efectivos y las cuentas que intervinieron. Podría ser útil correlacionar los registros con la configuración de sincronización y las actividades de otros usuarios.

Supongamos que los datos revelan una operación de traslado ejecutada mediante una cuenta de servicio durante una tarea programada. El resultado desmentiría la hipótesis inicial sin necesidad de encontrar un culpable alternativo. Esa es precisamente una de las virtudes de la disciplina: una investigación forense debe estar preparada para demostrar que la sospecha que la originó no estaba justificada.

En otro escenario, los registros podrían indicar un borrado realizado por la cuenta del exempleado. Aun así, habría que estudiar el origen de la operación, la configuración de autenticación, posibles herramientas automatizadas y la correspondencia entre la actividad lógica y la persona investigada. La calidad del trabajo estaría determinada tanto por lo que pudiera afirmarse como por la claridad con la que se describiesen las incertidumbres restantes.

Figura 3: Árbol de hipótesis del caso del repositorio

1.1.9. El ciclo de una investigación: visión de conjunto

Aunque existen diversos modelos metodológicos, una investigación suele desarrollarse mediante actividades reconocibles. Primero se define el encargo, la autoridad de actuación y el problema. Después se identifican las posibles fuentes y se toman medidas para que los datos relevantes no desaparezcan. A continuación se realiza la adquisición adecuada, se examinan las evidencias, se correlacionan los hallazgos y se formulan conclusiones. Finalmente, se documentan los resultados, se custodia el material y se comunica lo que pueda sostenerse técnicamente.

Este recorrido no siempre es lineal. Un registro encontrado durante el examen puede revelar la existencia de un servidor que no figuraba en el inventario inicial, o una marca temporal inesperada puede obligar a revisar la sincronización de relojes. El investigador necesita capacidad para volver sobre sus decisiones, ampliar justificadamente las comprobaciones y conservar el historial de cambios del alcance. Una investigación iterativa no debe convertirse, sin embargo, en una sucesión improvisada de búsquedas sin dirección.

NIST SP 800-86 ofrece una guía clásica para integrar técnicas forenses en la respuesta a incidentes y explica el tratamiento de fuentes como archivos, sistemas operativos, tráfico de red y aplicaciones [4]. Aunque fue publicada en 2006 y algunas tecnologías han evolucionado notablemente, mantiene valor como referencia metodológica; las técnicas concretas deben complementarse con documentación actualizada de cada plataforma. En capítulos posteriores se estudiarán estas fases con mayor precisión, junto con las decisiones necesarias para preservar las evidencias.

Una buena investigación comienza mucho antes de abrir una herramienta. Comienza cuando se determina con claridad qué pregunta merece respuesta, qué datos podrían contestarla y qué debe hacerse para no destruirlos durante el intento.

1.2. Investigación judicial, corporativa y respuesta a incidentes

La naturaleza de una investigación condiciona su alcance, sus prioridades y la forma de comunicar los resultados. No es lo mismo elaborar un dictamen para un procedimiento judicial, analizar un posible incumplimiento interno o investigar un ataque que continúa afectando a los sistemas de una organización. En los tres casos pueden aparecer exactamente los mismos artefactos —registros de autenticación, archivos, mensajes o conexiones—, pero las preguntas que se formulan y las decisiones permitidas son distintas.

1.2.1. El contexto determina el método operativo

El carácter forense de una actuación exige integridad, trazabilidad y rigor, con independencia del contexto. Sin embargo, la obtención de información necesita una base de autorización y debe ajustarse a la finalidad concreta. Un procedimiento judicial puede desarrollarse bajo una resolución que delimite los dispositivos, datos u operaciones que pueden examinarse. Una investigación corporativa dependerá de la relación entre la organización y los sistemas, de sus políticas legítimas, de las obligaciones de privacidad y de las autorizaciones aplicables. En una respuesta urgente a incidentes, el equipo puede tener que decidir qué datos conservar mientras detiene la propagación de un ataque.

También cambia el destinatario del resultado. El órgano judicial necesita comprender qué hechos técnicos se encuentran acreditados y cuáles son los límites de la interpretación. La dirección de una empresa puede necesitar decisiones operativas, identificación de riesgos y un relato comprensible. El responsable de respuesta a incidentes busca además indicadores y datos útiles para contener, erradicar y recuperar sistemas. Un mismo análisis puede alimentar varios informes, pero cada comunicación debe adaptarse al propósito sin alterar los hechos.

La procedencia de la evidencia tampoco es equivalente. En una investigación judicial puede intervenir una autoridad que recoge o autoriza la recogida de dispositivos. En una investigación interna, la información puede provenir de repositorios administrados por la organización o de plataformas contratadas a terceros. Durante una respuesta a incidentes, parte del material puede ser especialmente volátil: memoria de procesos, conexiones abiertas, contenedores efímeros o registros que se sobrescribirán en minutos.

Estas diferencias no justifican relajar el método, sino diseñarlo en función del riesgo. Un informe excelente puede resultar inútil si la adquisición careció de autorización; una prueba correctamente obtenida puede perder valor si se interpreta sin comprender su origen; y una intervención legalmente legítima puede ser técnicamente deficiente si se destruye información decisiva sin necesidad.

1.2.2. La investigación judicial y la prueba pericial

En una investigación judicial, los datos digitales pueden contribuir a acreditar o descartar hechos relevantes para un procedimiento. El examen puede recaer sobre equipos, soportes, servicios, comunicaciones o ficheros obtenidos de acuerdo con las facultades legales y resoluciones aplicables. El trabajo técnico puede ser realizado por unidades especializadas, laboratorios, peritos designados o profesionales que actúan a instancia de alguna de las partes, según el procedimiento y la jurisdicción.

El informe pericial no decide por sí mismo la responsabilidad jurídica de una persona. Su función es aportar conocimientos especializados para que los hechos técnicos puedan ser entendidos y valorados. Por eso debe distinguir entre observaciones, operaciones practicadas, resultados y opiniones justificadas. La autoridad judicial valora el conjunto de las pruebas y resuelve las cuestiones de su competencia; el perito explica los aspectos técnicos que conoce y evita ocupar el lugar de quien debe decidir.

En España, un ejemplo relevante de la necesidad de contar con autorización específica aparece en los artículos 588 sexies a y siguientes de la Ley de Enjuiciamiento Criminal. En particular, la regulación establece que la mera incautación de determinados dispositivos durante un registro domiciliario no legitima por sí sola el acceso a su contenido, sin perjuicio de la autorización judicial correspondiente [5]. Este principio ilustra por qué **poseer físicamente un dispositivo no equivale a estar habilitado para examinar toda su información**. Las condiciones de acceso deben evaluarse en cada caso, conforme al procedimiento y a la normativa vigente.

El alcance del examen importa tanto como su autorización. Una resolución orientada a investigar un determinado hecho no debe interpretarse como permiso ilimitado para revisar

información ajena al objeto autorizado. Pueden existir datos íntimos, secretos profesionales, comunicaciones protegidas o información de terceras personas. La metodología debe incorporar medidas de delimitación y tratamiento que sean compatibles con los derechos afectados.

Una característica central de la prueba pericial es su exposición al contraste. El informe puede ser revisado por otros especialistas; el perito puede ser interrogado sobre la procedencia de los datos, los procedimientos seguidos, las alternativas descartadas y los límites de las herramientas. La documentación técnica debe permitir esa revisión. No es suficiente afirmar que un programa detectó una conducta: habrá que explicar qué elemento concreto produjo el resultado y por qué se interpreta de determinada forma.

La cadena de custodia ocupa aquí un lugar importante. Su función es documentar quién tuvo la evidencia bajo su control, qué transferencias se realizaron, cómo se conservó y qué operaciones afectaron a los elementos custodiados. No demuestra automáticamente la veracidad de todo el contenido almacenado, pero ayuda a acreditar la continuidad del tratamiento del material. Los valores hash, los registros de acceso, las firmas y los inventarios pueden reforzar esa documentación; ninguno sustituye individualmente a la reconstrucción completa del recorrido de la evidencia.

1.2.3. Qué puede y qué no puede declarar un perito

Supongamos que en el equipo investigado aparece un archivo que contiene datos confidenciales. El perito puede describir su ruta, contenido, tamaño, sistema de archivos, marcas temporales y otros atributos que haya verificado. Puede explicar que existen rastros compatibles con la apertura o copia del archivo, cuando los mecanismos técnicos estudiados permitan sostener esa interpretación. También puede indicar si se localizan registros de conexión con un servicio externo durante el periodo relevante.

Lo que no debería afirmar sin evidencia adicional es que el propietario del equipo actuó personalmente, que su intención era divulgar el documento o que se consumó un delito determinado. La presencia de un archivo no revela por sí sola cómo llegó allí. Una conexión de red no identifica necesariamente el contenido transmitido. Una marca de último acceso puede cambiar por procesos automáticos o por determinadas operaciones del sistema. Y una cuenta autenticada no siempre identifica a una persona física sin ambigüedad.

La valoración pericial debe emplear un lenguaje proporcional: «se ha observado», «los registros muestran», «los datos son compatibles con», «no se ha podido determinar» o «la información disponible no permite concluir». Estas expresiones no debilitan el informe; lo hacen

más exacto. Decir «no se puede determinar» cuando no existen datos suficientes es una conclusión técnicamente válida.

Tampoco deben ocultarse resultados contrarios a la hipótesis inicial. Un informe pericial que selecciona únicamente los indicios acusatorios, ignora las explicaciones alternativas o presenta como certeza una posibilidad técnica ofrece una representación distorsionada. La imparcialidad no consiste en carecer de preguntas, sino en aplicar a todas las hipótesis un criterio de evaluación consistente.

1.2.4. Investigación corporativa: intereses legítimos y límites

Las organizaciones generan y conservan abundante información sobre sus actividades: autenticaciones, accesos a documentos, transacciones, registros de seguridad, copias de respaldo y actividad de aplicaciones. Estos datos pueden ser relevantes para investigar fraudes, incumplimientos, filtraciones, conflictos contractuales, sabotajes o incidentes de origen interno. Pero la existencia de una infraestructura corporativa no convierte toda la información que circula por ella en material disponible para cualquier examen.

Una investigación interna debe comenzar por identificar quién encarga el análisis, qué competencia tiene para hacerlo, qué sistemas y periodos quedan comprendidos y qué normas resultan aplicables. En la Unión Europea, el Reglamento General de Protección de Datos exige considerar, entre otros principios, la licitud del tratamiento, la limitación de finalidad, la minimización de datos y la integridad y confidencialidad. En España debe atenderse además a la Ley Orgánica 3/2018 y a las disposiciones específicas que correspondan [6], [7]. Las bases jurídicas y las garantías concretas no pueden presumirse a partir de un simple interés empresarial.

Esta cautela es especialmente importante cuando intervienen dispositivos personales utilizados profesionalmente, cuentas mixtas, servicios de mensajería, datos de clientes o comunicaciones de trabajadores. La evaluación puede requerir la intervención de asesoría jurídica, delegación de protección de datos, recursos humanos o responsables autorizados. El analista no debería improvisar decisiones jurídicas durante el examen ni asumir que una solicitud verbal basta para acceder a cualquier contenido.

El criterio de proporcionalidad puede traducirse en medidas prácticas: acotar intervalos temporales, comenzar por registros corporativos menos intrusivos, usar filtros relacionados con el hecho investigado, limitar quién examina contenido sensible y separar la información pertinente de la que no lo es. Es aconsejable conservar constancia de los criterios de selección, porque una búsqueda demasiado amplia también puede generar problemas posteriores de interpretación.

Una investigación corporativa presenta, además, un riesgo particular: la organización que encarga el trabajo puede tener una hipótesis preferida o un resultado que considera conveniente. La independencia técnica del analista exige resistir esa presión. Si los datos no respaldan la acusación, el informe debe decirlo; si la atribución individual no es posible, no debe maquillarse como certeza. La obligación profesional es investigar los hechos definidos, no confirmar la versión del solicitante.

1.2.5. Ejemplo: investigación de una supuesta fuga de información

Una empresa detecta que una cuenta corporativa descargó una cantidad inusual de documentación durante las dos semanas anteriores a la finalización de un contrato laboral. El sistema de prevención de pérdida de datos genera una alerta y la dirección solicita determinar si se produjo una apropiación de información confidencial.

La hipótesis inicial es plausible, pero la alerta necesita contextualización. Algunas aplicaciones descargan archivos para mantener copias locales, las herramientas de indexación realizan lecturas masivas y los clientes de sincronización pueden recuperar conjuntos completos de documentos tras un cambio de equipo. Incluso si la descarga fue iniciada manualmente, todavía faltaría determinar su finalidad y el destino posterior.

El investigador comienza definiendo los elementos relevantes: identidad de la cuenta, repositorios afectados, periodos de actividad, dispositivos administrados por la organización y mecanismos de acceso. Los registros podrían revelar que se descargaron 4,2 GB de un directorio concreto. Esa medida, por sí sola, no establece cuántos documentos distintos se copiaron, porque el volumen incluye transferencias repetidas y otros posibles elementos. El análisis puede comparar identificadores de objetos, nombres, versiones, horas y destinos, cuando esas dimensiones estén registradas.

Imaginemos que el sistema muestra descargas desde un equipo corporativo, una copia posterior a un soporte USB y la presencia de archivos coincidentes en dicho soporte. Si el examen del soporte está autorizado y los datos se preservaron correctamente, la combinación de evidencias fortalece la hipótesis de una transferencia. Pero todavía sería necesario distinguir la acción observada de la finalidad atribuida, valorar si había una tarea profesional legítima y comprobar quién utilizaba la sesión durante el intervalo.

Otra posibilidad es que la alerta procediese de la instalación de un nuevo cliente de sincronización, con una descarga automática respaldada por un cambio de configuración documentado. Un análisis realizado con criterios rigurosos permitiría descartar una sospecha inicialmente razonable. En ambos escenarios, el resultado sirve a la organización: en el primero,

orienta las decisiones oportunas; en el segundo, evita adoptar medidas injustificadas basadas en una interpretación precipitada.

1.2.6. La respuesta a incidentes y la necesidad de actuar

Cuando una organización sufre un ciberataque, la investigación debe desarrollarse en un entorno que puede seguir cambiando. Un adversario podría mantener acceso a sistemas, expandirse a otros equipos, cifrar archivos o preparar una extracción de datos. En esas condiciones, la preservación de evidencias compite con la urgencia de proteger los servicios y la información.

La respuesta a incidentes engloba actividades de preparación, detección, análisis, contención, erradicación, recuperación y aprendizaje, integradas en la gestión del riesgo de ciberseguridad. El enfoque actual de NIST SP 800-61 Rev. 3, publicado en 2025, conecta la respuesta con las funciones del Cybersecurity Framework 2.0 y supera la visión de un proceso exclusivamente reactivo [8]. La informática forense aporta una capacidad transversal: permite reconstruir hechos, identificar el alcance y fundamentar decisiones durante distintas etapas.

En las primeras horas de un incidente, el analista forense puede ayudar a responder preguntas operativas muy concretas. ¿Desde qué equipo comenzó la actividad? ¿Qué cuenta fue utilizada? ¿Qué mecanismo permitió el acceso inicial? ¿Existen evidencias de persistencia? ¿Qué otros recursos muestran actividad semejante? ¿Se observan señales de transferencia de información? ¿Qué datos desaparecerán si se reinician los sistemas?

No todas estas preguntas pueden contestarse de inmediato. La respuesta temprana suele apoyarse en información incompleta, por lo que resulta necesario distinguir entre **indicadores para actuar** y **conclusiones suficientemente contrastadas para informar de los hechos**. Un proceso sospechoso puede justificar aislar un equipo sin que todavía se haya determinado su finalidad exacta. Una dirección IP observada en varios sistemas puede orientar búsquedas adicionales sin demostrar que todos los accesos fueron maliciosos.

Esta distinción evita dos extremos igualmente problemáticos. El primero consiste en paralizar la contención hasta obtener un grado de certeza que tardará días en alcanzarse. El segundo consiste en destruir las fuentes de información sin necesidad y pretender después reconstruir los hechos únicamente a partir de alertas resumidas. Una respuesta madura articula mecanismos para preservar datos críticos mientras se ejecutan medidas de protección.

1.2.7. La tensión entre preservación y contención

Consideremos un servidor que mantiene una conexión de salida sospechosa mientras procesa operaciones críticas para el negocio. Desconectarlo inmediatamente podría detener una posible fuga, pero también interrumpir un servicio esencial y eliminar visibilidad sobre procesos y conexiones. Mantenerlo sin intervenir puede permitir que el ataque continúe. La decisión exige valorar el daño potencial, las alternativas de aislamiento, la disponibilidad de otros registros y la volatilidad de los datos.

En algunos contextos será posible capturar primero información volátil y después aislar la máquina. En otros, el riesgo exigirá bloquear el tráfico sin esperar. También puede recurrirse a controles de red externos al sistema afectado para restringir comunicaciones y preservar parte de su estado. Ninguna estrategia es universal: la presencia de cifrado, mecanismos destructivos, servicios críticos o sistemas controlados por un adversario puede alterar las prioridades.

Debe recordarse que toda interacción con un sistema vivo deja huellas. Ejecutar herramientas de adquisición consume memoria, genera procesos, modifica contadores y puede alterar archivos temporales. Esa modificación no invalida automáticamente la evidencia, pero debe ser comprendida y documentada. La alternativa de no ejecutar ninguna herramienta puede causar una pérdida mayor de información. La práctica forense consiste en elegir procedimientos que controlen el impacto y permitan explicar sus efectos.

La antigua RFC 3227 introdujo recomendaciones influyentes sobre el orden de volatilidad de los datos y la documentación de la recogida [9]. Aunque sus ejemplos tecnológicos reflejan la época de publicación, el principio sigue siendo útil: determinados datos desaparecen mucho antes que otros. Sin embargo, el orden debe adaptarse a cada plataforma y al riesgo operativo. En un sistema moderno, obtener una memoria completa antes de una contención urgente puede no ser viable ni prudente; una metodología debe justificar la elección concreta y no limitarse a aplicar una lista de memoria.

Figura 4: Diagrama de decisión entre preservar, aislar y recuperar.

1.2.8. De la alerta a la reconstrucción del incidente

Un sistema de monitorización detecta, a modo de ejemplo, una secuencia de autenticaciones fallidas seguida de una correcta. Minutos después aparecen conexiones hacia un servidor interno y un incremento de tráfico saliente. La consola de seguridad clasifica la actividad como posible compromiso de credenciales.

La investigación forense no debería aceptar la etiqueta como conclusión definitiva. Primero necesita establecer si los eventos pertenecen al mismo usuario, al mismo origen técnico y al mismo intervalo de tiempo. Después debe comprobar si el aumento de tráfico corresponde a una tarea conocida, una transferencia excepcional o una actividad del atacante. También es necesario considerar la integridad y cobertura de los registros: quizá el dispositivo que observó el tráfico únicamente conservó estadísticas agregadas y no permite conocer el contenido transmitido.

El analista podría encontrar que el acceso procedió de una VPN corporativa, que la dirección externa era compartida por varios usuarios y que el servidor interno recibió conexiones au-

tomatizadas legítimas. Alternativamente, podría identificar una credencial utilizada desde una ubicación inusual, un comando remoto no autorizado y la creación de un mecanismo de persistencia. La diferencia no reside en la alerta inicial, sino en el trabajo de contraste.

Una vez comprendida la secuencia, la investigación puede contribuir a delimitar el alcance: buscar el mismo indicador en otros equipos, revisar accesos relacionados, valorar si hay cambios en permisos y establecer qué datos estuvieron expuestos. La preservación de las evidencias permite continuar con análisis posteriores, incluso después de haber recuperado los servicios.

1.2.9. Cuando una investigación de incidentes adquiere dimensión judicial

Un incidente corporativo puede dar lugar a una denuncia, una reclamación o una investigación de autoridades competentes. Esta posibilidad no significa que todas las incidencias deban tratarse desde el primer minuto como una actuación policial, pero sí justifica establecer procedimientos de recogida y conservación que faciliten un uso posterior de los resultados.

Es aconsejable documentar quién ordenó las acciones, cuándo se obtuvieron los datos, qué sistemas se examinaron y qué transformaciones se realizaron. En especial, debe diferenciarse la información recogida para tomar decisiones inmediatas de las copias preservadas para un examen exhaustivo. La existencia de una emergencia no debe utilizarse para ampliar sin control el acceso a información ajena al incidente.

Si aparece un posible hecho delictivo, la organización debe valorar con su asesoramiento jurídico las actuaciones pertinentes, las obligaciones de notificación y la relación con las autoridades. El analista no necesita hacer calificaciones penales para desempeñar bien su trabajo. Debe mantener el relato en un plano técnico, conservar lo que resulte pertinente y facilitar que una evaluación posterior pueda entender los límites de sus actuaciones.

1.2.10. Tres entornos, un núcleo de buenas prácticas

Aspecto	Investigación judicial	Investigación corporativa	Respuesta a incidentes
Pregunta principal	¿Qué hechos técnicos pueden acreditarse?	¿Qué ocurrió en relación con un encargo interno delimitado?	¿Qué sucede, qué alcance tiene y cómo detenerlo?

Aspecto	Investigación judicial	Investigación corporativa	Respuesta a incidentes
Autoridad de actuación	Resoluciones y facultades legalmente aplicables	Base legítima, competencias, políticas y autorizaciones pertinentes	Competencias operativas y legales de respuesta
Prioridad característica	Fiabilidad, alcance legal y posibilidad de contradicción	Proporcionalidad, independencia y utilidad para decisiones internas	Contención, continuidad y preservación de datos perecederos
Fuentes habituales	Dispositivos, soportes, cuentas y datos autorizados	Registros corporativos, aplicaciones y equipos comprendidos en el encargo	Telemetría, memoria, red, identidades y registros centralizados
Resultado	Informe técnico o pericial	Informe de investigación y hallazgos fundamentados	Conclusiones operativas, alcance e informe técnico
Riesgo específico	Exceder la autorización o presentar inferencias como hechos	Investigación sesgada o excesivamente intrusiva	Alterar o perder evidencia durante la recuperación

Esta tabla describe orientaciones frecuentes, no categorías excluyentes. Un informe corporativo puede terminar aportándose a un procedimiento; una investigación judicial puede exigir actuaciones urgentes; y una respuesta a incidentes puede requerir formalidades estrictas de custodia desde el inicio. Lo que permanece constante es la obligación de distinguir información observada, procedimientos ejecutados e interpretaciones sustentadas.

1.2.11. Cooperación entre especialidades

En las investigaciones complejas intervienen personas con conocimientos y responsabilidades diferentes. El personal de sistemas conoce la infraestructura y puede explicar configuraciones históricas; el equipo de seguridad aporta alertas y contexto de amenaza; especialistas de redes interpretan comunicaciones; responsables de aplicaciones conocen los registros funcionales; los servicios jurídicos delimitan el alcance permitido; y el equipo forense se ocupa de preservar, examinar y correlacionar información.

Esta cooperación resulta imprescindible, pero requiere una coordinación clara. Un administrador bienintencionado puede reiniciar un servidor que el analista pretendía examinar en vivo. Un equipo de monitorización puede modificar una regla de retención y sobrescribir registros necesarios. Un proveedor puede reconstruir automáticamente una instancia que parecía inactiva. La investigación debe identificar estas dependencias antes de que produzcan pérdidas irreversibles.

La separación de funciones también mejora la calidad de los resultados. Quien administra un sistema puede aportar información valiosa, aunque quizá tenga un interés directo en la explicación del incidente. Cuando resulte viable, una revisión independiente permite contrastar supuestos y detectar errores. No se trata de desconfiar sistemáticamente de las personas, sino de reducir la dependencia de una única interpretación.

El producto final de este trabajo colaborativo debe mantener una procedencia clara. Si un especialista entrega un registro exportado, el investigador ha de saber cuándo se obtuvo, con qué permisos, mediante qué consulta y de qué sistema procede. Si un proveedor comunica una conclusión sin compartir los datos que la sustentan, esa limitación debe constar. **La colaboración multiplica las fuentes; no elimina la obligación de verificar su origen.**

1.3. Evidencias digitales: características, valor y limitaciones

La evidencia digital es información susceptible de contribuir al esclarecimiento de un hecho y que se encuentra almacenada, procesada o transmitida mediante sistemas digitales. Puede consistir en un archivo visible para el usuario, una estructura interna del sistema, un fragmento de memoria, una comunicación registrada por un equipo de red o un dato generado por un servicio remoto. Su relevancia no procede únicamente de su contenido: también importan su origen, su contexto, su integridad y la relación demostrable con la cuestión investigada.

El hecho de que un dato exista no significa que constituya una prueba suficiente. Un registro puede estar correctamente preservado y, sin embargo, reflejar una acción automatizada

irrelevante. Una captura de pantalla puede mostrar información auténtica, pero ser insuficiente para atribuir una operación. Un archivo puede coincidir byte a byte con otro sin que ello permita conocer cuándo o por qué fue copiado. La evidencia adquiere valor cuando se interpreta correctamente y se sitúa dentro de un razonamiento que reconoce alternativas y limitaciones.

1.3.1. De la evidencia potencial a la evidencia relevante

Durante la identificación inicial se trabaja con **fuentes potenciales de evidencia**. Son dispositivos, sistemas o conjuntos de datos que podrían contener información útil. Un ordenador incautado, por ejemplo, no es en su totalidad una prueba de un hecho específico. Su almacenamiento reúne datos del sistema, aplicaciones, usuarios, procesos automáticos y actividad histórica que puede no tener ninguna relación con la investigación.

A partir de esas fuentes se seleccionan elementos relevantes. Para determinar su utilidad, el analista debe valorar al menos cuatro cuestiones: qué hecho pretende esclarecer, qué representa realmente el artefacto, cómo se obtuvo y qué limitaciones presenta. Un mensaje electrónico puede ser importante por su contenido, por las cabeceras de transporte, por los adjuntos o por la secuencia de entrega; cada dimensión responde a preguntas diferentes.

La **pertinencia** relaciona el dato con el objeto de la investigación. La **fiabilidad** alude a la confianza razonable en su procedencia y en la interpretación técnica. La **integridad** se refiere a la detección y control de cambios respecto del material que se considera referencia. La **suficiencia** obliga a considerar si el conjunto de datos permite sostener la conclusión formulada. Estas propiedades están relacionadas, pero ninguna sustituye a las demás.

Una evidencia puede ser íntegra y poco fiable como descripción de la realidad. Si alguien escribe una afirmación falsa en un fichero y se calcula su hash, ese valor permite controlar cambios posteriores en el fichero, pero no convierte la afirmación en verdadera. Asimismo, conservar perfectamente un registro mal configurado no corrige los defectos de su origen. Debe examinarse por separado la integridad de la copia y la fiabilidad de la información contenida en ella.

1.3.2. Naturaleza lógica, física y distribuida

En el ámbito físico, un objeto puede identificarse por su material, forma o ubicación. La evidencia digital añade una característica singular: el contenido lógico puede existir en múltiples copias indistinguibles en términos de bytes. Un documento puede encontrarse en un disco local, una copia de seguridad, una carpeta sincronizada y una plataforma en la nube.

Las cuatro copias pueden compartir contenido y, al mismo tiempo, presentar metadatos y trayectorias de creación diferentes.

Por ello conviene distinguir el **soporte** de la **información**. Un disco SSD es un objeto físico. Una partición es una estructura lógica descrita por metadatos. Un archivo es una representación del sistema de archivos. Una imagen forense puede preservar determinadas unidades de información del soporte, dependiendo de la técnica de adquisición. Un registro exportado de un proveedor es otra representación cuyo alcance depende de la consulta y de las funciones de la plataforma.

Esta distinción evita afirmaciones excesivas. Obtener una copia lógica de documentos no equivale a capturar todos los bloques de un soporte. Extraer una carpeta sincronizada no supone adquirir el historial completo del servicio. Exportar una conversación desde una aplicación puede producir un conjunto distinto al almacenado localmente, especialmente si existen mensajes eliminados, contenido efímero o sincronización parcial.

La evidencia contemporánea es, además, **distribuida**. Una única acción del usuario puede producir rastros en un teléfono, un servicio de identidad, una API, una pasarela de acceso y un sistema de auditoría. Cada componente registra solo una perspectiva. Ninguno posee necesariamente una descripción completa del acontecimiento. La reconstrucción exige correlacionar las vistas disponibles y atender a los puntos ciegos.

1.3.3. La volatilidad: datos que desaparecen

No todas las fuentes conservan la información durante el mismo tiempo. Algunos datos permanecen durante años si el soporte no se modifica; otros cambian cada segundo. La tabla de procesos, las conexiones activas, ciertas claves cargadas en memoria, los contenidos de buffers y determinados eventos de corta retención pueden desaparecer tras un reinicio o una operación ordinaria del sistema.

La volatilidad no se limita a la memoria RAM. Un servicio en la nube puede conservar registros solo durante un periodo definido por la suscripción o la política de retención. Un contenedor puede destruirse y recrearse automáticamente. Un router doméstico puede mantener únicamente unas decenas de entradas recientes. Un registro circular puede sobrescribir eventos antiguos al alcanzar un tamaño máximo. Una aplicación puede borrar conversaciones o contenido temporal según su configuración.

El orden de adquisición debe considerar estas circunstancias. Si la investigación se inicia varios días después de los hechos, algunos rastros pueden haberse perdido de manera irreversible. El analista debe averiguar qué información aún existe, qué se sobrescribió, qué datos

podrían recuperarse desde otras fuentes y qué afirmaciones dejan de ser comprobables por ausencia de registros.

La falta de conservación no implica necesariamente una actuación maliciosa. Puede deberse a la operación normal del sistema o a una política de retención insuficiente. En otras ocasiones sí puede formar parte de una actividad deliberada de ocultación. La distinción requiere indicios; no se puede atribuir intención únicamente porque falten datos.

Figura 5: Comparación de fuentes por volatilidad y dependencia operativa.

1.3.4. Integridad y funciones hash

La posibilidad de copiar datos digitales con gran precisión es una ventaja importante para el análisis. Permite trabajar sobre copias controladas y reservar el material de referencia. Para verificar que una copia o un archivo no ha cambiado, es habitual calcular una función hash criptográfica, como SHA-256. Esta operación transforma una secuencia de bytes en un resumen de longitud fija, diseñado para que resulte computacionalmente difícil encontrar entradas diferentes con el mismo valor.

Si se calcula el hash de un archivo en el momento de su adquisición y se obtiene el mismo valor cuando se vuelve a comprobar, existe un fundamento técnico sólido para considerar que

el contenido comparado no ha sufrido alteraciones detectables entre ambas operaciones, dentro de las garantías de la función utilizada. Es importante precisar qué se ha comparado: el hash de un documento no verifica los metadatos que se encuentren fuera de él; el hash de una exportación no verifica datos que la consulta dejó fuera; y el hash de una imagen no informa por sí solo sobre los sectores que no pudieron leerse.

Una función hash **no demuestra quién creó el archivo, cuándo lo creó ni si su contenido es verdadero**. Tampoco acredita que la adquisición estuviera autorizada o que el dispositivo perteneciera a una persona concreta. Dos archivos con un hash idéntico calculado mediante un algoritmo criptográfico apropiado permiten sostener con alta confianza que sus bytes coinciden, pero no cómo llegaron a sus respectivas ubicaciones.

La integridad requiere además un proceso que identifique el objeto de referencia, la forma de adquisición y los controles de almacenamiento. Una captura errónea puede mantenerse íntegra después de su realización. Por ejemplo, si una herramienta omite determinados archivos y calcula un hash de la exportación, la coincidencia del hash en revisiones futuras garantiza la estabilidad de esa exportación, no su exhaustividad respecto del sistema original.

El uso de valores hash debe integrarse en la documentación de custodia y análisis. Se registran el algoritmo, el elemento examinado, el momento de cálculo y, cuando proceda, las comprobaciones posteriores. El capítulo de adquisición profundizará en la verificación por bloques, los formatos de imagen, los errores de lectura y las diferencias entre adquirir un soporte y exportar objetos lógicos.

1.3.5. La cadena de custodia no es un algoritmo

La cadena de custodia registra la continuidad del control sobre una evidencia y las acciones relevantes relacionadas con ella. En el mundo digital puede comprender dispositivos físicos, soportes, imágenes forenses, archivos exportados, copias de trabajo y conjuntos de registros remitidos por terceros. Cada elemento debe identificarse sin ambigüedad para evitar confusiones entre originales, copias y derivados.

La documentación suele contemplar quién recogió el elemento, dónde y cuándo, en qué condiciones se encontraba, qué identificadores permitían reconocerlo, cómo se embaló o almacenó, quién lo recibió posteriormente y qué operaciones se autorizaron. Cuando la evidencia es exclusivamente digital, la transferencia puede producirse entre repositorios o sistemas de custodia, por lo que también importan permisos de acceso, registros de descarga, verificaciones de integridad y controles de conservación.

No debe presentarse la cadena de custodia como una fórmula que automáticamente valida cualquier conclusión. Es un mecanismo para proporcionar garantías sobre el tratamiento del material. Su calidad puede reforzar la confianza en la continuidad de la evidencia, mientras que sus deficiencias introducen cuestiones que deberán evaluarse según su naturaleza e importancia. Una anotación ausente no permite deducir por sí sola que el contenido fue manipulado, del mismo modo que una cadena documental completa no impide que un archivo ya fuera engañoso antes de recogerse.

NISTIR 8387 aborda las dificultades particulares de la preservación de evidencia digital, entre ellas la diversidad de soportes y objetos digitales y las necesidades de gestión a largo plazo [10]. El problema no termina al crear una copia: también es necesario conservarla, mantenerla accesible bajo controles adecuados y poder demostrar qué se hizo con ella en el tiempo.

1.3.6. Autenticidad, procedencia y contexto

La **autenticidad** de un elemento debe analizarse atendiendo a qué representa y a las comprobaciones disponibles. Un correo que aparece en una bandeja puede haber sido recibido efectivamente, pero su campo visible de remitente puede ser engañoso. Una captura de pantalla puede reproducir una conversación auténtica o una composición creada para aparentarla. Un registro de aplicación puede proceder de un sistema legítimo, pero haber sido generado a partir de datos suministrados por un usuario malicioso.

La **procedencia** intenta reconstruir de qué sistema, cuenta, dispositivo o proceso surgió la información y cómo llegó al analista. En los sistemas complejos existen diversas capas de intermediación. Un proxy puede registrar la dirección que observa y no la del usuario original; una plataforma puede agregar eventos de múltiples regiones; una exportación puede normalizar campos o traducir marcas horarias. La interpretación depende de conocer esas transformaciones.

El **contexto** proporciona el significado técnico. Una línea de registro que contiene la palabra `deleted` podría referirse al borrado de un objeto, a la revocación de una sesión, a una tarea interna de limpieza o a un campo de diagnóstico. Interpretar únicamente la palabra, sin revisar el esquema de eventos y la documentación de la aplicación, puede conducir a un resultado erróneo.

Los metadatos también precisan contexto. La fecha de creación de un archivo puede referirse a su aparición en un volumen concreto, no al momento en que se redactó el documento. Un archivo copiado puede adquirir marcas temporales distintas de las del original. La sincronización y los sistemas de copia pueden conservar o transformar atributos según sus reglas.

Por eso conviene identificar con exactitud qué campo temporal se está examinando y qué operaciones pueden modificarlo.

1.3.7. El problema de las marcas temporales

La reconstrucción cronológica es una de las actividades más útiles y, a la vez, más delicadas del análisis forense. Los sistemas pueden emplear zonas horarias diferentes, guardar marcas en UTC o en hora local, utilizar relojes desajustados y registrar eventos con precisiones distintas. Un servidor podría conservar segundos, mientras que otro solo almacena minutos; un sistema de archivos puede registrar nanosegundos teóricos sin que todos los programas que lo manipulan respeten esa precisión.

El analista debe diferenciar **precisión de representación**, **exactitud del reloj** y **momento real del hecho**. Una marca que incluye seis decimales no garantiza que el reloj estuviera correctamente sincronizado. Tampoco indica necesariamente que la acción comenzara en ese instante: podría reflejar el momento de recepción, escritura en disco, procesamiento, cierre de una operación o exportación del evento.

Imaginemos dos registros. Un servidor A informa de una conexión a las 10:02:15 y un servidor B registra una descarga a las 10:01:58. A primera vista, la descarga parece anterior a la conexión. Sin embargo, si el reloj de B adelantaba 90 segundos respecto de A, el orden real podría ser el contrario. Antes de construir una narrativa causal es necesario conocer el origen temporal de cada fuente, sus desfases conocidos y la incertidumbre residual.

En sistemas modernos, la virtualización, los dispositivos móviles y los servicios distribuidos añaden complejidad. Pueden producirse ajustes de hora durante una ejecución, cambios de zona horaria y diferencias entre el tiempo generado por el cliente y el registrado por el servidor. Algunas plataformas incorporan identificadores secuenciales que ayudan a reconstruir el orden relativo de eventos sin depender únicamente del reloj. El análisis debe aprovechar esas referencias cuando existan.

Es una mala práctica corregir silenciosamente las horas para hacer que los eventos encajen. Si se aplica un ajuste, debe explicarse su base y conservarse el valor original. Cuando no sea posible determinar un desfase preciso, el informe debería expresar un intervalo o una secuencia probable, no un segundo aparentemente exacto.

1.3.8. Interpretación y atribución: el salto más peligroso

La evidencia digital describe habitualmente acciones de componentes tecnológicos. Puede indicar que una cuenta inició sesión, una aplicación abrió un archivo o un dispositivo se co-

nectó a una red. La atribución a una persona física requiere un razonamiento adicional y, con frecuencia, fuentes no digitales.

La dirección IP es un buen ejemplo. Una IP pública puede corresponder a una conexión residencial, una red corporativa, una salida de VPN, un centro de datos o un sistema de traducción de direcciones compartido. Su asignación puede cambiar con el tiempo. Los registros pueden mostrar qué dirección observó un servicio sin revelar la identidad del usuario final. Incluso cuando se conoce el abonado de una conexión, ello no demuestra necesariamente quién realizó una acción específica.

Algo parecido sucede con los nombres de dispositivo y las cuentas. Un ordenador puede ser utilizado por varias personas, un servicio puede ejecutar acciones en nombre de usuarios y una credencial puede ser sustraída o compartida. Los sistemas de identidad federada añaden delegaciones, tokens, aplicaciones y sesiones que pueden actuar sin una interacción humana simultánea. Identificar el principal técnico responsable de una operación es un paso; atribuir intención personal es otro.

El investigador debe evitar tres saltos frecuentes: de **presencia** a **uso**, de **uso de una cuenta** a **acción de su titular** y de **acción observada** a **intención**. Cada salto exige evidencia adicional. Un programa instalado no prueba su ejecución; una ejecución no prueba por sí sola una finalidad ilícita; y un archivo presente en un directorio no acredita necesariamente que su usuario lo haya leído conscientemente.

La corroboración entre fuentes independientes reduce algunas incertidumbres. Por ejemplo, un registro de inicio de sesión puede coincidir con actividad del equipo, eventos de autenticación multifactor y la conexión física de un dispositivo. Aun así, la fuerza de la conclusión depende de la calidad y la independencia real de esas fuentes. Cinco alertas generadas a partir de un mismo evento no constituyen cinco confirmaciones independientes.

1.3.9. Ausencia de evidencia y evidencia de ausencia

La inexistencia de un artefacto en una búsqueda no siempre significa que el hecho investigado no ocurrió. Quizá el sistema no generaba ese registro, su retención había vencido, la herramienta no examinó la ubicación correcta o el evento no produce necesariamente el rastro esperado. La ausencia resulta informativa únicamente cuando se conoce suficientemente el funcionamiento y la cobertura del mecanismo de registro.

Supongamos que se intenta demostrar que un equipo nunca se conectó a una red inalámbrica porque no aparece un evento en un archivo de registro. Si ese archivo solo conserva

una semana de actividad y el periodo investigado es de tres meses, la conclusión no es sostenible. El resultado correcto sería que no se localizó el evento en los registros disponibles para el intervalo efectivamente conservado.

En cambio, si existe un mecanismo que genera de forma consistente un registro por cada transacción, se verifica que estuvo activo durante todo el periodo, se comprueba que no hay pérdidas y se revisan los identificadores correspondientes, la ausencia del evento esperado puede tener mayor valor. Incluso entonces debe comprobarse que no existieron rutas alternativas capaces de evitar ese mecanismo.

La formulación precisa es fundamental: «no se ha encontrado evidencia de una transferencia en las fuentes examinadas» es diferente de «no se produjo ninguna transferencia». La segunda afirmación exige una cobertura de observación que muchas investigaciones no pueden garantizar.

1.3.10. Cifrado, borrado, daños y limitaciones de acceso

El cifrado constituye una medida legítima de seguridad y privacidad, pero también puede limitar una investigación. Un disco correctamente cifrado puede resultar inaccesible si no se dispone de la clave y el sistema está apagado. En un dispositivo encendido, determinadas claves o volúmenes pueden encontrarse accesibles bajo condiciones específicas; cualquier intento de adquisición debe considerar las autorizaciones y los riesgos de alterar el estado del sistema.

La eliminación de archivos tampoco produce un resultado uniforme. En algunos sistemas, parte del contenido puede permanecer en zonas no asignadas hasta ser sobrescrito. En otros, mecanismos como TRIM, cifrado por archivo, mantenimiento del sistema o gestión interna del almacenamiento pueden impedir la recuperación. No existe una regla general según la cual «todo lo borrado puede recuperarse». Las posibilidades dependen de la tecnología, el estado del soporte, el tiempo transcurrido y las operaciones efectuadas.

Hay además fuentes que nunca estuvieron disponibles para el investigador. Una plataforma puede no conservar el contenido de determinadas comunicaciones, un usuario puede haber empleado cifrado de extremo a extremo y un servicio puede registrar solo metadatos. Los permisos de una organización tampoco garantizan que el proveedor pueda entregar cualquier información. Las capacidades técnicas de adquisición y el derecho de acceso son problemas diferentes que deben resolverse por separado.

Cuando un soporte presenta errores físicos, una lectura repetida puede empeorar su estado o producir resultados inconsistentes. En estos casos adquiere importancia planificar la recuperación, documentar los sectores no legibles y evitar afirmaciones de integridad total

cuando la captura es parcial. Del mismo modo, una adquisición lógica selectiva puede ser completamente válida para el alcance acordado sin necesidad de presentarla como imagen exhaustiva de un dispositivo.

1.3.11. Manipulación deliberada y explicaciones benignas

Algunos actores intentan ocultar sus rastros mediante eliminación de registros, alteración de marcas de tiempo, cifrado, manipulación de metadatos o ejecución de herramientas que dificultan el análisis. Estas técnicas suelen agruparse bajo el término *antiforense*. Reconocerlas es importante, pero no debe conducir a interpretar cualquier ausencia o anomalía como prueba de encubrimiento.

La administración legítima de sistemas también puede rotar registros, purgar archivos temporales, optimizar almacenamiento, reconstruir índices y modificar atributos. Una aplicación puede generar fechas aparentemente incoherentes por un defecto de programación. Una migración puede alterar propietarios, rutas y marcas temporales. Incluso el proceso de preservación puede producir cambios controlados que se reflejarán después en las evidencias.

La diferencia entre una operación normal y una manipulación deliberada requiere contexto. Un conjunto de registros vacíos después de una actualización documentada admite una explicación distinta de un borrado selectivo ejecutado inmediatamente después de un acceso no autorizado. La proximidad temporal puede reforzar una hipótesis, pero la intención no debe inferirse únicamente de la coincidencia.

Cuando una anomalía no pueda explicarse, el informe debe describirla sin convertirla automáticamente en una acción maliciosa. Es preferible establecer «se observan cambios incompatibles con la secuencia esperada y no se ha determinado su origen» que afirmar un sabotaje cuya ejecución no puede demostrarse.

1.3.12. La correlación aumenta el valor, pero también introduce riesgos

La correlación consiste en relacionar datos provenientes de diferentes fuentes para reconstruir una secuencia o contrastar una hipótesis. Un evento de autenticación puede vincularse con una asignación de dirección IP, una conexión VPN y la ejecución posterior de un proceso. Cuando las fuentes son compatibles y sus relaciones se verifican, la explicación resultante gana consistencia.

Sin embargo, la correlación también puede crear errores. Dos registros pueden compartir un identificador que no es único. Un servicio puede reutilizar direcciones internas. Un nombre de equipo puede cambiar. Una cuenta puede ejecutarse en varios dispositivos. Las diferencias horarias pueden presentar eventos separados como simultáneos o relacionados. La coincidencia temporal tampoco establece por sí sola una relación causal.

Para evitar estos problemas, el analista debe documentar **las claves de correlación** empleadas: identificadores de sesión, nombres de recurso, direcciones, puertos, hashes, identificadores de objeto, nombres de cuenta y periodos temporales. Cada clave tiene un alcance y un nivel de fiabilidad. La dirección IP de origen puede servir para localizar conexiones, pero a menudo requiere acompañarse de otros campos para identificar una sesión individual.

El contraste de hipótesis alternativas es una protección adicional. Si un registro muestra que un archivo fue descargado poco después de un acceso sospechoso, debe examinarse si también existía una tarea automática que descargaba ese mismo archivo. La pregunta no es únicamente qué interpretación encaja con los datos, sino qué observaciones permitirían diferenciarla de otras explicaciones plausibles.

1.3.13. Un ejemplo de valoración progresiva de evidencias

Una organización detecta una conexión desde un equipo de oficina hacia un almacenamiento externo. El sistema de monitorización conserva destino, tiempo aproximado y volumen de tráfico. La investigación pretende determinar si se enviaron documentos confidenciales.

En una primera fase, los datos demuestran que se observó tráfico hacia ese destino. No permiten conocer por sí solos qué archivos circularon, ni siquiera si todo el volumen correspondió a contenido de usuario. En una segunda fase, los registros de proxy podrían mostrar una solicitud de subida a una ruta determinada, aunque tal vez no conserven el cuerpo de la petición. En una tercera fase, la telemetría del equipo podría registrar el acceso a un archivo concreto y su lectura por un proceso de sincronización.

Si además existe una auditoría del servicio remoto que identifica un objeto recibido, su tamaño y una huella verificable, la hipótesis de transferencia gana fuerza. El resultado será especialmente sólido si puede establecerse que la representación del objeto remoto coincide con el archivo origen y si se comprenden las transformaciones intermedias. Si el servicio fragmenta o cifra el contenido antes de la transmisión, una comparación directa de hashes de los paquetes de red no sería adecuada.

Aun con todas esas fuentes, la investigación puede no permitir atribuir la acción a una persona concreta. El equipo podría haberse utilizado remotamente o la tarea podría estar automatizada. Un informe riguroso separará las conclusiones: conexión observada, transferencia

identificada, coincidencia de contenido y atribución personal todavía no establecida. Cada afirmación tendrá su propio apoyo probatorio.

1.3.14. Valorar la evidencia como un conjunto, no como una colección de capturas

Las capturas de pantalla son útiles para comunicar hallazgos, pero suelen ser representaciones parciales. No sustituyen los datos originales ni la documentación de su extracción. Una imagen de un registro puede ocultar campos necesarios, filtros aplicados, información de cabecera, paginación o eventos anteriores y posteriores. Para un análisis defendible interesa preservar, cuando sea posible y pertinente, los datos subyacentes y los criterios utilizados para obtener la vista mostrada.

También deben distinguirse las fuentes primarias de los productos derivados. Un archivo de log recogido directamente, una exportación CSV generada por una consola y una gráfica elaborada a partir de ese CSV pueden ser útiles en distintas etapas. Pero la gráfica no debe convertirse en el único respaldo de una conclusión si todavía es posible conservar los registros originales. Los resúmenes automatizados pueden ser incompletos, eliminar valores nulos, agrupar por periodos o introducir interpretaciones propias de la herramienta.

El valor probatorio no crece necesariamente con la cantidad de páginas de un informe. La acumulación indiscriminada de capturas dificulta encontrar los hechos relevantes y puede ocultar contradicciones. Lo deseable es construir una argumentación técnica que muestre qué evidencia sustenta cada hallazgo, qué operaciones permitieron obtenerlo y qué incertidumbres permanecen. La transparencia metodológica es más importante que el volumen documental.

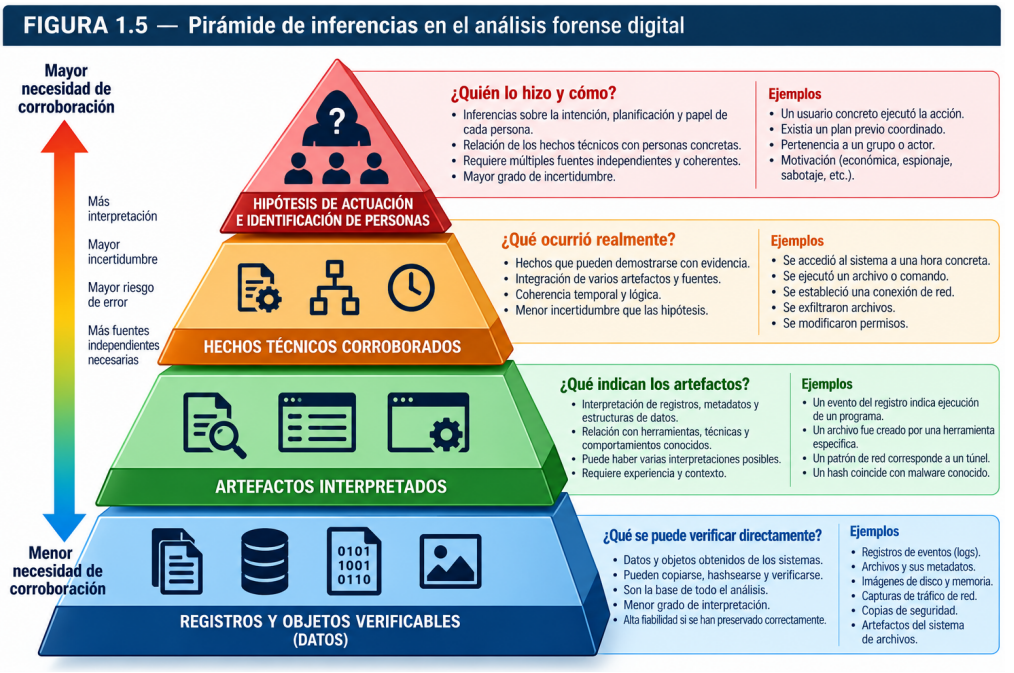


Figura 6: Pirámide de inferencias

1.3.15. Reconocer los límites es parte del resultado

Una investigación puede concluir que no existen datos suficientes para determinar la causa de un evento, que una fuente se perdió antes de la intervención o que varias explicaciones son compatibles con lo observado. Estas respuestas pueden decepcionar al solicitante, pero constituyen hallazgos legítimos si están razonados.

La honestidad técnica obliga a distinguir una limitación de adquisición, una limitación de los artefactos y una limitación interpretativa. La primera aparece cuando no se pudo obtener una fuente. La segunda surge cuando la propia fuente no registra la dimensión que interesa. La tercera se presenta cuando los datos existen, pero no permiten escoger de forma fundada entre hipótesis alternativas. Las tres reducen el alcance de determinadas conclusiones, aunque por razones distintas.

Documentar estas restricciones permite que otra persona valore si merece la pena ampliar el examen, acudir a un proveedor, buscar registros auxiliares o aceptar que la cuestión permanecerá sin resolver. Una limitación bien explicada es mucho más útil que una conclusión categórica construida sobre suposiciones.

La función del análisis forense no es producir certeza artificial. Es **reducir incertidumbre mediante evidencia examinada con método** y señalar con precisión la parte de incertidumbre que no ha podido eliminarse.

1.4. Fuentes de evidencia y responsabilidades del analista

Una investigación digital puede comenzar en un dispositivo concreto y extenderse rápidamente a otros sistemas. Una autenticación realizada desde un teléfono puede quedar reflejada en el propio terminal, un proveedor de identidad, un servicio de acceso remoto y una aplicación empresarial. Una transferencia de archivos puede producir huellas en el sistema de archivos, un cliente de sincronización, un proxy, un cortafuegos y un repositorio remoto. Para interpretar un hecho no basta con reconocer artefactos aislados; hace falta entender qué fuentes existen, qué parte de la actividad observan y cómo se relacionan entre sí.

La elección de fuentes debe responder a la pregunta investigada y a las limitaciones de acceso, conservación y proporcionalidad. No es necesario adquirir todo lo que pueda contener información. Lo importante es obtener un conjunto suficiente para reconstruir los hechos con el rigor requerido, evitando perder datos esenciales o acumular información cuya relación con el caso sea inexistente.

1.4.1. El equipo informático como fuente de huellas

Los ordenadores de sobremesa, portátiles y servidores continúan siendo fuentes centrales de evidencia. Sus dispositivos de almacenamiento contienen sistemas de archivos, aplicaciones, bases de datos locales, configuraciones, registros, documentos y múltiples artefactos generados durante la actividad ordinaria. Los sistemas operativos también conservan información sobre usuarios, procesos, dispositivos conectados, tareas programadas y servicios.

El análisis de un equipo requiere comprender su arquitectura. Una estación Windows puede conservar artefactos distintos a los de una máquina Linux o macOS. Incluso dentro de una misma familia de sistemas operativos cambian las ubicaciones, los formatos, las políticas de retención y las condiciones de generación de registros. Una técnica válida para una versión puede dejar de funcionar o producir resultados diferentes tras una actualización.

La ubicación de un artefacto no determina por sí sola su relevancia. Un historial del navegador puede proporcionar indicios sobre sitios visitados, pero las visitas pueden proceder de cargas automáticas, extensiones o contenido incrustado. Una lista de archivos recientes puede reflejar referencias generadas por una aplicación sin garantizar que el usuario haya

leído conscientemente cada documento. La interpretación requiere comprender el ciclo de vida del artefacto.

Tampoco todos los datos útiles residen en archivos convencionales. Algunos aparecen en estructuras del sistema de archivos, zonas no asignadas, bases de datos internas, registros transaccionales o memoria. La posibilidad de examinarlos depende del tipo de adquisición, el estado del sistema y las tecnologías de almacenamiento. Un análisis limitado a los documentos visibles en un explorador de archivos puede dejar fuera información decisiva.

1.4.2. Memoria y estado de ejecución

La memoria y el estado de ejecución pueden aportar una perspectiva que no se obtiene de un disco apagado. Un sistema activo mantiene procesos, hilos, conexiones, estructuras del núcleo y datos temporales que reflejan determinadas actividades en curso. En condiciones concretas pueden encontrarse fragmentos de comunicaciones, módulos cargados, configuraciones o material criptográfico presente durante la ejecución.

La adquisición de memoria implica decisiones técnicas y operativas. Las herramientas necesitan ejecutarse en el sistema o emplear mecanismos de captura compatibles con la plataforma. Esta intervención modifica parte del estado que se pretende observar; por ello se documentan el procedimiento, la herramienta, los privilegios utilizados y las limitaciones de la captura. En entornos virtualizados pueden existir opciones de instantánea o adquisición desde el hipervisor, pero no deben suponerse equivalentes sin valorar su funcionamiento real.

La ausencia de un elemento en una captura no prueba necesariamente que nunca existiera. Un proceso puede haber terminado, una región puede haber sido reutilizada y una herramienta puede no reconocer determinada estructura. La interpretación necesita conocer la versión del sistema, el mecanismo de adquisición y los modelos utilizados por el software de análisis.

En respuesta a incidentes, la memoria puede ser especialmente útil para investigar procesos sospechosos, conexiones y técnicas que dejan pocos rastros persistentes. En procedimientos judiciales puede aportar información contextual sobre el estado de un equipo, siempre que la actuación cuente con cobertura adecuada. Su importancia no elimina los riesgos de alteración ni convierte cada fragmento hallado en una descripción inequívoca de lo ocurrido.

1.4.3. Dispositivos móviles y aplicaciones personales

Los teléfonos móviles concentran comunicaciones, fotografías, documentos, datos de aplicaciones, configuraciones, credenciales y señales de actividad asociadas a múltiples servicios. Esta concentración aumenta su relevancia potencial y también la sensibilidad de cualquier investigación. Un terminal puede contener información de terceros, datos de localización, conversaciones íntimas y actividades que no guardan relación alguna con el encargo.

Además, los dispositivos móviles presentan restricciones técnicas específicas: cifrado por hardware, controles de desbloqueo, aislamiento de aplicaciones, sincronización con servicios remotos y mecanismos de protección que dependen del estado del dispositivo. Una extracción lógica, una copia de seguridad y una adquisición de mayor profundidad no ofrecen necesariamente el mismo conjunto de datos. Las posibilidades reales varían según el modelo, sistema operativo, configuración y estado de seguridad.

La sincronización añade otra capa de complejidad. Un mensaje visible en una aplicación puede provenir de una base de datos local, de un servidor remoto o de una caché. Algunos elementos pueden desaparecer del terminal y permanecer en una copia de seguridad; otros pueden existir únicamente en servidores administrados por terceros. El analista debe distinguir la fuente de cada objeto y evitar afirmar que una extracción representa la totalidad de la actividad del usuario.

La obtención de ubicaciones merece especial cautela. Un dispositivo puede registrar coordenadas GPS, estimaciones derivadas de redes, ubicaciones asignadas por una aplicación o datos inferidos mediante servicios. La precisión y el significado de esos registros pueden variar considerablemente. Una coordenada asociada a una fotografía no acredita automáticamente que el propietario estuviera allí en el momento indicado: el archivo puede haberse recibido, modificado o creado por otra persona.

Los capítulos dedicados a Android e iOS profundizarán en estas dificultades. El principio general ya puede formularse: **la sensibilidad y complejidad del entorno móvil exigen una adquisición proporcionada y una interpretación particularmente cuidadosa**.

1.4.4. Redes y dispositivos de comunicaciones

Los sistemas de red permiten observar parte de las comunicaciones entre equipos. Los registros de cortafuegos, servidores DNS, proxies, balanceadores, soluciones VPN, dispositivos de acceso inalámbrico y herramientas de detección pueden aportar información sobre destinos, protocolos, tiempos y decisiones de filtrado. Una captura de paquetes proporciona

una perspectiva diferente: conserva las unidades de tráfico recogidas en un punto concreto durante un intervalo determinado.

Cada fuente presenta límites. Un cortafuegos puede registrar únicamente sesiones permitidas o bloqueadas, sin conservar los datos transportados. Un sensor situado en un segmento determinado no observa necesariamente las comunicaciones que siguen otras rutas. Una captura puede perder paquetes por falta de capacidad o por filtros mal configurados. El cifrado puede impedir inspeccionar el contenido de las aplicaciones, aunque sigan siendo visibles ciertos metadatos, sujetos también a la evolución de los protocolos.

El tráfico de red resulta valioso para reconstruir conexiones, intercambios y posibles movimientos entre sistemas. Sin embargo, no debe confundirse conexión con compromiso ni volumen de datos con contenido exfiltrado. Una sesión TLS de varios cientos de megabytes puede corresponder a una copia de seguridad legítima, una descarga de software o una transferencia no autorizada. Los datos de red se interpretan mejor cuando se correlacionan con registros de procesos, usuarios y aplicaciones.

También intervienen mecanismos que complican la atribución: traducción de direcciones, proxies, redes privadas virtuales, direcciones dinámicas y servicios distribuidos. El analista tiene que comprender desde qué punto se observó cada conexión y qué significado conserva el identificador registrado. Una dirección en un log puede identificar el extremo que el sensor vio, no el origen último de la actividad.

1.4.5. Correo electrónico, navegación y mensajería

Los mensajes electrónicos son fuentes relevantes en investigaciones de fraude, suplantación de identidad, filtración de información y conflictos laborales. Su análisis puede abarcar el contenido, los adjuntos, las cabeceras técnicas, los resultados de autenticación del dominio, los registros de los servidores y el contexto de recepción. El nombre mostrado como remitente no constituye una prueba de origen; la ruta técnica debe examinarse con sus particularidades.

Mecanismos como SPF, DKIM y DMARC ayudan a evaluar determinados aspectos de autenticación y alineación de mensajes, pero no certifican por sí solos que el contenido sea legítimo ni que su autor sea quien aparenta. Un atacante puede enviar mensajes maliciosos desde un dominio que controla y superar correctamente esas verificaciones. También pueden existir reenvíos y configuraciones que compliquen la interpretación de los resultados. El examen debe considerar el conjunto de cabeceras y, cuando se disponga de ellos, los registros del proveedor.

La navegación web produce artefactos variados: historiales, cookies, cachés, descargas, bases de datos y datos sincronizados. Su disponibilidad depende del navegador, el perfil, el sistema operativo y las opciones de privacidad. Algunas acciones generan registros de modo consistente; otras no. Los modos privados pueden reducir determinadas persistencias locales, pero no implican ausencia de huellas en todos los sistemas o servicios involucrados.

En mensajería, las exportaciones y capturas deben evaluarse con especial prudencia. Una conversación representada en pantalla puede omitir mensajes, participantes o contexto. Las aplicaciones pueden manejar contenido efímero, cifrado de extremo a extremo y estados de sincronización que dificultan obtener una vista completa. Siempre que resulte procedente, se debe conservar la información técnica disponible que permita identificar la procedencia y las condiciones de la representación.

1.4.6. Registros de aplicaciones y bases de datos

Los registros de aplicación suelen aportar el significado funcional que falta en otras fuentes. Un sistema operativo puede mostrar que se accedió a un archivo, mientras que una aplicación de gestión puede indicar qué operación de negocio lo generó. Una base de datos puede conservar transacciones, identificadores de usuario, cambios de estado y relaciones entre objetos que permiten reconstruir acciones concretas.

Sin embargo, los registros funcionales dependen del diseño de la aplicación. Algunas plataformas registran el identificador de quien inicia la petición; otras utilizan una cuenta de servicio para ejecutar todas las operaciones. Un valor «usuario» puede representar al titular de la sesión, al actor que aprobó una tarea o a un campo transmitido por el cliente. Para interpretar adecuadamente el evento, a veces será necesario consultar documentación técnica o dialogar con los desarrolladores.

Las bases de datos presentan además diferencias entre el estado actual y el histórico. Una tabla puede mostrar que un pedido se encuentra cancelado, sin conservar por sí misma cuándo cambió de estado ni quién lo hizo. Esa información quizá resida en tablas de auditoría, registros transaccionales, colas de eventos o copias de seguridad. Las operaciones de mantenimiento y replicación también pueden producir registros técnicos que no corresponden a acciones directas de una persona.

La utilidad forense de una aplicación aumenta cuando dispone de auditoría coherente, identificadores estables, sincronización horaria y políticas de retención apropiadas. Estas medidas no deberían improvisarse durante una investigación: forman parte de la preparación

previa de la organización. Una aplicación que nunca registró quién modificó un dato difícilmente podrá reconstruir ese hecho con posterioridad sin recurrir a indicios indirectos.

1.4.7. Servicios en la nube e identidades

El entorno de nube modifica la ubicación y el control de las fuentes. Parte de la información reside en sistemas administrados por el proveedor, parte en recursos configurados por el cliente y otra en dispositivos que acceden al servicio. La disponibilidad de registros, instantáneas y mecanismos de exportación depende del modelo de servicio, de la configuración y de las capacidades contractuales y técnicas existentes.

En infraestructuras como servicio pueden examinarse discos virtuales, registros de instancias, configuraciones de red y eventos de administración, según los permisos y procedimientos disponibles. En plataformas y aplicaciones como servicio, la investigación puede depender especialmente de los registros de auditoría, la identidad y los datos que la interfaz o API permitan exportar. La ausencia de control físico sobre los servidores subyacentes obliga a diseñar métodos compatibles con la arquitectura ofrecida.

La identidad es una fuente transversal. Los proveedores de identidad pueden registrar autenticaciones, emisión de tokens, aprobación de segundo factor, cambios de permisos y actividad de aplicaciones. No obstante, la validez temporal de un token y la existencia de sesiones reutilizables implican que una acción posterior no siempre exige un nuevo inicio de sesión visible. Un evento de autorización puede referirse a una aplicación actuando en nombre de un usuario y no a una persona interactuando en ese instante.

La investigación debe conocer también qué datos se encuentran en distintas jurisdicciones y qué mecanismos legítimos existen para su conservación o entrega. Los detalles jurídicos requieren evaluación específica; desde el punto de vista técnico, interesa anticipar qué registros pueden desaparecer y qué información depende de terceros. En una organización que utiliza servicios en la nube, la preparación forense comienza con el inventario de fuentes y permisos mucho antes de que aparezca el incidente.

1.4.8. Virtualización, contenedores e infraestructuras efímeras

Las máquinas virtuales y los contenedores permiten crear y destruir entornos con rapidez. Esta flexibilidad es útil operativamente, pero puede dificultar la preservación de evidencias. Una aplicación alojada en un contenedor puede reiniciarse varias veces y perder el sistema de archivos temporal, mientras que sus registros se envían a una plataforma central. Una

máquina virtual puede migrar de anfitrión, utilizar discos diferenciales y depender de varias capas de almacenamiento.

No todas las instantáneas representan el mismo estado. Algunas conservan únicamente determinados bloques de almacenamiento; otras pueden incluir memoria y configuración, según la tecnología y las opciones empleadas. Una instantánea creada después de una actividad sospechosa no reconstruye mágicamente todo el estado anterior. También puede resultar inconsistente desde la perspectiva de aplicaciones con operaciones en curso si no se toman las precauciones necesarias.

En entornos orquestados, un nombre lógico de servicio puede permanecer estable mientras las instancias que lo ejecutan cambian. El analista debe identificar el contenedor o proceso concreto, el nodo, la imagen utilizada, los volúmenes persistentes y los registros asociados. Los identificadores de orquestación pueden ser más informativos que una dirección IP efímera.

Por ello resulta esencial preservar la relación entre los datos de una instancia y el contexto de infraestructura: configuración, imágenes, permisos, eventos de despliegue y registro de cambios. Una investigación centrada exclusivamente en el sistema de archivos de un contenedor puede ignorar que la modificación sospechosa procedió de una nueva versión desplegada por una cadena de integración continua.

1.4.9. Internet de las cosas y sistemas especializados

Los dispositivos conectados incluyen cámaras, grabadores, sensores, routers domésticos, equipos industriales y numerosos componentes con capacidad de almacenamiento o comunicación. A menudo poseen recursos limitados y mecanismos de registro poco documentados. Algunos dependen de servicios remotos para almacenar historial; otros conservan solo configuraciones y estados recientes.

Una cámara puede aportar un archivo audiovisual, marcas temporales, registros de acceso y datos sobre su configuración. Sin embargo, la hora superpuesta a una grabación puede depender de un reloj mal sincronizado. Un sensor puede mostrar una medida con periodicidad fija sin registrar cada cambio ocurrido entre lecturas. Un dispositivo doméstico puede generar eventos desde una aplicación externa y no desde una interacción física directa.

En estos entornos también deben considerarse las consecuencias de la intervención. Apagar o desconectar un controlador industrial puede afectar a un proceso físico; retirar un dispositivo de una red puede alterar su funcionamiento o hacer que deje de conservar datos. La seguridad de las personas y la continuidad de procesos críticos tienen prioridad en la planificación, junto con la necesidad de preservar evidencias de manera proporcionada.

La diversidad tecnológica impide tratar el IoT como un conjunto homogéneo. La adquisición puede requerir conocimientos de firmware, interfaces de depuración, protocolos especializados o servicios del fabricante. Antes de intervenir conviene estudiar el funcionamiento del dispositivo y documentar por qué se considera adecuada una técnica concreta.

1.4.10. Fuentes humanas y documentación de contexto

Aunque el objeto central de la informática forense son los datos digitales, una investigación rara vez puede entenderse sin información de contexto. Inventarios de activos, diagramas de red, cambios autorizados, políticas de retención, documentación de aplicaciones, comunicaciones de soporte y testimonios de responsables técnicos pueden ayudar a formular hipótesis y comprender los registros.

Esta información debe distinguirse de la evidencia obtenida directamente de los sistemas. El testimonio de un administrador puede orientar hacia un servidor de respaldo, pero no equivale a un registro técnico de la operación. Una documentación de arquitectura puede describir cómo debería funcionar una aplicación, mientras que los datos pueden mostrar que en el periodo investigado funcionó de otro modo. Las diferencias no deben ocultarse; pueden ser precisamente el origen de una explicación relevante.

Las entrevistas técnicas resultan especialmente útiles para descubrir operaciones legítimas que podrían parecer sospechosas: copias masivas, pruebas de carga, migraciones, cambios de certificados o tareas de mantenimiento. Deben documentarse las afirmaciones que influyen en la interpretación y, cuando sea posible, contrastarse con registros. La memoria humana es falible y los responsables pueden desconocer determinadas automatizaciones, del mismo modo que una herramienta puede interpretar incorrectamente un artefacto.

El contexto permite reducir errores, pero no reemplaza la comprobación. La investigación debe distinguir entre lo que una persona afirma que ocurrió, lo que el sistema registra y la conclusión que surge de confrontar ambas fuentes.

1.4.11. Cómo seleccionar fuentes: pertinencia, cobertura y coste de pérdida

La identificación de fuentes puede organizarse mediante una matriz sencilla: hecho a esclarecer, sistema que podría registrar la actividad, dato esperado, periodo de conservación, método de acceso y limitaciones conocidas. El propósito no es crear burocracia, sino evitar que una fuente decisiva desaparezca mientras se examinan otras menos relevantes.

Por ejemplo, si se sospecha un acceso no autorizado a una aplicación empresarial, podría resultar prioritario preservar los registros de identidad y de la propia aplicación antes de

que finalice su periodo de retención. Una copia completa del disco de un servidor quizá sea pertinente, pero no necesariamente debe preceder a una exportación de eventos que se eliminarán esa misma noche. La decisión dependerá del caso y del riesgo de intervención.

La **cobertura** expresa qué proporción de las actividades relevantes puede observar una fuente. Un servidor central de identidad quizá registre los accesos de usuarios, pero no las sesiones locales de un equipo desconectado. Una sonda de red puede observar tráfico externo y no comunicaciones internas entre determinados segmentos. Una copia de seguridad puede conservar documentos y omitir registros operativos. Conocer estas diferencias permite planificar adquisiciones complementarias.

El **coste de pérdida** debe valorarse tanto en términos técnicos como de oportunidad. Si una fuente desaparece, quizá ya no sea posible responder una pregunta crucial. Una fuente estable puede esperar un periodo breve mientras se conservan datos perecederos. Esto no autoriza a realizar capturas sin control: la preservación debe respetar los límites del encargo y las medidas de seguridad y privacidad correspondientes.

Figura 7: Mapa de fuentes para una investigación de acceso indebido a una aplicación en la nube

1.4.12. El encargo del analista: autoridad, preguntas y alcance

Antes de examinar datos, el analista necesita conocer con precisión qué se le solicita. Un encargo definido únicamente como «investigar todo lo que haya en este ordenador» puede ser técnicamente ineficiente y jurídicamente inadecuado. Es preferible establecer el hecho o periodo a investigar, los activos comprendidos, las preguntas que deben responderse, las autorizaciones aplicables y las condiciones para ampliar el trabajo.

El alcance inicial puede expresarse mediante preguntas operativas. En un posible acceso indebido: ¿qué cuentas se utilizaron?, ¿qué sistemas registraron la actividad?, ¿qué recursos fueron consultados o modificados?, ¿existen rastros de persistencia?, ¿qué intervalos presentan lagunas? Estas preguntas orientan las búsquedas y permiten justificar la obtención de cada fuente.

También deben definirse los límites de actuación. El acceso a dispositivos de terceras personas, sistemas fuera de la organización, datos especialmente sensibles o recursos administrados por proveedores puede requerir autorizaciones específicas. Si durante la investigación aparece información ajena al objeto acordado, el analista no debería ampliar el examen de forma unilateral. Debe documentar la circunstancia y solicitar las instrucciones pertinentes a quien tenga competencia.

El encargo debe prever, cuando sea posible, los criterios de cierre: qué hechos podrán considerarse suficientemente examinados, qué limitaciones obligarán a emitir una conclusión parcial y quién recibirá el informe. Un trabajo sin alcance ni condiciones de finalización corre el riesgo de transformarse en una búsqueda indefinida de información, con costes y riesgos crecientes.

1.4.13. Preservar antes de interpretar

La identificación de una fuente relevante suele ir acompañada de medidas de conservación. Un error frecuente consiste en explorar directamente el sistema hasta encontrar algo interesante y solo después preocuparse por preservar los datos. Esta práctica puede alterar marcas temporales, activar sincronizaciones, modificar cachés o perder información volátil durante el examen.

La estrategia de preservación depende del entorno. En un soporte desconectado puede resultar adecuado trabajar mediante mecanismos que impidan escrituras no autorizadas y crear una adquisición verificable. En un sistema activo puede ser necesaria una recogida controlada de datos volátiles. En una plataforma remota, la conservación podría consistir

en una exportación de registros, una instantánea o una solicitud al proveedor, siempre dentro de las facultades existentes.

La finalidad es mantener una referencia fiable sobre la que puedan realizarse análisis posteriores y evitar modificaciones innecesarias del material original. No todos los entornos permiten una copia bit a bit, y no toda investigación requiere esa profundidad. Debe explicarse qué se preservó, cómo se preservó, qué quedó fuera y qué cambios inevitables produjo el procedimiento.

Las recomendaciones de ISO/IEC 27037 y SWGDE sobre la recogida de evidencia digital insisten en la planificación, en la identificación de elementos y en el mantenimiento de su integridad durante el tratamiento [1], [11]. El valor de estas pautas aumenta cuando se integran en procedimientos conocidos antes de que aparezca una emergencia. Improvisar una herramienta, un formato de copia o una política de custodia durante una crisis introduce riesgos evitables.

1.4.14. La obligación de documentar

La documentación permite que otra persona reconstruya el trabajo realizado. Debe incluir la identificación del caso, el alcance, los responsables, las fuentes, las fechas, las acciones ejecutadas, los medios utilizados, las incidencias observadas y los resultados. El nivel de detalle debe ser suficiente para comprender el procedimiento, no simplemente para demostrar que se generaron muchas páginas.

Las anotaciones contemporáneas son especialmente valiosas. Si un analista advierte que un servidor tiene el reloj desajustado, debe registrar el dato mientras puede comprobarlo. Si una adquisición produjo errores de lectura, debe conservar el detalle de esos errores. Si una herramienta se ejecutó con un parámetro excepcional, es preferible documentarlo en ese momento antes de intentar reconstruir la decisión semanas después.

También es necesario registrar los resultados negativos relevantes. Si una búsqueda no encontró el artefacto esperado, conviene señalar la fuente examinada, el periodo y el criterio utilizado, en especial cuando la ausencia influya en una conclusión. No todas las consultas fallidas merecen incorporarse al informe final, pero las notas del caso deben permitir evaluar qué se intentó y por qué.

La documentación debe distinguir los hechos de las decisiones del investigador. «Se exportaron registros comprendidos entre dos fechas» describe una operación. «Se seleccionó ese intervalo porque coincide con la actividad sospechosa registrada en la alerta inicial» aporta la justificación. Ambas informaciones son importantes. Sin la segunda, otra persona podría

interpretar erróneamente una selección legítima como si fuera una omisión deliberada de periodos anteriores.

1.4.15. Competencia profesional y validación de herramientas

La calidad del análisis depende en parte de la competencia de quien lo realiza. Un profesional puede tener amplia experiencia en Windows y necesitar apoyo especializado para examinar un sistema industrial o un dispositivo móvil reciente. Reconocer los propios límites es una condición de responsabilidad, no una debilidad. La actuación debe adecuarse a la formación y a las capacidades técnicas disponibles.

Las herramientas requieren una atención semejante. Es necesario conocer qué formatos reconocen, qué operaciones realizan, qué versiones están validadas para una tarea y qué errores conocidos pueden afectar al resultado. El hecho de que una aplicación sea popular o utilizada en laboratorios no implica que todas sus funciones sean infalibles. Cuando un hallazgo es decisivo, el analista debería revisar los datos que lo sustentan y contrastarlo mediante otros medios razonables.

La validación no tiene por qué consistir en repetir todas las pruebas del fabricante en cada investigación. Puede apoyarse en procedimientos de laboratorio, casos de prueba conocidos, documentación técnica, comprobaciones de consistencia y revisión de resultados. Lo importante es demostrar que el método es adecuado para el propósito y que las limitaciones relevantes se conocen. La ISO/IEC 27041 aborda precisamente la adecuación de los métodos a la finalidad de la investigación [2].

También deben registrarse cambios de herramientas y entornos cuando puedan afectar a la interpretación. Una actualización puede modificar cómo se clasifican artefactos, cómo se convierten las fechas o qué formatos se reconocen. Un resultado generado con una versión no siempre será idéntico al obtenido con otra. Documentar esos detalles facilita la revisión y evita atribuir a los datos diferencias creadas por el software.

1.4.16. Independencia, confidencialidad y protección de datos

El analista tiene acceso potencial a información sensible. Puede encontrar datos de salud, comunicaciones personales, credenciales, secretos empresariales y datos de personas que no participan en el caso. Su responsabilidad no termina en evitar fugas intencionadas: también debe impedir exposiciones accidentales durante el almacenamiento, intercambio, presentación o publicación de resultados.

Las evidencias deben custodiarse con controles apropiados de acceso, cifrado cuando proceda, registro de operaciones y separación entre material del caso y entornos de uso general. Las copias de trabajo no deberían circular por canales improvisados si existe una alternativa segura. Tampoco es recomendable incorporar contraseñas, claves o contenido personal irrelevante a un informe distribuido a múltiples destinatarios.

La minimización exige valorar qué parte de un conjunto de datos es necesaria para responder la pregunta investigada. Este principio resulta especialmente importante cuando se examinan buzones, historiales de navegación, teléfonos o plataformas de colaboración. El uso de filtros y la segregación del contenido irrelevante pueden reducir exposición, aunque deben diseñarse de forma que no comprometan la trazabilidad ni oculten información necesaria para interpretar los hallazgos.

La independencia profesional supone mantener una relación honesta con el solicitante. Si una hipótesis queda descartada, debe indicarse. Si hay resultados inciertos, deben presentarse como tales. Si el encargo exige una conclusión que los datos no respaldan, el analista no debe adaptarla a las expectativas de quien paga el trabajo. La credibilidad del informe depende de que sus resultados respondan a la evidencia, no a un interés preestablecido.

1.4.17. Comunicar con precisión a públicos diferentes

Un informe técnico puede necesitar explicar estructuras del sistema de archivos, identificadores de sesión, consultas a registros y parámetros de herramientas. Sin embargo, si el destinatario no domina esos conceptos, un documento lleno de jerga puede dificultar la comprensión de los hallazgos. La solución no consiste en eliminar la profundidad técnica, sino en organizarla adecuadamente.

Una práctica útil consiste en distinguir el resumen de hallazgos, la explicación de su significado y el detalle metodológico que permite verificarlos. El destinatario debe poder comprender qué ocurrió según la información disponible, qué nivel de confianza merece cada conclusión y cuáles son las limitaciones. A su vez, otro profesional debería poder identificar las fuentes y operaciones necesarias para revisar el análisis.

La precisión del lenguaje evita confusiones relevantes. «Se observó una autenticación correcta» expresa un evento técnico. «Se confirmó la identidad del usuario» introduce otra afirmación. «Se transfirieron datos a un servicio remoto» puede describir una transferencia verificada; «se robaron datos» incorpora una calificación que requiere mayor contexto y puede exceder la competencia técnica del informe. Elegir las palabras adecuadas constituye una parte del método, no una cuestión meramente estilística.

Las recomendaciones de SWGDE sobre informes forenses subrayan la necesidad de identificar el propósito, los elementos examinados, los procedimientos, los resultados y la base de las conclusiones, así como el destino de las evidencias [12]. El capítulo dedicado a la elaboración de informes desarrollará estos elementos y la forma de presentarlos tanto en contextos técnicos como periciales.

1.4.18. Una investigación completa vista desde sus fuentes

Consideremos un caso ficticio que reúne muchos de los elementos presentados. Una pequeña organización detecta el uso de una cuenta administrativa para consultar un repositorio documental desde un origen no habitual. Horas después se registran cambios de permisos y una transferencia de datos hacia un servicio externo. El equipo de seguridad sospecha que alguien obtuvo acceso mediante credenciales comprometidas.

El investigador comienza por las fuentes con mayor riesgo de pérdida: eventos del proveedor de identidad, registros de la aplicación, auditoría de cambios, actividad de API y telemetría de red. Paralelamente se identifican los dispositivos desde los que se administraba habitualmente la cuenta. Antes de acceder a ellos se comprueba el alcance de las autorizaciones, especialmente si alguno contiene información personal o se encuentra fuera del control directo de la organización.

Los registros de identidad indican una autenticación desde una ubicación inesperada. Este hallazgo no demuestra por sí solo que la cuenta haya sido robada, porque podría existir una VPN o un desplazamiento legítimo. El historial de cambios muestra una modificación de permisos realizada mediante un token asociado a la misma cuenta. Una auditoría de almacenamiento identifica la descarga de objetos concretos. La relación técnica se fortalece si los identificadores de sesión y de operación permiten conectar los eventos.

La investigación examina entonces los sistemas desde los que se accedía normalmente al servicio. En uno aparece un mensaje de correo fraudulento recibido antes de la actividad sospechosa. El contenido podría ser compatible con una campaña de robo de credenciales, pero su mera presencia no demuestra que el usuario lo abriera ni que proporcionara sus datos. Se necesitarían rastros adicionales, como actividad del navegador, registros de autenticación y datos del proveedor, para evaluar esa hipótesis.

Supongamos que, tras correlacionar las fuentes, se comprueba que un token fue emitido después de una autenticación desde un origen inusual y se utilizó para cambiar permisos y descargar documentos. La investigación puede concluir que se produjo una secuencia de

operaciones administrativas no reconocidas y que determinados objetos fueron descargados. Si no se dispone de evidencia suficiente para identificar a la persona que controlaba el token, esa limitación debe permanecer explícita.

El equipo de respuesta puede revocar credenciales, restringir sesiones y revisar otros accesos. La organización puede evaluar notificaciones o acciones jurídicas según la normativa aplicable. El analista, por su parte, conserva los registros, documenta la metodología y explica las relaciones observadas. Las funciones se coordinan, pero no se confunden: investigar hechos técnicos, restaurar la seguridad y determinar responsabilidades son tareas vinculadas y distintas.

Este caso muestra además por qué es arriesgado depender de una sola fuente. El registro del proveedor de identidad permite observar una autenticación; la auditoría de la aplicación muestra una acción administrativa; el repositorio registra operaciones sobre documentos; el correo ofrece una posible vía de acceso inicial. Ninguna pieza aislada cuenta toda la historia. El trabajo forense consiste en ensamblarlas sin inventar los fragmentos que faltan.

1.4.19. Los principios que sostienen la práctica profesional

Las herramientas y plataformas cambiarán durante la vida útil de este libro. Algunos formatos desaparecerán, las técnicas de adquisición evolucionarán y nuevos entornos generarán evidencias que hoy no existen. Sin embargo, las exigencias esenciales del trabajo forense presentan mayor estabilidad.

Investigar requiere partir de preguntas claras y no de acusaciones preconcebidas. Preservar exige comprender cómo una intervención puede modificar o destruir información. Examinar obliga a conocer el mecanismo que genera cada artefacto. Interpretar supone separar los hechos observados de las hipótesis y admitir explicaciones alternativas. Documentar permite que otras personas revisen el trabajo. Comunicar exige expresar con exactitud los hallazgos y sus límites.

Estos principios pueden parecer sencillos, pero aplicarlos de forma consistente resulta difícil cuando el tiempo es escaso, los datos son incompletos o el resultado esperado ejerce presión. La formación técnica proporciona herramientas para extraer información; la disciplina forense enseña cuándo esa información permite afirmar algo y cuándo debe mantenerse la duda.

Una investigación puede ser pequeña y rigurosa. También puede ser extensa y metodológicamente débil. La diferencia no reside en el número de equipos examinados ni en el volumen del informe. Reside en la correspondencia entre las preguntas formuladas, la calidad de las evidencias, la corrección de los métodos y la prudencia de las conclusiones.

1.5. De las huellas digitales a los hechos demostrables

Al comenzar este capítulo planteamos una pregunta: ¿qué ocurrió realmente y qué datos permiten sostener una explicación verificable? Después de examinar los fundamentos, los contextos de investigación y las fuentes disponibles, la respuesta puede formularse con más precisión. No basta con encontrar información relacionada con un suceso. Es necesario comprender qué representa, cómo se produjo, si se conserva de manera fiable y qué interpretación admite dentro del alcance autorizado.

La informática forense digital ocupa un espacio singular entre las disciplinas técnicas. Se apoya en el conocimiento profundo de sistemas y aplicaciones, pero también necesita capacidad de análisis, conciencia de sus límites y una forma de comunicar que no transforme las conjeturas en hechos. Su utilidad se manifiesta tanto cuando acredita una secuencia de acontecimientos como cuando demuestra que una acusación no está suficientemente respaldada.

El analista trabaja en un entorno donde abundan las huellas parciales. Un ordenador recuerda determinadas actividades y olvida otras. Un servicio registra lo que su diseño considera importante. Un sensor observa solo el tráfico que pasa por su posición. Una marca temporal indica un valor registrado por un reloj, no necesariamente un instante exacto del mundo real. Incluso la mejor herramienta opera sobre esas restricciones. La investigación consiste en reconocerlas, combinarlas razonadamente y mantener visible la distancia entre lo observado y lo inferido.

De aquí se desprende una regla que recorrerá toda la obra: **ninguna técnica debe aplicarse sin comprender qué conserva, qué altera y qué permite demostrar**. Adquirir una imagen, extraer un registro, reconstruir una cronología o analizar una muestra de malware son medios para responder preguntas. La fiabilidad de las conclusiones depende de usar esos medios de manera adecuada y documentada.

Los siguientes capítulos profundizarán en los métodos y estándares que hacen posible ese trabajo. Primero se estudiará cómo organizar una investigación y seleccionar procedimientos defendibles. Después se abordarán el marco jurídico, la preservación de la escena digital, la adquisición de evidencias y la preparación del laboratorio. Sobre esa base podrán examinarse sistemas operativos, memoria, redes, aplicaciones y entornos especializados sin perder de vista lo esencial: **el valor de una evidencia no depende de lo convincente que parezca, sino de lo que realmente permite demostrar**.

Referencias del capítulo

Las referencias siguientes constituyen fuentes técnicas y normativas de apoyo. Las normas ISO/IEC citadas pueden estar sujetas a licencia; las referencias a su objeto y alcance se basan en la información pública de sus organismos editores. Las menciones jurídicas son orientativas y no sustituyen el examen de la normativa vigente ni el asesoramiento especializado para un caso concreto.

[1] ISO/IEC. **ISO/IEC 27037:2012.** *Information technology — Security techniques — Guidelines for identification, collection, acquisition and preservation of digital evidence*. https://www.iso.org/standard/44381.html

[2] ISO/IEC. **ISO/IEC 27041:2015.** *Information technology — Security techniques — Guidance on assuring suitability and adequacy of incident investigative method*. https://www.iso.org/standard/44405.htm

[3] ISO/IEC. **ISO/IEC 27042:2015.** *Information technology — Security techniques — Guidelines for the analysis and interpretation of digital evidence*. https://www.iso.org/standard/44406.html

[4] Kent, K., Chevalier, S., Grance, T. y Dang, H. (2006). **NIST SP 800-86.** *Guide to Integrating Forensic Techniques into Incident Response*. National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-86

[5] España. **Ley de Enjuiciamiento Criminal**, artículos 588 sexies a y siguientes, en su redacción aplicable. Boletín Oficial del Estado. https://www.boe.es/buscar/act.php?id=BOE-A-1882-6036

[6] Unión Europea. **Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo**, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos (Reglamento General de Protección de Datos). https://eur-lex.europa.eu/eli/reg/2016/679/oj

[7] España. **Ley Orgánica 3/2018, de 5 de diciembre**, de Protección de Datos Personales y garantía de los derechos digitales. Boletín Oficial del Estado. https://www.boe.es/buscar/act.php?id=BOE-A-2018-16673

[8] Nelson, A., Rekhi, S., Souppaya, M. y Scarfone, K. (2025). **NIST SP 800-61 Rev. 3.** *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*. National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-61r3

[9] Brezinski, D. y Killalea, T. (2002). **RFC 3227 / BCP 55.** *Guidelines for Evidence Collection and Archiving*. RFC Editor. https://doi.org/10.17487/RFC3227

[10] Guttman, B., White, D. R., Williams, S. y Walraven, T. (2022). **NISTIR 8387.** *Digital Evidence Preservation: Considerations for Evidence Handlers*. National Institute of Standards and Technology. https://doi.org/10.6028/NIST.IR.8387

[11] Scientific Working Group on Digital Evidence (2025). **SWGDE 18-F-002-2.0.** *Best Practices for Digital Evidence Collection*. https://www.swgde.org/documents/published-complete-listing/18-f-002-2-0/

[12] Scientific Working Group on Digital Evidence (2018). **SWGDE 18-Q-002-1.0.** *Requirements for Report Writing in Digital and Multimedia Forensics*. https://www.swgde.org/documents/published-complete-listing/18-q-002-swgde-requirements-for-report-writing-in-digital-and-multimedia-forensics/

2. Metodologías y estándares de investigación

> "En el momento presente es demasiado fácil utilizar datos incompletos y un razonamiento imperfecto para llegar a cualquier conclusión que deseemos." ("At the present moment it is all too easy to use incomplete data and imperfect reasoning to reach any conclusion we wish.") — Isaac Asimov, Forward the Foundation (Hacia la Fundación), Parte 3: "Hari Seldon"
>
> NOTA: Hari Seldon está respondiendo a las presiones del general Tennar de la junta militar, quien pretendía forzar las conclusiones matemáticas hacia lo que al régimen le convenía.

La calidad de una investigación digital no se mide por el número de herramientas utilizadas ni por la cantidad de archivos recuperados. Se mide, ante todo, por la capacidad de responder a unas preguntas delimitadas mediante procedimientos técnicamente adecuados, legalmente autorizados y suficientemente documentados como para que una tercera persona competente pueda evaluar sus resultados. Una captura de memoria impecable puede carecer de utilidad si se obtuvo después de que el sistema fuese reiniciado; un informe de cientos de páginas puede resultar débil si confunde indicios con hechos demostrados; una conclusión correcta puede ser difícil de defender cuando no consta cómo se llegó a ella.

En el capítulo anterior se estableció que los datos digitales no constituyen una explicación automática de lo ocurrido. Son observaciones que necesitan contexto, interpretación y corroboración. Esa distancia entre la huella y la conclusión es, precisamente, el espacio que ocupa la metodología forense. Su función es reducir la improvisación, limitar los sesgos, conservar la integridad de las evidencias y hacer explícitos los motivos de cada decisión. **El método no sustituye al criterio profesional: lo obliga a ser justificable.**

El problema adquiere especial importancia cuando una investigación atraviesa distintos entornos. Un incidente puede comenzar con la autenticación de una cuenta en la nube, continuar mediante una sesión de navegador, afectar a una máquina virtual y terminar con la descarga de datos hacia un servicio externo. Es posible que cada fuente utilice formatos, relojes, mecanismos de retención y administradores diferentes. En ocasiones habrá acceso físico al dispositivo; en otras, solo existirá una API o una exportación proporcionada por un tercero. Pretender aplicar mecánicamente el mismo procedimiento a todas esas fuentes sería tan inadecuado como prescindir de un procedimiento común.

Este capítulo presenta un marco de trabajo para convertir una solicitud de investigación en un proceso controlado. Se abordarán la planificación y el alcance, las fases del trabajo forense, los principales estándares y recomendaciones internacionales, el contraste de hipótesis,

la reproducibilidad y la validación de resultados. Finalmente, se examinará la *preparación forense* o *forensic readiness*: las decisiones que una organización debe adoptar antes de sufrir un incidente si pretende investigar después con garantías. El objetivo no es memorizar una secuencia de pasos, sino comprender las decisiones que hacen que un examen sea fiable y defendible.

> **Principio metodológico:** toda decisión significativa de una investigación debería poder responder a tres preguntas: qué se decidió, por qué se decidió y qué consecuencias tuvo para la evidencia o para el alcance de las conclusiones.

2.1. Planificación y alcance de una investigación

2.1.1. La investigación comienza antes de abrir la primera evidencia

Es habitual imaginar al analista forense trabajando frente a una estación especializada, examinando una imagen de disco o reconstruyendo una línea temporal. Sin embargo, buena parte de la calidad de su trabajo se decide antes de que abra la primera herramienta. Una investigación que comienza con preguntas imprecisas suele terminar en una exploración sin límites claros. Una investigación que ignora sus restricciones de tiempo puede perder evidencias efímeras. Y una investigación cuyo fundamento de autorización no ha sido establecido puede generar problemas jurídicos o de confidencialidad independientemente de su calidad técnica.

La planificación consiste en transformar una sospecha, una alerta o un encargo en un conjunto de cuestiones verificables. No equivale a anticipar la respuesta. Consiste en definir qué se necesita averiguar, qué fuentes podrían aportar información, con qué permisos se cuenta y cuáles son las prioridades de conservación. Para ello se requiere una conversación inicial entre quien solicita la investigación, quienes administran los sistemas, el responsable de seguridad y, cuando corresponda, los asesores jurídicos o la autoridad competente.

Consideremos una empresa que comunica lo siguiente: «Creemos que un empleado se ha llevado información confidencial». Tal formulación mezcla un posible hecho —una transferencia o copia— con una atribución personal y una intención. El encargo necesita descomponerse. ¿Qué información se considera afectada? ¿Se ha confirmado su salida? ¿De qué sistema? ¿En qué intervalo? ¿Qué cuentas podían acceder? ¿Se sospecha una copia a una memoria externa, un correo, un repositorio remoto o una plataforma de colaboración? ¿La persona trabajaba desde un dispositivo corporativo o personal? ¿Cuál es el fundamento que permitiría examinar cada uno de esos entornos?

Las respuestas no determinan de antemano que haya existido una conducta indebida. Permiten construir un plan de búsqueda de evidencia. Por ejemplo, el objetivo «determinar si se descargaron documentos de un repositorio corporativo entre el lunes y el miércoles» es más preciso que «encontrar quién robó los datos». El primero puede orientar la revisión de registros de auditoría y descargas; el segundo corre el riesgo de convertir la investigación en una búsqueda retrospectiva de confirmación de una acusación.

Una buena definición del objeto incluye también la posibilidad de que la hipótesis inicial sea falsa. La ausencia de documentos en una carpeta puede deberse a una eliminación, pero también a un movimiento, un cambio de permisos, un error de sincronización o una vista mal configurada. Planificar significa reservar espacio para esas explicaciones alternativas, aunque a primera vista parezcan menos llamativas.

2.1.2. Del relato inicial a las preguntas investigables

En cualquier encargo conviene separar al menos cuatro elementos: el **relato recibido**, los **hechos inicialmente constatados**, las **preguntas pendientes** y las **hipótesis de trabajo**. Esa separación evita que una afirmación de un testigo, una alerta automática o una interpretación preliminar acaben reproduciéndose como si fueran hechos probados.

El relato recibido es lo que alguien comunica: «Han accedido a mi correo». Un hecho inicialmente constatado podría ser: «El proveedor registra una autenticación satisfactoria desde una dirección IP no reconocida por el titular». La pregunta investigable sería: «¿La sesión asociada a esa autenticación permitió acceder a mensajes y realizar operaciones sobre ellos?». Las hipótesis abarcarían, entre otras, un acceso no autorizado, el uso legítimo de una red o dispositivo diferente, una sesión delegada o un registro interpretado de manera incorrecta.

La diferencia puede parecer lingüística, pero es operativa. Si el analista parte de que la cuenta ha sido comprometida, podría concentrarse exclusivamente en rastros de exfiltración y dejar de revisar mecanismos de autenticación legítimos. Si parte de que existe una autenticación que debe ser explicada, buscará evidencias que puedan confirmar o descartar varios escenarios.

Las preguntas deben ser suficientemente concretas para orientar la recogida de datos y suficientemente abiertas para admitir resultados inesperados. Algunas preguntas frecuentes son: ¿se ejecutó un programa determinado?, ¿se estableció una sesión de acceso remoto?, ¿se copió un archivo?, ¿se modificaron permisos?, ¿se utilizó una credencial después de su revocación?, ¿qué secuencia temporal puede reconstruirse? Otras preguntas requieren una

cautela adicional: ¿quién estaba físicamente delante del equipo?, ¿por qué actuó de ese modo?, ¿a qué persona corresponde una dirección IP? Estas últimas pueden no ser resolubles solo con evidencia técnica.

Un criterio útil consiste en formular cada pregunta junto con una posible condición de contraste. «¿Se descargó el fichero X?» puede contrastarse mediante registros de acceso, respuestas de la API, trazas del cliente, metadatos del almacenamiento y, si existen, artefactos del dispositivo receptor. «¿Lo hizo la persona Y?» exige otras fuentes y puede permanecer abierto incluso cuando la descarga está demostrada. La precisión metodológica incluye reconocer desde el principio esa diferencia.

2.1.3. Objetivos, entregables y criterios de cierre

Una investigación necesita un objetivo operativo y un producto final. Los objetivos pueden ser distintos según el contexto. En una actuación judicial interesa conservar y examinar determinados soportes para responder a los extremos del encargo pericial. En una investigación corporativa se buscan hechos relevantes para una decisión interna, respetando sus límites de autorización y las garantías aplicables. Durante la respuesta a incidentes, la prioridad puede consistir en comprender un compromiso con rapidez suficiente para apoyar la contención sin destruir información relevante.

El entregable tampoco será siempre el mismo. Puede consistir en un informe pericial completo, un informe técnico de hallazgos, una cronología sustentada, un inventario de evidencias, un dictamen sobre la fiabilidad de un artefacto o una comunicación urgente para los responsables de respuesta. Es aconsejable acordar quién recibirá el resultado, qué grado de detalle necesita, si existirán entregas provisionales y qué información debe quedar reservada a anexos técnicos.

También conviene definir qué significará terminar. Una investigación no concluye necesariamente cuando se han explicado todos los aspectos de un suceso. Puede concluir cuando se han contestado las preguntas autorizadas, se han agotado razonablemente las fuentes disponibles y se han documentado las incertidumbres que permanecen. La diferencia es importante: la ausencia de certeza sobre un extremo no impide alcanzar resultados técnicamente útiles respecto a otros.

El cierre requiere distinguir entre una **conclusión negativa**, una **ausencia de hallazgo** y una **limitación de examen**. «No se encontró un registro de eliminación» significa que no se identificó ese artefacto en lo examinado. No equivale a «se demostró que no hubo eliminación». Si el sistema rota los registros cada siete días y la incidencia ocurrió hace un mes, la limitación de retención debe aparecer expresamente en el informe. Un criterio de cierre razonable

no impone resultados; fija las condiciones para reconocer cuándo la evidencia disponible ya no permite avanzar de modo justificado.

2.1.4. Alcance técnico: sistemas, datos, periodos y operaciones

El alcance delimita el espacio dentro del cual el analista puede trabajar. Habitualmente tiene dimensiones organizativas, técnicas, temporales y jurídicas que conviene documentar por separado. En lo organizativo, se identifican los responsables de los sistemas, las personas autorizadas a solicitar acciones y los destinatarios de la información. En lo técnico, se determina qué dispositivos, cuentas, máquinas virtuales, servicios, aplicaciones o registros pueden examinarse. En lo temporal, se establece la ventana investigada y el margen necesario para reconstruir antecedentes y consecuencias. En lo jurídico, se concreta la fuente de autorización y las limitaciones que impone.

Supongamos que la petición autoriza revisar la actividad de una cuenta corporativa durante una semana. El alcance no se amplía automáticamente a todo el correo de su titular, a los documentos personales almacenados localmente ni a servicios externos que utilicen las mismas credenciales. Puede ser técnicamente posible acceder a datos que queden fuera del encargo; esa posibilidad no convierte su examen en necesario ni autorizado. Si aparecen indicios que justifican una ampliación, deberá valorarse y aprobarse por el cauce correspondiente antes de proceder, salvo situaciones excepcionales que tengan fundamento propio y deban quedar documentadas.

Las ventanas temporales exigen atención especial. Un incidente descubierto el viernes puede haberse iniciado el lunes anterior; un mecanismo de persistencia puede haberse instalado meses antes; una modificación de archivo puede reflejar una sincronización posterior al hecho. Por ello es útil distinguir la *ventana principal* —el intervalo que interesa investigar— de una *ventana de contexto* limitada, destinada a establecer líneas de referencia, antecedentes o continuidad temporal. Ambas deben justificarse y estar sometidas a criterios de minimización.

En sistemas distribuidos, las fronteras técnicas raramente coinciden con las administrativas. Un servidor puede pertenecer a una empresa, alojarse en infraestructura de un tercero, autenticarse contra un proveedor de identidad y registrar sus eventos en una plataforma externa. Identificar quién controla cada dato y quién puede autorizar su acceso es una tarea de planificación, no una formalidad que pueda posponerse hasta el momento de descargarlo.

2.1.5. Alcance dinámico y control de cambios

No es razonable exigir que toda fuente relevante sea conocida al principio. La propia investigación puede descubrir servicios, cuentas, equipos o periodos que no figuraban en el planteamiento inicial. El método debe permitir cambios, pero no cambios invisibles. Una ampliación de alcance requiere registrar el hallazgo que la motivó, el nuevo objeto propuesto, su relación con las preguntas originales, la autoridad que la aprueba y las posibles consecuencias para tiempo, recursos y confidencialidad.

Pensemos en un caso iniciado sobre un equipo Windows. Los registros muestran que la cuenta investigada utilizó una aplicación de almacenamiento remoto. Examinar el servicio podría ser decisivo, pero no estaba incluido en el encargo. Una actuación correcta separa tres acontecimientos: descubrir una referencia al servicio en el equipo, solicitar la ampliación y, una vez autorizada, adquirir los datos del servicio. Esa trazabilidad permite que otra persona comprenda por qué la investigación terminó incluyendo una fuente inicialmente desconocida.

Una modificación también puede reducir el alcance. Si las primeras comprobaciones muestran que la aplicación atribuida a un dispositivo pertenece realmente a otro, persistir en el examen del primero puede ser desproporcionado. Documentar por qué se descarta una fuente es tan importante como justificar por qué se incorpora.

2.1.6. Autorización, proporcionalidad y minimización

El analista forense no debe equiparar acceso técnico con facultad legítima. Disponer de credenciales de administrador, de un agente EDR o de una copia de seguridad no autoriza por sí mismo cualquier búsqueda imaginable. La legitimidad depende del escenario, la titularidad de los sistemas, los contratos, los procedimientos internos, los derechos de las personas afectadas y, cuando proceda, las decisiones de una autoridad judicial. La aplicación concreta de estos elementos exige asesoramiento jurídico; este capítulo describe el principio operativo, no pretende sustituirlo.

La proporcionalidad consiste en ajustar la actuación a la finalidad perseguida y al impacto razonablemente previsible. Si el objetivo es determinar si una cuenta accedió a una carpeta específica, puede ser suficiente examinar eventos de acceso y permisos. Una adquisición íntegra del ordenador, que incluye documentos ajenos a la investigación, quizá sea innecesaria o deba justificarse especialmente. La minimización busca evitar la recogida y exposición de información irrelevante. Ambas decisiones deben equilibrarse con la necesidad de preservar datos efímeros que, si se pierden, no podrán recuperarse después.

Existe una tensión legítima entre preservar ampliamente y examinar de forma limitada. En determinadas circunstancias puede estar justificada una conservación más amplia para evitar la desaparición irreversible de datos, acompañada de restricciones severas en su acceso, análisis y divulgación. No debe confundirse esa posibilidad con una autorización genérica para revisar todo el contenido preservado. La política concreta deberá fundamentarse en las competencias legales del caso y quedar reflejada en el plan.

También se considera desde el principio la presencia de información especialmente protegida, secretos profesionales, comunicaciones privadas, datos personales de terceros o información sometida a confidencialidad contractual. Su posible aparición puede exigir filtrados, segregación de funciones, autorizaciones adicionales o revisión jurídica previa. El investigador debe conocer estos límites antes de que un resultado potencialmente relevante termine incorporado inadvertidamente a un informe de amplia distribución.

2.1.7. Evaluación inicial de riesgos y prioridades

Una investigación forense es también una gestión de riesgos. Algunos riesgos afectan a la evidencia: pérdida por apagado, sobrescritura de registros, caducidad de sesiones, cambios producidos por el propio analista o indisponibilidad de un proveedor. Otros afectan a las personas y a la organización: interrupción de servicios críticos, expansión de un compromiso, exposición de datos personales o retrasos en obligaciones de comunicación. Hay además riesgos metodológicos: escoger una herramienta no probada, trabajar con una versión incompatible o interpretar timestamps sin conocer la zona horaria.

No basta con elaborar una lista. Conviene relacionar cada riesgo con una decisión concreta. Si una máquina virtual comprometida conserva únicamente registros en memoria, la prioridad puede ser adquirirlos antes de detenerla. Si mantiene una conexión activa hacia un atacante, el riesgo de propagación puede aconsejar aislarla inmediatamente, aunque se pierda parte de la información volátil. Si controla un proceso industrial, una decisión abrupta podría producir daños superiores a los que se pretende evitar. En cada escenario cambian las condiciones; no existe una secuencia universal e invariable.

La priorización puede representarse mediante una matriz sencilla que considere impacto, volatilidad, accesibilidad y coste de intervención. La matriz no sustituye al juicio profesional ni debe convertirse en una fórmula automática. Sirve para explicitar los factores examinados. En particular, la dificultad de adquirir una evidencia no determina por sí sola su valor: a veces una fuente fácil de recoger es decisiva, y otras una adquisición costosa apenas añade información a lo que ya está demostrado.

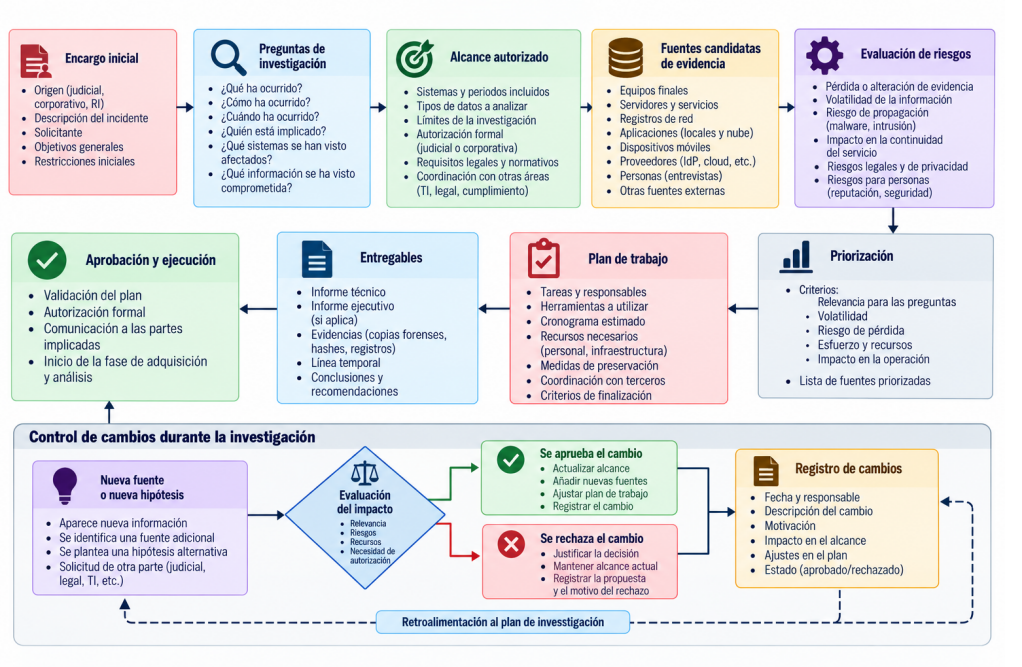


Figura 8: Planificación de una investigación

2.1.8. El plan de investigación como documento vivo

El plan inicial no necesita ser un documento extenso. Sí debe ser concreto. Es útil que incorpore el identificador del asunto, la persona o entidad solicitante, los objetivos, la autorización, las fuentes previstas, las restricciones, las responsabilidades, las prioridades de adquisición, las herramientas principales y el criterio de comunicación de incidencias. En actuaciones complejas se añaden ventanas de mantenimiento, dependencias con proveedores, normas de transferencia de evidencias y mecanismos de revisión.

Puede redactarse en lenguaje natural, siempre que permita verificar las decisiones. Una formulación del tipo «examinar los equipos afectados y elaborar informe» es demasiado vaga. En cambio, un plan que diga «preservar los eventos de autenticación del proveedor durante el periodo autorizado; adquirir los registros de actividad de la aplicación; contrastar ambos conjuntos usando identificadores de sesión; evaluar la actividad realizada por los tokens asociados; comunicar inmediatamente cualquier evidencia de acceso activo no autorizado» tiene un alcance operativo comprensible.

El plan debe mantener una distinción clara entre lo previsto y lo realmente ejecutado. Durante la investigación surgirán incidencias: un soporte no estará disponible, una API rechazará

determinadas consultas, un archivo resultará corrupto o una ventana de retención será menor de la esperada. El expediente final deberá mostrar esas diferencias. No se trata de ocultar desviaciones para que el trabajo parezca perfecto, sino de permitir que se comprenda qué se hizo de verdad y qué limitaciones provocó cada cambio.

2.1.9. Caso conductor: acceso sospechoso a un repositorio en la nube

Para seguir el capítulo utilizaremos un supuesto ficticio. Una empresa detecta que, a las 03:14, una cuenta con acceso a un repositorio documental inició sesión desde una dirección IP inusual. Al día siguiente, el propietario del repositorio observa que una carpeta contiene menos archivos. El equipo de seguridad recibe un aviso de autenticación anómala y solicita una investigación preliminar. La cuenta pertenece a una persona que trabaja en remoto y utiliza habitualmente varios dispositivos.

La alarma inicial plantea tres preguntas diferentes: si la autenticación fue legítima, qué operaciones se ejecutaron durante la sesión y qué explica la ausencia aparente de archivos. Ninguna exige presuponer un robo. El primer plan contempla los registros del proveedor de identidad, la auditoría del repositorio, los eventos de la aplicación y, si existe autorización, los artefactos del dispositivo corporativo. Las hipótesis incluyen acceso no autorizado, operación legítima, sincronización defectuosa, cambio de permisos y movimiento de documentos.

Hay dos datos temporales que requieren precaución. La marca de las 03:14 podría estar expresada en UTC o en una zona local y no tiene por qué corresponder al mismo reloj que utilizó el sistema de alertas. Además, el descubrimiento al día siguiente no indica cuándo dejaron de mostrarse los archivos. El plan incorpora una ventana de contexto anterior y posterior al aviso y obliga a conservar las marcas temporales originales antes de normalizarlas.

Al revisar el servicio, los investigadores descubren que los registros detallados de descargas se conservan solo durante un periodo limitado. La prioridad de preservarlos aumenta. Sin embargo, el acceso al dispositivo personal que a veces utiliza el titular no está autorizado; por tanto, no se incluye por el mero hecho de ser potencialmente útil. Este ejemplo acompañará la discusión sobre fases, validación y preparación forense, mostrando cómo un mismo caso puede evolucionar sin perder sus límites metodológicos.

2.2. Fases del proceso forense

2.2.1. Un modelo de proceso, no una cadena rígida

Los modelos de investigación digital suelen describir actividades como identificar, recoger, adquirir, preservar, examinar, analizar, interpretar y comunicar. Resulta útil agruparlas porque cada una tiene una finalidad y produce documentación diferente. Sin embargo, la práctica raramente presenta fronteras perfectas. El descubrimiento de un archivo durante el examen puede revelar una fuente adicional que debe preservarse. Una hipótesis descartada puede modificar la estrategia de análisis. Una dificultad técnica puede obligar a validar de nuevo una herramienta o a regresar a la planificación.

El proceso debe entenderse como un sistema de decisiones encadenadas y revisables. **Que las fases puedan repetirse no significa que puedan ejecutarse sin control.** Cada retorno a una etapa anterior tiene que conservar la trazabilidad de lo que se sabía en ese momento y de la razón del cambio. El expediente debe permitir reconstruir no solo la secuencia de hechos investigados, sino también la secuencia de decisiones investigadoras.

Las denominaciones varían entre publicaciones. La ISO/IEC 27037 pone el foco en la identificación, recogida, adquisición y preservación. La ISO/IEC 27042 aborda el análisis y la interpretación. La ISO/IEC 27043 proporciona una visión más amplia de la investigación de incidentes, incluida la preparación previa y el cierre. El modelo divulgado por NIST SP 800-86 integra las técnicas forenses en la respuesta a incidentes y diferencia actividades de recogida, examen, análisis e información de resultados. Sus propuestas resultan compatibles a nivel conceptual, aunque no deben presentarse como si fueran un procedimiento literal único o una certificación automática de calidad.

Para organizar el trabajo de este libro emplearemos una secuencia orientativa: **activación y preparación; identificación y priorización; recogida y adquisición; preservación y control de integridad; examen; análisis y contraste; comunicación; cierre y conservación**. La preservación no comienza después de adquirir, ni termina cuando empieza el análisis. Es una condición transversal que acompaña toda la vida de la evidencia. La documentación, el control de acceso y la revisión técnica también están presentes desde el primer momento.

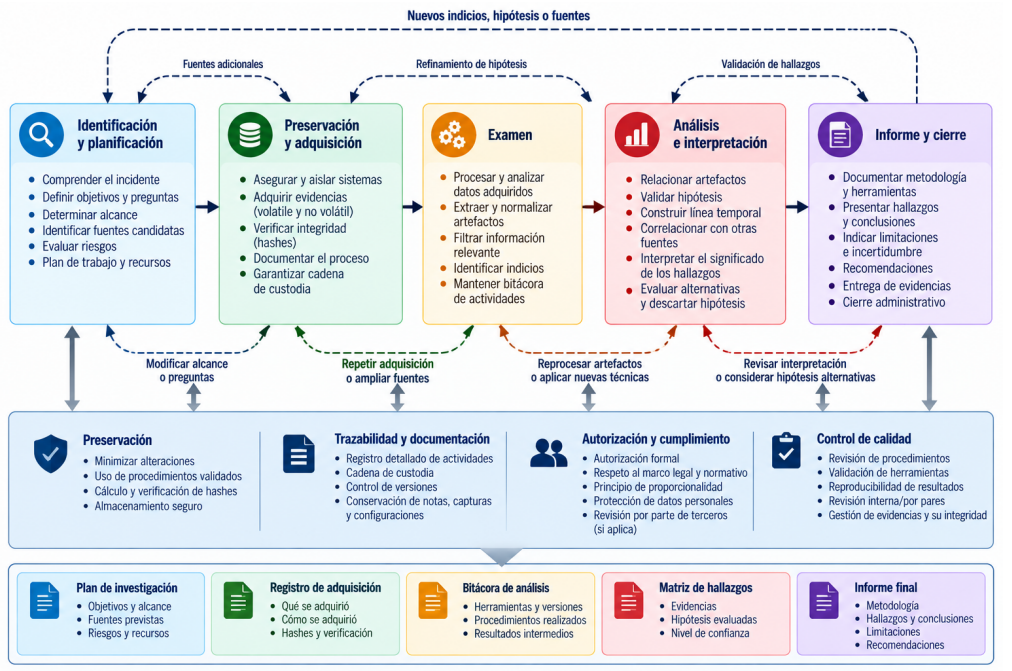


Figura 9: El proceso forense

2.2.2. Activación, recepción del encargo y preparación inmediata

El proceso se activa por una denuncia, un requerimiento pericial, una alarma de seguridad, una sospecha interna o la necesidad de examinar una anomalía técnica. La primera decisión consiste en establecer la naturaleza de la solicitud y el marco de actuación. Deben identificarse las personas responsables, la información disponible, el riesgo de pérdida de datos y los límites de autorización. En una intervención urgente, esta actividad puede completarse inicialmente con una conversación registrada y ampliarse después, pero la urgencia no convierte el alcance en ilimitado.

Desde el primer contacto deben preservarse los datos que podrían desaparecer antes de que finalice la planificación. Una organización con registros de corta retención puede necesitar exportarlos de inmediato. Un sistema encendido con cifrado activo puede requerir valorar la captura de memoria o de metadatos volátiles antes de apagarlo. Si existe una intrusión en curso, la respuesta debe coordinar la preservación con las medidas de contención. Algunas decisiones serán irreversibles; por eso es especialmente importante documentar quién las tomó y sobre qué información se apoyó.

En esta fase se crean los primeros identificadores del caso y de las evidencias. Conviene que el identificador sea único, estable y utilizable en nombres de archivos, formularios, etiquetas y comunicaciones. También se designan espacios seguros para recibir datos y se evita que las pruebas terminen repartidas entre carpetas personales, correos sin control y dispositivos extraíbles no inventariados. Aunque todavía no se haya adquirido ningún soporte, el expediente ya ha comenzado.

2.2.3. Identificación y localización de fuentes

Identificar una fuente no equivale a poseerla. Significa reconocer que un elemento podría contener información útil y determinar dónde se encuentra, de quién depende, cómo se accede a él y cuál es su riesgo de alteración o pérdida. Las fuentes pueden ser físicas —un ordenador, un teléfono, una unidad externa—, lógicas —un volumen, una cuenta, una base de datos— o distribuidas —una aplicación SaaS con datos y registros repartidos entre proveedores—.

La identificación exige construir un mapa técnico del escenario. En una aplicación corporativa, la actividad puede observarse parcialmente desde el navegador, el proveedor de identidad, la aplicación, una pasarela de API, el servicio de almacenamiento, el sistema de monitorización y el perímetro de red. Ninguna fuente ofrece necesariamente una vista completa. El proveedor de identidad puede registrar que una autenticación fue satisfactoria, pero no todas las operaciones ejecutadas después. La aplicación puede conocer la operación sobre un documento, pero no si quien controlaba la sesión era su titular legítimo. La memoria del dispositivo puede revelar actividad local, pero no el histórico que el servicio remoto ya ha eliminado.

Una herramienta práctica es la **matriz fuente-pregunta**. No se trata de recopilar todo lo accesible: se relaciona cada pregunta con las fuentes capaces de contrastarla y con las restricciones que presentan. Así, para conocer si un documento fue descargado podrían revisarse registros de acceso del repositorio, trazas de API, registros de proxy y artefactos del cliente. Una exportación parcial de logs o una retención vencida se anotan como limitaciones. La matriz ayuda a detectar dependencias ocultas, por ejemplo que todas las fuentes supuestamente independientes provengan en realidad de un mismo evento normalizado por un SIEM.

En el caso conductor, la alerta de acceso anómalo lleva a localizar cuatro fuentes principales: el proveedor de identidad, la auditoría del repositorio, los registros de la aplicación y el dispositivo corporativo. También se detecta que algunas descargas se realizan mediante tokens de API. Ese dato no demuestra una extracción, pero obliga a considerar registros

que inicialmente no estaban previstos. La incorporación a la adquisición se hará dentro del alcance autorizado o tras su ampliación documentada.

2.2.4. Recogida, adquisición y sus diferencias

En lenguaje cotidiano suelen confundirse *recoger* y *adquirir*. En el ámbito forense conviene diferenciarlos porque describen actividades y riesgos distintos. La **recogida** puede consistir en localizar, asegurar, trasladar o poner bajo control un dispositivo u otro elemento que contiene datos potencialmente relevantes. La **adquisición** implica obtener una representación de esos datos para su conservación y examen: una imagen de almacenamiento, una captura de memoria, una exportación de registros, una copia lógica o una extracción mediante una interfaz autorizada.

En una intervención sobre un ordenador apagado, puede recogerse físicamente el equipo y adquirir después una imagen de sus soportes en un laboratorio. En un servidor crítico, retirar la máquina quizá resulte inviable y la adquisición deba efectuarse de forma controlada en el propio entorno. En servicios en la nube, es frecuente que no exista acceso físico al soporte subyacente y que la única vía de adquisición sea una API, una instantánea gestionada o una exportación del proveedor. Son procedimientos con diferentes alcances, dependencias y grados de control.

Una adquisición física de un disco puede incluir sectores no asignados y metadatos internos del sistema de archivos, pero su cobertura estará limitada por las características del medio, las zonas inaccesibles, el cifrado, las herramientas y el estado del sistema. Una adquisición lógica copia determinados objetos y puede conservar propiedades relevantes, aunque no represente todos los sectores ni toda la información borrada. Una exportación de un servicio remoto depende de los datos que expone la plataforma, de los permisos utilizados, de los filtros aplicados y de los comportamientos de la API. Elegir un método implica aceptar un conjunto de posibilidades y limitaciones.

La idea de *no alterar nunca el original* expresa una aspiración de preservación, pero sería engañoso aplicarla sin matices a sistemas en funcionamiento. Leer determinados recursos puede producir registros, modificar tiempos de acceso o activar procesos auxiliares. Ejecutar una herramienta de adquisición de memoria modifica inevitablemente parte del estado volátil. En plataformas remotas, una llamada a la API puede generar auditoría adicional. El objetivo es utilizar procedimientos apropiados, reducir los efectos evitables y **documentar los cambios esperados o detectados**, no prometer una ausencia absoluta de intervención cuando técnicamente resulta imposible.

Siempre que sea posible se trabaja con copias de examen y se mantiene una referencia identificable del origen. Deben registrarse el método, la herramienta y versión, los parámetros, el intervalo de operación, el operador, los resultados, los errores y cualquier discrepancia relevante. Una colección parcial o defectuosa no se convierte en completa porque la herramienta haya mostrado un mensaje de éxito.

2.2.5. Preservación y continuidad de la evidencia

La preservación persigue mantener las propiedades relevantes de la evidencia y permitir que su origen, tratamiento y estado puedan explicarse. Abarca la protección física de los soportes, el control lógico de las copias, las condiciones ambientales cuando importan, la prevención de escrituras accidentales, la documentación de accesos y la política de conservación. No se reduce a calcular una suma hash.

La **cadena de custodia** documenta la posesión y las transferencias de los elementos de evidencia a lo largo del tiempo. Los **registros de tratamiento** describen qué operaciones técnicas se realizaron sobre ellos. Ambos mecanismos se complementan. Una cadena de custodia impecable no demuestra por sí sola que una imagen fue adquirida sin errores; una coincidencia de hashes no demuestra quién controló el dispositivo antes de la adquisición. La fiabilidad exige examinar conjuntamente procedencia, método y continuidad.

Los algoritmos hash criptográficos se utilizan para comprobar si dos conjuntos de bytes son iguales con una garantía práctica adecuada. Por ejemplo, calcular SHA-256 sobre un archivo adquirido y volver a calcularlo cuando se entrega a otro laboratorio ayuda a detectar modificaciones. Sin embargo, su interpretación tiene condiciones: hay que saber exactamente qué objeto se sometió a hash, si se trataron metadatos por separado, si un contenedor incluye información propia y si la adquisición omitió zonas no legibles. El mismo hash verificado en dos ocasiones confirma la continuidad de esos bytes entre verificaciones; no acredita por sí mismo que el origen fuese auténtico o que la extracción fuera exhaustiva.

En entornos de nube, la preservación puede incluir retenciones legales o administrativas, instantáneas, exportaciones versionadas y custodia de respuestas de API con sus metadatos. Debe registrarse si el proveedor genera internamente identificadores o hashes, y qué alcance tienen. Un ETag, una firma de servicio o un campo llamado `checksum` no deben tratarse automáticamente como si fueran un hash criptográfico del mismo objeto lógico que examina el investigador. Su semántica depende de la plataforma y del proceso que lo generó.

La preservación también alcanza la evidencia derivada. Cuando el analista convierte un registro binario a CSV, extrae una base SQLite o exporta resultados desde una herramienta, el

producto debe quedar vinculado a su origen mediante identificadores, rutas, procedimientos y, cuando proceda, hashes. Un informe que solo conserve capturas de pantalla de resultados seleccionados difícilmente permitirá repetir el análisis sin conocer las fuentes primarias.

2.2.6. Examen: extraer información sin adelantar conclusiones

El examen forense transforma los datos adquiridos en información accesible para su estudio. Incluye identificar particiones, interpretar sistemas de archivos, extraer metadatos, recuperar registros, reconstruir bases de datos, localizar artefactos, descodificar formatos y preparar conjuntos de eventos. Esta actividad puede ser automatizada en buena medida, pero los resultados deben revisarse bajo un criterio técnico explícito.

Una herramienta puede indicar que un archivo se ejecutó, que una URL fue visitada o que una memoria USB se conectó. Esas etiquetas resumen reglas de interpretación que pueden contener simplificaciones. La creación de un registro no siempre equivale a ejecución humana; la existencia de un enlace en un historial no siempre implica que una página se visualizase; una coincidencia de nombre no garantiza identidad de archivo. Durante el examen deben preservarse los datos subyacentes necesarios para valorar tales afirmaciones.

El examen incluye también el filtrado por relevancia, siempre dentro del alcance. No todo dato hallado debe analizarse en profundidad. Las búsquedas pueden combinar intervalos, rutas, usuarios, indicadores y tipos de artefacto. Conviene documentar los criterios para que otra persona sepa por qué ciertos elementos entraron en el conjunto examinado y otros quedaron fuera. Un filtro mal definido puede resultar tan perjudicial como una adquisición incompleta.

Los fallos tienen valor metodológico. Si una herramienta no consigue descodificar un artefacto, el analista debería identificar si se trata de corrupción, cifrado, versión no admitida, ausencia de componentes o comportamiento anómalo de la propia herramienta. No basta con omitir silenciosamente el archivo. Registrar el límite del examen impide que la ausencia de resultado sea interpretada como ausencia de evidencia.

2.2.7. Análisis: relacionar datos y reconstruir acontecimientos

El análisis comienza cuando el investigador trata de explicar qué significan los artefactos y cómo se relacionan con las preguntas planteadas. Puede estudiar cronologías, comparar sesiones, identificar patrones de autenticación, relacionar un proceso con una conexión de

red o contrastar la actividad observada con la configuración conocida de un sistema. La diferencia con el examen no es siempre una frontera temporal; es principalmente una diferencia de propósito: **el examen obtiene y organiza información; el análisis evalúa su significado**.

Un registro que indica una autenticación satisfactoria demuestra, dentro de las limitaciones del sistema de auditoría, que se produjo un evento de ese tipo. Para concluir que alguien accedió a un documento quizá sea necesario relacionarlo con una sesión concreta, una acción de aplicación y una respuesta del servicio. Para afirmar que hubo transferencia de contenido hará falta valorar qué registra realmente la plataforma: una solicitud iniciada, una respuesta entregada, un número de bytes transferidos o un objeto descargado de manera completa no son necesariamente equivalentes.

La correlación requiere conocer los relojes y los identificadores utilizados. Los registros pueden guardar UTC, zonas locales, tiempo Unix, marcas con precisión variable o tiempos de recepción distintos a los tiempos de origen. Antes de construir una línea temporal se debe conservar el valor original y documentar la conversión. Una marca con resolución de un segundo no permite ordenar con certeza dos eventos que ocurrieron dentro de ese mismo segundo si no hay otros datos que indiquen precedencia.

También deben reconocerse las dependencias entre fuentes. Un panel SIEM, una alerta del EDR y un informe semanal pueden utilizar el mismo evento inicial. Contarlos como tres pruebas independientes exagera la corroboración. Por el contrario, una entrada de auditoría del almacenamiento y un artefacto de descarga en el dispositivo cliente pueden aportar perspectivas más independientes sobre una operación. La fuerza de la correlación depende tanto de la coherencia como de la procedencia de cada dato.

El análisis se beneficia de registrar hipótesis rivales y de buscar evidencia capaz de refutarlas. En nuestro caso, el repositorio parece haber perdido archivos tras una autenticación inusual. Al contrastar registros, se descubre que una tarea de sincronización había movido parte de los documentos a otra ruta. El evento de autenticación sigue siendo relevante, pero ya no puede utilizarse como explicación automática de la desaparición. La investigación debe examinar ambas cuestiones por separado y evaluar si existe relación demostrable entre ellas.

2.2.8. Interpretación y valoración de límites

Interpretar significa traducir un conjunto de observaciones técnicas a afirmaciones cuya fuerza se corresponda con la evidencia. No todas las inferencias tienen el mismo nivel. «El servicio registró una llamada `DELETE` para el objeto X» es distinto de «el objeto X quedó

eliminado de forma irreversible». La primera puede proceder de un registro concreto; la segunda exige conocer el comportamiento del servicio, el resultado de la llamada, el versionado, las políticas de retención y las posibles copias existentes.

Del mismo modo, «la cuenta A inició sesión» no implica necesariamente «la persona titular de A actuó». Entre ambos enunciados intervienen la gestión de credenciales, el uso compartido, la delegación, el robo de tokens, el acceso físico al dispositivo y otros factores. La interpretación debe mostrar las transiciones entre observación, inferencia y conclusión, especialmente cuando el resultado puede tener consecuencias jurídicas o profesionales.

Una forma útil de redactar hallazgos combina cuatro elementos: la observación, la procedencia, su interpretación y una reserva explícita. Por ejemplo: «El registro de auditoría del servicio documenta tres operaciones de descarga asociadas al identificador de sesión S, entre las 03:16 y las 03:19 UTC. Dicho identificador corresponde a la autenticación de la cuenta A. El registro permite vincular operaciones y sesión, pero no identificar por sí solo a la persona que controlaba la cuenta». La reserva no debilita el hallazgo: evita atribuirle un significado que no puede sostener.

La valoración de limitaciones debe ser concreta. No aporta mucho escribir «las herramientas informáticas pueden cometer errores» si no se explica qué afectación tendría en el caso. Es preferible indicar que «el sistema conservó eventos de inicio de sesión, pero no el contenido de las respuestas de API», o que «la herramienta utilizada no soporta el formato de la base de datos en esta versión». Una limitación bien descrita muestra dónde termina el conocimiento disponible y permite planear nuevas verificaciones.

2.2.9. Informe, revisión y comunicación

El resultado de la investigación debe poder comunicarse a personas que no necesariamente comparten el conocimiento técnico del analista. Un buen informe no es una transcripción de comandos. Explica qué se solicitó, bajo qué condiciones se trabajó, qué fuentes se examinaron, con qué métodos, qué hallazgos se obtuvieron y qué conclusiones admiten. Los detalles de ejecución, hashes y registros completos pueden incorporarse en anexos o en el expediente técnico, sin sacrificar la inteligibilidad del cuerpo principal.

La revisión no debe limitarse a corregir el estilo. Es recomendable verificar la correspondencia entre conclusiones y evidencia, la integridad de las referencias, la coherencia de las fechas, el carácter adecuado de las herramientas y la presencia de limitaciones. En un laboratorio con varios profesionales, un segundo examinador puede reproducir pruebas seleccionadas o realizar una revisión técnica independiente. En equipos pequeños, también pueden

utilizarse listas de comprobación, pruebas automatizadas y muestreos sistemáticos, aunque conviene no confundirlos con una revisión realmente independiente.

Durante un incidente activo pueden necesitarse comunicaciones intermedias antes del informe final. Esas comunicaciones deben diferenciar claramente hechos confirmados, interpretaciones provisionales y acciones recomendadas. Una recomendación de contención puede ser urgente y razonable aun cuando no se conozca todavía toda la secuencia del ataque. Lo que no resulta aceptable es presentar como conclusión cerrada una evaluación preliminar solo porque se necesita tomar una decisión operativa.

2.2.10. Cierre, conservación y aprendizaje

El cierre incluye verificar que las preguntas del encargo han recibido una respuesta o que las razones de no responder están documentadas; inventariar los materiales conservados; registrar la disposición de soportes y copias; confirmar las autorizaciones de acceso y transferencia; y determinar los periodos de conservación aplicables. También implica asegurar que las versiones del informe queden identificadas. Si posteriormente aparece una corrección relevante, deberá emitirse una versión o adenda trazable, no sustituir silenciosamente la original.

La devolución o eliminación de materiales tiene consecuencias que deben regularse. Un soporte original puede requerir devolución al titular o depósito bajo custodia. Una copia forense puede permanecer sometida a una obligación legal de conservación. Determinados datos personales deben ser eliminados cuando ya no exista fundamento para conservarlos. Las reglas concretas dependen del procedimiento y del ordenamiento aplicable. El principio común es que el destino de la evidencia sea una decisión autorizada y documentada, no un efecto accidental de la limpieza de un directorio.

Por último, la investigación puede revelar problemas que no forman parte de sus conclusiones sobre el hecho investigado, pero sí del aprendizaje organizativo: ausencia de auditoría, desfases horarios, retención insuficiente, herramientas sin probar, cuentas sin inventario o falta de responsables para aprobar adquisiciones. Esas observaciones alimentan la preparación forense, que se abordará al final del capítulo. Una organización madura no espera al siguiente incidente para corregir deficiencias evidentes.

2.2.11. Ejemplo de secuencia documentada en el caso conductor

La investigación del repositorio permite observar las fases como un proceso iterativo. Al recibir la alerta, el responsable autoriza una preservación inicial de registros. Se identifican

los sistemas relacionados y se exportan las fuentes con retención corta. Durante el examen aparecen dos tipos de evento: una autenticación desde una IP inusual y un conjunto de operaciones de sincronización. El análisis muestra que las carpetas visibles cambiaron, pero los objetos continuaron almacenados con nuevos identificadores de ruta. Esta explicación debilita la hipótesis de eliminación manual sin resolver todavía el origen de la autenticación.

En ese punto se revisa el plan. La pregunta sobre desaparición de archivos queda razonablemente contestada mediante registros de movimiento y estado del almacenamiento. La pregunta sobre el inicio de sesión exige examinar otros indicadores, como el método de autenticación, el dispositivo registrado, las sesiones previas y los tokens derivados. Si los datos disponibles son insuficientes para identificar al operador humano, así se hará constar. No existe obligación metodológica de fabricar una respuesta completa allí donde las fuentes no permiten obtenerla.

La cronología del propio trabajo también será trazable: cuándo se solicitó la intervención, cuándo se exportaron los registros, quién autorizó cada fuente, qué consultas se realizaron, qué herramientas se usaron y cuándo se formularon o revisaron las hipótesis. Este doble registro —de los hechos investigados y de las actuaciones investigadoras— constituye una de las bases de una investigación reproducible.

2.3. Normas ISO/IEC, recomendaciones NIST y buenas prácticas SWGDE

2.3.1. Qué significa trabajar conforme a un estándar

La expresión «análisis forense conforme a estándares internacionales» se utiliza con frecuencia, pero puede significar cosas muy distintas. Una norma internacional es un documento desarrollado mediante un proceso de normalización y destinado a establecer requisitos, directrices o modelos de referencia. Una guía técnica aporta recomendaciones o buenas prácticas que pueden adoptarse según el contexto. Un procedimiento operativo es la traducción de esos principios a las condiciones de un laboratorio o una organización. La acreditación, cuando existe, es un reconocimiento formal de competencias o conformidad dentro de un alcance determinado. Ninguna de estas categorías debe confundirse con las demás.

Citar una norma en un informe no equivale a demostrar que se han aplicado sus principios. Para que la referencia tenga significado es necesario explicar qué procedimiento concreto se utilizó, qué registros lo respaldan y cómo se resolvieron las circunstancias particulares. Del mismo modo, seguir una guía no convierte automáticamente una evidencia en admisible

ante cualquier tribunal. La valoración jurídica depende del procedimiento, del contexto, de los derechos afectados y de la legislación aplicable.

La normalización aporta un lenguaje común y facilita la revisión del trabajo, pero no elimina la incertidumbre propia de los sistemas digitales. Una norma puede orientar sobre conservación y trazabilidad sin determinar cuál es la herramienta correcta para una versión reciente de un sistema operativo. Una guía puede describir la utilidad de las funciones hash sin garantizar que una adquisición concreta no haya sufrido omisiones. Una metodología profesional combina referencias generales, procedimientos propios probados y justificación específica del caso.

En este libro se utilizarán los documentos ISO/IEC para estructurar principios, las publicaciones NIST como referencia técnica y organizativa y las recomendaciones SWGDE para concretar prácticas habituales de adquisición, examen, pruebas de herramientas y elaboración de informes. Se citarán por su identificador y edición porque los contenidos evolucionan. Antes de aplicar cualquiera de ellos a un encargo real conviene comprobar la versión vigente y la normativa exigible en la jurisdicción correspondiente.

2.3.2. ISO/IEC 27037: identificación, recogida, adquisición y preservación

La **ISO/IEC 27037:2012** constituye una referencia central para el tratamiento inicial de evidencia digital potencial. Su ámbito comprende la identificación, recogida, adquisición y preservación. Estos conceptos son fundamentales porque las decisiones de los primeros momentos condicionan lo que podrá analizarse después. Una evidencia no adquirida antes de que expire su retención, o un soporte alterado sin documentación, puede dejar de ofrecer la información necesaria para responder a una pregunta.

La norma permite pensar en el ciclo inicial desde la perspectiva de las personas encargadas de tratar la evidencia. Antes de actuar deben comprender qué elementos pueden contener datos, qué condiciones presentan y qué acciones reducirían el riesgo de pérdida o alteración. En un escenario físico importan el estado del dispositivo, las conexiones, los periféricos y las condiciones de transporte. En un escenario lógico o remoto importan la autenticación, la configuración, los permisos, el estado del servicio y el método por el que se obtendrán los datos.

Su enfoque resulta especialmente útil al distinguir el hecho de asegurar un elemento del hecho de copiar sus datos. Una entidad puede quedar bajo custodia antes de que se examine técnicamente su contenido. En cambio, una API puede proporcionar una copia lógica sin que el investigador tenga acceso a la infraestructura donde reside la información original.

Las dos situaciones requieren una explicación de qué se ha preservado realmente y con qué garantías.

Las propiedades deseables de una actuación incluyen que pueda justificarse su pertinencia, que los procedimientos se adapten a las circunstancias y que se conserve un registro de acciones suficiente para valorar la fiabilidad de los resultados. La documentación no es un añadido burocrático: forma parte de la información que permite establecer continuidad y procedencia. El capítulo dedicado a adquisición profundizará en soportes, bloqueadores de escritura, formatos de imagen, memoria y captura remota; aquí interesa entender que todos esos mecanismos responden a un mismo principio metodológico.

La ISO/IEC 27037 no proporciona una receta universal para resolver investigaciones completas. No pretende desarrollar con el mismo nivel de detalle la correlación de eventos, el contraste de hipótesis o la interpretación de hallazgos. Esas actividades se relacionan más directamente con otras normas de la misma familia. Asignar correctamente el ámbito de cada referencia evita la práctica, demasiado frecuente, de atribuir a un solo estándar la totalidad del procedimiento.

2.3.3. ISO/IEC 27041: adecuación y garantía de los métodos

La **ISO/IEC 27041:2015** aborda una pregunta menos visible, pero decisiva: ¿cómo puede demostrarse que un método de investigación es adecuado para el objetivo que pretende cumplir? El uso de una herramienta conocida o de una técnica extendida no basta para responder. Hay que conocer las características de los datos, definir qué resultado se espera, evaluar las limitaciones del procedimiento y comprobar que su implementación funciona de manera suficientemente fiable en el escenario previsto.

La noción de que un método debe ser *apto para su finalidad —fit for purpose—* introduce una exigencia de proporcionalidad técnica. Una técnica que sirve para recuperar archivos simples quizá no sea adecuada para interpretar un sistema de archivos cifrado. Un extractor de eventos probado sobre una versión anterior de una aplicación puede fallar ante un cambio de esquema. Una exportación mediante API puede ser precisa para determinadas operaciones y, al mismo tiempo, incapaz de recoger eventos ya eliminados del servidor.

La adecuación se analiza comparando requisitos y capacidades. Si el encargo requiere determinar el instante de una operación con precisión de milisegundos, una fuente que registra únicamente minutos no satisface esa necesidad por sí sola. Si se quiere verificar la eliminación de un objeto, hay que comprobar que el registro utilizado distingue entre solicitud, autorización, ejecución y resultado. Si se pretende analizar un contenedor forense, debe

probarse que la herramienta interpreta correctamente sus segmentos, metadatos y posibles errores.

La 27041 es especialmente relevante cuando se usan scripts propios, herramientas nuevas o procedimientos no tradicionales. Estos métodos no deben descartarse automáticamente, pero requieren evidencias de funcionamiento. Se pueden crear conjuntos de datos con resultados conocidos, ejecutar pruebas controladas, comparar salidas con implementaciones independientes y conservar los informes de ensayo. El nivel de prueba debería corresponder al riesgo de una interpretación incorrecta: no demanda lo mismo un visor auxiliar que un programa cuyos resultados sustentan la conclusión central de un peritaje.

En un informe, la justificación metodológica no necesita reproducir toda la documentación de ingeniería de una herramienta, pero sí debe permitir entender por qué se consideró adecuada. Una frase como «se empleó la herramienta X, versión Y, cuya compatibilidad con el formato Z fue comprobada mediante un conjunto de referencia» tiene mayor valor que una referencia genérica a «software profesional». Si hubo una función no validada o un resultado anómalo, debe indicarse y evaluarse su impacto.

2.3.4. ISO/IEC 27042: análisis e interpretación

La **ISO/IEC 27042:2015** dirige la atención al análisis y la interpretación de la evidencia digital. Se ocupa de cuestiones como continuidad, validez, repetibilidad, reproducibilidad y registro suficiente para permitir un examen independiente. Su aportación principal es recordar que extraer datos no equivale a interpretarlos correctamente. Entre un registro y una conclusión intervienen conocimientos sobre el funcionamiento del sistema, reglas de inferencia y decisiones que deben poder explicarse.

Por ejemplo, un fichero con determinado nombre puede aparecer en una carpeta temporal. La observación directa puede estar clara, pero su significado depende de cómo lo crea la aplicación, cuándo lo modifica y qué circunstancias producen artefactos semejantes. Si el analista desconoce estos mecanismos, puede convertir un dato verdadero en una afirmación falsa. La validez del análisis exige demostrar que el significado atribuido al artefacto está respaldado por comportamiento conocido o por pruebas específicas.

La norma también resulta útil cuando existen varias técnicas posibles. Dos herramientas pueden extraer campos distintos del mismo archivo, trabajar sobre versiones diferentes o representar de otra forma los tiempos. No basta con elegir la salida más favorable a una hipótesis. Hay que analizar la discrepancia, identificar posibles causas y justificar cuál es la interpretación técnicamente más fundada. Las divergencias entre métodos no son siempre

un inconveniente; pueden revelar limitaciones que pasarían desapercibidas si se utilizara una sola herramienta.

El examen independiente requiere conservar la procedencia de los datos, las transformaciones realizadas y las decisiones interpretativas. Cuando la conclusión depende de un comportamiento complejo, es valioso acompañarla de un ensayo controlado o de referencias técnicas verificables. Esas pruebas no garantizan que todos los casos futuros se comporten del mismo modo, pero permiten establecer el alcance de la inferencia y sus límites.

2.3.5. ISO/IEC 27043: principios y procesos de investigación

La **ISO/IEC 27043:2015** ofrece una visión de conjunto de los principios y procesos de investigación de incidentes que implican evidencia digital. Su alcance se extiende desde la preparación anterior al incidente hasta el cierre. Por ello funciona como marco integrador de las actividades que en otras normas se estudian con mayor detalle. Resulta especialmente útil para organizaciones que necesitan diseñar procedimientos completos y no únicamente instrucciones sobre adquisición de soportes.

Su enfoque ayuda a identificar dependencias entre áreas: una buena preservación necesita preparación; un examen técnicamente correcto requiere saber cuál es la pregunta; la interpretación depende del método de obtención; y el informe final depende de que todas las decisiones relevantes hayan quedado registradas. Una investigación no es una suma de tareas aisladas, sino una sucesión de actuaciones que deben mantener coherencia entre sí.

La amplitud de la norma permite aplicarla conceptualmente a escenarios distintos: accesos indebidos, alteración de datos, fallos de sistemas o conflictos corporativos. No debe deducirse de ello que prescribe soluciones idénticas para cada caso. Un examen sobre un teléfono confiscado, una investigación de fraude en una aplicación SaaS y una respuesta a ransomware pueden compartir principios, pero difieren en autoridades, urgencia, fuentes y riesgos. La metodología debe admitir esas diferencias sin renunciar a la trazabilidad.

Si se observa conjuntamente la familia ISO/IEC 27037, 27041, 27042 y 27043, se obtiene una estructura especialmente útil: tratar correctamente la evidencia, comprobar la adecuación de los métodos, analizar e interpretar de manera rigurosa e integrar todo ello en un proceso de investigación coherente. Esta relación es una síntesis didáctica de sus ámbitos, no una transcripción de sus contenidos normativos ni una exigencia de aplicarlas como etapas consecutivas.

2.3.6. Otras normas relacionadas: gestión de incidentes y competencia de laboratorio

La familia **ISO/IEC 27035** se ocupa de la gestión de incidentes de seguridad de la información. Es relevante porque muchas investigaciones forenses se realizan durante una respuesta operativa. En particular, la ISO/IEC 27035-1:2023 establece principios y un proceso de gestión de incidentes, mientras que la ISO/IEC 27035-2:2023 desarrolla orientaciones para planificar y preparar la respuesta y aprender de ella. Su foco no es sustituir el examen forense, sino situarlo dentro de responsabilidades más amplias: coordinación, decisiones de contención, comunicaciones, recuperación y mejora.

Esta conexión ayuda a evitar dos errores opuestos. El primero consiste en sacrificar toda la evidencia para restablecer el servicio sin valorar alternativas de preservación. El segundo consiste en bloquear indefinidamente una medida de contención necesaria por perseguir una adquisición ideal que quizá no sea viable. La coordinación entre responsables de respuesta, propietarios de sistemas y analistas permite adoptar decisiones documentadas que ponderen ambos objetivos.

La **ISO/IEC 17025:2017** tiene otro propósito: establece requisitos generales de competencia, imparcialidad y funcionamiento coherente de laboratorios de ensayo y calibración. Es una referencia relevante para la gestión de calidad en determinados laboratorios forenses y puede formar parte de esquemas de acreditación cuando sea aplicable. Sin embargo, no debe afirmarse que cualquier profesional que realice un análisis forense esté automáticamente sometido a una obligación universal de acreditación ISO/IEC 17025. El contexto regulatorio, la actividad y los requisitos de la entidad solicitante determinan su aplicabilidad.

Desde una perspectiva metodológica, sus principios de competencia, control de métodos, registros técnicos y revisión refuerzan ideas que ya han aparecido: las herramientas necesitan pruebas, las personas necesitan formación, los procedimientos deben controlarse y el expediente debe permitir entender qué ocurrió. La calidad forense es una propiedad del sistema completo de trabajo, no una cualidad que se compra con una licencia de software.

2.3.7. NIST SP 800-86: técnicas forenses integradas en operaciones de seguridad

El **National Institute of Standards and Technology (NIST)** publica guías y documentos técnicos utilizados internacionalmente. La **NIST SP 800-86**, *Guide to Integrating Forensic Techniques into Incident Response*, publicada en 2006, sigue siendo una referencia conceptual para incorporar actividades forenses a investigaciones de incidentes y problemas operativos de tecnología. Su utilidad reside en relacionar recogida, examen, análisis e información de resultados con fuentes como archivos, sistemas operativos, tráfico de red y aplicaciones.

El carácter histórico de su publicación debe declararse. Los principios generales mantienen valor, pero muchas tecnologías descritas han evolucionado de forma considerable. La guía antecede a numerosos modelos actuales de servicios SaaS, orquestación de contenedores, almacenamiento distribuido y mecanismos modernos de cifrado de dispositivos. Utilizarla como marco no equivale a considerarla un manual actualizado para todos los entornos contemporáneos.

NIST presenta la integración del trabajo forense desde una perspectiva operativa de TI, no como un compendio de procedimientos judiciales. Esta distinción importa. La recogida de datos dentro de una empresa durante un incidente y la actuación sobre dispositivos sujetos a una orden judicial pueden compartir técnicas, pero las garantías y competencias no tienen por qué coincidir. Cualquier procedimiento debe ajustarse al marco jurídico aplicable y a las obligaciones de la organización.

La aportación más perdurable de SP 800-86 es mostrar que el examen forense no empieza y termina en el disco duro. Los archivos, los registros del sistema, las comunicaciones y las aplicaciones proporcionan perspectivas complementarias. En el caso del repositorio, esta idea se traduce en considerar juntos los eventos de identidad, la auditoría del servicio, los rastros del cliente y las trazas de red, en lugar de buscar toda la explicación en un único dispositivo.

2.3.8. NIST SP 800-61 Rev. 3: respuesta a incidentes y gestión del riesgo

La **NIST SP 800-61 Rev. 3**, publicada en abril de 2025, sitúa la respuesta a incidentes dentro de las actividades de gestión del riesgo del **NIST Cybersecurity Framework 2.0**. Sustituye a la revisión anterior de la publicación. Su enfoque resulta relevante porque la investigación forense es con frecuencia uno de los instrumentos que permiten comprender un incidente, valorar su alcance y orientar la recuperación.

La visión contemporánea de la respuesta a incidentes reconoce que la preparación no pertenece solo a un equipo de emergencia. Afecta al gobierno de la seguridad, al conocimiento de activos, a la protección, a la detección, a la respuesta y a la recuperación. Para el analista forense esto tiene consecuencias inmediatas: la disponibilidad de logs, las identidades bien inventariadas, las copias recuperables y los procedimientos de escalado dependen de decisiones adoptadas mucho antes de que se produzca una alerta.

No conviene presentar SP 800-61 Rev. 3 como si fuera una sustitución técnica de SP 800-86. Son documentos con finalidades distintas. La primera orienta la integración de técnicas forenses; la segunda aborda la respuesta a incidentes desde la gestión del riesgo. Trabajarán

mejor juntas cuando se entienda que una investigación necesita tanto técnicas fiables como coordinación organizativa.

2.3.9. NISTIR 8387: preservación a lo largo del ciclo de vida

El informe **NISTIR 8387**, *Digital Evidence Preservation: Considerations for Evidence Handlers* (2022), se centra en los problemas específicos de conservar evidencia digital. Es especialmente valioso para recordar que una evidencia puede seguir siendo relevante mucho después de haberse obtenido y examinado. No basta con realizar una copia inicial: hay que asegurar que el objeto y su contexto sigan disponibles y verificables cuando vuelva a necesitarse.

La preservación a largo plazo plantea dificultades diferentes de la adquisición. Puede cambiar la tecnología de almacenamiento; pueden desaparecer programas capaces de interpretar formatos propietarios; pueden caducar claves de acceso o cifrado; pueden fallar soportes; pueden alterarse permisos; puede necesitarse una nueva copia para migrar los datos. Una política adecuada relaciona integridad, disponibilidad, control de acceso, documentación y condiciones de conservación.

Desde una perspectiva práctica, es recomendable considerar el problema del formato. Conservar un archivo de evidencia en un contenedor poco documentado y no guardar la información necesaria para interpretarlo puede dificultar una revisión años después. Por el contrario, mantener formatos conocidos, versiones de herramientas, documentación de adquisición y manifestaciones de integridad ayuda a preservar no solo los bytes, sino la posibilidad de comprenderlos.

2.3.10. NIST CFTT y los conjuntos de referencia

El programa **Computer Forensics Tool Testing (CFTT)** de NIST desarrolla metodologías y recursos destinados a evaluar herramientas forenses. Su relevancia no radica en proporcionar una etiqueta universal de «herramienta certificada», sino en fomentar pruebas reproducibles con especificaciones, conjuntos de ensayo y criterios de evaluación. Los resultados de pruebas concretas ayudan a entender capacidades y limitaciones de productos y versiones específicos.

Una herramienta puede funcionar correctamente en un tipo de sistema de archivos y presentar fallos en otro. Puede manejar de manera fiable imágenes sin daños y comportarse de modo diferente ante sectores defectuosos. Puede reconocer determinados formatos y no admitir extensiones recientes. La prueba rigurosa evita razonar de esta manera: «La herramienta es conocida; por tanto, todo lo que muestra es verdadero». Una afirmación más

defendible sería: «La función utilizada ha sido sometida a pruebas relevantes para estos datos y sus resultados se han contrastado con evidencia independiente cuando ha sido necesario».

Los conjuntos de referencia con resultado conocido permiten comparar lo esperado con lo obtenido. El diseño de estos ensayos debe incluir condiciones ordinarias y casos límite: registros ausentes, fechas extremas, nombres con caracteres especiales, estructuras corruptas, duplicados, formatos parcialmente compatibles y diferencias de codificación. Aunque ninguna colección de pruebas puede cubrir todas las circunstancias, su utilización reduce la dependencia de suposiciones no comprobadas.

2.3.11. SWGDE: buenas prácticas orientadas al trabajo cotidiano

El **Scientific Working Group on Digital Evidence (SWGDE)** publica documentos de buenas prácticas para actividades de evidencia digital. Sus textos se distinguen por abordar problemas operativos concretos: recogida, adquisición, examen, pruebas de herramientas, informes, evidencia en nube y otros entornos especializados. Debe atenderse a la edición específica y a la fecha de cada documento, ya que las recomendaciones se revisan periódicamente.

Entre los documentos relevantes se encuentran las buenas prácticas de **recogida de evidencia digital** (SWGDE 18-F-002), de **adquisición forense de ordenadores** (SWGDE 17-F-002) y de **examen forense de ordenadores** (SWGDE 18-F-001). La distinción entre ellas refuerza la idea de que obtener un soporte, adquirir sus datos y examinarlos son actividades relacionadas, pero no equivalentes. Los documentos insisten en preparar el entorno, conocer las herramientas, preservar integridad, registrar incidencias y conservar información suficiente para revisión posterior.

Las directrices de SWGDE sobre adquisiciones señalan expresamente la necesidad de entender el efecto de la técnica sobre la fuente. Si resulta imposible evitar toda alteración, debe describirse la intervención de manera suficientemente detallada. Esta aproximación es especialmente razonable en sistemas vivos o remotos: exige rigor sin fingir que las operaciones de lectura son siempre invisibles para el sistema observado.

Las recomendaciones sobre **pruebas de herramientas**, como SWGDE 18-Q-001, ofrecen criterios de ensayo previos al uso operativo. Las relativas a **informes**, como SWGDE 18-Q-002, recuerdan la necesidad de identificar encargo, elementos examinados, métodos, resultados, conclusiones cuando procedan y destino de las evidencias. Existen además documentos específicos sobre **evidencia de proveedores de servicios en la nube**, que resultan útiles para

entender los problemas de dependencia del proveedor, formatos de exportación y alcance de los datos disponibles.

SWGDE no reemplaza la legislación, las resoluciones judiciales, los procedimientos de una organización ni los requisitos de un organismo acreditador. Sus documentos tampoco deben asumirse como instrucciones universales aplicables sin adaptación. Su principal valor es aportar una referencia profesional para diseñar procedimientos y detectar aspectos que una actuación improvisada podría pasar por alto.

2.3.12. Comparación práctica de las referencias principales

La siguiente tabla resume el foco metodológico de las referencias tratadas. Es una **orientación editorial**, no una equivalencia normativa entre documentos.

Referencia	Pregunta que ayuda a responder	Uso principal en una investigación
ISO/IEC 27037:2012	¿Cómo identificar, recoger, adquirir y preservar evidencia potencial?	Tratamiento inicial y preservación.
ISO/IEC 27041:2015	¿Es adecuado y suficientemente probado el método?	Selección y validación de procedimientos.
ISO/IEC 27042:2015	¿Cómo analizar e interpretar con continuidad y posibilidad de revisión?	Análisis, interpretación y garantías técnicas.
ISO/IEC 27043:2015	¿Cómo encajan las actividades en una investigación completa?	Organización del proceso y cierre.
ISO/IEC 27035 (familia)	¿Cómo se gestiona la respuesta a incidentes?	Coordinación con seguridad y operaciones.
ISO/IEC 17025:2017	¿Cómo demostrar competencia y consistencia en un laboratorio?	Gestión de calidad, cuando resulte aplicable.
NIST SP 800-86	¿Cómo integrar técnicas forenses en TI y respuesta a incidentes?	Marco práctico de fuentes y actividades.

Referencia	Pregunta que ayuda a responder	Uso principal en una investigación
NIST SP 800-61 Rev. 3	¿Cómo integrar la respuesta a incidentes en la gestión del riesgo?	Preparación, coordinación y recuperación.
NISTIR 8387	¿Cómo conservar evidencia digital durante su ciclo de vida?	Custodia y preservación continuada.
NIST CFTT	¿Cómo evaluar la fiabilidad de funciones de herramientas?	Pruebas basadas en requisitos y datos conocidos.
SWGDE	¿Qué buenas prácticas concretas ayudan en cada actividad?	Procedimientos de campo, adquisición, examen y calidad.

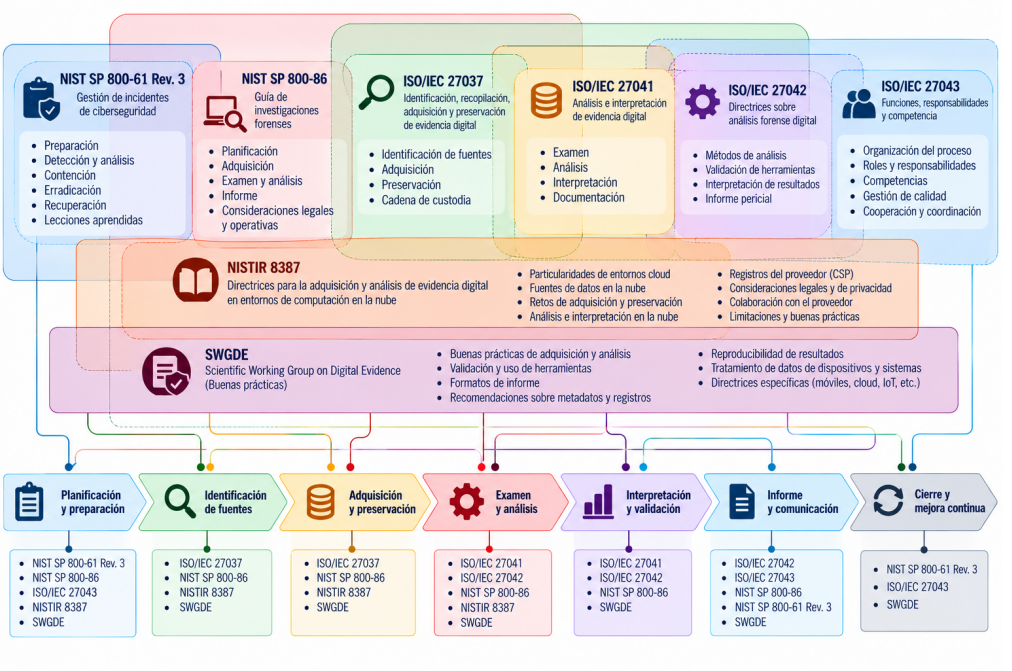


Figura 10: Mapa de correspondencias entre fuentes normativas y actividades forenses

2.3.13. Cómo se traduce una referencia en un procedimiento verificable

Supongamos que un laboratorio pretende instaurar un procedimiento para adquirir evidencias mediante una API de auditoría. La referencia a estándares no debería quedarse en una cabecera del documento. La organización puede convertir sus principios en preguntas operativas. Primero, ¿se dispone de autorización y se ha delimitado el alcance? Segundo, ¿qué datos expone la API y cuáles omite? Tercero, ¿cómo se registra la consulta y se conserva la respuesta original? Cuarto, ¿cómo se verifica que la paginación no ha dejado eventos sin obtener? Quinto, ¿qué pruebas demuestran que el conversor de JSON a tabla no pierde campos ni altera tiempos?

A continuación se diseña un procedimiento: registrar identificadores del servicio, versión de API, cuenta o rol utilizado, filtros, intervalos, tokens de paginación, códigos de respuesta y marcas temporales de extracción; conservar la respuesta original con protección de acceso; calcular hashes de archivos resultantes; anotar errores y reintentos; ejecutar una comprobación de completitud si el servicio la permite; y distinguir las transformaciones realizadas en las copias de trabajo. El procedimiento se prueba con un entorno de referencia y se revisa cuando cambia la API.

Una vez adoptado, el procedimiento debe utilizarse de forma consistente, pero admite excepciones justificadas. Si un proveedor modifica inesperadamente el servicio durante un incidente, quizá haya que utilizar otra ruta de exportación. La decisión deberá registrarse, explicando qué se preservó, qué diferencias de cobertura presenta la alternativa y cómo se validaron los resultados. **La conformidad metodológica se demuestra con registros de actuación y criterios de calidad, no con una colección de nombres de normas.**

2.4. Hipótesis, reproducibilidad y validación de resultados

2.4.1. Investigar no consiste en confirmar la primera explicación

Una hipótesis forense es una explicación provisional de un conjunto de hechos observados que puede contrastarse mediante evidencia. No debe confundirse con una intuición, una acusación o una conclusión anticipada. Es útil cuando permite derivar consecuencias observables: si ocurrió lo propuesto, ¿qué rastros esperaríamos encontrar?, ¿en qué sistemas?, ¿con qué limitaciones?, ¿qué evidencia sería difícil de explicar si la hipótesis fuera correcta?

El razonamiento exige diferenciar varias etapas. Se recibe una observación; se plantean explicaciones; se identifican predicciones; se buscan datos; se interpreta su correspondencia con las predicciones; y se valora qué explicaciones permanecen plausibles. El proceso es

iterativo. Una nueva evidencia puede modificar o descartar hipótesis, revelar una causa no prevista o demostrar que la pregunta original estaba mal formulada.

El riesgo metodológico más común es el *sesgo de confirmación*: favorecer la evidencia que apoya una explicación temprana y relegar la que la contradice. Puede aparecer de manera sutil. Quien recibe el encargo «demostrar que el trabajador copió información» tenderá a interpretar cada archivo temporal, cada unidad conectada y cada registro de transferencia como parte del mismo relato. Si el encargo se formula como «determinar si existieron copias o transferencias y quiénes o qué sistemas pudieron intervenir», aumenta la posibilidad de examinar alternativas sin reducir el rigor.

El analista no tiene que fingir una neutralidad imposible de toda intuición. La experiencia produce hipótesis útiles. Lo importante es establecer mecanismos que impidan tratarlas como pruebas: formular hipótesis rivales, registrar predicciones antes de revisar determinados conjuntos de datos, anotar resultados contrarios y realizar revisiones independientes cuando la trascendencia del caso lo aconseje.

2.4.2. Hipótesis alternativas y predicciones observables

Retomemos la desaparición aparente de archivos del repositorio. Una primera hipótesis atribuye el cambio a una eliminación manual. Otras proponen un movimiento entre carpetas, una sincronización conflictiva, una modificación de permisos y un problema de visualización. Las cinco son compatibles, al menos inicialmente, con la observación de que el usuario ya no encuentra ciertos documentos. Su valor reside en que generan predicciones diferentes.

Si hubo eliminación manual, podrían existir registros de operaciones de borrado, eventos de papelera o cambio de estado, identificadores de objetos afectados y operaciones asociadas a una sesión. Si hubo movimiento, aparecerán cambios de ruta, identificadores que conservan continuidad, eventos de renombrado o de traslado y acceso desde otra ubicación. Si existió un conflicto de sincronización, podrían encontrarse versiones divergentes, registros del cliente, colas pendientes o mensajes de resolución de conflictos. Un cambio de permisos generaría discrepancias entre existencia y visibilidad del objeto para distintas identidades. Un fallo de interfaz podría reproducirse al modificar filtros, caché, permisos de visualización o consultas, sin que el contenido haya cambiado realmente.

La comparación puede sistematizarse:

Hipótesis	Evidencia que la apoyaría	Evidencia que la debilitaría	Advertencia
Eliminación manual	Operación de borrado ejecutada y registrada; objeto pasa a estado eliminado.	Continuidad del objeto en otra ubicación y ausencia de cambio de estado, si la auditoría es completa.	No todos los servicios registran o conservan todos los borrados.
Movimiento	Operaciones de traslado o cambio de ruta; identificador estable.	Objeto definitivamente eliminado sin rastro de nueva ubicación, si existen datos completos.	Algunas interfaces implementan movimientos como copia y borrado.
Sincronización	Registros de cliente, conflictos, versiones y tareas automáticas.	Actividad humana inequívoca no explicada por los procesos de sincronización.	Las tareas pueden operar con credenciales del usuario.
Cambio de permisos	Nuevas ACL, herencia modificada, diferencias entre identidades.	Acceso denegado no asociado a permisos o inexistencia comprobada del objeto.	La caché de autorización puede retrasar cambios visibles.
Fallo de visualización	Discrepancias entre API, búsqueda y vista; filtros o cachés.	El objeto tampoco existe en fuentes independientes, dentro de la cobertura disponible.	Una interfaz puede fallar a la vez que existe otra causa real.

La tabla muestra un matiz importante: **las hipótesis no siempre son mutuamente excluyentes**. Puede haberse producido un movimiento automático y, después, una eliminación manual. Un cambio de permisos puede coexistir con una sesión comprometida. El investigador no debe forzar todos los hechos a una única explicación por comodidad narrativa.

2.4.3. Corroboración, independencia y calidad de las fuentes

Corroborar no consiste en repetir la misma afirmación con diferentes palabras. Una evidencia ofrece mayor apoyo a un hallazgo cuando procede de un mecanismo distinto, tiene propiedades conocidas y resulta coherente con lo observado. Si un informe de seguridad, un panel de control y una alerta se alimentan del mismo registro, los tres pueden ayudar a localizar el dato, pero no equivalen a tres observaciones independientes. Por el contrario, un evento de descarga en el servidor y un archivo adquirido en el dispositivo cliente representan perspectivas diferentes, aunque también será necesario demostrar su relación.

La independencia tiene grados. Dos fuentes pueden depender del mismo reloj, de una misma cuenta o de un mismo proveedor. Una plataforma de detección puede enriquecer eventos con datos externos que no son observaciones directas. Un proxy puede registrar solicitudes, mientras que la aplicación registra acciones de negocio. Ambas fuentes ofrecen información complementaria, pero una avería común en la red puede afectar a su cobertura temporal. Por ello es útil registrar la procedencia y los pasos de transformación, no solo el nombre de la herramienta donde se visualizó el resultado.

La calidad de una fuente también depende de su precisión, resolución, cobertura, retención y semántica. Un log puede ser auténtico, pero incompleto. Puede registrar fielmente un intento de operación sin documentar su éxito. Puede utilizar un identificador de cuenta correcto y, aun así, no indicar a qué persona física correspondió el control de la sesión. Una evidencia no se vuelve irrelevante por tener límites; se vuelve peligrosa cuando esos límites se ignoran.

2.4.4. Ausencia de evidencia y evidencia de ausencia

En las investigaciones digitales se encuentra con frecuencia el argumento «no hay registros, por tanto no ocurrió». La conclusión puede ser incorrecta. La ausencia de un evento solo resulta significativa si existe una expectativa razonablemente fundada de que, en caso de producirse el hecho, el sistema lo habría registrado y conservado. Para valorar esa expectativa se requiere conocer la configuración, el nivel de auditoría, el periodo de retención, las posibles pérdidas y el funcionamiento de las consultas realizadas.

Supongamos que una empresa afirma que no hubo accesos a un repositorio porque su SIEM no presenta alertas. Es posible que el SIEM solo genere alertas ante umbrales concretos, que no reciba todos los eventos o que la regla pertinente estuviera deshabilitada. La ausencia de alertas no prueba la ausencia de acceso. Si, en cambio, se dispone de un registro completo y validado de todas las operaciones de lectura del periodo autorizado, con comprobaciones

de integridad y cobertura, la falta de una operación específica puede aportar información negativa con mayor fuerza.

Incluso entonces la conclusión debe formularse dentro de sus límites: «No se identificaron eventos de descarga del objeto X en los registros completos disponibles para el intervalo Y, cuyo mecanismo de auditoría estaba habilitado y fue comprobado». No equivale necesariamente a descartar copias anteriores, otros canales de extracción o errores desconocidos. La precisión del lenguaje refleja la precisión de la investigación.

2.4.5. De la correlación temporal a la relación causal

Que dos acontecimientos sean próximos no demuestra que uno haya causado el otro. Una autenticación a las 03:14 y una modificación documental a las 03:16 pueden guardar relación; también pueden pertenecer a procesos independientes. La cronología permite establecer compatibilidad temporal, pero la causalidad necesita vínculos adicionales: identificadores de sesión, correlación de solicitudes, trazas de procesos, relaciones padre-hijo, eventos de autorización o pruebas controladas del comportamiento de la aplicación.

Los errores de tiempo pueden distorsionar esa valoración. Un sistema registra el evento al producirse, otro cuando lo recibe y un tercero al procesarlo. La normalización a UTC facilita la comparación, pero no convierte en exactos relojes que estaban desincronizados. Si una máquina tenía cinco minutos de desfase, debe conservarse el dato sobre el desfase y, cuando sea posible, estimar su incertidumbre. Ordenar acontecimientos por timestamps sin considerar ese margen puede producir una cronología aparentemente precisa y materialmente incorrecta.

También es preciso distinguir correlación técnica de atribución personal. Un token emitido para una cuenta permite vincular ciertas operaciones a una credencial o sesión, pero una credencial puede ser robada, delegada, compartida o utilizada por un servicio automatizado. La identificación de una persona requiere un conjunto distinto de evidencias y, con frecuencia, datos externos a la tecnología. El informe debe evitar que la precisión de los identificadores técnicos se convierta en una falsa precisión sobre la autoría humana.

2.4.6. Repetibilidad, reproducibilidad y revisión independiente

En el lenguaje cotidiano, *repetible* y *reproducible* se usan como sinónimos. En el análisis técnico conviene precisar su significado y declarar cómo se emplean. Una **repetición** de una operación se realiza bajo condiciones sustancialmente equivalentes, con el mismo método

y una configuración controlada. Una **reproducción independiente** pretende obtener resultados compatibles a partir de información suficiente, potencialmente con otro analista o una implementación diferente. La terminología formal puede variar entre marcos metrológicos y documentos normativos; lo fundamental es describir las condiciones efectivamente comprobadas.

Supongamos que una herramienta extrae 152 eventos de una base de datos. Ejecutarla por segunda vez sobre la misma copia con idénticos parámetros permite comprobar estabilidad de la operación. Utilizar otra herramienta, o una consulta documentada que lea directamente las estructuras pertinentes, permite valorar si el resultado depende de una implementación. Ambas verificaciones son valiosas, pero responden a preguntas diferentes. Una herramienta puede equivocarse de manera perfectamente repetible.

La reproducibilidad exige conservar información suficiente: copia de evidencia identificada, hashes cuando correspondan, versión de herramienta, sistema de ejecución relevante, comandos, parámetros, filtros, configuración de zona horaria, dependencias, resultados y anotaciones sobre el tratamiento de errores. Si la aplicación necesita una licencia, una base de firmas o un componente remoto, conviene documentarlo. Si se utilizaron modelos automáticos de clasificación, deben distinguirse sus resultados de los datos primarios y registrarse las condiciones de uso que afecten a su estabilidad.

No todos los resultados pueden reproducirse literalmente. Una consulta a un servicio remoto puede devolver menos registros días después por la política de retención. Un equipo encendido cambia constantemente. Un servidor externo puede alterar sus contenidos. En esas circunstancias, la reproducibilidad se apoya en conservar las respuestas originales, registrar el contexto y demostrar que las transformaciones posteriores sí pueden examinarse. El método debe reconocer la irrepetibilidad de ciertas adquisiciones sin renunciar al control de calidad de lo que se obtuvo.

2.4.7. Validación de métodos y verificación de resultados

La **validación** de un método busca establecer si es adecuado para la finalidad prevista; la **verificación** de una ejecución concreta busca comprobar si lo realizado produjo los resultados esperados dentro de sus condiciones. La terminología puede variar según el estándar utilizado, por lo que en documentación técnica es aconsejable definirla. En ambos casos se persigue evitar que una salida aparentemente convincente sustituya a una prueba de funcionamiento.

Un ejemplo ilustra la diferencia. Antes de utilizar un programa propio para interpretar registros JSON, el laboratorio lo prueba con archivos construidos que contienen eventos dupli-

cados, campos opcionales, caracteres Unicode, tiempos con diferentes zonas y respuestas paginadas. Se compara su salida con los resultados conocidos. Esa actividad aporta confianza sobre la adecuación del método para el tipo de datos ensayado. Durante un caso concreto, se revisan los errores del proceso, el número de entradas tratadas y muestras representativas de los eventos exportados. Esa comprobación se refiere a la ejecución particular.

La validación debe contemplar tanto casos normales como límites. Si una herramienta descarta silenciosamente registros con un campo vacío, el problema podría no aparecer en conjuntos de prueba demasiado limpios. Si un parser convierte todos los tiempos a la zona horaria del ordenador del analista, la discrepancia podría producir una cronología falsa. Si la aplicación trunca identificadores de gran tamaño al exportarlos a una hoja de cálculo, el daño puede pasar inadvertido hasta que se intenten correlacionar fuentes.

Cuando se emplea software de terceros, la información del fabricante y las pruebas publicadas pueden orientar, pero no siempre sustituyen la evaluación de la combinación concreta de versión, función y formato utilizada. Los cambios de versión pueden modificar el comportamiento. La revisión de notas de lanzamiento, errores conocidos y pruebas con datos de referencia resulta especialmente importante tras actualizaciones relevantes. En la medida de lo posible, las herramientas que sustentan conclusiones decisivas deben contrastarse con métodos independientes o con muestras examinadas manualmente.

2.4.8. Resultados discordantes y resolución de conflictos

Dos técnicas pueden producir valores diferentes sin que ninguna esté necesariamente defectuosa. Una herramienta puede mostrar la marca de creación del archivo; otra, la de inserción en una base de datos. Ambas pueden etiquetarse en pantalla como «fecha». Un visor puede ocultar registros eliminados; un parser forense puede recuperarlos. Un registro puede expresar tiempo local y otro UTC. Antes de escoger un resultado, el analista debe averiguar qué representa exactamente cada campo.

El procedimiento razonable consiste en conservar ambas salidas, recuperar los datos subyacentes, verificar conversiones y revisar la documentación del formato o el comportamiento de referencia. Si persiste una discrepancia relevante, debe declararse. En ocasiones la conclusión será un intervalo temporal en vez de una hora exacta; en otras, un hallazgo se excluirá por falta de garantías. Es preferible reducir la precisión de una afirmación a sostener una exactitud ficticia.

La divergencia también puede deberse a un cambio real en la fuente entre capturas. Por eso importa la secuencia de adquisición. Dos consultas al mismo servicio realizadas en momentos distintos no son necesariamente dos medidas sobre un objeto inmutable. Los sistemas

distribuidos pueden presentar consistencia diferida, cambios de estado y datos actualizados de manera asíncrona. La documentación debe indicar el momento y las condiciones de cada observación.

2.4.9. El registro de decisiones y el control del sesgo

Además de registrar comandos y herramientas, resulta útil mantener un **diario de decisiones analíticas**. En él se indica cuándo se formuló una hipótesis, qué datos la motivaron, qué pruebas se propusieron y qué resultado obtuvo cada una. Cuando se cambia de explicación, se conserva el razonamiento anterior en lugar de reescribir retrospectivamente la historia. Esta práctica permite que una revisión posterior identifique si las conclusiones se apoyaban en evidencias disponibles en aquel momento o si surgieron por acomodación posterior.

Un formato sencillo incluye: identificador de decisión, fecha, pregunta, hipótesis, predicciones, fuentes examinadas, resultado, interpretación provisional, incertidumbre y siguiente acción. No necesita convertirse en una carga desproporcionada, pero es especialmente valioso en casos prolongados, con varias personas o con hallazgos potencialmente controvertidos. También facilita continuar un análisis tras una pausa sin depender de la memoria del investigador.

En asuntos delicados puede ser conveniente que una persona revise las evidencias sin conocer inicialmente la identidad del sospechoso o el resultado esperado por quien encargó el trabajo, siempre que la organización de la investigación lo permita. La revisión por pares, los criterios previos de selección y la conservación de resultados negativos son otras formas de reducir sesgos. Ningún control elimina por completo la interpretación humana; su objetivo es hacer visibles los supuestos y limitar los efectos de una preferencia no justificada.

2.4.10. Un ejemplo completo de contraste de hipótesis

Volvamos al caso del repositorio. La hipótesis H1 afirma que una persona eliminó archivos manualmente utilizando la cuenta investigada. H2 propone que una tarea automática los trasladó. H3 atribuye la pérdida aparente a permisos. Antes de examinar los eventos detallados, el equipo define qué esperaría encontrar: para H1, operaciones de borrado con resultado satisfactorio; para H2, eventos de movimiento y persistencia de los identificadores; para H3, objetos existentes que no resultan visibles para el rol del usuario.

La auditoría muestra operaciones de movimiento ejecutadas por una integración de sincronización. El historial de versiones confirma que varios documentos continúan almacenados,

aunque asociados a rutas diferentes. Una consulta con permisos de administrador permite recuperar sus identificadores; otra, con el rol del usuario afectado, demuestra que parte de los objetos no se muestra en su vista habitual. Estos datos apoyan una combinación de H2 y H3. No se hallan eventos de borrado en el periodo conservado, pero el informe evita convertir esa ausencia en una prueba absoluta de que nunca se produjo una eliminación.

En paralelo, la autenticación desde una IP inusual sigue sin explicarse completamente. Los eventos del proveedor de identidad muestran que la sesión utilizó un mecanismo de autenticación permitido y que se emitió un token. Los registros de la aplicación no muestran, durante el intervalo disponible, acciones de modificación asociadas a esa sesión. Se alcanza por tanto una conclusión limitada: la desaparición aparente de los archivos se explica por movimiento y permisos con el grado de corroboración descrito; la autenticación inusual merece investigación adicional, pero no se ha demostrado que provocara el cambio documental.

Este resultado puede parecer menos espectacular que atribuir la pérdida a un intruso. Sin embargo, es metodológicamente más sólido porque **separa lo observado, lo corroborado y lo que permanece abierto**. La finalidad de una investigación no es producir una historia convincente, sino una explicación proporcionada a las evidencias disponibles.

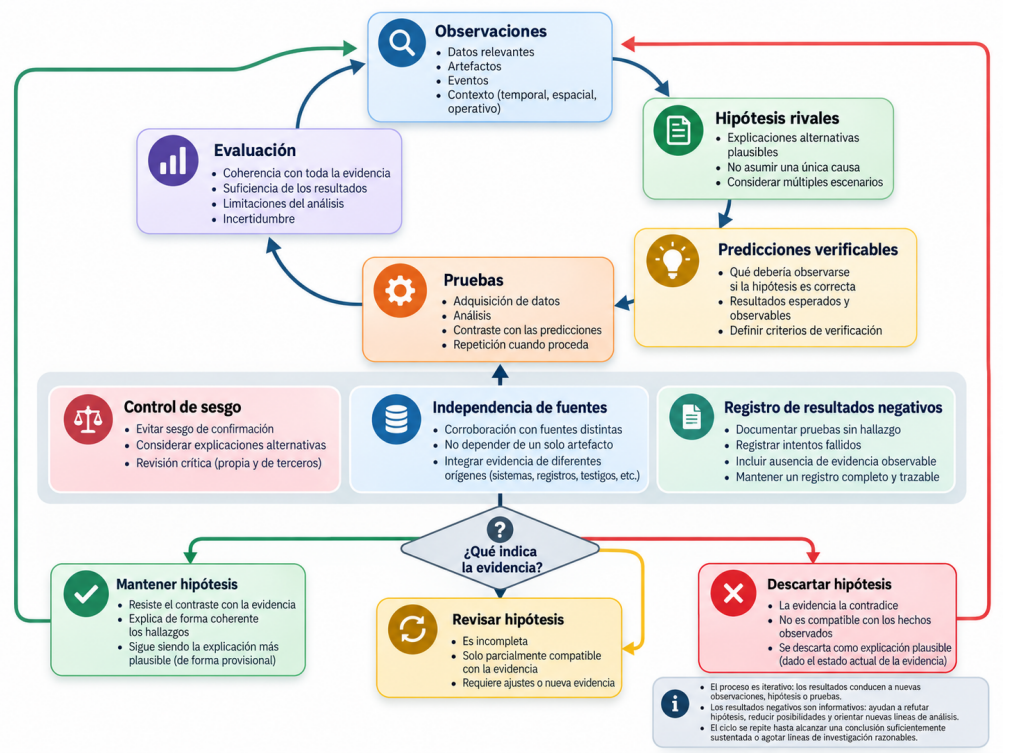


Figura 11: El ciclo de contraste de hipótesis

2.5. Preparación forense (*forensic readiness*)

2.5.1. Investigar después depende de decisiones tomadas antes

La expresión inglesa *forensic readiness* suele traducirse como **preparación forense** o **preparación para la investigación forense**. Describe la capacidad de una organización para identificar, conservar y utilizar evidencia digital de manera eficiente y fiable cuando surge una necesidad legítima de investigación. No consiste en mantener permanentemente un laboratorio examinando a todos los usuarios. Consiste en diseñar sistemas, responsabilidades y procedimientos para que, cuando aparezca un incidente, la información necesaria no haya desaparecido y pueda tratarse correctamente.

Muchas investigaciones fracasan parcialmente por decisiones que se tomaron meses o años antes de que ocurriera el hecho. Una aplicación deja de generar registros porque nadie definió requisitos de auditoría. Un servicio conserva eventos durante tres días aunque los incidentes se descubren habitualmente varias semanas después. Las marcas temporales de

dispositivos distintos no pueden correlacionarse porque faltan referencias fiables de sincronización. Una plataforma externa posee los datos, pero el contrato no prevé su entrega en un formato útil. Un sistema registra únicamente una cuenta técnica compartida y no permite distinguir qué operador realizó cada acción.

En estas situaciones el analista puede actuar con gran competencia y, aun así, no disponer de evidencias suficientes. La preparación forense busca reducir esa distancia entre lo que sería necesario investigar y lo que la arquitectura realmente permite observar. Se integra en la gestión del riesgo, la seguridad operativa, la continuidad y la gobernanza de datos, pero tiene objetivos propios: mejorar la disponibilidad y fiabilidad de los rastros, reducir el tiempo de preservación y facilitar investigaciones proporcionadas.

La preparación no significa conservar todo de forma indefinida. Esa estrategia sería costosa, aumentaría la superficie de exposición y podría vulnerar obligaciones de minimización o plazos de conservación. La decisión madura consiste en identificar los escenarios relevantes, determinar qué evidencia se necesitaría y configurar una retención razonada, protegida y revisable. La capacidad investigadora debe equilibrarse con privacidad, coste, disponibilidad y requisitos legales.

2.5.2. Partir de preguntas, escenarios y activos críticos

El diseño comienza identificando los sucesos que la organización necesitaría investigar: accesos indebidos, filtraciones, fraude, manipulación de registros, sabotaje, instalación de software malicioso, abuso de privilegios o fallos de configuración con consecuencias relevantes. Cada escenario se traduce en preguntas. Para un posible abuso de credenciales interesará saber qué identidad autenticó, con qué factores, desde dónde, qué sesión obtuvo y qué operaciones ejecutó. Para una alteración de datos interesará conocer el objeto, el cambio, su autor técnico, el mecanismo utilizado y las versiones anteriores.

Las preguntas permiten establecer requisitos de evidencia antes de comprar herramientas o ampliar la retención de todo el entorno. Un registro que solo indica «inicio de sesión correcto» quizá sea suficiente para determinadas métricas de operación, pero insuficiente para reconstruir el uso posterior de un token en varias aplicaciones. Un historial de cambios puede indicar que un objeto fue modificado y no conservar quién inició la modificación ni si procedía de una integración automática. La preparación exige comprobar estas limitaciones en condiciones reales.

El inventario de activos resulta esencial. No se puede planificar la preservación de un sistema cuya existencia se desconoce. Deben identificarse servicios corporativos, proveedores de identidad, repositorios, endpoints, dispositivos móviles gestionados, servidores, entornos

de virtualización, aplicaciones SaaS, sistemas de control y soluciones de seguridad. Junto al activo debe constar quién lo administra, quién puede autorizar la extracción de datos, qué auditoría genera, dónde la almacena y durante cuánto tiempo se conserva.

El resultado no tiene por qué ser una enciclopedia de infraestructura. Un inventario actualizado con propietarios y relaciones entre servicios ofrece más valor que un documento extenso que nadie mantiene. Cuando las organizaciones crecen, la automatización de descubrimiento y la gestión de configuraciones pueden ayudar a detectar activos nuevos. La preparación forense debe incorporarse a los procesos de alta, modificación y retirada de sistemas para evitar que el inventario envejezca desde el día de su aprobación.

2.5.3. Diseño de registros útiles y semánticamente claros

La disponibilidad de logs constituye una condición necesaria para muchas investigaciones, pero su cantidad no garantiza utilidad. Un buen registro debe representar una acción o un estado con suficiente contexto: qué ocurrió, cuándo, sobre qué recurso, mediante qué identidad técnica, con qué resultado y, cuando sea posible, a través de qué sesión o petición. Los campos adecuados dependen de la aplicación. Un evento de autenticación, una modificación de permisos y una descarga de objeto no necesitan exactamente la misma estructura.

Es importante conservar identificadores estables que permitan relacionar fuentes. Un identificador de petición puede conectar el registro de una pasarela de API con el registro de aplicación; un identificador de sesión puede vincular autenticación y operaciones posteriores; el identificador interno de un objeto puede permitir seguir su historia a través de cambios de nombre o ruta. Cuando estos identificadores faltan, el analista se ve obligado a correlacionar por proximidad temporal o coincidencias de texto, técnicas generalmente menos concluyentes.

También conviene registrar el **resultado** de las operaciones. Una solicitud de eliminación rechazada por falta de permisos no tiene las mismas consecuencias que una operación completada. Un acceso de lectura autorizado por la aplicación no confirma necesariamente que el cliente recibiera todos los bytes solicitados. Un registro de aplicación que informa de un error puede necesitar correlación con la capa de almacenamiento. La semántica del evento debe estar documentada: qué lo desencadena, en qué momento se genera y qué garantías ofrece respecto al resultado real.

Los registros deben diseñarse evitando que la utilidad forense justifique almacenar secretos de forma insegura. Tokens de acceso, contraseñas, claves privadas, datos sensibles en cuerpos de petición o contenido completo de comunicaciones pueden aparecer accidentalmen-

te en sistemas de auditoría. Es preferible almacenar identificadores y metadatos suficientes para investigar, proteger los campos especialmente sensibles y disponer de procedimientos de acceso excepcional cuando corresponda. La seguridad del sistema de logs forma parte del diseño, no una tarea posterior.

2.5.4. Tiempo, sincronización y calidad cronológica

Las marcas temporales son uno de los elementos más utilizados y peor interpretados en una investigación. Una preparación adecuada define fuentes de tiempo fiables, mecanismos de sincronización y políticas de registro consistentes. Es recomendable conservar tiempo en UTC cuando la arquitectura lo permita, sin perder la información original sobre zona horaria, precisión y procedencia. Los sistemas que usan hora local deben documentar la configuración y las reglas de cambio estacional aplicadas.

La sincronización mediante servicios adecuados reduce discrepancias, pero no garantiza que todos los eventos compartan la misma precisión. Un registro puede generarse cuando ocurre la operación; otro, cuando llega a una cola; otro, cuando el colector lo escribe en disco. El campo `timestamp` puede referirse a cualquiera de estos momentos. Una organización preparada conoce las diferencias y procura conservar tanto el tiempo de origen como el de recepción cuando la plataforma lo permite.

Las incidencias de sincronización también deben generar evidencias. Si un servidor pierde su fuente de tiempo o presenta un desfase importante, esa circunstancia debería quedar registrada y ser accesible para el analista. En un sistema crítico, verificar periódicamente la deriva de los relojes es una tarea con valor forense, no solo administrativo. Las diferencias de milisegundos pueden ser irrelevantes para un caso de movimientos de archivos durante varios días y decisivas para reconstruir una cadena de peticiones de alta frecuencia.

2.5.5. Retención, rotación y conservación selectiva

La retención debe relacionarse con el tiempo habitual de detección e investigación. Una organización que descubre incidentes tras varias semanas no puede depender exclusivamente de registros que se eliminan cada pocos días. Por otra parte, almacenar toda la telemetría durante años puede ser inviable y desproporcionado. La solución suele combinar niveles: datos de alta granularidad con retención más corta, eventos de seguridad relevantes conservados durante periodos definidos y mecanismos para suspender la eliminación ordinaria cuando existe una investigación legítima.

Es útil construir una matriz de retención por fuente que indique productor, contenido, volumen aproximado, frecuencia de rotación, plazo, localización, responsable, permisos y mecanismo de exportación. La matriz se revisa cuando cambian los sistemas o los riesgos. También conviene ensayar las políticas en lugar de fiarse de su configuración nominal. Una regla que declara noventa días de conservación no garantiza que realmente existan noventa días de eventos si el espacio se agota, el proveedor aplica límites adicionales o la ingesta se interrumpe.

La **conservación extraordinaria** durante una investigación —por ejemplo, una retención legal autorizada o la suspensión controlada de la rotación de determinados registros— debe ser un procedimiento previsto, no una improvisación. Es necesario definir quién puede ordenarla, qué datos comprende, durante cuánto tiempo se mantendrá, qué medidas de seguridad incorpora y quién decide su levantamiento. El registro de la medida ha de incluir el fundamento y el momento exacto de aplicación.

Para servicios en la nube, las opciones de exportación y conservación dependen del contrato, el plan de servicio y las interfaces ofrecidas. No debe darse por supuesto que una consola permite recuperar información que ya ha expirado ni que una copia de seguridad sustituye a una auditoría de operaciones. Las pruebas de retención deberían incluir simulaciones de acceso a eventos históricos y confirmación de la integridad de la exportación.

2.5.6. Integridad, seguridad de los logs y separación de funciones

Los propios registros pueden ser objetivo de un atacante. Una intrusión con privilegios elevados puede permitir alterar o eliminar eventos almacenados localmente. Por ello, los sistemas de auditoría deberían incorporar controles que dificulten su manipulación no autorizada: centralización razonada, controles de acceso, segregación de funciones, almacenamiento con protecciones de inmutabilidad cuando resulte apropiado, supervisión de la ingesta y registro de cambios administrativos.

Ningún mecanismo convierte los logs en una fuente infalible. Un atacante puede impedir que el evento se genere, comprometer la aplicación antes de la escritura o provocar pérdidas en el transporte. Las garantías de inmutabilidad tampoco se extienden automáticamente a la veracidad del contenido original. Conservar de forma inalterable un evento falso no lo transforma en verdadero. El propósito de los controles es reducir oportunidades de manipulación y aportar información para detectar fallos, no prometer una confianza absoluta.

La separación de funciones es una medida valiosa. Cuando quien administra una aplicación también puede eliminar sin rastro todos sus registros, el riesgo investigador aumenta. Las organizaciones pueden asignar la administración del servicio y de su archivo de auditoría

a roles distintos, con procedimientos controlados para excepciones. En entornos pequeños quizás no sea posible una segregación perfecta; aun así pueden utilizarse copias externas, registros de acceso, alertas sobre cambios y revisiones periódicas.

La supervisión debe verificar la **salud de la evidencia**. ¿Están llegando eventos de todos los activos previstos? ¿Existen retrasos anómalos? ¿Han cambiado las tasas de ingesta? ¿Se mantienen los campos obligatorios? Una caída del volumen de registros puede indicar una avería, un cambio de configuración o una actuación maliciosa. Detectarla a tiempo evita descubrir durante una investigación que la plataforma llevaba semanas sin recibir información.

2.5.7. Arquitectura de conservación y cadena de custodia digital

La preparación forense requiere definir dónde se almacenarán las evidencias adquiridas y quién las controlará. No es recomendable improvisar un destino en el ordenador personal del analista o en una carpeta compartida sin trazabilidad. Una arquitectura adecuada puede combinar repositorios cifrados, controles de acceso basados en roles, verificaciones de integridad, copias de seguridad, retención definida y registros de auditoría sobre consultas y transferencias.

Cada evidencia debe recibir un identificador y mantener su relación con el origen. Si una adquisición produce varios segmentos, manifiestos y registros de ejecución, el conjunto tiene que poder reconocerse como una unidad lógica. Una estructura de directorios uniforme ayuda, pero no sustituye a los metadatos de custodia. Un nombre de archivo descriptivo puede modificarse; un identificador de evidencia estable y registrado es una referencia más sólida.

En equipos con varios analistas, la separación entre copia maestra y copias de trabajo reduce riesgos. La copia preservada debe mantenerse bajo controles estrictos, mientras que las herramientas procesan derivados identificados. Si es necesario trasladar materiales a otro laboratorio, deben preverse mecanismos seguros de transferencia, cifrado y verificación. No basta con enviar un enlace: debe quedar claro qué se entregó, a quién, cuándo y qué verificación de integridad se realizó tras la recepción.

También importa la recuperación ante fallos. Una organización puede conservar correctamente los datos y perderlos durante una avería del repositorio de evidencias. Las copias de seguridad y las pruebas de restauración deben incluir tanto los objetos como sus metadatos, permisos, índices y registros de custodia. La continuidad de una investigación prolongada depende de que el sistema de conservación sea operativamente sostenible.

2.5.8. Preparación de personas, funciones y autorizaciones

Las mejores herramientas pierden utilidad cuando no está claro quién tiene capacidad para actuar. Una organización preparada establece funciones: quién detecta y escala, quién autoriza la preservación, quién ejecuta adquisiciones, quién administra las fuentes, quién valora las consecuencias jurídicas y quién revisa los resultados. Estas funciones pueden recaer en una misma persona en organizaciones pequeñas, pero las responsabilidades deben seguir siendo reconocibles.

El procedimiento debe resolver situaciones fuera del horario habitual. Si un incidente ocurre de madrugada y un registro caducará antes del siguiente día laborable, ¿quién puede autorizar una exportación urgente? ¿Quién puede activar una retención extraordinaria en el proveedor de identidad? ¿Cómo se contacta con el propietario del servicio? ¿Qué hacer si la persona responsable no está disponible? Un directorio de contactos desactualizado puede causar pérdidas de evidencia tan graves como un fallo de software.

La formación debe centrarse en acciones concretas. El personal de soporte puede necesitar saber qué no debe hacer con un equipo potencialmente comprometido; los administradores deben conocer cómo conservar logs sin alterar innecesariamente el sistema; el equipo de seguridad debe comprender qué artefactos se pierden al reiniciar o restaurar; los asesores jurídicos deben conocer los límites técnicos de las fuentes que se pretenden solicitar. No es necesario convertir a toda la organización en especialistas forenses, sino evitar que actuaciones ordinarias destruyan información relevante.

Los simulacros permiten comprobar la coordinación. Un ejercicio puede plantear una cuenta sospechosa, un equipo con cifrado activo o una aplicación que pierde datos. El objetivo es medir si la organización localiza las fuentes, obtiene autorización, preserva a tiempo y registra las operaciones. El aprendizaje procede de comparar lo que se esperaba hacer con lo que realmente fue posible ejecutar.

2.5.9. Laboratorio, procedimientos y herramientas preparados

La preparación incluye disponer de un entorno técnico confiable. Los sistemas de análisis deben mantenerse separados de los entornos de producción en la medida necesaria, con almacenamiento suficiente, controles de acceso y herramientas cuyos comportamientos sean conocidos. No hace falta que todo laboratorio sea una infraestructura compleja, pero sí que el entorno permita trabajar sin contaminar accidentalmente las evidencias o mezclarlas entre casos.

Es conveniente mantener procedimientos documentados para situaciones habituales: recepción de dispositivos, adquisición de discos, captura controlada de memoria, exportación de registros, preservación de datos SaaS, tratamiento de soportes dañados y entrega de resultados. Cada procedimiento debe incluir prerrequisitos, limitaciones, registros esperados y criterios de verificación. Debe revisarse cuando cambian las herramientas, los sistemas operativos o los formatos.

Los laboratorios deberían conservar conjuntos de referencia y pruebas de herramientas. Un cambio de versión puede alterar la descodificación de artefactos sin que el usuario lo advierta de inmediato. Una actualización del sistema operativo de la estación también puede afectar a controladores, permisos o bibliotecas. Mantener un registro de versiones y realizar pruebas selectivas tras cambios relevantes aporta confianza y facilita explicar por qué se utilizó una configuración determinada.

La automatización puede mejorar consistencia, pero introduce dependencias nuevas. Un script que siempre ejecuta los mismos comandos ayuda a reducir olvidos; si contiene un error, lo repetirá con la misma eficacia. Por eso conviene versionar el código, probarlo con datos conocidos, mantener registros de ejecución y revisar los resultados cuando aparecen formatos o situaciones no previstos. **Automatizar una tarea no equivale a validar su interpretación.**

2.5.10. Preparación forense en la nube, contenedores y entornos efímeros

Los entornos contemporáneos presentan un desafío particular: muchos objetos que contienen evidencia existen solo durante periodos breves. Una función sin servidor puede ejecutarse y desaparecer sin dejar un sistema operativo accesible. Un contenedor puede destruirse y recrearse automáticamente. Una instancia escalada de forma dinámica puede utilizar almacenamiento efímero. Si la organización espera a identificar el incidente para decidir qué debe conservar, quizá ya no existan las fuentes más relevantes.

La preparación debe incluir la exportación anticipada de eventos críticos fuera de los componentes efímeros. En orquestadores, puede ser necesario conservar auditoría del plano de control, eventos de despliegue, manifiestos, imágenes utilizadas, identidades de servicio y registros de ejecución. En servicios gestionados, hay que verificar qué tipos de actividad audita el proveedor y cuáles dependen de una configuración opcional. No todos los planes de servicio proporcionan la misma granularidad ni los mismos periodos de retención.

También conviene conocer qué capturas pueden realizarse sin detener un servicio. Una instantánea de almacenamiento puede preservar determinados bloques, pero no necesariamente el estado de memoria, las sesiones o los mensajes pendientes. Una copia de configu-

ración puede explicar cómo estaba previsto que funcionara un servicio, pero no demostrar que cada petición se procesó conforme a esa configuración. La preparación forense incorpora estas distinciones al plan de adquisición antes de que exista presión operativa.

Los contratos con proveedores son parte de la capacidad técnica. Si se necesita acceder a registros que solo conserva un tercero, deberá saberse quién puede solicitarlos, qué autorización se exige, qué costes pueden generarse y cuáles son los plazos. Una organización sin procedimiento de solicitud puede perder evidencias mientras identifica al interlocutor correcto. Este problema es especialmente visible en servicios multirregión, plataformas de colaboración y sistemas administrados por proveedores externos.

2.5.11. Medir la preparación: indicadores que aporten información

La preparación forense no debería evaluarse mediante afirmaciones vagas como «tenemos SIEM» o «conservamos muchos logs». Resulta más útil medir capacidades observables. Un indicador puede ser el porcentaje de activos críticos con fuentes de auditoría inventariadas y comprobadas. Otro, el tiempo necesario para preservar los registros de una cuenta comprometida desde que se solicita la acción. También puede medirse el porcentaje de procedimientos de adquisición probados recientemente, la proporción de fuentes con sincronización temporal monitorizada o la tasa de exportaciones que superan verificaciones de integridad y completitud.

Estos indicadores necesitan contexto. Una reducción del tiempo de adquisición no siempre es buena si se consigue omitiendo comprobaciones. Un aumento del volumen de registros no garantiza más capacidad investigadora si se deben a duplicados o eventos poco útiles. Es preferible medir escenarios concretos: «ante una sospecha de acceso a documentos, ¿podemos identificar la sesión, la operación, el objeto y el resultado dentro del periodo de retención comprometido?». Una prueba de extremo a extremo responde mejor que una cifra agregada de gigabytes almacenados.

El seguimiento debe incluir los fallos detectados en incidentes y simulacros. Cada investigación permite descubrir carencias: campos que no se generan, exportaciones defectuosas, responsables ausentes, inconsistencias horarias o políticas mal configuradas. Convertir esos hallazgos en acciones asignadas y verificadas cierra el ciclo de mejora. Sin responsables ni fechas de revisión, la preparación forense corre el riesgo de convertirse en documentación decorativa.

2.5.12. Un programa gradual para organizaciones pequeñas y medianas

No todas las organizaciones pueden desplegar un centro de operaciones de seguridad o un laboratorio especializado. La preparación forense debe adaptarse a los recursos disponibles. En una empresa pequeña, las primeras medidas pueden ser identificar sistemas críticos y proveedores, conservar adecuadamente registros de autenticación y administración, sincronizar relojes, proteger las copias de seguridad, asegurar que los servicios permiten exportar auditoría y establecer un contacto para actuar en caso de incidente.

El siguiente nivel consiste en definir procedimientos de preservación, implantar controles de integridad, separar permisos de administración y custodia, documentar ventanas de retención y probar la recuperación de registros históricos. Cuando el riesgo y el tamaño lo justifiquen, se incorporan automatización, centralización avanzada, simulacros periódicos y herramientas especializadas. Esta evolución por etapas suele ser más efectiva que adquirir una plataforma compleja sin responsables ni casos de uso definidos.

El coste de preparar una investigación debe compararse con el coste potencial de no poder realizarla. Un incidente no esclarecido puede prolongar la exposición, impedir determinar qué datos se vieron afectados o dificultar decisiones contractuales y legales. No obstante, tampoco sería razonable intentar conservar cada bit generado por cada sistema. El equilibrio se encuentra en priorizar escenarios de mayor impacto y fuentes cuya desaparición impediría responder a preguntas importantes.

En el caso del repositorio, una organización razonablemente preparada habría establecido auditoría de autenticación, operaciones sobre objetos y cambios de permisos; habría inventariado el proveedor y la aplicación; habría documentado la retención efectiva; y dispondría de un mecanismo autorizado para conservar eventos antes de su caducidad. Con esas condiciones, el analista podría contrastar la autenticación sospechosa con los movimientos documentales sin tener que improvisar accesos ni depender de capturas informales.

2.5.13. Simulacro de preparación: desaparición de documentos

Imaginemos que una organización desea comprobar su capacidad antes de sufrir un incidente real. En un repositorio de pruebas crea varias carpetas, mueve documentos, cambia permisos y provoca una sincronización conflictiva con una cuenta de ensayo. Mantiene un registro de referencia con las acciones realizadas y sus tiempos reales. Después entrega al equipo encargado únicamente un aviso semejante al que recibiría en producción: «Faltan documentos; hubo una autenticación inusual».

El equipo debe localizar las fuentes disponibles, solicitar autorización, exportar los datos y formular hipótesis. El ejercicio no se evalúa solo por si descubre correctamente el movimiento de archivos. También se comprueba cuánto tardó en encontrar al responsable del servicio, si obtuvo respuestas completas de la API, si los relojes eran coherentes, si los registros mostraban el resultado de las operaciones y si quedó documentación suficiente para repetir el tratamiento de las exportaciones.

En una revisión posterior pueden encontrarse fallos concretos. Quizá el proveedor de identidad conservaba las autenticaciones, pero no los detalles del método utilizado; quizá la aplicación no registraba el identificador interno del objeto; quizá una exportación de miles de eventos omitió páginas porque el script no trataba correctamente un token de continuación. Estos descubrimientos permiten mejorar el sistema antes de una investigación real y sirven al mismo tiempo como pruebas de adecuación de los procedimientos.

La evaluación también debería revisar el impacto sobre la privacidad. Si el ejercicio exige inspeccionar innecesariamente cuentas de personas reales, el propio diseño es deficiente. Utilizar cuentas y datos sintéticos, definir reglas de acceso y separar objetivos técnicos de información personal demuestra que la preparación forense puede reforzar las garantías en lugar de debilitarlas.

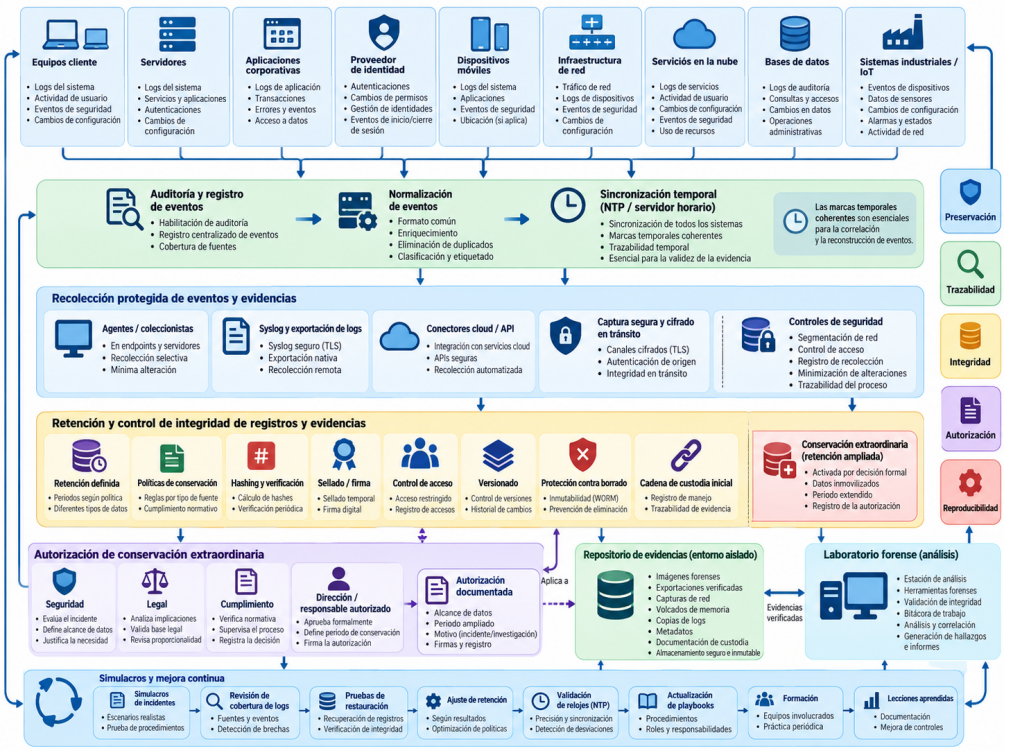


Figura 12: Arquitectura de preparación forense

2.5.14. La preparación forense como propiedad de la organización

La preparación forense funciona cuando deja de depender de la memoria de una única persona. Una organización puede contar con un experto capaz de obtener registros complejos, pero seguir siendo vulnerable si ese conocimiento no está documentado, si nadie puede sustituirle o si las autorizaciones tardan más que el periodo de retención. Las capacidades duraderas requieren procedimientos sencillos, inventario actualizado, contactos, pruebas y revisiones.

Desde una perspectiva estratégica, la preparación aporta algo más que mejores informes. Reduce la incertidumbre inicial durante los incidentes, facilita tomar decisiones proporcionadas, disminuye el riesgo de destruir evidencias mediante operaciones de recuperación y mejora la relación con asesores jurídicos, aseguradoras, proveedores y autoridades cuando es necesario comunicar resultados. No garantiza que todas las investigaciones puedan resolverse, pero evita que la organización pierda innecesariamente oportunidades de conocer lo sucedido.

El objetivo final no es que cada sistema registre todo, sino que la organización conozca de antemano **qué podrá demostrar, con qué datos y durante cuánto tiempo**. Esa pregunta relaciona arquitectura, seguridad, operaciones, calidad y derechos de las personas. Por eso la preparación forense debe entenderse como una capacidad transversal y revisable, no como la compra aislada de una herramienta.

2.6. Conclusión: la investigación como proceso auditable

El análisis forense digital necesita herramientas, pero depende de una disciplina que empieza antes de utilizarlas. El encargo ha de traducirse a preguntas investigables; esas preguntas determinan qué fuentes pueden ser relevantes; las fuentes condicionan las técnicas disponibles; y las técnicas deben producir resultados que puedan comprobarse e interpretarse sin ocultar su incertidumbre. Cuando se invierte este orden y se comienza explorando datos sin propósito definido, aumenta el riesgo de exceder el alcance, interpretar coincidencias como causalidades o perder información esencial mientras se persiguen detalles secundarios.

Planificar no significa anticipar todos los acontecimientos. Una investigación puede descubrir evidencias inesperadas, cambiar de hipótesis y modificar prioridades. Lo que la hace rigurosa no es seguir un guion inmutable, sino conservar la capacidad de justificar sus cambios. La trazabilidad se refiere tanto a la cadena de custodia de los objetos como al historial de decisiones del investigador. Ambas historias deben ser coherentes y revisables.

Las normas ISO/IEC ofrecen referencias para el tratamiento de evidencia, la adecuación de los métodos, el análisis y la organización del proceso. NIST contribuye con orientación técnica, criterios de prueba y una perspectiva de integración con la respuesta a incidentes. SWGDE desarrolla buenas prácticas de aplicación directa. Ninguna referencia reemplaza la necesidad de comprender los sistemas examinados, comprobar las herramientas, respetar el alcance autorizado y explicar el significado real de los datos.

La hipótesis es un instrumento de trabajo, no un destino predeterminado. Los hechos deben utilizarse para poner a prueba las explicaciones, incluidas aquellas que contradicen la sospecha inicial. Repetir una operación, emplear una segunda herramienta, comprobar la cobertura de los registros y conservar los resultados negativos son medidas concretas para aumentar la confianza. Cuando la evidencia no permite una atribución o una explicación completa, reconocer el límite constituye una conclusión profesional válida.

Finalmente, la capacidad de investigar depende de la preparación del entorno. La auditoría, la retención, la sincronización temporal, el inventario de activos, los permisos de extracción y la conservación de evidencias deben diseñarse antes del incidente. La preparación forense conecta así la investigación con la arquitectura y el gobierno cotidiano de la tecnología. Un

método excelente no puede recuperar retrospectivamente toda la información que nunca se registró o que ya fue eliminada.

> **Idea central del capítulo:** una investigación defendible no necesita aparentar certeza absoluta. Necesita demostrar que sus preguntas fueron pertinentes, sus métodos adecuados, sus datos preservados, sus inferencias contrastadas y sus límites declarados.

En los capítulos siguientes se examinarán los requisitos jurídicos, la escena digital, la cadena de custodia y las técnicas de adquisición. El marco presentado aquí servirá para interpretar esas actividades como decisiones dentro de un proceso de investigación, y no como una colección inconexa de herramientas y comandos.

2.7. Referencias y lecturas recomendadas

Las referencias siguientes son fuentes técnicas y normativas para ampliar los conceptos desarrollados. Las normas ISO/IEC son documentos sujetos a derechos de autor y, en general, su texto completo requiere acceso a través de los canales oficiales. Las descripciones de su ámbito incluidas en este capítulo se han elaborado a partir de la información pública de los organismos editores y de principios técnicos generales; no reproducen su articulado. Para trabajos profesionales debe verificarse la edición y vigencia aplicables en la fecha de actuación.

1. **ISO/IEC 27037:2012.** *Information technology — Security techniques — Guidelines for identification, collection, acquisition and preservation of digital evidence.* International Organization for Standardization. Ficha oficial.
2. **ISO/IEC 27041:2015.** *Information technology — Security techniques — Guidance on assuring suitability and adequacy of incident investigative method.* International Organization for Standardization. Ficha oficial.
3. **ISO/IEC 27042:2015.** *Information technology — Security techniques — Guidelines for the analysis and interpretation of digital evidence.* International Organization for Standardization. Ficha oficial.
4. **ISO/IEC 27043:2015.** *Information technology — Security techniques — Incident investigation principles and processes.* International Organization for Standardization. Ficha oficial.
5. **ISO/IEC 27035-1:2023.** *Information technology — Information security incident management — Part 1: Principles and process.* International Organization for Standardization. Ficha oficial.

6. **ISO/IEC 27035-2:2023.** *Information technology — Information security incident management — Part 2: Guidelines to plan and prepare for incident response.* International Organization for Standardization. Ficha oficial.
7. **ISO/IEC 17025:2017.** *General requirements for the competence of testing and calibration laboratories.* International Organization for Standardization. Ficha oficial.
8. **Kent, K.; Chevalier, S.; Grance, T.; Dang, H. (2006).** *Guide to Integrating Forensic Techniques into Incident Response.* NIST SP 800-86. Publicación oficial. DOI: 10.6028/NIST.SP.800-86.
9. **Nelson, A.; Rekhi, S.; Scarfone, K.; Souppaya, M. (2025).** *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile.* NIST SP 800-61 Rev. 3. Publicación oficial. DOI: 10.6028/NIST.SP.800-61r3.
10. **Guttman, B.; White, D. R.; Williams, S.; Walraven, T. (2022).** *Digital Evidence Preservation: Considerations for Evidence Handlers.* NISTIR 8387. Publicación oficial. DOI: 10.6028/NIST.IR.8387.
11. **NIST.** *Computer Forensics Tool Testing (CFTT) Program.* Descripción del programa.
12. **SWGDE (2025).** *Best Practices for Digital Evidence Collection.* Documento 18-F-002, versión 2.0. Publicación oficial.
13. **SWGDE (2025).** *Best Practices for Computer Forensic Acquisition.* Documento 17-F-002, versión 2.1. Publicación oficial.
14. **SWGDE (2025).** *Best Practices for Computer Forensic Examinations.* Documento 18-F-001, versión 2.0. Publicación oficial.
15. **SWGDE (2024).** *Minimum Requirements for Testing Tools Used in Digital and Multimedia Forensics.* Documento 18-Q-001, versión 2.1. Publicación oficial.
16. **SWGDE (2018).** *Requirements for Report Writing in Digital and Multimedia Forensics.* Documento 18-Q-002, versión 1.0. Publicación oficial.
17. **SWGDE (2024/2025).** *Best Practices for Digital Evidence Acquisition, Preservation, and Analysis from Cloud Service Providers.* Documento 23-F-004, versión 1.1. Referencia en NIST OSAC.

3. Marco legal, responsabilidad y ética profesional

> "El aspecto más triste de la vida actual es que la ciencia reúne conocimiento mucho más rápido de lo que la sociedad adquiere sabiduría." ("The saddest aspect of life right now is that science gathers knowledge faster than society gathers wisdom.")
>
> — Isaac Asimov, Isaac Asimov's Book of Science and Nature Quotations (1988) NOTA: Existe un abismo entre el desarrollo de herramientas forenses capaces de extraerlo absolutamente todo frente a la madurez jurídica y ética necesaria para saber qué se puede tocar, cuándo y con qué garantías.

El análisis forense digital se desarrolla en un terreno en el que la capacidad técnica no equivale a la facultad de actuar. Que una herramienta permita acceder a un teléfono, recuperar mensajes eliminados o reconstruir la actividad de una cuenta no significa que el analista esté autorizado a hacerlo. La distinción parece elemental, pero condiciona todas las etapas de una investigación: desde la primera conversación con quien encarga el trabajo hasta la destrucción o devolución de las copias obtenidas. En un laboratorio se puede demostrar la posibilidad de una adquisición; en un caso real, además, es imprescindible justificar su legitimidad.

Un ordenador contiene documentos de trabajo, pero también comunicaciones privadas, información sobre terceras personas, credenciales, fotografías, datos médicos, mensajes familiares y rastros de actividades que nada tienen que ver con el suceso investigado. Una cuenta en la nube puede pertenecer a una organización y, al mismo tiempo, incorporar información de trabajadores, clientes y proveedores sometida a diferentes deberes de confidencialidad. Incluso un registro aparentemente inocuo —la hora de inicio de sesión o la dirección IP asignada a un dispositivo— puede convertirse en dato personal cuando permite identificar directa o indirectamente a una persona. La investigación forense necesita esos registros para reconstruir acontecimientos, pero no puede tratar la información disponible como si careciera de titulares, derechos o contexto.

A la dificultad técnica se añade la diversidad de escenarios. Un juzgado puede encomendar a un perito el examen de un soporte concreto. Una empresa puede investigar una posible extracción de información confidencial. Una aseguradora puede solicitar un dictamen sobre un incidente. Un equipo de respuesta puede adquirir evidencias mientras contiene un ataque. Un abogado puede pedir la evaluación crítica de un informe de la parte contraria. Las obligaciones no son idénticas: cambian la fuente de legitimación, el alcance autorizado, las garantías exigibles y los destinatarios de los resultados.

El objetivo de este capítulo consiste en proporcionar al profesional una forma rigurosa de razonar sobre tales límites. Se estudiarán la autorización, la legitimidad del tratamiento y la

proporcionalidad; las diferencias entre los procedimientos judiciales y corporativos; la privacidad y la protección de datos; los problemas de jurisdicción, especialmente en servicios en la nube; y los deberes éticos y profesionales de quienes identifican, adquieren, analizan e interpretan evidencias digitales. No se pretende convertir al investigador en jurista. Se pretende evitar que el desconocimiento jurídico convierta una actuación técnicamente impecable en una intervención cuestionable o lesiva para los derechos de las personas.

El marco de referencia principal será el de **España y la Unión Europea**, con atención a instrumentos internacionales cuando el supuesto lo requiera. Las reglas expuestas deben contrastarse siempre con el texto vigente, el procedimiento aplicable y las circunstancias del caso. La valoración de la licitud, de la admisibilidad de una prueba o de la existencia de responsabilidades corresponde a los órganos y profesionales competentes; el perito no sustituye sus funciones.

> **Principio rector:** el acceso técnicamente posible no es necesariamente un acceso legítimo. Antes de actuar deben estar claros el fundamento de la intervención, las preguntas que se pretende responder, los límites del examen y quién está facultado para autorizarlo.

3.1. Autorización y legitimidad de una investigación

3.1.1. Poder acceder no significa tener derecho a examinar

En la práctica cotidiana resulta frecuente que las facultades técnicas y las jurídicas se confundan. Un administrador puede disponer de privilegios suficientes para consultar buzones, copiar volúmenes virtuales y leer registros de autenticación. Un responsable de sistemas puede controlar un equipo corporativo que utiliza una persona determinada. El titular de un contrato de almacenamiento puede descargar todas las copias de seguridad asociadas al servicio. Ninguna de esas circunstancias resuelve por sí sola si un análisis concreto resulta lícito, proporcionado y compatible con las obligaciones de confidencialidad.

El **control material** de un dispositivo describe quién puede manipularlo. La **titularidad** se refiere a quién ostenta determinados derechos sobre él o sobre el servicio. La **facultad de administración** permite realizar operaciones técnicas dentro de un ámbito de gestión. La **autorización para investigar** habilita unas actuaciones dirigidas a un fin delimitado. Estos planos pueden coincidir, pero también pueden separarse por completo. Una universidad puede ser propietaria de un portátil, un profesor puede usarlo diariamente, el departamento de sistemas puede administrarlo y el acceso a determinados contenidos personales puede seguir estando limitado por las garantías aplicables.

Es por eso que una orden informal como «revísalo todo y dime qué encuentras» constituye un punto de partida deficiente. Su vaguedad no evita responsabilidades: las desplaza hacia el profesional que decide unilateralmente hasta dónde llegar. La primera obligación práctica consiste en precisar quién solicita el trabajo, con qué competencia, para qué finalidad, sobre qué objetos y mediante qué operaciones. En una investigación interna pueden requerirse intervenciones coordinadas de seguridad, asesoría jurídica, recursos humanos y protección de datos. En una investigación penal, el régimen de habilitación depende de las diligencias acordadas por la autoridad judicial y de la legislación procesal.

El analista debe trabajar con documentos que permitan reconstruir esa legitimidad. Una autorización no necesita adoptar siempre la misma forma, pero su contenido debe poder verificarse: identidad y cargo del autorizante, fecha, hechos o incidente que motiva la actuación, sistemas cubiertos, intervalo temporal, categorías de datos, técnicas autorizadas, restricciones expresas, personas que ejecutarán la actuación y reglas para ampliar el alcance. Cuando una resolución judicial existe, hay que atender a sus términos efectivos, no a una interpretación extensiva de lo que «seguramente se quiso decir».

3.1.2. Tres preguntas que deben resolverse antes de comenzar

Conviene ordenar la revisión jurídica inicial alrededor de tres cuestiones relacionadas, pero distintas. **La primera es quién tiene facultad para ordenar o consentir una operación determinada**. **La segunda es qué normas permiten tratar la información que se obtendrá**. **La tercera es si la intervención concreta resulta necesaria y proporcionada respecto al objetivo**. Contestar una sola no hace desaparecer las otras dos.

Un investigador puede recibir instrucciones del representante de una empresa para examinar los registros de una plataforma corporativa. La empresa puede tener una base legítima para ciertos tratamientos, pero deberá delimitar las consultas y controlar el acceso de quienes intervengan. Un empleado puede consentir voluntariamente la entrega de determinados archivos, pero ese consentimiento no convierte en irrelevantes los derechos de terceras personas mencionadas en ellos. Una autoridad puede obtener un soporte físico durante una diligencia; en determinados supuestos, el acceso a los datos alojados en ese soporte exige una habilitación adicional y específica.

Estos problemas no se resuelven con una fórmula universal. El análisis debe identificar la naturaleza del caso —judicial, laboral, contractual, administrativo o de seguridad—, los titulares potencialmente afectados y la operación pretendida. Preservar un archivo de auditoría en el servidor de la propia organización puede presentar exigencias distintas de abrir el correo privado del usuario, clonar su teléfono personal o iniciar una sesión en una cuenta alojada por un proveedor extranjero. El profesional no tiene por qué emitir una opinión jurídica

definitiva sobre cada paso, pero sí debe detectar las situaciones en las que es imprescindible obtenerla antes de continuar.

La autorización y su justificación deben registrarse **antes** de ejecutar acciones intrusivas, salvo supuestos de actuación urgente previstos legalmente y debidamente amparados, cuya apreciación no corresponde improvisar al técnico. Una necesidad operativa intensa no crea automáticamente una excepción jurídica. Cuando existe riesgo de pérdida inmediata de datos, una respuesta responsable puede consistir en solicitar una orden de conservación, asegurar registros cuya preservación ya esté legitimada o elevar la decisión con carácter urgente a las personas competentes.

3.1.3. Finalidad, necesidad y proporcionalidad

La legitimidad no se agota en disponer de un documento firmado. También exige que la medida sea adecuada al propósito perseguido. Una investigación sobre accesos indebidos a un repositorio durante dos días no justifica sin mayor razonamiento la lectura indiscriminada de años de correspondencia personal. Una sospecha sobre la instalación de un programa no convierte en pertinentes todas las fotografías del dispositivo. El hecho de que la información pueda recuperarse técnicamente tampoco obliga a recuperarla.

La **finalidad** identifica el problema que se intenta esclarecer. La **necesidad** exige explicar por qué una determinada medida aporta información relevante y por qué no basta una alternativa menos intrusiva que permita alcanzar razonablemente el mismo objetivo. La **proporcionalidad** obliga a ponderar la intensidad de la intervención frente a la importancia del interés protegido, los riesgos y los derechos que puedan verse afectados. Estos conceptos poseen un contenido jurídico cuya aplicación concreta depende del caso, pero tienen consecuencias técnicas muy prácticas.

Por ejemplo, ante un posible uso indebido de una cuenta de colaboración empresarial, puede ser razonable empezar por los registros de autenticación, los eventos de descarga y la configuración de permisos. Si esos datos permiten establecer lo ocurrido, quizá no sea necesario acceder al contenido de los documentos descargados. Si los registros revelan una operación cuya naturaleza no puede determinarse sin examinar un archivo concreto, podrá plantearse una ampliación motivada y delimitada. El orden de consulta no es una regla automática: es una forma de justificar por qué se elige una fuente frente a otra más invasiva.

La minimización también puede expresarse mediante parámetros verificables: identificadores de cuentas, fechas iniciales y finales, rutas afectadas, categorías de evento, destinatarios de una comunicación o tipos de artefactos. Esos filtros deben documentarse con precisión.

Sin embargo, hay ocasiones en que adquirir una imagen completa de un soporte resulta técnicamente necesario para preservar sectores, estructuras o metadatos que quedarían excluidos con una copia selectiva. La adquisición amplia y el examen ilimitado son decisiones diferentes. Puede conservarse una imagen íntegra bajo controles estrictos y restringir las búsquedas analíticas a lo autorizado, siempre que el fundamento y las garantías de la adquisición sean adecuados.

3.1.4. La delimitación del alcance como garantía

El alcance constituye una barrera de control para el investigador y una garantía para las personas afectadas. Debe definir tanto lo **incluido** como lo **excluido**. Un encargo podría autorizar el análisis de los eventos de acceso a una aplicación, el historial de cambios de un conjunto determinado de archivos y las conexiones desde dos terminales corporativos durante una semana. Al mismo tiempo, podría excluir el contenido de las conversaciones privadas, otros departamentos, dispositivos particulares y periodos anteriores, salvo autorización posterior.

Es frecuente que durante el examen aparezcan indicios que apunten hacia otra fuente. Por ejemplo, un registro de descarga puede mostrar que la cuenta investigada se utilizó desde un teléfono ajeno al inventario. El hallazgo justifica formular una nueva pregunta, pero no habilita automáticamente la adquisición del teléfono. El analista debe conservar el dato que ha encontrado, detenerse en el límite de su mandato y solicitar una ampliación cuando proceda. Esa ampliación debería identificar la nueva fuente, su relevancia, las operaciones previstas, las personas afectadas y las razones que justifican la intervención.

Otra situación delicada aparece cuando la evidencia contiene información sobre hechos distintos del encargo inicial. Un análisis sobre filtración documental puede revelar datos íntimos, comunicaciones protegidas o una posible actividad ilícita no relacionada. La respuesta no consiste en explotar libremente ese descubrimiento. Debe preservarse la confidencialidad, limitar la difusión y trasladar la cuestión a quien corresponda para decidir qué tratamiento resulta legítimo. En contextos judiciales existen reglas particulares para hallazgos casuales, secreto profesional y acceso a información especialmente protegida; su aplicación requiere dirección jurídica y procesal.

La revisión del alcance tiene una dimensión temporal. Un plan inicialmente proporcionado puede dejar de serlo si aparecen fuentes menos invasivas, se demuestra que una hipótesis era falsa o se obtiene la información necesaria. La autorización no convierte todo lo permitido en obligatorio. Una práctica madura incluye momentos de reconsideración: ¿sigue siendo necesaria la siguiente adquisición?, ¿persiste la finalidad?, ¿podemos contestar ya las preguntas?, ¿qué riesgo introducirá ampliar la búsqueda?

3.1.5. Documentar la autorización y sus cambios

La documentación mínima de un expediente debería permitir reconstruir qué se solicitó, quién lo autorizó y en qué condiciones se realizó. Un registro de alcance puede conservar el identificador del caso, el motivo de apertura, las preguntas investigables, la autoridad u órgano que decide, las categorías de información, los sistemas afectados, los responsables de ejecución y las restricciones conocidas. A ese registro se incorporarán las ampliaciones o modificaciones sucesivas, con su fecha y justificación.

Las instrucciones de un cliente privado deberían distinguirse de las decisiones técnicas adoptadas por el perito. El cliente define el encargo y su finalidad legítima; el profesional decide, dentro de sus competencias y autorizaciones, cómo obtener resultados fiables. Cuando un cambio altere materialmente los derechos afectados, el profesional no debe convertirlo en una simple variación instrumental. Revisar una ruta adicional dentro del mismo volumen puede ser una adaptación menor; acceder por primera vez a un buzón privado o a la cuenta personal de un tercero es una intervención de naturaleza distinta.

También conviene registrar expresamente las acciones **no realizadas**. Si se decidió no adquirir un teléfono por falta de autorización, no recuperar conversaciones privadas por irrelevancia o no consultar una base de datos externa por dudas de jurisdicción, la anotación contextualiza las limitaciones del informe. Una conclusión como «no se hallaron comunicaciones externas» sería equívoca si no se examinó la principal fuente donde podrían haberse producido. El alcance no es un anexo administrativo: forma parte del significado técnico de cualquier resultado.

3.1.6. Escenario práctico: sospecha de filtración desde un portátil corporativo

Una empresa de ingeniería detecta que varias carpetas de proyectos fueron consultadas la noche anterior a la salida de un trabajador. El responsable de tecnología solicita una copia completa del portátil que utilizaba y pretende recuperar todos sus mensajes. La sospecha puede justificar una investigación; sin embargo, la medida pedida requiere una valoración adicional.

El investigador comienza por separar las preguntas: si se accedió a determinados archivos, si se copiaron fuera del entorno autorizado, qué identidades y dispositivos aparecen asociados a las operaciones y si existen explicaciones legítimas. Solicita información sobre las políticas de uso de equipos, las advertencias e instrucciones conocidas por la plantilla, la administración del dispositivo, la participación de las áreas correspondientes y la base jurídica del tratamiento. Propone preservar los registros de acceso sujetos a rotación y, bajo autorización, examinar primero los eventos relacionados con las rutas y el intervalo definidos.

Si se concluye que es necesaria una adquisición del portátil, el alcance del análisis debe quedar igualmente delimitado. La imagen puede contener información ajena al expediente; los filtros, los accesos autorizados y la documentación deben impedir que esa información se transforme en un objeto de exploración general. Si aparecen documentos de terceras personas o comunicaciones protegidas, el procedimiento debe prever cómo segregarlos y cuándo solicitar orientación jurídica. El informe recogerá los hallazgos técnicos y evitará afirmar, por el mero uso de una cuenta, que una persona determinada ejecutó materialmente cada acción.

La lección del ejemplo no es que siempre deba elegirse una adquisición selectiva ni que una imagen completa esté prohibida. La lección es que **la decisión técnica debe estar vinculada a la finalidad y a una autorización real**, con un tratamiento proporcional de la información afectada.

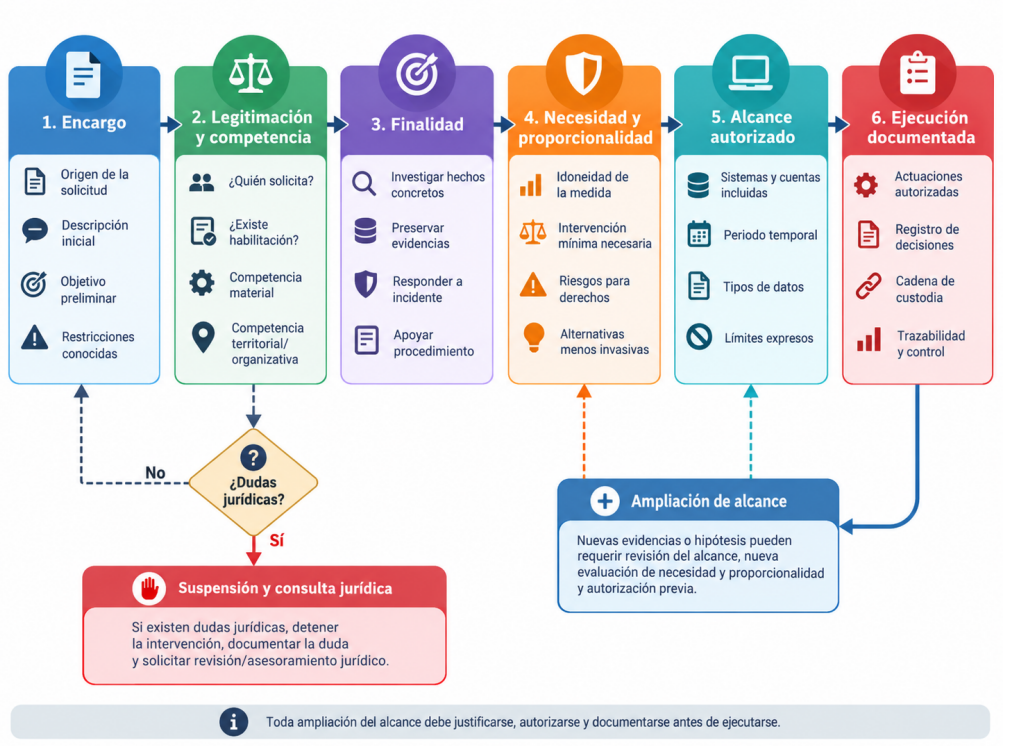


Figura 13: La intervención forense

3.2. Tratamiento de evidencias en investigaciones judiciales y corporativas

3.2.1. La evidencia no cambia de naturaleza, pero sí su contexto jurídico

Un registro de autenticación es técnicamente el mismo objeto con independencia de que lo examine una unidad policial, un equipo de seguridad empresarial o un perito de parte. Lo que cambia son las competencias de quienes intervienen, las garantías del procedimiento, las posibilidades de acceso, las reglas de comunicación y el modo en que el resultado podrá utilizarse. Por ello, no basta con definir la cadena de custodia o calcular un resumen criptográfico: hay que situar cada actuación en su marco procesal o contractual.

La expresión «prueba digital» se utiliza coloquialmente para describir archivos, registros, imágenes forenses, fotografías o mensajes. Conviene diferenciar el **dato o evidencia digital** obtenido durante una investigación del **medio probatorio** a través del cual se incorpora a un procedimiento y de la **valoración** que hará el órgano competente. La existencia de un archivo relevante no garantiza por sí sola que sea admisible ni que demuestre la interpretación propuesta. Tampoco un informe pericial sustituye al juzgador. El perito aporta conocimientos especializados, expone operaciones y explica limitaciones; el resultado jurídico es otra cuestión.

En el orden jurisdiccional civil español, la Ley de Enjuiciamiento Civil contempla medios relacionados con la reproducción de palabras, sonidos e imágenes y con instrumentos que permiten archivar o reproducir datos (entre otros, artículos 299, 382 y 384). Es una referencia útil para comprender que las evidencias electrónicas se introducen y valoran dentro de un procedimiento, sometidas a reglas de contradicción y valoración. En el orden penal, la Ley de Enjuiciamiento Criminal establece un régimen específico para diversas medidas de investigación tecnológica, con requisitos y garantías que no se trasladan mecánicamente a los encargos privados.

3.2.2. Investigación penal: intervención y control judicial

En una investigación penal pueden intervenir policía judicial, Ministerio Fiscal, órganos judiciales, especialistas y peritos. Las facultades de cada actor no son intercambiables. El analista puede ser requerido para realizar operaciones técnicas dentro de una diligencia acordada por la autoridad competente. Ese encargo exige conocer la resolución, sus límites y el procedimiento de preservación y entrega de las evidencias.

La Ley de Enjuiciamiento Criminal española contiene previsiones relevantes en los artículos **588 bis** y siguientes sobre medidas de investigación tecnológica. En particular, los artículos

588 sexies a, b y c regulan extremos del registro de dispositivos de almacenamiento masivo de información. Un principio especialmente importante es que **la mera incautación de un dispositivo durante un registro no legitima automáticamente el acceso a su contenido**. La motivación y el alcance del acceso deben examinarse conforme a las reglas aplicables, incluida la autorización judicial cuando corresponda. Es una distinción esencial entre aprehender el objeto físico y registrar el universo informativo que contiene.

Los registros remotos de equipos informáticos se someten a un régimen específico en los artículos **588 septies**; no deben confundirse con una operación habitual de administración remota ni con la simple exportación autorizada de un registro corporativo. Las medidas de conservación de datos y otras diligencias relacionadas tienen también previsiones diferenciadas. El técnico ha de saber reconocer cuándo una operación entra en terrenos sometidos a control judicial, para no tratarla como un problema de credenciales o conectividad.

La autorización judicial delimita objeto, duración, condiciones y garantías según la medida. Desde el punto de vista forense, eso implica preparar una actuación capaz de demostrar qué se examinó, qué procedimientos se aplicaron, qué copias se realizaron y si surgieron circunstancias que exigían una nueva decisión judicial. La tentación de «aprovechar» que una imagen ya está montada para consultar otros directorios puede resultar incompatible con el mandato. La técnica debe obedecer al alcance, no ampliarlo silenciosamente.

3.2.3. Aprehensión, adquisición y análisis: operaciones distintas

La **aprehensión** o intervención de un dispositivo afecta a la posesión o disponibilidad del soporte. La **adquisición** produce una copia o extracción de información. El **análisis** interpreta datos y artefactos. Son operaciones que pueden practicarse por personas distintas, en lugares diferentes y bajo condiciones específicas. Su diferenciación permite revisar tanto la integridad como la legitimidad de cada fase.

Supongamos que se interviene un teléfono durante una diligencia. La actuación sobre el objeto puede incluir su identificación, documentación, aislamiento y traslado. La posterior extracción lógica, física o mediante un servicio de respaldo puede requerir otras decisiones, dependiendo del título habilitante. No es correcto afirmar que «se analizó el teléfono porque estaba intervenido» sin documentar qué autorización amparaba el acceso. Del mismo modo, una autorización para examinar información almacenada no debe interpretarse automáticamente como permiso para acceder activamente a cuentas remotas vinculadas, realizar comunicaciones con terceros o modificar contenidos.

El informe técnico debería permitir seguir la secuencia sin confusión: dispositivo recibido, estado, precintos, responsables de custodia, método de adquisición, identificadores de la

extracción, comprobaciones de integridad, acciones sobre copias y resultados. Si el acceso técnico exige alterar el estado del equipo —por ejemplo, iniciar una sesión, desbloquear un dispositivo o ejecutar un agente de adquisición— debe explicarse qué cambios podrían producirse y por qué eran razonables y autorizados.

3.2.4. Custodia, integridad y contradicción

La cadena de custodia documenta la trayectoria de la evidencia y las personas que la han tenido bajo su responsabilidad. Incluye entrega, recepción, almacenamiento, apertura, reproducción y, cuando corresponda, devolución. Su utilidad consiste en poder explicar razonablemente que el objeto examinado es el que se obtuvo y qué ocurrió con él. La ausencia de una anotación no tiene una consecuencia procesal idéntica en todos los asuntos: habrá que valorar su naturaleza, relevancia y efecto sobre la fiabilidad y el procedimiento. No corresponde al técnico declarar automáticamente «nula» toda evidencia con una incidencia documental.

Los resúmenes criptográficos ayudan a detectar diferencias entre determinadas representaciones binarias, pero no prueban por sí solos el origen, la licitud de la adquisición o la exactitud de una interpretación. Si una exportación se genera desde una interfaz de proveedor, el hash de ese fichero permitirá comprobar que el fichero no cambió después de su generación. No demostrará, por sí mismo, que la plataforma exportó todos los eventos existentes, que el usuario mostrado era el autor físico de la acción o que las marcas temporales reflejaban un reloj correctamente sincronizado.

La posibilidad de **contradicción** —que las partes puedan conocer y discutir los elementos relevantes en los términos del procedimiento— refuerza la importancia de conservar metodologías, versiones de herramientas, filtros, parámetros, ficheros de entrada y resultados intermedios. Un informe que solo presenta capturas seleccionadas dificulta su revisión. A veces no será posible compartir datos completos por confidencialidad o protección de terceros; en tal caso deberán emplearse mecanismos procesales y técnicos adecuados para permitir el examen sin difundir información innecesaria.

3.2.5. Perito judicial, perito de parte y técnico que interviene en los hechos

La función de un especialista puede variar. Un **perito designado judicialmente** recibe un cometido dentro del procedimiento. Un **perito de parte** es contratado por una persona u organización interesada en el litigio. Un **analista de respuesta a incidentes** puede haber participado antes en la contención y recuperación de los sistemas, y ser llamado después para explicar decisiones técnicas. Un **testigo de hechos** relata lo que presenció o realizó. A

veces una misma persona reúne conocimientos técnicos y participación directa; esa doble condición debe hacerse transparente.

Ser contratado por una parte no equivale a tener permiso para deformar los resultados. La independencia intelectual se manifiesta en la elección de métodos adecuados, en la declaración de limitaciones y en la capacidad de comunicar hallazgos desfavorables para quien paga el trabajo. El cliente puede definir preguntas legítimas y exigir claridad, pero no debería dictar qué hechos «deben» encontrarse. Si el análisis contradice la hipótesis inicial, la responsabilidad profesional exige expresarlo.

El técnico que ejecutó medidas urgentes durante un incidente merece especial atención. Su intervención pudo modificar procesos, credenciales, conexiones o registros. Esos cambios pueden haber sido necesarios para proteger el servicio, pero deben distinguirse de los artefactos atribuibles al incidente. Una cronología coherente incorpora la actuación defensiva como evento de la investigación, no como ruido que se omite. Las conclusiones tendrán que reconocer las limitaciones derivadas de operaciones irreversibles.

3.2.6. Investigación corporativa: propiedad, poder de dirección y límites

Las organizaciones poseen intereses legítimos en proteger su información, garantizar la seguridad de los sistemas y cumplir obligaciones contractuales y legales. En España, el empleador tiene facultades de vigilancia y control dentro de los límites del ordenamiento, pero no dispone de un derecho irrestricto sobre todo lo que circula por un dispositivo que entrega a una persona trabajadora. El artículo **87 de la Ley Orgánica 3/2018 (LOPDGDD)** reconoce el derecho a la intimidad en el uso de dispositivos digitales puestos a disposición por el empleador y establece condiciones relativas a los criterios de utilización, información a la plantilla y garantías cuando se admiten usos privados.

Por ello, la política de uso de medios corporativos no es una formalidad que se redacta después del incidente. Debe existir, ser accesible, comunicarse y aplicarse conforme a las normas pertinentes. Su contenido puede ayudar a definir expectativas de privacidad y mecanismos de control, pero no transforma automáticamente en proporcional cualquier inspección. La necesidad de revisar comunicaciones, historiales o ficheros exige valorar el objetivo, los medios disponibles y las garantías concretas.

El uso de cámaras y la geolocalización de trabajadores tienen reglas específicas en los artículos **89 y 90 de la LOPDGDD**. Si durante la investigación se propone consultar imágenes, sonidos o posiciones de un trabajador, deben revisarse las condiciones legales de obtención y uso de esas fuentes, además de la finalidad inicial de los sistemas. No puede suponerse que la existencia de una grabación permita reutilizarla indiscriminadamente. Las exigencias de

información previa, proporcionalidad y protección de espacios íntimos son particularmente relevantes.

El investigador corporativo debería actuar con un mandato claro del responsable competente y coordinarse, cuando proceda, con asesoría jurídica, recursos humanos, representación de trabajadores y delegado de protección de datos. Los controles pueden ser necesarios para un incidente de seguridad; al mismo tiempo, se debe evitar que una investigación técnica se convierta en una vigilancia generalizada o en una búsqueda retrospectiva de comportamientos ajenos al hecho investigado.

3.2.7. Investigación interna, expediente disciplinario y procedimiento penal

Una organización puede investigar incumplimientos contractuales o hechos que sospecha delictivos. Sin embargo, una investigación interna no adquiere por ello las potestades de la policía judicial. Una empresa no puede ordenar registros secretos de cuentas ajenas ni acceder a datos custodiados por terceros simplemente porque teme haber sufrido un delito. Cuando las actuaciones exijan facultades reservadas a autoridades públicas, será necesario acudir a los cauces competentes.

La comunicación de resultados también requiere cuidado. El informe interno puede ser utilizado para valorar una decisión disciplinaria, mejorar controles, defender intereses ante un litigio o formular una denuncia. Esas finalidades no justifican revelar todo el material obtenido a todo destinatario. Conviene separar el informe ejecutivo, los hallazgos técnicos y la evidencia bajo custodia. Los anexos pueden contener credenciales, datos sensibles o información de terceros que no debe circular junto con un resumen de gestión.

Si existe la posibilidad de un procedimiento penal, la organización debe preservar datos relevantes y recibir asesoramiento sobre los canales apropiados de entrega a la autoridad. Manipular cuentas, recuperar información mediante accesos no autorizados o alterar sistemas de posibles implicados puede comprometer la investigación y generar riesgos adicionales. La colaboración con la autoridad y la conservación de evidencias deben planificarse sin convertir al departamento de sistemas en un investigador con potestades que no le corresponden.

3.2.8. Comparación operativa de los tres escenarios principales

Aspecto	Investigación judicial	Investigación corporativa	Respuesta a incidentes
Finalidad habitual	Aclarar hechos relevantes para un procedimiento	Esclarecer incidentes o incumplimientos dentro de competencias legítimas	Comprender y contener una amenaza y recuperar operaciones
Título habilitante	Resoluciones, diligencias y competencias procesales aplicables	Facultades legítimas, base jurídica del tratamiento y autorizaciones internas	Competencias de seguridad y operación, junto a las habilitaciones pertinentes
Acceso a fuentes	Limitado por las medidas legalmente acordadas	Limitado por derechos, políticas y alcance autorizado	Limitado por roles operativos, derechos y proporcionalidad
Prioridad temporal	Garantías procesales y preservación	Preservación compatible con continuidad y derechos	Puede predominar la urgencia de contención y conservación volátil
Resultado	Dictamen, actuaciones o informe incorporable al procedimiento	Informe interno, pericial o de cumplimiento	Informe de incidente, cronología, indicadores, evidencias y lecciones
Principal riesgo	Exceder la autorización o comprometer garantías	Invadir privacidad o exceder la finalidad	Alterar evidencias en operaciones urgentes o ampliar accesos sin control

Esta tabla describe tendencias, no compartimentos estancos. Un incidente puede comenzar en el equipo de seguridad, continuar como investigación interna y terminar en un proceso judicial. La transición debe quedar registrada. La legitimidad de una fase no se presume idén-

tica en las siguientes y los documentos generados para un objetivo pueden requerir revisión antes de utilizarse para otro.

3.2.9. Caso práctico: una cuenta comprometida durante la respuesta

El centro de operaciones de una empresa detecta varias autenticaciones sospechosas y descargas de documentos en un servicio de colaboración. Para contener la amenaza, deshabilita temporalmente la cuenta, revoca sesiones activas y conserva los eventos disponibles. Días después, se solicita un informe con destino a una posible reclamación judicial.

Durante la fase de respuesta, el equipo actuó con un objetivo prioritario de seguridad. Sus acciones deben constar en la cronología: hora de revocación de sesiones, cambios de configuración, herramientas utilizadas y registros exportados. El informe posterior no puede tratar esos cambios como comportamiento del presunto atacante. Debe separar los datos de la plataforma, las actuaciones de defensa y las inferencias que vinculan ambas secuencias.

La segunda fase puede exigir revisar legitimidad y alcance de nuevas fuentes, conservar copias verificables, validar formatos y preparar anexos capaces de soportar una contradicción pericial. Nada obliga a repetir todo el incidente como si no hubiera existido una respuesta operativa; tampoco permite fingir que la documentación inicial poseía una formalidad que realmente no tenía. La transparencia sobre el origen de la evidencia hace el resultado más sólido, incluso cuando revela límites.

Figura 14: Los tres entornos de utilización de evidencia digital

3.3. Protección de datos y privacidad

3.3.1. La investigación como tratamiento de información personal

La protección de datos no es una cuestión secundaria que comienza cuando se redacta el informe. Aparece desde el instante en que se identifican usuarios, direcciones, comunicaciones, cuentas y dispositivos asociados a personas físicas. Bajo el **Reglamento (UE) 2016/679**, conocido como Reglamento General de Protección de Datos (*RGPD*), la noción de dato personal comprende información relativa a personas identificadas o identificables. Los identificadores en línea, las ubicaciones y las combinaciones de registros pueden entrar en ese concepto. Además, «tratamiento» incluye operaciones tan cotidianas para un analista como consultar, copiar, clasificar, conservar, correlacionar, exportar y suprimir datos.

No toda información técnica es necesariamente personal en cualquier circunstancia. Un identificador completamente ajeno a personas identificables puede no serlo, mientras que una dirección IP, un identificador de dispositivo o un registro de actividad pueden adquirir

esa condición por el contexto y por la información adicional disponible. Una tabla de auditoría donde aparecen nombres, usuarios o direcciones vinculadas a trabajadores exige desde el principio valorar la protección de datos. La seudonimización puede reducir la exposición, pero no equivale sin más a una anonimización irreversible.

Esta perspectiva tiene una consecuencia práctica: una imagen de disco, un volcado de memoria o una exportación de correo no son simplemente «objetos forenses». También pueden ser conjuntos de datos personales sometidos a principios de licitud, finalidad, minimización, seguridad y conservación limitada. La posibilidad de que se utilicen como evidencia no elimina tales principios. Puede justificar determinados tratamientos cuando exista fundamento suficiente y garantías adecuadas, pero nunca sustituye la valoración jurídica concreta.

El **responsable del tratamiento** determina sus fines y medios esenciales. El **encargado del tratamiento** actúa por cuenta de aquel, conforme al artículo 28 y a las condiciones que resulten aplicables. Un laboratorio forense externo puede desempeñar funciones de encargado en determinados contratos, aunque la calificación no depende del nombre que figure en la factura. Si decide por su cuenta finalidades nuevas o reutiliza material para sus propias actividades, pueden cambiar su condición y sus responsabilidades. Los miembros del equipo que acceden a información personal deben hacerlo dentro de sus funciones e instrucciones, con controles efectivos y deber de confidencialidad.

3.3.2. No todos los contextos se rigen por la misma norma

En España conviven diferentes regímenes jurídicos. Para numerosos tratamientos empresariales, administrativos y profesionales resulta central el RGPD, complementado por la LOPDGDD. Sin embargo, el RGPD excluye de su ámbito material determinados tratamientos realizados por autoridades competentes para fines de prevención, investigación, detección o enjuiciamiento de infracciones penales. En ese ámbito, el marco específico deriva de la **Directiva (UE) 2016/680** y de su transposición española mediante la **Ley Orgánica 7/2021**.

La diferencia importa porque una investigación penal oficial no puede describirse sin más como si fuera un expediente interno de una empresa. No deben trasladarse automáticamente las bases jurídicas, los procedimientos para ejercer derechos o las reglas de comunicación de información de un régimen al otro. Además, una empresa privada que investiga un posible fraude no pasa a convertirse por ese motivo en una autoridad competente sometida al régimen policial-penal. Por regla general, su tratamiento requiere encaje en el marco que le corresponda como organización privada, aunque los hechos investigados pudieran constituir un delito.

El analista debería reconocer, como mínimo, cuatro escenarios: tratamiento empresarial ordinario de registros; investigación interna sobre trabajadores; tratamiento por autoridades competentes con fines penales; y actuaciones de un perito que maneja información en el marco de un procedimiento judicial. En cada caso pueden concurrir disposiciones sobre secreto profesional, derechos fundamentales, reglas procesales y protección de datos. La solución no consiste en memorizar una única base jurídica, sino en identificar quién decide, con qué finalidad y dentro de qué régimen.

3.3.3. Bases jurídicas: el consentimiento no es la respuesta universal

El artículo **6 del RGPD** establece distintas bases de licitud del tratamiento, entre ellas el cumplimiento de obligaciones legales, la realización de misiones de interés público, la ejecución de contratos y la satisfacción de intereses legítimos en las condiciones previstas. La base adecuada depende del responsable, la operación y la normativa aplicable. No es correcto afirmar que todas las investigaciones forenses requieren consentimiento ni, en el extremo opuesto, que toda investigación de seguridad queda legitimada por el simple interés de la organización.

En el contexto laboral, el consentimiento de la persona trabajadora puede resultar problemático como fundamento cuando existe una relación de desequilibrio. Además, una política corporativa firmada no constituye un consentimiento irrestricto para cualquier control posterior. Las obligaciones de información, la finalidad, los derechos y las garantías aplicables deben analizarse con independencia de que exista una cláusula contractual genérica.

Para una organización puede ser legítimo registrar accesos de seguridad, investigar una intrusión y conservar ciertos datos cuando concurra una base adecuada. Pero la licitud de recopilar registros no legitima automáticamente todas las operaciones posteriores. La exportación a un laboratorio extranjero, la revelación a un proveedor de inteligencia de amenazas o el uso de un modelo de inteligencia artificial externo pueden constituir tratamientos adicionales con riesgos y condiciones propias. Una evaluación correcta se centra en la operación real, no en una etiqueta genérica como «ciberseguridad».

También existen **categorías especiales de datos** del artículo 9 del RGPD, cuya utilización se somete a restricciones reforzadas. Una investigación de un portátil puede revelar información de salud, convicciones, afiliación sindical u otros contenidos especialmente protegidos. Los datos relativos a condenas e infracciones penales se rigen por previsiones específicas del artículo 10. El analista no puede suponer que su relevancia potencial basta para levantar todas las restricciones; debe escalar la cuestión y aplicar controles apropiados.

3.3.4. Principios del RGPD trasladados a decisiones técnicas

El artículo **5 del RGPD** reúne principios que pueden traducirse a prácticas concretas. La **licitud, lealtad y transparencia** exigen identificar la base de actuación y cumplir las obligaciones de información que procedan, teniendo en cuenta las posibles limitaciones legalmente establecidas. La **limitación de la finalidad** impide convertir una investigación de accesos en una explotación general de comportamientos personales. La **minimización** favorece el uso de filtros y la separación entre datos relevantes y material incidental. La **exactitud** obliga a corregir atribuciones erróneas y a distinguir los registros de las conclusiones. La **limitación del plazo de conservación** exige revisar por cuánto tiempo deben mantenerse copias e informes. La **integridad y confidencialidad** obligan a proteger los repositorios, las comunicaciones y los soportes.

Finalmente, la **responsabilidad proactiva** exige que el responsable pueda demostrar el cumplimiento de esos principios. No basta con declarar que los datos se utilizaron correctamente: se necesitan decisiones registradas, controles de acceso, políticas, autorizaciones y registros de tratamiento. La documentación forense resulta útil también en este plano, porque permite relacionar los accesos a la evidencia con una finalidad definida y una persona responsable.

La minimización merece un análisis específico. Una imagen forense completa puede capturar millones de objetos, incluidos archivos eliminados, espacios no asignados y contenidos ajenos. En determinados escenarios esa amplitud es necesaria para no perder contexto técnico o para preservar el estado del soporte. Sin embargo, **obtener mucho no obliga a leerlo todo ni a divulgarlo todo**. Puede aplicarse una estrategia en dos niveles: una adquisición documentada y protegida cuando esté jurídicamente justificada, seguida de un análisis filtrado por objeto, periodo y relevancia. El acceso al material excluido debe quedar restringido, y cualquier ampliación necesita justificación.

3.3.5. Privacidad desde el diseño del procedimiento forense

Los principios de privacidad desde el diseño y por defecto, recogidos en el artículo **25 del RGPD**, pueden orientar la arquitectura de un laboratorio. En lugar de confiar únicamente en la discreción de los profesionales, se establecen controles que reducen estructuralmente la exposición: separación de casos, cifrado de almacenamiento, credenciales nominales, privilegios mínimos, registros de acceso, permisos temporales y reglas de eliminación.

Por ejemplo, una estación de análisis no debería conservar indefinidamente montajes de imágenes ajenas cuando termina un caso. Las carpetas temporales, miniaturas, índices de

búsqueda y cachés creadas por las herramientas pueden contener copias de datos personales aunque el archivo principal se encuentre protegido. Las aplicaciones forenses que generan bases de datos auxiliares deben configurarse y supervisarse para que sus resultados permanezcan dentro del perímetro autorizado. La eliminación al cierre del expediente requiere tener en cuenta estas copias derivadas.

Conviene distinguir entre **evidencia maestra**, **copias de trabajo**, **resultados intermedios** y **extractos incluidos en el informe**. La evidencia maestra puede conservarse con acceso extraordinariamente restringido; la copia de trabajo sirve para el examen; los resultados intermedios permiten reproducir operaciones; los extractos divulgables incorporan solo lo necesario para sustentar hallazgos. No siempre es posible separar material con total limpieza, pero el esfuerzo de segmentación reduce riesgos y facilita la respuesta a solicitudes de acceso y auditorías.

La gestión de claves es otro aspecto crítico. Cifrar un repositorio sin establecer una política de custodia, recuperación y rotación de claves puede proteger frente a accesos indebidos y, simultáneamente, impedir el cumplimiento de una obligación legítima de conservación. La arquitectura adecuada combina confidencialidad con disponibilidad controlada, separación de funciones y registro de aperturas. En casos sensibles, el uso de autorizaciones múltiples para acceder a originales o a secretos especialmente protegidos puede añadir garantías.

3.3.6. Datos de terceros y descubrimientos incidentales

Las evidencias suelen incluir información de personas que no son objeto de investigación: clientes, familiares, contactos, profesionales externos o compañeros de trabajo. Un buzón puede incorporar cientos de conversaciones privadas que carecen de interés. Una copia de memoria puede contener credenciales de servicios ajenos. Un repositorio puede incluir información comercial de terceros. La relevancia de un archivo determinado no transforma todo su contenido en materia libremente examinable.

Por esta razón, antes de analizar grandes conjuntos conviene decidir cómo se reconocerán y tratarán los hallazgos incidentales. Una opción consiste en establecer categorías de exclusión y protocolos de segregación: documentos de salud, comunicaciones con asesores jurídicos, mensajes personales y material ajeno al periodo investigado. La selección concreta debe adaptarse al contexto legal y no puede convertirse en una técnica para ocultar evidencia relevante. Cuando la pertinencia o la protección jurídica de un documento sea dudosa, la revisión por personal autorizado y con competencia adecuada ofrece más garantías que una decisión unilateral del analista.

La **información cubierta por secreto profesional** exige especial cuidado. El correo de un abogado, por ejemplo, puede encontrarse técnicamente en un dispositivo accesible, pero su tratamiento plantea cuestiones adicionales que deben resolverse por los cauces pertinentes. No corresponde al profesional técnico decidir por sí solo que una comunicación protegida deja de estarlo porque contiene un término de búsqueda relevante. En el informe pueden describirse las limitaciones y el tratamiento seguido sin reproducir el contenido confidencial.

Los datos de menores, personas vulnerables o víctimas de determinados hechos requieren protección reforzada, tanto en el manejo de la evidencia como en la redacción de entregables. La curiosidad técnica —examinar fotografías, conversaciones o perfiles para «completar el contexto»— nunca es una finalidad legítima por sí misma. La disciplina profesional se demuestra especialmente al no abrir información cuyo examen no está justificado.

3.3.7. Seguridad, incidentes de datos personales y deberes de notificación

El artículo **32 del RGPD** exige medidas técnicas y organizativas apropiadas al riesgo, que pueden incluir cifrado, confidencialidad, resiliencia y evaluación de controles. En un laboratorio forense esas medidas deben contemplar amenazas particulares: robo de soportes, sincronización accidental con nubes personales, fugas por herramientas, acceso de terceros al puesto de análisis, pérdida de claves o contaminación entre expedientes.

Una investigación puede originarse en una violación de seguridad de datos personales. Es importante separar dos preguntas: **qué sucedió técnicamente** y **qué deberes de notificación se activan**. Bajo el artículo **33 del RGPD**, determinados incidentes deben notificarse a la autoridad de control sin dilación indebida y, de ser posible, dentro de las 72 horas desde que el responsable tenga conocimiento, salvo cuando sea improbable que entrañen riesgo para los derechos y libertades de las personas físicas. El artículo **34** regula la comunicación a los interesados en supuestos de alto riesgo, con condiciones y excepciones. La calificación concreta corresponde al responsable y a quienes le asesoran, no al analista por intuición.

El equipo forense contribuye proporcionando una cronología verificable, categorías de datos potencialmente afectadas, número aproximado de registros, vectores de acceso, estado de los sistemas y grado de incertidumbre. No debe retrasar la comunicación necesaria hasta alcanzar una certeza absoluta. También debe evitar lo contrario: presentar estimaciones preliminares como hechos cerrados. Es válido comunicar una conclusión provisional claramente identificada y actualizarla según se incorporen nuevos elementos.

Un informe puede afirmar, por ejemplo, que se confirmó la descarga de un archivo comprimido desde una cuenta administrativa, pero que no se dispone de registros suficientes para

identificar de forma completa su contenido o destino. Esa incertidumbre resulta relevante para la evaluación del riesgo. La obligación de documentar lo que se sabe y lo que no se sabe favorece decisiones regulatorias más responsables.

3.3.8. Conservación, bloqueo y eliminación: un equilibrio difícil

Las investigaciones necesitan preservar datos, pero la conservación indefinida no puede darse por supuesta. El principio de limitación temporal del RGPD debe relacionarse con obligaciones legales, plazos de prescripción, exigencias procesales, contratos y posibles reclamaciones. Una política de retención operativa de treinta días puede ser insuficiente para investigar un incidente conocido meses después; una decisión de conservar durante años todas las exportaciones sin distinción puede ser desproporcionada. La respuesta exige categorías, justificaciones y reglas de revisión.

Es útil diferenciar la retención **ordinaria** de los sistemas —determinada por finalidades de operación, seguridad y cumplimiento— de una conservación extraordinaria o **legal hold** vinculada a un asunto específico. La segunda debe activarse por quien posea competencia para ello, identificar el material y el motivo, limitar accesos y establecer cuándo revisar o levantar la medida. No se trata de un permiso genérico para prolongar sin límite todos los tratamientos.

Cuando existe una solicitud de supresión, una obligación de bloqueo, un derecho ejercitado o una orden de conservación, el analista debe evitar respuestas automáticas. Puede haber razones jurídicas para conservar cierta información aun cuando termine su uso ordinario; también pueden existir obligaciones de restringir el tratamiento y evitar consultas adicionales. En España, la LOPDGDD incorpora la figura del **bloqueo de datos** en su artículo 32, cuyo alcance debe examinarse con asesoramiento adecuado. Desde la perspectiva técnica, conservar no significa necesariamente mantener los datos visibles para todos los usuarios o disponibles para búsquedas rutinarias.

Al finalizar el caso debe existir una decisión expresa sobre originales, copias, índices, archivos temporales y documentación. Algunas evidencias deberán entregarse al órgano correspondiente; otras se conservarán bajo mandato o contrato; otras deberán eliminarse mediante procedimientos apropiados y documentados. Antes de destruir, es necesario verificar que no existen obligaciones de conservación pendientes. Un proceso controlado evita tanto la pérdida prematura como la acumulación indefinida de datos sensibles.

3.3.9. Uso de servicios externos y herramientas con componentes en la nube

Las aplicaciones modernas de análisis pueden ofrecer reconocimiento de texto, clasificación automática, traducción, búsqueda semántica o procesamiento asistido por modelos de inteligencia artificial. Estas funciones resultan atractivas cuando una investigación contiene grandes volúmenes de documentos. Sin embargo, enviar evidencia a un servicio externo puede constituir una comunicación a un tercero y, según la arquitectura del proveedor, una transferencia internacional de datos. También puede dar lugar a retenciones, registros, uso para mejora de servicios o acceso por subencargados.

La decisión requiere examinar el contrato, la condición del proveedor, los lugares de procesamiento, las políticas de conservación, las garantías técnicas y las obligaciones aplicables. No es prudente copiar correos corporativos, documentos confidenciales o extractos de memoria a una aplicación pública de IA con la expectativa de que «no pasa nada porque solo se usa para analizar». Tampoco es suficiente anonimizar superficialmente un texto si las combinaciones de datos permiten reidentificar a personas o revelar secretos empresariales.

Si una herramienta local puede realizar la operación necesaria sin salir del laboratorio, se reduce una parte del riesgo, aunque no desaparecen las exigencias de licitud, seguridad y validación. Si el procesamiento externo resulta indispensable, deben existir autorizaciones, contratos y garantías adecuados. Además, las salidas generadas automáticamente deben verificarse: un resumen producido por un modelo no equivale a una constatación forense, y una clasificación probabilística no debe presentarse como prueba de autoría.

3.3.10. Un caso de privacidad en la práctica: análisis de un buzón

Una organización investiga si una cuenta corporativa envió un fichero estratégico a un destinatario externo. Los registros del servidor muestran un mensaje saliente, pero el encabezado y el asunto no permiten determinar qué contenido fue enviado. El equipo solicita una exportación completa de los diez últimos años del buzón.

El profesional comienza por identificar qué sería necesario para responder a la pregunta: fecha aproximada, cuenta emisora, destinatario, identificador de mensaje y, si es posible, huellas del adjunto. Una búsqueda limitada puede recuperar el mensaje pertinente sin explorar años de conversaciones. Si la plataforma exige una exportación más amplia por limitaciones técnicas, debe explicarse la razón, establecer una conservación protegida y limitar el examen a los filtros previstos. La mera disponibilidad de correspondencia personal no autoriza a incorporarla al informe.

Durante la extracción aparece un correo privado con información médica. No está relacionado con el hecho investigado. El analista no lo utiliza como indicio, no lo adjunta y evita reproducirlo en los resultados de búsquedas. Si el sistema de análisis ha generado miniaturas o índices derivados, aplica también las reglas de protección y cierre correspondientes. El informe se centra en el mensaje relevante y documenta los criterios de selección sin divulgar material incidental.

La calidad de la investigación no disminuye por haber dejado fuera información irrelevante. Al contrario, una delimitación clara ayuda a defender que los hallazgos provienen de un procedimiento orientado a preguntas legítimas y no de una exploración indiscriminada.

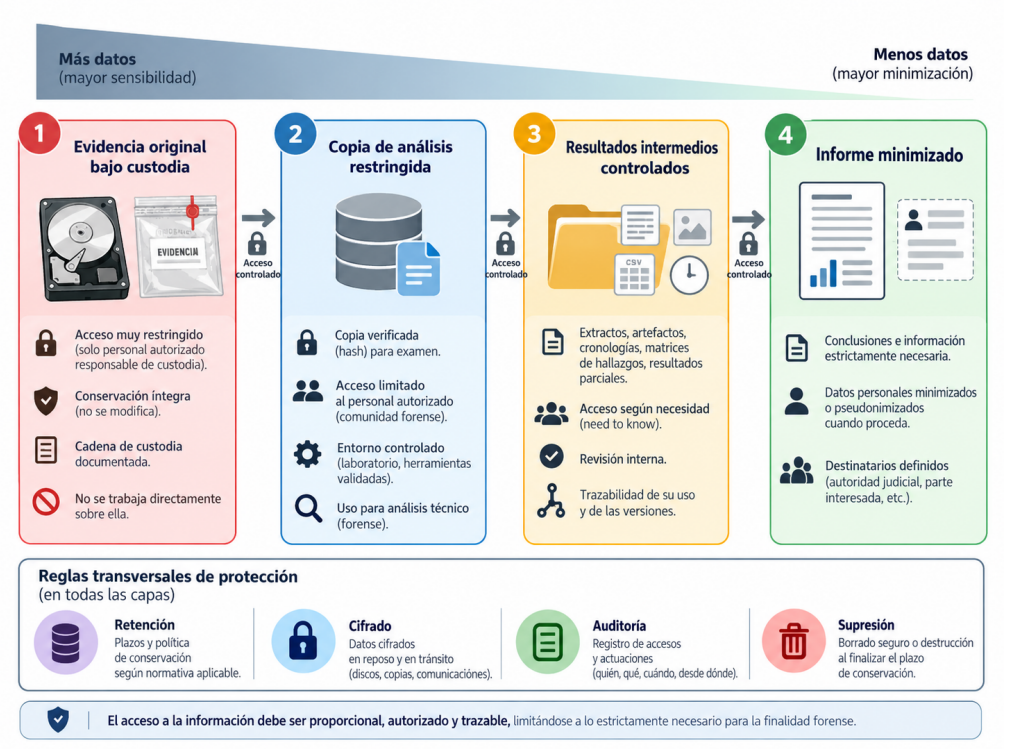


Figura 15: Privacidad por capas

3.4. Jurisdicción y obtención de evidencias

3.4.1. Un sistema digital no termina en la frontera del dispositivo

Los sistemas actuales distribuyen funciones entre lugares, empresas y ordenamientos diferentes. Un ordenador localizado en España puede autenticarse mediante un proveedor de identidad gestionado desde Irlanda, consultar una aplicación alojada en otro Estado miembro, generar trazas en una región de procesamiento distinta y almacenar copias de respaldo fuera del Espacio Económico Europeo. El investigador puede observar todas esas relaciones en una misma línea temporal, pero no adquiere por ello un derecho uniforme a intervenir sobre todos los sistemas.

La **jurisdicción** plantea preguntas sobre qué autoridades y tribunales son competentes, qué legislación resulta aplicable y cómo puede requerirse colaboración para acceder a información situada o controlada en otro territorio. La **ubicación física de los datos** es relevante en algunos escenarios, pero no siempre basta para resolver estas cuestiones. También importan el establecimiento del proveedor, el domicilio de las personas afectadas, la naturaleza del servicio, el lugar desde el que se ofrece y las obligaciones impuestas por los distintos sistemas jurídicos. Una copia replicada puede existir temporalmente en varias regiones; una empresa puede gestionar una base de datos desde un país sin que eso determine por sí solo todas las reglas de acceso.

El error habitual consiste en transformar un problema internacional en una cuestión de conectividad: «La consola de administración funciona desde aquí, luego puedo descargarlo». Una API puede permitir exportar mensajes almacenados por un proveedor extranjero; esa capacidad técnica no resuelve las condiciones contractuales, la protección de datos, la autoridad para ordenar la operación ni la eventual necesidad de asistencia judicial internacional. Antes de comenzar, el plan debe identificar la fuente, quién la controla, qué derecho se pretende ejercer y cuáles son los canales apropiados para obtenerla.

3.4.2. Residencia de datos, control administrativo y facultad jurídica

Conviene separar la **residencia** de la información, el **control operativo** del servicio y la **facultad jurídica** para exigir o realizar la obtención. Un proveedor puede ofrecer al cliente la posibilidad de elegir una región de almacenamiento. Esa preferencia no asegura que todos los metadatos, registros de soporte, datos de autenticación o copias de continuidad se procesen exclusivamente en ella. A su vez, una persona puede administrar un servicio sin tener acceso a todos los registros técnicos, porque el proveedor conserva las trazas en un plano de control separado.

La investigación comienza con un inventario de fuentes y responsables: cuenta o suscripción, organización titular del contrato, región de datos declarada, subencargados conocidos, categorías de logs disponibles, ubicación aproximada de los registros y canales de solicitud. Los acuerdos de nivel de servicio y las condiciones de privacidad pueden limitar las exportaciones, establecer plazos de retención o determinar qué procedimientos se utilizan ante un requerimiento oficial. Registrar esas características desde el inicio impide que la ausencia de un artefacto se interprete erróneamente como ausencia de actividad.

Una exportación que aparece bajo un nombre como *audit log* no tiene necesariamente la cobertura de auditoría que su nombre sugiere. Puede excluir operaciones administrativas, accesos mediante aplicaciones heredadas o eventos anteriores a la activación de una licencia. La documentación del proveedor puede describir esos límites y formar parte de la base para interpretar el valor de la evidencia. También deben anotarse filtros y opciones empleados en la exportación, pues la selección puede introducir exclusiones sin que el analista sea consciente.

3.4.3. Cooperación penal internacional y preservación urgente

Cuando la investigación corresponde a autoridades competentes y afecta a datos controlados en otra jurisdicción, existen mecanismos de cooperación internacional. Entre ellos se encuentran los instrumentos de asistencia judicial mutua y el **Convenio sobre la Ciberdelincuencia del Consejo de Europa**, conocido como **Convenio de Budapest**, que contiene disposiciones sobre conservación rápida de datos y cooperación para su obtención. Estos instrumentos operan dentro de sus condiciones propias; no autorizan a cualquier investigador particular a solicitar o extraer directamente información de terceros.

La preservación rápida responde a un problema específico: los registros pueden desaparecer por rotación antes de que concluya una solicitud formal de entrega. Por ello, los mecanismos jurídicos pueden distinguir entre ordenar que determinados datos **se conserven** y obtener efectivamente una copia de ellos. En el ámbito técnico, esa diferencia se refleja en actuaciones también distintas. Solicitar la retención de ciertos logs no equivale a adquirir su contenido, y la existencia de una obligación de conservar no permite inferir un acceso ilimitado.

El Convenio de Budapest contempla modalidades de acceso transfronterizo bajo condiciones delimitadas, incluida la relativa a datos públicamente disponibles y determinados accesos consentidos conforme a su artículo 32. Esa previsión no debe leerse como una licencia general para explorar sistemas extranjeros con credenciales obtenidas durante una investigación. La identidad y competencia de quien actúa, el carácter voluntario y lícito del

consentimiento y la naturaleza del dato son determinantes. En situaciones ambiguas, debe intervenir la autoridad o el asesoramiento jurídico competente antes de acceder.

En la práctica, el analista puede resultar decisivo sin asumir funciones que no le corresponden: identifica los registros pertinentes, especifica las cuentas y periodos, documenta la volatilidad, indica formatos deseables y propone comprobaciones de integridad. Esa precisión facilita que quien tiene autoridad formule una solicitud útil. Una petición demasiado amplia puede encontrar obstáculos jurídicos y técnicos; una petición incompleta puede llegar cuando el proveedor ya ha eliminado los datos.

3.4.4. El régimen europeo de pruebas electrónicas: e-Evidence

La Unión Europea ha establecido instrumentos específicos para facilitar, bajo condiciones y garantías, la obtención y conservación de prueba electrónica en procedimientos penales transfronterizos. El **Reglamento (UE) 2023/1543** regula las órdenes europeas de producción y las órdenes europeas de conservación dirigidas a determinados prestadores de servicios. **Es aplicable desde el 18 de agosto de 2026**. Se acompaña de la **Directiva (UE) 2023/1544**, relativa a establecimientos designados y representantes legales de prestadores a efectos de recabar pruebas electrónicas.

La actualidad de este régimen importa para un libro publicado en 2026: no debe describirse como una promesa futura ni presentarse como una herramienta de investigación privada. Las órdenes están destinadas a autoridades competentes en el marco de los procedimientos contemplados y sujetas a requisitos de emisión, controles, derechos y mecanismos de ejecución. Su ámbito no equivale al acceso indiscriminado a todos los datos en la nube ni reemplaza la necesidad de examinar la categoría de información solicitada.

Desde la perspectiva forense, destacan dos conceptos. La **orden de conservación** busca evitar que datos específicos dejen de estar disponibles mientras se tramita la actuación posterior. La **orden de producción** persigue que el prestador entregue la información que corresponde conforme al mecanismo jurídico aplicable. En ambos casos resultan esenciales la correcta identificación de cuentas, periodos y categorías, la documentación de las respuestas y la verificación de qué recibió realmente el investigador.

El profesional debe distinguir, además, entre el instante en que el proveedor registra un evento, el momento en que se emite una orden, la fecha en que se ejecuta y aquella en que se genera la exportación. Es posible que los datos ya hubieran dejado de existir antes de recibir la orden. También pueden existir diferencias entre el formato interno de auditoría del proveedor y el entregado. Una línea temporal rigurosa registra esas circunstancias, porque inciden directamente en la posibilidad de corroborar hechos.

3.4.5. Las solicitudes extranjeras no son instrucciones técnicas ordinarias

El artículo **48 del RGPD** contiene reglas relativas al reconocimiento y ejecución de decisiones de autoridades y tribunales de terceros países que exijan transferencias o comunicaciones de datos personales, sin perjuicio de otros fundamentos de transferencia previstos en el capítulo V. Su aplicación es jurídica y depende de las circunstancias, pero transmite una idea fundamental: recibir un requerimiento extranjero no equivale, por sí solo, a disponer de legitimidad universal para comunicar datos.

Imaginemos una empresa europea que recibe de una entidad extranjera una solicitud de exportación de mensajes de varios trabajadores. La petición menciona una investigación y pide al equipo de sistemas «cooperación inmediata». El analista no debería ejecutar la exportación solo porque la solicitud parece formal. Debe verificar su procedencia, remitirla a quienes gestionan requerimientos legales y exigir instrucciones validadas sobre datos, finalidad y alcance. Si existe riesgo de pérdida, se valorará por los canales competentes una medida de conservación adecuada, sin asumir que conservar y entregar son actos equivalentes.

La misma cautela resulta pertinente con empresas matrices, filiales, consultoras o aseguradoras de otros países. La relación contractual entre entidades del mismo grupo no convierte automáticamente en libre la circulación de evidencias. Deben analizarse responsables y encargados, acceso remoto, destinatarios y posibles transferencias internacionales, así como las excepciones o garantías aplicables. Las medidas de cifrado, la seudonimización y el acceso limitado pueden reducir riesgo, pero no sustituyen una base jurídica válida.

3.4.6. Transferencias internacionales en la práctica del laboratorio

El capítulo V del RGPD regula las transferencias de datos personales a terceros países u organizaciones internacionales. Las herramientas disponibles pueden incluir decisiones de adecuación, garantías adecuadas y excepciones específicas, según las condiciones previstas. No basta con identificar dónde está la sede comercial del proveedor; es necesario conocer quién accede a los datos, desde dónde y con qué garantías. El análisis depende de la transferencia concreta y de las obligaciones vigentes.

Supongamos que un laboratorio español contrata un servicio de procesado documental con servidores fuera del Espacio Económico Europeo. El proveedor afirma que cifra los archivos en tránsito y ofrece un contrato estándar. El cifrado es importante, pero no resuelve todas las cuestiones: quién conserva las claves, si existe acceso administrativo al contenido, cuánto tiempo permanecen los ficheros, qué subcontratistas intervienen y qué régimen de transferencia resulta aplicable. Las recomendaciones del **Comité Europeo de Protección de Datos**

sobre medidas complementarias a herramientas de transferencia constituyen una referencia para este tipo de análisis.

En un laboratorio avanzado, la clasificación previa de casos puede evitar decisiones apresuradas. Algunas evidencias podrán procesarse localmente por su sensibilidad o por restricciones contractuales; otras se gestionarán mediante servicios expresamente autorizados; y otras exigirán un tratamiento especialmente segregado. Esta planificación no impide el trabajo forense: permite que la tecnología utilizada no introduzca un problema jurídico adicional.

3.4.7. El uso de credenciales obtenidas durante la investigación

Las credenciales constituyen un caso singular. Durante un análisis pueden recuperarse contraseñas, tokens de acceso, cookies de sesión o claves de API. Su presencia es un dato potencialmente relevante, pero usarlos para abrir otras cuentas constituye una operación distinta. La obtención de un secreto durante una adquisición autorizada no implica una autorización general para autenticarse en sistemas relacionados. El acceso puede afectar a datos nuevos, modificar marcas temporales, activar controles de seguridad o cruzar fronteras jurídicas.

El artículo **197 bis del Código Penal español**, dentro de su ámbito de aplicación, contempla conductas de acceso no autorizado a sistemas de información vulnerando medidas de seguridad, así como determinados supuestos de interceptación de transmisiones no públicas. No corresponde al analista calificar automáticamente cualquier operación como delictiva o inocua. Sí debe saber que experimentar con credenciales ajenas sin título suficiente no es una simple técnica de verificación. Incluso una autenticación aparentemente pasiva puede modificar registros, activar notificaciones y producir un perjuicio operativo.

Ante una credencial recuperada, la conducta técnicamente prudente consiste en documentar dónde apareció, qué sistemas podría identificar, su estado conocido y su relevancia. Si es necesario verificar su validez, debe definirse expresamente la operación, la autorización y el entorno, favoreciendo mecanismos de comprobación menos intrusivos cuando existan. La reconstrucción de un compromiso de cuentas puede basarse en logs y configuraciones sin volver a utilizar los tokens del presunto atacante.

3.4.8. Pruebas electrónicas proporcionadas por terceros

Las investigaciones dependen cada vez más de exportaciones entregadas por proveedores, clientes o administradores. El analista puede no haber controlado la generación original del

archivo. Su tarea no consiste en fingir que lo adquirió directamente, sino en documentar la procedencia y evaluar qué fiabilidad puede atribuirse a cada componente.

Una entrega debería acompañarse, cuando sea viable, de información sobre la fuente, el procedimiento de exportación, la identidad y rol del operador, las fechas, los filtros aplicados, el formato, la zona horaria, los identificadores de cuenta, las posibles limitaciones de retención y los hashes de los ficheros finalmente proporcionados. Si el proveedor firma digitalmente el paquete o genera un manifiesto, debe conservarse el mecanismo de verificación. Si no lo hace, la ausencia de firma no convierte automáticamente la entrega en inútil: delimita qué controles pueden practicarse.

También deben evitarse equivalencias fáciles. Un CSV de auditoría generado por una API puede contener filas íntegras respecto a la consulta, pero estar incompleto respecto al conjunto real de eventos. Una captura de pantalla puede reflejar una interfaz en un instante determinado, pero ocultar filtros, paginación, campos expandibles o elementos fuera de la vista. Una carta de un proveedor puede explicar la procedencia sin permitir reproducir el sistema interno. La valoración final necesita combinar metadatos, documentación, coherencia de formatos y corroboración externa.

3.4.9. Caso práctico: archivos desaparecidos en un repositorio multinacional

Una consultora española investiga la desaparición de documentos de un espacio colaborativo. La sede contractual del proveedor está en otro Estado miembro, los usuarios trabajan desde tres países y el servicio conserva registros detallados durante un periodo limitado. El departamento de seguridad puede consultar determinados eventos desde la consola corporativa, pero no tiene acceso a los logs internos de infraestructura.

La hipótesis inicial es que una persona eliminó deliberadamente los documentos. Sin embargo, también podrían haberse movido, modificado los permisos o fallado una sincronización. El equipo conserva los registros administrativamente accesibles dentro de sus atribuciones, registra filtros y periodos, verifica permisos actuales y revisa el historial de versiones. No intenta acceder a las cuentas privadas de los usuarios ni solicita informalmente a una filial extranjera todos sus datos personales.

Si los hallazgos justifican recurrir a registros de proveedor que no están disponibles para el cliente, se define con exactitud qué eventos serían necesarios y se eleva la petición por los cauces contractuales o jurídicos que correspondan. Si existen indicios de delito y se activa un procedimiento penal, la autoridad competente determinará los instrumentos utilizables, incluidas, cuando procedan, las herramientas europeas o de cooperación internacional. La

función técnica consistirá en preservar, interpretar y documentar lo recibido sin ocultar diferencias de procedencia y alcance.

La conclusión podría indicar que hay evidencia sólida de un cambio de permisos a una hora determinada, pero no de eliminación de datos, y que una atribución personal definitiva no puede realizarse con la información disponible. Esa respuesta puede ser menos espectacular que la acusación inicial, pero es más precisa y responsable.

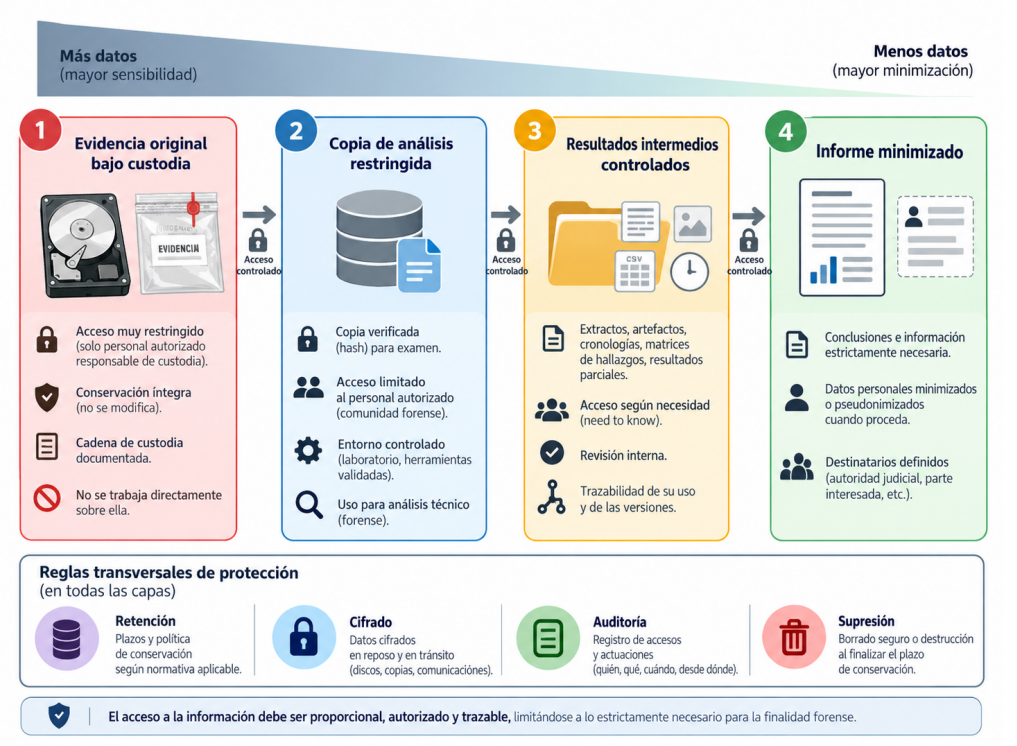


Figura 16: Jurisdicciones y capas de acceso

3.5. Ética, imparcialidad y responsabilidad profesional

3.5.1. La responsabilidad empieza donde termina la capacidad de la herramienta

La ética profesional no es un complemento ornamental de la técnica forense. Constituye una condición de su credibilidad. Un analista puede trabajar con métodos reproducibles y conservar todos los hashes correctamente y, sin embargo, actuar de modo irresponsable si excede su autorización, manipula la presentación de los resultados, esconde incertidumbres

o utiliza información sensible para una finalidad ajena. La integridad de una evidencia debe ir acompañada de la integridad de quien la trata.

La responsabilidad profesional puede examinarse en tres dimensiones. La **técnica** exige conocer los procedimientos, sus limitaciones y las condiciones de validez de los resultados. La **jurídica y organizativa** exige actuar dentro del mandato y cumplir las normas aplicables. La **ética** exige tratar con honestidad a quienes solicitan el trabajo, a las personas afectadas y a los destinatarios del informe, incluso cuando una conducta impropia pudiera resultar difícil de detectar. Las tres dimensiones se refuerzan mutuamente; ninguna permite compensar la ausencia de las otras.

En el ámbito procesal civil español, el artículo **335.2 de la Ley de Enjuiciamiento Civil** recoge expresamente el deber de objetividad del perito, incluyendo la consideración de circunstancias que puedan favorecer o perjudicar a cualquiera de las partes. El principio sirve para ilustrar una exigencia general de la actividad pericial: el especialista no debe buscar exclusivamente datos favorables a la hipótesis del cliente. Su función consiste en esclarecer hechos mediante conocimientos especializados, no en construir una narración conveniente.

No debe confundirse la independencia profesional con la ausencia de toda relación con las partes. Muchos peritos son contratados por quienes tienen interés legítimo en un procedimiento; otros pertenecen a organizaciones donde investigan incidentes internos. La cuestión ética es si pueden aplicar un método honesto, revelar conflictos relevantes, comunicar los límites del análisis y negarse a presentar como probado lo que no está demostrado. Cuando esas condiciones no se cumplen, la calidad de la evidencia pierde significado práctico.

3.5.2. Imparcialidad y sesgos de interpretación

Los sistemas digitales producen una gran cantidad de datos y el analista rara vez puede examinarlos sin selección. Cada consulta, filtro, palabra clave e hipótesis dirige la atención hacia una parte de la información. La selección es inevitable; el sesgo no tiene por qué serlo. El primer paso consiste en reconocer que las expectativas influyen en lo que se considera relevante y en cómo se interpreta una coincidencia.

El **sesgo de confirmación** aparece cuando se buscan indicios que apoyen una sospecha y se ignoran explicaciones alternativas. El **sesgo de anclaje** hace que la primera hipótesis recibida del cliente determine la interpretación posterior de los registros. El **sesgo de autoridad** puede llevar a aceptar una conclusión porque proviene de un superior, de una herramienta reconocida o de otro perito. El **sesgo retrospectivo** provoca que una secuencia parezca obvia una vez conocido el desenlace. Ninguno requiere mala fe: pueden aparecer incluso en profesionales experimentados.

La mitigación necesita prácticas concretas. Antes del examen, es útil escribir las preguntas investigables y las hipótesis rivales. Durante el análisis, deben registrarse resultados que contradigan la versión inicial. En la revisión, otra persona puede examinar una muestra de artefactos sin conocer la atribución personal propuesta, cuando el procedimiento lo permita. Las conclusiones importantes deben vincularse a evidencias identificables y verificarse con fuentes cuyo origen sea suficientemente independiente.

La independencia de fuentes merece precisión. Dos exportaciones del mismo sistema pueden parecer corroboración, aunque procedan de la misma base de datos y compartan errores. Un indicador de un panel de seguridad y un evento de una API pueden derivar ambos de un único registro subyacente. La verdadera corroboración requiere valorar cómo se generó cada dato, quién lo produjo y qué dependencias existen entre las fuentes. Repetir la misma inferencia con dos interfaces no la transforma en un hecho independiente.

3.5.3. Diferenciar observación, hallazgo, inferencia y atribución

Una de las responsabilidades más exigentes del perito consiste en utilizar un lenguaje proporcional a la evidencia. Una **observación** describe lo que consta directamente: «El registro contiene un evento de autenticación satisfactoria a las 02:17». Un **hallazgo** integra interpretación técnica: «El evento corresponde a una sesión emitida para la cuenta examinada». Una **inferencia** combina hallazgos para explicar un acontecimiento: «La sesión probablemente se utilizó para consultar el repositorio». La **atribución personal** añade una cuestión más compleja: quién controlaba realmente la sesión y con qué intención.

Los saltos entre esos niveles exigen justificación creciente. Una dirección IP no identifica necesariamente a la persona usuaria; una credencial válida no demuestra que actuara su titular; un artefacto de ejecución no siempre permite reconstruir el propósito de quien puso en marcha el programa. La coincidencia de una marca temporal con una presencia física puede ser significativa, pero no debe convertirse en identidad demostrada sin corroboración adecuada. La prudencia de vocabulario no reduce el valor del informe: permite conocerlo.

Es especialmente importante evitar expresiones aparentemente técnicas que esconden una valoración moral o jurídica. «El empleado robó los archivos» incluye autoría, intención y calificación del hecho. Si lo que se ha constatado es una descarga, debe describirse como tal, junto con su origen, destino aparente y limitaciones. «Se identificó actividad compatible con exfiltración» puede ser una conclusión adecuada cuando existen indicios, pero debe explicarse qué la apoya y qué alternativas no se han podido descartar. El informe forense no debería sustituir hechos por calificativos.

Tampoco conviene transformar la incertidumbre en porcentajes improvisados. Decir que una hipótesis es «un 95 % segura» no aporta rigor si no existe un modelo validado que produzca y justifique esa cifra. Son preferibles formulaciones que indiquen el soporte de la conclusión: «Se confirma la existencia de la sesión», «los datos son compatibles con una copia», «no se dispone de elementos suficientes para atribuir la operación a una persona física». Cuando se empleen escalas de confianza deben definirse previamente, con sus límites y criterios.

3.5.4. Competencia técnica y derecho a reconocer límites

Nadie domina por igual los sistemas de archivos, las plataformas móviles, las redes industriales, la criptografía, la nube y el análisis de malware. Una actuación ética requiere aceptar ese límite. Un profesional puede ser competente para adquirir y analizar registros de Windows y necesitar apoyo especializado al interpretar un dispositivo iOS cifrado o un sistema industrial propietario. Reconocer la necesidad de otro especialista no constituye un defecto: evita que una conclusión insegura se presente como conocimiento experto.

Las herramientas tampoco confieren competencia por sí mismas. Que un programa forense clasifique un registro como «archivo eliminado» no significa que el término refleje necesariamente el comportamiento real del sistema. Una herramienta puede interpretar incorrectamente marcas temporales, estructuras dañadas o artefactos de una versión reciente. Su resultado debe relacionarse con el formato de origen y, cuando la conclusión sea decisiva, contrastarse mediante análisis manual, otra herramienta o pruebas controladas.

La validación debe ser proporcionada al riesgo. Para una operación rutinaria conocida, puede bastar una comprobación documentada. Para un artefacto novedoso del que depende una atribución personal, pueden requerirse ensayos de reproducción con datos de referencia, revisión por pares y documentación de alternativas. Los informes deben reflejar el alcance de esa validación. Presentar la salida de un software como una verdad infalible porque el producto es comercial o popular constituye una delegación indebida del juicio profesional.

Mantener competencia implica actualizar conocimientos. Los sistemas cambian sus políticas de registro, versiones de formatos, esquemas de cifrado y mecanismos de autenticación. Una interpretación correcta para una versión antigua puede dejar de serlo después de una actualización. Antes de aplicar un procedimiento aprendido en otro caso, deben verificarse las condiciones del sistema actual. Las referencias bibliográficas, documentación de proveedores y pruebas locales forman parte de ese trabajo, especialmente cuando se incorporan nuevas herramientas o automatizaciones.

3.5.5. Conflictos de interés y presión del cliente

Un conflicto de interés puede ser económico, personal, profesional u organizativo. Un investigador puede haber diseñado los controles de seguridad cuya eficacia debe evaluar. Puede haber participado en una decisión operativa que produjo la pérdida de registros. Puede tener relaciones con una persona investigada o con una organización que financia el trabajo. La existencia de relaciones previas no determina automáticamente la imposibilidad de intervenir, pero puede comprometer la percepción o la realidad de su independencia y debe ser examinada.

La transparencia permite gestionar buena parte de estas situaciones. Conviene declarar vínculos relevantes, delimitar el cometido y, en asuntos sensibles, promover revisión independiente de los hallazgos. Si un analista participó en la contención, puede documentar con precisión sus acciones, pero sería inadecuado omitir una decisión propia que alteró un registro decisivo. Si el cliente solicita confirmar una conclusión que la evidencia no respalda, debe resistirse a modificar el texto por conveniencia y, si es necesario, renunciar al encargo de acuerdo con sus obligaciones contractuales y profesionales.

La presión adopta formas sutiles. «Necesitamos una conclusión clara para mañana» puede traducirse en un incentivo para ignorar la falta de fuentes. «No incluyas esa limitación porque confunde al juez» puede impulsar a suprimir información esencial. «La dirección está convencida de que fue esta persona» puede orientar filtros y selección de artefactos. El profesional responsable responde delimitando lo que puede afirmarse y dejando constancia de las limitaciones. Una conclusión más breve y prudente puede ser mucho más útil que un informe contundente pero vulnerable al examen crítico.

3.5.6. Confidencialidad y necesidad de conocer

Las evidencias digitales pueden contener información extremadamente sensible. Su mera custodia confiere una responsabilidad que se mantiene fuera del horario de trabajo y, en general, más allá de la terminación del encargo. El deber de confidencialidad se traduce en decisiones sencillas pero estrictas: no comentar detalles identificables con personas ajenas, no utilizar ejemplos reales sin autorización y anonimización efectiva, no copiar evidencias a soportes personales y no convertir las capturas de un caso en material de demostración pública.

La aplicación de permisos por **necesidad de conocer** debe regir incluso entre miembros de un mismo equipo. Que varias personas trabajen en el laboratorio no significa que todas deban poder abrir las evidencias de cada expediente. Los registros de acceso, los permisos

temporales y la separación entre casos reducen errores accidentales y permiten aclarar responsabilidades si se produce una incidencia. Las plataformas de colaboración interna deben configurarse con el mismo criterio que los repositorios principales.

La comunicación hacia los destinatarios del informe requiere adaptación. El equipo de respuesta necesita indicadores y decisiones técnicas; la dirección puede necesitar impacto y riesgos; un tribunal requiere hechos, metodología y justificación. La diferencia de presentación no autoriza a alterar el contenido material de las conclusiones. La confidencialidad tampoco implica ocultar información relevante a quienes tienen legítimo derecho a conocerla, sino utilizar canales y versiones apropiados para cada destinatario.

3.5.7. Transparencia sobre errores y correcciones

En cualquier investigación pueden aparecer errores: una conversión de zona horaria equivocada, una herramienta configurada con un filtro incorrecto, un archivo duplicado que altera un recuento o una secuencia atribuida inicialmente a la cuenta equivocada. La exigencia ética no consiste en prometer infalibilidad. Consiste en detectar, corregir y documentar errores de forma proporcionada a sus consecuencias.

Si el error se descubre antes de emitir el informe, la bitácora debe recoger qué cambió y por qué. Si se detecta después de entregar resultados, puede ser necesario emitir una corrección o adenda, comunicar el alcance del cambio y revisar conclusiones relacionadas. Reemplazar silenciosamente un documento entregado destruye trazabilidad y debilita la confianza. El control de versiones debe identificar de manera inequívoca qué informe ha visto cada destinatario.

Es igualmente importante distinguir entre **cambio de interpretación** y **alteración de evidencia**. Una hipótesis puede revisarse porque aparecen nuevos datos o porque una metodología demuestra que un artefacto se interpretó mal. Ese cambio no significa que se haya modificado el archivo original. El expediente debe conservar tanto los resultados anteriores como el motivo de su revisión. La evolución razonada de una conclusión puede ser un signo de rigor, no de inconsistencia.

3.5.8. Seguridad psicológica, trato humano y consecuencias de los informes

Las investigaciones afectan a personas. Una sospecha de filtración puede comprometer un empleo, una reputación o una relación contractual. La interpretación de mensajes personales puede poner de manifiesto circunstancias íntimas ajenas al incidente. Un dictamen

apresurado puede inducir medidas disciplinarias o denuncias basadas en una atribución insegura. El trabajo forense no es una actividad moralmente neutra por el simple hecho de analizar bits.

Un profesional debe tratar a las personas afectadas con respeto, evitar expresiones despectivas y no presentar sospechas como culpabilidades. El anonimato relativo de una cuenta o una dirección IP no reduce esa obligación. La disciplina narrativa consiste en hablar de sistemas, artefactos y acciones comprobables antes de construir afirmaciones sobre individuos. La formulación correcta protege tanto a las personas como a la credibilidad técnica del informe.

Las entrevistas o solicitudes de información a usuarios pueden producir sesgos y riesgos de privacidad. Cuando el analista participe en ellas, deberá respetar su ámbito de competencia y las garantías aplicables. Una pregunta sugestiva puede contaminar el relato; enseñar antes de tiempo una hipótesis puede alterar recuerdos o comportamientos; confrontar directamente a una persona investigada puede comprometer actuaciones formales. La coordinación con profesionales jurídicos o de investigación humana es tan importante como la correlación de registros.

También importa la comunicación de resultados negativos. Si no se han encontrado indicios suficientes para sostener una acusación, debe indicarse con precisión. No hallar un evento en un registro incompleto no equivale a demostrar que el evento nunca ocurrió; pero tampoco es aceptable mantener una acusación por la sola expectativa de que «algo aparecerá». La responsabilidad consiste en describir qué se buscó, qué cobertura existía y qué puede concluirse con ese resultado.

3.5.9. Inteligencia artificial y automatización: ayuda, no autoridad

La automatización permite analizar miles de eventos, identificar patrones y preparar cronologías. Las herramientas basadas en modelos de lenguaje pueden resumir registros, traducir documentos o proponer hipótesis. Todas estas posibilidades requieren una disciplina adicional: conocer las entradas utilizadas, evaluar el rendimiento real y verificar cada afirmación decisiva frente a la fuente primaria. Un modelo puede producir referencias inexistentes, combinar casos distintos o introducir relaciones causales donde solo hay proximidad textual.

La ética del uso de inteligencia artificial en un caso forense no se agota en comprobar que el resumen «suena razonable». Deben considerarse la confidencialidad de los datos enviados, las condiciones de uso, la capacidad de reproducir las operaciones, los posibles sesgos del sistema y las expectativas de quienes recibirán el informe. Si un resultado importante

fue obtenido o transformado mediante automatización, conviene documentar el papel de la herramienta y las verificaciones realizadas por el profesional.

Una práctica correcta es utilizar estos sistemas para tareas auxiliares y contrastar sistemáticamente los resultados. Pueden ayudar a localizar conceptos dentro de documentos o a proponer expresiones de búsqueda, pero no deberían recibir la responsabilidad final de decidir si una persona cometió un hecho, si una evidencia es auténtica o si una actuación estuvo autorizada. Los modelos no asumen la responsabilidad profesional que corresponde al analista y a quien dirige la investigación.

3.5.10. Responsabilidad del laboratorio y de la organización

El comportamiento individual resulta insuficiente si la organización no proporciona medios para trabajar correctamente. Un laboratorio necesita procedimientos de admisión de casos, verificación de autorizaciones, segregación de evidencias, gestión de credenciales, registros de custodia, copias de seguridad, control de herramientas y revisión de informes. Sin estas medidas, la ética se convierte en una exigencia abstracta depositada en personas sometidas a presión y plazos difíciles.

La dirección debe asegurar recursos acordes con el riesgo y evitar incentivos que premien exclusivamente la rapidez o el volumen de hallazgos. También debe definir procedimientos para comunicar conflictos de interés, errores, solicitudes impropias y dudas sobre la legitimidad de actuaciones. El analista necesita un canal real para suspender una operación cuando el riesgo jurídico o técnico supera su competencia, sin verse obligado a improvisar por falta de interlocutores.

La revisión por pares aporta una garantía valiosa, siempre que se realice con independencia suficiente y conocimiento del método. No basta con revisar la ortografía del informe. La revisión técnica puede comprobar correspondencia entre conclusiones y evidencias, filtros, integridad, reproducibilidad, sesgos, cronología, limitaciones y adecuación del lenguaje. En asuntos especialmente sensibles es recomendable que una persona distinta valide las inferencias decisivas o revise los elementos que podrían refutarlas.

3.5.11. Decisiones difíciles: cuándo detener una investigación

No existe una regla ética que obligue a agotar siempre todas las posibilidades técnicas. A veces lo correcto es detenerse. Puede faltar autorización para una nueva fuente, haber desaparecido el objetivo legítimo, haberse comprobado que la siguiente medida sería desproporcionada o existir un conflicto de interés incompatible con una actuación independiente.

La suspensión debe documentarse, comunicarse a quien corresponda y acompañarse de medidas de preservación legítimas si existe riesgo de pérdida.

Detenerse también puede ser adecuado cuando la evidencia es insuficiente para una conclusión sólida. No todo caso requiere un culpable y no todo incidente puede reconstruirse completamente. El cierre profesional puede consistir en exponer las hipótesis compatibles con los datos, la información que faltó y qué habría sido necesario preservar para esclarecer mejor el hecho. La falta de certeza no debe compensarse con un lenguaje categórico.

En sentido contrario, tampoco debe abandonarse una línea de investigación solo porque sus resultados contradigan la expectativa del cliente. Si una fuente pertinente y autorizada ofrece una explicación inocua, debe ser tratada con la misma seriedad que aquella que apunta a una actividad indebida. La obligación de considerar información favorable y desfavorable es parte de la imparcialidad, no una concesión voluntaria.

3.5.12. Un compromiso profesional verificable

La ética es más útil cuando puede expresarse en conductas observables. En la apertura se verifica el mandato y se identifican riesgos. En la adquisición se minimizan alteraciones y se documentan excepciones. En el análisis se contrastan hipótesis alternativas y se conservan resultados negativos. En la interpretación se distinguen hechos de inferencias. En el informe se declaran fuentes, herramientas, incertidumbre y posibles conflictos. En el cierre se protege y gestiona el destino de las evidencias.

Un código de conducta interno puede sintetizar esas obligaciones, pero su eficacia depende de que existan mecanismos para cumplirlo: revisiones, formación, gestión de incidentes del propio laboratorio y una cultura que permita rectificar. La confianza de un tribunal, de una empresa o de una persona afectada no debería descansar en una declaración de honor aislada, sino en un conjunto de decisiones trazables.

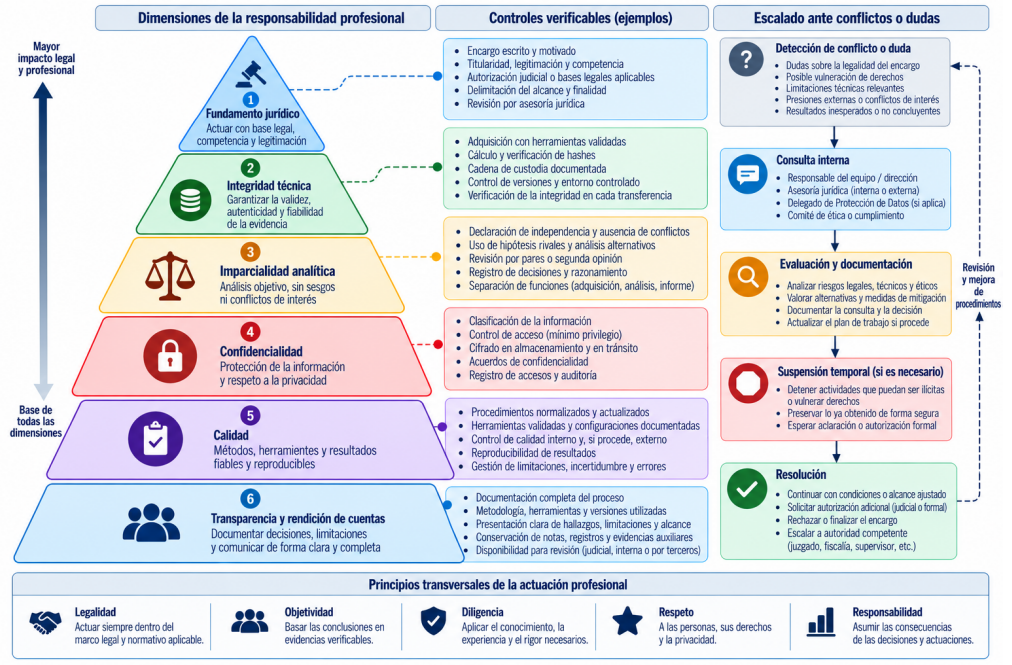


Figura 17: Pirámide de responsabilidad profesional

3.6. Caso integrador: una investigación con límites jurídicos y técnicos

3.6.1. El encargo y las primeras decisiones

Una compañía que presta servicios de mantenimiento industrial detecta que un usuario externo accedió a una plataforma de documentación durante la madrugada. Los eventos disponibles muestran una autenticación correcta y varias solicitudes a la API de descarga. La cuenta pertenece a una ingeniera que trabaja de forma híbrida y que, según la primera información recibida, se encontraba de vacaciones. La empresa sospecha que alguien utilizó sus credenciales para obtener documentación confidencial.

La dirección solicita «revisar toda la actividad de la trabajadora, incluidos sus dispositivos y mensajes». El equipo de seguridad sabe que el servicio conserva los registros detallados durante un periodo corto. Existe, por tanto, una tensión inmediata: preservar datos antes de su rotación y evitar una intervención indiscriminada sobre información personal. El analista propone separar las actuaciones de conservación que ya pueden realizarse legítimamente dentro de la plataforma administrada de aquellas nuevas adquisiciones que requieren una autorización y valoración específica.

El encargo se redefine en términos comprobables: establecer si se produjo una sesión, identificar qué operaciones quedaron registradas, determinar qué documentos pudieron descargarse, reconstruir los controles de autenticación utilizados y evaluar qué explicaciones alternativas encajan con los datos. Se documentan las cuentas, aplicaciones y fechas incluidas. Al mismo tiempo, el asesoramiento jurídico revisa la base de tratamiento y el alcance permitido respecto a recursos corporativos y posibles dispositivos particulares.

En esta fase no se solicita a la trabajadora que entregue su teléfono personal ni se inicia sesión con tokens recuperados. La empresa puede necesitar información de ese tipo más adelante, pero su utilidad hipotética no convierte automáticamente la medida en legítima. El expediente registra esa exclusión de manera expresa, con la posibilidad de reconsiderarla si aparecen razones y habilitaciones suficientes.

3.6.2. Preservación, exportación y evaluación de datos

Se exportan los eventos de autenticación, los registros de la API disponibles y el historial de cambios de permisos dentro del alcance autorizado. El operador documenta la identidad de la cuenta administrativa utilizada, la fecha y hora de la operación, los parámetros de búsqueda, el formato entregado y los hashes calculados sobre los ficheros resultantes. Se conserva también la documentación técnica necesaria para comprender qué representa cada campo de registro.

El equipo advierte que el panel de auditoría permite consultar noventa días de determinados eventos, pero solo treinta de otros. Esta diferencia limita la reconstrucción retrospectiva. Se anotan además la zona horaria de presentación, la resolución de las marcas temporales y la posibilidad de retrasos en la ingestión. El registro de una descarga puede indicar que la plataforma procesó una solicitud; no demuestra necesariamente por sí solo que el archivo terminara íntegramente almacenado en el dispositivo remoto.

La autenticación aparece asociada a una dirección IP residencial conocida, pero esa coincidencia no acredita quién tenía el control físico del equipo en el instante de la operación. El sistema de identidad permite identificar un método de autenticación multifactor, pero no aporta directamente la identidad de la persona que confirmó la notificación. El analista evita convertir correlaciones en autoría. El dato disponible es compatible con distintos escenarios: sesión legítima, credenciales compartidas, compromiso del dispositivo, uso remoto no detectado o una interpretación incompleta de los registros.

3.6.3. Aparición de una fuente situada fuera del alcance

En uno de los eventos aparece el identificador de un cliente de sincronización instalado en un dispositivo que no figura en el inventario empresarial. El administrador local propone usar el token de sesión recuperado para acceder a la cuenta del dispositivo. El analista se opone a ejecutar la acción sin resolver antes su alcance y legitimidad. La mera existencia del token como evidencia no autoriza a emplearlo para una operación distinta sobre información potencialmente privada.

En su lugar, se verifica qué puede deducirse de los registros que ya están disponibles, se comprueba si el servicio conserva detalles adicionales mediante sus mecanismos administrativos autorizados y se describe qué información permanece inaccesible. La existencia de una fuente externa se incorpora como limitación y, en caso de ser necesaria, se eleva una petición formal de ampliación con fundamento, datos buscados y salvaguardas. Si los datos están bajo control de un proveedor situado fuera de España, se identifican los canales contractuales o jurídicos apropiados antes de solicitar su entrega.

El informe provisional describe una descarga asociada a un identificador de sesión, pero deja abierta la autoría. La dirección considera que esa cautela debilita su posición. El perito explica que presentar una atribución personal no demostrada sería mucho más vulnerable. Una conclusión limitada pero sostenida permite adoptar medidas de seguridad y solicitar nuevas diligencias sin confundir sospechas con hechos constatados.

3.6.4. Revisión independiente y comunicación

Antes del informe final, otro especialista examina los eventos decisivos sin partir de la conclusión propuesta. Detecta que una parte de las solicitudes corresponde a la comprobación automática de versiones realizada por el cliente, no necesariamente a descargas solicitadas manualmente. El primer analista revisa los recuentos y separa los eventos automáticos de las transferencias que parecen responder a operaciones de usuario. La corrección se documenta y se conservan los resultados anteriores como parte del historial técnico.

El informe final incluye una síntesis comprensible, la metodología, los límites jurídicos y técnicos, una cronología de eventos, las comprobaciones de integridad, las hipótesis valoradas y las conclusiones con su incertidumbre. Se omiten de la versión ejecutiva datos personales que no son necesarios para decidir las medidas de contención. La evidencia íntegra queda restringida en un repositorio protegido y su destino posterior se somete a la política de conservación aplicable y a las decisiones del responsable.

La conclusión confirma que se produjo actividad desde una sesión asociada a la cuenta investigada, que una parte de esa actividad corresponde a solicitudes de descarga y que existen elementos insuficientes para atribuir materialmente las operaciones a una persona concreta. El caso demuestra que una investigación útil no necesita ignorar las garantías jurídicas para avanzar. Al contrario, cuando la recogida de datos, las decisiones de alcance y las inferencias son transparentes, el resultado se vuelve más defendible.

3.6.5. Qué enseña el caso

El supuesto conecta las cinco dimensiones estudiadas. La **autorización** impide que el encargo inicial se transforme en una búsqueda general. La **diferencia entre contextos** obliga a distinguir respuesta operativa, investigación laboral y posible proceso judicial. La **protección de datos** exige controlar exportaciones, accesos e informes. La **jurisdicción** condiciona nuevas solicitudes al proveedor. La **ética profesional** conduce a corregir el análisis y a declarar los límites de la atribución.

Ninguna de esas exigencias es ajena al trabajo técnico. Todas influyen en qué artefactos se obtienen, cómo se documentan, quién puede verlos y qué conclusiones se expresan. Una investigación que no puede explicar sus propias decisiones de acceso tiene un problema de trazabilidad tan real como aquella que pierde el historial de una evidencia.

3.7. Conclusión

El análisis forense digital obtiene su valor de una combinación inseparable de conocimientos técnicos, actuación legítima y razonamiento honesto. Los sistemas ofrecen datos; las herramientas permiten adquirirlos y procesarlos; la metodología ayuda a convertirlos en hallazgos. Pero solo un marco de autorización, proporcionalidad, protección de las personas y responsabilidad profesional permite sostener ese trabajo dentro de una investigación real.

La primera disciplina consiste en reconocer el límite de las facultades. No basta con conocer una contraseña, poseer físicamente un dispositivo o administrar una plataforma. Es necesario determinar quién puede ordenar cada intervención, para qué finalidad, con qué base y bajo qué restricciones. Cuando el alcance cambia, debe revisarse la autorización. Cuando una medida revela datos de terceros, debe protegerse lo ajeno al caso. Y cuando los hechos apuntan a otra jurisdicción, deben utilizarse los procedimientos adecuados, sin convertir la facilidad técnica en una forma de eludirlos.

La segunda disciplina consiste en respetar la diferencia entre contextos. Una actuación policial o judicial se rige por competencias y garantías procesales específicas. Una investigación empresarial depende de facultades legítimas y de los derechos de las personas afectadas. La respuesta a incidentes puede requerir decisiones urgentes para proteger servicios, pero no transforma todas las operaciones técnicas en actuaciones forenses libres de restricciones. Los expedientes pueden pasar de un contexto a otro, y esa transición debe quedar documentada.

La tercera disciplina se refiere al tratamiento de información. Los datos personales aparecen en prácticamente cualquier investigación significativa: identificadores, comunicaciones, ubicaciones, contenidos y registros. La minimización, el control de acceso, la seguridad, la conservación justificada y el tratamiento de información incidental no son trámites externos al laboratorio. Deben integrarse en la arquitectura de herramientas y procedimientos y mantenerse hasta el cierre definitivo del caso.

La cuarta disciplina es la imparcialidad. El perito debe poder explicar tanto los datos que apoyan una hipótesis como aquellos que la debilitan. Tiene obligación de señalar incertidumbres, reconocer errores, no atribuir acciones sin sustento suficiente y aceptar que algunas preguntas no pueden contestarse con las fuentes disponibles. La credibilidad no procede de la contundencia verbal, sino de la relación demostrable entre las observaciones, los métodos y las conclusiones.

Por último, la responsabilidad no recae solamente sobre una persona. Las organizaciones que investigan necesitan políticas de uso, canales de autorización, procedimientos de custodia, sistemas de protección de datos y mecanismos de revisión de calidad. Sin esa infraestructura, incluso los mejores profesionales trabajarán expuestos a improvisaciones y presiones evitables. La preparación jurídica y ética, al igual que la preparación técnica, debe comenzar mucho antes de que aparezca el incidente.

> **Idea central del capítulo:** la evidencia no adquiere legitimidad por ser digital ni credibilidad por haber sido procesada con una herramienta reconocida. Su utilidad depende de cómo se obtuvo, qué derechos se respetaron, qué controles se aplicaron y hasta dónde permiten llegar realmente sus resultados.

El siguiente capítulo profundizará en la escena digital y la cadena de custodia. Allí estas exigencias se traducirán en operaciones concretas de identificación, preservación, documentación, transporte, almacenamiento y entrega. El marco jurídico y ético desarrollado aquí seguirá siendo la condición de partida de todas ellas.

3.8. Referencias jurídicas y lecturas recomendadas

Las referencias se ofrecen como fuentes primarias para verificar conceptos y profundizar en el marco español y europeo. Los textos consolidados de las bases de datos oficiales facilitan su consulta, pero para una actuación profesional debe contrastarse la redacción y vigencia relevantes en la fecha de los hechos y del procedimiento. Este capítulo tiene finalidad técnica y editorial; **no sustituye el asesoramiento jurídico especializado**.

1. **Constitución Española de 1978.** Especialmente artículo 18, relativo a intimidad, domicilio, secreto de las comunicaciones y garantías frente al uso de la informática. BOE, texto oficial.
2. **Ley de Enjuiciamiento Criminal.** Real Decreto de 14 de septiembre de 1882, en sus disposiciones vigentes sobre diligencias y medidas de investigación tecnológica, particularmente los artículos 588 bis y siguientes. BOE, texto consolidado.
3. **Ley Orgánica 13/2015, de 5 de octubre.** Reforma de la Ley de Enjuiciamiento Criminal para el fortalecimiento de garantías procesales y regulación de medidas de investigación tecnológica. BOE.
4. **Ley 1/2000, de 7 de enero, de Enjuiciamiento Civil.** Entre otros, artículos 299, 335, 382 y 384 sobre medios de prueba, peritos y datos electrónicos. BOE, texto consolidado.
5. **Ley Orgánica 10/1995, de 23 de noviembre, del Código Penal.** Especialmente preceptos sobre descubrimiento y revelación de secretos y acceso no autorizado a sistemas de información. BOE, texto consolidado.
6. **Reglamento (UE) 2016/679, Reglamento General de Protección de Datos (RGPD).** Artículos 4–6, 9–10, 24–25, 28, 32–35 y 44–49, entre otros. EUR-Lex, texto oficial.
7. **Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales.** Especialmente artículos 32 y 87–90. BOE, texto consolidado.
8. **Directiva (UE) 2016/680.** Protección de datos tratados por autoridades competentes para fines penales. EUR-Lex.
9. **Ley Orgánica 7/2021, de 26 de mayo.** Protección de datos personales tratados para fines de prevención, detección, investigación y enjuiciamiento de infracciones penales y ejecución de sanciones penales. BOE, texto consolidado.
10. **Reglamento (UE) 2023/1543, de 12 de julio de 2023.** Órdenes europeas de producción y conservación de pruebas electrónicas en procesos penales. Aplicable desde el 18 de agosto de 2026. EUR-Lex, texto oficial.
11. **Directiva (UE) 2023/1544, de 12 de julio de 2023.** Establecimientos designados y representantes legales de prestadores para recabar pruebas electrónicas en procesos penales. EUR-Lex.

12. **Convenio del Consejo de Europa sobre la Ciberdelincuencia (Convenio de Budapest), ETS n.º 185.** Particularmente disposiciones sobre conservación y cooperación internacional, incluidos los artículos 16, 29–32. Consejo de Europa.
13. **Fiscalía General del Estado (2019).** *Circular 1/2019, de 6 de marzo, sobre disposiciones comunes y medidas de aseguramiento de las diligencias de investigación tecnológicas en la Ley de Enjuiciamiento Criminal.* BOE.
14. **Comité Europeo de Protección de Datos (2021).** *Recommendations 01/2020 on measures that supplement transfer tools to ensure compliance with the EU level of protection of personal data*, versión final. EDPB.
15. **Agencia Española de Protección de Datos.** Guías, informes y orientaciones sobre protección de datos y derechos digitales en el ámbito laboral y sobre gestión de violaciones de seguridad. Portal oficial.
16. **European Court of Human Rights (Tribunal Europeo de Derechos Humanos).** Jurisprudencia sobre privacidad y vigilancia en el trabajo, incluida *Bărbulescu c. Rumanía* (Gran Sala, 2017) y *López Ribalda y otros c. España* (Gran Sala, 2019). HUDOC, buscador oficial.
17. **NIST (2006).** Kent, K.; Chevalier, S.; Grance, T.; Dang, H. *Guide to Integrating Forensic Techniques into Incident Response*, SP 800-86. Referencia técnica complementaria, no fuente de autorización jurídica. NIST.
18. **SWGDE.** Publicaciones sobre adquisición, conservación, análisis, validación e informes de evidencia digital. Recomendaciones técnicas que no sustituyen el marco jurídico aplicable. Repositorio oficial.

4. La escena digital y la cadena de custodia

> Había una sola cosa que podía hacer (…) Instalé un receptor de Registro Visual, para que cualquier cosa que sucediera quedase preservada para su estudio posterior. Con la esperanza, la descabellada pero ferviente esperanza, de que lo que me confundía en ese momento pudiera aclararse tras una revisión. («There was one thing I could do… I set up a Visual Record receiver, so that whatever happened might be preserved for future study. This was in the hope, the wild but earnest hope, that what confused me at the time might become plain upon review.»)
>
> — Isaac Asimov, Fundación (Foundation), Parte V: «Los Príncipes Comerciantes» (Hober Mallow durante su juicio)

Una investigación forense puede fracasar antes de que el analista examine su primer archivo. Basta con que alguien reinicie un ordenador cifrado sin comprobar su estado, desconecte una máquina virtual cuya memoria todavía contiene información relevante, manipule un teléfono sin registrar las operaciones o traslade un disco sin identificar quién lo recibió. En ocasiones la pérdida es irreversible: una clave que residía en memoria desaparece, una sesión autenticada expira, una cola de registros se sobrescribe o un soporte queda dañado durante el transporte. Otras veces la información sobrevive, pero la investigación pierde la capacidad de demostrar de dónde procedía y qué ocurrió con ella durante la intervención.

La escena digital constituye el punto de encuentro entre los hechos, la tecnología y las decisiones humanas. A diferencia de una escena física delimitada por las paredes de una habitación, puede extenderse a estaciones de trabajo, servidores, teléfonos, soportes extraíbles, redes, sistemas de vigilancia, máquinas virtuales y servicios prestados desde otros países. Incluso cuando el objeto de la intervención es un único portátil, sus rastros pueden depender de un proveedor de identidad, una plataforma de correo, un servidor de ficheros o un sistema de copias de seguridad. Por eso, asegurar una escena no significa necesariamente ocupar una sala ni retirar todos sus dispositivos. Significa reconocer las fuentes relevantes, preservar las posibilidades de investigación y mantener bajo control las actuaciones que podrían modificar o destruir información.

El capítulo anterior estableció que toda intervención necesita un fundamento legítimo y un alcance definido. Aquí ese principio se traduce en decisiones materiales: quién entra en la escena, qué puede tocar, qué debe fotografiarse, qué información es urgente, cuándo conviene aislar un sistema y cómo se acredita la continuidad entre un objeto localizado y los resultados que finalmente aparecen en un informe. La dimensión jurídica permanece presente, aunque el propósito central sea operativo. Una cadena de custodia impecable no convierte

en lícito un acceso no autorizado; una autorización válida tampoco convierte en fiable una adquisición mal documentada.

Conviene distinguir desde el principio **recogida**, **adquisición** y **preservación**. La recogida puede consistir en hacerse cargo de un dispositivo físico. La adquisición crea u obtiene una representación de datos —por ejemplo, una imagen de disco, una extracción lógica o un volcado de memoria—. La preservación agrupa las medidas encaminadas a impedir pérdidas o modificaciones injustificadas a lo largo de todo el ciclo de vida de la evidencia. No siempre coinciden en el tiempo ni las realiza la misma persona. Es posible preservar datos remotos sin disponer todavía de una copia; es posible adquirir un registro sin retirar el servidor; y es posible custodiar un teléfono cuya extracción se realizará semanas después, siempre que se haya elegido y documentado una estrategia de conservación apropiada.

Este texto toma como referencias metodológicas la familia de buenas prácticas de **SWGDE**, especialmente sus documentos sobre recogida de evidencia y adquisición informática; **ISO/IEC 27037:2012**, dedicada a identificación, recogida, adquisición y preservación; las guías **NIST SP 800-86** y **NIST SP 800-101 Rev. 1**; y las orientaciones del **National Institute of Justice** para primeros intervinientes. Estos documentos no sustituyen la legislación ni establecen una secuencia universal aplicable a cualquier escena. Las técnicas propuestas deben adaptarse al dispositivo, al riesgo, a las facultades de intervención y a los procedimientos vigentes del organismo o laboratorio.

La idea principal a lo largo de todo el capítulo es sencilla, aunque su aplicación no siempre lo sea: **la evidencia debe conservarse junto con la historia verificable de las decisiones que permitieron obtenerla**. Preservar un archivo sin conservar su contexto puede ser insuficiente. Documentar una intervención sin preservar la información puede ser inútil. La solidez aparece cuando ambas obligaciones se cumplen de manera coordinada.

4.1. Identificación y aseguramiento de la escena

4.1.1. La primera decisión no es técnica: determinar qué escena tenemos delante

Antes de conectar herramientas, extraer cables o pedir credenciales, es necesario comprender qué ha ocurrido, qué se ha autorizado y qué puede perderse. Una llamada que comunica «han desaparecido documentos de un repositorio» no describe todavía una escena forense. Los archivos pueden haber sido eliminados, movidos, ocultados por un cambio de permisos, retirados por una política de retención o mostrarse incorrectamente por un error de sincronización. Del mismo modo, una estación de trabajo con una alerta de malware puede ser el origen de la actividad, una víctima secundaria o simplemente el dispositivo donde se detectó un comportamiento generado en otro lugar.

El responsable de la intervención necesita obtener un relato inicial sin transformarlo en una conclusión anticipada. Importa registrar quién notificó el hecho, cuándo se advirtió, cuál fue la última situación conocida, qué sistemas están afectados y qué operaciones se realizaron después de la detección. También debe identificarse el motivo de la intervención: investigación judicial, investigación interna autorizada, respuesta a un incidente o aseguramiento de información para una controversia. Cada contexto impone límites diferentes a la presencia del equipo, a la obtención de datos y a su eventual comunicación.

La escena ha de interpretarse como un **conjunto de relaciones entre objetos, servicios, personas y tiempos**. El disco de un ordenador no es independiente de la cuenta con la que se inicia sesión. Un archivo compartido puede tener réplicas, versiones y enlaces de acceso. Una cámara puede conservar las imágenes en una tarjeta local, en un grabador o en una plataforma externa. Un registro de autenticación puede originarse en un proveedor de identidad y no en la aplicación examinada. Localizar el equipo físicamente visible no garantiza haber identificado la fuente que conserva el dato decisivo.

Esta distinción resulta especialmente importante cuando varias organizaciones comparten infraestructura. Un contratista administra una plataforma, el titular de los datos es otra entidad, el equipo se encuentra en unas instalaciones arrendadas y los registros se retienen en un servicio de terceros. Quien interviene debe confirmar qué puede preservar directamente, qué necesita solicitar y qué no puede examinar sin una autorización adicional. Las operaciones urgentes no eliminan estas fronteras; obligan a gestionarlas con rapidez.

4.1.2. Delimitación material, lógica y temporal

Una escena suele tener, al menos, tres dimensiones. La **material** identifica espacios físicos, dispositivos, soportes, cableado, conexiones y objetos asociados. La **lógica** comprende cuentas, máquinas virtuales, recursos compartidos, volúmenes, identidades, claves, registros y relaciones entre servicios. La **temporal** delimita cuándo pudo producirse el hecho y cuánto tiempo seguirán disponibles los rastros relevantes. Ninguna dimensión puede considerarse aislada.

Pensemos en una investigación por acceso indebido a una aplicación de gestión. La dimensión material incluye el portátil desde el que supuestamente se accedió y los dispositivos de red de la oficina. La lógica incorpora la identidad del usuario, la aplicación, sus API, el almacenamiento y la plataforma de auditoría. La temporal comienza antes del primer acceso sospechoso e incluye, quizá, la creación de una credencial días atrás y la expiración de registros una semana después. Si el equipo se ocupa correctamente, pero los registros remotos se borran por rotación, el aseguramiento ha sido incompleto.

Una delimitación útil debe responder a cuatro preguntas: qué sistemas son potencialmente relevantes, en qué intervalos, por qué relación concreta con el hecho y con qué fundamento pueden intervenirse. La delimitación no exige conocer desde el inicio todas las fuentes. Exige contar con un mecanismo documentado para ampliar el alcance cuando aparezcan nuevas relaciones. La incorporación de un equipo adicional no debería quedar oculta en una nota técnica ni justificarse retrospectivamente mediante la relevancia de lo hallado.

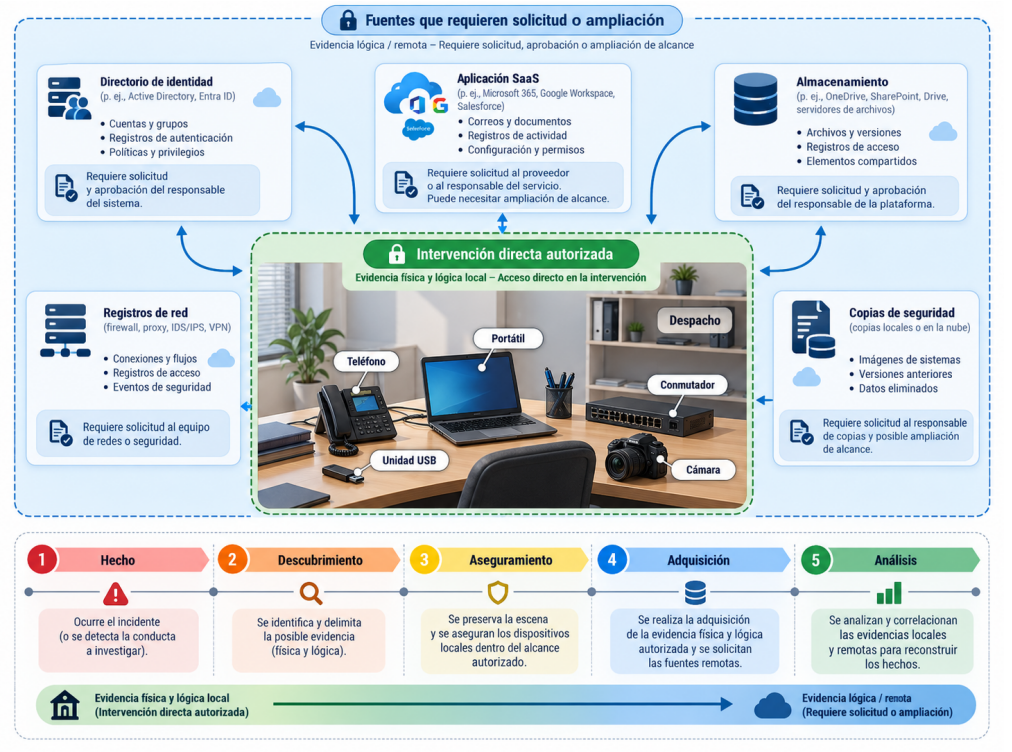


Figura 18: La escena del análisis

4.1.3. Asegurar sin destruir: control de personas, accesos y cambios

En una escena física, impedir que personas no autorizadas entren y manipulen objetos constituye una precaución intuitiva. En un entorno digital existe un equivalente menos visible: impedir que continúen tareas automáticas, accesos remotos y operaciones administrativas capaces de alterar información relevante. Puede ser necesario restringir la presencia física en una sala, pero también identificar quién posee privilegios para apagar servicios, reinstalar equipos, purgar registros o cambiar reglas de retención.

La primera protección consiste en **controlar y documentar la intervención humana**. Se designa una persona responsable de la escena, se identifica a quienes participan, se registra su entrada y salida cuando resulte procedente y se acuerda que ninguna manipulación se realice sin comunicación al responsable. En una organización pequeña puede bastar un registro sencillo; en una intervención judicial o de especial relevancia se aplicarán las medidas previstas por el procedimiento correspondiente. Lo importante es que una decisión tomada por un técnico de soporte, un responsable de sistemas o un tercero contratado no se vuelva invisible para el equipo forense.

En paralelo se evalúa la **actividad técnica en curso**. Un sistema puede estar cifrando ficheros, borrando registros, sincronizando documentos o recibiendo órdenes remotas. Mantenerlo conectado preserva algunos datos volátiles, pero también permite que el incidente continúe. Aislarlo puede detener la propagación y dificultar la actuación del adversario, aunque modifique conexiones y haga inaccesibles servicios remotos. No existe una respuesta correcta independiente del contexto. La decisión debe vincularse al riesgo de daño, la volatilidad, las fuentes alternativas, las obligaciones legales y la continuidad operativa.

La seguridad de las personas siempre prevalece sobre la comodidad forense. Un equipo puede encontrarse en una instalación eléctrica, una planta industrial, una unidad sanitaria o un entorno con riesgos físicos. Intervenir sobre controles industriales, dispositivos médicos o maquinaria sin coordinación con su responsable técnico puede causar daños reales. La obtención de evidencias no autoriza a provocar una parada insegura. En esos casos debe planificarse la captura con especialistas operativos y, si procede, priorizar registros externos que permitan estudiar el incidente sin manipular inicialmente el sistema crítico.

4.1.4. Reconocimiento inicial: observar antes de actuar

Una disciplina básica del aseguramiento consiste en **registrar el estado encontrado antes de modificarlo**, siempre que la urgencia y la seguridad lo permitan. Se anotan fecha y hora del hallazgo, lugar, personas presentes, condiciones ambientales pertinentes, pantallas visibles, aplicaciones abiertas, conexiones físicas y dispositivos cercanos. Se toman fotografías generales para fijar la disposición de la escena y después imágenes de detalle que permitan distinguir identificadores, puertos, cables y daños visibles. Fotografiar no equivale a interpretar; constituye una forma de conservar observaciones para futuras comprobaciones.

La documentación visual debe evitar dos errores comunes. El primero es mostrar únicamente primeros planos sin contexto: una memoria USB fotografiada sobre una mesa puede reconocerse, pero no saberse dónde estaba conectada ni a qué equipo pertenecía. El segundo es confundir una fotografía posterior a la manipulación con el estado original. Si se retiró una tapa, se desconectó un cable o se movió un dispositivo para leer su número de serie, esa

alteración debe quedar registrada. No es necesario ocultar la intervención para defenderla; es necesario explicar qué cambió y por qué.

Ante un equipo encendido, la pantalla puede contener una sesión desbloqueada, una herramienta de cifrado, una transferencia en curso o una alerta de seguridad. La fotografía de la pantalla preserva parte del contexto, pero no sustituye una adquisición técnica: no registra procesos ocultos, datos de memoria ni conexiones que no aparezcan en la interfaz. También es posible que la pantalla muestre información sensible ajena a la finalidad autorizada. La documentación debe gestionarse conforme al principio de acceso limitado; las fotografías de la escena son, en sí mismas, material potencialmente confidencial.

Hay detalles que merecen especial atención por su relación con la futura interpretación: reloj mostrado en pantalla, zona horaria configurada cuando pueda comprobarse, estado de conexión a redes, indicadores de alimentación, presencia de unidades externas, disposición de un NAS, numeración de puertos y conexiones de almacenamiento. Si no es posible comprobar alguno de esos elementos sin intervenir, se indica como no verificado. La precisión de una nota es preferible a una descripción aparentemente completa basada en suposiciones.

4.1.5. Preservación remota y decisiones urgentes

No todas las escenas pueden visitarse. Es posible que el activo esté en otra sede, que solo exista como instancia en la nube o que pertenezca a un proveedor que conserva registros durante un periodo breve. En esas situaciones, asegurar la escena puede consistir en solicitar la preservación de datos, impedir rotaciones mediante un cambio autorizado de retención, realizar una exportación conforme al procedimiento disponible o capturar un estado de máquina virtual con las limitaciones conocidas.

Una **solicitud de conservación** y una **entrega de datos** no son la misma operación. La primera pretende evitar la pérdida de información potencialmente relevante; la segunda implica obtenerla. En ambos casos hay que atender al régimen contractual y jurídico aplicable, especialmente si interviene una autoridad o si la información está controlada por un tercero. Una empresa tampoco debe asumir que una cuenta administradora de la nube le concede automáticamente facultades para consultar contenidos personales de cualquier usuario.

Cuando la actuación depende de una API, de un panel web o de una consola de administración conviene documentar la identidad usada, los permisos efectivos, el intervalo consultado, los filtros, la paginación, el formato exportado, las advertencias del servicio y la hora de la extracción. Un archivo CSV obtenido de una consola no contiene necesariamente todos

los campos que el proveedor almacena; una descarga puede excluir registros antiguos, datos sujetos a restricciones o elementos no visibles para ese rol. La limitación de la fuente debe incorporarse al inventario y, más adelante, al análisis.

4.1.6. Ejemplo: una sala de servidores después de una intrusión

Una organización descubre una cuenta administrativa utilizada fuera de horario. En la sala técnica hay dos servidores físicos, un NAS, una consola de virtualización y un cortafuegos. Uno de los servidores muestra una sesión activa; otro está apagado. La respuesta operativa ha bloqueado temporalmente la cuenta y aislado una VLAN. La escena ya ha cambiado antes de que llegue el analista, pero no por ello carece de valor. El primer trabajo consiste en reconstruir esas actuaciones iniciales y obtener sus registros: quién bloqueó la cuenta, desde qué consola, a qué hora, qué reglas modificó y qué servicios pudieron quedar afectados.

El inventario preliminar revela que la aplicación comprometida está alojada en una máquina virtual sobre el servidor encendido. Los registros del proveedor de identidad se conservan solo durante un plazo limitado, mientras que el NAS dispone de instantáneas diarias. La prioridad no puede decidirse por proximidad física. Puede ser más urgente preservar los registros remotos y la memoria de la máquina virtual que retirar el servidor apagado. Sin embargo, cualquier captura de una instantánea debe revisarse para saber si incluye memoria, si altera el estado de la máquina y si es coherente con los procedimientos de la plataforma.

El equipo documenta el estado de la sala, registra las actuaciones ya realizadas, acuerda el alcance y comienza por aquellas fuentes cuya pérdida es más probable. Solo después decide qué dispositivos físicos necesitan retirarse. Si una nueva fuente aparece —por ejemplo, una consola SaaS administrada por un tercero— se inicia el procedimiento de ampliación pertinente. El caso muestra por qué asegurar una escena consiste en gestionar fuentes y riesgos, no en apagar indiscriminadamente todo lo que se encuentra.

4.2. Inventario y documentación de dispositivos

4.2.1. Inventariar no es redactar una lista de objetos

Un inventario forense debe permitir reconocer inequívocamente aquello que se ha localizado, relacionarlo con su contexto y seguir su trayectoria. Una enumeración del tipo «ordenador, dos discos y teléfono» resulta insuficiente incluso para una intervención pequeña. Se necesita un **identificador único de evidencia**, vinculado al número del caso, que no dependa únicamente de la etiqueta comercial, del nombre del equipo o del número de serie del fabricante. Dos discos del mismo modelo pueden llevar etiquetas intercambiadas; un equipo

puede carecer de número visible; y una imagen de disco, al no ser un objeto físico, necesita también su propio identificador.

La identificación debe separar tres niveles: **activo**, **soporte u objeto** y **conjunto de datos adquirido**. El activo representa el sistema en contexto, como una estación de ingeniería denominada `ENG-WS-07`. El soporte es, por ejemplo, la unidad SSD extraída de esa estación. El conjunto adquirido puede ser una imagen E01 obtenida del SSD o una colección lógica de registros. Estos elementos están relacionados, pero no son intercambiables. En una investigación con varias copias, conservar esta distinción evita que un informe atribuya al equipo completo un hash calculado sobre una imagen concreta.

Puede adoptarse una nomenclatura como `AF-2026-017-E03` para un objeto y `AF-2026-017-E03-A01` para su primera adquisición. El patrón exacto no es obligatorio: lo esencial es que sea estable, único dentro del sistema de gestión y suficientemente sencillo para utilizarse sin errores. Si se descubre una etiqueta equivocada, se documenta la corrección; no se reescribe silenciosamente el historial. El identificador debe mantenerse en formularios, contenedores de evidencia, fotografías, registros de adquisición y entregas.

4.2.2. Atributos del inventario físico y lógico

La ficha de un equipo físico suele incluir fabricante, modelo, número de serie, etiqueta de activo, descripción, ubicación exacta de hallazgo, estado de encendido, conexiones relevantes, soporte instalado cuando sea identificable, daños aparentes y observaciones. Se incorpora quién lo localizó, quién lo manipuló, la hora del registro y el identificador de la fotografía. Conviene distinguir **dato observado** de **dato proporcionado por otra persona**. «Número de serie leído en la carcasa» no posee la misma procedencia que «número de serie comunicado por administración de sistemas».

Las conexiones aportan contexto. Una unidad USB conectada a un puerto trasero puede ser pertinente si se investiga una posible extracción de datos. Un cable conectado a un adaptador de red distinto del principal puede explicar rutas alternativas. Una estación puede tener simultáneamente Ethernet, Wi-Fi y una VPN. Antes de desconectar, la documentación debe permitir reconstruir la topología que se observó. En escenas complejas, una fotografía general y un esquema sencillo de conexiones son más eficaces que una serie de notas inconexas.

El inventario lógico incorpora identificadores distintos: nombre de host, UUID de máquina virtual, identificador de volumen, ID de cuenta, tenant, suscripción cloud, región, ID de instancia o nombre de recurso. Algunos son modificables, otros se reutilizan o pueden no ser

globalmente únicos. Un nombre de host por sí solo no demuestra identidad física ni continuidad temporal. Por ello se asocia cada identificador a su fuente, a la fecha de observación y, cuando procede, a otros atributos que permitan corroborarlo.

En dispositivos móviles la identificación exterior puede requerir cautela: no siempre es posible observar el IMEI, el número de serie o la versión del sistema sin desbloquear el equipo o interactuar con él. La ficha recogerá únicamente lo comprobado sin operaciones no autorizadas y registrará qué datos quedan pendientes para una adquisición especializada. En servicios remotos, la ficha debe indicar además el mecanismo de exportación, los permisos del rol utilizado y el proveedor responsable de la conservación de los datos.

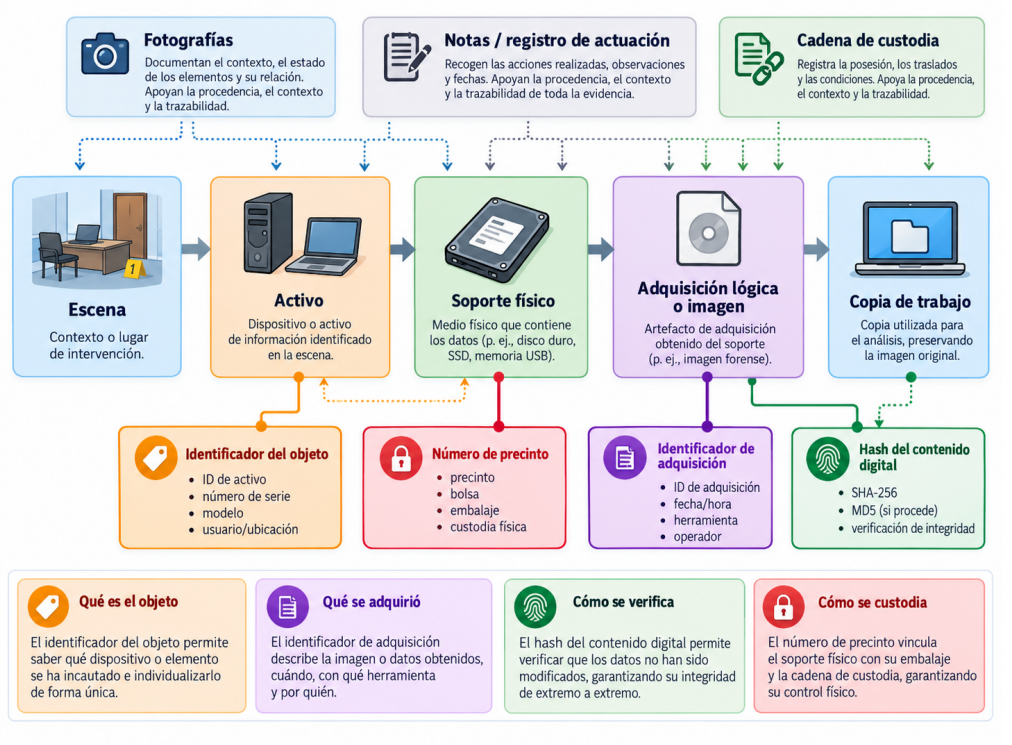


Figura 19: Evidencia compuesta

4.2.3. La fotografía y el croquis como evidencias de contexto

Una fotografía no es un simple recordatorio visual. Puede ayudar a demostrar la posición de un objeto antes de su recogida, la existencia de conexiones y el estado de sellos o etiquetas. Debe conservarse el archivo original de captura cuando sea posible, registrar quién realizó la

fotografía y diferenciarlo de versiones editadas para presentación. Recortar una imagen con finalidad ilustrativa no es necesariamente incorrecto; el problema surge cuando se pierde el original o se presenta el recorte como si contuviera toda la escena.

Los dispositivos de captura también generan metadatos que pueden ayudar a ordenar fotografías, aunque no deben considerarse relojes de referencia sin comprobación. La hora EXIF puede ser incorrecta por configuración, cambio horario o sincronización defectuosa. Conviene fotografiar, si resulta pertinente, una referencia horaria controlada o documentar la desviación del reloj de la cámara respecto de una fuente fiable. Si las fotografías son realizadas por diferentes personas, deberá preservarse quién captó cada una y su secuencia real.

Los croquis y diagramas permiten representar relaciones que no aparecen completas en una fotografía. El trazado de un cable puede atravesar un armario cerrado, y un disco asociado a una máquina virtual puede residir en un almacenamiento compartido situado en otro edificio. Un croquis puede combinar elementos físicos con una representación lógica, siempre que indique qué parte fue observada y qué parte procede de documentación técnica. La etiqueta «topología declarada por el administrador» evita presentar una hipótesis de arquitectura como una observación directa.

4.2.4. Documentar el estado y el comportamiento, no solo la identidad

El inventario también debe reflejar condiciones que condicionan la extracción posterior. ¿Está el equipo encendido? ¿La pantalla está bloqueada? ¿Se aprecia un software de cifrado? ¿Existen notificaciones de sincronización? ¿El dispositivo presenta daños? ¿Está conectado a la corriente? ¿Hay un disco externo montado? ¿Se observan LEDs de actividad? Esas preguntas ayudan a valorar riesgos, pero no autorizan a realizar manipulaciones para obtener respuesta a todas ellas.

Una descripción como «portátil apagado» puede ser ambigua. Algunos equipos modernos utilizan suspensión, hibernación o modos de espera conectada; una pantalla oscura no demuestra ausencia de alimentación. La observación debe formularse con precisión: «pantalla negra; indicador de alimentación encendido; ventilador audible», o «no se observan indicadores de actividad; no se manipuló el botón de encendido». De forma semejante, «servidor aislado» requiere especificar si se desconectó físicamente, se bloqueó su puerto de conmutador, se modificó una regla de cortafuegos o se retiraron credenciales de acceso.

Las notas también deben registrar incidencias y límites. Si no pudo leerse el número de serie porque abrir el equipo habría alterado un precinto, se señala. Si un dispositivo no se fotografió antes de que personal de emergencia lo desplazara, se consigna esa circunstancia. Si un administrador había reiniciado el servidor antes de la llegada del equipo forense, el hecho

forma parte de la historia de la escena y puede explicar la ausencia de determinados registros volátiles.

4.2.5. Modelo de ficha de inventario

La siguiente ficha ficticia muestra un nivel razonable de detalle para una primera intervención. Los nombres y valores son ilustrativos; no representan evidencias reales.

Campo	Registro ilustrativo
Caso	AF-2026-017
Evidencia	AF-2026-017-E03
Tipo	Portátil corporativo
Fabricante y modelo	Fabricante X, serie profesional Y
Identificación visible	Serie de carcasa `S-EXEMPLO-207` (ficticia)
Etiqueta corporativa	ENG-WS-07
Lugar	Despacho de ingeniería, puesto 4
Localización	21/10/2026, 09:42 CEST (hora registrada por interviniente)
Estado observado	Encendido, pantalla bloqueada, alimentación conectada
Conexiones visibles	Ethernet, corriente, memoria USB conectada
Fotografías	AF-2026-017-F012 a F019
Precinto posterior	P-006381 (ejemplo)
Recogida	Pendiente de decisión; equipo inicialmente preservado in situ
Observaciones	No se pulsaron teclas ni se desconectaron cables durante el reconocimiento

Una ficha de esta clase debe vincularse al registro de actuaciones, no sustituirlo. La hora de localización no es la hora de recogida, y ninguna de las dos equivale necesariamente al momento en que se adquirieron datos. Una misma evidencia puede experimentar varios cambios de estado entre esos acontecimientos. El inventario fija qué se encontró; la bitácora

de intervención explica qué se hizo; y la cadena de custodia acredita quién asumió su control en cada transferencia.

4.2.6. Relaciones entre evidencias y procedencia de los datos

En una investigación moderna pueden coexistir cientos de archivos exportados, imágenes de disco, fotografías, capturas de memoria y registros descargados. Sin una estructura relacional, el inventario termina convertido en una lista que no permite reconstruir la procedencia. Conviene documentar que la adquisición `A01` procede del soporte `E03`, que la copia de trabajo `C02` se creó a partir de `A01` y que el informe cita el artefacto `H17`, extraído mediante un procedimiento determinado de esa copia.

Esta relación puede representarse como un **grafo de procedencia**: objeto original, operación de adquisición, archivo resultante, verificación de integridad, derivaciones analíticas y hallazgo. No hace falta implantar una herramienta compleja para obtener su beneficio. Una tabla bien diseñada y referencias cruzadas consistentes pueden ser suficientes en casos modestos. En investigaciones de gran volumen conviene utilizar un gestor de evidencias que conserve relaciones, permisos y auditoría de cambios.

Un principio útil es evitar que la misma palabra «original» se aplique a elementos distintos. El disco físico intervenido puede ser el soporte original. El fichero entregado por un proveedor puede ser la primera copia disponible para el laboratorio, pero no necesariamente el archivo original almacenado en la plataforma. La imagen adquirida puede convertirse en **copia maestra de referencia** para el análisis, sin convertirse por ello en el dispositivo físico que la originó. La terminología debe explicar exactamente qué se conserva y qué se verificó.

4.2.7. Ejemplo: un disco externo que cambia de manos

Un analista localiza un disco externo conectado a una estación de trabajo, lo fotografía, lo identifica y lo desconecta conforme a la estrategia acordada. Una segunda persona traslada el soporte al laboratorio y una tercera realiza la imagen forense. Si en todos los documentos aparece simplemente «disco USB», el historial será débil. Si el objeto dispone de identificador, descripción, fotos, número de precinto, registro del retiro, entrega firmada y correspondencia con la adquisición, será posible reconstruir la operación.

Supongamos, sin embargo, que el laboratorio descubre que el número de serie leído en la escena no coincide con el registrado durante la adquisición. La reacción correcta no consiste en modificar las fichas antiguas para eliminar la discrepancia. Debe abrirse una incidencia,

comparar fotografías y etiquetas, establecer si hubo un error de transcripción o una sustitución y dejar constancia de la resolución. Una corrección transparente puede preservar la fiabilidad del caso; una corrección invisible puede convertir una equivocación menor en una duda sobre toda la documentación.

4.3. Intervención sobre equipos encendidos y apagados

4.3.1. El estado del equipo condiciona la estrategia

La primera decisión al intervenir sobre un equipo informático suele formularse incorrectamente como una alternativa simple: apagarlo o dejarlo encendido. En realidad, deben considerarse muchos estados. Un servidor puede estar operativo y accesible; una estación puede tener la pantalla bloqueada y el volumen cifrado montado; un portátil puede encontrarse suspendido; un dispositivo puede aparentar estar apagado y continuar conectado en un modo de bajo consumo; una máquina virtual puede seguir ejecutándose aunque nadie tenga abierta su consola. Las posibilidades de preservación varían radicalmente.

Un equipo encendido conserva **información volátil** que puede desaparecer al interrumpir la alimentación: contenido de memoria, procesos en ejecución, conexiones de red, sesiones de usuario, material criptográfico en uso y parte del estado de aplicaciones. Esa información puede resultar decisiva para reconstruir un incidente, especialmente si existen indicios de ejecución de código en memoria, conexiones con infraestructura externa o cifrado de volúmenes. Por otro lado, mantener el sistema operativo permite que continúen procesos legítimos y maliciosos, que se escriban registros y que un adversario actúe de forma remota. La preservación no equivale a congelación perfecta.

Un equipo realmente apagado presenta otro conjunto de ventajas y límites. Por regla general es más sencillo evitar modificaciones del sistema operativo durante una adquisición fuera de línea, pero quizá se hayan perdido claves, sesiones y procesos volátiles. Arrancarlo para examinar su contenido puede disparar montajes automáticos, recuperación de sistemas de archivos, sincronizaciones o cambios en metadatos. Si está cifrado, arrancarlo sin el procedimiento adecuado puede no permitir acceder a sus datos y complicar una intervención posterior.

La estrategia debe derivarse de una **evaluación de consecuencias**, no de una regla universal aprendida fuera de contexto. Una orden de desconectar de inmediato todos los dispositivos puede ser necesaria ante un riesgo físico o una instrucción legal específica, pero no constituye por sí sola una buena práctica general. Tampoco lo es mantener todo encendido a cualquier precio. La decisión razonable conserva las fuentes más importantes que todavía pueden obtenerse, minimiza alteraciones y deja constancia de las renuncias inevitables.

4.3.2. Equipos encendidos: observación, captura y control del riesgo

La intervención sobre un equipo encendido comienza con la observación externa del estado que presenta: alimentación, pantalla, actividad aparente, periféricos, conexiones y señales de ejecución. La presencia de una pantalla bloqueada no autoriza a intentar contraseñas, desbloquear cuentas o elevar privilegios fuera del alcance establecido. Si se ha autorizado una actuación en vivo, hay que precisar previamente qué clases de información se pretenden obtener y qué herramientas resultan adecuadas.

La **adquisición en vivo** consiste en extraer datos de un sistema que continúa ejecutándose. Puede abarcar memoria RAM, tablas de procesos, conexiones, sesiones, descriptores de archivos, información de dispositivos montados o registros disponibles únicamente durante la operación. Su principal ventaja es que permite observar estados que no existirán después del apagado. Su principal limitación es que el propio acto de observar puede alterar el sistema: iniciar un programa crea procesos, ocupa memoria, modifica cachés, abre archivos y genera eventos. Este fenómeno no invalida automáticamente la evidencia, pero obliga a documentar cómo se produjo y qué artefactos pueden atribuírsele.

Por esa razón conviene preparar de antemano medios de recogida adecuados. Una herramienta que se ejecuta desde un soporte externo no se vuelve inocua por ese motivo: utiliza memoria, bibliotecas y servicios del sistema examinado. Puede incluso desencadenar alertas de seguridad o interactuar con el software que se pretende estudiar. Se debe conocer su funcionamiento, su versión, las dependencias y, cuando sea posible, disponer de pruebas previas sobre sistemas comparables. Si el método genera archivos temporales, registros o servicios, esos efectos deben identificarse.

La elección del destino de la adquisición también influye en la escena. Es posible guardar resultados en una unidad externa preparada, en un repositorio de red controlado o en almacenamiento remoto seguro. Cada alternativa añade riesgos: escribir localmente puede consumir espacio o sobrescribir datos; transferir por red altera conexiones y genera tráfico; utilizar una unidad externa puede producir eventos de conexión USB. La intervención debe registrar el medio de destino, su identificación y el procedimiento de protección aplicado a los resultados.

En un sistema comprometido es prudente desconfiar de lo que el propio sistema informa. Un proceso malicioso con privilegios elevados puede manipular vistas y registros. Las herramientas ejecutadas dentro del sistema operativo pueden observar una representación parcial o falseada. Cuando el alcance y las circunstancias lo permitan, conviene contrastar con fuentes independientes, como telemetría de red, capturas del hipervisor, registros centralizados y adquisiciones fuera de línea. No toda discrepancia revela manipulación deliberada: también puede deberse a cambios de estado entre dos capturas.

4.3.3. La paradoja de la memoria: capturar lo que cambia al capturarlo

La memoria RAM representa el caso paradigmático de evidencia dinámica. Su contenido cambia constantemente por la actividad del sistema. Una captura completa realizada en un equipo en funcionamiento tiene un intervalo de adquisición: las primeras páginas pueden haberse leído segundos o minutos antes que las últimas. No equivale, por tanto, a una fotografía atómica de todo el estado de la memoria. El analista debe conocer las capacidades y limitaciones de la herramienta utilizada y evitar describir el volcado como una representación perfecta de un instante único.

La captura puede revelar estructuras de procesos, módulos cargados, conexiones, fragmentos de documentos, datos de sesión y material criptográfico presente en ese momento. Sin embargo, no garantiza encontrar todas las claves ni todas las huellas de una actividad. Algunas regiones pueden estar protegidas, no ser accesibles o haber sido reutilizadas. El volcado puede contener información privada de personas no relacionadas con la investigación. Por ello se exige una autorización adecuada, protección reforzada de la evidencia y análisis proporcional.

En las adquisiciones de memoria es especialmente importante comprender qué significa el valor hash. Calcular SHA-256 sobre el archivo resultante permite verificar posteriormente que **ese archivo** no ha cambiado. No demuestra que el sistema estuviera inmóvil durante la recogida ni que la herramienta obtuviera absolutamente todo el contenido de la memoria. Tampoco permite esperar que dos capturas sucesivas tengan el mismo hash: el sistema continúa funcionando y sus datos son diferentes. La fiabilidad se apoya en el método, la documentación y la corroboración, además de en la integridad de la copia obtenida.

Imaginemos que un analista adquiere memoria, luego enumera conexiones y finalmente recoge registros del sistema. Al procesar el volcado identifica una conexión asociada a un proceso sospechoso que ya no aparece en el listado posterior. La diferencia no es, por sí sola, un defecto de la adquisición. Puede significar que la conexión terminó durante la intervención. El análisis tendrá que confrontar marcas temporales, evidencia de red y alcance real de cada técnica, en lugar de suponer que todos los resultados representan el mismo instante.

4.3.4. Cifrado, autenticación y sesiones abiertas

El cifrado completo de disco modifica de forma significativa la estrategia. Un volumen protegido puede estar accesible mientras el sistema está encendido y montado, pero requerir una clave o un procedimiento de desbloqueo después del apagado. Esto afecta tanto a estaciones como a servidores, máquinas virtuales y ciertos soportes externos. El estado de una

sesión abierta no equivale necesariamente al estado de cifrado del almacenamiento: es posible que el disco siga montado con la pantalla bloqueada, o que el sistema requiera nuevas credenciales para un recurso concreto.

Ante un equipo encendido con cifrado aparente, el analista debe identificar las opciones técnicas **sin improvisar actuaciones intrusivas**. Puede ser prioritario preservar la información accesible mediante métodos autorizados y documentados, o puede ser preferible retirar el soporte y trabajar fuera de línea si se dispone legítimamente del material necesario. La decisión depende del riesgo, de los permisos, de las herramientas y del valor de los datos volátiles. Un reinicio puede hacer que desaparezca la posibilidad de acceder a información que estaba descifrada en ese momento.

Las credenciales encontradas durante una intervención requieren un tratamiento especialmente prudente. Localizar una contraseña, un token o una clave privada no equivale a recibir autorización para usarla en otra cuenta, ampliar el acceso a nuevos dispositivos o consultar servicios de terceros. Su existencia puede ser relevante como evidencia; utilizarla puede constituir una actuación nueva con implicaciones jurídicas y técnicas propias. Cuando sea necesario acceder a un servicio, se debe optar por mecanismos autorizados, auditables y compatibles con las reglas del procedimiento.

También es importante diferenciar **capturar una sesión** de **suplantar una identidad**. El hecho de que una aplicación esté abierta puede facilitar la exportación legítima de información, pero la operación debe encontrarse dentro del alcance y quedar registrada. Un analista no debe navegar libremente por espacios personales aprovechando que la sesión está iniciada. El carácter oportunista de un acceso no lo convierte en proporcionado.

4.3.5. Suspensión, hibernación y estados híbridos

Los modos de ahorro energético introducen ambigüedad en la escena. En una suspensión convencional ciertos datos pueden permanecer en memoria mientras el sistema dispone de energía; la hibernación puede trasladar parte del estado al almacenamiento; los mecanismos modernos de suspensión conectada pueden mantener actividades de red y sincronización. La configuración exacta depende del hardware, del sistema operativo y de sus políticas. Una pantalla cerrada no permite inferir por sí sola el modo utilizado.

Manipular la tapa, el teclado, el ratón o el botón de encendido puede reactivar el equipo y modificar su estado. Por eso, cuando no existe urgencia ni riesgo inmediato, conviene documentar los indicadores visibles y consultar el procedimiento específico del laboratorio antes de actuar. Puede ser necesario conocer el modelo y las políticas de energía del dispositivo

para valorar si una desconexión hace perder información. La incertidumbre sobre el estado debe reconocerse, no resolverse mediante un gesto automático.

La hibernación también puede dejar artefactos en disco que contengan información procedente de memoria, pero su existencia y utilidad no deben darse por supuestas. Hay sistemas que cifran ese material, sistemas que lo sobrescriben y configuraciones que lo eliminan. La posibilidad de recuperar información debe analizarse de acuerdo con el soporte, la versión del sistema y las acciones previas.

4.3.6. Equipos apagados: preservar antes de arrancar

Cuando un dispositivo está apagado y no existe una razón fundada para iniciar su funcionamiento, suele ser prudente **mantenerlo en ese estado** hasta realizar una adquisición planificada. No se trata de una regla absoluta, sino de una medida para evitar cambios innecesarios. Encender un ordenador para «mirar qué contiene» puede alterar registros, actualizar bases de datos, iniciar tareas programadas, conectarse a redes, montar volúmenes y reconfigurar servicios. Tales cambios dificultan distinguir la actividad anterior de la generada por la investigación.

La intervención fuera de línea puede incluir la retirada del soporte de almacenamiento o el uso de un entorno de adquisición controlado, siempre que el hardware y las autorizaciones lo permitan. Un bloqueador de escritura puede reducir el riesgo de modificaciones durante el acceso a ciertos soportes, pero su eficacia depende del tipo de interfaz, del dispositivo y de que se utilice correctamente. El profesional debe conocer los casos que no cubre; los bloqueadores no constituyen una garantía abstracta aplicable por igual a cualquier SSD, dispositivo integrado o servicio remoto.

Hay sistemas donde extraer el soporte es difícil, arriesgado o innecesario. Muchos portátiles modernos incorporan almacenamiento soldado, elementos de seguridad integrados o cifrado vinculado al hardware. Algunos servidores necesitan controladoras y configuraciones específicas para interpretar correctamente un conjunto de discos. En estos escenarios la adquisición lógica, la exportación mediante herramientas del fabricante o la captura desde un hipervisor pueden ser alternativas justificadas. Cada una representa una clase diferente de evidencia y debe describirse como tal.

La evidencia física también puede incluir huellas, trazas biológicas, restos materiales o indicios de manipulación del hardware. Abrir una carcasa sin coordinarse con otros especialistas puede destruir esas fuentes. Las recomendaciones forenses digitales no eliminan las exigencias de otras disciplinas; el orden de intervención debe acordarse cuando varias especialidades comparten el objeto.

4.3.7. Apagado ordenado frente a retirada de alimentación

La distinción entre un apagado normal del sistema y una interrupción súbita de alimentación suele aparecer en los manuales clásicos. Un apagado ordenado puede cerrar sesiones, registrar eventos, limpiar áreas temporales y activar procedimientos de eliminación o sincronización. Una retirada súbita de alimentación puede impedir algunas de esas operaciones, pero también puede ocasionar daños, corrupción o pérdida de datos pendientes de escritura. Ninguna de las dos opciones es universalmente preferible.

Las características actuales complican más el problema. Los sistemas de archivos emplean diarios y mecanismos de recuperación; las controladoras de SSD realizan operaciones internas; las baterías mantienen la alimentación de portátiles; ciertas fuentes están respaldadas por sistemas de alimentación ininterrumpida; y algunos servidores ofrecen mecanismos de gestión remota. Desconectar un cable no siempre provoca el efecto que se supone. Antes de adoptar una medida irreversible hay que comprender qué se apaga realmente y qué consecuencias puede tener.

En contextos corporativos el equipo de respuesta puede necesitar detener un proceso destructivo de inmediato. Esa necesidad operativa se documenta y coordina. En una intervención pericial en la que no existe una amenaza activa, normalmente habrá más margen para analizar opciones de conservación. El objetivo no es defender una técnica por tradición, sino justificar por qué se eligió el curso de actuación menos perjudicial para los fines legítimos del caso.

4.3.8. Dispositivos móviles: conectividad, bloqueo y alimentación

Los teléfonos plantean una combinación singular de volatilidad, cifrado, conectividad y control remoto. Pueden recibir órdenes, borrar o sincronizar contenidos y cambiar su estado mientras permanecen aparentemente inactivos. El estado de encendido, la pantalla bloqueada, la presencia de una sesión reciente y el nivel de batería condicionan las oportunidades de adquisición. Sin embargo, interactuar con un dispositivo puede modificar datos, exigir autenticación o activar mecanismos de seguridad. Por ello, el primer interviniente debe aplicar un procedimiento específico y, cuando sea posible, contar con personal competente en análisis móvil.

La **aislación radioeléctrica** suele evaluarse para reducir comunicaciones que alteren la evidencia. Puede realizarse mediante mecanismos de configuración autorizados o con dispositivos de apantallamiento apropiados. Ninguna solución debe suponerse perfecta sin verificarla: el modo avión puede no deshabilitar todas las radios según modelo y configuración, y una bolsa Faraday defectuosa o mal cerrada puede permitir comunicaciones. La pérdida

de cobertura puede hacer que el teléfono aumente su actividad de búsqueda de red y consuma más batería. Además, una bolsa con alimentación externa puede requerir un diseño específico para evitar que el cable actúe como vía de comunicación o antena.

Si el dispositivo está apagado, encenderlo puede modificar sustancialmente su estado de seguridad y debe evitarse salvo decisión técnicamente fundada y autorizada. Si permanece encendido, apagarlo puede impedir una extracción posterior de determinados datos. Estas decisiones no pueden reducirse a «todos los teléfonos encendidos se dejan encendidos» o «todos se colocan en modo avión». El profesional debe evaluar el modelo, el estado, los riesgos, las capacidades disponibles y la preservación de la cadena de custodia. Las guías móviles de NIST y SWGDE aportan criterios, pero las tecnologías cambian con rapidez y obligan a mantener actualizados los procedimientos.

Las baterías de litio añaden un problema de seguridad física. Un dispositivo hinchado, perforado, caliente o dañado no debe tratarse como un objeto inocuo que puede cargarse o introducirse en un contenedor cerrado sin más. Las medidas de seguridad, embalaje y transporte adecuadas al estado de la batería pueden prevalecer sobre la conservación electrónica inmediata. Si el equipo necesita seguir alimentado, ha de elegirse una solución segura y supervisada, evitando improvisaciones con cargadores y cables.

4.3.9. Virtualización, contenedores y servicios remotos

En una escena virtual no siempre existe un objeto físico identificable como «el ordenador». Una instancia puede depender de varios discos virtuales, instantáneas, capas de almacenamiento, redes lógicas y servicios de identidad. Suspender, apagar, migrar o tomar una instantánea puede tener efectos diferentes sobre memoria y disco. El analista debe conocer qué captura realmente la operación, qué metadatos aporta, si requiere pausar la máquina y qué registros genera en el plano de administración.

Una instantánea de volumen en un servicio cloud puede representar un estado del almacenamiento, pero no proporcionar una captura de memoria ni garantizar por sí sola la consistencia de una aplicación con escrituras en curso. Una instantánea de máquina virtual puede contener memoria en determinadas configuraciones o no incluirla en otras. Los contenedores suelen tener capas efímeras cuya desaparición depende del ciclo de vida del orquestador. Destruir y recrear un contenedor para «limpiar» la infraestructura puede hacer perder procesos, archivos temporales y metadatos de ejecución.

El análisis de estos sistemas requiere coordinar registros del hipervisor o plano de control, datos de la máquina invitada, redes virtuales, almacenamiento, APIs y bitácoras de administración. La adquisición puede hacerse sin intervención física, pero eso no reduce la im-

portancia de la cadena de custodia: debe quedar claro quién exportó qué recurso, con qué identidad, en qué región, bajo qué filtros y a qué destino. Si el proveedor entrega archivos ya preparados, habrá que conservar el paquete original de entrega, sus metadatos y las condiciones de generación.

4.3.10. Sistemas críticos y dispositivos especializados

La intervención sobre un NAS, un equipo industrial, un grabador de videovigilancia o un dispositivo embebido puede exigir conocimientos ajenos a la informática de escritorio. Un NAS con varios discos no se comprende examinando cada unidad como si fuera independiente: puede utilizar RAID, sistemas de archivos distribuidos, cifrado o snapshots. Extraer discos sin registrar posiciones, bahías, controladora y estado de la matriz puede dificultar la reconstrucción. En un grabador de vídeo, desconectar la alimentación puede interrumpir la grabación y provocar una pérdida o una inconsistencia; en ciertos casos la exportación controlada de un intervalo debe valorarse antes de intervenir sobre el hardware.

Los sistemas industriales y sanitarios requieren coordinación operativa para evitar daños a personas y procesos. Puede ser más seguro preservar registros de un concentrador, capturas pasivas de red o historiales del sistema de supervisión que manipular un controlador en funcionamiento. En dispositivos IoT, sensores y equipos emparejados, parte de la evidencia puede estar fuera del dispositivo: plataforma cloud, aplicación móvil, router o concentrador. La escena incluye esas dependencias y no únicamente el objeto encontrado.

4.3.11. Matriz de decisiones para la primera intervención

La siguiente tabla no constituye un algoritmo obligatorio. Expone preguntas que orientan una decisión documentada; la técnica concreta depende del caso.

Estado o contexto	Riesgo relevante	Oportunidad de conservación	Precaución metodológica
Equipo encendido, sin amenaza activa aparente	Alteración por procesos y por herramientas	Datos volátiles, sesiones, volúmenes montados	Evaluar captura en vivo y sus efectos antes de intervenir

Estado o contexto	Riesgo relevante	Oportunidad de conservación	Precaución metodológica
Equipo encendido con actividad destructiva	Pérdida de datos y propagación	Memoria, eventos remotos, conexiones	Coordinar contención y preservación; justificar las prioridades
Equipo apagado	Pérdida previa de estado volátil	Adquisición controlada de almacenamiento	No arrancar solo para inspeccionar; valorar cifrado y hardware
Portátil suspendido	Reanudación involuntaria o pérdida de estado	Posible información de sesión	Documentar indicadores; no inferir el estado solo por la pantalla
Teléfono encendido	Borrado remoto, comunicaciones, batería	Estado accesible y datos transitorios	Aislamiento y energía conforme a procedimiento especializado
Máquina virtual activa	Pérdida de memoria y artefactos efímeros	Captura desde host o plano de control	Verificar alcance real de snapshots y consistencia
Infraestructura crítica	Riesgos para seguridad y servicio	Telemetría externa y registros de control	Coordinar con responsables y no improvisar paradas

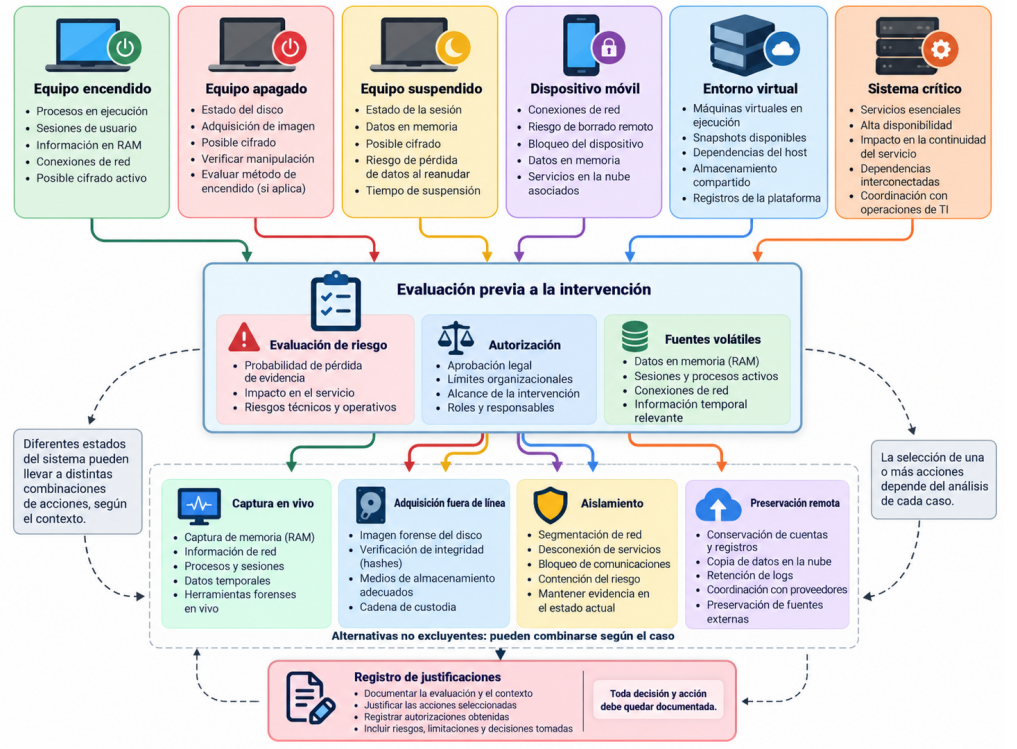


Figura 20: Diagrama de decisión

4.3.12. Registro ilustrativo de una intervención en vivo

Una bitácora breve, ficticia, ayuda a comprender qué nivel de precisión se necesita. No es una receta de comandos ni supone que las técnicas resulten apropiadas para cualquier sistema.

Hora local	Actuación documentada	Motivo o efecto observado
10:02:14 CEST	Se inicia la inspección de la estación E03 sin interacción con teclado	Pantalla bloqueada; alimentación y Ethernet presentes
10:04:32 CEST	Se comprueba la autorización para adquirir memoria y datos volátiles	Alcance confirmado por el responsable designado

Hora local	Actuación documentada	Motivo o efecto observado
10:07:05 CEST	Se conecta el soporte de adquisición A-USB-04	La conexión puede generar eventos del sistema; se registra el identificador
10:08:11 CEST	Comienza la captura de memoria mediante herramienta validada, versión consignada en la ficha técnica	Estado dinámico; se documentan duración y posibles efectos
10:15:48 CEST	Finaliza la captura; se anotan mensajes y errores	Un área no pudo leerse; se conserva el registro íntegro
10:17:20 CEST	Se calcula SHA-256 del archivo resultante en el destino	Fijación de una referencia de integridad de esa copia
10:20:03 CEST	Se transfiere el archivo al repositorio autorizado	Se registra responsable, destino y verificación posterior

Los tiempos son ilustrativos. No debe deducirse de ellos que la captura de memoria siempre dure varios minutos ni que las mismas herramientas puedan utilizarse en todos los equipos. La bitácora muestra algo más importante: **la trazabilidad de la intervención importa tanto como el archivo obtenido**. Una extracción sin errores aparentes puede ser cuestionable si no se sabe qué sistema se examinó, en qué estado, con qué versión de herramienta y mediante qué método.

4.4. Orden de volatilidad y conservación de evidencias

4.4.1. La volatilidad es una propiedad de la información en su contexto

El **orden de volatilidad** expresa la idea de que ciertas fuentes pueden desaparecer antes que otras y, por tanto, requieren una atención temporal diferente. Se usa con frecuencia para explicar por qué conviene considerar conexiones, memoria y sesiones antes que determinados datos persistentes. Pero no debe confundirse con una clasificación rígida de dispositivos ni con un mandato de adquisición aplicable a cualquier incidente. Lo que importa no

es únicamente el tipo de soporte: importan las condiciones que pueden hacer desaparecer la información concreta.

Una sesión en memoria puede terminar en segundos; un registro de seguridad puede conservarse durante meses; un disco puede fallar de manera inminente; una instancia cloud puede destruirse automáticamente al cabo de cinco minutos; y un proveedor puede purgar un conjunto de eventos cuando finaliza un plazo contractual. La memoria suele ser volátil, pero también puede estar disponible mediante una captura suspendida; un archivo suele ser persistente, pero puede residir en una capa efímera de contenedor. La volatilidad describe **riesgo de pérdida**, no una etiqueta permanente del objeto.

NIST SP 800-86 presenta un ejemplo de priorización de datos volátiles de sistemas operativos que incluye conexiones de red, sesiones de inicio, contenido de memoria, procesos, archivos abiertos, configuración de red y hora del sistema. Es una guía útil para comprender que los estados desaparecen de formas distintas. Sin embargo, no debe aplicarse como una secuencia mecánica. En un equipo cifrado, el estado del volumen montado puede condicionar toda la intervención. En una infraestructura virtual, una instancia a punto de terminar exige atención inmediata a su memoria y almacenamiento efímero. En un incidente de ransomware activo, detener el daño puede resultar más urgente que completar una enumeración exhaustiva.

La decisión necesita una evaluación explícita de **relevancia, volatilidad, accesibilidad, riesgo y coste de intervención**. No toda fuente volátil es pertinente. Capturar la memoria de un sistema ajeno al incidente solo porque está encendido puede generar una enorme cantidad de datos privados y comprometer recursos sin aportar valor. A la inversa, preservar un registro remoto con retención de veinticuatro horas puede ser más importante que obtener inmediatamente un disco almacenado bajo control físico.

4.4.2. Una clasificación orientativa, no una escalera obligatoria

Puede resultar útil agrupar fuentes por la forma en que pierden información:

Familia de fuente	Mecanismo frecuente de pérdida	Pregunta de preservación
Sesiones y conexiones activas	Cierre, expiración, desconexión, cambio de estado	¿Existe una fuente externa que registre la sesión y sus atributos?

Familia de fuente	Mecanismo frecuente de pérdida	Pregunta de preservación
Memoria y procesos	Apagado, reinicio, reutilización de memoria, finalización de procesos	¿Puede capturarse de modo autorizado y con herramientas adecuadas?
Contenedores y recursos efímeros	Destrucción, reasignación, escalado, rotación automática	¿Qué datos residen fuera del volumen persistente?
Registros de corta retención	Rotación, límites de cuota, políticas de ciclo de vida	¿Cuándo se perderá la ventana investigada?
Colas y mensajes transitorios	Consumo, confirmación, caducidad	¿Hay una forma legítima de congelar o exportar su estado?
Almacenamiento de equipos	Sobrescritura, mantenimiento, TRIM, borrado, daño físico	¿Qué operaciones posteriores podrían modificarlo?
Instantáneas y copias históricas	Caducidad programada, consolidación, eliminación de versiones	¿Cuáles son la cobertura temporal y la política de retención?
Evidencias bajo custodia	Fallos de soporte, acceso no autorizado, corrupción, pérdida de claves	¿Existen copias verificadas y controles duraderos?

La posición de una fuente en una tabla orientativa no establece automáticamente su prioridad. Un registro guardado durante una hora puede ser más urgente que una conexión cuya información ya quedó registrada por un sensor de red. Una copia histórica puede tener una fecha de eliminación más próxima que un fichero local. En determinados soportes SSD la conservación debe tener en cuenta procesos internos y borrado lógico, pero sería engañoso prometer recuperaciones basadas en un supuesto «tiempo fijo» antes de que ocurra TRIM: el comportamiento depende del sistema, la controladora, el estado del dispositivo y las operaciones posteriores.

Figura 21: Priorización de fuentes

4.4.3. Una priorización defendible se razona y se registra

En una escena con varias fuentes, el analista puede construir una matriz provisional. Para cada fuente se anotan su relación con las preguntas de investigación, el plazo estimado de disponibilidad, el grado de control sobre ella, las consecuencias de intervenir y la posibilidad de obtener una alternativa independiente. Una clasificación cualitativa —alta, media, baja o desconocida— puede ser suficiente; asignar valores numéricos aparentando una precisión científica inexistente resulta menos útil.

Por ejemplo, ante una intrusión en un servidor Linux alojado en una plataforma de virtualización, podría considerarse alta la urgencia de preservar memoria si existe una sesión sospechosa activa y una posible ejecución residente. También puede ser urgente exportar logs centralizados si rotan cada pocas horas. Una copia de seguridad mensual conservada sin modificaciones puede tener menor urgencia inicial, aunque un valor probatorio enorme para comparar estados anteriores. El orden resultante no debe justificarse con la frase «se siguió el orden estándar», sino con las condiciones observadas.

El razonamiento cambia durante la intervención. Una sesión expira, una copia comienza a fallar o aparece un nuevo sistema en el que se han realizado las mismas conexiones. Debe

existir un mecanismo para revisar prioridades y, si cambia el alcance, obtener la autorización correspondiente. **La prioridad no es un permiso**. El riesgo de pérdida puede justificar la urgencia de solicitar una conservación, pero no habilita por sí mismo un acceso ajeno a las facultades del investigador.

4.4.4. La conservación comienza antes de la adquisición

Preservar datos puede significar medidas diferentes. En una estación, puede consistir en restringir alteraciones y preparar una adquisición controlada. En un servidor de registros, puede ser modificar de forma autorizada una política de rotación. En un servicio en la nube, puede requerir una solicitud al proveedor o la exportación de eventos antes de que desaparezcan. En una base de datos, puede ser necesaria una copia consistente con mecanismos propios del motor. En un dispositivo móvil, puede exigir gestionar alimentación y comunicaciones de forma especializada.

No existe un método único para «congelar» todos esos estados. Además, algunas medidas de conservación **también modifican metadatos y generan eventos**. Al activar una retención ampliada, una exportación o una suspensión de tareas se crean registros administrativos y puede cambiar el comportamiento normal del sistema. Tales modificaciones no deberían ocultarse. En determinados casos es preferible documentar con precisión una operación necesaria que pretender una ausencia absoluta de cambios imposible de conseguir.

La conservación tiene también una dimensión temporal. Si se solicita a un proveedor que retenga determinados registros, el equipo debe verificar que la solicitud fue recibida, qué datos comprende, desde cuándo se aplica y hasta cuándo permanece vigente. No debe confundirse la aceptación de una petición con la confirmación de que la información existía o ha sido efectivamente conservada. Una orden de preservación puede llegar después de que una rotación haya eliminado registros y no recuperarlos mágicamente.

4.4.5. Integridad: qué demuestra y qué no demuestra un hash

Los valores hash criptográficos desempeñan un papel esencial en la verificación de integridad de archivos e imágenes forenses. Un algoritmo como SHA-256 produce un resumen calculado sobre una secuencia concreta de bytes. Si posteriormente se calcula el hash sobre esa misma secuencia y el resultado coincide, existe una fuerte base técnica para afirmar que el contenido no ha cambiado entre verificaciones, bajo las propiedades del algoritmo utilizado.

No obstante, un hash **no demuestra de manera autónoma** quién creó el archivo, que su contenido sea verdadero, que proceda de una fuente legítima ni que la adquisición incluyera todos los datos potencialmente accesibles. Un archivo manipulado antes de la recogida tendrá un hash perfectamente válido. Una exportación incompleta de registros puede conservarse sin modificación y seguir siendo incompleta. La integridad es un requisito importante, pero no equivale a autenticidad de origen, exhaustividad o interpretación correcta.

Es fundamental identificar **sobre qué objeto exacto se calculó** el resumen: flujo leído del dispositivo, archivo de imagen en bruto, contenido lógico adquirido, contenedor forense, cada segmento del contenedor o conjunto empaquetado por un proveedor. Dos herramientas pueden generar contenedores diferentes a partir del mismo flujo de datos; sus hashes de archivo no coincidirán necesariamente, aunque los datos contenidos puedan corresponder. Los metadatos añadidos a un contenedor también forman parte de sus bytes. Por ello las fichas de adquisición deben distinguir hashes del contenido adquirido de hashes calculados sobre archivos de almacenamiento o entrega.

En la práctica, puede ser útil disponer de un valor calculado durante la adquisición y una verificación posterior sobre la imagen, cuando el procedimiento y el formato lo permitan. La documentación debe indicar algoritmo, fecha, herramienta, objeto de cálculo y resultado. En adquisiciones lógicas o sistemas activos quizá no exista una referencia estable del origen con la que comparar el resultado. Se debe explicar entonces qué se verificó realmente y conservar los registros de la operación. El valor hash sirve como control verificable, no como sustituto del procedimiento.

4.4.6. Errores de lectura, datos inaccesibles y alcance real

La adquisición forense rara vez constituye un proceso perfecto en todos los entornos. Un disco puede contener sectores defectuosos; una controladora puede impedir leer áreas protegidas; una interfaz lógica puede omitir archivos; una API puede limitar resultados; un teléfono puede restringir determinadas bases de datos; un motor de bases de datos puede ofrecer una exportación consistente solo bajo ciertas condiciones. La descripción «imagen completa» debe utilizarse con cautela cuando existen regiones inaccesibles o errores.

Los errores deben registrarse y evaluarse, no ocultarse para presentar la adquisición como exitosa. Si una herramienta informa de bloques no leídos, se conserva su registro y se identifica, en la medida de lo posible, qué parte de los datos puede estar afectada. La coincidencia posterior del hash del archivo adquirido no elimina los sectores que no pudieron capturarse. Si una adquisición se repite, los resultados pueden diferir por cambios de la fuente o por correcciones de lectura; esos hechos requieren interpretación.

El objetivo profesional no consiste en prometer una adquisición perfecta, sino en ofrecer un resultado **con alcance conocido y límites expresos**. Un conjunto parcial puede responder de forma fiable a una pregunta específica. Una copia técnicamente impecable puede ser insuficiente para otra. La decisión de continuar con una adquisición dañada o intentar técnicas adicionales deberá ponderar el riesgo de deterioro, el valor esperado y las posibilidades disponibles.

4.4.7. Conservación de la procedencia de exportaciones y registros

En sistemas remotos y aplicaciones corporativas, buena parte de la evidencia llega como CSV, JSON, PDF, paquetes ZIP o resultados de API. Esos formatos son útiles, pero su procedencia debe quedar acreditada. Un CSV de eventos sin información sobre filtros, zona horaria, columnas omitidas o cuenta de exportación puede ser difícil de interpretar. Una captura de pantalla puede demostrar lo que mostraba una interfaz, pero no reemplaza los registros subyacentes ni permite inferir necesariamente su exhaustividad.

Una adquisición de registros bien documentada conserva, cuando resulte posible, la **consulta**, el **intervalo temporal**, la **identidad y permisos usados**, el **formato de salida**, la **cantidad de registros**, los **controles de paginación**, los **mensajes de error** y los **identificadores de la solicitud**. Si el servicio ofrece metadatos de generación del paquete, se preservan junto a los archivos. Si se realiza una transformación posterior —normalización de hora, conversión de JSON a CSV, descompresión, eliminación de duplicados—, se genera un resultado derivado y se conserva la fuente original.

Una prueba de integridad no evita que las marcas temporales sean erróneas. Un registro puede expresar una hora local sin zona, una marca UTC correcta o una marca procedente de un reloj desfasado. Durante la recogida conviene registrar la referencia temporal utilizada y cualquier desviación conocida. Convertir todos los tiempos a UTC para el análisis suele facilitar la correlación, pero exige conservar el valor original y explicar la transformación. No debe «corregirse» una hora editando silenciosamente el registro fuente.

4.4.8. Reglas de retención y preservación extraordinaria

El almacenamiento indefinido no es sinónimo de buena conservación. Las evidencias pueden contener información personal, secretos comerciales y datos altamente sensibles. Su retención debe responder al fundamento y la finalidad del caso, a las obligaciones aplicables y a los procedimientos establecidos. Una organización puede conservar registros ordinarios

durante un plazo determinado y necesitar una retención extraordinaria para una investigación concreta. Esa decisión debe autorizarse, delimitarse, registrarse y revisarse periódicamente.

La conservación extraordinaria, en ocasiones denominada *legal hold* en entornos corporativos, busca evitar que una política rutinaria elimine información relevante. Debe especificar qué fuentes se incluyen, qué intervalo cubre, quién autoriza la medida, cómo se verifica su aplicación y bajo qué condiciones termina. No es una habilitación indiscriminada para examinar todos los contenidos preservados; conservación y acceso mantienen requisitos diferentes.

Una política madura evita dos extremos: perder información relevante porque nadie suspendió una rotación conocida y conservar sin límite copias de todos los dispositivos por mera prudencia. El equilibrio requiere colaboración entre seguridad, asesoría jurídica, protección de datos, responsables de infraestructura y laboratorio. La trazabilidad de las decisiones permite explicar por qué un dato se preservó, por qué se excluyó otro y cuándo se devolvió o eliminó una copia.

4.4.9. El efecto de una intervención previa a la llegada del perito

Muchas escenas se reciben después de decisiones operativas adoptadas por terceros. Un técnico ha reiniciado un servidor, un usuario ha cambiado su contraseña, el sistema EDR ha puesto en cuarentena un fichero o el proveedor ha bloqueado una cuenta. No es razonable exigir que toda organización se abstenga de protegerse hasta disponer de un analista forense. Pero es necesario reconstruir las modificaciones para interpretar correctamente la evidencia.

El perito debe obtener los registros y testimonios técnicos de esas actuaciones, separar los hechos conocidos de los comunicados y valorar qué fuentes se perdieron. Si se sabe que una máquina fue reiniciada, la ausencia de determinadas conexiones en la memoria recogida después no permite afirmar que nunca existieron. Si una aplicación fue actualizada durante la respuesta, parte de sus archivos y marcas temporales podrían proceder del mantenimiento. La cronología de la intervención forma parte de la cronología del caso, pero ambas deben diferenciarse.

En consecuencia, la preservación eficaz requiere **forensic readiness**: procedimientos previos, registros de cambios, sincronización de relojes, capacidad de exportación, responsables designados y formación básica para los primeros intervinientes. Un entorno preparado no evita todas las pérdidas, pero reduce las decisiones improvisadas y facilita distinguir los efectos del incidente de los efectos de la respuesta.

4.5. Cadena de custodia, embalaje y almacenamiento

4.5.1. Custodia significa continuidad demostrable, no una firma aislada

La **cadena de custodia** puede describirse como el registro continuo y verificable de las personas, lugares, estados y actuaciones que afectan a una evidencia desde su identificación o recogida hasta su destino final. Su finalidad es que un tercero pueda reconstruir quién tuvo control sobre un elemento, durante qué intervalo, con qué motivo, en qué condiciones y mediante qué transferencias. La terminología y las consecuencias procesales concretas dependen de la jurisdicción y del contexto; no debe confundirse una práctica técnica de trazabilidad con un dictamen jurídico sobre admisibilidad.

En la práctica es frecuente reducir la custodia a una hoja con nombres y firmas. Ese registro puede ser necesario, pero no resulta suficiente si no permite identificar el objeto o relacionar una entrega con un estado verificable. Una sucesión de firmas sobre «un ordenador portátil» carece de fuerza descriptiva cuando había tres portátiles idénticos en la escena. Tampoco basta con conocer quién transportó un disco si no se registró cómo se embaló, qué precinto utilizaba, dónde se almacenó y quién pudo acceder a él.

La cadena debe integrarse con inventario, fotografías, bitácora, registros de adquisición y controles de integridad. Cada componente responde a una pregunta. El inventario permite saber **qué** es el objeto. La documentación de la escena indica **dónde y en qué estado** se encontró. La cadena de custodia muestra **quién lo controló y cuándo**. La bitácora técnica describe **qué operaciones** se realizaron. Los hashes de copias digitales ayudan a comprobar **qué contenido** permaneció inalterado. Ninguno sustituye a los demás.

La continuidad no exige necesariamente que una sola persona supervise físicamente el objeto las veinticuatro horas. Puede mantenerse mediante transferencias registradas, almacenes controlados, accesos auditados y procedimientos documentados. Lo decisivo es que no existan intervalos inexplicados de disponibilidad material o lógica relevantes para la evaluación del caso. Cuando se detecta una discontinuidad, la reacción profesional consiste en investigarla y documentarla, no en inventar una firma retrospectiva ni en ocultar la incidencia.

4.5.2. Inicio de la custodia y delimitación de responsabilidades

La custodia comienza cuando una persona u organización asume formalmente el control de una evidencia, de acuerdo con su procedimiento. En una intervención física puede iniciarse

en el momento de recogida. En una exportación remota puede comenzar cuando el laboratorio recibe y fija una copia, aunque la fuente original siga bajo administración del proveedor. Es imprescindible dejar claro qué control se ejercía y sobre qué objeto.

Si un proveedor entrega un archivo ZIP con registros de actividad, el analista puede custodiar la **copia recibida**, documentando el canal de entrega y sus verificaciones. Esa cadena no acredita por sí misma lo ocurrido en los sistemas internos del proveedor antes de generar el paquete. Para conocer ese tramo pueden necesitarse declaraciones técnicas, metadatos de exportación, registros del servicio o documentación de sus procedimientos. Una cadena de custodia local no convierte automáticamente una exportación de tercero en una captura íntegra de origen conocido.

La responsabilidad debe asignarse de forma expresa. El interviniente que recoge la evidencia responde de las actuaciones que realiza; quien la transporta debe mantener las condiciones previstas; el custodio del laboratorio controla el acceso y el almacenamiento; el analista documenta las operaciones de examen; el destinatario final debe dejar constancia de la recepción. Las funciones pueden coincidir en una persona en casos pequeños, pero no desaparecen por ello las necesidades de registro y separación de operaciones.

La custodia también tiene un componente institucional. Un técnico puede entregar un equipo a un depósito especializado sin que una persona concreta permanezca a su lado. En esa transferencia han de poder identificarse el centro receptor, las condiciones de admisión, la persona que acepta el objeto, la referencia del lugar de almacenamiento y los controles de acceso. La entrega a una instalación no significa que el equipo quede fuera del sistema de trazabilidad.

4.5.3. Transferencias: información mínima que debe acompañar al objeto

Toda transferencia relevante debería permitir responder, al menos, a estas preguntas: qué evidencia se entrega, quién la entrega, quién la recibe, cuándo ocurre, dónde ocurre, cuál es su finalidad y qué estado presenta. En soportes físicos se añaden condiciones de embalaje, numeración de precintos y anomalías. En archivos digitales se incluyen el mecanismo de transferencia, identificador del paquete o archivo, verificaciones de integridad y destino autorizado. No es necesario que todo se encuentre en una única hoja, siempre que la relación entre registros sea inequívoca.

Una tabla de ejemplo ayuda a visualizarlo:

Fecha y hora (zona)	Evidencia	Origen → destino	Motivo	Estado verificado	Referencia
21/10/2026 11:25 CEST	E03	Interviniente A → custodio B	Traslado a depósito	Embalaje P-006381 íntegro	TR-001
21/10/2026 13:04 CEST	E03	Custodio B → examinador C	Adquisición autorizada	Precinto íntegro antes de apertura	TR-002
21/10/2026 15:40 CEST	E03	Examinador C → custodio B	Devolución al depósito	Nuevo precinto P-006392	TR-003
21/10/2026 16:02 CEST	A01	Examinador C → repositorio seguro	Conservación de imagen	SHA-256 verificado; fichero identificado	TD-004

Los nombres genéricos, identificadores y horarios son ficticios. Lo esencial es advertir que el equipo físico `E03` y la imagen `A01` tienen historias relacionadas pero no idénticas. La apertura de un precinto no es una ruptura de custodia si la realiza la persona autorizada, en el procedimiento previsto y queda documentada, incluido el reemplazo del cierre. Un sello que aparece roto sin explicación, en cambio, constituye una incidencia que debe investigarse.

Las firmas manuscritas, electrónicas o los registros de un sistema de gestión pueden ayudar a atribuir cada transferencia, según el marco y las reglas aplicables. Ningún formato es inherentemente suficiente en cualquier escenario. Importan la identificación efectiva de la persona, la resistencia a alteraciones, la conservación del registro y la posibilidad de verificarlo después. Un formulario de papel puede ser sólido con control documental; una base de datos puede ser débil si cualquiera puede reescribir entradas sin auditoría.

4.5.4. Precintos, etiquetas y embalaje: controles físicos con objetivos concretos

El embalaje protege frente a daño, contaminación, pérdida, acceso indebido y condiciones ambientales incompatibles con la conservación. Debe seleccionarse según el dispositivo y el medio de transporte. Un disco duro, una placa electrónica, un teléfono, un servidor completo y una tarjeta de memoria no presentan los mismos riesgos. Tampoco todos requieren el mismo contenedor o pueden transportarse legalmente y con seguridad de igual manera.

Las etiquetas deberían permitir identificar el caso y la evidencia sin revelar información confidencial innecesaria a terceros. Un número de precinto registrado permite detectar determinadas aperturas, aunque no demuestra por sí solo que el objeto nunca haya sido manipulado. Los precintos son un **control de indicios de apertura**, no una garantía absoluta de inviolabilidad. Antes de mover o abrir un embalaje deben fotografiarse y registrarse su estado y cualquier anomalía visible.

En soportes electrónicos sensibles a descargas electrostáticas pueden utilizarse materiales antiestáticos apropiados. Sin embargo, no todos los materiales comercializados como «antiestáticos» son equivalentes ni adecuados para todos los dispositivos. La elección debe atender al tipo de soporte y a las recomendaciones del fabricante o del procedimiento del laboratorio. Las unidades magnéticas, la electrónica expuesta y los soportes ópticos tienen necesidades distintas de protección frente a impactos, humedad, presión y condiciones térmicas.

Es preferible proteger un disco duro contra golpes y vibraciones con un sistema apropiado a envolverlo indiscriminadamente en materiales que puedan generar electricidad estática o impedir disipar calor. Los dispositivos que permanecen encendidos generan calor y requieren ventilación y alimentación controladas. Los que incorporan baterías de litio deben observar precauciones específicas, especialmente si están dañados o muestran hinchazón. Una solución de apantallamiento radioeléctrico no sustituye las condiciones de seguridad de la batería ni las medidas contra sobrecalentamiento.

Para medios extraíbles de pequeño tamaño, una etiqueta adherida directamente al objeto puede resultar poco práctica o provocar daños. Puede ser más adecuado un contenedor individual identificado que conserve el soporte y evite mezclas. Cuando varios discos forman parte de una matriz, deben registrarse su orden de extracción, bahía de origen, cableado y asociación con controladoras o chasis. El inventario del conjunto y el de cada miembro cumplen funciones complementarias.

4.5.5. Particularidades del traslado de equipos activos

Transportar un dispositivo encendido puede ser necesario en algunas intervenciones especializadas, pero añade dificultades significativas: alimentación continua, calor, seguridad física, conexiones, vibraciones y posibilidad de apagado durante el trayecto. No debería convertirse en práctica habitual por miedo abstracto a perder una clave. Antes de decidirlo, deben evaluarse alternativas de adquisición en la escena, conservación remota o coordinación con laboratorio especializado.

En teléfonos y otros dispositivos de radio puede considerarse el apantallamiento, pero hay que comprobar la eficacia real de la solución y el estado energético. Un sistema que pierde conectividad puede incrementar el consumo tratando de encontrar la red. Si el nivel de batería cae hasta provocar apagado, la medida de aislamiento podría producir precisamente la pérdida que se pretendía evitar. La estrategia necesita considerar aislamiento, alimentación, ventilación y seguridad de forma conjunta.

Los equipos no deben transportarse conectados a redes ajenas o improvisadas si ello genera riesgos de acceso remoto o alteración. Tampoco debe suponerse que desactivar todas las comunicaciones sea técnicamente posible sin interactuar con el dispositivo. El procedimiento debe ser específico, estar respaldado por personal competente y dejar constancia de cualquier modificación de estado ocurrida durante el traslado.

4.5.6. Almacenamiento físico: seguridad y condiciones verificables

Una sala de evidencias necesita controles de acceso compatibles con el valor y sensibilidad de los objetos. Es importante saber quién está autorizado a entrar, cómo se registra cada entrada, qué ocurre fuera del horario habitual, cómo se separan los casos y quién puede retirar o devolver elementos. El nivel de seguridad depende de la organización y del procedimiento aplicable; una instalación policial, un laboratorio privado y una empresa pueden utilizar mecanismos diferentes sin renunciar a la trazabilidad.

El almacenamiento debe proteger frente a robo, manipulación, incendios, inundaciones, humedad, temperatura inadecuada y fallos de infraestructura. Algunos soportes deteriorados necesitan condiciones o manipulaciones especiales para no agravar daños. Un dispositivo con batería defectuosa puede requerir aislamiento físico de seguridad y supervisión distinta de la utilizada para discos externos en buen estado. Los protocolos de seguridad material tienen prioridad sobre una organización administrativa cómoda del depósito.

La conservación a largo plazo requiere revisar periódicamente el estado de los soportes. La vida útil de una unidad no está garantizada por permanecer apagada en una estantería. Los fallos de almacenamiento pueden surgir por envejecimiento, defectos de fabricación, pérdida de integridad de los medios o problemas de lectura posteriores. Mantener referencias de integridad y, cuando esté autorizado, copias de seguridad verificadas permite reducir la dependencia de un único soporte vulnerable.

Un depósito bien organizado ofrece registros de ubicación, ingresos, movimientos, responsables y controles. No es imprescindible utilizar tecnología compleja para ello, pero sí establecer responsabilidades inequívocas y auditar las desviaciones. La seguridad física no

termina cuando se cierra una puerta: incluye los procedimientos para abrirla, atender una emergencia, admitir un objeto nuevo y corregir un error de localización.

4.5.7. Custodia digital: repositorios, permisos y verificaciones

Las imágenes forenses y exportaciones pueden conservarse en un repositorio digital en lugar de circular como soportes físicos. La custodia sigue siendo necesaria. Se deben controlar identidades, roles, permisos, accesos, operaciones administrativas, copias, restauraciones, cambios de ubicación y eliminación. Una ruta de servidor escrita en un informe no demuestra quién pudo acceder al contenido ni si alguien lo modificó antes de la verificación.

Una arquitectura razonable distingue **copia de referencia**, **copia de trabajo** y **resultados derivados**. La copia de referencia se conserva con controles de escritura estrictos y un registro de integridad. Las copias de trabajo permiten ejecutar herramientas, crear índices y producir artefactos sin modificar la referencia. Los resultados derivados incluyen bases de datos de análisis, cronologías, exportaciones y documentos que deben relacionarse con la fuente de la que proceden. Esa separación facilita repetir el examen y analizar discrepancias.

El cifrado en reposo y en tránsito ayuda a proteger datos sensibles, pero introduce nuevas dependencias: claves, permisos de descifrado, caducidad de credenciales y procedimientos de recuperación. Una evidencia cifrada cuya clave se pierde puede permanecer intacta y, sin embargo, volverse inutilizable. La gestión de claves es, por tanto, parte de la preservación. Debe evitarse conservar contraseñas de repositorios junto a los soportes a los que protegen o compartir credenciales personales entre analistas.

Los controles de solo lectura, versionado, inmutabilidad lógica o almacenamiento de tipo WORM pueden aportar garantías adicionales. Deben comprenderse sus límites: un administrador con determinados privilegios quizá pueda cambiar políticas, eliminar cuentas o alterar configuraciones. Una etiqueta de «inmutable» no reemplaza la auditoría ni la revisión del diseño. Los sistemas cloud también dependen de contratos, regiones, identidades y procedimientos de exportación y recuperación. En todos los casos se debe conservar la evidencia de las operaciones administrativas relevantes.

4.5.8. El ciclo de vida de la copia y su historia técnica

Una cadena de custodia digital robusta no registra únicamente que un archivo se copió de un ordenador a otro. Debe permitir reconstruir la creación de la adquisición, su nombre y tamaño, los hashes calculados, los destinos, las verificaciones posteriores y las derivaciones

de análisis. Si se comprime un archivo, se genera un objeto distinto; si se descifra bajo autorización, se produce otro conjunto; si se extraen ficheros de un contenedor, los elementos resultantes tienen relaciones de procedencia que conviene conservar.

Es útil distinguir operaciones que cambian la **representación** de la información de operaciones que cambian su **contenido semántico**. Convertir una zona horaria para una cronología transforma la presentación temporal; convertir un registro JSON a CSV puede omitir tipos, estructura o campos si se realiza incorrectamente; reconstruir una base de datos puede crear vistas derivadas. Los resultados deben identificar herramienta, versión, parámetros y fuente. La integridad de una derivación no demuestra por sí misma que la transformación fuese correcta: para eso se necesitan validación y, cuando procede, reproducción independiente.

El uso de repositorios compartidos también exige evitar accesos que mezclen casos. Un índice de búsqueda construido con evidencias de investigaciones distintas puede provocar contaminación analítica y vulnerar confidencialidad. La segregación debe diseñarse desde el almacenamiento hasta las herramientas de procesamiento. El control de permisos debe aplicarse a copias temporales, archivos de intercambio y resultados intermedios, no solo a la carpeta etiquetada como «evidencias».

Figura 22: Ciclo de custodia de una evidencia física y sus derivados digitales

4.5.9. Incidentes de custodia y tratamiento de discrepancias

Una incidencia puede consistir en un precinto deteriorado, una fecha incorrecta, una unidad cuya identificación no coincide, una transferencia no firmada, un hash diferente al esperado o una restauración de copia sin registro. No todas tienen las mismas consecuencias. El profesional debe identificar qué se sabe, qué pudo cambiar y qué controles permiten delimitar el problema. La respuesta no debe confundirse con declarar automáticamente inútil toda la evidencia ni con minimizar la incidencia sin análisis.

Si falla una verificación hash, la primera obligación es detener operaciones que puedan agravar el problema, preservar los registros disponibles y comprobar que se están comparando realmente los mismos objetos y algoritmos. Podría haberse calculado un hash sobre el contenido de una imagen y otro sobre el contenedor, o haberse modificado un fichero. También podría existir corrupción. La discrepancia no se resuelve recalculando un nuevo hash y sustituyendo el anterior sin explicación. Debe conservarse el valor histórico, investigar la causa y registrar la decisión final.

Si un precinto se encuentra abierto al llegar al laboratorio, debe documentarse de inmediato su estado, quién lo recibió, las condiciones de embalaje y la ruta seguida. Las fotografías anteriores pueden ayudar a determinar si el defecto existía en origen. Cuando no sea posible reconstruir quién tuvo acceso, se debe expresar el límite. Una investigación puede conservar otras evidencias independientes que mantengan valor, pero no corresponde al analista inventar continuidad donde no puede demostrarla.

La confianza aumenta cuando los procedimientos prevén los errores. Un sistema que permite registrar incidencias, corregir fichas con historial y solicitar revisión por un segundo profesional resulta más fiable que otro donde todas las entradas aparecen perfectas porque las equivocaciones se borraron. La calidad se mide por la posibilidad de auditar las decisiones, no por la ausencia artificial de problemas.

4.5.10. Entrega, devolución, destrucción y cierre de custodia

El fin del análisis no implica necesariamente el fin de la custodia. Una evidencia puede permanecer sujeta a una investigación judicial, a una medida de conservación extraordinaria, a un procedimiento administrativo o a obligaciones contractuales. Su destino debe decidirse conforme al marco aplicable y quedar documentado. Las opciones pueden incluir devolución del objeto, traslado a otra autoridad, conservación temporal, eliminación autorizada de copias de trabajo o destrucción segura cuando proceda.

La entrega a un tercero debe precisar si se transfiere un soporte físico, una copia digital, un conjunto parcial de artefactos o un informe. Se registra el destinatario, el fundamento de la entrega, el canal, las medidas de protección y el resultado de la verificación de integridad. En una transferencia digital pueden utilizarse cifrado, canales autenticados y comprobaciones hash. Debe evitarse entregar por comodidad un volumen completo de información sensible cuando solo se requieren determinados elementos, siempre que la entrega parcial sea jurídicamente y técnicamente apropiada.

La devolución de un dispositivo puede requerir comprobar el estado del embalaje y los accesorios asociados. La destrucción de una copia puede necesitar un registro del procedimiento y del soporte afectado. En medios modernos, el borrado seguro debe adaptarse a las capacidades de la tecnología y no basarse en suposiciones sobre la eficacia de sobrescribir determinados sectores. Si existe una obligación de conservación vigente, destruir datos para liberar espacio constituye una decisión potencialmente grave; si el plazo ha expirado, conservarlos indefinidamente también puede ser improcedente.

Cerrar la custodia significa que la trayectoria de cada objeto tiene un destino conocido. Un informe técnicamente correcto acompañado por decenas de copias sin control es señal de un expediente todavía incompleto. La disciplina profesional comprende tanto la adquisición inicial como la disposición final.

4.5.11. La cadena de custodia no reemplaza la interpretación

Conviene insistir en un error recurrente. Una evidencia puede tener una cadena de custodia íntegra y, sin embargo, no demostrar el hecho que se pretende atribuirle. Un archivo con un nombre comprometedor puede haber sido creado automáticamente por una aplicación. Un registro de acceso asociado a una cuenta no prueba por sí solo quién utilizó esa identidad. Un hash idéntico confirma la estabilidad del archivo verificado, no la veracidad de todas sus afirmaciones.

La cadena permite confiar en que el material examinado corresponde al material conservado bajo determinadas condiciones. La interpretación requiere además métodos adecuados, contexto, hipótesis alternativas y corroboración. Ambas dimensiones son necesarias, pero resuelven preguntas distintas. Por eso las hojas de custodia deben permanecer vinculadas al análisis sin convertirse en un argumento retórico de certeza absoluta.

4.6. Caso integrador: aseguramiento de una escena híbrida tras una extracción de documentos

4.6.1. El encargo y las primeras noticias

Una empresa ficticia de ingeniería comunica que varios documentos de un proyecto reservado parecen haber sido descargados desde una cuenta corporativa fuera del horario habitual. El equipo de seguridad detecta un volumen anómalo de transferencias y avisa al responsable de cumplimiento. La organización solicita una investigación técnica limitada a determinar qué recursos se consultaron, desde qué contextos se produjo el acceso y qué fuentes deben conservarse para permitir una eventual revisión independiente. El caso es inventado; todos los identificadores, horas y resultados se incluyen únicamente con finalidad ilustrativa.

La cuenta afectada pertenece a una persona que utiliza un portátil corporativo, pero esa coincidencia no demuestra que la persona ejecutara la descarga. Es posible que se utilizaran credenciales comprometidas, tokens de sesión, automatizaciones autorizadas o integraciones de servicio. El equipo de investigación evita formular una acusación inicial. En su lugar define preguntas comprobables: qué operaciones se realizaron sobre los documentos, qué identidad registraron las plataformas, qué dispositivos o direcciones aparecen, qué mecanismos de autenticación intervinieron y si existe correlación con actividad local en el equipo.

El encargo escrito delimita el examen a una cuenta corporativa, un portátil concreto, los registros administrativos de las plataformas utilizadas y un intervalo temporal de tres días. Se establece quién puede autorizar ampliaciones y se designan responsables de seguridad, análisis, custodia y asesoría jurídica. El equipo acuerda que la contención operativa seguirá bajo responsabilidad de respuesta a incidentes y que sus actuaciones se comunicarán para poder distinguirlas de la actividad investigada.

La situación inicial no es estática. La cuenta ya fue bloqueada por seguridad; el proveedor de identidad mantiene registros durante una ventana limitada; el portátil está encendido y bloqueado; y la plataforma documental conserva versiones históricas de ciertos archivos. Un técnico informa de que reinició el agente EDR del portátil, aunque no el sistema operativo completo. Ese dato se documenta como declaración del técnico pendiente de contraste con registros, no como observación directa del perito.

4.6.2. Reconocimiento, fotografía y catálogo de fuentes

Al llegar al puesto de trabajo, el analista confirma el identificador del equipo con la ficha corporativa y comprueba los datos visibles de su carcasa. Fotografía la mesa, las conexiones y la pantalla bloqueada sin introducir credenciales. También localiza una memoria USB que

permanece conectada. En las notas se distinguen los hechos observados de la información declarada: la presencia física de la memoria está comprobada, pero no se sabe aún quién la conectó ni qué datos contiene.

Se abre un registro de escena con hora, zona horaria, personas presentes y alcance. El portátil recibe el identificador `AF-2026-028-E01`; la memoria USB, `AF-2026-028-E02`. Los registros de identidad obtenidos posteriormente se identificarán como adquisición `A03`, y la exportación de la aplicación documental como `A04`. Esta organización impide confundir elementos de naturalezas diferentes. Las fotografías generales, los detalles del equipo y el listado de conexiones se relacionan con `E01` y `E02` desde el inicio.

El inventario lógico revela que el sistema utiliza un proveedor de identidad, una aplicación SaaS y una solución centralizada de seguridad. La memoria del portátil podría contener información de sesión, pero el sistema presenta cifrado de disco y un estado de bloqueo que exige evaluar cuidadosamente la intervención. El analista no intenta desbloquearlo ni utiliza credenciales que no se le hayan autorizado. Solicita confirmación expresa del alcance técnico previsto y verifica que existen herramientas y personal adecuados para la posible captura de memoria.

En paralelo, el responsable de seguridad conserva las configuraciones de las acciones de contención ya ejecutadas: bloqueo de cuenta, revocación de sesiones y cambio de una regla de acceso condicional. Esas operaciones pueden alterar el estado de las sesiones y generar nuevos registros. Por ello su cronología se archiva separadamente de los eventos investigados, aunque más adelante ambas líneas temporales deberán correlacionarse.

4.6.3. La priorización cambia el orden intuitivo

La proximidad física sugiere ocuparse primero del portátil. Sin embargo, el proveedor de identidad conserva determinada telemetría detallada durante menos tiempo que el almacenamiento documental, y un administrador confirma que la ventana investigada está próxima al límite de retención. El equipo decide gestionar primero la preservación autorizada de esos registros, mientras otro interviniente mantiene el control de la escena física. La medida no implica examinar información de nuevas cuentas ni ampliar los permisos de manera indiscriminada.

Para la exportación de registros se documentan usuario o identidad administrativa utilizada, permisos, intervalo, zona horaria, filtros, formato, número de entradas y advertencias de la herramienta. El archivo se recibe en un destino controlado, se calcula su SHA-256 y se conserva como referencia. Se crea una copia separada para examen. Como el servicio admite paginación, se comprueba que todas las páginas previstas fueron recuperadas y se registra

cualquier limitación de la API. El hash prueba la estabilidad del fichero exportado, no que el proveedor conservara absolutamente todos los eventos desde el inicio del incidente.

A continuación se evalúa la posible adquisición en vivo del portátil. La autorización incluye memoria y datos operativos vinculados al incidente, con limitaciones de uso de información incidental. El examen deberá minimizar alteraciones y registrar las operaciones ejecutadas. Un especialista verifica previamente la herramienta y acuerda el destino seguro de la captura. Se mantiene la distinción entre lo que la herramienta puede obtener y lo que el analista está facultado para examinar.

La unidad USB constituye otra posible fuente, pero no existe una relación probada con la descarga. Se decide recogerla bajo el alcance autorizado y examinarla mediante un procedimiento posterior, sin asumir que su mera presencia implica exfiltración. El equipo documenta el puerto de conexión, los identificadores visibles y el momento de retirada. Su estudio permitirá contrastar hipótesis, no confirmar automáticamente la sospecha inicial.

4.6.4. Adquisición, embalaje y traslado

Durante la captura de información volátil se generan registros de herramienta y se conserva la secuencia de actuaciones. El proceso informa de que una zona protegida no pudo leerse. La incidencia se documenta y no se presenta la captura como absolutamente completa. Se calculan y registran hashes de los archivos resultantes, identificando qué objeto representa cada valor. También se anotan los tiempos de inicio y finalización y la diferencia entre esos momentos y la hora que mostraba el equipo cuando se observó, sin dar por supuesta la precisión de ninguno de los relojes.

Tras completar las operaciones autorizadas en vivo, el equipo debe decidir cómo preservar el soporte persistente. La política técnica permite una adquisición planificada en laboratorio; por ello documenta los pasos de preparación y gestiona el traslado del portátil. La decisión de apagado o conservación del estado no se resuelve por una instrucción genérica, sino por la combinación de cifrado, disponibilidad de mecanismos de adquisición y riesgo operativo. El procedimiento concreto y su justificación quedan en la bitácora.

El portátil se identifica, embala y precinta. La memoria USB se conserva en un contenedor individual, también identificado, para evitar que dos objetos se mezclen. La persona que recoge las evidencias transfiere su control al responsable del transporte. Se registran identificadores, precintos, estado aparente, hora y lugar. El laboratorio verifica esos datos al recibirlos. Una discrepancia entre el número de precinto consignado en una ficha y el observado físicamente se trata como incidencia y se resuelve mediante las fotografías y registros disponibles, sin modificar silenciosamente la anotación original.

En el laboratorio se crea la adquisición del almacenamiento conforme al método elegido y se conserva la información sobre errores, herramienta, versión, configuración y verificaciones. La copia de referencia se almacena con acceso restringido, mientras el análisis se realiza sobre derivados autorizados. La entrada al repositorio, la creación de las copias de trabajo y sus referencias de integridad quedan auditadas. De esta forma, un revisor podrá seguir la procedencia de un artefacto citado desde el informe hasta el origen que lo produjo.

4.6.5. Correlación y límites de la atribución

El examen posterior permite reconstruir un conjunto de operaciones: el proveedor de identidad registra autenticaciones de la cuenta, la aplicación documental registra descargas y el sistema local conserva algunos artefactos compatibles con actividad del navegador. Los registros externos muestran una dirección IP vinculada a las solicitudes. Sin embargo, ninguno de esos datos identifica por sí solo a la persona sentada ante el portátil. La IP puede corresponder a un acceso compartido o a una conexión mediante proxy, los tokens pueden reutilizarse y los registros de aplicación pueden documentar la identidad lógica sin acreditar una presencia física.

La investigación incorpora explicaciones alternativas. Una hipótesis sostiene que el usuario legítimo descargó los documentos. Otra plantea el uso de credenciales por un tercero. Una tercera considera una integración automatizada cuya configuración fue modificada. Cada hipótesis exige observaciones distintas: telemetría de autenticación, identificadores de dispositivo, actividad local, ejecución de procesos, permisos de aplicaciones y operaciones de servicio. La conclusión debe reflejar qué explicaciones fueron corroboradas, cuáles quedaron debilitadas y cuáles no pudieron evaluarse por falta de datos.

Además, la captura parcial de memoria impide afirmar que se observaron todos los procesos que pudieron estar presentes. La ausencia de un programa concreto en el volcado no demuestra que nunca se ejecutara. El equipo cita esa limitación junto con la posible diferencia temporal entre la captura, los registros de la aplicación y los eventos centralizados. El informe distingue hechos técnicos documentados de atribuciones personales que requerirían otras fuentes y, en su caso, otra clase de investigación.

En este punto aparece una nueva fuente: un teléfono personal presuntamente vinculado a la autenticación multifactor. El hecho de que pudiera aportar información no significa que el equipo pueda intervenirlo. La fuente se comunica al responsable, se registra la necesidad de valorar una ampliación y no se examina hasta resolver las cuestiones de legitimidad, necesidad y proporcionalidad. El procedimiento no obstaculiza la investigación; evita que una conclusión técnicamente atractiva se obtenga mediante una intervención fuera de alcance.

4.6.6. El expediente final como historia verificable

El caso no se cierra con una carpeta denominada «pruebas» y varias capturas de pantalla. El expediente conserva autorización, inventario, fotografías, registros de contención previa, bitácoras, fichas de adquisición, logs de herramientas, hashes, cadena de custodia, incidencias y resultados. Cada hallazgo relevante remite a la fuente y al procedimiento que permitió obtenerlo. Los documentos originales se preservan en sus formatos, mientras que las conversiones utilizadas para la cronología se identifican como productos derivados.

El laboratorio comunica sus conclusiones dentro del alcance acordado y distingue las preguntas respondidas de aquellas que permanecen abiertas. Puede afirmarse, por ejemplo, que una plataforma registró determinadas operaciones de descarga asociadas a una identidad digital, con la precisión y los límites de los registros disponibles. No corresponde convertir automáticamente esa observación en una atribución personal inequívoca. La cadena de custodia permite confiar en el recorrido de los datos examinados; la valoración de autoría necesita pruebas adicionales y un razonamiento independiente.

Figura 23: Línea temporal

4.6.7. Qué revela este caso sobre la escena digital

El supuesto integra los cinco temas del capítulo. La **identificación** evita reducir la escena a un portátil y reconoce proveedores, cuentas y registros. El **inventario** proporciona identidad estable a equipos, soportes y adquisiciones. La **intervención según el estado** permite decidir qué información volátil conviene preservar sin convertir la captura en una operación

automática. El **orden de volatilidad** explica por qué una exportación remota puede preceder a una retirada física. La **custodia** garantiza que los resultados conservan una relación documentada con los objetos, las transferencias y las operaciones.

La principal enseñanza no es que exista una secuencia perfecta. En otro incidente podría ser imprescindible aislar inmediatamente el portátil para detener una amenaza activa, conservar una máquina virtual antes de que el orquestador la destruya o priorizar un soporte dañado que está a punto de dejar de funcionar. Lo profesional es poder explicar qué riesgos se identificaron, qué se hizo, qué se dejó de hacer y cómo esas decisiones condicionan los resultados.

4.7. Conclusión

La escena digital es un entorno dinámico de fuentes conectadas cuya conservación exige algo más que conocimientos de adquisición. Su aseguramiento comienza con preguntas sobre legitimidad, alcance, riesgos y relaciones entre sistemas. Un equipo visible puede ser solo una parte de la evidencia, y una fuente remota puede perderse antes de que se retire el primer disco. La labor del analista consiste en reconocer esas dependencias y transformar una situación cambiante en un conjunto de observaciones y operaciones documentadas.

El inventario constituye la primera infraestructura de trazabilidad. Identificar correctamente activos, soportes, adquisiciones y copias evita atribuciones erróneas y permite reproducir el recorrido de un hallazgo. La documentación de estados y conexiones conserva el contexto físico y lógico que más tarde podría desaparecer. La calidad no depende de completar todos los campos posibles, sino de distinguir claramente lo observado, lo comunicado, lo inferido y lo que quedó sin comprobar.

La intervención sobre sistemas encendidos y apagados requiere juicio técnico. No es posible conservar simultáneamente todos los estados ni impedir que cualquier acción altere algo. La adquisición de memoria modifica el sistema del que obtiene información; el apagado elimina determinadas fuentes; el aislamiento puede proteger el servicio y alterar las conexiones; una instantánea puede preservar solo parte del estado de una máquina virtual. La justificación y la documentación de esas decisiones son componentes de la fiabilidad forense.

El orden de volatilidad aporta un criterio valioso, pero no una receta inflexible. La prioridad se construye con relevancia, riesgo de pérdida, accesibilidad, autorización, continuidad operativa y recursos disponibles. Un procedimiento que responde a esas variables es más sólido que una secuencia aplicada por costumbre. Igualmente, la conservación de registros y objetos debe concebirse a lo largo del tiempo, desde la petición urgente hasta la disposición final.

La cadena de custodia integra todos esos esfuerzos. Su finalidad no consiste en adornar una evidencia con firmas, sino en explicar su procedencia y cada transferencia significativa. Embalajes, precintos, repositorios, controles de acceso, verificaciones hash y bitácoras contribuyen de forma complementaria. Cuando ocurre una incidencia, la transparencia de su investigación fortalece el expediente mucho más que el intento de ocultarla. Cuando una fuente no puede verificarse plenamente, el límite debe declararse.

Finalmente, una evidencia íntegra no es necesariamente una interpretación correcta. El análisis posterior deberá convertir registros y objetos en hallazgos mediante métodos conocidos, hipótesis alternativas y corroboración. Lo que este capítulo aporta es el suelo sobre el que ese trabajo puede construirse: material preservado, fuentes identificables, decisiones justificadas y una trayectoria verificable desde la escena hasta el laboratorio.

> **Importante:** conservar evidencia digital significa preservar tanto la información como la capacidad de demostrar qué información se obtuvo, de dónde procedía, cómo fue tratada, qué pudo cambiar y quién asumió su control en cada momento.

El siguiente capítulo abordará con más detalle las técnicas de adquisición de evidencias y sus mecanismos de verificación. Allí se desarrollarán imágenes físicas y lógicas, formatos de contenedor, bloqueadores de escritura y particularidades de almacenamiento. Las reglas de reconocimiento, preservación y custodia estudiadas aquí seguirán siendo el contexto indispensable de esas operaciones.

4.8. Referencias técnicas y lecturas recomendadas

Las fuentes siguientes orientan los procedimientos expuestos y permiten profundizar en sus fundamentos. Se han identificado las ediciones cuando corresponde. Las recomendaciones técnicas **no constituyen por sí mismas autorización jurídica** ni sustituyen protocolos institucionales, normas de seguridad laboral o requerimientos del procedimiento concreto. Las guías históricas deben interpretarse con atención a la evolución de las plataformas y los dispositivos.

1. **ISO/IEC (2012).** *ISO/IEC 27037:2012 — Information technology — Security techniques — Guidelines for identification, collection, acquisition and preservation of digital evidence*. Norma sobre reconocimiento, recogida, adquisición y preservación de evidencia digital. Ficha oficial de ISO.
2. **Scientific Working Group on Digital Evidence (SWGDE, 2025).** *Best Practices for Digital Evidence Collection*, **18-F-002, versión 2.0 (30 de junio de 2025)**. Preparación, seguridad, búsqueda, documentación, adquisición y conservación. Documento oficial.

3. **SWGDE.** *Best Practices for Computer Forensic Acquisition*, **17-F-002, versión 2.1**. Métodos de adquisición, límites, verificación y documentación. Documento oficial.
4. **SWGDE (2022).** *Best Practices for Remote Collection of Digital Evidence from a Networked Computing Environment*, **22-F-003, versión 1.0 (22 de septiembre de 2022)**. Consideraciones sobre adquisición remota, autorización, herramientas, alteraciones y registros. Documento oficial en PDF.
5. **SWGDE.** *Best Practices for Mobile Device Evidence Collection, Preservation, Handling, and Acquisition*, **18-F-003**. Buenas prácticas relativas a estado, conectividad, documentación y preservación de dispositivos móviles; debe consultarse la versión publicada vigente. Catálogo oficial de publicaciones.
6. **Kent, K.; Chevalier, S.; Grance, T.; Dang, H. (NIST, 2006).** *Guide to Integrating Forensic Techniques into Incident Response*, **NIST SP 800-86**. Guía histórica de técnicas forenses aplicadas a respuesta a incidentes; no constituye un manual exhaustivo ni asesoramiento jurídico. Ficha oficial.
7. **Ayers, R.; Brothers, S.; Jansen, W. (NIST, 2014).** *Guidelines on Mobile Device Forensics*, **NIST SP 800-101 Revision 1**. Conservación, adquisición y limitaciones en dispositivos móviles. Ficha oficial.
8. **National Institute of Justice (NIJ, 2008).** *Electronic Crime Scene Investigation: A Guide for First Responders*, segunda edición, **NCJ 219941**. Reconocimiento, documentación, recogida, embalaje, transporte y almacenamiento. Oficina de Programas de Justicia de Estados Unidos.
9. **National Institute of Justice (NIJ, 2009).** *Electronic Crime Scene Investigation: An On-the-Scene Reference for First Responders*, **NCJ 227050**. Referencia breve para primeras intervenciones. NIJ.
10. **NIST Computer Forensics Tool Testing Program (CFTT).** Publicaciones de pruebas y métodos de evaluación de herramientas forenses. Su aplicabilidad depende de la función, versión y entorno de la herramienta examinada. Portal oficial.
11. **SWGDE.** Repositorio de documentos sobre informes, validación, adquisición, análisis en la nube, dispositivos especiales y tratamiento de evidencia digital. Conviene comprobar la edición vigente antes de aplicar una recomendación. Catálogo completo.
12. **National Institute of Standards and Technology (NIST).** Recursos sobre seguridad, gestión de incidentes y preservación de información. Los estándares y guías constituyen referencias metodológicas sujetas a contexto, no sustitutos de una valoración jurídica. Computer Security Resource Center.

5. Adquisición de evidencias y verificación de integridad

> "No es una cuestión de enfoque. Hay factores aleatorios que afectan al flujo de información… lo que llamamos el principio de incertidumbre. Cuando se registra y se interpreta, ese factor aleatorio se traduce en borrosidad, o"ruido", como dicen los técnicos en comunicaciones. (…) La naturaleza física del universo impone límites." ("It's not a question of focus. There are random factors affecting the neutrino stream… What we call the uncertainty principle. When the stream is recorded and interpreted, the random factor comes out as fuzziness, or"noise" as the communications boys speak of it. (…) The physical nature of the universe sets limits.")
>
> — Isaac Asimov, The Dead Past (El pasado muerto, diálogo entre el físico Foster y el historiador Potterley)

La adquisición de evidencias digitales constituye uno de los momentos más delicados de una investigación forense. Hasta ese instante, el investigador ha identificado fuentes de información, delimitado un escenario, evaluado riesgos y preparado una intervención. A partir de la adquisición comienza a existir un nuevo objeto probatorio: un conjunto de datos obtenidos de una fuente concreta, mediante un procedimiento determinado, en un momento identificable y bajo unas condiciones que deben poder explicarse. La operación parece sencilla cuando se describe como una copia. Sin embargo, copiar no significa necesariamente adquirir de forma forense, y una copia técnicamente exacta puede resultar insuficiente para responder a las preguntas de un caso si se desconoce qué parte de la fuente se ha obtenido, qué transformaciones se han producido o qué información ha quedado fuera.

Imaginemos que una organización detecta una posible extracción no autorizada de documentos desde un equipo portátil. El ordenador utiliza una unidad SSD, tiene el disco cifrado y permanece encendido con una sesión de usuario abierta. Parte de los documentos se almacena en una aplicación corporativa en la nube; otra parte se ha sincronizado en una carpeta local. La cuenta sospechosa continúa activa y algunos registros del proveedor tienen un periodo de retención limitado. La decisión de apagar el equipo para extraer su unidad, aparentemente conservadora, puede impedir el acceso posterior a los datos descifrados. Mantenerlo encendido permite capturar información efímera, pero también provoca nuevas escrituras, actualizaciones y cambios en los registros. Obtener únicamente una exportación lógica puede preservar los documentos visibles sin conservar los indicios de su eliminación. Realizar una imagen completa del SSD, por su parte, no garantiza recuperar datos sobre los que ya haya actuado TRIM.

La tarea del analista consiste en elegir y justificar una combinación de técnicas que conserve la información relevante con el menor riesgo razonable y dentro de la autorización recibida.

No existe una técnica universal que sea simultáneamente completa, inocua, rápida y aplicable a cualquier tecnología. Una adquisición rigurosa se reconoce, precisamente, por la capacidad de explicar qué se consiguió, qué no pudo conseguirse y por qué el resultado es fiable dentro de sus límites.

Este capítulo desarrolla los procedimientos de adquisición física, lógica y remota; el papel de los bloqueadores de escritura; la naturaleza y los formatos de las imágenes forenses; el uso correcto de las funciones hash; las particularidades de los soportes y sistemas modernos; y la documentación necesaria para convertir una operación técnica en un proceso auditable. La atención se centra en el razonamiento metodológico y en las prácticas reproducibles, sin confundir el dominio de una herramienta con la competencia profesional para emplearla.

5.1. Adquisición física, lógica y remota

5.1.1. Del hallazgo a la adquisición: definir exactamente el objeto

En el lenguaje corriente, una evidencia puede ser «el ordenador», «el móvil» o «la cuenta de correo». Estas expresiones sirven para una primera conversación, pero no describen con precisión qué se va a adquirir. El objeto de adquisición puede ser una unidad física completa, una partición, un volumen lógico descifrado, una memoria RAM, un conjunto de archivos, una base de datos, una máquina virtual, una exportación de auditoría o una respuesta estructurada de una API. Cada opción delimita un universo de datos diferente y, por tanto, un conjunto distinto de conclusiones posibles.

Antes de iniciar cualquier operación conviene formular dos preguntas. La primera es **qué fuente constituye el origen técnico de los datos**: el SSD instalado en el portátil, el volumen expuesto por el sistema operativo, un recurso compartido, el backend de una aplicación o un proveedor externo. La segunda es **qué representación de esa fuente se va a conservar**: una secuencia de sectores direccionables, el contenido de determinados archivos con metadatos, una exportación de registros, una instantánea o una captura de memoria. Confundir origen y representación conduce a expresiones como «se obtuvo una copia exacta del ordenador» cuando, en realidad, se descargaron algunas carpetas mediante la interfaz de usuario.

La distinción se hace todavía más importante en un entorno de nube. El administrador de una plataforma puede exportar los mensajes de un buzón, pero normalmente no tiene acceso a los bloques físicos de almacenamiento donde el proveedor conserva esos mensajes. Una instantánea de una máquina virtual puede abarcar determinados discos virtuales, mientras que sus registros de identidad y actividad permanecen en otros servicios. En ambos

casos, una adquisición es útil y potencialmente sólida, pero no debe describirse como una imagen física integral de toda la infraestructura.

Una ficha de planificación de adquisición debería dejar establecidos al menos los siguientes extremos: identificador de fuente y autorización; finalidad y preguntas del caso; técnica propuesta; condiciones iniciales; clases de datos incluidas y excluidas; riesgos de pérdida o modificación; herramienta y formato; capacidad de destino; método de verificación; y criterios para suspender o repetir la operación. Esta planificación no es un trámite añadido al trabajo técnico: constituye la referencia contra la que se evaluará el resultado.

5.1.2. Qué significa adquirir físicamente

La expresión *adquisición física* suele utilizarse para referirse a la obtención de los datos accesibles en una unidad de almacenamiento por debajo del nivel del sistema de archivos. En un disco de ordenador, el resultado habitual es una imagen sector a sector del espacio de direcciones lógicas que el dispositivo presenta al sistema anfitrión. En algunos entornos especializados, el término puede significar acceso de nivel todavía inferior, como la extracción de memoria de un chip. Por ello, el informe debe especificar el método real en lugar de confiar únicamente en una etiqueta genérica.

Una adquisición de bloques de una unidad completa suele incluir la tabla de particiones, los sistemas de archivos existentes, las estructuras auxiliares, los sectores no asignados a archivos y, según la tecnología y el método, el espacio no asignado entre particiones. Esta amplitud es valiosa cuando se investigan borrados, persistencia de malware, alteraciones del sistema, cambios de particiones o rastros que no aparecen en la navegación normal del explorador.

No obstante, una imagen sectorial del dispositivo **no representa necesariamente la totalidad de la información física almacenada por su hardware**. El controlador de un SSD administra internamente páginas NAND que no están expuestas por la interfaz lógica; los mecanismos de reasignación de sectores de un HDD pueden ocultar sectores defectuosos sustituidos; y determinadas áreas especiales pueden quedar fuera del espacio direccionable observado. También pueden existir zonas restringidas por la configuración del dispositivo, dependientes de sus interfaces y capacidades. En un informe resulta preferible escribir «imagen de todos los bloques lógicos accesibles mediante la interfaz empleada» que afirmar, sin matices, «copia absoluta de todos los datos del soporte».

La adquisición física ofrece amplitud, pero tiene costes. Puede demandar muchas horas, espacio proporcional a la capacidad del dispositivo y técnicas de lectura tolerantes a errores. También puede proporcionar bytes cifrados que resulten imposibles de interpretar sin las

credenciales o claves necesarias. En un equipo activo y cifrado, una imagen del volumen descifrado obtenida mediante mecanismos del sistema puede aportar más información inmediatamente útil que una imagen de la unidad apagada. Ambas representan cosas distintas y, cuando el alcance lo permite, pueden complementarse.

5.1.3. La adquisición lógica y sus distintas modalidades

Una adquisición lógica obtiene información a través de una abstracción proporcionada por el sistema operativo, una aplicación, una base de datos o un servicio. Puede incluir archivos y directorios, mensajes, registros, objetos de almacenamiento, exportaciones de correo, colecciones de una base de datos y metadatos ofrecidos por la interfaz. No necesariamente incluye sectores libres, estructuras internas inaccesibles ni todos los estados históricos del origen.

La adquisición lógica no debe considerarse una alternativa inferior por definición. Es con frecuencia la técnica apropiada cuando se necesita preservar un buzón empresarial en funcionamiento, un conjunto de documentos compartidos, un teléfono cuyo fabricante restringe el acceso a bloques o un servicio de nube sin acceso al almacenamiento subyacente. Su calidad depende de la exactitud del alcance, la cobertura de los datos relevantes y la fidelidad de la exportación. Un volcado lógico que conserva los encabezados completos de los mensajes, los identificadores originales y los registros de auditoría puede tener un valor probatorio superior a una colección desordenada de capturas de pantalla.

Bajo la denominación lógica conviven procedimientos muy distintos. Una copia realizada con herramientas del sistema de archivos puede preservar rutas, tamaños y algunos tiempos, pero perder listas de control de acceso, flujos alternativos, atributos extendidos o propietarios si se utiliza una opción inadecuada. Una exportación nativa de una aplicación puede transformar nombres, fechas, estructuras o formatos. Una consulta SQL puede devolver un subconjunto correcto de filas sin preservar transacciones recientes, registros de escritura anticipada o el historial de modificaciones. Una API puede paginar los resultados, imponer límites de velocidad o dejar fuera objetos eliminados. Por ello, no basta con decir «se hizo una copia lógica»; es necesario identificar la interfaz, sus parámetros y sus límites.

Consideremos una carpeta con documentos en un equipo Windows. Copiar su contenido al arrastrarlo a una memoria USB puede modificar fechas de acceso, generar archivos auxiliares y omitir rutas largas o ciertos atributos. Una herramienta que preserve de manera explícita las marcas temporales, los permisos y otros metadatos reduce algunas pérdidas, pero tampoco convierte esa copia en una imagen de disco. La idoneidad de una adquisición lógica se determina por la relación entre la pregunta de investigación y los elementos que efectivamente reproduce.

5.1.4. Adquisición selectiva, focalizada y de triaje

El volumen de datos de una investigación puede superar con facilidad la capacidad de adquisición y revisión disponible. Un servidor con decenas de terabytes, cientos de estaciones o un repositorio SaaS con millones de documentos plantea un problema de proporcionalidad, tiempo y coste. En ese contexto, una adquisición selectiva, también denominada *targeted acquisition*, puede conservar las fuentes y los objetos con mayor relevancia inicial.

La selección debe guiarse por hipótesis y criterios registrados, no por una confianza intuitiva en que «los archivos importantes» se encuentran en determinadas carpetas. Si el objetivo es reconstruir un acceso remoto, los registros de autenticación, las claves usadas, los eventos del sistema y las conexiones pueden resultar más decisivos que los documentos de usuario. Si se analiza una posible eliminación de información, limitarse a los archivos visibles constituye una elección especialmente arriesgada. La ausencia de un archivo en la exportación no demuestra que nunca existiera.

El triaje es un procedimiento de decisión rápida que permite identificar sistemas o datos merecedores de una adquisición más profunda. No constituye por sí mismo una conclusión forense definitiva. Es legítimo comenzar por una búsqueda de nombres, un listado de procesos o un conjunto limitado de registros y ampliar después el alcance, siempre que la técnica utilizada, sus efectos y sus límites queden recogidos en la documentación. Una adquisición selectiva puede ser el primer paso de un proceso escalonado o su resultado suficiente, según la finalidad y la autorización.

5.1.5. Adquisición en vivo y fuera de línea

Otra clasificación atraviesa las anteriores: la diferencia entre adquirir un sistema mientras funciona y obtener los datos con el sistema detenido o desconectado. Ambas posibilidades existen tanto para adquisiciones amplias como para adquisiciones focalizadas.

En una **adquisición en vivo**, la fuente permanece operativa. Es posible recoger la memoria RAM, la lista de procesos, conexiones y sesiones, las claves accesibles al proceso autorizado, el estado de dispositivos, los contenedores en ejecución y determinados datos descifrados. Sin embargo, la herramienta ejecutada utiliza recursos, crea procesos, abre archivos, puede generar registros y modifica el sistema observado. La adquisición en vivo busca minimizar y documentar esos cambios, no fingir que no se producen.

En una **adquisición fuera de línea**, el soporte se conecta a una estación de adquisición bajo controles adecuados o se arranca el equipo mediante un entorno controlado, con las precauciones necesarias para impedir modificaciones. Esta modalidad facilita una lectura más

estable de datos persistentes, pero no recupera automáticamente información que dependía de la sesión activa. El cifrado de disco completo, el arranque seguro, la soldadura del almacenamiento a la placa y las dependencias de plataformas remotas pueden alterar por completo la viabilidad del método.

La decisión no se resuelve con la regla simplista de «siempre apagar primero» o «siempre capturar RAM». Deben ponderarse la volatilidad, el valor esperado, el riesgo de que el sistema sea alterado, la continuidad de servicio y la capacidad del equipo pericial. Un servidor que sostiene una instalación sanitaria o industrial puede exigir coordinación y un procedimiento específico antes de cualquier intervención. Un equipo que se sospecha manipulado de forma remota puede requerir contención inmediata, aun cuando se pierdan determinados datos efímeros. La decisión debe quedar justificada en términos de riesgos aceptados y beneficios de preservación.

5.1.6. Adquisición remota y de terceros

Adquirir de forma remota significa obtener información sin tener necesariamente el soporte bajo control físico directo. Puede hacerse desde una herramienta de administración desplegada en un equipo, mediante un agente forense, a través de SSH o de una API, desde una consola de virtualización o mediante una exportación solicitada a un tercero. Este tipo de adquisición resulta habitual en organizaciones distribuidas, servicios en la nube e investigaciones de incidentes que afectan a muchos activos.

El principal problema metodológico no es la distancia, sino el cambio de confianza: el investigador depende de sistemas de autenticación, conexiones, agentes, relojes, permisos y respuestas de plataformas que pueden encontrarse fuera de su control. Debe registrarse quién ejecutó la operación, con qué identidad, desde qué entorno, qué credenciales o privilegios autorizados se utilizaron, cuáles fueron los filtros y cómo se entregó la información. En caso de datos recibidos de terceros es importante conservar el paquete original de entrega, sus mensajes acompañantes, su estructura y sus verificaciones, antes de extraerlo o transformarlo para el análisis.

Las plataformas SaaS suelen ofrecer varios niveles de exportación: contenido del usuario, registros de auditoría, datos administrativos y artefactos sujetos a retención especial. La información disponible puede variar entre planes, licencias, regiones, periodos de conservación y permisos. Una exportación íntegra «según la API consultada» no demuestra que se hayan obtenido todos los datos mantenidos internamente por el proveedor. Las consultas y respuestas deben documentarse, incluyendo errores, paginación, truncamientos, límites temporales y diferencias entre exportaciones sucesivas.

La adquisición remota obliga asimismo a valorar el riesgo de intervención sobre el sistema. Una consulta que parece de lectura puede actualizar el último acceso de un objeto; ejecutar un agente puede registrar servicios; crear una instantánea puede modificar metadatos operativos. No se trata de prohibir estas acciones, sino de conocerlas, reducirlas y documentarlas. Las mejores prácticas de SWGDE para recolección remota y para proveedores cloud son referencias útiles para esta tarea.

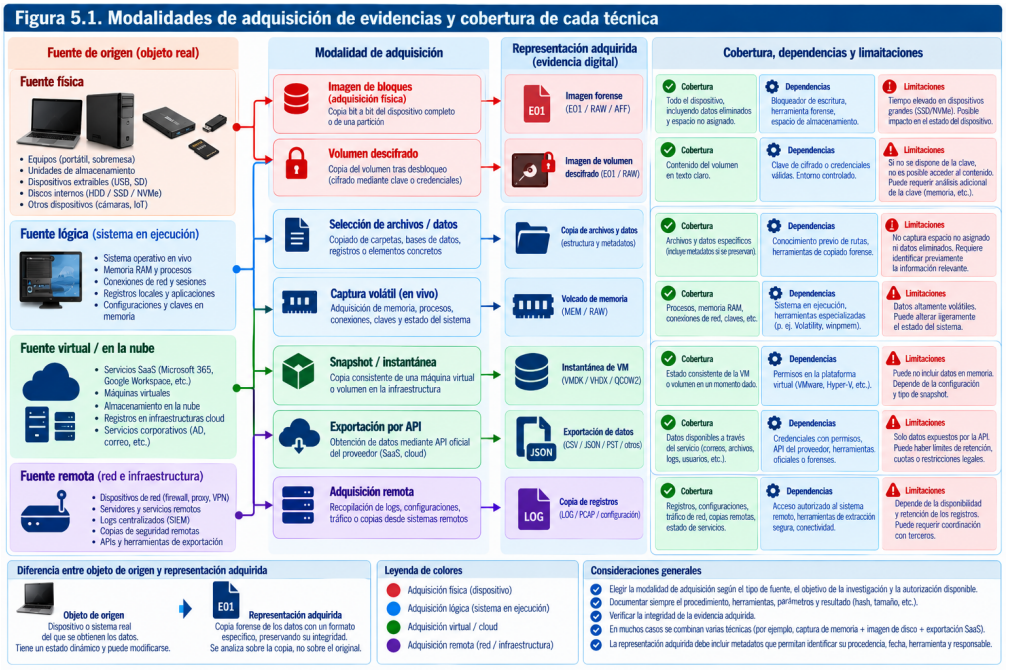


Figura 24: Modalidades de adquisición

5.1.7. La matriz de decisión: cobertura frente a invasividad y tiempo

Seleccionar una modalidad requiere comparar tres dimensiones que no avanzan necesariamente juntas: cobertura de evidencia, riesgo de alteración y coste temporal u operativo. Una imagen de bloques puede ofrecer gran cobertura del espacio lógico de una unidad, pero no incorporar una sesión descifrada ni los datos que residen solo en la nube. Una exportación API puede obtener rápidamente registros críticos y, al mismo tiempo, depender de la exactitud de los filtros. Una captura de RAM puede preservar procesos y claves, pero demanda intervenir sobre el sistema activo y tiene una ventana temporal estrecha.

La siguiente tabla es orientativa. No establece una jerarquía universal entre métodos:

Modalidad	Objeto típico	Ventaja principal	Limitación relevante	Verificación habitual
Imagen de bloques	Unidad o volumen direccionable	Amplitud del espacio lógico	Puede incluir datos cifrados o no accesibles; no equivale a NAND completa	Hash del flujo adquirido y verificación de imagen
Copia lógica	Archivos y metadatos seleccionados	Proporcionalidad y acceso dirigido	Excluye sectores libres y atributos no exportados	Hash por archivo y manifiesto del conjunto
Captura en vivo	RAM, procesos, sesiones, volumen abierto	Conserva estados efímeros y datos descifrados	Modifica el entorno operativo	Hash de salida, registros de ejecución y contexto
Exportación API	Objetos, eventos y registros de servicio	Acceso a sistemas remotos y cloud	Retención, paginación y permisos limitan cobertura	Hash del paquete, consulta y manifiesto
Instantánea	Disco virtual o estado admitido por plataforma	Conservación rápida de un estado coherente según mecanismo	No representa necesariamente memoria ni servicios externos	Identificadores, metadatos, hashes de exportación
Recuperación de soporte dañado	Bloques legibles y mapa de errores	Rescata información sin exigir lectura perfecta	Sectores irrecuperables, degradación adicional	Mapa de sectores, hash de imagen resultante y limitaciones

El método elegido debe describirse en el plan y revisarse si las condiciones reales contradicen las previstas. Por ejemplo, si un disco presentado como HDD es en realidad un SSD con cifrado, las expectativas de recuperación de borrados y el tratamiento del soporte cambian.

El analista no debería continuar por inercia con el procedimiento inicialmente seleccionado.

5.1.8. Una adquisición escalonada en un caso corporativo

Volvamos al portátil del caso inicial. La organización pretende determinar si una cuenta autorizada descargó documentos del repositorio, si posteriormente salieron del equipo y qué evidencias respaldan esa secuencia. El ordenador está encendido y el usuario ha sido separado temporalmente de sus funciones. Existe autorización escrita para preservar el equipo y exportar los registros corporativos; no se ha autorizado revisar cuentas privadas ajenas a la finalidad.

Una estrategia razonable podría comenzar por registrar el estado del equipo y los servicios, solicitar al proveedor SaaS la conservación de registros expuestos a rotación y evaluar si procede capturar memoria y los volúmenes montados. También se puede valorar una imagen de bloques fuera de línea, una vez protegida la información volátil y resuelto el problema de acceso al cifrado. Paralelamente, el área de identidad puede exportar los eventos de autenticación y cambios de sesión dentro del alcance aprobado. Las adquisiciones se realizarán con identificadores separados y una relación documental que explique cómo se complementan.

El resultado no es una única «gran evidencia», sino un conjunto coherente: registros del proveedor, instantáneas o exportaciones, memoria o datos vivos si se han autorizado, imagen del soporte y documentos de trazabilidad. Cada pieza tendrá su propia procedencia, fecha, cobertura y forma de verificación. La correlación de esas piezas pertenece a la fase de análisis; no debe improvisarse durante la adquisición ni alterar el registro de lo que efectivamente se conservó.

5.2. Bloqueadores de escritura

5.2.1. El riesgo de modificar la fuente durante su lectura

Los sistemas operativos y las herramientas habituales fueron diseñados para trabajar con soportes activos, no para preservar objetos probatorios. Cuando se conecta una unidad, un equipo puede intentar reconocer particiones, montar sistemas de archivos, comprobar errores, crear carpetas auxiliares, indexar contenido o actualizar metadatos. Incluso una inspección aparentemente inocua puede activar componentes que realizan escrituras. En otros casos, los cambios proceden del propio dispositivo, cuyos procesos internos continúan funcionando aunque el anfitrión solo solicite lecturas.

El bloqueo de escritura tiene un objetivo delimitado: impedir, dentro de las capacidades del mecanismo empleado, que operaciones originadas por el equipo de adquisición modifiquen el contenido accesible del soporte. La prevención de modificaciones reduce el riesgo de contaminación y facilita explicar que los datos obtenidos proceden del soporte intervenido y no de una intervención accidental del analista. No exime de mantener una cadena de custodia, documentar los pasos ni comprobar la adquisición.

Es importante comprender que «solo lectura» puede referirse a capas diferentes. Un sistema de archivos montado con la opción `ro`, un dispositivo de bloques marcado como de solo lectura, un controlador que rechaza determinados comandos de escritura y un puente físico diseñado como bloqueador forense no proporcionan las mismas garantías. La presencia de una opción de software no demuestra, por sí sola, que se hayan interceptado todos los caminos de modificación relevantes para la interfaz y el firmware del dispositivo.

5.2.2. Bloqueadores de escritura por hardware

Los bloqueadores físicos se interponen entre la estación forense y el soporte. Habitualmente exponen una interfaz de lectura al ordenador del examinador y restringen operaciones de escritura dirigidas al dispositivo de origen. Existen soluciones específicas para SATA, SAS, USB y otros entornos; ciertas interfaces modernas, como NVMe, requieren adaptadores o equipos especializados. La elección depende de la compatibilidad real con el soporte, los comandos admitidos, la alimentación y la versión de firmware del bloqueador.

Un bloqueador puede informar de que rechaza operaciones de escritura, pero el investigador no debería limitarse a confiar en un indicador luminoso. Debe verificar el modelo, identificar su versión y confirmar que ha sido probado para la combinación de hardware y protocolo relevante. El programa *Computer Forensic Tool Testing* (CFTT) del NIST ha publicado procedimientos y resultados relativos a categorías de herramientas, entre ellas las de bloqueo de escritura y adquisición de discos. Sus criterios ayudan a entender qué propiedades se deben comprobar, aunque la validación concreta corresponde al entorno donde se va a usar la herramienta.

Hay situaciones en las que un bloqueador por hardware introduce una limitación importante. Una unidad cifrada puede presentar únicamente bloques cifrados cuando se conecta fuera de su ordenador original. Un equipo con almacenamiento soldado puede impedir el acceso directo sin técnicas invasivas. Un dispositivo con daños físicos puede reaccionar mal al cambio de alimentación o de adaptador. En estos escenarios, la protección frente a escrituras no puede decidirse aisladamente de la estrategia global de preservación.

5.2.3. Bloqueo por software y precauciones en Linux

Un laboratorio Linux permite inspeccionar discos y realizar imágenes con herramientas de propósito general, pero debe configurarse cuidadosamente. Las reglas de montaje automático, los servicios de escritorio, el gestor de volúmenes y las rutinas de descubrimiento de dispositivos pueden actuar antes de que el analista haya comprobado qué unidad se acaba de conectar. Por ello, el procedimiento debe empezar por un entorno controlado, con los servicios de automontaje deshabilitados y con reglas previamente probadas para el equipo empleado.

Un comando como `blockdev --setro` establece una condición de solo lectura en la capa del dispositivo de bloques gestionada por Linux. Es útil como defensa adicional en escenarios concretos; **no es una prueba suficiente de bloqueo forense integral ni sustituye sin más a un bloqueador validado**. De forma semejante, montar un sistema de archivos con `-o ro` reduce operaciones de escritura desde esa montura, pero no demuestra que el dispositivo completo esté protegido frente a otras rutas de acceso. Algunos sistemas de archivos poseen mecanismos de recuperación de diario o de modificación de estado que exigen opciones adicionales o, preferentemente, evitar el montaje de la fuente.

En Linux, `/dev/sda` o `/dev/nvme0n1` son nombres asignados dinámicamente; no deben aceptarse como identificadores permanentes. Antes de operar sobre un dispositivo conviene cotejar identificadores estables, modelo, número de serie, capacidad y ruta física. Una confusión entre origen y destino puede destruir un soporte o sobrescribir evidencia. La validación de identidad debe repetirse tras reconectar, reiniciar o cambiar un adaptador.

Ejemplo de identificación no destructiva en laboratorio:

```
lsblk -o NAME,PATH,TRAN,MODEL,SERIAL,SIZE,RO,TYPE,MOUNTPOINTS
ls -l /dev/disk/by-id/
```

El primero ofrece una vista del estado actual del sistema y el segundo permite relacionar algunas rutas estables con los nodos del núcleo. La salida debe contrastarse con la etiqueta física, el registro de inventario y el contexto de conexión. Ninguna de estas órdenes autoriza a asumir que una unidad es la correcta solo porque aparece en primer lugar. Tampoco garantiza que todas las unidades expongan un serial fiable, especialmente cuando existen adaptadores USB o controladoras que modifican la información presentada.

En una estación correctamente preparada se puede consultar el atributo de solo lectura de un dispositivo:

```
sudo blockdev --getro /dev/disk/by-id/ID_VERIFICADO
```

El valor observado documenta el estado reportado por esa interfaz de software en ese momento. No certifica la ausencia de escrituras autónomas del firmware ni la cobertura de un bloqueador externo. Esta diferencia entre *medida aplicada* y *garantía realmente obtenida* debe mantenerse en todo procedimiento pericial.

5.2.4. Verificación práctica del bloqueo

Un mecanismo de bloqueo no se valida escribiendo datos de prueba sobre una evidencia real. La evaluación debe realizarse antes, sobre soportes de laboratorio conocidos y sin valor probatorio. Una prueba habitual consiste en establecer un estado inicial del soporte de ensayo, calcular sus hashes, intentar operaciones controladas de escritura a través de la configuración que se desea evaluar, comprobar su rechazo y confirmar que los bytes accesibles y los metadatos relevantes permanecen sin cambios. El protocolo debe incluir operaciones representativas del conjunto de comandos que el bloqueador afirma restringir.

Este ensayo es más fiable cuando se repite tras actualizaciones de firmware, cambios de adaptadores, sustitución del sistema operativo o incorporación de nuevas familias de dispositivos. La mera compatibilidad eléctrica no demuestra la compatibilidad forense. Las unidades NVMe pueden gestionarse con comandos y rutas distintos de los empleados por un disco SATA, y algunos puentes USB no conservan toda la información de identificación del dispositivo. Además, la función del bloqueador debe ensayarse con la herramienta real de adquisición, ya que las interacciones entre componentes pueden introducir comportamientos imprevistos.

El resultado se documentará con fecha, responsable, versiones, soporte de prueba, comandos o acciones efectuadas, resultados observados y limitaciones. Si la prueba demuestra que una configuración no bloquea determinadas operaciones, la conclusión correcta no es ocultar el problema: debe retirarse o restringirse ese procedimiento hasta disponer de controles adecuados.

5.2.5. Lo que un bloqueador no impide

El bloqueo de escritura suele interpretarse erróneamente como una congelación completa del estado de almacenamiento. En realidad, un SSD puede gestionar internamente reasignaciones, recogida de basura y operaciones de mantenimiento. Aunque el anfitrión no emita escrituras, la representación de determinadas zonas puede verse afectada por el diseño del dispositivo o por operaciones previamente programadas. En otros casos, el contenido leído puede cambiar por defectos físicos, errores intermitentes o comportamientos del firmware.

El bloqueador reduce un vector concreto de modificación, pero no elimina todos los riesgos.

Tampoco impide que el operador confunda unidades, lea un dispositivo incompleto, corte la alimentación o seleccione un rango erróneo de bloques. No resuelve problemas de autorización ni de privacidad. Un bloqueo impecable aplicado a un soporte equivocado produce una adquisición técnicamente controlada pero inútil para el caso. A la inversa, una adquisición lógica en vivo puede ser válida y necesaria aunque no exista bloqueo de escritura, siempre que se registre y justifique el tratamiento de modificaciones inherentes a la operación.

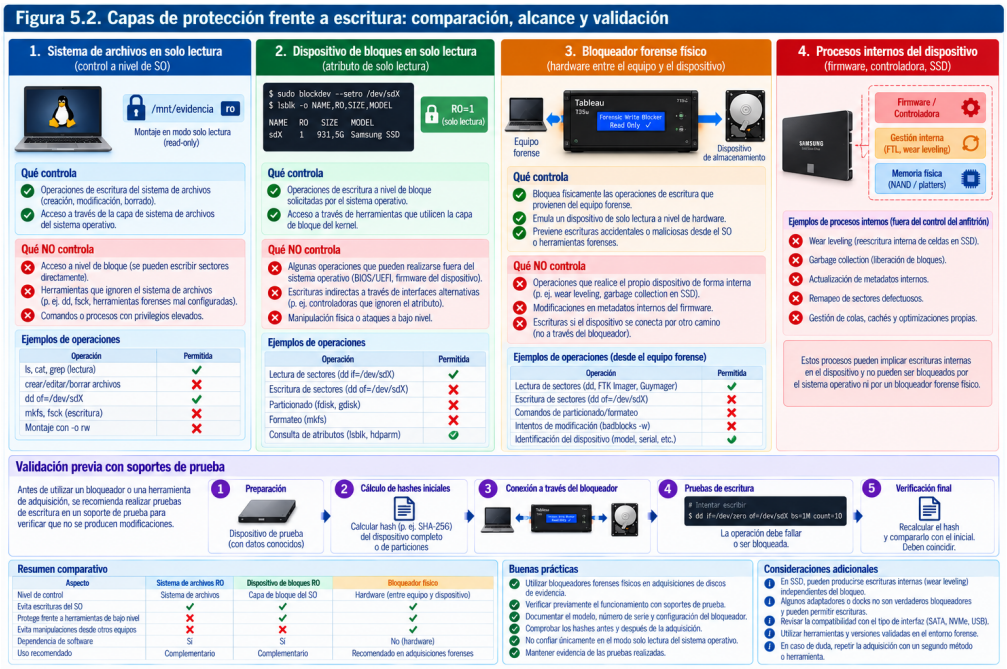


Figura 25: Capas de protección frente a escritura

5.2.6. Decidir sin convertir el bloqueador en un ritual

La buena práctica no consiste en introducir sistemáticamente el mismo accesorio en todas las investigaciones, sino en escoger controles coherentes con el riesgo. Ante un HDD convencional, accesible y estable, un bloqueador validado puede formar parte de la vía preferente para una imagen fuera de línea. Ante un ordenador encendido con cifrado activo, aislar y extraer el disco sin examinar el estado de las claves puede resultar contraproducente. Ante un

servicio SaaS, el control pertinente no será un bloqueo físico, sino una exportación con credenciales autorizadas, registros de actividad, verificación del paquete recibido y protección de las copias.

Así entendidos, los bloqueadores son componentes de un sistema de aseguramiento de calidad, no símbolos de validez automática. El informe ha de identificar el mecanismo utilizado, la razón de elegirlo, sus resultados de verificación y cualquier circunstancia que pueda afectar a la integridad o a la cobertura de la adquisición.

5.3. Imágenes forenses y sus formatos

5.3.1. La imagen forense como objeto independiente

Una imagen forense es una representación conservada de datos obtenidos de una fuente mediante un proceso de adquisición documentado. Con frecuencia se asocia a una copia de disco sector a sector, pero el concepto abarca también representaciones de particiones, volúmenes, memorias y ciertos conjuntos de datos estructurados. Lo esencial no es la extensión del archivo resultante, sino la correspondencia entre los datos adquiridos y la fuente que se afirma representar.

Conviene diferenciar tres elementos. El **soporte original** es la unidad o sistema de origen; la **adquisición** es la operación que extrae los datos y produce un resultado; y la **imagen** es el objeto digital resultante de esa operación. Posteriormente se pueden generar **copias de referencia** destinadas a conservar el resultado y **copias de trabajo** sobre las que realizar búsquedas, montajes, transformaciones y análisis. Los nombres pueden variar entre laboratorios, pero la relación entre los objetos debe permanecer explícita.

La imagen obtenida no es un archivo «idéntico al disco» en todos los sentidos. Un disco es un dispositivo que expone bloques y responde a comandos; una imagen es un archivo o conjunto de archivos que contiene una secuencia de datos, acompañada o no de metadatos. El proceso puede capturar todos los bloques accesibles, una partición, solo los bloques utilizados o un conjunto lógico. También puede comprimir, segmentar y encapsular la información. La fidelidad se evalúa respecto del objeto y alcance declarados, no por una equivalencia metafórica entre ambos soportes.

5.3.2. Imagen RAW: simplicidad y transparencia

Una imagen RAW, frecuentemente identificada por extensiones como `.dd`, `.raw` o `.img`, suele almacenar una secuencia lineal de bytes correspondiente a los bloques leídos del ori-

gen. Su principal virtud es la sencillez: un programa capaz de leer archivos binarios puede examinarla y, si conoce la geometría y los desplazamientos necesarios, interpretar sus particiones y sistemas de archivos. No depende de un formato de contenedor complejo para representar la secuencia adquirida.

La contrapartida es que un RAW convencional no incorpora de manera intrínseca un registro completo de quién lo creó, qué herramienta se utilizó, cuál era el número de serie del dispositivo, qué sectores fallaron ni cómo se verificó la operación. Esa información debe conservarse en un manifiesto, un informe de adquisición, los registros de la herramienta y otros ficheros relacionados. Tampoco es habitual que RAW comprima automáticamente: una imagen completa de un dispositivo de 1 TB puede requerir una capacidad de destino cercana a su tamaño lógico, incluso si muchos bloques contienen ceros o datos repetidos. Algunas técnicas del sistema de archivos de destino permiten almacenar regiones dispersas sin ocupar todos los bloques físicos, pero esa optimización debe distinguirse de los bytes que la imagen representa.

RAW ofrece interoperabilidad con numerosas herramientas, facilita el cálculo de hashes de la secuencia y permite efectuar comprobaciones sencillas. En un entorno de laboratorio, puede resultar muy adecuada para discos de prueba, soportes pequeños y flujos de adquisición que necesitan transparencia. No es, sin embargo, una solución universal: en casos amplios puede ser conveniente usar contenedores que integren metadatos, segmentación, compresión y mecanismos adicionales de control.

5.3.3. El formato EWF y los ficheros E01

El formato conocido como EWF (*Expert Witness Format*) y su uso habitual mediante archivos `E01` permite almacenar evidencia adquirida en un contenedor forense, con información descriptiva y, según la variante y las opciones elegidas, compresión, segmentación y mecanismos de verificación. Su adopción en numerosos laboratorios ha favorecido la compatibilidad con herramientas de análisis comerciales y abiertas. No todas las variantes históricas y modernas del formato son idénticas, por lo que conviene identificar la herramienta y la versión que han producido el conjunto.

Una adquisición `E01` suele generar uno o varios segmentos. Si el tamaño total lo requiere, el primer fichero puede denominarse `.E01` y continuar con extensiones secuenciales. La existencia de varios segmentos no implica que haya varias adquisiciones independientes: forman parte de un contenedor lógico. Perder un segmento puede impedir el análisis completo o comprometer la validación. El laboratorio debe conservar todos los elementos relacionados y registrar su estructura y sus comprobaciones.

La compresión tiene efectos sobre los hashes que conviene anticipar. El hash calculado sobre el **contenido lógico reconstruido** de la imagen puede corresponder al flujo de bytes adquirido desde la fuente. En cambio, el hash calculado sobre los **bytes del archivo contenedor E01** representa ese archivo empaquetado, incluyendo cabeceras y datos comprimidos; normalmente será distinto del hash del flujo fuente. Ambos valores son útiles, pero verifican objetos diferentes. Comparar uno con otro y concluir que la adquisición está alterada sería un error conceptual.

Los contenedores también pueden incorporar información sobre errores de lectura o metadatos relevantes, aunque la disponibilidad exacta depende del formato y de la herramienta. No debe darse por supuesta la conservación de una propiedad sin comprobar que el software realmente la registra. Una ficha de adquisición EWF debería anotar el formato concreto, los parámetros de compresión y segmentación, la herramienta y su versión, los hashes y el resultado de verificación, además de los informes generados.

5.3.4. AFF, AFF4 y otras representaciones

AFF (*Advanced Forensic Format*) surgió como una alternativa orientada a mejorar el almacenamiento de imágenes y metadatos forenses. AFF4 desarrolla un modelo de contenedor más flexible, destinado a representar conjuntos de datos, flujos y relaciones mediante estructuras de almacenamiento y metadatos. Sus posibilidades incluyen usos para los que una secuencia RAW simple resulta menos expresiva. Sin embargo, la interoperabilidad real no se debe presuponer: una herramienta puede admitir cierto subconjunto de un formato y otra puede interpretarlo de manera distinta.

En el ecosistema forense también se utilizan formatos propietarios, contenedores de adquisición lógica y paquetes nativos de cada proveedor. Las exportaciones de correo pueden adoptar estructuras como MBOX, PST u otros formatos; una captura de memoria suele guardarse en un archivo binario acompañado de un registro; y una adquisición cloud puede consistir en cientos de objetos y un manifiesto. No es correcto describir todas esas representaciones como E01 ni convertir una exportación de aplicación en una «imagen física» por el hecho de empaquetarla posteriormente.

El criterio de selección debe contemplar interoperabilidad, compatibilidad futura, conservación de metadatos, capacidad de segmentación, integridad verificable, necesidad de compresión y posibilidad de reconstruir los bytes relevantes con herramientas independientes. Para un libro o un procedimiento destinado a durar años, es preferible enseñar los principios de representación antes que imponer un producto comercial cuya disponibilidad o compatibilidad pueda cambiar.

5.3.5. Las imágenes segmentadas

Dividir una adquisición en segmentos facilita almacenarla en destinos con límites de tamaño, transferirla por redes o distribuirla entre medios de conservación. La segmentación introduce, al mismo tiempo, más elementos que gestionar. Los segmentos deben identificarse de manera inequívoca, conservar su orden y acompañarse de un manifiesto que documente su pertenencia al conjunto.

Es útil mantener dos niveles de verificación: uno para cada fichero tal como está almacenado y otro para el contenido adquirido reconstruido, siempre que la herramienta y el formato lo permitan. El primer nivel detecta la modificación o pérdida de un segmento concreto. El segundo comprueba que la reconstrucción del flujo ofrece los mismos bytes que se registraron en la adquisición. Si se ha usado compresión, cifrado del repositorio o transferencia a otro almacenamiento, estos niveles ayudan a localizar el punto donde se ha producido una incidencia.

La fragmentación arbitraria de un archivo RAW con herramientas generales puede resultar manejable, pero debe documentarse con precisión y probarse la reconstrucción. Si se utiliza un contenedor EWF, normalmente conviene dejar la segmentación a una herramienta que conozca el formato. El propósito es asegurar que el examinador futuro pueda identificar y utilizar el conjunto sin depender de conjeturas sobre nombres de archivo.

5.3.6. Compresión, cifrado y preservación del contenido

La compresión sin pérdida reduce el espacio necesario cuando los datos son compresibles; no garantiza ahorrar espacio en soportes que contienen información ya comprimida o cifrada. Un volumen BitLocker, FileVault o LUKS en estado cifrado puede presentar una entropía alta y ofrecer una reducción escasa. En cambio, una imagen de bloques con grandes zonas de ceros puede comprimirse notablemente.

La compresión debe ser reversible y la verificación debe permitir comprobar que la secuencia reconstruida es la esperada. Si un contenedor forense se cifra para proteger los datos en reposo, aparece una capa adicional de dependencia: conservar la clave y los mecanismos de descifrado se vuelve tan importante como conservar el archivo. El cifrado del repositorio protege la confidencialidad de la evidencia; no debe confundirse con el cifrado que ya existía en la fuente investigada.

En una infraestructura seria resulta conveniente separar la preservación de la **imagen maestra**, el acceso controlado a **copias de referencia** y la generación de **copias de trabajo**. Una

política de almacenamiento inmutable o de escritura restringida puede reforzar la conservación, pero la inmutabilidad debe probarse y auditarse. Una copia desconectada y cifrada reduce ciertos riesgos, aunque exige procedimientos de recuperación de claves y verificación periódica. La integridad no es un atributo que se establezca una vez y se olvide; es un estado que se comprueba a lo largo del ciclo de vida del objeto.

5.3.7. Metadatos de adquisición y metadatos de contenido

Los metadatos de adquisición describen cómo se obtuvo la evidencia: fecha, identificador del operador, método, herramienta, número de serie del origen, parámetros y resultados. Los metadatos de contenido, por el contrario, se encuentran dentro de los datos adquiridos: marcas temporales del sistema de archivos, atributos, propietarios, estructuras de partición y registros de actividad, entre otros. La diferencia importa porque los primeros documentan el proceso forense y los segundos pueden constituir materia de análisis del caso.

Un error habitual consiste en interpretar la fecha de creación del archivo `E01` en el laboratorio como la fecha de creación de los archivos contenidos en el disco. Esa fecha pertenece al objeto de adquisición, no al evento investigado. De forma parecida, si una exportación cloud se descarga hoy, la fecha de descarga del paquete no coincide necesariamente con la creación o modificación de los objetos exportados. Los metadatos de distintas capas deben conservar su denominación, fuente y zona horaria.

5.3.8. Ejemplo controlado de imagen RAW en Linux

Los comandos siguientes ilustran un flujo con **medios de laboratorio sin valor probatorio**. No deben ejecutarse sobre dispositivos reales hasta comprobar identidad, autorización, montaje, bloqueo y capacidad de destino. En especial, nunca se debe sustituir de forma improvisada el origen por una ruta como `/dev/sda` sin identificarla.

Primero se identifican las unidades visibles y las rutas persistentes:

```
lsblk -o NAME,PATH,MODEL,SERIAL,SIZE,RO,TYPE,MOUNTPOINTS
ls -l /dev/disk/by-id/
```

En una situación de entrenamiento donde la fuente sea un fichero preparado, el mismo concepto puede practicarse sin acceder a un disco físico:

```
mkdir -p laboratorio/adquisiciones
# "fuente-lab.img" es un archivo sintético preparado previamente.
dd if=fuente-lab.img \
```

```
   of=laboratorio/adquisiciones/ADQ-LAB-001.raw \
   bs=4M iflag=fullblock status=progress
sha256sum fuente-lab.img \
          laboratorio/adquisiciones/ADQ-LAB-001.raw
```

La comparación de hashes comprueba que los dos archivos contienen la misma secuencia de bytes para el algoritmo utilizado. No demuestra cómo fue creado `fuente-lab.img` ni que represente un dispositivo completo: esas garantías dependen de la trazabilidad del origen. Se recomienda que los ejemplos iniciales del laboratorio usen fuentes sintéticas o imágenes ya preparadas para evitar que un error de sintaxis afecte a un soporte real.

Para una unidad física, una herramienta específica de adquisición debe registrar los errores y el proceso de verificación. Si se utiliza dd en un dispositivo sano y protegido, los controles externos —identificación, bloqueo, cálculo de hash, registro de fallos y revisión de tamaño— deben completarse explícitamente. dd no convierte por sí solo una copia en procedimiento forense certificado.

5.3.9. Consulta y validación de una imagen EWF

En un laboratorio que emplee `libewf` se dispone de utilidades como `ewfinfo` y `ewfverify`. Su función es, respectivamente, consultar información del contenedor y realizar comprobaciones de consistencia y verificación según el formato soportado. La sintaxis debe consultarse en la versión instalada, y una verificación satisfactoria debe interpretarse de acuerdo con lo que la herramienta documenta realmente:

```
ewfinfo ADQ-2026-001.E01
ewfverify ADQ-2026-001.E01
```

Una comprobación de estructura interna no sustituye automáticamente la comparación con un hash del flujo leído originalmente, ni confirma que el dispositivo fuente se identificó correctamente. Puede ser una prueba sólida de que el contenedor almacenado conserva determinados datos y se reconstruye de forma consistente, pero la conclusión pericial debe mencionar la cobertura exacta de la verificación.

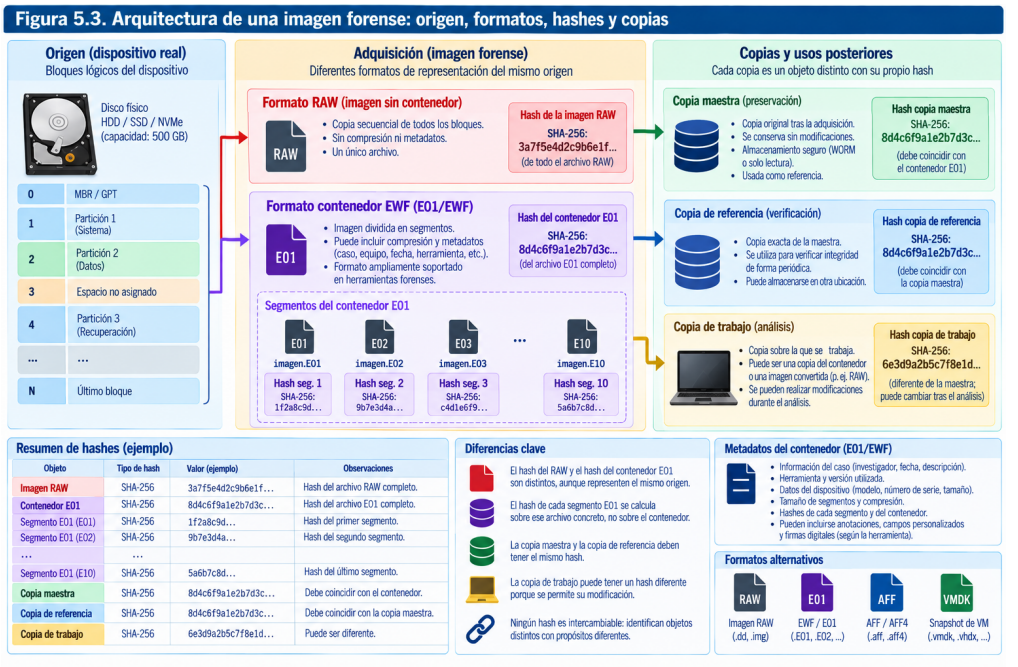


Figura 26: Arquitectura de una imagen forense.

5.3.10. Selección de formato en escenarios habituales

Una investigación de un puesto de trabajo con disco extraíble y buen estado puede optar por una imagen sectorial RAW o EWF, según la infraestructura de análisis y conservación. En un caso con necesidad de transferencia de varios terabytes, la compresión y segmentación pueden favorecer un contenedor que admita esos recursos. En el examen de un servidor crítico, puede resultar más viable una instantánea de volúmenes y la posterior exportación verificada, siempre que se entiendan sus garantías de coherencia. En un incidente cloud, un paquete original exportado mediante API será normalmente el objeto base que se deba custodiar.

Esta diversidad exige evitar la frase «hemos hecho una imagen forense» como si describiera por sí sola un procedimiento. El informe debería responder a las preguntas siguientes: ¿imagen de qué?, ¿obtenida por qué interfaz?, ¿con qué cobertura?, ¿mediante qué herramienta?, ¿en qué formato?, ¿con qué transformaciones?, ¿cómo se verificó?, ¿qué quedó excluido? Solo cuando esas respuestas están disponibles se puede valorar de manera fundada la utilidad de la adquisición.

5.4. Hashes y comprobación de integridad

5.4.1. Una huella criptográfica no es una cadena de custodia

Una función hash criptográfica transforma un conjunto de bytes de longitud arbitraria en un resumen de longitud fija. SHA-256, por ejemplo, produce un resultado de 256 bits que se representa habitualmente como 64 caracteres hexadecimales. Un pequeño cambio en los bytes de entrada producirá, con probabilidad abrumadora, un resumen distinto. Esta propiedad permite detectar alteraciones entre dos estados de un objeto digital.

El valor hash es una herramienta esencial de la informática forense, pero su interpretación requiere precisión. Si dos archivos tienen el mismo SHA-256 y han sido calculados correctamente, existe una evidencia técnica muy fuerte de que contienen los mismos bytes. Eso no significa que procedan de la misma fuente física, que sean lícitos, que todos los datos relevantes del dispositivo hayan sido adquiridos o que la persona investigada haya creado esos bytes. El hash no autentica por sí solo la identidad del operador ni el contexto de obtención. Tampoco reemplaza el registro de transferencias ni las autorizaciones.

Para que un hash tenga valor de control debe estar asociado al objeto exacto sobre el que se calculó, a un momento, a una herramienta y a un procedimiento. Un número escrito sin indicar si corresponde al disco, al volumen descifrado, al contenedor E01 o al fichero comprimido puede originar aparentes contradicciones durante la revisión.

5.4.2. Funciones hash y resistencia criptográfica

Las funciones utilizadas para verificar integridad deben ser apropiadas para el contexto y el periodo de conservación. MD5 y SHA-1 han formado parte de numerosos flujos de trabajo forense históricos, pero presentan debilidades criptográficas conocidas, especialmente en su resistencia a la generación deliberada de colisiones. No conviene emplearlas como única garantía de integridad en adquisiciones nuevas cuando se dispone de alternativas modernas. SHA-256 y otras funciones de la familia SHA-2 ofrecen una elección conservadora y ampliamente interoperable; SHA-3 es otra familia estandarizada que puede utilizarse donde exista soporte adecuado.

La colisión criptográfica es la existencia de dos entradas distintas con el mismo resumen. No equivale a que cualquier coincidencia entre hashes sea sospechosa ni a que la integridad de todas las pruebas históricas con MD5 sea automáticamente inválida. La relevancia del riesgo depende del algoritmo, del escenario de ataque, del control sobre los datos de entrada y de la forma en que se utiliza el hash. El criterio profesional consiste en elegir algoritmos adecuados y declarar las limitaciones, no en presentar el hash como un mecanismo infalible.

Utilizar dos algoritmos puede aportar compatibilidad con herramientas o repositorios que manejan formatos distintos, pero conviene priorizar al menos uno resistente a colisiones conocidas. Un informe puede incluir SHA-256 como valor de referencia y MD5 como identificador auxiliar por razones de interoperabilidad, aclarando que este último no sustituye la garantía ofrecida por el primero.

5.4.3. Hash de la fuente, de la adquisición y de la copia

En la práctica intervienen varias comparaciones posibles:

- El **hash del flujo fuente** puede calcularse durante la lectura desde el origen, cuando la herramienta lo soporta.
- El **hash del contenido adquirido** representa los bytes reconstruidos a partir de la imagen o exportación.
- El **hash del contenedor** identifica los bytes del fichero que guarda la adquisición, incluidas sus cabeceras, compresión y metadatos externos al flujo.
- El **hash de una copia de trabajo** permite confirmar la coincidencia con el objeto del que procede, cuando no se realizan transformaciones.
- El **hash por archivo** permite verificar individualmente objetos de una adquisición lógica; el conjunto requiere además un manifiesto completo, cobertura declarada y control de su estructura.

No todos los procedimientos pueden producir todos estos valores. En un dispositivo con sectores que cambian, errores de lectura o cifrado que presenta datos distintos entre sesiones, volver a leer el origen para calcular un segundo hash puede dar un resultado diferente sin que ello implique una manipulación. Por el contrario, dos hashes coincidentes calculados sobre una imagen incompleta no convierten los sectores ausentes en datos válidos. La verificación y la completitud son propiedades distintas.

5.4.4. Cuándo calcular los hashes

Una estrategia habitual consiste en calcular un valor durante la adquisición y otro al terminar sobre la representación adquirida. Posteriormente, se vuelve a comprobar la integridad antes de transferir, abrir para análisis o entregar la evidencia. El momento exacto depende de la técnica y de la estabilidad de la fuente.

Si la lectura original fue fiable y el dispositivo permaneció estable, la coincidencia entre la huella del flujo de origen y la de la imagen reconstruida refuerza la correspondencia. Si hubo

errores, la herramienta puede introducir rellenos, omisiones o marcas; entonces la comparación debe interpretarse a la luz del mapa de sectores legibles y de la política aplicada. Si la fuente es una plataforma en la nube, el primer valor fiable disponible puede ser el SHA-256 del paquete exportado al llegar al laboratorio, acompañado de un manifiesto del proveedor. No debe inventarse un hash «de origen» que nunca se calculó.

La integridad debe comprobarse también después de operaciones de mantenimiento, migración de repositorios o traslado a soportes de conservación. Un laboratorio que custodia grandes volúmenes de evidencias necesita una política verificable de comprobaciones periódicas, alertas de error y gestión de versiones, no una simple carpeta con ficheros y un listado de hashes guardado durante años.

5.4.5. Ejemplo: verificar una adquisición lógica

Supongamos que un departamento autorizado entrega tres archivos obtenidos de una carpeta corporativa: un PDF, un CSV de auditoría y un registro de accesos. El objetivo es preservar esos archivos tal como se recibieron. Para comprobar su integridad no es suficiente calcular un único hash sobre una carpeta, porque una carpeta no constituye por sí sola una secuencia de bytes definida de forma universal. Se puede crear un manifiesto con el nombre exacto y el SHA-256 de cada archivo, conservar ese manifiesto y verificar posteriormente el conjunto.

En un directorio de prueba con nombres sencillos, el procedimiento puede representarse así:

```
cd adquisicion-logica-lab
sha256sum documento.pdf auditoria.csv accesos.log \
    > manifiesto-sha256.txt
sha256sum -c manifiesto-sha256.txt
```

La salida permite comprobar la coincidencia entre los archivos presentes y los resúmenes consignados. En un caso real, se registrarían también el tamaño, la ruta original, los metadatos relevantes, la fecha de exportación, la identidad del exportador y cualquier transformación. Si los nombres contienen caracteres especiales, rutas complejas o miles de elementos, conviene utilizar herramientas de generación de manifiestos que definan inequívocamente la codificación, el escape de nombres y el orden. El manifiesto debe custodiarse y verificarse, por ejemplo mediante firma digital o mediante su incorporación a un repositorio con controles de integridad y auditoría.

El ejemplo revela una limitación importante. Si antes de crear el manifiesto se omitió uno de los archivos existentes en la fuente, la comprobación será correcta para los tres recibidos, pero no advertirá necesariamente la omisión. La validación criptográfica acredita la estabilidad de un conjunto definido; la evaluación de su exhaustividad requiere contrastar el procedimiento de obtención y el inventario esperado.

5.4.6. La importancia del tamaño, las rutas y la semántica

En una adquisición de imagen de disco, el tamaño esperado constituye una verificación básica. Una imagen que termina antes del último sector direccionable puede ser parcial. Sin embargo, una igualdad de tamaños tampoco demuestra identidad de contenido. De manera semejante, una coincidencia de hash de una copia no comprueba que esa copia sea el dispositivo correcto si el origen no se identificó adecuadamente.

En adquisiciones lógicas, los nombres de archivo, los directorios y los metadatos pueden ser tan relevantes como el contenido. Dos ficheros con el mismo SHA-256 pueden encontrarse en rutas distintas y haber sido usados en contextos diferentes. El hash del contenido no captura por sí mismo permisos, propietario, nombre, ruta ni la totalidad de los metadatos de sistema de archivos. Cuando estas propiedades importan, deben registrarse y verificarse por separado.

Hay asimismo diferencias entre el contenido lógico y la representación física. Un documento puede tener contenido idéntico aunque haya sido movido; un sistema de archivos puede actualizar su diario sin que cambien los bytes de un archivo; una exportación CSV puede representar los mismos registros que otra exportación y, sin embargo, diferir en codificación, salto de línea u orden de filas. En todos estos casos, los hashes responden a una pregunta limitada: si dos secuencias concretas de bytes coinciden, no si dos estados operativos son semánticamente equivalentes.

5.4.7. Errores de lectura, hashes parciales y discordancias

La aparición de una diferencia entre hashes obliga a investigar, no a atribuir de inmediato una manipulación. Las causas posibles incluyen una transferencia truncada, corrupción accidental, selección de un archivo distinto, cambio en la representación, descompresión incorrecta, segmentos faltantes, fallos de almacenamiento o modificaciones reales. La respuesta metodológica consiste en comprobar qué se comparó, repetir de forma controlada las verificaciones disponibles, analizar registros y conservar ambos valores con sus circunstancias.

No se debe alterar una evidencia para conseguir que «el hash cuadre». Tampoco resulta aceptable calcular únicamente el valor de un fichero alterado y sustituir el registrado inicialmente sin explicar la incidencia. Los resultados negativos forman parte de la historia de custodia y pueden ser necesarios para interpretar una conclusión. Si una adquisición original presentó errores y se realizó otra posteriormente, ambas deben conservar identificadores distintos; la segunda no borra el hecho de que la primera fuera incompleta.

Cuando solo se pudieron leer determinadas regiones, puede calcularse un hash sobre cada región o sobre el fichero resultante, pero debe declararse la cobertura. La huella no permite inferir los bytes de las regiones ilegibles. La documentación del mapa de errores y de la política de relleno resulta crucial para evitar que los programas de análisis interpreten como datos originales los ceros presentes en los huecos de un rescate.

5.4.8. Firmas digitales, sellado temporal y hashes

Un hash puede incorporarse a un documento firmado digitalmente o registrarse en un sistema de sellado temporal. Estas técnicas añaden propiedades diferentes. La firma puede vincular una declaración a una identidad o clave bajo un esquema de confianza, mientras que un sello temporal confiable puede respaldar la existencia de determinado resumen en un momento. Ninguna de ellas demuestra por sí sola que el contenido proceda del dispositivo indicado ni que la adquisición haya sido exhaustiva; esas propiedades siguen dependiendo del procedimiento y sus registros.

En una organización es útil distinguir entre tres preguntas: ¿los bytes se han mantenido íntegros?, ¿quién documentó o aprobó la actuación?, ¿desde cuándo existe una determinada representación registrada? El hash, la firma y el sello temporal atienden parcialmente a estas preguntas desde planos técnicos diferentes. Su combinación mejora la auditabilidad cuando se aplica correctamente, pero no transforma una obtención no autorizada o un dato mal atribuido en una evidencia concluyente.

5.4.9. Árboles de hashes y grandes conjuntos de datos

Cuando las adquisiciones contienen muchos ficheros o grandes cantidades de bloques, resulta conveniente usar esquemas de verificación por fragmentos. En lugar de depender exclusivamente de un único resumen del conjunto, se pueden calcular hashes por segmento y construir estructuras de agregación, como árboles de Merkle. Estos mecanismos permiten localizar qué parte de un conjunto ha cambiado sin releer siempre la totalidad para identificar la discrepancia. También facilitan ciertos procesos de transferencia y verificación distribuidos.

Su utilidad no elimina la necesidad de conocer el criterio de fragmentación, el orden de los elementos y las reglas de composición. Dos conjuntos que contienen idénticos archivos pero siguen órdenes distintos pueden generar raíces diferentes. Si el árbol se construye sobre bloques, modificar el tamaño de bloque o la estructura de empaquetado cambia el resultado aunque determinados contenidos de interés se conserven. Un protocolo de verificación debe documentar el algoritmo completo, no solo la raíz final.

5.4.10. Detección de errores y autenticidad: una distinción final

Es frecuente leer que una evidencia «es auténtica porque su hash coincide». La coincidencia demuestra que el objeto verificado coincide en bytes con la referencia empleada, dentro de las garantías del algoritmo y de la operación. La autenticidad en una investigación abarca además la procedencia, las condiciones de obtención, la identidad y el control de la fuente, los posibles cambios anteriores a la adquisición y la correspondencia entre el objeto y el hecho investigado.

El informe debe evitar tanto el exceso de confianza como el escepticismo indiscriminado. Un hash correctamente calculado y custodiado proporciona una garantía técnica importante; negar su utilidad sería incorrecto. Atribuirle capacidades que no posee también lo sería. La práctica profesional consiste en integrar la comprobación de integridad dentro de una cadena de afirmaciones verificables, desde la fuente identificada hasta el resultado presentado.

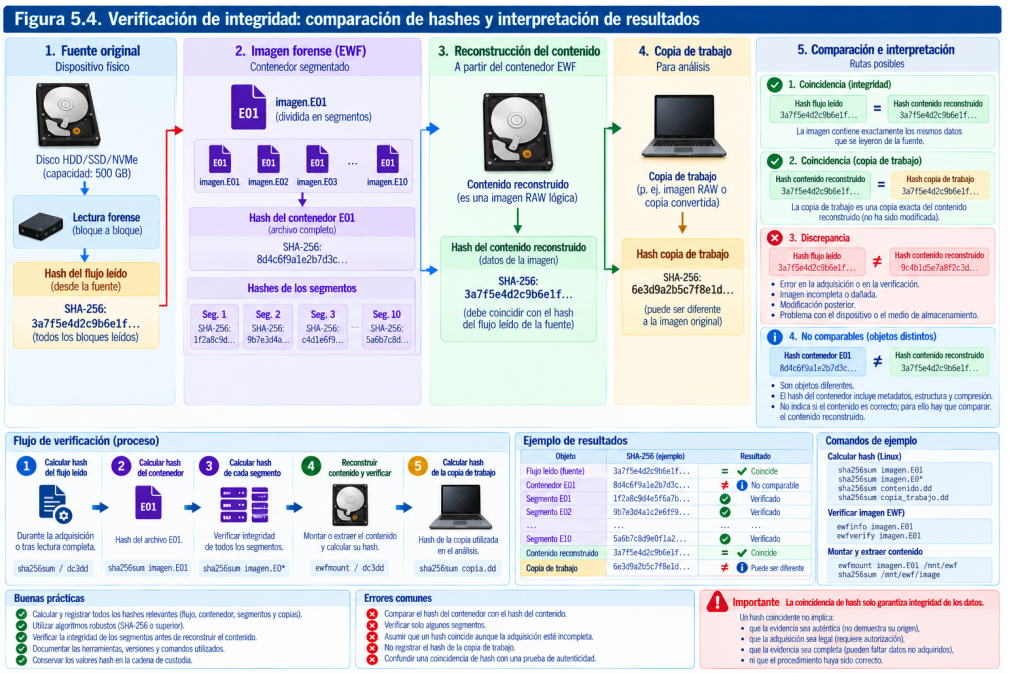


Figura 27: Mapa de verificación de integridad

5.5. Particularidades de HDD, SSD, cifrado y sistemas dañados

5.5.1. El soporte físico condiciona lo que puede recuperarse

El análisis de evidencias almacenadas comienza a menudo con una abstracción cómoda: un dispositivo que entrega una secuencia ordenada de sectores. Esa abstracción es suficiente para muchas tareas, pero oculta diferencias fundamentales entre tecnologías. Un disco duro magnético, una unidad SSD SATA, un SSD NVMe, una memoria USB de bajo coste y un volumen virtual sobre almacenamiento distribuido pueden presentar una interfaz aparentemente similar y comportarse de manera muy distinta ante lecturas, borrados, pérdidas de alimentación o comandos de mantenimiento.

La identificación correcta de la tecnología no es una curiosidad de inventario. Determina qué mecanismos de adquisición pueden utilizarse, cuáles son los riesgos de daño, qué datos cabe esperar en las zonas no asignadas y cómo interpretar una ausencia. También puede cambiar el sentido de una intervención: extraer una unidad física de un equipo para conectarla al laboratorio es viable en algunos ordenadores, pero imposible o perjudicial en otros

que integran almacenamiento, controladora y claves criptográficas en una misma arquitectura.

En una investigación profesional no debe confundirse el procedimiento que se sabe ejecutar con el procedimiento que más conserva. El analista necesita conocer suficientemente el soporte para explicar qué propiedades del medio pueden influir sobre el resultado.

5.5.2. Discos magnéticos: sectores, remapeos y datos residuales

En un HDD convencional los datos se almacenan mediante estados magnéticos sobre platos, administrados por una controladora. El sistema anfitrión accede normalmente a direcciones lógicas de bloque; no controla directamente la disposición física de los sectores. El firmware puede reasignar sectores defectuosos a áreas de reserva y ocultar ese remapeo al sistema operativo. Por tanto, una imagen completa del espacio lógico del disco no equivale siempre a la extracción de todas las regiones físicas que existen en su interior.

Los HDD siguen siendo especialmente relevantes para recuperar archivos eliminados porque la eliminación lógica suele afectar primero a metadatos y a la asignación de espacio, sin implicar necesariamente una sobreescritura inmediata del contenido. Si los sectores de un archivo borrado continúan intactos y accesibles, pueden ser recuperables mediante el sistema de archivos, sus estructuras auxiliares o técnicas de *file carving*. Esta posibilidad no constituye una garantía: el uso posterior del disco, las tareas automáticas, la fragmentación, la compresión, el cifrado y los fallos físicos pueden reducir o eliminar el contenido disponible.

La estabilidad mecánica merece especial atención. Un HDD que presenta ruidos anómalos, errores crecientes o problemas de reconocimiento puede deteriorarse durante una adquisición intensiva. Cada nuevo ciclo de encendido y cada lectura de una zona dañada puede incrementar el riesgo. Ante síntomas claros de avería física, la primera obligación es evaluar si el caso requiere un laboratorio especializado en recuperación de soportes, no insistir repetidamente con una herramienta general hasta agotar la unidad.

Una intervención no especializada puede convertir una avería parcial en una pérdida irreversible. Abrir el conjunto mecánico, sustituir componentes sin condiciones adecuadas o ejecutar utilidades de reparación sobre el origen compromete tanto los datos como la explicación técnica de lo sucedido. La prioridad debe ser obtener la mejor representación posible del soporte con una estrategia de lectura proporcional al estado del dispositivo.

5.5.3. SSD: controladora, FTL, TRIM y recogida de basura

En una unidad SSD, los datos residen en memoria flash gestionada por una controladora que traduce bloques lógicos en páginas físicas. Esta capa, habitualmente denominada FTL (*Flash Translation Layer*), permite distribuir escrituras, gestionar bloques defectuosos y efectuar tareas de mantenimiento. El sistema anfitrión no ve necesariamente la ubicación física real de un sector lógico y no puede asumir que cada dirección permanezca vinculada al mismo conjunto de celdas a lo largo del tiempo.

El mecanismo TRIM y sus equivalentes según la interfaz permiten que el sistema operativo informe a la unidad de qué rangos lógicos ya no contienen datos que el sistema de archivos considere necesarios. Después de recibir esa información, la controladora puede tratar el contenido correspondiente como descartable y gestionar sus páginas mediante sus procesos internos. El resultado observable varía entre unidades, controladoras, sistemas de archivos y estados de funcionamiento. Algunas lecturas posteriores de rangos descartados pueden devolver ceros u otro comportamiento documentado por el dispositivo; en otros contextos, pueden observarse diferentes respuestas. No existe un plazo universal que permita afirmar que todos los archivos borrados se destruyen de inmediato, pero tampoco es legítimo prometer que permanecerán recuperables hasta una sobrescritura visible.

La recogida de basura (*garbage collection*) reorganiza internamente la memoria para disponer de bloques reutilizables. Estas operaciones ayudan al rendimiento y a la vida útil del SSD, pero complican la inferencia forense sobre estados físicos anteriores. La posibilidad de desactivar TRIM en el sistema operativo no recupera automáticamente datos ya descartados, ni garantiza que la unidad detenga todas sus tareas internas. El analista debe registrar el tipo de dispositivo, su interfaz y las condiciones conocidas, y evitar conclusiones categóricas basadas exclusivamente en que un archivo borrado no aparece en la imagen.

En ciertos entornos pueden existir instantáneas, versiones anteriores, copias de seguridad, registros o datos replicados que documenten el contenido perdido. La investigación de un borrado en SSD debe considerar esas fuentes alternativas desde el principio, en lugar de concentrarse únicamente en técnicas clásicas de recuperación de sectores. La ausencia de restos en el espacio lógico no demuestra que el archivo nunca existiera ni que fuera borrado por una persona concreta.

5.5.4. NVMe, unidades externas y adaptadores

NVMe es un protocolo concebido para acceder a almacenamiento no volátil con baja latencia, habitualmente a través de PCI Express. Aunque un SSD NVMe comparte con otros SSD los problemas de la FTL y de la gestión del borrado, su adquisición plantea particularidades de

conectividad, comandos, nombres de dispositivo y compatibilidad de herramientas. No es apropiado asumir que un adaptador diseñado para SATA protegerá una unidad NVMe por el mero hecho de que ambos sean «discos».

Los puentes USB añaden otra capa de comportamiento. Un adaptador puede ocultar o modificar el número de serie presentado al anfitrión, limitar el acceso a comandos específicos o transformar determinadas respuestas. La presencia de una unidad detrás de USB no informa por sí sola de la tecnología interna. Algunas memorias externas incorporan además cifrado en la carcasa o en la controladora; retirar el disco interno y conectarlo mediante otro adaptador puede producir bytes aparentemente ininteligibles aunque no exista ninguna contraseña adicional introducida por el usuario en ese momento.

El registro de adquisición debe identificar el conjunto utilizado: unidad, carcasa, cableado relevante, adaptador, estación forense y modo de conexión. Si un cambio de interfaz produce un tamaño o una identidad diferente, esa discrepancia debe investigarse antes de continuar. La normalidad aparente de una operación de lectura no sustituye la comprobación de que se están adquiriendo los bloques esperados.

5.5.5. Cifrado completo de disco: dos representaciones posibles

El cifrado completo de disco protege los datos almacenados frente a accesos que no dispongan de las claves correspondientes. Entre las soluciones habituales se encuentran BitLocker en Windows, FileVault en macOS y configuraciones basadas en LUKS o dm-crypt en Linux. Sus arquitecturas difieren, y algunas combinan contraseñas de usuario, claves de recuperación, módulos TPM o componentes de seguridad integrados. La adquisición debe tener en cuenta tanto la existencia del cifrado como el estado del sistema en el momento de intervenir.

Si se obtiene una imagen de bloques de la unidad apagada, es posible que gran parte del contenido aparezca cifrado. Esa imagen puede ser valiosa porque conserva una representación del soporte y permite posteriores intentos legítimos de descifrado cuando se obtienen las credenciales o claves adecuadas. Sin embargo, no es equivalente a una imagen del volumen ya descifrado. Si, en cambio, se adquiere un volumen montado y accesible a través de un sistema activo, el resultado puede contener datos en claro que la unidad física almacena cifrados. Esta segunda representación depende de la capa de descifrado y puede excluir partes del dispositivo que queden fuera de ese volumen.

La actuación debe intentar preservar las dos perspectivas cuando sean relevantes y viables dentro del alcance. El momento es crítico: apagar o reiniciar el dispositivo puede cerrar una sesión y destruir información necesaria para mantener el acceso. La captura de datos en vivo,

las claves de recuperación facilitadas por el titular autorizado o los mecanismos empresariales de gestión del cifrado pueden ser alternativas. Cualquier manipulación de credenciales, acceso a datos descifrados o exportación de claves está sujeta a autorización, proporcionalidad y procedimientos específicos de protección.

Un informe correcto describiría, por ejemplo, que «se adquirió el volumen lógico descifrado mediante la sesión autorizada activa y, posteriormente, se conservó una imagen de bloques cifrada de la unidad física». Esta formulación es mucho más informativa que «se copió el disco» y permite entender por qué los hashes de ambas representaciones no coinciden.

5.5.6. Cifrado por archivo, contenedores cifrados y datos en uso

El cifrado puede estar limitado a carpetas, archivos, bases de datos o contenedores virtuales. En esos casos, un disco aparentemente no cifrado puede conservar archivos cifrados cuya interpretación dependa de una contraseña, una clave guardada en un gestor de secretos o una sesión de aplicación. También pueden existir claves temporales o materiales de autenticación que solo estén disponibles mientras se ejecuta un proceso.

Adquirir un archivo cifrado y obtener su versión descifrada son actuaciones diferentes. Ambas pueden ser pertinentes: la primera conserva la representación original visible en el soporte; la segunda permite examinar el contenido al que tenía acceso una aplicación. La obtención de la segunda puede requerir ejecutar software, introducir credenciales o usar mecanismos de exportación que alteran metadatos. Deben registrarse el alcance, la herramienta, las autorizaciones y el resultado de esas transformaciones.

El investigador no debe almacenar contraseñas o claves en texto claro dentro de los informes generales si ello no es indispensable. Los secretos se custodiarán con controles reforzados, separando las copias operativas de la documentación destinada a terceros. En una investigación corporativa, la capacidad técnica para acceder a material cifrado no elimina las limitaciones de privacidad ni permite ampliar por iniciativa propia la inspección a cuentas personales o espacios ajenos a la finalidad autorizada.

5.5.7. Errores de lectura y dispositivos parcialmente dañados

Una adquisición perfecta exige que los bloques seleccionados puedan leerse de manera fiable. Cuando el dispositivo devuelve errores, la herramienta puede detenerse, omitir regiones o aplicar un criterio de relleno. La elección tiene consecuencias técnicas y probatorias: una imagen incompleta puede ser el mejor resultado posible, pero debe describirse como tal y conservar un mapa preciso de los intervalos no recuperados.

La herramienta GNU `ddrescue` está diseñada para rescatar datos desde medios que presentan errores de lectura. Permite trabajar con un archivo de mapa (*mapfile*) que registra el estado de los bloques y facilita reanudar la recuperación y concentrar reintentos donde tienen sentido. No es un sustituto automático de una estación forense ni de un procedimiento de preservación; su utilidad está en gestionar de forma controlada un problema concreto de lectura. El manual oficial recomienda utilizar el mapa y advierte expresamente contra reparar un sistema de archivos dañado sobre el soporte fuente.

En un entorno de laboratorio sin evidencia real, el principio de funcionamiento puede ilustrarse con un dispositivo sintético preparado y un destino vacío:

```
# Ejemplo exclusivamente de laboratorio.
# El archivo de origen es una imagen de ensayo, no un dispositivo real.
mkdir -p laboratorio/rescate

ddrescue -n fuente-danada-lab.img \
    laboratorio/rescate/ADQ-LAB-RESCATE.raw \
    laboratorio/rescate/ADQ-LAB-RESCATE.map
```

La opción `-n` realiza una primera pasada evitando determinadas operaciones intensivas de recuperación. El mapa conserva información necesaria para valorar los segmentos obtenidos y las áreas pendientes. Si se plantean reintentos, deben justificarse según el estado del dispositivo y el riesgo de degradación; no conviene establecer automáticamente un número elevado sobre soportes físicamente inestables.

Conviene conservar tanto la imagen como el mapa, los registros de ejecución y un resumen del estado de recuperación. Al reutilizar un mapa debe asegurarse que corresponde al mismo origen y a la misma imagen de salida; aplicar el archivo de mapa equivocado puede invalidar las expectativas del rescate. Un hash de la imagen resultante sirve para verificar su conservación posterior, pero no demuestra que los sectores ilegibles hayan sido recuperados.

5.5.8. Qué hacer con los sectores no recuperados

Cuando una lectura falla, el archivo de salida puede presentar ceros u otros bytes preexistentes, según el modo de trabajo, el destino y la herramienta. No se debe asumir que esos bytes proceden de la fuente. En particular, un destino previamente utilizado puede contener información antigua en las regiones que no hayan sido sobrescritas durante la recuperación. Esta posibilidad obliga a controlar el estado inicial del destino y a interpretar conjuntamente la imagen y el mapa de lectura.

Si en el informe se utiliza una imagen con áreas no recuperadas, es necesario cuantificarlas de forma proporcional: número de regiones, tamaño total estimado, posiciones afectadas y consecuencias previsibles para los sistemas de archivos. No basta con escribir «la imagen se completó con algunos errores». Si un archivo importante atraviesa un sector ilegible, una herramienta de análisis puede mostrarlo parcialmente y, en algunos casos, representar su contenido restante con ceros. Ese archivo no es necesariamente idéntico al original.

La transparencia sobre los errores permite seguir analizando las zonas recuperadas sin formular afirmaciones más amplias de lo que permite la evidencia. Un disco dañado no hace inútil todo el caso, pero obliga a ajustar el alcance de las conclusiones. Este principio es especialmente importante cuando se utilizan hashes: la verificación de la imagen reconstruida y la integridad de los datos realmente recuperados no deben confundirse con la integridad de lo que nunca pudo leerse.

5.5.9. RAID, volúmenes lógicos y almacenamiento distribuido

En sistemas corporativos es habitual que una unidad lógica esté construida sobre varios soportes físicos. RAID, LVM, Storage Spaces, pools ZFS, plataformas de virtualización y sistemas distribuidos introducen una separación entre discos, volúmenes y objetos visibles. La adquisición de un único disco miembro puede no contener datos interpretables de forma autónoma. También puede faltar información relevante si se copian únicamente los archivos expuestos por el volumen y no las estructuras que describen su configuración.

El analista debe identificar la arquitectura antes de separar componentes. Registrar el orden de discos, sus números de serie, la configuración de la controladora, el tamaño de bloques o *stripe*, los parámetros del pool y las versiones de software puede ser esencial para reconstruir el conjunto. Extraer y conectar discos sin documentar su posición puede dificultar o impedir la recuperación de la estructura original. Algunas configuraciones pueden volverse inconsistentes si se desmontan sin coordinación o si el sistema continúa operando mientras se obtienen imágenes individuales.

Las instantáneas de sistemas de archivos o de hipervisores ofrecen alternativas operativas, pero debe conocerse su semántica. Una instantánea de almacenamiento puede representar un punto de consistencia del sistema de archivos, un estado coordinado con aplicaciones o, en situaciones menos favorables, un conjunto de bloques capturado sin garantizar coherencia transaccional de todas las aplicaciones. Una instantánea de disco de una máquina virtual no incluye necesariamente memoria RAM, conexiones activas, registros externos ni discos no gestionados por la misma plataforma.

La elección entre imagen física de miembros, adquisición del volumen lógico, instantánea y exportación de la máquina dependerá del objetivo. Si se investiga corrupción de metadatos RAID, los discos miembros pueden ser fundamentales. Si se necesita reconstruir una acción de usuario sobre un recurso de trabajo, una instantánea coherente del volumen y sus registros puede resultar más útil y menos disruptiva. Como en todo el capítulo, la denominación de la técnica debe reflejar lo que realmente se ha conservado.

5.5.10. Sistemas en producción y coherencia de los datos

La adquisición de un sistema que sigue escribiendo presenta un problema de consistencia. Si una imagen se genera durante varias horas, los bloques adquiridos al principio pueden reflejar un estado distinto de los bloques leídos al final. El resultado no representa necesariamente un punto temporal atómico. Los riesgos se incrementan en bases de datos, máquinas virtuales, sistemas de archivos con mucha actividad y servidores con escrituras concurrentes.

Las tecnologías de instantáneas y los mecanismos de consistencia de aplicación buscan reducir este problema. En Windows pueden intervenir servicios como VSS; en sistemas Linux pueden utilizarse mecanismos de instantánea del volumen o del sistema de archivos; en entornos de base de datos existen exportaciones consistentes y métodos coordinados con registros de transacciones. Cada mecanismo tiene requisitos, efectos y limitaciones. Una copia de archivos abiertos realizada sin coordinación puede contener estados intermedios imposibles de reproducir después.

La consistencia del origen en un momento y la integridad de la imagen conservada son propiedades diferentes. Una imagen puede estar intacta y representar fielmente una lectura realizada sobre datos que estaban cambiando. En ese caso el hash puede verificarse perfectamente, pero el conjunto puede no corresponder a una transacción lógica coherente. La documentación debe indicar si se suspendieron escrituras, se utilizó una instantánea, se aplicó un modo de solo lectura o se realizaron exportaciones consistentes con mecanismos de aplicación.

5.5.11. La nube y los soportes que nunca llegan al laboratorio

En servicios cloud, el investigador suele adquirir objetos lógicos, no discos de infraestructura compartida. Las copias de seguridad y las instantáneas pueden existir bajo gestión del proveedor, mientras que el cliente solo puede solicitar exportaciones o actuar sobre recursos que administra. Deben identificarse qué datos están dentro del control contractual, qué

información requiere cooperación del proveedor y qué solicitud exige autorizaciones adicionales o cauces legales.

La localización lógica del recurso, la región contractual y la ubicación efectiva de réplicas pueden no coincidir. Este hecho afecta a la obtención y a la jurisdicción, pero también a la integridad y la consistencia. Una operación de exportación de millones de objetos podría durar mucho tiempo y mezclar versiones de diferentes momentos si no se establece un punto de referencia o una instantánea. Algunas APIs devuelven identificadores de versión, ETags o checksums que ayudan a correlacionar objetos; no debe asumirse que todos los ETags constituyen hashes criptográficos del contenido, pues su significado puede variar con el servicio y el método de subida.

Una estrategia adecuada comprende la conservación del paquete original, el manifiesto de objetos y versiones, los parámetros de la consulta y los registros de transferencia. Si el proveedor facilita un informe de generación o de conservación legal, debe incorporarse al expediente con su procedencia. La ausencia de acceso al soporte físico no invalida la adquisición lógica; simplemente define un límite que debe explicarse.

5.5.12. Eliminación segura y funciones de saneamiento: una advertencia esencial

Las herramientas y normas de saneamiento de soportes persiguen hacer inviable la recuperación de datos en determinados contextos. Su finalidad es distinta y, en ocasiones, opuesta a la preservación forense. Comandos de borrado seguro, *sanitize*, *crypto erase*, recreación de sistemas de archivos y utilidades de reparación pueden alterar irreversiblemente el contenido que se pretende investigar. No deben ejecutarse sobre una evidencia original como paso rutinario de adquisición.

La guía NIST SP 800-88 Rev. 2, publicada en 2025, trata sobre **saneamiento de medios**, no sobre cómo recuperar información borrada. Puede ayudar a comprender por qué ciertas operaciones diseñadas para eliminación de datos dificultan la recuperación posterior y a definir la disposición final autorizada de los soportes. No debe citarse como si garantizara resultados de recuperación o describiera una técnica universal para SSD.

Cuando se decide devolver o destruir una evidencia al final del periodo de conservación, el procedimiento de saneamiento queda sujeto a obligaciones legales y políticas de custodia que deben documentarse. Esa etapa pertenece al ciclo de vida del objeto, pero no forma parte de la adquisición técnica inicial.

5.5.13. Caso práctico: un portátil cifrado con SSD y sincronización cloud

Una empresa investiga la posible extracción de información confidencial desde un portátil con SSD NVMe y cifrado de disco. El sistema está encendido, una sesión corporativa permanece abierta y una herramienta de sincronización conecta el equipo con un repositorio SaaS. El analista dispone de autorización para conservar datos profesionales relevantes y los registros corporativos relacionados con una ventana temporal delimitada.

El primer riesgo es perder estados efímeros al apagar el ordenador. El segundo es que el dispositivo continúe modificando registros o recibiendo órdenes remotas. El tercero consiste en que una imagen física obtenida posteriormente muestre únicamente bytes cifrados y no permita acceder a la misma representación que estaba visible durante la sesión. El cuarto es depender exclusivamente de la copia local cuando el historial de versiones y los accesos al repositorio residen en la nube.

La respuesta no consiste necesariamente en una operación única. Es razonable documentar el estado inicial, valorar la contención de comunicaciones, preservar los registros externos con ayuda de sus administradores autorizados y estudiar una adquisición en vivo de elementos que solo existen mientras funciona el sistema. Antes de apagar, debe decidirse si hay material criptográfico o información relevante que no podrá recuperarse después. Si se dispone de mecanismos legítimos de recuperación del cifrado, una imagen de bloques fuera de línea puede complementar la adquisición lógica realizada desde el entorno activo.

En la documentación deberían figurar dos distinciones. La primera es técnica: el volumen descifrado, la imagen cifrada del soporte y la exportación del proveedor son representaciones diferentes, aunque estén relacionadas con un mismo equipo o usuario. La segunda es temporal: el momento de creación de la imagen, el de los archivos contenidos y el de los accesos investigados pertenecen a cronologías distintas. Un hash de la imagen física no puede compararse directamente con el del volumen descifrado; cada uno verifica su propia secuencia.

Supongamos que una búsqueda posterior no encuentra fragmentos de los archivos eliminados en el espacio no asignado del SSD. Ese resultado no demuestra que nunca se copiaron ni que alguien aplicó necesariamente una técnica antiforense. El comportamiento de TRIM, las escrituras posteriores y los mecanismos de sincronización son explicaciones posibles. Para establecer qué ocurrió habrá que correlacionar registros de acceso, historial de versiones, archivos locales, dispositivos conectados y cualquier otra fuente obtenida lícitamente.

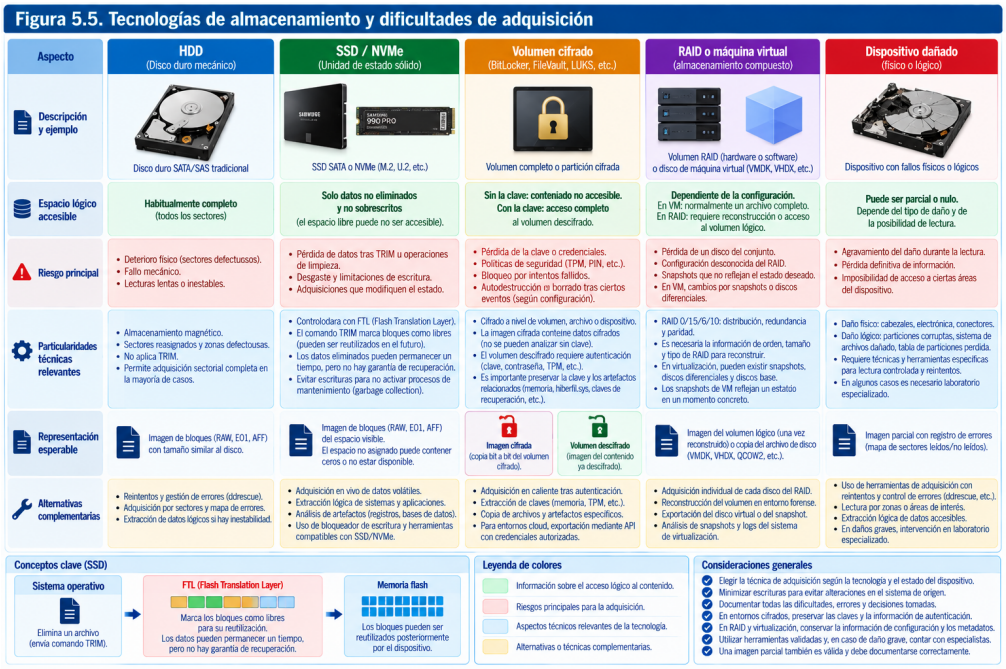


Figura 28: Esquema comparativo de tecnologías y dificultades de adquisición.

5.6. Documentación del procedimiento de adquisición

5.6.1. Documentar para hacer verificable la actuación

El trabajo de adquisición no finaliza cuando la herramienta anuncia que ha terminado. Finaliza, en términos profesionales, cuando se han comprobado los resultados, conservado los registros, identificado el objeto obtenido y documentado de manera suficiente el proceso para que otra persona cualificada pueda evaluarlo. Una evidencia cuyos bytes se conservan intactos puede perder gran parte de su utilidad si no se sabe de qué fuente procede, si el rango de bloques está definido o si los errores de lectura se resolvieron o simplemente se ignoraron.

La documentación no se reduce al informe final. Comprende registros contemporáneos elaborados durante la intervención, identificadores de origen y destino, fotografías, salidas de herramientas, manifiestos de archivos, referencias de versiones de software, constancia de autorizaciones y un historial de transferencias. Es habitual que estas piezas se distribuyan en varios documentos y sistemas; lo importante es que permanezcan vinculadas mediante identificadores inequívocos.

El objetivo práctico de un expediente de adquisición es que un revisor pueda responder sin recurrir exclusivamente al recuerdo del operador: qué se pretendía conservar, cuál era el origen, qué se hizo, cuándo y bajo qué condiciones, qué se obtuvo, qué incidencias aparecieron, qué verificaciones se realizaron y dónde quedó depositado el resultado. Esta disciplina protege la calidad del examen incluso cuando no existe controversia judicial, porque facilita la detección de errores, la continuidad entre turnos de analistas y la reproducción de resultados.

5.6.2. Identificadores: caso, origen, adquisición y copia

Una investigación puede contener decenas de equipos, múltiples volúmenes por equipo, varias adquisiciones de una misma fuente y numerosas copias. Utilizar un único identificador para todas esas entidades crea ambigüedad. Es aconsejable separar, al menos, el **identificador de caso**, el **identificador del objeto o fuente**, el **identificador de adquisición** y el **identificador de copia**.

Por ejemplo, el caso `CAS-2026-014` puede contener un portátil `OBJ-2026-014-03`. De ese portátil pueden obtenerse una captura de memoria `ADQ-2026-014-07` y una imagen del disco `ADQ-2026-014-08`. La copia de trabajo de la imagen puede quedar registrada como `TRB-2026-014-08-A`. La relación entre estos elementos impide confundir el disco intervenido con el archivo producido o asumir que dos adquisiciones son versiones intercambiables de una misma secuencia de bytes.

También es útil registrar los números de precinto de los embalajes físicos, sin mezclarlos con los identificadores de imagen. Un precinto documenta un mecanismo de control sobre el acceso al paquete; no describe el hash de los bytes contenidos en una imagen. Del mismo modo, los números de serie de fabricación ayudan a identificar un dispositivo, pero no sustituyen al identificador de evidencia asignado por el laboratorio, especialmente cuando hay varios soportes de igual modelo o algunos carecen de serial fiable.

El sistema de identificación debe admitir excepciones. Una adquisición remota puede no tener ningún precinto; una exportación cloud puede proceder de una cuenta lógica sin soporte físico intervenido; un conjunto RAID puede componerse de varias unidades que comparten un volumen lógico. Forzar todas las evidencias a un formulario diseñado exclusivamente para discos externos oculta información. Lo correcto es un modelo flexible con tipos de objetos relacionados.

5.6.3. Estado inicial y condiciones de acceso

Antes de adquirir, el analista documenta el estado observado del origen. En un soporte extraíble interesan el modelo, serie, interfaz, capacidad presentada, estado físico, precintos, conexiones y eventual daño. En un sistema encendido se registran, según el alcance, la hora observada, la sesión abierta, las conexiones, el estado del cifrado, los procesos relevantes, las unidades montadas y las medidas de contención aplicadas. En una fuente remota se consignan la cuenta o recurso, el ámbito administrativo, la región o entorno, la identidad autorizada utilizada y las condiciones de acceso.

Debe distinguirse entre observación y explicación. Es una observación documentable que un volumen se encontraba montado como descifrado a determinada hora. Es una inferencia que había permanecido descifrado durante los días anteriores. Registrar la primera no autoriza automáticamente la segunda. Esta separación, ya examinada al estudiar el valor de las evidencias digitales, se mantiene durante toda la adquisición.

La documentación también recoge el reloj y la zona horaria. Un timestamp en formato UTC no debe mezclarse sin aviso con una hora local; tampoco es correcto convertir todas las marcas a la zona horaria del examinador y perder la representación original. Cuando se utilice una fuente temporal externa, se indicará cuál; si el equipo investigado presenta un desfase conocido, se registrará como observación. Una diferencia horaria puede condicionar la correlación futura entre logs, archivos y operaciones de laboratorio.

5.6.4. Registro de la herramienta y de sus parámetros

No basta con escribir «se utilizó software forense». La herramienta debe identificarse por nombre, versión y, cuando sea relevante, compilación o distribución. Deben consignarse también el sistema donde se ejecutó, sus componentes de captura, los parámetros significativos y el formato de salida. En adquisiciones automatizadas puede resultar útil conservar el fichero de configuración o la invocación completa, revisando previamente que no exponga credenciales o secretos innecesarios.

La configuración influye en el resultado. Elegir la unidad completa o una partición; incluir o excluir espacio no asignado; utilizar compresión; establecer tamaños de segmento; activar el tratamiento de errores; seleccionar algoritmos de hash; o habilitar determinados filtros cambia los datos obtenidos o la forma en que quedan representados. Una persona distinta no podrá reproducir razonablemente la operación si solo dispone del nombre de la aplicación.

El registro puede incluir información que la herramienta produce automáticamente: inicio y fin, número de bytes adquiridos, sectores con errores, velocidades, mensajes, hashes y resultado de la verificación. Estos registros deben incorporarse tal como fueron generados, preferiblemente como archivos originales, y relacionarse con el informe narrativo. Si se resume una salida extensa, el resumen no debería sustituir al registro completo cuando este sea relevante para una revisión posterior.

5.6.5. Incidencias y desviaciones

En adquisiciones reales aparecen situaciones no previstas: una unidad se desconecta, la batería cae, el proveedor interrumpe una exportación, un disco informa sectores ilegibles, una captura de memoria provoca inestabilidad o una sesión se cierra durante la intervención. El impulso de presentar un procedimiento impecable puede tentar al operador a excluir esas incidencias del informe. Es un error. La credibilidad de una adquisición aumenta cuando sus limitaciones se describen de forma verificable y proporcionada.

Cada incidencia debería registrar su momento, el síntoma observable, la herramienta que lo detectó, la decisión adoptada, la autorización necesaria y las consecuencias para el resultado. No todo error exige invalidar por completo la adquisición, pero sí entender su alcance. Si una exportación remota se reanuda tras una interrupción, debe comprobarse que los rangos o páginas solicitadas no hayan quedado duplicados u omitidos. Si la imagen de un disco contiene sectores ilegibles, deben conservarse las posiciones y el criterio utilizado para completar el archivo de salida.

La decisión de repetir puede tener riesgos. Una segunda lectura de un dispositivo físicamente deteriorado puede empeorar la situación; una segunda exportación cloud puede reflejar un estado distinto del primero; una segunda captura de RAM no es idéntica a la inicial porque el sistema continúa ejecutándose. Repetir no equivale necesariamente a reproducir, y una adquisición posterior debe recibir su propio identificador cuando represente un nuevo estado u operación independiente.

5.6.6. La ficha de adquisición: un modelo de referencia

El siguiente modelo puede adaptarse a un procedimiento operativo interno. Está deliberadamente diseñado para distinguir campos que en la práctica suelen confundirse. No constituye un formulario oficial ni sustituye los requisitos de custodia aplicables a cada organización.

Campo	Contenido a registrar
Caso e intervención	Identificador, referencia de encargo, autoridad o responsable que solicita
Autorización y alcance	Base de actuación, fecha, sistemas o datos incluidos, exclusiones, cambios aprobados
Fuente	Identificador del objeto, origen físico o lógico, titularidad o unidad responsable
Estado inicial	Encendido/apagado, cifrado, montaje, conexión, daños, observaciones, fotografías
Identificación técnica	Modelo, serie, capacidad, interfaz, ruta o identificador cloud, zona/región si procede
Modalidad	Física de bloques, lógica, remota, en vivo, instantánea, exportación por API
Herramienta	Nombre, versión, sistema anfitrión, configuración, parámetros significativos
Protección	Bloqueo de escritura, modo solo lectura, control de acceso, límites de intervención
Fechas y responsables	Inicio y fin, zona horaria, ejecutor, testigos o revisores si los hay
Destino	Identificador de adquisición, formato, estructura, ruta de custodia y capacidad
Cobertura	Rango de bloques u objetos, filtros, periodos, exclusiones y criterios utilizados
Integridad	Algoritmos, hashes del objeto definido, momento de cálculo y resultados de comparación
Errores	Sectores ilegibles, API fallida, interrupciones, reintentos y decisiones adoptadas
Resultado	Completo según alcance / parcial / fallido; justificación de la valoración
Custodia	Precintos, transferencias, depósito físico o lógico, accesos y copias derivadas

Campo	Contenido a registrar
Referencias	Logs originales, fotografías, manifiestos, actas, tickets y autorizaciones

Las fichas deben evitar campos ambiguos. En lugar de «hash del disco» conviene utilizar «SHA-256 del flujo lógico de adquisición», «SHA-256 del contenedor E01» o «SHA-256 del fichero exportado», según corresponda. En lugar de «completo» sin cualificación, es preferible «completó todos los bloques direccionables que reportó el dispositivo; sin errores de lectura observados», si eso es lo que realmente acredita la operación. La precisión terminológica facilita evaluar la evidencia años después.

5.6.7. Registro de transferencias de evidencia digital

En la custodia física suelen constar la persona que entrega, quien recibe, fecha, motivo y estado del embalaje. Para los derivados digitales es necesario añadir el objeto exacto transferido, la forma de transporte, la verificación de integridad y los controles de acceso. Una imagen movida de un disco de adquisición a un repositorio protegido puede conservar sus bytes, pero el laboratorio debe poder explicar cómo se comprobó esa coincidencia y quién tuvo acceso a los archivos durante el traslado.

Las transferencias entre repositorios pueden introducir capas de cifrado, fragmentación o almacenamiento de objetos. La aplicación de un hash al archivo original y la comprobación del mismo archivo al llegar ayudan a verificar la continuidad. Si se trata de un contenedor comprimido o cifrado, se debe decidir si se verifican los bytes del contenedor, el contenido reconstruido o ambos. El registro indicará qué fue realmente comprobado. La copia de trabajo debe quedar identificada como derivado de la imagen preservada; no corresponde reetiquetarla como si fuese el objeto original.

Un sistema de almacenamiento con permisos estrictos, auditoría de lecturas y escrituras, autenticación robusta y redundancia aporta controles útiles. Sin embargo, un registro de almacenamiento inmutable tampoco reemplaza la necesidad de revisar que la adquisición inicial era la esperada. En todos los casos, las medidas de seguridad deben proteger la confidencialidad de datos personales o empresariales contenidos en la evidencia, no solo prevenir alteraciones.

5.6.8. De los registros operativos al informe pericial

Los registros detallados están destinados a permitir la revisión técnica. El informe dirigido a una autoridad judicial, una dirección de empresa o un equipo de respuesta necesita seleccionar esa información y explicar su relevancia sin perder precisión. La descripción de la adquisición suele contener: origen, legitimación y alcance, método elegido, estado inicial, medidas de preservación, herramientas, resultado, validación, incidencias y límites.

Una formulación adecuada podría ser la siguiente: «En fecha y hora indicadas, se adquirió una imagen de los bloques lógicos accesibles de la unidad identificada como OBJ-03, mediante el dispositivo de bloqueo de escritura registrado y la herramienta especificada en el acta. La adquisición produjo el conjunto de segmentos ADQ-08, cuyo contenido reconstruido fue verificado con SHA-256. No se notificaron errores de lectura. La operación no incluyó información de memoria RAM ni recursos alojados exclusivamente en servicios externos». La afirmación es verificable y expresa qué propiedades no están cubiertas.

Frente a ello, expresiones como «se clonó el ordenador sin modificar nada» o «se obtuvo una copia perfecta de toda la información» suelen exceder lo que técnicamente puede demostrarse. Ninguna redacción elegante sustituye la necesidad de registros, pero una buena redacción evita introducir afirmaciones absolutas innecesarias y permite a lectores no técnicos comprender qué acredita la evidencia.

5.6.9. Revisión independiente y control de calidad

Una adquisición compleja se beneficia de una segunda revisión. Esta no consiste necesariamente en repetir toda la lectura del soporte, que podría ser inviable o perjudicial. Puede abarcar la comprobación del inventario, la validación de identidades, la revisión de parámetros, la comparación de tamaños esperados, la comprobación de hashes, el examen de registros de errores y la confirmación de que el destino incluye todos los segmentos y manifiestos.

El revisor debe poder identificar no conformidades y registrar las acciones correctivas. Si falta una fotografía, una zona horaria o un número de serie, debe determinar si puede subsanarse de forma legítima consultando documentos contemporáneos o si la incertidumbre ha de mantenerse expresamente. No es aceptable completar retrospectivamente un dato dudoso como si hubiera sido observado en el momento original. Toda corrección debe conservar su autor, fecha y motivo.

Este control resulta especialmente valioso cuando la adquisición se entrega a un tercero o forma parte de un proceso judicial. Una revisión externa puede descubrir que el hash consignado corresponde al archivo comprimido en vez del contenido reconstruido, que un segmento fue omitido al copiarlo o que se confundió la ruta de un dispositivo. Detectarlo a tiempo permite corregir la documentación antes de que el error se propague al análisis y a las conclusiones.

5.6.10. Un procedimiento operativo verificable

Un laboratorio puede estructurar su procedimiento de adquisición en decisiones sucesivas, sin convertirlo en una secuencia rígida para cualquier caso. Antes de tocar la fuente se verifica el encargo, la autorización, la identidad del objeto y las características que condicionan la técnica. A continuación se valora la volatilidad, la presencia de cifrado, el estado físico y la posibilidad de obtener una representación suficientemente completa. Se eligen herramientas y controles validados, se prepara el destino y se establece un sistema de identificadores.

Durante la operación se registran los parámetros y las incidencias contemporáneamente. Al terminar se comparan los resultados con el alcance previsto, se comprueba la estructura y la integridad de los archivos, se revisan las áreas omitidas y se protege el conjunto. Si la adquisición es parcial, se documenta como parcial. Si aparecen nuevas fuentes, se gestiona la ampliación de alcance antes de obtenerlas. El procedimiento finaliza con el depósito, la entrega controlada de copias de trabajo y la revisión de calidad.

La flexibilidad es una exigencia metodológica y no una licencia para improvisar. Una investigación de incidente puede capturar primero registros de corta retención y después una imagen de disco; un caso sobre un HDD estable puede comenzar por la imagen física; un móvil cifrado puede exigir conservar el estado encendido y consultar procedimientos específicos. En todos los casos se mantiene una obligación común: poder explicar la secuencia real de actuaciones, las razones que la determinaron y las limitaciones resultantes.

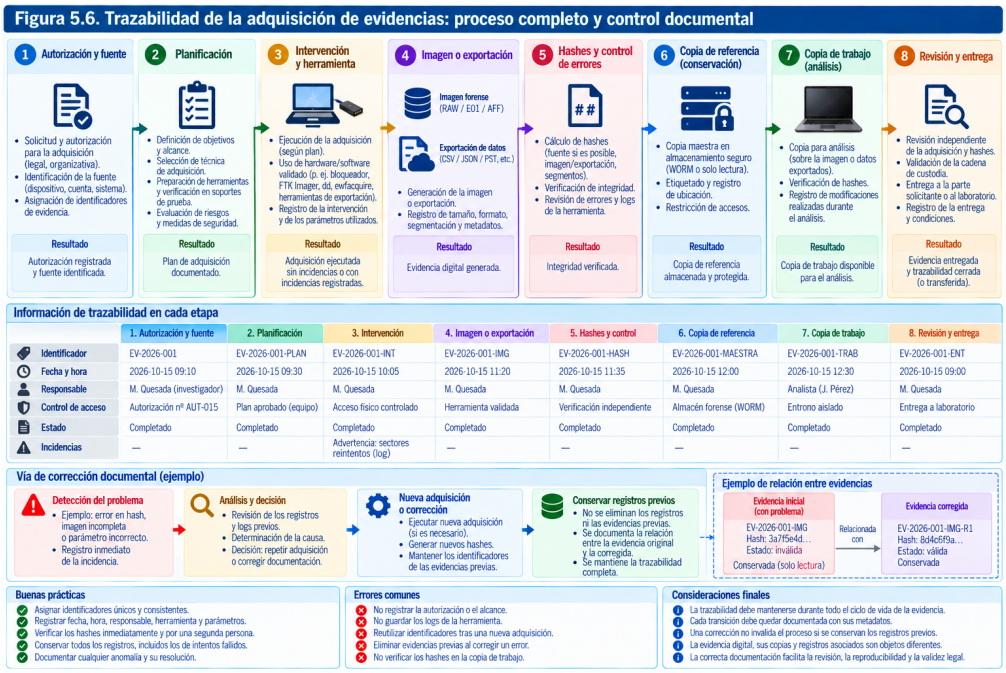


Figura 29: Diagrama de trazabilidad de la adquisición

5.7. Caso integrador: reconstrucción de una adquisición compleja

5.7.1. El encargo

La empresa ficticia MareNorte Ingeniería detecta que un conjunto de planos reservados ha aparecido en una ubicación externa no autorizada. Los archivos estaban alojados en un repositorio de colaboración y eran utilizados desde un portátil corporativo. La investigación debe averiguar qué documentos se descargaron, si se utilizaron dispositivos externos y si la información fue remitida a otros destinos. El servicio de identidad conserva registros durante un plazo limitado y el portátil se encuentra encendido, con cifrado activo y una sesión laboral abierta.

El encargo inicial autoriza la adquisición del equipo, el acceso a registros corporativos y las exportaciones necesarias del repositorio empresarial, dentro de una ventana temporal definida. Excluye cuentas personales del trabajador y otros recursos no relacionados. El equipo de respuesta aplica medidas de contención coordinadas con el responsable de seguridad, documentando las acciones y evitando extender la inspección a sistemas para los que no existe habilitación.

La estrategia contempla varias fuentes porque ninguna de ellas resulta suficiente por sí sola. Una imagen de bloques puede conservar rastros locales, pero no los eventos internos de la aplicación SaaS. Una exportación SaaS puede identificar descargas, pero no demuestra que un archivo haya sido copiado a un USB concreto. Una captura de RAM puede mostrar procesos y claves accesibles, pero su contenido es volátil y no acredita necesariamente lo sucedido días antes. La adquisición se diseña como un conjunto de representaciones complementarias, cada una sujeta a su propio control de integridad.

5.7.2. La decisión inicial y los riesgos

En la llegada al puesto se identifica el portátil y se fotografían su pantalla, sus conexiones y los dispositivos próximos. Se documenta el estado de las cuentas y de la red. Dado que el cifrado está activo y el sistema sigue encendido, se evalúa si una adquisición en vivo puede conservar datos que desaparecerían con el apagado. La intervención se limita al alcance autorizado y se revisa que las herramientas estén preparadas para evitar una exploración improvisada de datos personales ajenos al caso.

Al mismo tiempo, el servicio de identidad notifica que determinados registros se encuentran próximos al final de su periodo de retención. El equipo legal y el responsable habilitado gestionan su conservación y exportación. Esta decisión prioriza una fuente que puede desaparecer con independencia del estado del portátil. No existe contradicción entre preservar un endpoint y solicitar registros remotos: ambas actuaciones atienden riesgos de pérdida diferentes.

El análisis de riesgo identifica también una posibilidad de contenido malicioso en el portátil. Por ello se establece una técnica de contención proporcionada que evite nuevas comunicaciones no autorizadas sin destruir innecesariamente los estados que se pretende recoger. Las operaciones y sus efectos quedan registrados. La contención pertenece al contexto de respuesta a incidentes, pero influye directamente en las condiciones de la adquisición y debe aparecer en su documentación.

5.7.3. Adquisición del portátil y de las fuentes externas

Se obtiene una captura autorizada de memoria y una exportación focalizada de ciertos artefactos del sistema en vivo. Posteriormente, una vez resuelta la estrategia de cifrado y valorado el estado del dispositivo, se realiza una adquisición de los bloques lógicos accesibles mediante un procedimiento documentado. Para conservar los datos descifrados relevantes se utiliza asimismo una representación lógica del volumen montado. Cada salida recibe un identificador propio, un manifiesto y una comprobación de integridad.

El repositorio SaaS genera una exportación de actividad con la ventana temporal definida, identificadores de cuenta, acciones de descarga y metadatos disponibles. El proveedor de identidad facilita los registros de autenticación en un paquete separado. Se conservan los parámetros de consulta, la cuenta administrativa autorizada utilizada y los metadatos de generación. Si la aplicación produce ficheros CSV o JSON, se mantienen los originales y se crean copias de trabajo para su normalización durante el análisis.

Aparece también una memoria USB en el entorno, pero el objeto no fue identificado en el encargo inicial. En vez de adquirirlo sin más, el analista registra su presencia, su relación aparente con la escena y solicita la aclaración o ampliación correspondiente antes de examinar su contenido. La necesidad técnica de contrastar una hipótesis no implica automáticamente legitimidad para consultar cualquier dispositivo próximo.

5.7.4. Verificación de integridad y una incidencia documentada

Las primeras adquisiciones se verifican conforme al procedimiento. Los paquetes de la nube y los archivos de memoria reciben hashes SHA-256 calculados al incorporarse al repositorio. Para la imagen EWF se conserva el resultado de verificación del flujo reconstruido y se documentan los segmentos que forman el contenedor. Las copias de trabajo se generan posteriormente, conservando una separación entre material de referencia y datos manipulados durante el análisis.

En una de las transferencias aparece una discrepancia: la copia destinada a otro laboratorio tiene un hash distinto del fichero de referencia. La revisión revela que el segmento final del contenedor quedó incompleto durante la transferencia. El equipo conserva el registro de la incidencia, anula esa copia como material apto para análisis y repite la transferencia desde la fuente custodiada. La copia corregida verifica satisfactoriamente. El informe documenta el incidente y sus efectos; no se modifica el registro inicial para ocultarlo.

La diferencia entre integridad y procedencia se vuelve aquí tangible. El hash correcto del nuevo conjunto permite comprobar que el fichero transferido coincide con el conservado, pero la identidad del soporte original procede de la ficha de escena y de la adquisición. También hay una diferencia entre una copia corrupta y una imagen fuente dañada: en este caso el problema estaba en la transferencia, no en la lectura del portátil. Distinguir ambos supuestos evita introducir dudas injustificadas sobre el origen.

5.7.5. Resultados y límites de la fase de adquisición

Al cerrar esta fase, el laboratorio dispone de una imagen de bloques del portátil, una representación lógica de datos descifrados, una captura de memoria, registros de identidad, una exportación del repositorio y la documentación asociada. Se han preservado elementos con diferente procedencia, cobertura temporal y estructura. También se ha registrado qué información estaba excluida, qué actuaciones necesitaron autorización adicional y qué operaciones se ejecutaron sobre un sistema en funcionamiento.

Aún no puede afirmarse que la persona titular de la cuenta haya extraído deliberadamente los planos. Esa atribución requiere análisis e interpretación posteriores: correlación de tiempos, actividades del dispositivo, sesiones de identidad, eventos de SaaS y posibles trazas de soportes externos. La fase de adquisición acredita que se obtuvieron ciertos datos mediante determinados procedimientos y que esos datos fueron preservados y verificados según controles concretos. No convierte automáticamente los datos obtenidos en una explicación de los hechos.

La lección principal del caso no es que todas las investigaciones deban seguir idéntica secuencia. Es que una adquisición bien diseñada preserva distintas representaciones de un escenario, hace visibles sus límites y deja constancia de las decisiones necesarias para que la investigación pueda continuar sin depender de la memoria de quien intervino.

5.8. Conclusiones

La adquisición forense se encuentra en la intersección entre tecnología, método y responsabilidad. Su éxito no depende exclusivamente de obtener la mayor cantidad de datos, sino de conservar los adecuados con garantías verificables y de poder explicar qué representan. Una imagen de bloques, una exportación lógica, una captura en vivo o una adquisición remota son instrumentos diferentes que sirven a preguntas diferentes. La técnica debe seleccionarse según las características de la fuente, los objetivos del caso, la volatilidad, el riesgo y las autorizaciones disponibles.

Los bloqueadores de escritura reducen el riesgo de alterar determinados soportes, pero no congelan todos los procesos internos del dispositivo ni convierten la operación en una adquisición válida por sí solos. Los formatos forenses facilitan almacenar y verificar datos, pero ninguna extensión de archivo reemplaza la documentación. Los hashes proporcionan una comprobación criptográfica poderosa sobre conjuntos concretos de bytes, pero no prueban automáticamente la autenticidad, la procedencia, la licitud o la completitud del origen. Los SSD, los sistemas cifrados, los soportes dañados y las arquitecturas distribuidas demuestran que la adquisición no puede resolverse mediante un procedimiento único.

El criterio que debe permanecer estable es la trazabilidad. Identificar la fuente, declarar la representación obtenida, conservar la salida original, registrar el proceso, explicar los errores y verificar las copias constituye una cadena de garantías complementarias. Cada una cubre un riesgo diferente y ninguna debe atribuirse propiedades que no posee. El analista competente no promete una copia perfecta de una realidad técnica cambiante: ofrece una adquisición cuya cobertura, integridad y limitaciones pueden evaluarse con independencia de quien la practicó.

Sobre esta base, los capítulos siguientes podrán abordar la estructura de los sistemas de archivos, los artefactos de los sistemas operativos y las técnicas de examen. En todos ellos, los hallazgos deberán vincularse a las adquisiciones descritas aquí. Una interpretación rigurosa empieza con datos de procedencia conocida; cuando esa procedencia es incierta, la incertidumbre debe acompañar a la conclusión.

5.9. Referencias y lecturas recomendadas

Las referencias siguientes identifican fuentes técnicas de orientación y consulta. Su aplicación debe adaptarse a la tecnología, a la versión concreta de la herramienta y a las obligaciones legales y organizativas del caso. Las publicaciones de mejores prácticas no sustituyen las autorizaciones ni los procedimientos de la institución competente.

1. **SWGDE**. *Best Practices for Computer Forensic Acquisition*, documento 17-F-002, versión 2.1. Scientific Working Group on Digital Evidence. https://www.swgde.org/documents/published-complete-listing/17-f-002-2-1/
2. **SWGDE**. *Best Practices for Digital Evidence Collection*, documento 18-F-002, versión 2.0. Scientific Working Group on Digital Evidence. https://www.swgde.org/documents/published-complete-listing/18-f-002-2-0/
3. **SWGDE**. *Best Practices for Remote Collection of Digital Evidence from an Endpoint*, documento 22-F-003, versión 2.0. Scientific Working Group on Digital Evidence. https://www.swgde.org/documents/published-complete-listing/22-f-003-best-practices-for-remote-collection-of-digital-evidence-from-an-endpoint/
4. **SWGDE**. *Best Practices for Digital Evidence Acquisition, Preservation, and Analysis from Cloud Service Providers*, documento 23-F-004, versión 1.1 (2025). https://www.swgde.org/documents complete-listing/23-f-004-best-practices-for-digital-evidence-acquisition-preservation-and-analysis-from-cloud-service-providers/
5. **NIST**. *Guide to Integrating Forensic Techniques into Incident Response*, SP 800-86 (2006). https://doi.org/10.6028/NIST.SP.800-86

6. **NIST**. *Guidelines for Media Sanitization*, SP 800-88 Rev. 2 (2025). Referencia sobre saneamiento de soportes y disposición de medios, no sobre recuperación forense. https://doi.org/10.6028/NIST.SP.800-88r2
7. **NIST**. *Computer Forensic Tool Testing (CFTT)*. Programa de evaluación de herramientas y procedimientos de prueba de informática forense. https://www.nist.gov/itl/ssd/software-quality-group/computer-forensics-tool-testing-program-cftt
8. **ISO/IEC**. *27037:2012 — Guidelines for identification, collection, acquisition and preservation of digital evidence*. Norma de referencia sobre tratamiento inicial de evidencias digitales. https://www.iso.org/standard/44381.html
9. **GNU Project**. *GNU ddrescue Manual*. Documentación técnica de recuperación de datos, mapas de progreso, manejo de errores y advertencias sobre dispositivos dañados. https://www.gnu.org/software/ddrescue/manual/ddrescue_manual.html
10. **libewf**. Proyecto y documentación de herramientas de lectura y escritura del formato Expert Witness. https://github.com/libyal/libewf
11. **NIST**. *FIPS 180-4 — Secure Hash Standard (SHS)*. Especificación de SHA-1 y de la familia SHA-2; las decisiones actuales deben atender a la fortaleza del algoritmo y a las recomendaciones vigentes. https://doi.org/10.6028/NIST.FIPS.180-4
12. **NIST**. *FIPS 202 — SHA-3 Standard: Permutation-Based Hash and Extendable-Output Functions*. https://doi.org/10.6028/NIST.FIPS.202

Nota editorial. Los ejemplos de comandos están destinados a entornos de laboratorio controlados, con imágenes sintéticas o medios expresamente preparados. Las rutas de dispositivos, las características del software y las opciones de adquisición deben comprobarse en cada sistema antes de realizar una intervención. Los diagramas indicados como figuras 5.1 a 5.6 se incorporarán en una fase posterior; no forman parte todavía de este archivo.

6. Preparación del laboratorio forense

> *La fiabilidad de una investigación no comienza cuando el analista abre la primera imagen de disco. Comienza mucho antes: cuando decide qué sistemas utilizará, cómo los comprobará, dónde conservará los datos y de qué modo podrá explicar cada operación realizada.*

El laboratorio forense constituye el espacio técnico y organizativo en el que las evidencias digitales se reciben, preservan, examinan, correlacionan y transforman en resultados documentados. Puede ocupar una instalación física con zonas de acceso restringido, estar distribuido entre varias sedes o apoyarse parcialmente en infraestructuras virtuales. Su carácter forense, sin embargo, no depende de la cantidad de ordenadores, de las marcas de las herramientas ni de la apariencia de sus instalaciones. Depende, sobre todo, de la capacidad para trabajar de forma controlada, minimizar modificaciones injustificadas y demostrar de dónde procede cada resultado.

Conviene distinguir desde el principio entre tres realidades que a menudo se confunden. El **almacén de evidencias** conserva los originales y sus representaciones autorizadas; la **infraestructura de examen** proporciona capacidad de cálculo y herramientas para trabajar sobre copias; y el **entorno experimental** permite probar procedimientos, reproducir comportamientos y estudiar hipótesis sin comprometer el material del caso. En un laboratorio pequeño, las tres funciones pueden compartir una sala o determinados equipos, pero no deberían compartir indiscriminadamente permisos, credenciales, redes y directorios de datos.

La preparación no se reduce a instalar aplicaciones. También exige determinar qué perfiles pueden acceder al laboratorio, cómo se incorporan herramientas nuevas, cómo se registran las versiones utilizadas, qué sucede si un soporte presenta errores, quién autoriza la conexión a una red exterior o qué procedimiento se sigue cuando una automatización devuelve resultados inesperados. En otras palabras: además de disponer de capacidad técnica, el laboratorio necesita gobierno y memoria de sus propias actuaciones.

Este capítulo aborda la construcción progresiva de esa capacidad. Primero se estudia el diseño físico y virtual; después, la organización de las estaciones y del almacenamiento; a continuación, las familias de herramientas libres y comerciales y sus criterios de selección. El análisis se completa con un método de validación, una propuesta de automatización trazable y una serie de escenarios reproducibles. No se pretende ofrecer una única arquitectura válida para cualquier organización. Un equipo que atiende investigaciones corporativas urgentes, un laboratorio pericial que recibe dispositivos intervenidos judicialmente y un grupo de investigación que trabaja exclusivamente con conjuntos de datos públicos tienen necesidades

distintas. Comparten, no obstante, la obligación de conocer sus capacidades y reconocer sus límites.

La guía NIST SP 800-86 sitúa la organización de las técnicas forenses dentro de la respuesta a incidentes y subraya la necesidad de ajustarse al contexto operativo y jurídico. Las recomendaciones SWGDE y el programa CFTT de NIST aportan, por su parte, criterios útiles para ensayar herramientas y documentar su comportamiento. Ninguna de estas referencias sustituye la evaluación concreta que debe realizar el propio laboratorio: una herramienta contrastada para una función, versión y tipo de datos no queda automáticamente validada para todas sus posibilidades.

6.1. Equipamiento físico y virtual

6.1.1. Diseñar a partir de las preguntas que debe responder el laboratorio

El primer error de diseño consiste en adquirir equipos antes de definir las investigaciones que deberán atender. Una estación extraordinariamente potente para el análisis de memoria puede resultar poco útil si el laboratorio no dispone de un medio fiable para adquirir discos NVMe. Del mismo modo, un armario repleto de bloqueadores de escritura apenas resuelve un incidente cuyo material principal consiste en registros de identidad alojados en una plataforma SaaS. El inventario de capacidades debe preceder al catálogo de compras.

La planificación comienza por los **casos de uso**: adquisición de ordenadores encendidos y apagados, extracción de dispositivos móviles, análisis de sistemas Windows y Linux, interpretación de memoria volátil, respuesta remota, tráfico de red, servicios cloud, máquinas virtuales o investigación de aplicaciones empresariales. Para cada clase conviene conocer la frecuencia estimada, las dimensiones habituales de los datos, el grado de urgencia, las tecnologías empleadas, los requisitos de autorización y la posibilidad de necesitar especialistas externos.

El segundo elemento es el **volumen de trabajo simultáneo**. No equivale analizar diez casos pequeños a mantener abiertos dos asuntos que contienen decenas de terabytes, numerosos soportes y retenciones prolongadas. La capacidad del laboratorio se mide en una combinación de almacenamiento, rendimiento de entrada y salida, tiempo de procesamiento, personal cualificado y capacidad de conservar evidencias durante años. Si se aumenta uno de esos recursos sin revisar los demás, el cuello de botella simplemente cambia de ubicación.

Resulta útil formular preguntas concretas: ¿puede recibirse un dispositivo sin conectar su contenido a la red corporativa? ¿Existe una ruta para capturar memoria antes de un apagado inevitable? ¿Se puede examinar una imagen E01 sin modificar el original? ¿Cómo se re-

cuperaría una copia de referencia si falla el almacenamiento principal? ¿Dónde quedan las credenciales temporales usadas para una exportación cloud? ¿Es posible reproducir una versión antigua de una herramienta después de una actualización? Cada respuesta condiciona el diseño.

El laboratorio debe diferenciar también la **capacidad declarada** de la **capacidad comprobada**. Tener instalado un programa que anuncia compatibilidad con un formato de disco no equivale a haber demostrado que lo interpreta correctamente en las configuraciones relevantes. Disponer de un hardware de bloqueo de escritura tampoco garantiza que se haya comprobado con la combinación exacta de interfaz, adaptador y firmware prevista. El inventario útil asocia capacidades con procedimientos verificados, no solo con equipos disponibles.

6.1.2. Zonas físicas y circulación del material

Un laboratorio puede organizarse en zonas con finalidades diferentes, aunque no siempre sea necesario construir divisiones arquitectónicas. Una zona de **recepción** permite registrar la llegada de soportes, identificar su procedencia, fotografiar embalajes y comprobar precintos. El área de **custodia** reserva un espacio controlado para los objetos originales. La zona de **adquisición** concentra interfaces, bloqueadores y equipos que entran en contacto con las fuentes. Por último, el área de **análisis** alberga las estaciones que procesan copias y producen resultados.

La circulación deseable es sencilla de explicar: un objeto se registra, se deposita o se traslada de manera documentada a la zona adecuada, se adquiere siguiendo un procedimiento autorizado y vuelve a una custodia definida. Los resultados digitales siguen un itinerario distinto, a través de repositorios y permisos propios. En algunos casos, el dispositivo original debe permanecer encendido o no puede abandonar su ubicación; entonces la escena, el lugar de custodia y el laboratorio dejan de coincidir. La documentación tiene que reflejar esa excepción en lugar de fingir que todos los objetos han seguido el circuito estándar.

El control físico incluye cerraduras, gestión de llaves o credenciales, registro de visitantes, separación de funciones, protección frente al fuego y daños por agua, acondicionamiento eléctrico y detección de incidentes ambientales. Estos controles no garantizan por sí solos la conservación, pero disminuyen riesgos previsibles. Una interrupción de alimentación durante la escritura de una imagen, por ejemplo, puede dejar un resultado incompleto. Una avería de climatización que provoque temperaturas anómalas puede comprometer estaciones y cabinas de discos. Un inventario sin ubicación actualizada convierte cualquier búsqueda posterior en una investigación dentro de la propia organización.

La electricidad merece especial atención. Un sistema de alimentación ininterrumpida permite cerrar adquisiciones y equipos con seguridad ante cortes breves; no debe interpretarse como autonomía ilimitada. Conviene comprobar su capacidad real bajo carga, su antigüedad, las baterías y el tiempo necesario para detener operaciones. La protección contra sobretensiones, las tomas identificadas y la distribución equilibrada de cargas completan la medida. En instalaciones que trabajan con soportes potencialmente dañados, además, deben existir superficies adecuadas, medios de descarga electrostática cuando proceda y reglas para evitar manipulaciones innecesarias.

La recepción de aparatos húmedos, quemados, con baterías hinchadas o afectados por un accidente requiere un circuito especial de seguridad. La prioridad es proteger a las personas y prevenir daños adicionales. No debe energizarse de forma improvisada un dispositivo que presenta signos de deterioro físico. En determinados casos será razonable derivarlo a una instalación de recuperación especializada, conservando y documentando su estado y las transferencias realizadas.

6.1.3. Puestos de adquisición, examen y administración

Aunque una misma estación pueda desempeñar varias funciones, es útil distinguir sus perfiles. El **puesto de adquisición** está preparado para conectarse a evidencias físicas con las garantías pertinentes. Puede contar con controladoras y adaptadores SATA, SAS, USB y NVMe, bloqueadores compatibles y herramientas para registrar errores de lectura. Su prioridad es obtener una representación definida de la fuente, no ejecutar indiscriminadamente todas las aplicaciones de análisis.

El **puesto de examen** trabaja principalmente con imágenes, volcados y exportaciones previamente incorporados al caso. Necesita memoria, capacidad de proceso y almacenamiento rápido, especialmente cuando genera índices, recupera archivos eliminados o reconstruye líneas temporales con millones de registros. El **puesto de administración**, finalmente, gestiona permisos, copias de seguridad, actualizaciones del entorno y supervisión. Mantener separadas esas funciones reduce la posibilidad de que una credencial administrativa utilizada cotidianamente comprometa también el repositorio de evidencias.

La separación puede ser física, lógica o mixta. No obliga a comprar un ordenador por cada operación, pero sí a precisar qué usuario y qué proceso pueden acceder a cada recurso. Una estación de análisis no necesita permiso de escritura sobre la copia maestra del caso. Un servidor de informes no debería tener acceso irrestricto a todos los discos intervenidos. Un sistema de actualizaciones puede necesitar conexión a Internet, mientras que una imagen sospechosa debe examinarse en un entorno aislado. El diseño debe reflejar esas diferencias.

Un puesto de recepción no debería utilizar una cuenta personal del analista como mecanismo de auditoría. La identidad individual es necesaria para atribuir acciones, pero los registros deben mantenerse en una infraestructura controlada por la organización y con un procedimiento de conservación independiente del puesto desde el que se trabaja.

6.1.4. Virtualización y separación de entornos

La virtualización facilita construir laboratorios complejos con recursos limitados. Un hipervisor permite alojar simultáneamente máquinas Windows, Linux y servidores, configurar redes de investigación, realizar instantáneas para pruebas y restablecer escenarios a estados conocidos. Tecnologías como KVM/QEMU, Proxmox VE, Hyper-V o VMware cumplen distintas necesidades; ninguna es por sí misma la plataforma universal del análisis forense. Lo decisivo es comprender sus características, los formatos utilizados y los efectos de sus operaciones sobre los datos.

Conviene separar, al menos, tres familias de máquinas virtuales. Las **máquinas instrumentales** ejecutan aplicaciones de análisis, indexación o correlación. Las **máquinas de experimentación** reproducen comportamientos mediante datos sintéticos o públicos. Las **máquinas de simulación adversarial** pueden generar tráfico, malware de prueba o técnicas controladas de intrusión y requieren un aislamiento más estricto. La etiqueta «laboratorio» no convierte automáticamente en inocua una muestra de código potencialmente dañino.

Una instantánea de máquina virtual no debe confundirse con una imagen forense completa. Puede almacenar diferencias de disco, memoria, estado de dispositivos y metadatos particulares de la plataforma. Su comportamiento depende del hipervisor, de la configuración y del momento de captura. Algunas instantáneas son consistentes a nivel de sistema de archivos; otras no garantizan consistencia transaccional de aplicaciones. Para preservar evidencia procedente de una máquina virtual interesa documentar qué se exportó: disco base, cadena de discos diferenciales, configuración, estado de memoria o una combinación de ellos.

También importa la procedencia del tiempo. Las máquinas invitadas pueden sincronizarse mediante NTP, mediante herramientas del hipervisor, por el reloj del anfitrión o por varias vías a la vez. Suspender y reanudar un invitado puede producir saltos aparentes que alteren el significado de sus registros. Un laboratorio preparado contempla estas características en sus pruebas de interpretación de marcas temporales.

6.1.5. Topología de red y niveles de confianza

La red del laboratorio no es una simple extensión de la red de la oficina. Debe diseñarse pensando en dos flujos distintos: el de administración de la infraestructura y el de datos potencialmente hostiles obtenidos durante una investigación. Una segmentación razonable puede disponer de una red para gestión del hipervisor y almacenamiento, otra para estaciones de análisis, una para escenarios reproducibles y una zona aislada para ejecutar software o contenidos peligrosos.

El empleo de VLAN ayuda a separar dominios de difusión, pero **una VLAN no constituye por sí sola una barrera completa de seguridad**. Las reglas de enrutamiento y cortafuegos determinan si existe conectividad entre segmentos. El propio hipervisor puede introducir puentes, adaptadores adicionales o funciones de enrutamiento que rompan el aislamiento previsto. Las máquinas con dos interfaces, una hacia la red corporativa y otra hacia el laboratorio, merecen atención especial porque pueden convertirse en rutas involuntarias entre ambas.

Un entorno destinado al análisis estático de archivos no requiere, por principio, acceso a Internet. Cuando una técnica precisa consultar un servicio externo —por ejemplo, recuperar metadatos públicos de un dominio— conviene definir qué datos saldrán del laboratorio y con qué autorización. Subir un archivo evidencial completo a un servicio de análisis en línea puede divulgar datos personales, secretos comerciales o información sometida a reserva. Incluso la búsqueda pública de un hash puede revelar intereses de la investigación o establecer asociaciones no previstas.

En el análisis dinámico de software sospechoso, la salida a Internet debe evaluarse de manera específica. A veces basta una red interna simulada que conteste a peticiones DNS y HTTP sintéticas; otras investigaciones necesitan observar conexiones externas reales. Esa decisión requiere control de destino, registro de tráfico, límites temporales, contención y aprobación del alcance. Una máquina virtual «sin acceso a la LAN» pero con NAT hacia Internet no está aislada: posee conectividad saliente y puede producir consecuencias fuera del laboratorio.

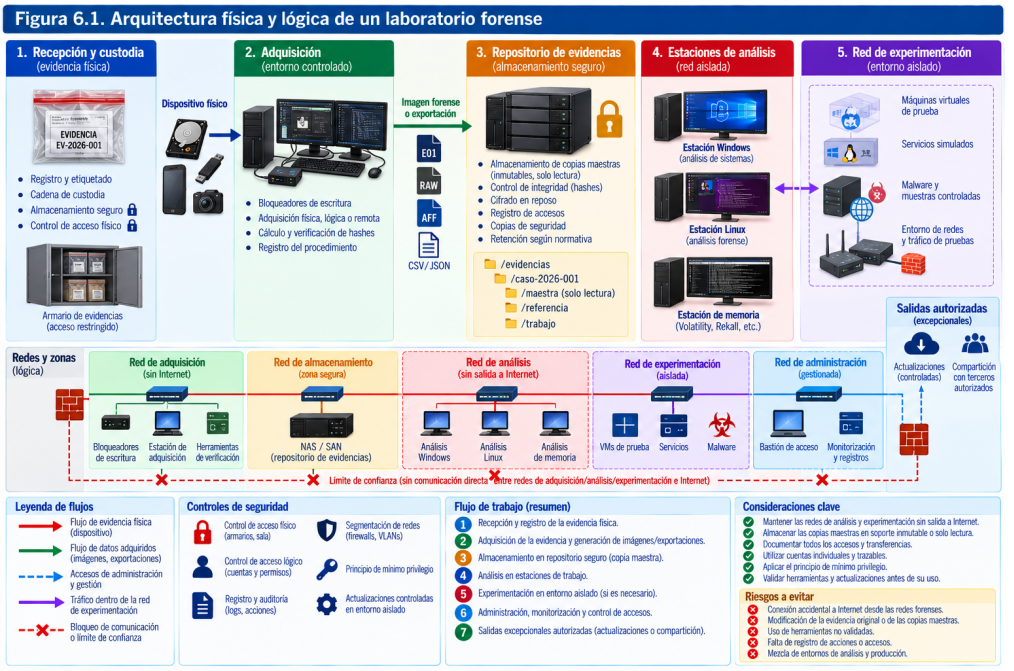


Figura 30: Arquitectura física y lógica de un laboratorio forense

6.1.6. Dimensionamiento, redundancia y crecimiento

El diseño de capacidad comienza por estimar la cantidad de información que entra y la que produce el proceso de análisis. Una adquisición de un disco de 2 TB puede consumir una cantidad similar de espacio en formato RAW. A ella se suman copias de referencia, índices, bases de datos, archivos recuperados, imágenes de memoria, resultados exportados y versiones de informes. La compresión puede reducir algunos componentes, pero no debe suponerse una tasa fija: el comportamiento depende del tipo de datos, del cifrado, de la compresión previa y del formato de imagen.

Una estimación orientativa puede representarse así:

$$C_{\text{necesaria}} = C_{\text{evidencias}} + C_{\text{referencias}} + C_{\text{trabajo}} + C_{\text{derivados}} + C_{\text{reserva}}$$

La expresión no implica que todas las investigaciones deban mantener tres copias de cada objeto ni que cada copia ocupe el mismo espacio. Su propósito es hacer visible el coste que suele ocultarse cuando se compara únicamente la capacidad de los discos intervenidos. La

retención legal de casos cerrados puede superar con mucho el tiempo necesario para analizarlos, y el laboratorio debe estimar ambos horizontes por separado.

Además del volumen, importa la velocidad. La adquisición secuencial de un disco grande, la creación simultánea de índices y las consultas aleatorias sobre millones de archivos tienen perfiles de entrada y salida distintos. Un almacenamiento HDD puede resultar adecuado para conservar grandes imágenes de referencia, mientras que los derivados de análisis y las bases de datos se benefician de SSD o NVMe. Esta distinción ayuda a optimizar recursos sin sacrificar las garantías de conservación.

RAID, copias de seguridad e inmutabilidad resuelven problemas diferentes. RAID puede aportar continuidad ante la avería de determinadas unidades, pero no restaura por sí solo archivos borrados, datos cifrados por ransomware ni configuraciones alteradas. La copia de seguridad permite recuperar estados anteriores dentro de sus límites de retención. La inmutabilidad o protección frente a modificación ayuda a resistir ciertas amenazas, aunque requiere comprobar permisos, credenciales y mecanismos de administración. Ninguna de esas medidas constituye por sí sola una cadena de custodia.

El crecimiento debe ser modular. La introducción de un nuevo sistema de archivos, un formato de nube o una familia de dispositivos no debería obligar a rediseñar toda la infraestructura. Un laboratorio maduro conserva procedimientos comunes de identificación, registro y validación, y añade módulos especializados cuando la naturaleza de los casos lo exige.

6.1.7. Continuidad operativa y fallo previsto

La preparación incluye asumir que algo fallará: una fuente de alimentación, un disco, un cable, una herramienta, la conexión al proveedor cloud o una credencial temporal. El laboratorio debe poder distinguir entre una avería ordinaria y un incidente de integridad de evidencia, y saber cómo reaccionar ante ambos sin ocultar la incidencia. Los errores no documentados son más peligrosos que muchos errores detectados a tiempo.

Un plan elemental contempla la recuperación de los inventarios, el registro de custodia, los procedimientos de trabajo y las claves necesarias para acceder a evidencias cifradas. De nada sirve contar con tres copias de un repositorio si todas dependen de una única cuenta comprometida o de una clave almacenada en el mismo servidor. La recuperación debe ensayarse periódicamente sobre un conjunto de prueba y registrarse, no limitarse a la presencia de una tarea programada que informa de «copia realizada».

Conviene reservar capacidad alternativa para operaciones urgentes: un puesto secundario, adaptadores de repuesto, soportes vacíos identificados, acceso a otro laboratorio o un contrato de recuperación especializada. La contingencia no debe consistir en improvisar el uso

de cualquier ordenador disponible. Cuanto mayor sea la presión de tiempo, más necesaria resulta una infraestructura conocida.

6.2. Estaciones de trabajo y almacenamiento de evidencias

6.2.1. La estación como parte de la cadena técnica

En una investigación, la estación de análisis no es un elemento neutro. Su sistema operativo decide cómo se enumeran los dispositivos, sus controladores interpretan protocolos, sus bibliotecas leen formatos y sus aplicaciones generan resultados. Una modificación de la configuración puede alterar una adquisición o una interpretación aunque el analista ejecute aparentemente el mismo procedimiento. Por esta razón, las estaciones deberían inventariarse como instrumentos de trabajo y no solo como ordenadores de propósito general.

La ficha técnica de una estación incluye identificador del equipo, componentes relevantes, sistema operativo, versión y nivel de actualización, interfaces de almacenamiento, herramientas instaladas, controladores especiales y cambios conocidos. Para una operación concreta no siempre será necesario consignar todos esos elementos en el informe final, pero sí debe ser posible reconstruir el entorno utilizado cuando una discrepancia lo haga relevante. Si una herramienta produjo un fallo que desaparece al cambiar de versión del controlador NVMe, esa dependencia es parte de la explicación técnica.

La estandarización facilita el mantenimiento. Contar con un número reducido de imágenes maestras de sistema operativo, configuraciones conocidas y procedimientos de puesta en servicio disminuye la diversidad accidental entre estaciones. La estandarización no debe conducir, sin embargo, a imponer el mismo entorno para toda clase de evidencias. Algunas adquisiciones requieren Windows por compatibilidad con controladores, otras se realizan mejor en Linux y ciertos análisis necesitan versiones concretas de macOS o herramientas de un fabricante. La solución no es una estación universal imaginaria, sino un catálogo controlado de entornos especializados.

En las estaciones utilizadas para procesar archivos potencialmente maliciosos deben aplicarse medidas adicionales. Es preciso limitar las credenciales, deshabilitar servicios innecesarios, controlar dispositivos USB y evitar que el contenido de evidencia se abra automáticamente con aplicaciones capaces de ejecutar macros, previsualizadores vulnerables o complementos no comprobados. Una vista previa gráfica también es software que procesa datos no confiables y, por tanto, puede representar una superficie de ataque.

6.2.2. Memoria, CPU, GPU y rendimiento efectivo

El número de núcleos y la cantidad de memoria influyen en el rendimiento, pero no de manera uniforme. El análisis de una imagen pequeña con unos pocos registros no necesita una estación de gama extrema. En cambio, indexar varios terabytes, descomprimir colecciones grandes, procesar fotografías o construir una línea temporal global puede requerir cantidades importantes de RAM y numerosas operaciones de disco. La capacidad de memoria reduce la paginación, pero no sustituye un almacenamiento rápido ni corrige una herramienta que escala mal.

Las tareas se benefician de recursos diferentes. Algunas son secuenciales y están limitadas por la velocidad de lectura. Otras distribuyen el trabajo entre núcleos, mientras que ciertas operaciones criptográficas aprovechan instrucciones específicas de la CPU. Una GPU puede acelerar funciones concretas, por ejemplo determinados procesos de reconocimiento, clasificación o recuperación autorizada de contraseñas, pero no hace automáticamente más rápido cualquier análisis. Cada mejora de hardware debería justificarse mediante una medida reproducible, no solo por especificaciones comerciales.

Para dimensionar una estación es preferible ensayar una carga representativa. Puede prepararse un conjunto sintético de archivos, una imagen de prueba de varios tamaños y una colección de eventos conocida. Se mide el tiempo de extracción, la memoria máxima utilizada, las tasas de lectura y escritura, el número de errores y el espacio temporal necesario. Después se varía un recurso cada vez. Si duplicar la RAM no altera el tiempo porque el almacenamiento alcanza su límite, la inversión prioritaria está en otro componente.

En laboratorio forense, la rapidez es importante, pero no debe conseguirse ocultando errores o descartando verificaciones. Un procesamiento que termina antes porque omite archivos dañados sin avisar no constituye una mejora. La métrica principal debe combinar **tiempo, cobertura, integridad y explicabilidad**.

6.2.3. Sistemas operativos de trabajo

No existe una obligación técnica de que todos los investigadores utilicen el mismo sistema operativo. Windows concentra numerosas suites comerciales y herramientas especializadas. Linux ofrece un entorno flexible para montaje controlado de imágenes, automatización, análisis de sistemas de archivos y procesamiento masivo de registros. macOS puede ser necesario para determinados procedimientos de análisis o reproducción de artefactos propios de su ecosistema. La elección responde a requisitos verificables de adquisición, compatibilidad, soporte y seguridad.

En Linux, una diferencia fundamental es la que existe entre **detectar un dispositivo** y **montar automáticamente su sistema de archivos**. Un soporte puede ser reconocido por el núcleo sin que todavía se haya accedido a su contenido en la forma pretendida. Los servicios de escritorio que realizan montajes automáticos, indexación o generación de miniaturas pueden interferir en un entorno de adquisición. Por eso conviene deshabilitar comportamientos automáticos relevantes, comprobar el estado de montaje y trabajar con bloqueadores o procedimientos validados cuando la fuente es original.

Los siguientes comandos sirven para inventariar una estación Linux y sus dispositivos, no para demostrar por sí mismos que existe protección forense:

```
uname -a
lsblk -o NAME,SIZE,MODEL,SERIAL,RO,TYPE,MOUNTPOINTS
findmnt
lsusb
lspci
```

El atributo RO mostrado por `lsblk` resulta útil para diagnóstico, pero no es una certificación de inalterabilidad del soporte ni sustituye las pruebas de protección frente a escritura. Asimismo, el uso de `sudo` no convierte una operación en forense; solo la ejecuta con mayores privilegios, lo que exige más cautela.

Una práctica recomendable es mantener una ficha de arranque que registre la versión de la distribución, el núcleo, las bibliotecas y las herramientas empleadas. Las actualizaciones de seguridad deben planificarse, pero cuando introducen cambios relevantes es necesario comprobar nuevamente las funciones forenses afectadas. Aplazar indefinidamente todas las actualizaciones crea riesgos propios; actualizarlas sin control puede romper reproducibilidad. Ambos extremos son evitables mediante gestión de versiones y pruebas.

6.2.4. Modelos de almacenamiento y separación entre originales y derivados

La distinción entre objeto físico, adquisición, copia de referencia, copia de trabajo y producto analítico debe traducirse en una estructura de almacenamiento comprensible. Una imagen recibida de una autoridad, un fichero `E01` generado por el laboratorio y una carpeta exportada desde un proveedor SaaS pueden tener naturalezas diferentes, pero deben poder integrarse en un mismo expediente sin perder su procedencia.

Puede organizarse un caso mediante zonas lógicas:

```
CASO-2026-014/
├── 00-administracion/
│   ├── autorizaciones/
```

```
│   ├── inventario/
│   └── custodia/
├── 01-originales-digitales/
│   ├── ADQ-001/
│   └── ADQ-002/
├── 02-referencia/
│   ├── ADQ-001/
│   └── ADQ-002/
├── 03-trabajo/
│   ├── analista-a/
│   └── analista-b/
├── 04-derivados/
│   ├── artefactos/
│   ├── cronologias/
│   └── informes-de-herramientas/
├── 05-validacion/
├── 06-informe/
└── manifiestos/
```

La estructura es ilustrativa y no debe copiarse literalmente a todos los casos. Algunas organizaciones mantienen los originales digitales en un repositorio independiente, gestionado por un sistema de evidencias, y solo exponen referencias lógicas en el expediente. Otras almacenan los derivados en bases de datos o sistemas de objetos. Lo importante es que la ubicación no sustituya al identificador y que el mecanismo de vinculación entre elementos no dependa exclusivamente del nombre de una carpeta.

Una política de denominación evita ambigüedades. Por ejemplo, `OBJ-014-03` puede identificar el soporte intervenido; `ADQ-014-03-A` la primera adquisición de ese soporte; `REF-014-03-A-01` una copia de referencia verificada, y `TRB-014-03-A-02` una copia destinada a examen. Los identificadores no se deben reciclar después de un error. Si se repite una adquisición, el nuevo resultado merece un identificador propio y una relación explícita con el anterior.

La copia maestra o adquisición inicial se protege frente a modificaciones; la referencia puede conservarse para comprobaciones periódicas; la copia de trabajo se utiliza para extraer artefactos e incorporar resultados. No todas las herramientas interpretan del mismo modo una imagen segmentada o un volumen descifrado, y una copia transformada puede no conservar exactamente la misma secuencia de bytes que su origen. En esos casos deben registrarse los objetos comparables y el procedimiento de transformación.

6.2.5. Control de acceso y principio de mínimo privilegio

El acceso al repositorio debe basarse en la función que desempeña cada persona y en su participación autorizada en un caso. No es necesario que todos los miembros del laboratorio puedan examinar todas las evidencias. La separación por expediente y por clase de recurso disminuye el riesgo de consulta improcedente, alteración accidental y divulgación. Un investigador puede necesitar lectura de una copia de trabajo y escritura sobre su carpeta de resultados, pero no permisos para eliminar originales o alterar registros de custodia.

Los permisos convencionales de un sistema de archivos constituyen la primera línea, no la única. Es aconsejable controlar cuentas privilegiadas, accesos remotos, autenticación multifactor cuando resulte viable, cuentas de servicio y credenciales para aplicaciones que indexan repositorios. La cuenta técnica que ejecuta una tarea automática debe tener acceso solamente a las entradas y salidas necesarias. Su actividad debe quedar asociada a la ejecución específica, no confundida con la identidad de la persona que revisa los resultados.

La protección de originales requiere un enfoque por capas: permisos, almacenamiento que impida o dificulte modificaciones, registro de accesos, verificaciones de integridad y procedimientos de restauración. El almacenamiento de tipo WORM o la retención inmutable de objetos puede aportar garantías adicionales, pero hay que estudiar quién puede modificar las políticas, borrar claves, cambiar la retención o administrar el sistema. La posibilidad de que un administrador con privilegios excepcionales altere la configuración forma parte del modelo de amenaza.

Un sistema de auditoría no cumple su función si sus registros pueden ser modificados sin rastro por la misma cuenta que realiza las operaciones analizadas. Cuando sea posible, los eventos deben remitirse a un destino separado, con acceso restringido y política de retención conocida. No todos los laboratorios necesitarán un SIEM completo, pero todos deberían poder responder quién accedió a una evidencia relevante, cuándo y para qué operación.

6.2.6. Integridad, copias de seguridad y recuperación

La verificación de integridad de los contenidos digitales se apoya habitualmente en funciones hash como SHA-256. Su uso debe ser preciso. Un hash identifica una secuencia concreta de bytes: si se calcula sobre un contenedor EWF, no tiene por qué coincidir con el hash del flujo de bloques reconstruido ni con el de cada segmento E01, E02 y sucesivos. Registrar solo «hash de la imagen» sin aclarar el objeto puede generar una falsa apariencia de discrepancia.

Para un archivo ordinario de laboratorio, la comprobación puede ejecutarse con:

```
sha256sum muestra_prueba.bin
sha256sum -c muestra_prueba.bin.sha256
```

La segunda instrucción presupone que se ha preparado previamente un archivo de comprobación con el nombre y formato adecuados. La equivalencia entre dos valores no certifica la autenticidad de la fuente, la legalidad de la obtención, la exhaustividad de la adquisición ni la ausencia de errores de interpretación. Es una propiedad de integridad aplicada a los bytes comparados.

Las comprobaciones periódicas deben estar justificadas por el riesgo y el sistema de almacenamiento. Un repositorio con detección de corrupción a nivel de bloques, redundancia y vigilancia activa puede adoptar una estrategia distinta de un conjunto de discos externos desconectados. En cualquier caso, interesa documentar fecha, herramienta, objeto examinado, valor esperado, valor obtenido, resultado y tratamiento de excepciones. La discrepancia no debe desaparecer del histórico porque una copia de respaldo permita sustituir el archivo.

La copia de seguridad del repositorio se diseña a partir de objetivos definidos de recuperación. El *recovery point objective* (RPO) expresa la pérdida de datos tolerable medida en tiempo; el *recovery time objective* (RTO), el plazo que se pretende para restaurar el servicio. Ambos conceptos proceden de continuidad de negocio y deben adaptarse al valor de las evidencias. Un RPO de 24 horas puede ser inaceptable para registros de custodia o adquisiciones que no pueden repetirse. Además, hay situaciones en las que no existe una adquisición recuperable fuera del sistema principal, de modo que el riesgo no se reduce a un número abstracto.

El laboratorio debe ensayar restauraciones sobre un espacio separado. La prueba debe comprobar tanto la recuperación de los contenidos como la de su identidad, metadatos y permisos. Recuperar un archivo sin los manifiestos que explican su procedencia puede preservar los bytes, pero empobrecer gravemente su valor operativo y probatorio.

6.2.7. Cifrado, claves y tratamiento de información sensible

El cifrado en reposo protege frente a ciertos accesos no autorizados al almacenamiento. El cifrado de transporte reduce la exposición durante transferencias entre estaciones y repositorios. Ambos requieren gestión cuidadosa de claves, copias de recuperación y separación de funciones. En un laboratorio, perder una clave de cifrado puede equivaler a perder el acceso a un conjunto irremplazable de evidencias; conservar todas las claves junto a las propias evidencias puede anular buena parte de la protección.

Conviene distinguir entre claves de infraestructura, claves utilizadas para abrir evidencias cifradas y credenciales temporales de proveedores cloud. Pertenecen a ciclos de vida diferentes. Las primeras sostienen el servicio, las segundas pueden constituir material relacionado con el caso y las terceras quizá deban revocarse al terminar una exportación. Su gestión debe quedar regulada sin escribirlas innecesariamente en bitácoras, comandos visibles, capturas de pantalla o repositorios de código.

Los conjuntos de evidencia contienen con frecuencia datos no relacionados con el objeto de la investigación. La capacidad técnica de consultar una carpeta no implica autorización para revisar todo su contenido. El almacenamiento debe permitir aplicar segmentación por caso, registro de accesos y medidas de minimización en los derivados e informes. Cuando una revisión produce extractos de correos, historiales médicos o documentos personales ajenos al objeto investigado, el laboratorio debe poder controlar su circulación y los destinatarios autorizados.

Para compartir resultados, una alternativa es elaborar paquetes de entrega que contengan únicamente los archivos necesarios, manifiestos de integridad, explicación metodológica y un registro de salida. No se debe sustituir esta selección razonada por una copia completa del directorio de trabajo. Las exportaciones automáticas merecen revisiones específicas para detectar rutas absolutas, nombres de usuario, tokens, claves o comentarios internos inadvertidamente incluidos.

6.2.8. Capacidad de almacenamiento y política de retención

Un almacenamiento de evidencias no puede administrarse como un directorio temporal del que se borran los casos más antiguos cuando falta espacio. La retención se vincula a la finalidad, el régimen jurídico aplicable, las obligaciones contractuales y las instrucciones de la autoridad o responsable competente. Los plazos pueden diferir entre el soporte original, la adquisición, los archivos de trabajo, la información de auditoría y el informe definitivo.

Por tanto, cada expediente necesita un estado: abierto, pendiente de revisión, entregado, sometido a conservación extraordinaria, cerrado o sujeto a eliminación autorizada, entre otros. La transición de estados debe registrarse. La supresión de un derivado que ya no resulta necesario puede ser legítima, mientras que eliminar un original sometido a una orden de conservación sería gravísimo. La automatización del almacenamiento debe conocer esa diferencia.

Los equipos de análisis suelen acumular datos intermedios que pueden ser especialmente sensibles: índices que contienen fragmentos de textos, bases de datos de palabras clave,

miniaturas, cachés, ficheros temporales y resultados de herramientas. Una política de retención que solo mencione imágenes E01 y documentos PDF deja fuera una parte importante de la información del caso. La limpieza del espacio de trabajo requiere identificar primero los derivados y comprobar qué otros procesos los necesitan.

El almacenamiento también envejece. Las tecnologías, interfaces y formatos cambian. Una evidencia que deba conservarse durante años necesita una estrategia de migración controlada para evitar dependencia de hardware obsoleto o de una aplicación sin soporte. Migrar no significa reinterpretar: cuando sea posible, se preservan los bytes originales y los metadatos de custodia; la transformación necesaria se registra como un nuevo derivado y no como una modificación silenciosa del original.

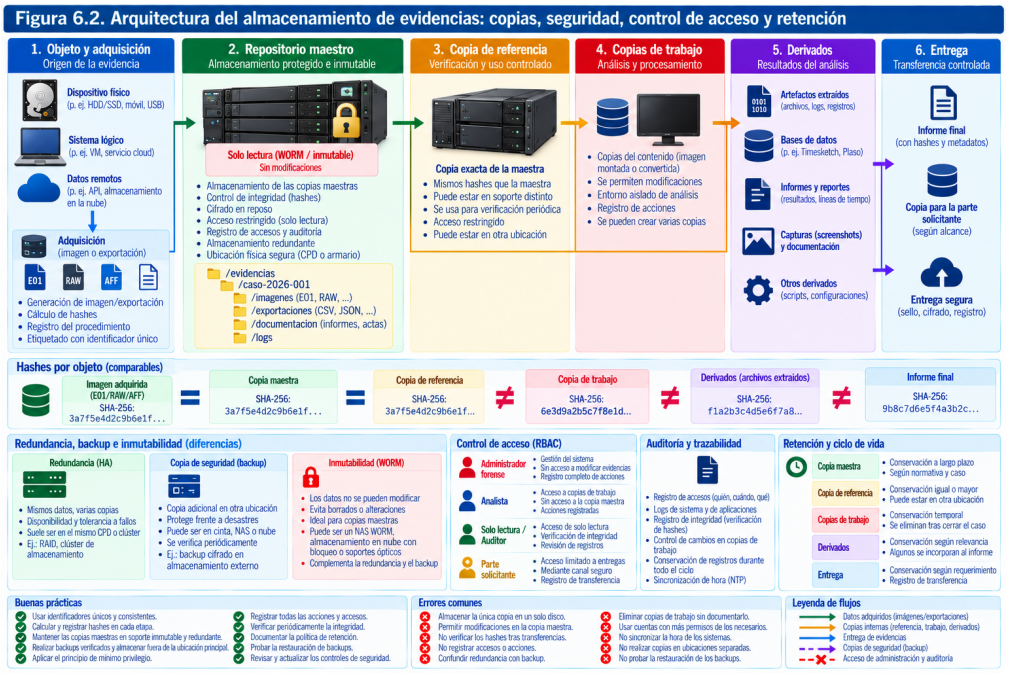


Figura 31: Arquitectura del almacenamiento de evidencias

6.2.9. Ejemplo de diseño: dos laboratorios, dos escalas

Imaginemos un laboratorio pequeño con dos analistas y un volumen moderado de casos. Puede disponer de un puesto de adquisición dedicado, dos estaciones de análisis, almacenamiento central con permisos por expediente, copia de seguridad fuera de línea y una plataforma de virtualización para pruebas. Su prioridad es documentar correctamente las intervenciones y disponer de procedimientos validados para las técnicas más utilizadas. No

necesita replicar la infraestructura de una unidad nacional de investigación para actuar con rigor.

Una unidad de mayor tamaño quizá requiera varios puestos de adquisición, capacidad para procesar simultáneamente evidencias de móviles y ordenadores, sistemas de indexación distribuida, almacenamiento con niveles de rendimiento, administración central de identidades y repositorios sometidos a retenciones diferenciadas. La complejidad trae ventajas de escala, pero también nuevas dependencias: versiones coordinadas, colas de trabajo, control de recursos compartidos y una auditoría capaz de reconstruir qué nodo ejecutó cada operación.

En ambos casos, la pregunta correcta es la misma: ¿puede reconstruirse el camino desde la fuente hasta el hallazgo sin recurrir a suposiciones sobre el comportamiento del entorno? Si la respuesta es negativa, el laboratorio necesita corregir su arquitectura o sus procedimientos, con independencia de que cuente con dos o doscientas máquinas.

6.3. Herramientas forenses libres y comerciales

6.3.1. La herramienta como medio, no como garantía

La elección de una herramienta forense suele comenzar por una pregunta incorrecta: cuál es «la mejor». Sin especificar la tarea, el tipo de evidencia, la versión de formato, los requisitos jurídicos y los recursos disponibles, la pregunta no tiene una respuesta útil. Un programa puede ser excelente para examinar una imagen NTFS y resultar inadecuado para adquirir un teléfono de última generación. Otro puede crear un informe visual convincente sin proporcionar suficiente información sobre el origen de determinados campos. Las capacidades no se comparan mediante una calificación global, sino función por función.

La herramienta tampoco sustituye el razonamiento. Un artefacto señalado como «ejecución de programa» necesita interpretarse de acuerdo con la fuente que lo produjo, la versión del sistema operativo y las condiciones conocidas de generación. Un evento marcado como «archivo eliminado» puede provenir de una operación del usuario, de sincronización, de mantenimiento automático o de una aplicación. Ninguna interfaz gráfica elimina la obligación de comprobar qué significa realmente el dato.

Las aplicaciones comerciales suelen aportar interfaces integradas, soporte contratado, conectores específicos y funciones que reducen tiempos en determinados flujos de trabajo. Las herramientas libres ofrecen transparencia de código en muchos proyectos, posibilidad de automatización, ausencia de ciertas dependencias de licencia y capacidad de especialización. Ninguna de las dos categorías es inherentemente más fiable. La transparencia de

código no garantiza que se haya auditado correctamente; el carácter comercial no constituye validación independiente.

Lo prudente es construir una **cartera de herramientas**: soluciones principales para tareas frecuentes, herramientas secundarias para corroboración y utilidades especializadas para casos concretos. La cartera debe mantenerse como un inventario vivo, con versiones, fuentes oficiales, procedimientos comprobados, restricciones de licencia, responsables y resultados de las pruebas locales.

6.3.2. Familias de herramientas y funciones

Las aplicaciones de **adquisición** realizan imágenes de dispositivos o extraen conjuntos de datos. Deben seleccionarse atendiendo a interfaces, formatos, gestión de errores, registro de parámetros y mecanismos de verificación. En este grupo pueden aparecer utilidades de línea de comandos, sistemas especializados de imagen y aplicaciones gráficas. El capítulo anterior explicó que no todas las adquisiciones tienen la misma cobertura: una imagen de bloques, una exportación lógica y un paquete devuelto por una API son objetos distintos.

Las herramientas de **análisis de sistemas de archivos** interpretan particiones, directorios, metadatos, estructuras internas y contenido. *The Sleuth Kit* proporciona utilidades de línea de comandos y bibliotecas para estas funciones, mientras que *Autopsy* ofrece un entorno gráfico extensible para investigaciones. Pueden combinarse para contrastar resultados, pero compartir componentes internos exige cuidado: dos interfaces basadas en la misma biblioteca no representan necesariamente una corroboración independiente.

La **informática forense de memoria** requiere otro tipo de instrumentación. Volatility 3 permite extraer e interpretar artefactos de determinados sistemas a partir de volcados de memoria. Su comportamiento depende del sistema de origen, la disponibilidad de símbolos, el complemento utilizado y el estado del volcado. Un proceso que no aparece en una salida no puede considerarse inexistente sin estudiar la cobertura y las limitaciones del método. La ausencia de hallazgos tampoco equivale automáticamente a ausencia de actividad sospechosa.

El análisis de **registros y líneas temporales** puede apoyarse en Plaso, cuyos componentes `log2timeline` y `psort` permiten extraer y procesar eventos, y en Timesketch, orientado a explorar cronologías colaborativamente. En ambos casos es esencial conservar la referencia a las fuentes, el significado de las marcas temporales y los filtros aplicados. El volumen de eventos que una herramienta representa gráficamente puede inducir una apariencia de precisión mayor que la disponible en los registros originales.

Las herramientas de **redes** como Wireshark y sus utilidades asociadas permiten inspeccionar capturas de paquetes y reconstruir determinados intercambios. Su cobertura depende de dónde se obtuvo la captura, qué tráfico atravesó el punto de observación, qué protocolos se reconocen y cuánto contenido está cifrado. Un PCAP capturado en un tramo de la red no constituye una imagen completa de toda la comunicación del sistema.

Para **respuesta remota y recopilación de artefactos**, Velociraptor proporciona un modelo basado en consultas y artefactos sobre equipos, incluyendo mecanismos de recogida mediante clientes y colectores preparados para actuar sin comunicación continua con un servidor. Estos procedimientos son útiles en incidentes distribuidos, pero pueden modificar el equipo de origen, consumir recursos y producir registros nuevos. El inventario de efectos previstos y la autorización forman parte de su puesta en servicio.

Hay herramientas de **análisis de malware** que examinan metadatos, importaciones, cadenas y estructuras de ejecutables, otras observan el comportamiento en ejecución y otras ayudan a aplicar reglas YARA. El laboratorio debe distinguir análisis estático, instrumentación y ejecución controlada. Abrir una muestra en un visor hexadecimal no plantea el mismo riesgo que ejecutarla en una máquina virtual con acceso de red. Cada técnica requiere una zona y un procedimiento acordes con su riesgo.

Por último, existen herramientas de **gestión del caso, informes y administración**. Su función no consiste en descubrir artefactos, sino en mantener la identidad de los objetos, asignar tareas, documentar revisiones y generar entregables. Una hoja de cálculo, un gestor documental o un repositorio Git pueden aportar valor en determinadas tareas, siempre que su uso cumpla los requisitos de confidencialidad, control de cambios y retención del expediente. No deben introducirse automáticamente datos sensibles del caso en plataformas externas por la comodidad de disponer de colaboración.

6.3.3. Un catálogo orientativo y sus límites

El siguiente cuadro identifica ejemplos representativos, no una clasificación exhaustiva ni una recomendación comercial. Las funcionalidades concretas dependen de la edición, el sistema operativo, las licencias y la versión instalada.

Familia	Ejemplos	Utilidad principal	Cautela de validación
Sistemas de archivos	The Sleuth Kit, Autopsy	Interpretación de imágenes, metadatos y archivos	Comprobar sistema de archivos y artefactos admitidos
Memoria	Volatility 3	Extracción e interpretación de estructuras de RAM	Verificar símbolos, sistema y complementos
Cronologías	Plaso, Timesketch	Extracción, filtrado y correlación de eventos	Preservar zonas horarias, procedencia y filtros
Redes	Wireshark, TShark	Inspección de PCAP y protocolos	Estudiar punto de captura y tráfico no observable
Recopilación remota	Velociraptor	Colección estructurada de artefactos	Evaluar impacto en el equipo y cobertura del colector
Imágenes y examen integrado	FTK Imager, X-Ways Forensics, EnCase	Adquisición, examen y determinadas funciones integradas	Probar funciones y formatos efectivamente utilizados
Análisis integrado y correlación	Magnet AXIOM, Belkasoft X	Examen de distintas fuentes y presentación de resultados	Revisar interpretación de artefactos y trazabilidad
Entornos de investigación	SIFT Workstation, CAINE, REMnux	Paquetes y utilidades especializadas	Confirmar versiones incluidas y uso previsto
Análisis programático	Python, bibliotecas especializadas, consultas SQL	Extracción y tratamiento automatizado	Ensayar con datos conocidos y guardar el código exacto

El hecho de que una aplicación figure en el catálogo NIST de herramientas no significa que haya sido probada ni certificada por NIST: el propio catálogo advierte que parte de la información procede del desarrollador. Los **informes de ensayo CFTT**, cuando existen para la herramienta y función pertinente, ofrecen una base de evaluación más específica. Aun así, el laboratorio debe comprobar que el entorno, la versión y las condiciones de uso coinciden razonablemente con aquellas de las pruebas publicadas.

Para el análisis móvil, cloud o de aplicaciones, la compatibilidad puede cambiar con rapidez. Es preferible evitar expresiones como «permite extraer todos los mensajes» o «recupera toda la actividad de un usuario». Los fabricantes incorporan y retiran soporte, los proveedores modifican APIs y los sistemas operativos alteran sus esquemas de almacenamiento. Una evaluación seria precisa fecha, combinación de versiones y resultado de pruebas representativas.

6.3.4. Selección basada en requisitos medibles

Imaginemos que el laboratorio debe seleccionar una herramienta para examinar imágenes E01 de estaciones Windows. El proceso empieza estableciendo criterios: capacidad de abrir las imágenes utilizadas por la organización, comprobar sus segmentos, recuperar estructura de volúmenes, exportar archivos con sus metadatos, generar una cronología, conservar referencias al origen y producir registros de errores. Se añade la posibilidad de operar sin acceso a Internet, el coste de la licencia y las condiciones del soporte.

No todos los criterios tienen el mismo peso. La capacidad de presentar miniaturas de forma atractiva puede mejorar el trabajo, pero no compensa que el programa interprete incorrectamente un campo temporal crítico. Un modelo sencillo puede diferenciar requisitos imprescindibles, deseables y secundarios. Los imprescindibles se ensayan primero y funcionan como condiciones de aceptación. Solo después tiene sentido comparar comodidad, rendimiento o coste.

La selección debería considerar la **explicabilidad**. Una herramienta que permite exportar el archivo bruto, mostrar su ruta dentro de la imagen, indicar el parser aplicado y reproducir una consulta ofrece mayor capacidad de revisión que otra que presenta un único indicador sin fundamento accesible. Esto no obliga a descartar aplicaciones que abstraen mucha complejidad, pero sí a conocer qué partes pueden verificarse independientemente.

Es especialmente importante examinar el **modelo de dependencia** de los resultados. Si dos productos incorporan el mismo motor de interpretación, su coincidencia aporta menos independencia que si utilizan implementaciones diferentes. Si ambos leen una exportación ya transformada por un tercero, quizá estén corroborando únicamente el resultado de esa

transformación, no la fuente original. La independencia no se mide por el número de ventanas abiertas, sino por la diversidad efectiva de procesos y observaciones.

6.3.5. Versiones, firmas y procedencia del software

La instalación de herramientas debe seguir un procedimiento controlado. Conviene obtener los paquetes de fuentes oficiales, conservar referencias de descarga y verificar firmas o valores hash cuando el proyecto los publica por un canal confiable. También interesa guardar la versión exacta, la compilación, los módulos adicionales y las dependencias relevantes. Un archivo ejecutable llamado `forensic_tool.exe` no constituye una identificación suficiente.

Algunas soluciones descargan símbolos, módulos, firmas o reglas durante su uso. Ese comportamiento puede alterar resultados entre ejecuciones si no se controla. Es aconsejable conservar una instantánea del conjunto de reglas o de la versión del paquete utilizado, con su procedencia. En un análisis de memoria, por ejemplo, disponer de símbolos adecuados es esencial para interpretar determinadas estructuras; registrar solamente «se ejecutó Volatility» omite información crítica.

Los contenedores de software son útiles para fijar dependencias, pero la referencia a una etiqueta mutable como `latest` no permite reconstruir una ejecución pasada. Si se usa una imagen de contenedor, conviene registrar su identificador inmutable o digest, la configuración relevante, los volúmenes montados y los parámetros de ejecución. En los contenedores con acceso a imágenes evidenciales, además, los montajes en solo lectura deben comprobarse, no darse por supuestos.

Una solución comercial puede incorporar actualizaciones silenciosas, servicios en la nube o módulos que se activan por licencia. Es necesario conocer esas dependencias antes de instalarla en estaciones conectadas a evidencias sensibles. La comodidad operativa no justifica perder la capacidad de explicar qué versión o qué modelo de análisis produjo una conclusión determinada.

6.3.6. Herramientas auxiliares y riesgo de interpretación

Parte del trabajo se realiza con utilidades generales: editores hexadecimales, intérpretes de Python, lectores de SQLite, motores de búsqueda, herramientas de compresión, conversores de fecha y clientes de bases de datos. Su condición de herramienta no especializada no las invalida para uso forense. Sin embargo, hay que comprender sus efectos y comprobar que la transformación efectuada conserva la información relevante.

Una consulta SQL puede devolver filas correctas y a la vez omitir registros que no satisfacen un filtro mal diseñado. Un conversor de fecha puede interpretar una marca temporal como segundos desde 1970 cuando en realidad usa otra época o unidad. Un programa de extracción puede normalizar finales de línea o sustituir caracteres no representables. Si el analista no registra esas decisiones, el resultado puede parecer originario de la evidencia cuando en realidad es un producto transformado.

Por esta razón, un laboratorio debería conservar los datos fuente, las reglas o consultas aplicadas y el resultado de su ejecución. La salida visual puede ser el medio más claro para presentar un hallazgo, pero la posibilidad de reproducirlo descansa en la disponibilidad de los elementos anteriores.

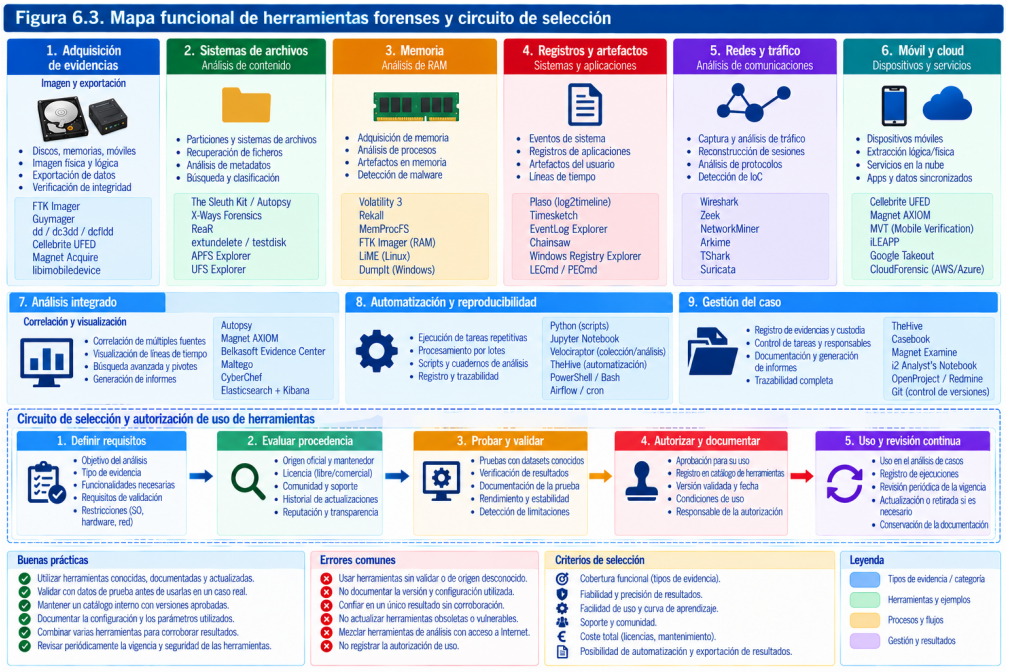


Figura 32: Herramientas forenses

6.3.7. Cuando ninguna herramienta resuelve por completo el problema

Las investigaciones reales contienen formatos desconocidos, aplicaciones propietarias y datos parcialmente corruptos. Una herramienta puede reconocer parte de una estructura sin comprender la totalidad de sus campos. En vez de forzar una interpretación mediante aproximaciones invisibles, el analista debe delimitar el resultado parcial y plantear técnicas com-

plementarias: análisis de cabeceras, inspección hexadecimal, reproducción experimental, documentación del fabricante o comparación con muestras conocidas.

En ocasiones será preferible desarrollar un parser específico. Esa decisión incrementa el control sobre el tratamiento de los datos, pero también la responsabilidad de probar el código. El resultado de un script propio no adquiere fiabilidad por estar escrito en Python ni la pierde por no proceder de un fabricante. Su fiabilidad dependerá de los casos de prueba, la cobertura conocida, la revisión independiente y la posibilidad de reproducir la transformación.

El catálogo de herramientas del laboratorio debe contener también **limitaciones conocidas**. Registrar que una versión interpreta incorrectamente ciertos valores, que un complemento falla con determinados archivos o que una función necesita permisos adicionales puede ahorrar horas y evitar conclusiones defectuosas. Un historial de incidencias técnicas, compartido internamente sin divulgar datos innecesarios de casos, es una forma de conocimiento acumulado.

6.4. Validación de herramientas

6.4.1. Qué significa validar y qué no significa

La validación es una de las diferencias más importantes entre un laboratorio capaz de producir resultados convincentes y un laboratorio capaz de defenderlos. Validar no consiste en abrir una aplicación, comprobar que arranca y guardar una captura de pantalla. Tampoco se reduce a calcular el hash del instalador ni a confirmar que un fabricante anuncia soporte para un formato. Se trata de reunir evidencia objetiva, mediante ensayos apropiados, de que un procedimiento o herramienta funciona de manera adecuada **para el uso previsto y dentro de condiciones conocidas**.

Conviene diferenciar varias actividades. La **verificación de instalación** confirma que la herramienta recibida y su entorno coinciden con lo esperado. La **comprobación funcional** permite observar si realiza una operación concreta. La **validación del método** pretende demostrar que ese procedimiento es apto para su finalidad; cuando una organización usa el término *validación de herramienta*, normalmente se refiere a comprobar funciones y límites aplicables al trabajo previsto. La **verificación de resultados de un caso** contrasta salidas concretas con la evidencia y, cuando procede, con técnicas independientes. Son actividades relacionadas, pero no intercambiables.

El programa Computer Forensics Tool Testing (CFTT) del NIST constituye una referencia relevante: establece especificaciones funcionales, procedimientos, criterios y conjuntos de prueba para evaluar herramientas. La documentación SWGDE, especialmente *Minimum Require-*

ments for Testing Tools Used in Digital and Multimedia Forensics, propone pruebas mínimas según categorías y riesgos. Sus recomendaciones no implican que todas las herramientas deban ensayarse de idéntica manera, ni que un resultado favorable cubra cualquier versión o configuración.

La norma ISO/IEC 17025:2017, aplicable a la competencia y funcionamiento consistente de laboratorios de ensayo y calibración, puede servir como marco general de calidad en ámbitos pertinentes. No debería afirmarse que utilizar una herramienta verificada convierte automáticamente a un laboratorio en acreditado, ni que todos los laboratorios forenses digitales estén necesariamente sujetos a los mismos requisitos de acreditación. Cualquier declaración formal debe relacionarse con el alcance concreto de la acreditación, la entidad evaluadora y la normativa aplicable.

6.4.2. Riesgo, criticidad y profundidad de la prueba

El esfuerzo de validación debe ser proporcional a las consecuencias de un error. Una herramienta que permite inspeccionar de forma auxiliar una cadena de texto plantea riesgos distintos de otra que escribe sobre la fuente durante una adquisición. La segunda puede destruir información irrecuperable; por ello necesita controles de mayor rigor antes de utilizarse sobre originales.

Es posible clasificar las herramientas en función de su intervención. Las de **protección y adquisición** pueden afectar directamente al soporte o determinar qué evidencia se conserva. Las de **procesamiento** transforman, extraen, indexan o interpretan datos. Las de **presentación** comunican resultados, elaboran gráficos y generan informes. Una misma aplicación puede pertenecer simultáneamente a varias categorías. No se valida «Autopsy» o «una suite forense» en abstracto: se prueban las funciones utilizadas y se documentan las limitaciones relevantes.

Un bloqueador de escritura exige comprobar que los intentos de modificación procedentes del anfitrión son bloqueados y que no impide la lectura esperada. Una herramienta de adquisición debe ensayarse con conjuntos conocidos que incluyan patrones comprobables, espacios no asignados y, cuando proceda, errores de lectura simulados. Un parser temporal necesita casos con zonas horarias, cambios de horario de verano y valores ambiguos. Un sistema de búsqueda ha de contrastarse con términos existentes y ausentes, codificaciones distintas y archivos que el producto declare soportar.

La priorización puede apoyarse en una matriz simple de **impacto y probabilidad**. El impacto es la gravedad de una posible alteración o interpretación incorrecta; la probabilidad se evalúa atendiendo a complejidad, madurez, cambios recientes, heterogeneidad de datos y

experiencia previa. La matriz ayuda a asignar recursos, pero no sustituye las obligaciones que pudieran resultar de un procedimiento de calidad o una norma aplicable.

6.4.3. Diseñar un conjunto de datos con verdad conocida

Un ensayo sólido requiere disponer de un conjunto cuyo contenido y comportamiento esperado sean conocidos antes de ejecutar la herramienta. En inglés suele denominarse *ground truth*. Puede tratarse de una imagen pequeña construida expresamente, registros generados en un entorno controlado o una muestra pública con respuestas documentadas. La clave es que el resultado esperado no se derive exclusivamente de la misma herramienta que se está comprobando: de lo contrario, la prueba se vuelve circular.

Supongamos que se desea evaluar un lector de imágenes forenses. Se construye un pequeño volumen de prueba y se incorporan archivos con nombres ASCII y Unicode, directorios anidados, distintas longitudes, contenidos conocidos y marcas temporales controladas. Cuando el sistema de archivos y el procedimiento lo permitan, se generan también archivos eliminados, espacio no asignado, archivos fragmentados y nombres potencialmente ambiguos. El laboratorio conserva una tabla que describe qué debería resultar visible y qué no puede garantizarse. La herramienta examinada se utiliza después sobre una adquisición de ese volumen.

Los resultados deben compararse con el manifiesto original y, cuando convenga, con otra técnica independiente. Si se esperan cincuenta archivos y se obtienen cuarenta y nueve, no basta anotar «casi correcto»: debe explicarse qué archivo falta, si el motivo es un defecto, una función no incluida o una propiedad del sistema de archivos. Una prueba que detecta límites conocidos puede ser más valiosa que una prueba aparentemente perfecta que nunca exigió a la herramienta.

Los datos sintéticos facilitan la repetición y evitan introducir información personal. No obstante, también tienen límites. Una imagen artificialmente pequeña puede no reproducir problemas de escala, daños físicos, escrituras concurrentes o combinaciones de software que aparecen en equipos reales. Por eso conviene combinar pruebas controladas con conjuntos públicos representativos y ensayos operativos que no expongan datos ajenos sin autorización.

El portal CFReDS de NIST ofrece conjuntos de referencia y materiales útiles para ensayar herramientas y formar profesionales. Debe revisarse la documentación de cada conjunto: no todos contienen la misma granularidad de respuestas esperadas ni permiten medir las mismas funciones. Un conjunto de datos diseñado para recuperación de archivos no valida automáticamente una herramienta de correlación de identidades cloud.

6.4.4. Casos positivos, negativos y adversos

Un test útil incluye casos en los que una función **debe producir un hallazgo** y casos en los que **no debe producirlo**. Si un script identifica conexiones a una IP concreta, conviene darle registros con coincidencias legítimas, registros sin coincidencias y registros que contengan la cadena dentro de otro campo. El objetivo es comprobar tanto falsos negativos como falsos positivos, sin asumir que la ausencia de ambos en una muestra pequeña representa el comportamiento de toda la población de datos.

Los casos límite también son esenciales. Una marca temporal puede estar fuera del rango habitual; un fichero puede contener bytes nulos; una ruta puede incluir espacios, comillas, caracteres de control o Unicode; una exportación JSON puede presentar campos opcionales; un archivo de log puede terminar con una línea incompleta. Si la herramienta interpreta silenciosamente estas condiciones de manera errónea, el problema puede manifestarse mucho después en una conclusión de caso.

Las pruebas deberían cubrir **errores controlados**. Un segmento de imagen ausente, un fichero corrupto, un volumen de almacenamiento lleno o una conexión remota interrumpida no deberían conducir a un mensaje de éxito indistinguible del procesamiento íntegro. Cuando el sistema no pueda completar la operación, el analista necesita saber qué se obtuvo, qué faltó y cuál fue la causa conocida o probable. Una herramienta que falla de manera visible puede ser más segura que otra que entrega resultados parciales sin advertirlo.

Además se deben ensayar los **mecanismos de salida**. La exportación de un archivo puede modificar metadatos del sistema de archivos de destino; la generación de un CSV puede transformar separadores o codificaciones; la exportación de un informe puede truncar campos demasiado largos. El laboratorio debe poder rastrear esas modificaciones y decidir si el producto generado es apto para la finalidad del informe.

6.4.5. Repetibilidad, reproducibilidad y contraste independiente

En lenguaje cotidiano, repetibilidad y reproducibilidad suelen utilizarse como sinónimos. En el trabajo técnico resulta útil distinguir, al menos, entre obtener resultados consistentes bajo condiciones esencialmente iguales y corroborarlos mediante otro operador, herramienta o entorno. La terminología formal puede variar según la referencia adoptada, por lo que conviene definirla expresamente en los procedimientos internos.

Una prueba de **repetibilidad** puede consistir en ejecutar tres veces un parser sobre la misma muestra congelada y comprobar si produce el mismo conjunto de registros normalizados.

En cada ejecución se registran versión, parámetros, entrada, hora, código de salida y diferencias. Si el programa inserta un identificador aleatorio o una hora de procesamiento en su resultado, los archivos completos pueden diferir aunque los campos interpretados sean idénticos. Por eso las comparaciones deben atender a la naturaleza de la salida y no confiar ciegamente en un único hash del informe.

Una prueba de **reproducción externa** puede entregar el conjunto de prueba, el procedimiento y las expectativas a otro analista. Si este obtiene resultados distintos, debe investigarse si cambió la versión, el entorno, la configuración, el sistema de archivos o la interpretación humana. El desacuerdo no es necesariamente un fracaso: puede revelar una dependencia que nadie había documentado.

El **contraste con otra herramienta** aporta información cuando las implementaciones son suficientemente independientes. Sin embargo, la mera coincidencia no demuestra verdad. Dos herramientas pueden compartir una biblioteca de interpretación o un error conceptual. Cuando sea posible, la corroboración más valiosa relaciona la salida procesada con datos fuente observables, especificaciones de formato, registros de otro sistema y experimentos controlados.

6.4.6. Plan de prueba y criterios de aceptación

Un procedimiento de validación debe existir antes de conocer los resultados. De otro modo, el investigador puede terminar ajustando inconscientemente las condiciones hasta que la herramienta parezca funcionar. La ficha del ensayo debería contener una referencia de versión, el objetivo, el conjunto de datos, las condiciones de entorno, los pasos previstos, las expectativas y los criterios para decidir si una función es apta para el uso previsto.

Una plantilla simplificada sería:

Campo	Contenido que debe registrarse
Identificador	Código único del ensayo
Herramienta y función	Producto, módulo, versión y operación probada
Entorno	Sistema operativo, dependencias y configuración relevante
Conjunto de prueba	Identificador, procedencia, hash y descripción

Campo	Contenido que debe registrarse
Expectativa	Resultados que deberían obtenerse y criterios de tolerancia
Procedimiento	Pasos, parámetros, comandos y condiciones
Resultado observado	Salidas, errores, tiempos y comportamientos inesperados
Discrepancias	Diferencias respecto a las expectativas y evaluación
Conclusión	Aptitud para el uso previsto y limitaciones conocidas
Revisión	Responsable, fecha y aprobación según procedimiento interno

El criterio de aceptación no debería limitarse a «sin errores». Una herramienta de recuperación puede producir resultados parciales de forma legítima porque los bloques se han sobrescrito; otra puede encontrar archivos pero asignarles nombres incorrectos. Debe fijarse qué aspectos son necesarios para considerar adecuada la función. Si se pretende usar un parser para calcular una cronología judicial, la precisión de las marcas temporales y la procedencia de cada evento son requisitos esenciales, no detalles secundarios.

Los resultados de una prueba se archivan como evidencias del **sistema de calidad del laboratorio**, separados del material de los casos. Esta separación permite volver a comprobar una herramienta sin exponer datos confidenciales. Cada ensayo puede incluir scripts, muestras, logs, capturas, tablas de comparación e informe de aceptación.

6.4.7. Ejemplo de validación de una función de búsqueda

Supongamos que una herramienta afirma localizar expresiones en archivos de texto UTF-8. El laboratorio prepara un conjunto con cien archivos: algunos contienen la expresión en distintas posiciones, otros contienen variantes de mayúsculas, otros incluyen caracteres Unicode y otros contienen una cadena parecida que no debería coincidir. El inventario de verdad conocida se genera y comprueba mediante un procedimiento independiente.

La prueba se divide en escenarios. En el primero se busca la coincidencia exacta y se exige que aparezcan todos los archivos que contienen esa secuencia de bytes. En el segundo se

utiliza una búsqueda insensible a mayúsculas y se verifica el comportamiento con caracteres Unicode. En el tercero se introduce un archivo inaccesible o corrupto y se comprueba si la herramienta informa de la excepción. En el cuarto se exportan resultados para confirmar que sus rutas y ubicaciones no se alteran.

Si la herramienta obtiene el conjunto esperado en los escenarios primero y tercero, pero presenta una ambigüedad en Unicode, puede considerarse apta para búsquedas exactas sobre archivos válidos y no apta, sin un procedimiento complementario, para búsquedas insensibles a mayúsculas con determinadas codificaciones. La conclusión restringida es más útil que un sello genérico de «validada».

Una validación rigurosa se relaciona así con el **uso declarado**. La organización no tiene por qué prohibir una herramienta para todas sus funciones cuando una prueba descubre un límite concreto. Debe, eso sí, impedir que el operador la utilice fuera de las condiciones conocidas sin evaluación adicional.

6.4.8. Ensayar un bloqueador de escritura sin arriesgar una evidencia

La prueba de un bloqueador requiere un soporte de ensayo, nunca una evidencia original para la primera comprobación. Se prepara el soporte con datos conocidos y se documenta su estado inicial. Luego se conecta a través del bloqueador y se intenta realizar, de manera controlada, una operación de escritura que debería resultar denegada. Se verifica si hubo cambios en los bytes accesibles mediante lecturas y hashes adecuados, y se comprueba además que la lectura a través del bloqueador funciona correctamente.

El protocolo debe tener en cuenta que el tamaño del medio, la interfaz, los comandos y las capacidades del bloqueador pueden afectar al resultado. La comprobación de una única escritura ordinaria no demuestra que el dispositivo bloquee todas las clases posibles de comandos. Para evaluaciones más amplias pueden utilizarse procedimientos y materiales como los desarrollados por CFTT y su iniciativa *Federated Testing*. Las pruebas que pudieran alterar el soporte deben ejecutarse exclusivamente sobre datos de laboratorio desechables.

El informe de validación identifica modelo, número de serie, firmware, puertos, adaptadores, versión de software y tipo de soporte. Si se actualiza el firmware o se cambia un adaptador relevante, puede ser necesario repetir las pruebas afectadas. El laboratorio no debería extrapolar un resultado favorable a combinaciones jamás comprobadas.

6.4.9. Automatizaciones y parsers propios: especial precaución

Los scripts locales pueden reducir tareas repetitivas, pero su familiaridad suele generar una falsa sensación de seguridad. Un pequeño programa que renombra archivos puede alterar asociaciones si se ejecuta sobre una ruta equivocada; un parser defectuoso puede cambiar unidades temporales, ignorar registros o producir duplicados; una consulta SQL incompleta puede excluir eventos relevantes. Su apariencia de simplicidad no elimina sus consecuencias.

Para utilidades internas de influencia significativa es recomendable realizar revisión por una persona distinta del desarrollador cuando sea viable, construir conjuntos de prueba que no se hayan utilizado solamente durante la programación y conservar los resultados. Las recomendaciones SWGDE distinguen estas herramientas de simples auxiliares administrativos y proponen pruebas proporcionadas a la complejidad y al efecto sobre los resultados.

En un proyecto versionado, cada modificación del script debería incluir una descripción, las pruebas ejecutadas y, cuando corresponda, una comparación entre resultados anteriores y nuevos. Una mejora de rendimiento que cambia la cantidad de registros detectados requiere explicación, incluso cuando el programador está convencido de que la nueva versión es más correcta.

6.4.10. Errores descubiertos durante un caso y gestión de cambios

La validación previa disminuye riesgos, pero no elimina la aparición de defectos. Si durante un caso se descubre que una versión interpreta incorrectamente una clase de artefactos, es necesario delimitar su impacto: qué función, qué entradas, qué casos y qué conclusiones podrían estar afectados. Se suspende o restringe el uso de la función cuando el riesgo lo aconseje y se comunica la incidencia a quienes correspondan.

Después debe ensayarse la hipótesis del defecto sobre datos conocidos y buscarse un método de corroboración. Puede ser necesario reprocesar evidencias, corregir informes o emitir un anexo explicativo. La trazabilidad exige conservar resultados anteriores con su estado, documentar la corrección y dejar visible la relación entre ambos. Sobrescribir silenciosamente un informe defectuoso destruye información necesaria para comprender lo ocurrido.

La validación es por tanto un ciclo: se establecen requisitos, se ensaya, se autoriza el uso, se monitorizan incidencias, se revisan cambios y se reevalúa cuando la tecnología o las necesidades se modifican. Una herramienta no pasa de «no validada» a «válida para siempre» mediante un único acto administrativo.

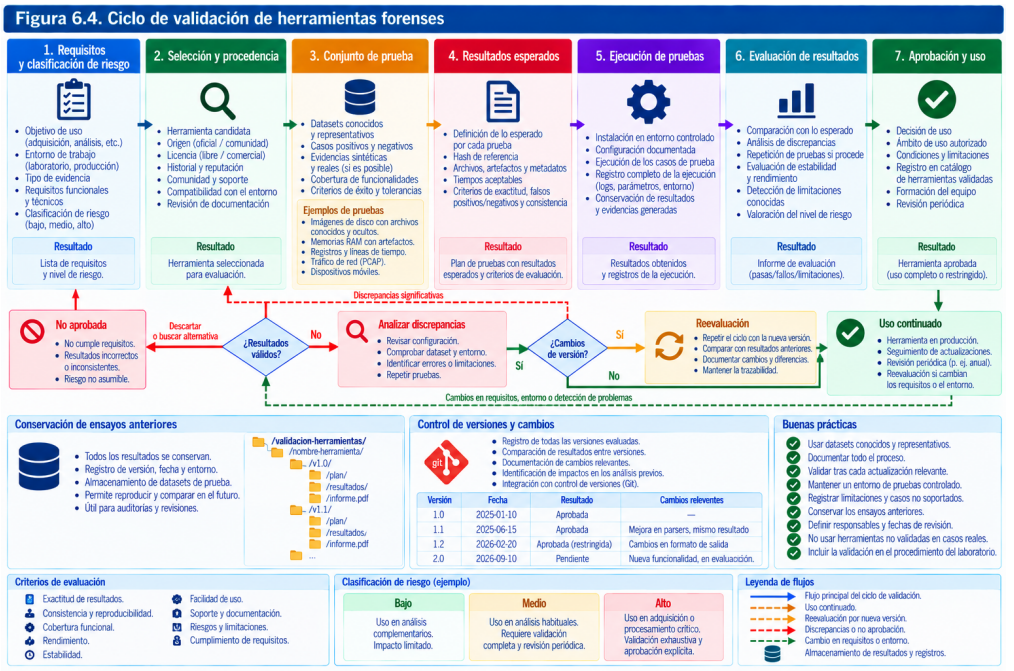


Figura 33: Validación de herramientas

6.4.11. La documentación de validación como garantía de independencia

La existencia de un informe de prueba no debería reducirse a una formalidad. Su función es permitir que otra persona entienda qué se hizo, con qué medios, qué se esperaba encontrar y por qué se tomó una decisión. Un resumen ejecutivo puede expresar «apta para extraer archivos de imágenes RAW NTFS en las condiciones ensayadas», pero debe enlazar con registros suficientes para demostrarlo.

Cuando se utilizan pruebas publicadas por terceros, hay que distinguir su aceptación documental de la verificación propia del entorno. El laboratorio puede adoptar resultados externos si su procedimiento de calidad lo permite y la correspondencia con el uso previsto es razonable. Esa adopción exige identificar fuente y alcance, no copiar un logotipo institucional a la ficha de un producto.

El principio editorial que debe retenerse es sencillo: **la confianza se deposita en una combinación documentada de método, implementación, condiciones de uso y revisión; no en el nombre de una aplicación**. Esa idea resulta especialmente importante cuando el laboratorio incorpora técnicas nuevas que todavía no han acumulado experiencia operativa suficiente.

6.5. Automatización, trazabilidad y reproducción de análisis

6.5.1. Automatizar no es delegar el juicio pericial

La automatización ayuda a tratar grandes volúmenes de datos, aplicar procedimientos de forma consistente y repetir operaciones que manualmente serían lentas o propensas a errores. También puede multiplicar un defecto: un script que interpreta mal una fecha generará la misma conclusión equivocada sobre miles de registros. Por ese motivo, el objetivo principal no debe ser ejecutar más comandos en menos tiempo, sino construir procesos **observables, controlables y revisables**.

Es útil distinguir entre tareas mecánicas y tareas interpretativas. Calcular hashes, inventariar archivos, extraer metadatos, convertir formatos o comprobar la existencia de campos son funciones que admiten una elevada automatización cuando están bien definidas. Decidir si una conexión implica exfiltración, si una secuencia de autenticaciones corresponde a un acceso ilegítimo o si una persona concreta realizó una operación exige examinar hipótesis, contexto y limitaciones. Las herramientas pueden ayudar a organizar esa información, pero no deben convertirse en el origen no cuestionado de la conclusión.

Cada automatización debería responder a preguntas prácticas: ¿qué entradas admite? ¿Qué hace si falta un archivo? ¿Qué operación puede modificar los datos? ¿Qué registros produce? ¿Cuánto ocupa la salida? ¿Cómo detecta un procesamiento parcial? ¿Qué versiones de herramientas invoca? ¿Es posible detenerla sin dejar resultados aparentemente completos? ¿Cómo se puede comparar el resultado con una ejecución anterior? La capacidad para responder estas cuestiones es tan importante como que el programa funcione en el caso habitual.

6.5.2. Diseñar el flujo de trabajo como una secuencia de transformaciones

Una arquitectura automatizada robusta separa **entradas**, **procesamiento** y **salidas**. Las entradas se identifican y verifican antes de comenzar. El procesamiento utiliza una versión determinada de las herramientas y recibe parámetros explícitos. Las salidas se guardan en un destino diferente, reciben identificadores y se acompañan de logs. Si un paso falla, la ejecución debe comunicarlo de manera inequívoca y conservar la información suficiente para determinar qué se completó.

El diseño puede imaginarse como un grafo dirigido de operaciones: una adquisición alimenta varios procesos de extracción; sus resultados contribuyen a una cronología, a una tabla de artefactos y a un conjunto de indicadores; los hallazgos finales remiten a los derivados y estos a su vez a la adquisición. El grafo no necesita una aplicación compleja para existir:

puede representarse mediante manifiestos JSON, una base de datos o ficheros de control. Lo esencial es que las relaciones sean explícitas.

Un flujo reproducible distingue el **identificador del caso**, el **identificador del objeto adquirido**, la **ejecución concreta** y el **resultado generado**. Si un parser se lanza dos veces sobre la misma imagen con parámetros distintos, ambas salidas proceden del mismo origen, pero no son el mismo procesamiento. Si se detecta un error, la nueva ejecución no debería reemplazar silenciosamente a la anterior.

Una regla útil consiste en considerar los resultados como derivados inmutables de una ejecución documentada. Cuando algo necesita cambiarse, se crea una nueva versión y se deja registrada la relación de sustitución o corrección. Este enfoque impide que una actualización automática de una base de datos borre, sin querer, los resultados que sustentaron un informe anterior.

6.5.3. Manifiestos, metadatos y registros de ejecución

Un **manifiesto** describe qué objetos participaron en un procesamiento y cómo se relacionan. Puede incluir sus identificadores, rutas relativas, tamaños, hashes, tipos, tiempos de captura y referencias de custodia. El registro de ejecución añade fecha y zona horaria, identidad o cuenta técnica, nombre y versión de la herramienta, parámetros, código de salida, mensajes de error y ubicación de resultados.

Para un proceso de extracción de eventos, un manifiesto simplificado podría representarse de la siguiente forma:

```
{
  "schema_version": "1.0",
  "case_id": "CASO-2026-014",
  "run_id": "PROC-2026-014-003",
  "input": {
    "evidence_id": "ADQ-014-03-A",
    "object": "imagen_prueba.raw",
    "sha256": "VALOR_SHA256_REAL_DEL_OBJETO"
  },
  "process": {
    "tool": "herramienta-de-extraccion",
    "version": "VERSION_COMPROBADA",
    "configuration_id": "CFG-EXTRACCION-02"
  },
  "output": {
```

```
    "artifact_id": "DER-2026-014-022",
    "object": "eventos.jsonl",
    "status": "pendiente_de_verificacion"
  }
}
```

Los valores en mayúsculas son marcadores explicativos, no hashes válidos ni metadatos obtenidos de una ejecución real. El manifiesto constituye un ejemplo de estructura, no un estándar interoperable universal. Si se adopta un esquema para la organización, conviene definir qué campos son obligatorios, cómo se versiona y qué controles impiden contradicciones entre registros.

La fecha de ejecución debe almacenarse preferentemente de forma que incluya zona horaria o se exprese inequívocamente en UTC. Es importante conservar, además, el valor temporal original de los artefactos y las decisiones usadas para interpretarlo. Normalizar una fecha para visualizarla no debería destruir su representación inicial.

Los logs técnicos pueden contener rutas, nombres de usuario, direcciones de correo, tokens o fragmentos de evidencias. La trazabilidad no exige divulgar esta información indiscriminadamente. Se debe restringir el acceso a las bitácoras, minimizar secretos y utilizar mecanismos de redacción o seudonimización cuando los registros se incorporen a informes distribuidos a terceros.

6.5.4. Un manifiesto SHA-256 sobre archivos sintéticos

El siguiente ejemplo de Python genera un inventario de hashes para **archivos de prueba** contenidos en un directorio y escribe el resultado fuera de él. No adquiere discos ni certifica cadena de custodia; sirve para comprender la construcción reproducible de un manifiesto sencillo. Es conveniente ejecutarlo en un entorno de experimentación, con ficheros propios, y validar su comportamiento antes de incorporarlo a procedimientos de trabajo.

```
#!/usr/bin/env python3
"""Inventario SHA-256 de un directorio de prueba.

Uso: python3 inventario.py ENTRADA SALIDA_JSON
No modifica los contenidos de ENTRADA.
La salida debe estar fuera del directorio de entrada.
"""
import hashlib
import json
import sys
```

```
from datetime import datetime, timezone
from pathlib import Path


def sha256_archivo(ruta, bloque=1024 * 1024):
    resumen = hashlib.sha256()
    with ruta.open("rb") as archivo:
        while True:
            datos = archivo.read(bloque)
            if not datos:
                break
            resumen.update(datos)
    return resumen.hexdigest()


def main():
    if len(sys.argv) != 3:
        raise SystemExit("Uso: inventario.py ENTRADA SALIDA_JSON")

    origen = Path(sys.argv[1]).resolve(strict=True)
    salida = Path(sys.argv[2]).resolve()
    if not origen.is_dir():
        raise SystemExit("La entrada debe ser un directorio")
    if salida == origen or origen in salida.parents:
        raise SystemExit("La salida debe estar fuera de la entrada")
    if salida.exists():
        raise SystemExit("La salida ya existe: no se sobrescribe")

    archivos = []
    for ruta in sorted(origen.rglob("*")):
        if ruta.is_symlink():
            # No se siguen enlaces simbólicos por diseño.
            continue
        if not ruta.is_file():
            continue
        archivos.append({
            "ruta_relativa": ruta.relative_to(origen).as_posix(),
            "tamano_bytes": ruta.stat().st_size,
            "sha256": sha256_archivo(ruta),
        })

    manifiesto = {
```

```
        "creado_utc": datetime.now(timezone.utc).isoformat(),
        "algoritmo": "SHA-256",
        "elementos": archivos,
    }
    # Se exige un directorio de salida previamente autorizado.
    with salida.open("x", encoding="utf-8") as destino:
        json.dump(manifiesto, destino, ensure_ascii=False, indent=2)
        destino.write("\n")
    print(f"Inventariados {len(archivos)} archivos")


if __name__ == "__main__":
    main()
```

El programa ilustra varias decisiones explícitas: no sigue enlaces simbólicos, no sobrescribe un manifiesto existente y exige que la salida quede fuera de la entrada. Estas restricciones reducen errores frecuentes, pero el script no es suficiente para inventariar todos los elementos de una evidencia real. No conserva flujos alternativos NTFS, atributos extendidos, propietarios, enlaces duros, estructuras del sistema de archivos ni información sobre sectores no asignados. Tampoco garantiza una instantánea consistente si los ficheros cambian durante su lectura. No debe afirmarse que un árbol de archivos inventariado de este modo equivale a una imagen forense completa.

Incluso en un conjunto de prueba deben evaluarse las incidencias. Si un archivo se modifica mientras se calcula el hash, el valor resultante puede representar un estado transitorio. El código anterior no detecta por sí mismo todas esas condiciones. Para un uso más exigente habría que añadir gestión de excepciones por archivo, estado de ejecución, captura consistente de la fuente cuando sea necesaria, comprobaciones de cambios entre lecturas y pruebas específicas de rutas difíciles.

El ejemplo permite introducir otra distinción: **determinismo de resultados** no significa identidad byte a byte de todos los informes. Si se ejecuta el programa dos veces, los hashes de los archivos sin modificaciones deberían coincidir, pero el campo `creado_utc` será diferente. Una comparación razonable debe separar los datos investigados de los metadatos de procesamiento. Si el tiempo de ejecución interesa para la auditoría, debe conservarse, no eliminarse para obtener un informe artificialmente idéntico.

6.5.5. Control de versiones y dependencia de datos

Los procedimientos se benefician de un sistema de control de versiones como Git, con separación estricta entre código y evidencias. Se pueden versionar scripts, documentación, espe-

cificaciones de pruebas y reglas de procesamiento. No debería utilizarse un repositorio Git corriente como depósito indiscriminado de imágenes forenses, secretos o conjuntos reales de evidencia, en especial si está sincronizado con servicios de terceros.

Un identificador de revisión del código permite relacionar un resultado con la implementación utilizada. Sin embargo, no basta registrar el *commit* si el procedimiento depende de paquetes externos, variables de entorno o servicios remotos. La reproducción requiere conocer las dependencias relevantes y, cuando sea posible, fijar versiones y registrar sus hashes. Las bases de datos de firmas o los modelos de clasificación también deben tratarse como dependencias que pueden cambiar.

La automatización puede ejecutarse en contenedores o máquinas virtuales preparadas a partir de configuraciones declarativas. Esto simplifica el despliegue y facilita reconstruir versiones antiguas. La contrapartida es que hay que conservar imágenes o procedimientos de reconstrucción, credenciales de registros de paquetes y una referencia confiable de los artefactos utilizados. Un archivo de configuración sin paquetes disponibles años después no reproduce por sí solo el entorno original.

Para tareas de investigación ordinaria, la solución puede ser modesta: entorno Python virtual, lista de dependencias fijadas, copia del script, manifiesto de entrada y registro de salida. La complejidad debe corresponder al riesgo. Un sistema de orquestación sofisticado puede introducir fallos difíciles de explicar si las necesidades reales se satisfacen mediante una secuencia pequeña y bien ensayada.

6.5.6. Automatización en paralelo y efectos sobre la evidencia

Procesar simultáneamente varias imágenes incrementa la capacidad de trabajo, pero presenta riesgos. Dos procesos pueden competir por memoria y almacenamiento; las herramientas pueden utilizar directorios temporales con nombres idénticos; una base de datos común puede bloquearse; y un programador de tareas puede reiniciar automáticamente un proceso que debería haber quedado suspendido tras un error de integridad.

La concurrencia necesita reglas explícitas. Cada ejecución debe contar con un espacio de trabajo propio, límites razonables de CPU, memoria y almacenamiento, y una política de reintentos. Los reintentos son útiles ante errores transitorios de red, pero deben evitar duplicar o sobrescribir resultados sin registrar la repetición. Una exportación SaaS repetida en otro momento puede devolver un conjunto diferente porque el estado remoto cambió; no debe tratarse automáticamente como la misma adquisición.

El control de integridad de las entradas debe preceder al procesamiento, cuando técnicamente sea posible y pertinente. Si se detecta una discrepancia respecto al valor esperado,

el flujo se detiene o se deriva a una revisión según el procedimiento aplicable. El sistema no debería «arreglar» silenciosamente un archivo de evidencia que parece corrupto. Si se usa una copia alternativa verificada, hay que registrar cuál y por qué.

La distinción entre adquisición y análisis reaparece aquí. Los procesos de adquisición remota pueden actuar sobre sistemas en producción y modificar su estado. Sus tiempos, consumo de recursos y efectos secundarios requieren pruebas diferentes de las necesarias para un parser que solo lee una copia inmóvil. No es correcto suponer que todo lo automatizado es de solo lectura porque el resultado final se guarda en un archivo.

6.5.7. Orquestación y revisión humana

Una forma práctica de diseñar el proceso consiste en asociar a cada etapa un estado: pendiente, en ejecución, completada, completada con advertencias, fallida o sometida a revisión. Las condiciones de salida se definen previamente. Una etapa completada con advertencias puede permitir continuar ciertos análisis, pero debe trasladar sus limitaciones a los resultados posteriores.

El circuito debe identificar puntos de revisión humana. Por ejemplo, la admisión de un nuevo origen de datos requiere confirmar autorización; la adquisición se revisa para comprobar su cobertura; un parser recién actualizado necesita resultados de prueba; y los hallazgos utilizados en el informe deben ser corroborados según su relevancia. La revisión no significa abrir y leer manualmente cada archivo, sino ejercer control en decisiones de mayor impacto.

Para evitar que la supervisión se vuelva una formalidad, cada punto debe registrar qué se revisó y cuál fue la decisión. Una casilla marcada como «validado» sin referencia a elementos concretos ofrece poco valor. Es preferible anotar «se ha comprobado el hash de ADQ-014-03-A y el registro indica tres sectores ilegibles, descritos en INC-014-02» que presentar una afirmación genérica sobre el buen estado de la adquisición.

6.5.8. Inteligencia artificial, clasificación y resultados probabilísticos

Los sistemas de aprendizaje automático pueden ayudar a agrupar archivos, localizar similitudes, transcribir contenido o seleccionar material para revisión. Su utilidad práctica no elimina la necesidad de distinguir **resultado de modelo** y **hecho evidencial**. Un clasificador que asigna una etiqueta a una imagen puede equivocarse; una transcripción puede inventar o confundir palabras; un modelo de lenguaje puede sintetizar de manera incorrecta una cronología si recibe datos ambiguos.

Cuando se utilicen estos recursos, el laboratorio debe conservar la entrada pertinente, la versión del modelo o servicio, la configuración disponible, los límites de transferencia de datos y la forma en que una persona verificó las afirmaciones decisivas. En servicios remotos debe comprobarse qué información se transmite, qué retención aplica el proveedor y qué autorizaciones resultan necesarias. No deben subirse automáticamente evidencias confidenciales a un servicio de IA de terceros.

Los modelos generativos introducen un problema añadido: la salida puede variar entre ejecuciones aun con entradas semejantes. Por ese motivo, un resumen automático no sustituye la conservación de los registros ni el razonamiento verificable. La automatización puede asistir en la búsqueda y organización, pero las conclusiones deben apoyarse en datos identificados y en una argumentación que permita su revisión independiente.

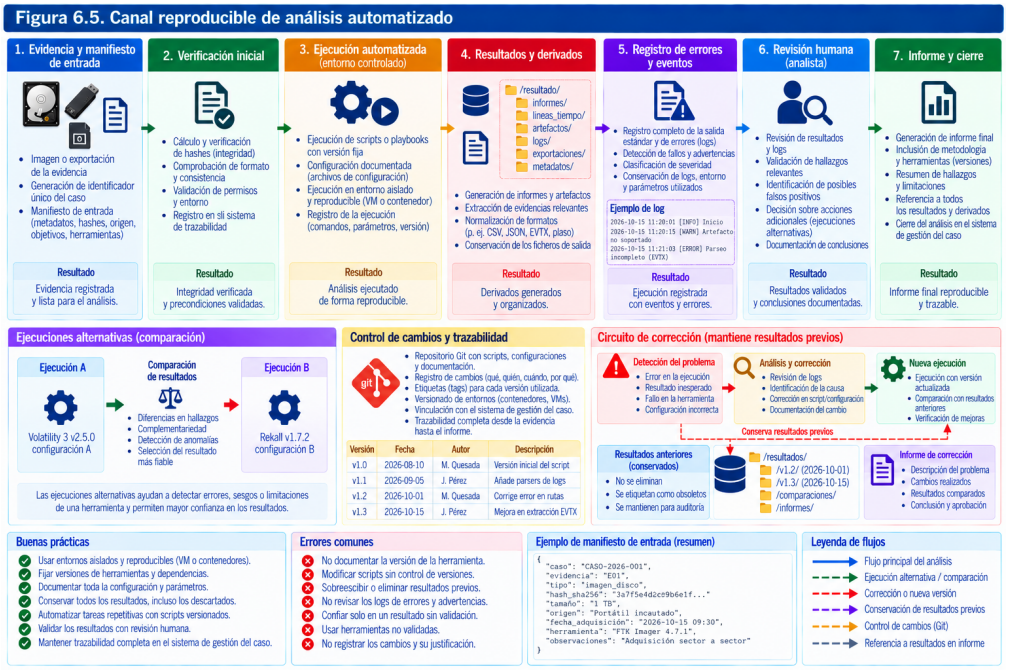


Figura 34: Canal reproducible

6.5.9. Reproducción de una conclusión, no solo de un comando

Una conclusión reproducible no se agota en ejecutar otra vez la misma orden. El revisor debe poder identificar el dato original, conocer su contexto, aplicar el procedimiento de extracción y comprobar si la interpretación se sostiene. Si el informe afirma que un archivo fue abierto

a una hora concreta, la revisión debe comprobar qué artefacto soporta esa afirmación, qué representa su marca temporal y si existen explicaciones alternativas.

Por tanto, la cadena de reproducción parte de la fuente, pasa por la adquisición y el parser, identifica el registro generado y llega a la proposición interpretativa. Cada transición tiene que ser explicable. Los manifiestos y scripts permiten reproducir el tratamiento de los datos; las notas del analista explican el razonamiento que conecta el tratamiento con la conclusión.

Una buena bitácora de análisis no es una transcripción indiscriminada de cada clic. Es un registro suficiente de operaciones materiales, decisiones, incidencias y resultados. Documentar con precisión no exige confundir detalle con ruido. El criterio es que otra persona competente pueda seguir el procedimiento y entender qué decisiones influyeron en el resultado.

6.6. Preparación de escenarios prácticos

6.6.1. Por qué una investigación simulada debe parecerse a una real

El laboratorio experimental permite ensayar herramientas, formar a investigadores y observar cómo se generan artefactos sin comprometer evidencias reales. Un escenario útil no consiste simplemente en encender varias máquinas virtuales y ejecutar comandos. Necesita una situación inicial conocida, una secuencia controlada de acciones, fuentes observables, resultados esperados y variaciones que obliguen a distinguir datos de inferencias.

Un ejemplo demasiado limpio puede ser engañoso. Si todos los registros están perfectamente sincronizados, ningún archivo cambia de nombre y una sola fuente confirma sin ambigüedad lo sucedido, el analista aprende a reconocer patrones, pero apenas practica la gestión de incertidumbre. La realidad contiene errores de reloj, registros ausentes, duplicados, permisos insuficientes, eventos automáticos y operaciones legítimas que se parecen a comportamientos sospechosos. Es deseable introducir algunas de esas condiciones de forma deliberada y documentar la verdad conocida antes de entregar el caso a quien lo examina.

Un escenario debe permitir responder tanto **qué ocurrió** como **qué no puede demostrarse con los datos disponibles**. La evaluación no debería recompensar afirmaciones categóricas cuando la evidencia admite varias explicaciones. Una reconstrucción que distingue adecuadamente hechos corroborados, hipótesis plausibles y extremos no resueltos refleja mejor la práctica profesional que un informe que pretende resolverlo todo sin mencionar limitaciones.

Los laboratorios sintéticos son particularmente adecuados para validar herramientas nuevas. La infraestructura puede reiniciarse a un punto conocido, repetir una secuencia y comparar los artefactos obtenidos en distintas versiones de software. Esa capacidad desaparece cuando se usa material real de terceros cuyo estado no puede reconstruirse libremente.

6.6.2. Preparación de los activos y del inventario inicial

Antes de simular un incidente conviene crear un inventario del entorno: máquinas, sistemas operativos, versiones, direcciones lógicas internas, usuarios ficticios, servicios, aplicaciones y fuentes de registro activadas. Cada equipo recibe un identificador independiente de su nombre DNS o de la etiqueta que tenga en una interfaz. Si una VM se restaura y vuelve a generar un identificador interno distinto, el manifiesto de escenario debe poder reflejar esa relación.

La topología debe indicar conexiones autorizadas y prohibidas. Un dominio de pruebas, un servicio de archivos, un puesto cliente y un colector de eventos pueden instalarse en una red privada sin rutas hacia sistemas de producción. Si se requiere simular Internet, se emplean servicios locales que emiten respuestas controladas. El uso de nombres y direcciones reservadas para documentación —por ejemplo, `example.test` para nombres ficticios en un entorno preparado y las redes de documentación definidas para IPv4— ayuda a evitar atribuciones accidentales a terceros; en el despliegue real deben configurarse la resolución y el aislamiento de manera correcta.

El escenario debe incluir un método de reinicio seguro y una comprobación de estado. Las instantáneas pueden servir para restablecer máquinas de laboratorio, pero conviene saber si incluyen memoria y datos de discos adicionales. Si una base de datos queda fuera de la instantánea, la restauración de la máquina principal no devuelve todo el escenario al mismo punto. Este tipo de discrepancias explica por qué el manifiesto debe registrar las dependencias de cada activo.

La documentación inicial merece un tratamiento similar al de una adquisición: fecha de construcción, responsable, versiones, identificadores y valores hash de imágenes o paquetes relevantes. Estos datos no constituyen cadena de custodia judicial, pero aportan trazabilidad experimental y permiten saber si dos personas están examinando efectivamente el mismo material.

6.6.3. Escenario de archivos y dispositivos extraíbles

Un primer escenario puede representar la sospecha de extracción de documentos desde una estación de trabajo. Se prepara una máquina Windows con un conjunto de archivos ficticios y un dispositivo USB destinado a pruebas. Durante una ventana temporal definida se realizan acciones conocidas: creación y modificación de documentos, copia selectiva, movimiento de una carpeta, conexión y retirada del USB y apertura de algunos archivos. Se añaden operaciones normales que generan artefactos semejantes, como actualizaciones del sistema o ejecuciones automáticas del explorador.

La verdad conocida describe cada acción y su hora de referencia, pero no se entrega inicialmente a quien examina la evidencia. El material de investigación puede incluir una imagen de disco, determinados registros y el contenido de la unidad extraíble, siempre que las adquisiciones se realicen conforme al procedimiento del propio laboratorio. El objetivo no es identificar a un culpable ficticio por intuición, sino reconstruir qué archivos estuvieron presentes, qué artefactos respaldan su acceso o transferencia y qué aspectos no pueden determinarse con certeza.

La prueba permite estudiar metadatos del sistema de archivos, elementos recientes, rastros de dispositivos y diferencias entre tiempo de creación y tiempo de modificación. Conviene introducir al menos un archivo que se haya movido sin copiarse al USB y otro que haya sido modificado después de la copia. Si la herramienta confunde esos hechos, el caso revela una limitación del método o de la interpretación.

El informe resultante debe expresar la diferencia entre la **existencia de un USB conectado**, la **presencia de archivos en ese USB** y la **atribución de una transferencia a una persona concreta**. Las tres proposiciones requieren evidencias de diferente naturaleza y fuerza. El uso de una misma cuenta del sistema operativo no elimina automáticamente la posibilidad de acceso por terceros o procesos automáticos.

6.6.4. Escenario de memoria y sesión activa

El análisis de memoria merece un escenario distinto porque la evidencia puede desaparecer al apagar o reiniciar el equipo. En una máquina virtual de prueba se prepara una sesión con programas conocidos, una conexión de red controlada y archivos de uso temporal. Se registra el estado inicial y se obtiene una captura de memoria mediante un método previamente ensayado. Después se repite la prueba con algunos programas cerrados o en estados diferentes.

La comparación permite observar que los artefactos en memoria dependen del momento de adquisición y de condiciones internas del sistema. No existe una relación simple entre «programa ejecutado» y «proceso visible» en todas las circunstancias. Un programa puede haber terminado, un proceso puede conservar restos, y algunas estructuras pueden no ser recuperables. El laboratorio debe tener un mecanismo para documentar el momento de captura y las acciones que la propia herramienta de adquisición provocó en el equipo.

Para el análisis puede utilizarse una versión controlada de Volatility 3 con símbolos adecuados y funciones ya ensayadas. No es necesario ejecutar malware real para comprobar la capacidad de enumerar procesos y conexiones. Los programas de prueba y los servicios sintéticos proporcionan suficientes datos para practicar interpretación, validación y comparación entre ejecuciones.

Una variación valiosa introduce una diferencia intencionada de reloj entre el anfitrión y el invitado. Los analistas deben identificar qué marcas temporales proceden de cada sistema y explicar sus criterios de normalización. La prueba enseña que dos valores temporales aparentemente contradictorios pueden resultar compatibles al considerar sus fuentes y zonas horarias.

6.6.5. Escenario de servidor Linux y persistencia legítima

Un servidor Linux de laboratorio puede representar la investigación de una cuenta de servicio cuya actividad genera dudas. Se preparan accesos SSH autorizados, tareas programadas y cambios conocidos de configuración. Algunas acciones se realizan mediante cuentas humanas, otras mediante procesos automáticos. Se conserva una copia de los registros relevantes y, cuando proceda, una adquisición del sistema de archivos.

El objetivo es comprobar si el analista distingue autenticación, apertura de sesión, ejecución de comandos y persistencia de una tarea. Un registro de autenticación satisfactorio no demuestra, por sí solo, que se ejecutara una orden determinada. Un archivo de historial de shell puede ser incompleto, alterarse por concurrencia o reflejar acciones cuya atribución necesita contrastarse. Una tarea de `cron` o un servicio `systemd` puede responder a administración legítima o a un mecanismo de persistencia no autorizado: la interpretación requiere conocer el contexto.

Una parte del caso puede incorporar archivos de configuración almacenados en un repositorio Git local. Se realizan cambios y restauraciones controladas, y se conserva una copia de la historia del repositorio. El analista deberá distinguir las marcas del sistema de archivos de las fechas registradas en commits, así como el hecho de que un autor declarado en un commit no autentica por sí solo a una persona física.

Este escenario puede servir, además, para comparar dos herramientas de análisis temporal. La comparación se centra en eventos normalizados y referencias al origen, no solo en el número global de filas. Si un parser interpreta un formato de journald y otro utiliza una exportación textual, deben quedar documentadas las diferencias de cobertura.

6.6.6. Escenario de identidad y aplicación en la nube

Para simular un acceso indebido a una aplicación SaaS sin exponer cuentas reales, puede prepararse un servicio web local de prueba con autenticación, registros de actividad, almacenamiento de documentos sintéticos y una API de exportación. Si se emplea una plataforma real en una cuenta de laboratorio, deben definirse presupuestos, permisos mínimos, retención, región y procedimientos de eliminación autorizada. No se deberían utilizar cuentas personales ni datos verdaderos para acelerar la preparación.

El escenario contiene una secuencia controlada: autenticación exitosa, acceso a documentos, modificación de permisos y descarga de un conjunto ficticio. Una segunda sesión ejecuta acciones legítimas que pueden confundirse con las anteriores. El proveedor de identidad, la aplicación, la API y los registros de red emiten observaciones diferentes. El objetivo consiste en correlacionarlas sin atribuir a cada fuente visibilidad sobre operaciones que no registra.

La exportación de registros se lleva a cabo mediante un procedimiento autorizado y se conserva el resultado bruto de la API junto con los parámetros de consulta: intervalo temporal, filtro, paginación, permisos usados y respuesta del servicio. Si una API solo devuelve los primeros cien elementos por defecto, la omisión de paginación puede ocasionar una adquisición aparentemente correcta pero incompleta. Esta es una prueba excelente para una herramienta de recolección automatizada.

Una variación introduce retenciones distintas entre fuentes: el servicio de identidad conserva más eventos que la aplicación; el proxy registra conexiones pero no el contenido cifrado; el repositorio de documentos ofrece versiones anteriores, aunque no todas las operaciones de lectura. Se invita al analista a indicar qué hipótesis están corroboradas, cuáles permanecen abiertas y qué datos requerirían nuevas solicitudes o ampliación de alcance.

El resultado es útil tanto para validar conectores y parsers como para entrenar la formulación de preguntas que pueden responderse con una determinada fuente. La ausencia de una descarga en los registros de una aplicación no significa necesariamente que la descarga no haya existido si el origen carece de esa clase de auditoría.

6.6.7. Escenario de contenedores y servicios efímeros

La virtualización moderna plantea problemas diferentes de los de un ordenador persistente. Un escenario con contenedores puede incluir una aplicación web, una base de datos y un servicio de registros separados, cada uno con ciclos de vida distintos. Se programan reinicios y sustituciones de contenedores, cambios de configuración y generación de archivos temporales. El laboratorio registra qué datos permanecen en volúmenes y cuáles desaparecen al destruir un contenedor.

La adquisición puede considerar imágenes de contenedor, configuración, registros del orquestador, volúmenes persistentes y exportaciones de la aplicación. No siempre existe una única imagen de disco que represente adecuadamente el estado global. La documentación debe conservar las relaciones entre instancias, capas y servicios, así como la hora de los eventos. Una copia de una imagen de contenedor no equivale a una captura completa de su estado de ejecución.

El caso permite ensayar procedimientos de preservación remota y verificar la capacidad de reproducir aplicaciones mediante configuraciones versionadas. Una versión del escenario puede almacenar registros en un volumen persistente; otra puede perderlos tras una rotación breve. Esta diferencia ilustra por qué la preparación forense debe diseñarse antes del incidente y por qué la volatilidad no depende únicamente de si el soporte es RAM o disco.

En términos de validación, el ejercicio comprueba que las herramientas puedan asociar correctamente identificadores de instancias, periodos de ejecución, imágenes y rutas de almacenamiento. Si dos contenedores sucesivos usan el mismo nombre de servicio, el analista no debería confundirlos con un único objeto inmutable.

6.6.8. Escenario de red y correo con evidencias discordantes

Una investigación de correo sospechoso puede prepararse con mensajes de prueba, dominios controlados, cabeceras sintéticas y tráfico capturado en una red de laboratorio. Los mensajes contienen remitentes declarados, campos `Received`, resultados de autenticación de correo producidos por el entorno controlado y enlaces hacia un servidor local. El objetivo es analizar la diferencia entre identidad afirmada en el mensaje, servidores observados y validez de mecanismos de autenticación.

Para introducir ambigüedad, una parte del tráfico puede capturarse fuera del segmento por el que circula un mensaje. Otra parte puede aparecer en registros de aplicación pero no en el PCAP disponible. El caso muestra que la falta de paquetes en una captura no prueba la

ausencia de comunicación en toda la red, y que determinados campos de correo pueden ser manipulados por un emisor antes del primer servidor confiable.

El laboratorio debe conservar el mensaje en un formato que mantenga sus cabeceras y contenido original, el PCAP, los registros del servidor y una cronología de las acciones del escenario. Los analistas pueden utilizar Wireshark y herramientas de análisis de correo para comprobar coincidencias y discrepancias. Una conclusión sólida explicará cuáles de los saltos de transporte están respaldados por infraestructura bajo control del laboratorio y qué afirmaciones proceden solamente de campos aportados por terceros.

Esta prueba permite valorar también la gestión de marcas temporales entre sistemas con relojes diferentes y la capacidad de diferenciar resolución temporal de exactitud. Un sello que contiene milisegundos no es necesariamente más exacto que otro expresado en segundos si el reloj de origen no estaba sincronizado.

6.6.9. Preparar variaciones y condiciones negativas

Cada escenario debería disponer de al menos una versión básica, una versión con incidencias y una variante negativa. La básica comprueba que el procedimiento detecta los artefactos esperados. La versión con incidencias introduce ausencia de registros, errores de exportación, retrasos o cambios de formato. La variante negativa representa una actividad parecida pero legítima, para comprobar si el analista evita inferencias indebidas.

En el caso de dispositivos extraíbles, la variación negativa podría consistir en conectar un USB sin copiar documentos. En identidad, puede tratarse de un acceso desde una dirección IP compartida por varios usuarios legítimos. En correo, un mensaje con fallo de autenticación no tiene por qué ser automáticamente fraudulento en todos sus aspectos; puede reflejar errores de configuración o intermediarios de transporte. En contenedores, la desaparición de una instancia puede ser el resultado esperado de un despliegue automatizado.

La incorporación de condiciones negativas dificulta la tendencia a encontrar siempre un «culpable» o un indicador de compromiso. Un laboratorio profesional no debería valorar sus métodos únicamente por la cantidad de hallazgos, sino también por su capacidad para evitar afirmaciones injustificadas.

6.6.10. Un caso integrador: la carpeta de contratos que dejó de estar disponible

Consideremos una organización ficticia que trabaja con documentación contractual en una aplicación interna. Un viernes, varias personas advierten que la carpeta de contratos de un proyecto ya no aparece en la interfaz. La dirección sospecha que un usuario la eliminó antes

de abandonar la empresa, pero no dispone de evidencia suficiente. El equipo de seguridad recibe el encargo de preservar las fuentes disponibles e investigar qué ocurrió, dentro de un alcance autorizado y documentado.

El entorno de laboratorio reproduce la situación mediante una aplicación web de pruebas, un servicio de identidad, una estación cliente, un servidor Linux, una base de datos y un repositorio de documentos con historial de versiones. Se preparan tres eventos distintos: una operación de cambio de ubicación, una modificación de permisos y una sincronización incompleta en otro cliente. Además, un índice de búsqueda no se actualiza inmediatamente. Quien construye el escenario conoce la secuencia exacta, pero los analistas reciben solamente una descripción del incidente y las evidencias adquiridas.

El primer equipo se encarga de la recepción y catalogación. Comprueba que los paquetes de registros estén identificados, asigna códigos a cada adquisición, verifica hashes de archivos comparables y documenta la procedencia. El segundo se ocupa de la interpretación, sin recibir la verdad conocida. El tercero realiza una revisión independiente de una muestra de los resultados y de las limitaciones declaradas. Los roles pueden rotar entre distintas ejecuciones de la prueba.

El análisis se organiza alrededor de cinco hipótesis: eliminación intencionada, movimiento a otra ubicación, modificación de permisos, fallo de sincronización y error de visualización. Cada hipótesis implica predicciones verificables. Una eliminación debería dejar determinados rastros cuando la aplicación los registra; un cambio de permisos puede permitir la existencia del objeto sin visibilidad para ciertos perfiles; un movimiento debería reflejarse en metadatos de ubicación o historial; una sincronización fallida puede producir discrepancias entre servidor y cliente; un problema de indexación puede alterar la búsqueda sin cambiar el repositorio subyacente.

La evidencia disponible es deliberadamente imperfecta. La aplicación conserva eventos de negocio, pero omite ciertos accesos de lectura. El servicio de identidad registra autenticaciones y emisión de tokens, pero no cada operación documental. La estación mantiene artefactos locales y cachés que pueden representar estados antiguos. El servidor registra errores de la tarea de sincronización y el sistema de búsqueda conserva una reconstrucción anterior del índice. Ninguna fuente, aislada, contiene la explicación completa.

Los analistas deben producir una matriz que relacione dato, interpretación, hipótesis y limitación. Un registro de «objeto movido» puede apoyar la hipótesis de cambio de ubicación; una lista de permisos posterior al evento puede apoyar la hipótesis de restricción de acceso. No obstante, la correlación temporal de dos eventos no garantiza automáticamente que uno causara al otro. El informe debe separar hechos observados de explicaciones plausibles y especificar qué experimentos o datos adicionales podrían aumentar la confianza.

En una segunda ejecución, el responsable del escenario introduce un cambio no comunicado en la API de exportación: uno de los campos aparece con un nombre diferente y un parser antiguo lo ignora. La discrepancia debería descubrirse por controles de validación o, al menos, manifestarse como dato ausente o advertencia. Si la herramienta continúa silenciosamente, la incidencia se registra y se analiza cómo pudo afectar al informe. La corrección requiere una nueva ejecución identificada, no modificar manualmente el resultado anterior sin historial.

En una tercera ejecución se simula el fallo del almacenamiento de resultados. El equipo debe restaurar datos desde una copia de seguridad de laboratorio, comprobar manifiestos y recuperar relaciones entre evidencias. No basta con devolver los archivos a sus rutas: deben poder identificarse su versión, la adquisición que los produjo y los procesamientos que ya se habían ejecutado. La prueba mide así continuidad operativa y trazabilidad al mismo tiempo.

El caso integrador demuestra que la calidad del laboratorio depende de su capacidad para **reconstruir y explicar todo el itinerario de los datos**, incluso cuando el proceso se interrumpe, se repite o revela un error. Las herramientas especializadas facilitan la tarea, pero no sustituyen el inventario, las autorizaciones, los procedimientos, las revisiones ni la gestión de incidencias.

6.6.11. Evaluación de la preparación y criterio de finalización

Un escenario no debería considerarse satisfactorio solo porque el equipo encontró el archivo o evento previsto. La revisión debe contemplar varias dimensiones: respeto del alcance, integridad de las entradas, completitud de las adquisiciones dentro de sus límites, fiabilidad de parsers, documentación de incidencias, calidad de las interpretaciones, capacidad de reproducción y seguridad del entorno.

Una matriz de revisión interna puede utilizar las siguientes preguntas:

Dimensión	Pregunta de control	Evidencia esperada
Alcance	¿Se actuó solo sobre fuentes autorizadas?	Plan, permisos y cambios aprobados
Preparación	¿Se conocía el estado inicial del entorno?	Inventario y manifiesto de escenario
Adquisición	¿Se identificaron entradas, errores y cobertura?	Registros, hashes y observaciones

Dimensión	Pregunta de control	Evidencia esperada
Herramientas	¿Las funciones utilizadas estaban comprobadas?	Ensayos y limitaciones conocidas
Trazabilidad	¿Puede seguirse la relación entre fuente y hallazgo?	Identificadores y bitácora
Interpretación	¿Se valoraron hipótesis alternativas?	Matriz de evidencias e inferencias
Reproducción	¿Puede repetirse la parte técnica relevante?	Código, versiones, parámetros y muestras
Confidencialidad	¿Se respetaron límites de acceso y difusión?	Permisos, auditoría y registro de entregas
Continuidad	¿Se gestionaron fallos sin perder procedencia?	Pruebas de restauración e incidencias

La matriz no equivale a una acreditación de laboratorio ni a una certificación formal. Es una herramienta para detectar carencias y priorizar mejoras. El nivel exigible depende del uso previsto y de las obligaciones aplicables. Los hallazgos sobre fallos del propio laboratorio deben tratarse con la misma disciplina que cualquier otra incidencia: registro, análisis de causa, corrección y comprobación posterior.

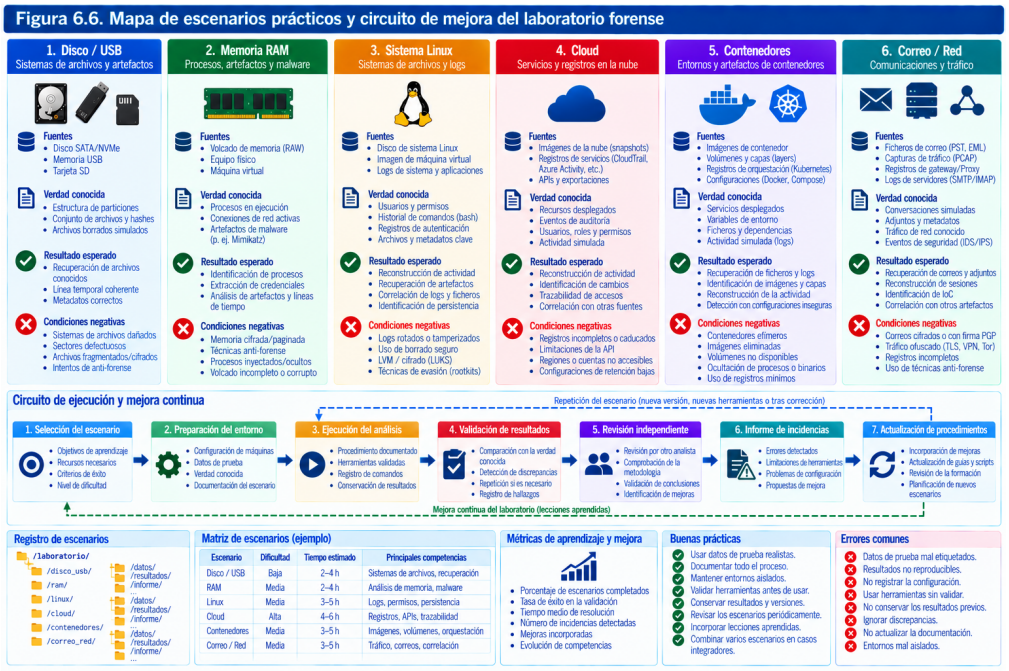


Figura 35: Mapa de escenarios prácticos y circuito de mejora del laboratorio

6.6.12. De la simulación a la intervención real

Una preparación exitosa no significa que el laboratorio esté autorizado para utilizar cualquier técnica en cualquier investigación. Cada caso real exige revisar su encargo, las tecnologías presentes, el impacto de la intervención y los procedimientos aplicables. El entrenamiento permite reconocer problemas y acotar riesgos, pero no reemplaza la evaluación del contexto.

Es conveniente definir un umbral de escalado. Cuando se desconoce una tecnología, una adquisición exige operar sobre un soporte dañado, una función no ha sido comprobada o la intervención puede afectar gravemente a un servicio crítico, el investigador debe poder solicitar apoyo especializado. Reconocer límites profesionales es parte del rigor, no una carencia que deba ocultarse.

El valor de los simulacros aumenta cuando sus resultados modifican el laboratorio. Una prueba que descubre una copia de seguridad imposible de restaurar, una función de bloqueo mal configurada o una red experimental con salida indebida debe conducir a una mejora verificable. Repetir el mismo ejercicio sin corregir el problema solo produce familiaridad con el defecto.

6.7. El laboratorio como sistema de confianza verificable

Los capítulos anteriores han mostrado que la identificación, la adquisición, la cadena de custodia y la interpretación de evidencias dependen de decisiones concretas. El laboratorio reúne esas decisiones dentro de una infraestructura capaz de conservarlas y hacerlas comprensibles. La calidad no se alcanza mediante un inventario de herramientas prestigiosas, sino con prácticas que permiten detectar errores, corregirlos sin borrar su historia y explicar los resultados obtenidos.

Un laboratorio pequeño puede trabajar con gran rigor si conoce bien sus límites, protege los originales, utiliza procedimientos proporcionados y documenta sus actuaciones. Uno grande puede ser vulnerable pese a disponer de tecnología avanzada si combina sin control redes, credenciales, versiones y repositorios. La infraestructura proporciona posibilidades; la disciplina transforma esas posibilidades en trabajo fiable.

La preparación comienza antes de recibir un caso y continúa después de cerrarlo. Los sistemas se actualizan, los formatos cambian, aparecen nuevos dispositivos, se modifican las APIs y las herramientas evolucionan. Por eso un laboratorio forense no se inaugura una vez para permanecer inalterado: se mantiene mediante ensayos periódicos, vigilancia de dependencias, revisión de incidentes internos y ejercicios de reproducción.

A la hora de formular una conclusión, el objetivo último no será demostrar que el analista utilizó una determinada aplicación. Será poder responder, con precisión, **qué evidencia se examinó, cómo se obtuvo, qué transformaciones sufrió, qué resultados produjo, cuáles son sus límites y por qué esos resultados sustentan —o no— una determinada interpretación**. Una infraestructura que permite contestar esas preguntas constituye la verdadera base de un laboratorio forense profesional.

6.8. Referencias y lecturas recomendadas

Las publicaciones siguientes permiten ampliar los criterios expuestos. Debe comprobarse la versión vigente y el ámbito de aplicación antes de adoptar cualquiera de ellas como procedimiento interno. Cuando una norma esté sujeta a licencia, la referencia pública no sustituye la consulta autorizada del texto íntegro.

- **NIST**. *Guide to Integrating Forensic Techniques into Incident Response*, SP 800-86 (2006). Referencia de fundamentos y organización de actividades forenses en contextos de TI e incidentes. https://csrc.nist.gov/pubs/sp/800/86/final.

- **NIST**. *Computer Forensics Tool Testing (CFTT)*. Programa de especificaciones, metodologías y ensayos funcionales de herramientas forenses. https://www.nist.gov/programs-projects/computer-forensics-tool-testing-cftt.
- **NIST**. *Federated Testing Project*. Materiales y procedimientos de ensayos distribuidos para diversas categorías de herramientas. https://www.nist.gov/itl/csd/secure-systems-and-applications/computer-forensics-tool-testing-program-cftt/federated.
- **NIST**. *Computer Forensic Reference Data Sets (CFReDS)*. Conjuntos de datos y documentación útiles para pruebas y formación. https://cfreds.nist.gov/.
- **NIST**. *Computer Forensics Tools & Techniques Catalog*. Catálogo de funciones y herramientas; su inclusión no supone certificación ni evaluación independiente de cada producto. https://toolcatalog.nist.gov/.
- **NIST**. *NIST Cloud Computing Forensic Reference Architecture*, SP 800-201 (2024). Arquitectura de referencia para la preparación forense en servicios cloud. https://csrc.nist.gov/pubs/sp/800/201/final.
- **SWGDE**. *Minimum Requirements for Testing Tools Used in Digital and Multimedia Forensics*, documento 18-Q-001, versión 2.1. Recomendaciones sobre categorías y ensayos de herramientas forenses. https://www.swgde.org/documents/published-complete-listing/18-q-001-minimum-requirements-for-testing-tools-used-in-digital-and-multimedia-forensics/.
- **SWGDE**. *Model Standard Operation Procedures for Computer Forensics*. Referencia sobre procedimientos documentados, pruebas y producción de resultados. https://www.swgde.org/documents/published-complete-listing/12-f-001-swgde-model-standard-operation-procedures-for-computer-forensics/.
- **ISO/IEC**. *ISO/IEC 17025:2017 — General requirements for the competence of testing and calibration laboratories*. Referencia general de competencia e imparcialidad para laboratorios dentro de su ámbito. https://www.iso.org/standard/66912.html.
- **Sleuth Kit Labs**. Documentación oficial de *The Sleuth Kit* y *Autopsy*. https://www.sleuthkit.org/.
- **Volatility Foundation**. Repositorio y documentación técnica de *Volatility 3*. https://github.com/volatilityfoundation/volatility3.
- **Plaso**. *User's Guide* de `log2timeline`, `psort` y utilidades relacionadas. https://plaso.readthedocs.io/en/latest/sources/user/Users-Guide.html.
- **Timesketch**. Documentación y repositorio del proyecto de análisis colaborativo de líneas temporales. https://github.com/google/timesketch.
- **Velociraptor**. Documentación de recopilaciones y colectores sin conexión continua con el servidor. https://docs.velociraptor.app/docs/deployment/offline_collections/.

La bibliografía de herramientas se incorpora como información técnica contextual, no como aval comercial ni como garantía de que una función concreta esté disponible en todas las

versiones. Las prácticas descritas deben adaptarse al alcance autorizado de cada investigación, a los procedimientos validados del laboratorio y a las exigencias legales aplicables.

7. Discos, particiones y sistemas de archivos

7.1. Introducción

Un disco no es una colección de documentos dispuestos en carpetas. Es un soporte que expone unidades de direccionamiento y sobre el que varias capas de software construyen estructuras de significado: tablas de particiones, volúmenes, sistemas de archivos, directorios, nombres, atributos y relaciones temporales. Para el usuario, un archivo puede ser una fotografía con un nombre reconocible. Para quien investiga, esa misma fotografía es también una secuencia de bytes cuya localización, asignación, historial y contexto deben demostrarse. La diferencia no es académica: de ella depende que un resultado sea repetible y que no se atribuya a un usuario una acción que solo se ha inferido de una estructura técnica.

El análisis forense de almacenamiento requiere razonar de abajo arriba y de arriba abajo. De abajo arriba, el investigador determina qué bytes se adquirieron, cómo se organizan y qué estructuras los interpretan. De arriba abajo, parte de una pregunta —por ejemplo, si un documento fue creado, copiado, modificado o eliminado— y busca qué artefactos pueden sostener o refutar cada explicación. Ninguno de los dos recorridos basta por sí solo. Una herramienta puede mostrar un archivo eliminado con una fecha precisa y, aun así, la interpretación ser equivocada porque la marca temporal se refiere a una entrada de directorio reutilizada, a un cambio de metadatos o a una conversión horaria incorrecta.

Este capítulo presenta las capas de almacenamiento, los esquemas MBR y GPT, los sistemas FAT, exFAT, NTFS, ext4 y APFS, la interpretación de metadatos y tiempos, y las posibilidades reales de recuperar información. Se presta especial atención a las diferencias entre *encontrar bytes*, *reconstruir un objeto* y *atribuir un hecho*. El tratamiento de discos cifrados, SSD y adquisición de soportes dañados se conecta con el capítulo anterior, pero aquí el foco está en el significado de las estructuras adquiridas y en los límites de su interpretación.

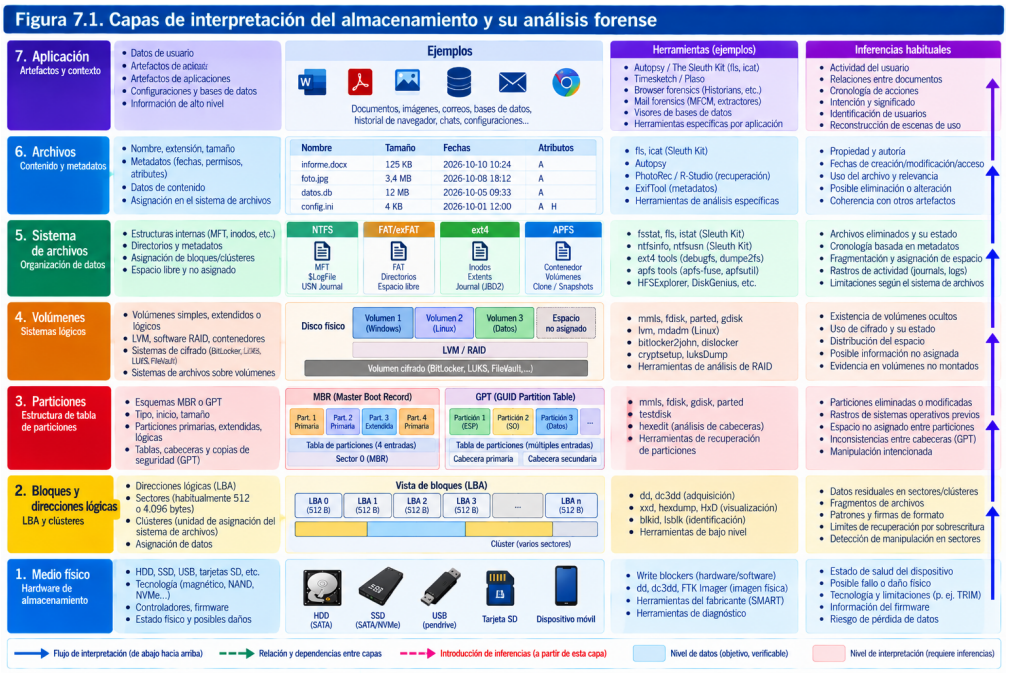


Figura 36: Capas de interpretación del almacenamiento

7.2. Estructura de los soportes de almacenamiento

7.2.1. Del medio físico al espacio direccionable

Los discos magnéticos, las memorias flash y los discos virtuales no almacenan los datos de la misma manera, pero suelen presentar al sistema operativo una interfaz de bloques direccionables. El sistema solicita leer o escribir bloques lógicos, mientras que el dispositivo o la capa de virtualización resuelve cómo materializar esas operaciones. La distinción es fundamental: el sector lógico que observa el analista no equivale necesariamente a una posición física estable dentro del soporte.

En un disco duro magnético, la controladora abstrae pistas, sectores físicos, zonas de reserva y reasignaciones. En un SSD, la capa de traducción flash (*Flash Translation Layer*, FTL) asigna direcciones lógicas a páginas y bloques de memoria que pueden cambiar por nivelación de desgaste, recolección de basura y operaciones de mantenimiento. En una máquina virtual, el disco aparente puede ser un archivo, una cadena de discos diferenciales, un volumen de red o una abstracción proporcionada por el hipervisor. El mismo número de bloque lógico puede corresponder a objetos físicos distintos en momentos diferentes.

Una adquisición de bloques obtiene la representación que el dispositivo entrega por su interfaz en ese momento. No debe describirse sin matices como una lectura de «toda la memoria física» del soporte: pueden existir áreas inaccesibles, bloques reasignados, espacios ocultos por el firmware o datos no expuestos por el controlador. Tampoco es seguro que los bloques liberados de un SSD conserven información recuperable. El alcance real depende del medio, la interfaz, su estado, la herramienta y las condiciones de adquisición.

7.2.2. Sectores lógicos, tamaño de bloque y offsets

En muchos soportes se emplean sectores lógicos de 512 bytes o 4096 bytes, pero no debe asumirse uno de estos valores sin comprobarlo. Los formatos 512e presentan sectores físicos de 4096 bytes con interfaz lógica de 512; los dispositivos 4Kn exponen sectores lógicos de 4096. Un error en el tamaño de sector altera todos los cálculos de desplazamiento y puede provocar que una partición válida parezca corrupta.

El desplazamiento en bytes de un bloque lógico se obtiene multiplicando su dirección por el tamaño del bloque:

[offset_{bytes} = LBA ×tamaño del sector lógico]

Si una partición empieza en LBA 2048 y el sector lógico mide 512 bytes, el inicio está a 1 048 576 bytes del comienzo del dispositivo. Ese cálculo es verificable y debe constar en las notas si se extraen estructuras manualmente. Con sectores de 4096 bytes, el mismo LBA representaría un desplazamiento ocho veces mayor. El valor del LBA por sí solo, por tanto, no basta.

Un sistema de archivos puede agrupar varios sectores en una unidad de asignación o *clúster*. El clúster es una decisión del formato lógico; no debe confundirse con el sector lógico del dispositivo, con el bloque físico de un SSD ni con los bloques de una herramienta de adquisición. En ext4 se habla habitualmente de bloques del sistema de archivos, mientras que APFS utiliza su propia organización de bloques y objetos. Cada capa debe identificarse por separado.

7.2.3. Capacidad anunciada, capacidad visible y geometría

La capacidad comercial de un dispositivo suele expresarse en unidades decimales: 1 TB representa 10^{12} bytes. Los sistemas operativos y algunas herramientas emplean unidades binarias, como TiB, equivalentes a 2^{40} bytes. La diferencia de presentación no implica pérdida de datos. Antes de afirmar que una imagen está incompleta, deben compararse tamaños en bytes, número de sectores, tamaño lógico de sector y eventuales límites de adquisición.

Las referencias históricas a cilindros, cabezas y sectores (*CHS*) permanecen en ciertos campos de MBR, pero en la práctica el direccionamiento LBA es el mecanismo relevante para los sistemas actuales. Las cifras CHS pueden ser ficticias o estar truncadas; usarlas como prueba principal de ubicación en discos modernos sería metodológicamente débil.

En una investigación deben conservarse, cuando estén disponibles, fabricante, modelo, número de serie, firmware, capacidad expuesta, tamaño lógico y físico de sector, interfaz, identificadores de volumen y cualquier advertencia de lectura. Estos atributos permiten detectar errores de identificación, pero tampoco prueban por sí solos que el soporte no haya sido sustituido o alterado.

7.2.4. Capas intermedias: RAID, LVM, cifrado y virtualización

Una partición no siempre contiene directamente un sistema de archivos. Puede albergar un volumen cifrado, un miembro RAID, un volumen físico de LVM, un contenedor APFS u otra estructura. El investigador debe identificar las capas en el orden correcto y conservar la descripción de cada transformación. Montar directamente como NTFS un dispositivo que contiene LUKS no dará resultados válidos; interpretar un miembro RAID aislado como volumen completo puede producir datos fragmentarios o aparentes corrupciones.

En Linux, un esquema frecuente es disco → GPT → partición → LUKS → LVM → volumen lógico → ext4. En Windows puede aparecer disco → GPT → partición → BitLocker → NTFS. En macOS, disco → GPT → contenedor APFS → volúmenes APFS, eventualmente protegidos por cifrado. En virtualización puede añadirse una capa externa: archivo QCOW2 → disco virtual → GPT → volumen invitado. Cada capa tiene metadatos, riesgos y mecanismos de validación propios.

Una imagen de un miembro RAID no equivale a la imagen del volumen lógico reconstruido. Una instantánea de VM puede representar solo cambios respecto de un disco base. Una exportación de volumen descifrado no tiene los mismos bytes que la imagen cifrada subyacente, aunque ambas se refieran a datos relacionados. Los hashes deben asociarse al objeto concreto y no trasladarse de una representación a otra.

7.2.5. El estado del soporte también es evidencia

El análisis no comienza únicamente cuando se abre el sistema de archivos. La existencia de particiones anómalas, zonas sin asignar, encabezados dañados, sectores ilegibles, volúmenes ocultos o discrepancias entre tablas puede ser relevante. Una partición eliminada de la tabla puede conservar parte de sus datos; una tabla modificada puede ocultar un volumen

sin haberlo sobrescrito; un soporte con sectores defectuosos puede haber producido archivos aparentemente truncados sin intervención humana.

Por ello, la exploración inicial debería responder: ¿qué objeto se adquirió?, ¿qué tamaño y estructura tiene?, ¿qué capas se identifican?, ¿qué regiones son accesibles?, ¿qué errores se produjeron?, ¿qué partes no se interpretan todavía? Registrar explícitamente lo desconocido es preferible a rellenarlo con supuestos.

7.2.6. Reconocimiento inicial con herramientas de solo lectura

En un entorno Linux de laboratorio pueden consultarse propiedades y particiones con comandos como los siguientes, aplicados a una **imagen de prueba** y no directamente a un original sin un procedimiento aprobado:

```
sha256sum disco-prueba.raw
file disco-prueba.raw
mmls disco-prueba.raw
fdisk -l disco-prueba.raw
```

`mmls`, de The Sleuth Kit, ayuda a enumerar regiones y particiones; `fdisk` ofrece otra perspectiva de la tabla. Los resultados no son intercambiables con una validación completa de la imagen. Si discrepan, deben conservarse ambas salidas, comprobar sector lógico, offsets y tipo de tabla, y examinar manualmente los campos relevantes. El uso de `file` es orientativo: detecta firmas, pero no demuestra que una estructura sea completa o íntegra.

La salida de cada herramienta debe asociarse con versión, parámetros, zona horaria del sistema de análisis, hash de entrada y fecha de ejecución. Una interpretación manual posterior ha de distinguirse del dato devuelto automáticamente.

7.2.7. Interpretar sectores no equivale a interpretar archivos

Una imagen de almacenamiento puede examinarse desde al menos cuatro perspectivas, cada una de las cuales responde preguntas diferentes. En el nivel de bloques se determina qué secuencia de bytes ofrece el dispositivo: permite localizar firmas, regiones inaccesibles, estructuras repetidas y patrones de ocupación. En el nivel de particiones se establece cómo se delimitan espacios de uso. En el nivel del sistema de archivos se reconstruye la relación entre metadatos, nombres, directorios y contenido. Finalmente, el nivel de aplicación interpreta documentos, bases de datos, contenedores comprimidos o archivos de configuración con reglas que el sistema de archivos desconoce. Mezclar estos planos conduce a conclusiones difíciles de sostener.

Supongamos que se encuentra la firma de un documento PDF en un sector libre. El hecho inicial es que en una posición de la imagen existen bytes compatibles con un encabezado PDF; ni siquiera está demostrado todavía que exista un archivo íntegro. Si se reconstruye un conjunto de bloques y se valida su estructura, podrá afirmarse que se ha recuperado un objeto interpretable como PDF. Si aparecen en la misma imagen referencias de una antigua entrada de directorio, podremos relacionarlo, con reservas, con una ruta. Afirmar que alguien lo abrió, lo copió o lo eliminó exige información adicional. El salto del hallazgo de bytes a la conducta humana no lo proporciona el propio formato del disco.

La distinción entre **ubicación física**, **ubicación lógica** y **ubicación semántica** ayuda a precisar las notas. Una ubicación física puede ser desconocida o variable en un SSD; una ubicación lógica, en cambio, se expresa mediante LBA y desplazamiento; una ubicación semántica indica que esos bytes corresponden, por ejemplo, al atributo de datos de un archivo identificado por un registro MFT. El informe debe indicar qué plano utiliza. La expresión «recuperado del sector 315 000» aporta trazabilidad técnica, pero no sustituye el análisis del objeto reconstruido.

Conviene utilizar unidades inequívocas. Los términos «bloque», «sector», «clúster», «extento» y «página» pueden significar cosas distintas. Un **extento** suele representar una secuencia contigua de unidades lógicas; un **sector lógico** es la unidad de direccionamiento expuesta por el dispositivo; una **página de NAND** es una unidad física interna gestionada por la controladora; una **página de memoria** pertenece a otra capa del sistema. Un investigador que reciba una salida con la dirección `0x0000000001000000` debe conocer si se trata de un desplazamiento absoluto en bytes, un número de sector, un bloque de sistema de archivos o un offset relativo a un volumen.

7.2.8. Alineación, estructuras superpuestas y falsos positivos

Las particiones modernas suelen comenzar en límites alineados, frecuentemente a 1 MiB, para mejorar compatibilidad y rendimiento. La alineación es una pista contextual, no una condición de validez ni una prueba de una configuración concreta. Un disco antiguo puede usar desplazamientos diferentes; un fabricante puede reservar regiones propias; una imagen procedente de una máquina virtual puede contener metadatos exteriores al disco que ve el invitado.

Hay otra fuente habitual de error: un mismo conjunto de bytes puede satisfacer más de un detector. Un bloque lleno de ceros puede parecer espacio sin uso, pero formar parte legítima de un archivo disperso, de un volumen cifrado que presenta ceros, de una instantánea o de una adquisición incompleta. Una firma de sistema de archivos hallada en espacio no

asignado puede pertenecer a una partición anterior, a una imagen de disco guardada como archivo o a datos aleatorios que coincidan con parte de una cabecera. La detección de una firma constituye una hipótesis que debe contrastarse comprobando campos internos, coherencia de tamaños, referencias cruzadas y límites del soporte.

En una revisión manual se distingue entre **identificación por firma** y **validación estructural**. La primera suele ser rápida: una secuencia como `EFI PART` apunta a una cabecera GPT. La segunda exige verificar que la cabecera está donde debería, que sus longitudes son plausibles, que los desplazamientos no superan la imagen y que los valores CRC de la tabla concuerdan. En un entorno forense no se debe aceptar automáticamente toda sugerencia de una herramienta de reconocimiento, especialmente si el soporte está dañado o contiene restos de configuraciones antiguas.

Las imágenes que incluyen varios discos añadidos por concatenación, un encabezado propietario de contenedor o bloques ausentes merecen un examen adicional del formato externo. Un error de origen frecuente consiste en calcular la posición de una partición sobre los bytes del archivo de contenedor, en vez de hacerlo sobre el **flujo de bloques reconstruido**. La imagen EWF, por ejemplo, no se interpreta como si su archivo `.E01` fuese directamente un disco RAW. Primero hay que acceder a su contenido lógico mediante una herramienta compatible y documentar el proceso.

7.2.9. Una primera ficha técnica del soporte

Antes de reconstruir cualquier archivo, el investigador puede redactar una ficha de reconocimiento cuyo interés va más allá del inventario. Debe permitir a otra persona repetir los cálculos y comprender qué partes de la imagen han quedado sin revisar. Un modelo operativo sería el siguiente:

Campo	Ejemplo ficticio	Interpretación o comprobación
Evidencia	`EV-07-001`	Identificador del objeto adquirido
Adquisición	`ADQ-07-001`	Procedimiento y archivo resultante
Formato	RAW	Sin cabecera de contenedor asociada al archivo
Tamaño	64 424 509 440 bytes	Medido sobre el flujo adquirido

Campo	Ejemplo ficticio	Interpretación o comprobación
Sector lógico	512 bytes	Deducido de la documentación y contrastado
Sectores esperados	125 829 120	Tamaño dividido por 512, si no hay cabeceras externas
Tabla de particiones	GPT	Cabecera primaria y respaldo inspeccionadas
Volúmenes	FAT32 y NTFS	Tipos verificados, no solo reconocidos por firma
Errores de lectura	Ninguno registrado	Se debe disponer del log que lo sustente
Hash de la imagen	SHA-256 registrado	Identifica los bytes del objeto concreto
Regiones pendientes	Espacio entre particiones	No debe describirse como vacío sin examen

El ejemplo no representa un caso real. La capacidad medida debe ser coherente con el formato; en un contenedor segmentado o comprimido el tamaño en disco de los ficheros no equivale necesariamente a la longitud del flujo lógico adquirido. Si la adquisición presenta sectores sustituídos por patrones de relleno a causa de errores, conviene registrar tanto la extensión afectada como el efecto que tiene sobre la interpretación.

La ficha también distingue **datos observados**, **configuración declarada** e **inferencias**. Un tamaño de sector reportado por un archivo de adquisición puede ser un parámetro suministrado por el operador; un valor observado en una cabecera del sistema de archivos ofrece una comprobación independiente, pero puede no coincidir con el tamaño lógico original del dispositivo. Las discrepancias no se ocultan: se investigan y se incorporan al registro.

7.2.10. El laboratorio ante capas no evidentes

En investigaciones complejas es útil conservar un mapa de dependencias. En un servidor con LVM sobre RAID, por ejemplo, la evidencia puede proceder de tres discos físicos, de una imagen del dispositivo RAID ya presentado al sistema o de una exportación de un volumen

lógico. Las tres opciones muestran objetos relacionados pero de alcance distinto. Con solo uno de los miembros RAID quizá no puedan reconstruirse los archivos; con la exportación lógica pueden quedar fuera las regiones que gestionaba la controladora; con una instantánea virtual pueden omitirse cambios pendientes en memoria.

Una buena pregunta de control es: «¿qué componente añadió, eliminó o transformó bytes entre el soporte original y la representación que examino?». La respuesta puede mencionar cifrado, compresión de imágenes, capas diferenciales, snapshots, virtualización, reasignación de bloques, caché o acceso a través de una API. Cada transformación es un punto donde hay que mantener identificadores y registros de verificación independientes.

La práctica de laboratorio debe evitar intervenir sobre la fuente para «hacer que se vea» una estructura. Si una imagen necesita ser descifrada, ensamblada o convertida, se documenta la transformación y se preserva la imagen anterior. Si una partición parece averiada, se trabaja con copias y se contrasta el estado antes y después de cualquier herramienta de reparación. Una operación aparentemente inocente, como abrir un volumen con un controlador que reproduce el diario o actualiza metadatos, puede alterar precisamente la información que se pretendía interpretar. No se trata de prohibir toda operación transformadora, sino de ubicarla sobre derivados controlados y explicitarla.

7.3. Particiones MBR y GPT

7.3.1. Qué resuelve una tabla de particiones

Una tabla de particiones describe regiones del espacio direccionable que se ofrecen como unidades lógicas independientes. No contiene necesariamente el inventario de archivos ni los nombres de directorios. Su misión principal es indicar dónde empiezan y terminan las regiones y, según el esquema, aportar tipos, identificadores y atributos. Una tabla de particiones válida no garantiza que el sistema de archivos dentro de cada región sea coherente.

La ausencia de una tabla reconocible tampoco implica que el soporte carezca de datos. Existen dispositivos formateados directamente sin particiones (*superfloppy*), volúmenes cifrados que ocultan firmas reconocibles, discos virtuales que representan un volumen y soportes con tablas destruidas. El primer diagnóstico debe describir la estructura observada, no imponer una arquitectura esperada.

7.3.2. MBR: organización y límites

El esquema MBR tradicional sitúa información de arranque y una tabla de hasta cuatro entradas primarias en el primer sector lógico del disco, habitualmente de 512 bytes. En el formato clásico, la firma final `55 AA` ocupa los dos últimos bytes del sector. Cada entrada de partición tiene 16 bytes e incluye, entre otros campos, tipo, LBA inicial y número de sectores. Los campos de direccionamiento de 32 bits limitan el espacio representable con sectores de 512 bytes a aproximadamente 2 TiB.

El MBR clásico permite hasta cuatro particiones primarias; una de ellas puede designarse como extendida y albergar una cadena de registros de arranque extendidos (*EBR*) que describen particiones lógicas. La cadena no debe recorrerse suponiendo que todas las entradas son consecutivas o que las direcciones relativas se interpretan igual en todos los contextos. Una corrupción o manipulación de un EBR puede afectar la visibilidad de varios volúmenes.

Los tipos de partición son indicativos. Un valor de tipo asociado a NTFS no demuestra que dentro exista un NTFS funcional; puede haber un volumen reformateado, cifrado o sobrescrito. En la investigación se cotejan los campos de la tabla con las firmas y estructuras internas del volumen.

7.3.3. GPT: cabeceras, entradas y redundancia

GPT, asociado habitualmente a UEFI, emplea direcciones LBA de 64 bits y una organización más flexible. Normalmente incluye un MBR protector en LBA 0, una cabecera GPT principal en LBA 1, una matriz de entradas de partición y una cabecera secundaria cerca del final del disco, acompañada de una copia de la matriz. La ubicación exacta y el tamaño de la matriz se obtienen de la cabecera y no deben deducirse de una plantilla fija.

La cabecera GPT incorpora, entre otros datos, la firma `EFI PART`, revisión, tamaño, LBA actual, LBA de respaldo, límites de espacio utilizable, GUID del disco, ubicación y tamaño de la matriz de entradas, y valores CRC32 para detectar determinadas corrupciones accidentales. Cada entrada puede incluir GUID de tipo, GUID único de partición, LBA inicial y final, atributos y nombre codificado en UTF-16LE.

La presencia de una cabecera secundaria es útil para contrastar o recuperar una tabla dañada, pero no convierte automáticamente una copia en verdadera y la otra en falsa. Una modificación intencionada puede afectar una o ambas. Si hay discrepancias, deben preservarse ambas versiones, comprobar CRC, tamaños y coherencia de límites, y buscar evidencia adicional de operaciones recientes de particionado.

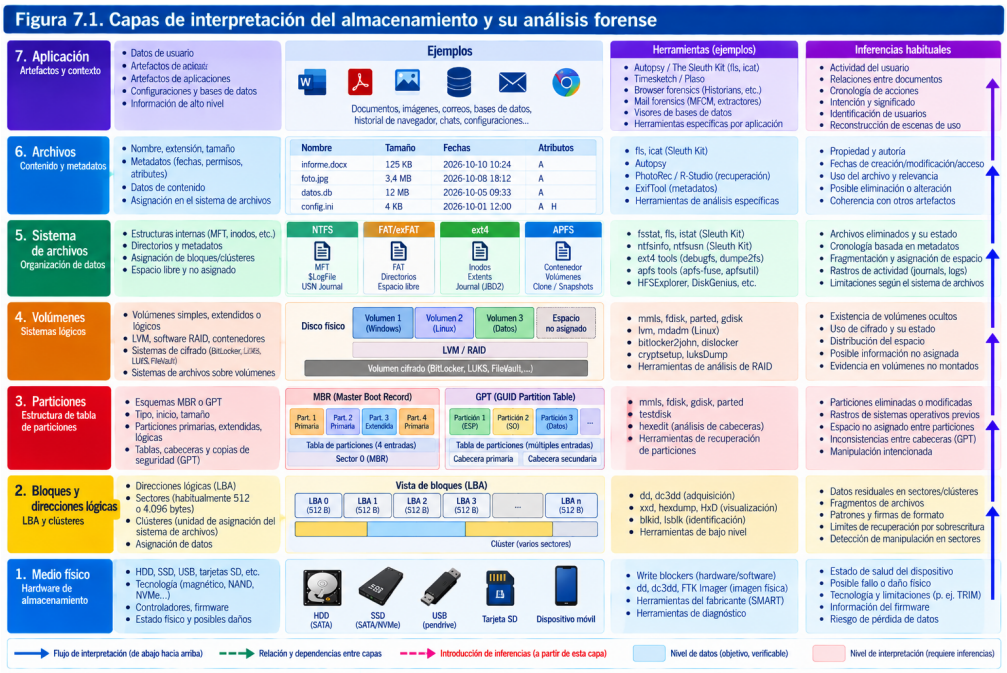


Figura 37: Comparación de las estructuras MBR y GPT

7.3.4. MBR protector, híbridos y anomalías

El MBR protector reduce el riesgo de que utilidades antiguas interpreten un disco GPT como vacío. En algunos entornos existen configuraciones híbridas MBR/GPT, que introducen dos descripciones potencialmente divergentes del mismo espacio. Estas configuraciones merecen especial cautela: una herramienta puede mostrar una partición y otra no, sin que ninguna haya leído mal los bytes; pueden estar aplicando interpretaciones distintas.

Una anomalía de particionado debe registrarse con precisión. «La partición no existe» es una conclusión excesiva si lo único observado es que no figura en la tabla principal. Resulta más defendible indicar que «la entrada de partición no aparece en la tabla GPT principal adquirida; se observa una entrada compatible en la tabla secundaria», añadiendo offsets y evidencias de contraste.

7.3.5. Espacios entre particiones y regiones residuales

Los huecos anteriores, posteriores o intermedios entre particiones pueden contener restos de estructuras anteriores, datos arbitrarios, cargadores, metadatos de gestores de volúme-

nes o simplemente ceros. La existencia de bytes no nulos en una región sin asignar a particiones no prueba ocultación deliberada. Para valorar su significado deben examinarse firmas, continuidad, contexto y posibles explicaciones legítimas.

La alineación moderna de particiones suele dejar espacio inicial antes de la primera partición. También pueden aparecer particiones de recuperación, EFI, MSR u otras áreas de servicio. No deben clasificarse como «ocultas» por el mero hecho de que el explorador de archivos no les asigne letra o punto de montaje.

7.3.6. Ejemplo de cálculo y verificación

Supóngase una imagen de prueba con sector lógico de 512 bytes y una entrada GPT que declara inicio en LBA 4096 y final en LBA 1052671, ambos inclusive. El volumen empieza en 2 097 152 bytes y ocupa 1 048 576 sectores, equivalentes a 536 870 912 bytes. Es importante explicitar que el LBA final es inclusivo:

[sectores = LBA*{final}* - *LBA*{inicial} + 1]

Una comprobación manual puede extraer una pequeña región de una **copia de trabajo** con dd:

```
dd if=disco-prueba.raw of=inicio-volumen.bin \
   bs=512 skip=4096 count=8 status=none
sha256sum inicio-volumen.bin
xxd -l 256 inicio-volumen.bin
```

Estos comandos no validan por sí solos el sistema de archivos: sirven para contrastar offsets y reconocer estructuras iniciales. Los valores de `skip` y `bs` deben derivarse de la evidencia concreta; copiarlos sin adaptación puede llevar a una región equivocada.

7.3.7. Lectura forense de una cabecera MBR

La tabla MBR clásica se ubica en el primer sector lógico del disco y utiliza cuatro entradas de partición de 16 bytes cada una, situadas a partir del desplazamiento 446 de los primeros 512 bytes. Sus dos últimos bytes suelen corresponder a la firma `55 AA`. Esta descripción es estructural: la presencia de la firma no demuestra que las entradas de partición sean correctas, ni que exista un sistema de archivos íntegro en el intervalo que designan. En medios con sector lógico mayor de 512 bytes, estos campos tradicionales se mantienen en la porción inicial correspondiente.

Cada entrada contiene, entre otros datos, un indicador de arranque, un tipo de partición, una dirección inicial LBA de 32 bits y una longitud expresada también en sectores de 32 bits. Los campos históricos CHS están sometidos a restricciones que les restan utilidad práctica en medios actuales. El tamaño y la posición declarados por una entrada permiten proponer un intervalo, pero el analista debe contrastar que empieza en una región verosímil, que no invade el área de otras particiones y que la estructura que se encuentra en su inicio corresponde al tipo esperado.

La existencia de cuatro entradas no significa que todos los discos MBR solo puedan tener cuatro volúmenes utilizables. El esquema clásico admite particiones extendidas y cadenas de registros de arranque extendidos (*Extended Boot Records*, EBR), capaces de representar particiones lógicas. La reconstrucción de una cadena EBR exige distinguir entre direcciones relativas a la partición extendida y direcciones relativas a cada registro; un desplazamiento interpretado respecto del origen equivocado conduce a una extracción incorrecta. Algunas herramientas ocultan este detalle y presentan directamente los volúmenes resultantes, por lo que resulta útil comparar sus cálculos con las estructuras encontradas.

Cuando una entrada señala un volumen que ya no existe o apunta a un intervalo fuera del tamaño adquirido, hay varias explicaciones posibles: partición eliminada, disco clonado y redimensionado, error de una herramienta, corrupción accidental o manipulación deliberada. El forense no elige la opción más llamativa sin pruebas. Busca coincidencia de firmas de sistema de archivos en el destino, coherencia de superestructuras, restos de entradas anteriores y evidencias de operaciones administrativas.

Ejemplo de razonamiento. Una imagen de 32 GiB contiene un MBR válido desde el punto de vista de su firma, pero una entrada anuncia que un volumen comienza después del último LBA adquirido. El dato verificable es la incompatibilidad entre la entrada y el tamaño disponible. El hallazgo es que esa entrada no identifica un volumen contenido íntegramente en la imagen. La causa queda abierta: podría tratarse de una adquisición truncada o de una tabla inconsistente. Antes de concluir «partición falsa», se consulta el registro de adquisición y el tamaño original de la fuente.

7.3.8. Verificación manual de GPT y redundancia no infalible

GPT introduce una cabecera primaria, normalmente en LBA 1, una matriz de entradas de partición y sus correspondientes estructuras de respaldo hacia el final del soporte. La especificación UEFI define campos de verificación CRC32 para la cabecera y para la matriz de entradas. Son mecanismos diseñados para detectar alteraciones accidentales de esas estructuras, no firmas criptográficas ni garantías de autenticidad. Un atacante con capacidad de escribir sobre el disco puede modificar una tabla y recalcular correctamente sus CRC.

Para evaluar una GPT se comprueba, como mínimo, la firma de cabecera, su tamaño, el valor `MyLBA`, la posición de la cabecera alternativa (`AlternateLBA`), los límites `FirstUsableLBA` y `LastUsableLBA`, la ubicación y longitud de la matriz de entradas, y las verificaciones CRC declaradas. También debe revisarse que las particiones activas no se solapen y que no apunten fuera del espacio utilizable. Una herramienta puede advertir de una cabecera primaria dañada y proponer reconstruirla desde la secundaria; la **propuesta de reparación** no autoriza al analista a modificar la evidencia original.

Hay situaciones especialmente interesantes. Tras ampliar un disco virtual, la GPT de respaldo puede permanecer en la antigua última posición y aparecer un espacio adicional al final. Tras clonar una unidad a otra de distinta capacidad, la geometría y los límites almacenados pueden dejar de describir completamente el medio. Al convertir un disco entre MBR y GPT, pueden subsistir restos de la tabla anterior. Incluso una GPT primaria y una secundaria válidas pueden no coincidir si fueron modificadas en momentos distintos. La comparación de ambas aporta una hipótesis sobre la historia del soporte, pero no fija por sí misma quién realizó la operación ni cuándo.

Los identificadores GUID permiten relacionar particiones y tipos, aunque no son identificadores criptográficos de procedencia. Una clonación puede duplicarlos. Un mismo GUID de partición observado en dos imágenes podría apoyar una relación de copia, pero deben descartarse plantillas reutilizadas, discos clonados legítimamente y artefactos derivados de la misma máquina virtual. Tampoco cabe concluir que un volumen contiene determinado sistema de archivos solo por su tipo GPT: el contenido debe comprobarse de forma independiente.

7.3.9. La diferencia entre estructura declarada y estructura encontrada

Un mapa de particiones completo combina al menos dos perspectivas. La **estructura declarada** procede de MBR, GPT o del esquema de volúmenes identificado. La **estructura encontrada** se obtiene al inspeccionar firmas y metadatos compatibles con sistemas de archivos a lo largo del flujo de bloques. Normalmente ambas coinciden. Cuando no lo hacen, la discrepancia es precisamente un resultado susceptible de investigación.

Imaginemos una imagen que declara tres particiones y cuyo espacio entre la primera y la segunda contiene una posible cabecera NTFS. Si la cabecera presenta campos coherentes, copias de estructuras en posiciones esperadas y registros MFT reconocibles, podría corresponder a un volumen anterior. Sin embargo, también podría formar parte de un archivo de imagen que estuvo allí antes de una reorganización. Para discriminar, interesa buscar continuidad espacial de las estructuras, coherencia de límites, identificadores y evidencias exter-

nas del uso de la unidad. El hallazgo no se confirma con una búsqueda indiscriminada de la cadena NTFS.

Un sector de arranque válido, por sí solo, tampoco garantiza que el resto del sistema de archivos sea legible. Si se recupera un volumen anterior solo en parte, deben trazarse las regiones que se pueden describir con confianza y las que podrían pertenecer a datos de otro período. Un volumen «reconstruido» a partir de un arranque antiguo y una MFT posterior puede reunir estructuras de distintas épocas. El peligro consiste en presentar ese ensamblaje como una fotografía coherente del disco en un momento histórico que nunca existió.

7.3.10. Análisis numérico de intervalos y solapamientos

Los intervalos deben trabajarse con una convención explícita. Cuando una partición comienza en LBA 2048 y ocupa 4096 sectores, su último sector es `2048 + 4096 - 1 = 6143`. El primer sector siguiente es 6144. Muchas herramientas muestran un extremo inicial y otro final inclusivo, mientras que programas y bibliotecas utilizan intervalos semiabiertos `[inicio, fin)`. No documentar esta diferencia provoca errores de un sector que pueden afectar precisamente al límite de una partición y a las estructuras de respaldo.

Para auditar cálculos sencillos puede utilizarse un script independiente con enteros, sin acceder al soporte original:

```
# Ejemplo con datos sintéticos; no escribe sobre evidencias.
sector_bytes = 512
inicio_lba = 2048
longitud_sectores = 4096
ultimo_lba = inicio_lba + longitud_sectores - 1
inicio_bytes = inicio_lba * sector_bytes
longitud_bytes = longitud_sectores * sector_bytes
print(f"LBA final inclusivo: {ultimo_lba}")
print(f"Desplazamiento: {inicio_bytes} bytes")
print(f"Longitud: {longitud_bytes} bytes")
```

Si se comparan dos particiones, el solapamiento existe cuando comparten al menos un LBA. No debe confundirse que una partición termine en 6143 y la siguiente comience en 6144 con un solapamiento. El investigador que calcule tamaños en bytes deberá usar el sector lógico correspondiente a **esa adquisición**, no el de una unidad diferente conectada al laboratorio. De forma análoga, la extracción por offsets se realiza sobre el flujo lógico correcto y no sobre los bytes físicos del archivo EWF comprimido.

Un procedimiento defensable conserva tanto la salida de una herramienta reconocida como el cálculo independiente de uno o varios valores críticos. Si las herramientas no coinciden, es preferible registrar una tabla de discrepancias antes que forzar una interpretación común. La discrepancia puede proceder de un sector lógico supuesto, de una cabecera corrupta, de una GPT antigua o de un formato de imagen mal interpretado.

7.3.11. Escenarios de práctica reproducible con particiones

Un laboratorio puede construir tres imágenes sintéticas diferentes para entrenar el reconocimiento sin necesidad de alterar un dispositivo incautado. En la primera, un disco MBR contiene dos particiones y una región sin asignar; la respuesta conocida incluye offsets, tipos y tamaños. En la segunda, una GPT tiene su cabecera primaria válida y la secundaria dañada en una copia; se espera que el analista la detecte sin reparar el original. En la tercera, la imagen incorpora una firma de sistema de archivos dentro de espacio no asignado sin suficientes estructuras complementarias; la respuesta correcta es **indicio no confirmado**, no «partición recuperada».

Estas prácticas muestran que un resultado negativo puede ser igualmente válido: no detectar una estructura compatible, no lograr calcular su tamaño con garantías o no encontrar pruebas de que una firma corresponda a un volumen operativo. Cada escenario debe conservar un manifiesto de generación, un hash del fichero de prueba y la verdad conocida contra la que se evaluarán las herramientas. Si se modifica un byte de la imagen para introducir una anomalía, se obtiene un **nuevo objeto de prueba**, con un identificador y un hash propios. La diferencia frente a la imagen original constituye parte de la práctica.

7.4. Sistemas de archivos: FAT, exFAT, NTFS, ext4 y APFS

7.4.1. Sistemas de archivos como modelos de asignación

Un sistema de archivos establece cómo se representan los objetos y cómo se relacionan nombres, directorios, contenidos, metadatos y espacio libre. Algunos modelos usan tablas de asignación, otros inodos y árboles, y otros combinan estructuras transaccionales con copia en escritura. Ningún formato puede interpretarse adecuadamente aplicando sin más los supuestos de otro.

La adquisición a nivel de bloques permite observar estructuras que una exportación lógica normalmente omite: entradas borradas, bloques no asignados, diarios, espacio de relleno y restos de asignaciones anteriores. Sin embargo, disponer de todos los bloques accesibles

no garantiza poder reconstruir su significado. La corrupción, el cifrado, la sobrescritura y los cambios internos pueden impedir una interpretación fiable.

La tabla siguiente resume diferencias relevantes sin pretender sustituir la documentación técnica de cada implementación:

Sistema	Estructura característica	Artefactos útiles	Precaución principal
FAT12/16/32	Tabla de asignación y entradas de directorio	Entradas eliminadas, cadenas de clústeres	Reutilización y marcas temporales limitadas
exFAT	Mapa de asignación, bitmap y conjuntos de entradas	Entradas de archivo, asignación y metadatos	Semántica de asignación y recuperación variable
NTFS	MFT, atributos, bitmap y registros transaccionales	`$MFT`, `$UsnJrnl`, `$LogFile`	Distinguir contenido, atributos y operaciones registradas
ext4	Inodos, extents, bitmaps y journal	Inodos, directorios, journal, extents	Reutilización, borrado y alcance del journal
APFS	Contenedores, objetos, B-trees y snapshots	Metadatos de volumen, instantáneas, clones	Copy-on-write, cifrado y cambios entre versiones

7.4.2. FAT: simplicidad aparente y ambigüedad forense

FAT organiza el volumen mediante una región de arranque, tablas de asignación, directorios y área de datos. La tabla FAT describe el estado de los clústeres y, para archivos no contiguos, la secuencia que compone su contenido. Las variantes FAT12, FAT16 y FAT32 difieren en el tamaño de las entradas y otros detalles estructurales; FAT32 no debe confundirse con un sistema que utilice exactamente 32 bits de direccionamiento libre para cada clúster.

Las entradas de directorio clásicas de 32 bytes almacenan nombre corto, atributos, marcas temporales, clúster inicial y tamaño. Los nombres largos se implementan mediante entradas adicionales que deben interpretarse conjuntamente con la entrada principal. Una entrada

marcada como eliminada puede conservar nombre parcial, tamaño y clúster inicial, pero la cadena de asignación puede haberse liberado o reutilizado. Recuperar un archivo fragmentado basándose solo en su primer clúster puede producir un contenido erróneo que conserve, no obstante, una cabecera de archivo plausible.

En FAT, las marcas temporales presentan limitaciones de resolución y semántica. Algunas marcas de acceso almacenan solo la fecha, y las horas locales pueden carecer de información explícita de zona horaria. No deben compararse automáticamente con marcas UTC de otros sistemas sin registrar la conversión y la incertidumbre asociada.

Un archivo eliminado de una tarjeta FAT puede reconstruirse completamente si sus clústeres permanecen intactos y su distribución es deducible. Pero también puede producirse una recuperación parcial o un falso ensamblaje. La comprobación de cabeceras y pies de archivo es insuficiente para demostrar que todos los bytes intermedios pertenecen al mismo objeto.

7.4.3. exFAT: almacenamiento extraíble contemporáneo

exFAT está diseñado para soportes y volúmenes que necesitan manejar archivos grandes y compartir datos entre plataformas. Emplea estructuras como el mapa de asignación (*allocation bitmap*) y conjuntos de entradas de directorio. La tabla FAT puede utilizarse para describir cadenas de clústeres, pero determinadas asignaciones contiguas se representan sin depender de una cadena FAT ordinaria. El analista no debe asumir que un valor aparentemente vacío en la FAT significa que no existe contenido asignado.

La recuperación depende de los campos conservados en las entradas, de la asignación y del grado de reutilización. Un conjunto de entradas puede incluir metadatos y nombres repartidos entre varias estructuras; si una parte está dañada o sobrescrita, puede mantenerse el contenido sin poder recuperar el nombre original, o viceversa. Los análisis deben distinguir los objetos íntegramente reconstruidos de los que solo son candidatos.

En medios extraíbles, exFAT plantea además cuestiones de procedencia. La fecha de modificación de un documento no indica necesariamente cuándo fue copiado al dispositivo; la operación de copia puede conservar algunas marcas y alterar otras. Para sostener que una memoria USB se utilizó para extraer información, el contenido del volumen debe correlacionarse con registros del equipo anfitrión, accesos, identificadores de dispositivo y, cuando existan, otras fuentes independientes.

7.4.4. NTFS: registros, atributos y operaciones

NTFS representa gran parte de sus objetos mediante registros en la *Master File Table* (`$MFT`). Cada archivo o directorio puede tener atributos que describen nombres, datos, información estándar y otras propiedades. Algunos datos pequeños pueden ser residentes en el registro; otros se almacenan fuera y se describen mediante secuencias de asignación. El identificador de un registro MFT y su número de secuencia son relevantes para detectar reutilizaciones y evitar confundir objetos distintos que ocuparon la misma posición de tabla en momentos diferentes.

Los atributos `$STANDARD_INFORMATION` y `$FILE_NAME` pueden contener marcas temporales que no coincidan. Esa diferencia no es automáticamente indicio de manipulación: responden a funciones y patrones de actualización diferentes. Una interpretación sólida examina las cuatro marcas temporales habituales —creación, modificación de contenido, modificación de metadatos y acceso—, identifica su fuente exacta y considera operaciones como renombrado, copia, restauración, extracción de archivos o movimientos entre volúmenes.

La MFT permite detectar archivos existentes, algunos eliminados y relaciones entre directorios. No debe confundirse una entrada no asignada con la certeza de que el contenido sigue recuperable. Los clusters pueden haberse reutilizado, y los atributos residentes pueden haber desaparecido al reciclarse el registro. Asimismo, un registro MFT puede ser válido mientras el contenido referenciado sea ilegible o no esté presente en la adquisición.

NTFS dispone de artefactos adicionales. `$LogFile` se relaciona con operaciones de registro transaccional del sistema de archivos; `$UsnJrnl`, cuando está habilitado y disponible, puede conservar registros de cambios en objetos. Su presencia, retención y alcance varían. Un evento de USN no constituye por sí solo una narración completa de la actividad humana: expresa que se registró una determinada clase de cambio sobre un objeto en el sistema de archivos. La atribución a una aplicación o usuario requiere correlación adicional.

Los *Alternate Data Streams* (ADS) permiten asociar flujos de datos con un archivo más allá del flujo principal. El analista debe decidir si la herramienta de exportación conserva estos flujos; algunas copias lógicas pueden omitirlos. Los enlaces duros y puntos de nueva interpretación (*reparse points*) también pueden complicar la relación entre nombre, ruta y objeto físico.

7.4.5. Ejemplo de interpretación de una eliminación en NTFS

Supóngase que la MFT contiene un registro marcado como no asignado para `informe.xlsx`, con un tamaño de 82 944 bytes. En `$UsnJrnl` aparece un evento compatible

con eliminación y, en registros de aplicación, una sincronización posterior. El primer hallazgo defendible es que la imagen conserva un registro de sistema de archivos asociado a ese nombre y marcado como no asignado. El segundo es que un diario registra una operación compatible con eliminación en una fecha determinada. Todavía no puede concluirse quién eliminó el archivo, si lo hizo deliberadamente, si el contenido desapareció del repositorio remoto o si el evento fue resultado de sincronización.

Para contrastar hipótesis, se revisan la secuencia de registro MFT, referencias de directorio, marcas temporales, registros del cliente de sincronización, historial de versiones y auditoría del servicio remoto. Una coincidencia temporal estrecha ayuda a reconstruir, pero no convierte por sí misma dos eventos en causa y efecto.

7.4.6. ext4: inodos, extents y diario

ext4 organiza datos y metadatos mediante grupos de bloques, inodos, estructuras de asignación y, habitualmente, un diario. Un inodo describe un objeto y puede contener atributos, marcas temporales y referencias a su contenido. Los nombres se mantienen en entradas de directorio: un inodo no equivale a una ruta textual única. Un mismo archivo puede tener varios enlaces duros, y una ruta puede cambiar sin que cambie el contenido.

Los *extents* describen rangos de bloques contiguos y sustituyen, en muchos casos, a listas extensas de bloques individuales. En la investigación es necesario interpretar los extents conforme a su estado y a las estructuras efectivamente presentes. Los bloques liberados pueden reutilizarse y las referencias del inodo pueden cambiar tras la eliminación. Por ello, la existencia de una referencia antigua no garantiza que el contenido permanezca.

El journal de ext4 facilita la coherencia del sistema de archivos ante interrupciones, pero no es un registro forense exhaustivo de todas las operaciones de usuario. Su alcance depende del modo de diario, la carga, la configuración y el tiempo transcurrido. Las operaciones de montaje o recuperación automática pueden modificar estructuras; de ahí la importancia de analizar una copia y de controlar las opciones de montaje, preferentemente evitando cualquier reproducción del journal sobre la evidencia de referencia.

ext4 puede almacenar tiempos con precisión subsegundo y campos adicionales, pero la disponibilidad de una fecha de creación depende de la estructura y de la herramienta utilizada. Las fechas mostradas por `stat` o por una suite forense deben interpretarse según la versión del sistema de archivos, la implementación y la procedencia del dato. Una fecha ausente no debe rellenarse con otra marca temporal sin dejarlo explícito.

7.4.7. APFS: contenedores, volúmenes y copia en escritura

APFS emplea una arquitectura basada en contenedores y volúmenes, estructuras de objetos y mecanismos de copia en escritura (*copy-on-write*). Puede compartir espacio entre volúmenes del mismo contenedor y admitir instantáneas y clones. La visión de «un disco, una partición, un sistema de archivos» es insuficiente para describir estas relaciones.

La copia en escritura permite que determinadas versiones de estructuras permanezcan temporalmente disponibles sin sobrescribir directamente las anteriores. Sin embargo, ello no garantiza recuperación indefinida. La gestión de espacio, la eliminación de instantáneas, el cifrado y las operaciones de mantenimiento condicionan qué objetos son accesibles. Un análisis debe especificar si observa el estado actual, una instantánea concreta o una reconstrucción basada en objetos históricos.

Los clones pueden compartir extents de datos y divergir posteriormente. Dos archivos que muestran contenidos iguales no necesariamente fueron copiados byte a byte en el momento sugerido por sus marcas temporales. Del mismo modo, el espacio libre compartido entre volúmenes complica atribuir ciertos bloques a un único volumen sin interpretar correctamente los metadatos del contenedor.

El cifrado en APFS puede estar integrado con mecanismos de protección de claves del dispositivo. Obtener una imagen de bloques cifrados no implica que se puedan leer los archivos. La adquisición de un volumen accesible en una sesión autorizada y la adquisición del contenedor cifrado son representaciones distintas, con cobertura y riesgos diferentes. Su relación debe documentarse sin confundir los hashes.

7.4.8. Comparación de operaciones comunes

La operación «copiar un archivo» no tiene una firma universal. En un volumen FAT puede crear una entrada nueva y asignar clústeres; en NTFS, generar nuevos registros y cambios en el journal; en ext4, modificar inodos y directorios; en APFS, intervenir mecanismos de clonación o copia en escritura. Las aplicaciones pueden conservar o modificar las marcas temporales, y los clientes de sincronización pueden producir cambios locales sin una interacción directa con el archivo.

Por ello, las conclusiones deben formularse con referencia al sistema de archivos y al artefacto: «se observó un nuevo registro de archivo», «se registró una operación de cambio de nombre», «el contenido es idéntico según SHA-256» o «existe una instantánea anterior que contiene una versión diferente». «El usuario copió el archivo a las 10:32» es una afirmación de mayor nivel que exige evidencia adicional sobre usuario, proceso, origen, destino y reloj.

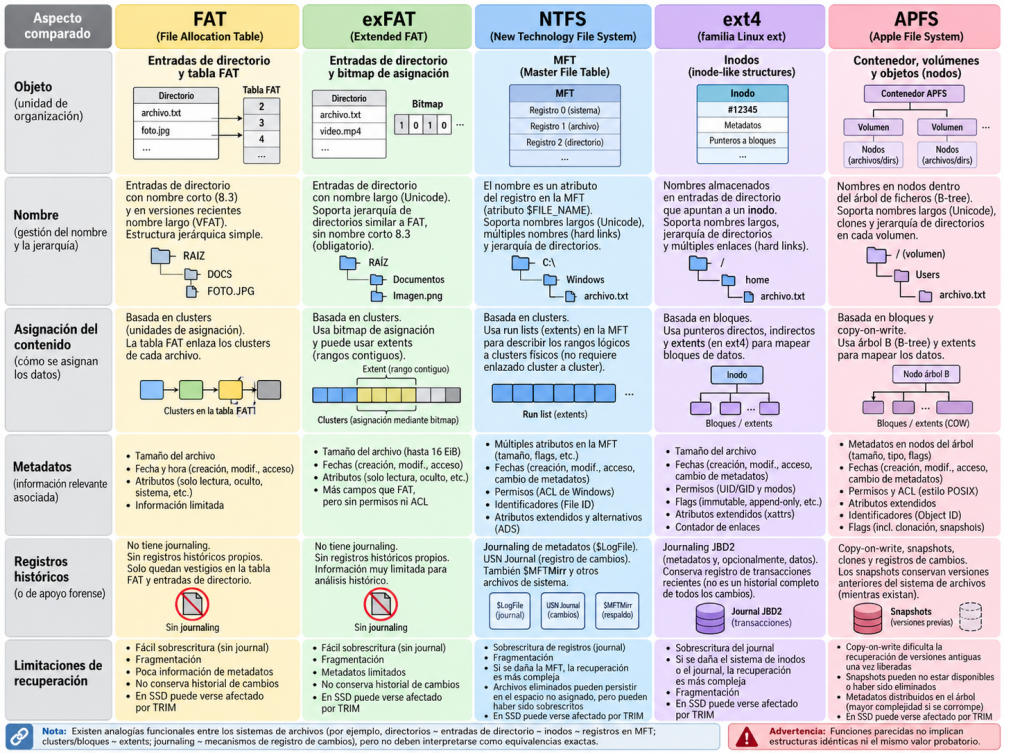


Figura 38: Mapa comparativo de FAT, exFAT, NTFS, ext4 y APFS

7.4.9. FAT en profundidad: cadenas, directorios y nombres largos

FAT nació en un contexto de medios comparativamente sencillos, pero su investigación requiere distinguir cuidadosamente las estructuras. El sector de arranque describe parámetros que permiten calcular dónde se encuentran las tablas FAT, el directorio raíz —según variante— y el área de datos. En FAT12 y FAT16, la posición del directorio raíz está restringida de forma distinta de FAT32; en este último, el directorio raíz se ubica en la región de datos y se trata de manera más parecida a otros directorios. La denominación FAT12, FAT16 o FAT32 se relaciona con la anchura práctica de las entradas de asignación y el número de clústeres, no con que las aplicaciones guarden respectivamente archivos de 12, 16 o 32 bits.

La FAT relaciona clústeres de datos mediante entradas que pueden indicar continuidad de una cadena, final de archivo, área libre o marcas de clúster defectuoso. Un archivo fragmentado puede ocupar una secuencia lógica cuyos clústeres físicos no sean contiguos. Recuperar solo desde el primer clúster hasta alcanzar la longitud anunciada, sin seguir la cadena que corresponda, puede producir un archivo aparente con bytes pertenecientes a objetos

diferentes. La fragmentación es por ello una limitación importante de recuperaciones basadas únicamente en firmas.

Las entradas de directorio clásicas emplean nombres cortos compatibles con el esquema 8.3. Los nombres largos, habituales en Windows, se implementan mediante entradas adicionales asociadas a la entrada principal. Tras una eliminación pueden persistir restos de esas entradas, pero su asociación puede quedar debilitada si una parte ha sido reutilizada. Es incorrecto presentar siempre el nombre largo reconstruido como seguro solo porque varias entradas contiguas parecen contener caracteres de un mismo nombre. La validación exige examinar secuencias, indicadores y, cuando proceda, comprobaciones de consistencia previstas en el formato.

Al eliminar un archivo en FAT se suele marcar la entrada de directorio como eliminada y se liberan las entradas correspondientes de asignación. La información sobre el primer clúster o parte del nombre puede permanecer; sin embargo, la cadena de clústeres ya no tiene por qué ser recuperable a través de una FAT coherente. Se puede obtener una reconstrucción completa de archivos que estaban contiguos, mientras que los fragmentados pueden presentar discontinuidades silenciosas. El analista distingue entre archivo recuperado y contenido **aparentemente recuperado** cuyos límites no se han podido verificar.

Las marcas temporales de FAT tienen resolución y semántica diferentes de las de NTFS. Algunas variantes almacenan fechas y horas locales sin una zona horaria asociada de modo inequívoco. FAT clásico no presenta la misma riqueza de metadatos de cambio que otros formatos, por lo que la ausencia de una marca concreta no acredita que la operación correspondiente no ocurriera. En dispositivos extraíbles, además, es común que varios sistemas operativos manipulen los mismos archivos y apliquen reglas de conversión distintas.

7.4.10. exFAT: mapa de asignación y conjuntos de entradas

En exFAT, la asignación de clústeres se gestiona mediante un *Allocation Bitmap*, y la FAT conserva funciones relevantes según cómo se organicen las cadenas de datos. Las entradas de archivo se presentan mediante conjuntos que incluyen una entrada principal y entradas secundarias, como extensión del flujo y fragmentos de nombre. El estado de asignación, los atributos, la longitud del flujo y los indicadores del archivo deben interpretarse de forma conjunta. Aplicar a exFAT las reglas de recuperación de FAT32 sin considerar esta diferencia puede producir falsos resultados.

Una característica práctica es que ciertas cadenas de clústeres pueden representarse como contiguas sin necesidad de seguir entradas FAT para cada enlace, según los indicadores del conjunto de entradas. En un archivo eliminado, la pérdida o reutilización de una parte del

conjunto puede impedir determinar con seguridad si su contenido era contiguo, cuál era la longitud válida o cuál era el nombre completo. La existencia de bytes plausibles en el *cluster heap* no resuelve por sí sola esas dudas.

Las regiones de arranque principal y de respaldo de exFAT ofrecen posibilidades de comprobación de coherencia, pero su presencia no garantiza que todos los directorios estén íntegros. También conviene registrar la versión y las características implementadas, porque no todos los sistemas operativos aplican idénticas políticas de montaje y actualización de tiempo. La especificación del formato describe marcas locales de fecha y hora y mecanismos para almacenar desplazamientos respecto de UTC en determinados campos; la interpretación debe respetar la información concreta que realmente se encuentre disponible.

Un caso habitual es la memoria USB que se conecta a un ordenador con Windows y posteriormente a un equipo con macOS o Linux. Si un documento conserva un tiempo de modificación pero aparece con otra hora en una herramienta diferente, antes de inferir una manipulación deliberada hay que reconstruir la conversión desde el formato original y la zona horaria asumida por cada programa. La regla editorial es sencilla: **nunca se atribuye un cambio temporal a una persona sin descartar antes las transformaciones automáticas del soporte y del software**.

7.4.11. NTFS: la MFT como fuente de relaciones, no como biografía perfecta

La *Master File Table* (MFT) es central en NTFS. Cada archivo y directorio dispone de registros y atributos que describen propiedades y, en determinados casos, contenido. Sin embargo, no debe simplificarse afirmando que «cada archivo cabe en un único registro». Atributos extensos, archivos muy fragmentados o determinadas características pueden implicar registros adicionales. Los atributos residentes almacenan datos dentro del registro cuando resulta posible; los no residentes los describen mediante asignaciones hacia clústeres del volumen.

En la reconstrucción de un objeto es necesario considerar la identidad del registro y su número de secuencia, no solo el número de entrada MFT aislado. Una entrada puede quedar libre y reutilizarse para otro archivo; si una herramienta une una referencia antigua con un registro posterior que tiene el mismo número base, puede establecer asociaciones erróneas. Por ello, los enlaces a directorios, los identificadores de archivo y los números de secuencia ofrecen comprobaciones importantes cuando se investigan referencias residuales.

Dos conjuntos de marcas temporales llaman especialmente la atención: las incluidas en atributos `$STANDARD_INFORMATION` y las relacionadas con `$FILE_NAME`. No tienen por qué evolucionar simultáneamente ni obedecer las mismas reglas en todas las operaciones. Sus discrepancias pueden ser indicios de copia, renombrado, modificación de metadatos o

manipulación, pero no constituyen una firma universal de *timestomping*. Un cambio de nombre no implica necesariamente alteración de contenido; una copia puede generar tiempos de creación distintos manteniendo ciertos valores de modificación; una restauración puede conservar atributos que anteceden al momento de recuperación.

El diario `$LogFile` ayuda a comprender determinadas operaciones de NTFS y su consistencia transaccional, pero no es una grabación exhaustiva de toda la actividad del usuario. El diario de cambios USN, cuando existe y conserva registros relevantes, puede aportar eventos sobre archivos, sus identificadores y motivos de cambio. Microsoft advierte que estos registros no contienen información suficiente para revertir operaciones. Además, pueden rotarse o eliminarse entradas antiguas; varios cambios pueden quedar representados con menos detalle del que una investigación desearía.

Otro artefacto interesante es `$Bitmap`, utilizado para representar el estado de asignación de clústeres del volumen. Contrastar un archivo que se considera activo con su asignación puede revelar incoherencias, aunque los resultados exigen estudiar si se está trabajando con una instantánea consistente, si existen operaciones pendientes o si la herramienta reconstruye las estructuras del mismo momento lógico. Los archivos dispersos, las secuencias alternativas de datos (*Alternate Data Streams*) y los puntos de reanálisis introducen otros escenarios en los que el nombre visible no describe completamente el almacenamiento o la ruta real de acceso.

Ejemplo interpretativo. Un registro MFT de un informe aparece marcado como no asignado; hay referencias residuales al nombre anterior; una entrada USN compatible indica un cambio de nombre seguido de eliminación. Esto sostiene con más fuerza la historia de una operación sobre el archivo que el registro MFT por sí solo. Aun así, no identifica al usuario humano. Para atribuir una cuenta o una sesión sería necesario relacionar la actividad con registros adicionales de sistema, acceso, proceso y contexto organizativo, teniendo presentes sus propios límites.

7.4.12. NTFS y los objetos que no parecen archivos ordinarios

La perspectiva centrada en archivos de usuario puede pasar por alto elementos decisivos. Los enlaces duros permiten varios nombres para un mismo archivo; su eliminación puede afectar a una entrada de directorio sin eliminar inmediatamente los datos mientras queden otras referencias. Los puntos de reanálisis pueden redirigir rutas, enlazar volúmenes o introducir un comportamiento que no se deduce del árbol mostrado por una herramienta básica. Las secuencias alternativas de datos pueden almacenar contenido no visible en listados simplificados, y los archivos comprimidos o dispersos necesitan interpretación específica de asignación y tamaño lógico.

El investigador debe anotar la diferencia entre «ruta aparente» y «objeto subyacente». Si una búsqueda textual devuelve dos rutas con idénticos hashes de contenido, podría tratarse de copias independientes, enlaces duros, clones gestionados por capas superiores o archivos coincidentes. El hash no resuelve por sí mismo la relación de almacenamiento. Cuando la cuestión investigada es si una persona duplicó un documento, resulta esencial discriminar entre una segunda representación de nombre y una copia materializada en otra ubicación.

En NTFS la asignación del espacio también puede modificarse sin que exista una acción intencional de borrado por parte del usuario. Limpiezas automáticas, restauraciones, actualizaciones del sistema, servicios de sincronización y procesos de seguridad pueden crear, mover y eliminar archivos temporales. Un informe prudente pregunta qué proceso pudo generar la operación antes de denominarla eliminación deliberada.

7.4.13. ext4: inodos, directorios y operaciones transaccionales

En ext4, los metadatos centrales de un archivo residen en su inodo, mientras que el nombre se mantiene en estructuras de directorio que enlazan nombres e identificadores de inodo. La separación es importante: una entrada de directorio antigua puede señalar un inodo que posteriormente ha sido reutilizado para otro objeto. Leer el contenido actual de ese número y atribuírselo automáticamente al nombre antiguo puede unir información incompatible de distintas épocas.

Los *extents* permiten describir rangos de bloques contiguos con una estructura más compacta que una enumeración de cada bloque. No significa que todo archivo sea contiguo. Los archivos fragmentados pueden requerir varios extents; las formas internas de su árbol dependen del tamaño y la distribución. Existen además archivos dispersos, enlaces simbólicos, enlaces duros y datos que pueden residir en el propio inodo según características habilitadas. La herramienta de análisis debe manejar correctamente las características relevantes del sistema de archivos concreto.

El diario JBD2 y la política de consistencia merecen una advertencia. En la configuración habitual de ext4, el diario protege principalmente metadatos y no conserva necesariamente todas las escrituras de datos del archivo como lo haría una grabación de sesiones. Modos como `data=journal`, `data=ordered` y `data=writeback` no ofrecen las mismas garantías. En consecuencia, hallar una transacción compatible con una actualización de inodo no equivale a reconstruir todo el contenido anterior del archivo ni el motivo de esa actualización.

En la interpretación temporal, `ctime` designa el cambio de estado del inodo, no una fecha de creación universal. Algunos inodos ext4 incluyen `crtime` o tiempo de nacimiento, pero

su existencia depende de formato y características. Los campos adicionales pueden proporcionar mayor precisión temporal, aunque una marca con muchos decimales no está automáticamente sincronizada con un reloj fiable. También pueden existir políticas de actualización de `atime` que reduzcan escrituras o impidan inferir todas las lecturas realizadas.

Un caso práctico: un fichero `informe.odt` deja de figurar en el directorio `/home/usuario/Documentos`, pero su inodo aparece en estructuras residuales. El analista tendrá que comprobar si el inodo sigue asignado a otro nombre, si pertenece a otro enlace duro, si su contenido ha sido reutilizado y si el diario aporta un indicio compatible con eliminación o renombrado. Si la reconstrucción solo identifica bloques de contenido sin una relación fiable con el directorio, el informe debe expresarlo: **contenido recuperado de la imagen**, sin atribución concluyente a una ruta anterior.

7.4.14. APFS: contenedores, volúmenes, instantáneas y clones

APFS utiliza un modelo de contenedor en el que diferentes volúmenes pueden compartir espacio disponible. Por ello, la presencia de varios volúmenes no implica una partición independiente para cada uno. Sus estructuras de metadatos emplean mecanismos de copia en escritura (*copy-on-write*): ciertas actualizaciones generan nuevos objetos o nodos en lugar de sobrescribir todos los anteriores. Esto puede conservar información histórica en determinadas circunstancias, pero no autoriza a esperar que todo archivo eliminado siga disponible.

Las instantáneas (*snapshots*) registran estados coherentes según las capacidades y condiciones del sistema. Su valor forense consiste en que pueden permitir examinar la representación de un volumen en un momento diferente del actual. No son equivalentes a copias de seguridad completas y externas; su disponibilidad puede depender de políticas de retención, consumo de espacio, operaciones de mantenimiento y configuración. Tampoco debe inferirse que una instantánea contenga necesariamente todos los datos externos referenciados por una aplicación.

Los clones APFS pueden compartir extents entre archivos hasta que se modifican regiones concretas. Dos nombres pueden representar objetos independientes con contenido inicialmente común, sin que se haya realizado una segunda copia física completa de los bloques. La investigación de duplicaciones tiene que distinguir identidad del objeto, identidad del contenido, relación de clone y acción de copia en la aplicación. Del mismo modo, la eliminación de un nombre no implica necesariamente que todos los bloques de datos dejen de estar referenciados si otro clon o snapshot los conserva.

El cifrado de APFS introduce una limitación independiente de su estructura lógica. Una imagen de bloques cifrados puede ser íntegra y estar correctamente adquirida, pero resultar inaccesible a nivel de sistema de archivos sin los mecanismos legítimos necesarios para descifrarla. Una exportación del volumen ya desbloqueado proporciona un objeto analizable distinto de la imagen cifrada. Sus hashes no tienen por qué coincidir; el expediente debe describir cómo se obtuvieron y qué información quedó fuera.

En macOS las decisiones de presentación de volúmenes del sistema y de datos, sus roles y mecanismos de sellado pueden influir en la interpretación. No conviene identificar automáticamente el volumen mostrado por el Finder con una única estructura física independiente. Los análisis de APFS deberán registrar versión del sistema, capacidad de la herramienta, disponibilidad de snapshots y el nivel al que se llevó a cabo la adquisición.

7.4.15. Comparación transversal: una misma pregunta, cinco respuestas estructurales

La pregunta «¿se eliminó el archivo?» se traduce de manera diferente en cada formato. En FAT puede comenzar por una entrada de directorio marcada y una cadena de clústeres liberada. En exFAT, por el conjunto de entradas y la información del mapa de asignación. En NTFS, por el estado de registros MFT y, si existen, por rastros transaccionales y de USN. En ext4, por la relación entre entradas de directorio, inodos, extents y diario. En APFS, por las estructuras del volumen y los posibles estados retenidos por instantáneas y clones.

Sistema	Identificador o estructura central	Asignación de datos	Dificultad común tras eliminación	Apoyo contextual
FAT	Entradas de directorio	Tabla FAT y clústeres	Pérdida de cadena y fragmentación	Nombres, primer clúster, copias FAT si existen
exFAT	Conjuntos de entradas	Bitmap y FAT según uso	Entradas parciales o bitmap reutilizado	Flujo, nombre y metadatos asociados
NTFS	MFT y atributos	Runs y bitmap del volumen	Reutilización de registros o clusters	USN, `$LogFile`, otras fuentes Windows

Sistema	Identificador o estructura central	Asignación de datos	Dificultad común tras eliminación	Apoyo contextual
ext4	Inodos y directorios	Extents y bitmaps	Reutilización de inodos y bloques	Diario y registros Linux
APFS	Objetos del volumen y árboles	Mapeo de objetos, clones y espacio compartido	Cifrado, snapshots ausentes, reutilización	Estados de snapshot y registros del sistema

La tabla es una guía conceptual, no un catálogo de garantías. Ningún formato permite deducir automáticamente intención o autoría. La interpretación debe incluir la versión del controlador, las capacidades de la herramienta y la posibilidad de que las operaciones de aplicaciones o del propio sistema hayan producido el mismo patrón.

7.5. Metadatos y marcas temporales

7.5.1. Qué es un metadato y qué no demuestra

Los metadatos describen propiedades de objetos y operaciones: nombres, tamaños, identificadores, permisos, atributos, referencias, tiempos, propietarios, ubicaciones y relaciones con otras estructuras. Son evidencia técnica, pero no una narración autosuficiente de la intención humana. Un nombre de usuario en un campo no demuestra quién estaba físicamente ante el equipo; un tiempo de creación no demuestra cuándo se redactó por primera vez el contenido; una ruta no prueba que el archivo haya sido abierto.

La procedencia del metadato importa tanto como su valor. Un campo obtenido directamente de una estructura de sistema de archivos tiene una cadena interpretativa diferente de una fecha mostrada por un explorador, de un EXIF de fotografía o de un encabezado HTTP. Los cuatro pueden ser útiles, pero sus relojes, reglas de actualización y posibilidades de manipulación difieren.

7.5.2. MACB y otras convenciones temporales

En el análisis forense se utiliza con frecuencia la agrupación MACB: *Modified* (contenido modificado), *Accessed* (acceso), *Changed* (cambio de metadatos) y *Birth/Created* (creación). La correspondencia exacta con campos disponibles depende del sistema de archivos y de la herramienta. En sistemas Unix, `ctime` representa normalmente el cambio de estado del inodo, no la fecha de creación. En Windows, distintos atributos NTFS pueden exponer fechas con semánticas diferentes.

Las marcas de acceso son especialmente delicadas. Algunos sistemas reducen su actualización por rendimiento, utilizan `relatime` o `noatime`, o actualizan datos de forma diferida. La ausencia de cambio en una marca de acceso no demuestra que un archivo no haya sido leído. En sentido inverso, una actualización de acceso puede deberse a procesos automáticos, indexadores o antivirus, no necesariamente a una acción consciente del usuario investigado.

7.5.3. Tiempo almacenado, tiempo mostrado y zona horaria

Una marca temporal puede almacenarse en UTC, en tiempo local sin zona explícita, en una época propia o con una resolución limitada. La herramienta puede convertirla a la zona horaria del analista, del sistema de origen o de un parámetro configurado. Una línea temporal que mezcle valores sin normalización puede introducir desplazamientos de una o varias horas y alterar el orden aparente de los hechos.

El procedimiento reproducible conserva, siempre que sea posible, el valor original, su formato, la zona horaria asumida, la conversión y la precisión. En investigaciones que atraviesan cambios de horario de verano, una hora local puede ser ambigua o inexistente. La documentación debe identificar qué regla de zona horaria se utilizó y si existe incertidumbre.

Además del huso horario, importan la deriva del reloj, la sincronización NTP, los ajustes manuales, la suspensión del equipo y los relojes independientes de dispositivos periféricos. Una diferencia de dos minutos entre registros de un portátil y de un servidor puede ser relevante para correlacionar eventos; antes de interpretarla como secuencia causal, conviene estimar la desviación de cada reloj.

7.5.4. Precisión frente a exactitud

Un campo que muestra nanosegundos no implica que el evento se haya medido con exactitud de nanosegundos. La resolución del formato, la frecuencia de actualización del sistema,

el mecanismo de escritura y la precisión del reloj son cuestiones distintas. Una herramienta que imprime nueve cifras decimales puede dar apariencia de precisión que la fuente no posee.

La incertidumbre temporal debe expresarse cuando afecte a una conclusión. Es más riguroso afirmar que «el registro sitúa la modificación aproximadamente a las 14:07, según el reloj del sistema» que presentar un segundo exacto como prueba irrefutable si se desconoce la sincronización. Las líneas temporales pueden ordenar observaciones sin eliminar las incertidumbres de cada una.

7.5.5. Metadatos de aplicación y contenido

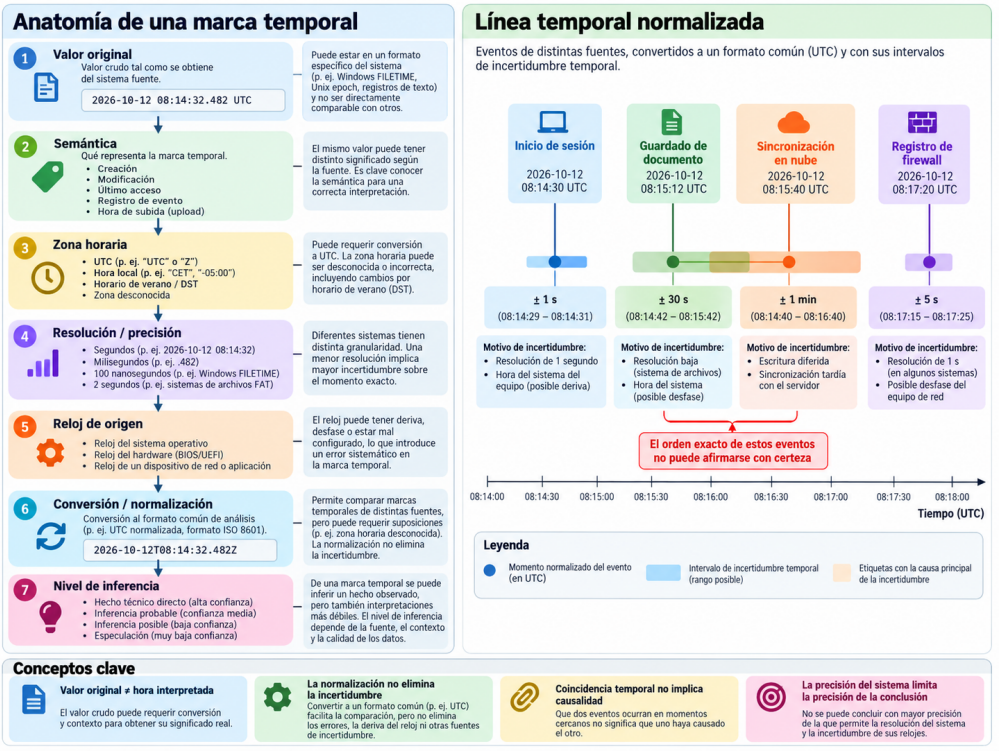
Los sistemas de archivos conviven con metadatos internos de documentos, fotografías, bases de datos y aplicaciones. Un documento de oficina puede incluir autor, fechas internas, revisiones o identificadores; una imagen puede contener EXIF; una base de datos puede registrar sus propios tiempos. Estos valores pueden ser más próximos al evento investigado o pueden estar más expuestos a edición. No debe privilegiarse uno sin estudiar cómo se genera.

La concordancia entre metadatos de distintas capas refuerza una hipótesis cuando las fuentes son realmente independientes. Si una herramienta genera dos informes a partir del mismo campo de la MFT, no se han obtenido dos corroboraciones independientes. La independencia se evalúa por el origen del dato, no por el número de programas que lo presentan.

7.5.6. Cronologías y eventos derivados

Una cronología forense combina observaciones de varias fuentes para contrastar hipótesis. Debe conservar la relación entre cada evento normalizado y el artefacto original, con ruta, identificador, offset cuando corresponda, herramienta y reglas de conversión. Los eventos derivados —por ejemplo, «posible copia a USB»— se deben marcar como interpretaciones y no mezclar visualmente con registros primarios.

Una línea temporal puede revelar secuencias, agrupaciones y lagunas. No demuestra por sí sola causalidad. Si una entrada de directorio se elimina poco después de una conexión USB, ello es compatible con varias explicaciones: copia y borrado, sincronización, limpieza automática, reorganización o coincidencia. La investigación debe formular predicciones que permitan distinguirlas.



![[

7.5.7. Ejemplo de matriz de interpretación temporal

Observación	Fuente	Qué permite afirmar	Qué no permite afirmar por sí sola
Fecha de modificación de contenido	Metadato de archivo	Valor registrado para esa propiedad	Autor o intención del cambio
Entrada de diario de cambio	Journal del sistema de archivos	Operación registrada dentro de su alcance	Historia completa del archivo
Archivo en carpeta de sincronización	Estructura local	Presencia en una ruta concreta	Que se haya descargado o abierto manualmente

Observación	Fuente	Qué permite afirmar	Qué no permite afirmar por sí sola
Marca de acceso	Metadato del sistema de archivos	Valor actual del campo	Que no hubo accesos no registrados
Versión histórica cloud	Servicio remoto	Existencia de una versión según el proveedor	Identidad física de quien actuó

La matriz no es una lista cerrada. Su utilidad consiste en obligar a separar observación e inferencia antes de redactar conclusiones.

7.5.8. Metadatos de archivo, de sistema y de aplicación

Una de las dificultades de construir líneas temporales es que distintas capas asignan significados distintos al verbo «crear». La marca de creación de un archivo puede describir la aparición de un registro en el sistema de archivos actual; la fecha de creación interna de un documento puede haberse conservado al copiarlo; una base de datos puede registrar cuándo una fila fue insertada; un servicio de sincronización puede informar de cuándo recibió una versión. Todas estas fechas podrían ser correctas, pero responden a preguntas diferentes. El analista debe identificar la entidad cuya historia cuenta cada marca.

También es relevante distinguir entre un metadato **almacenado** en una estructura y un metadato **derivado** o calculado por una herramienta. El tamaño visible de un archivo disperso puede ser superior al espacio efectivamente asignado. La fecha «más antigua» de una cronología puede proceder de una conversión de formato, de un campo sin inicializar o de un valor predeterminado. Un informe cuidadoso registra, para cada marca crítica, su ubicación original, formato, precisión, zona de referencia y mecanismo de interpretación.

Los formatos con varias fuentes temporales son especialmente propensos a discrepancias. Un archivo NTFS puede contener varios tiempos que representan operaciones diferentes; ext4 registra `mtime` y `ctime` con semánticas distintas; exFAT puede necesitar interpretar componentes de zona horaria; APFS puede ofrecer alta resolución, pero no por ello mayor exactitud. El investigador no debe normalizar eliminando el valor original: conserva primero la marca tal como se almacena y después añade su presentación estandarizada para la comparación.

7.5.9. Fijar una referencia temporal antes de ordenar los eventos

Para construir una línea temporal coherente es útil establecer UTC como escala de comparación, mientras se conservan en los registros las zonas y offsets originales. Esto no significa que todos los metadatos permitan una conversión inequívoca. Si una marca se almacenó en hora local sin zona y se desconoce dónde estaba configurado el sistema, convertirla a UTC requiere una hipótesis documentada. Esa incertidumbre debe permanecer visible en la cronología.

También deben considerarse el cambio estacional de hora, las configuraciones erróneas de reloj, las máquinas virtuales suspendidas, los registros recibidos con demora y las operaciones registradas por terceros. Un log puede contener la hora del evento observado, la hora de recepción y la hora de escritura definitiva. Un conjunto de eventos ordenados por una sola de esas marcas puede producir una secuencia engañosa si mezcla clases de tiempo diferentes.

Un ejemplo sencillo: el sistema A marca un acceso a las `09:58:30 UTC`; el sistema B registra la copia de un archivo a las `11:59:12` en hora local de Madrid durante horario de verano. Si B estaba efectivamente configurado en ese huso, la copia correspondería aproximadamente a `09:59:12 UTC`. Sin embargo, aún queda comprobar la sincronización de ambos relojes y que ambas marcas describen acciones comparables. La proximidad temporal ofrece una correlación posible, no demuestra causalidad.

Para evitar una precisión aparente excesiva se puede representar un evento como intervalo: entre `09:59:00` y `10:00:00 UTC`, por ejemplo, si la fuente solo conserva resolución de minuto o su reloj presenta un margen conocido. En ciertos casos lo correcto es conservar varios escenarios temporales alternativos. Un valor de fecha modificado por la aplicación o por una copia de archivos no se vuelve fiable simplemente por ser internamente consistente.

7.5.10. Una tabla de procedencia para marcas temporales

La siguiente tabla constituye un ejemplo ficticio de cómo registrar interpretaciones sin perder el origen:

ID	Fuente original	Campo y valor observado	Interpretación	Reserva
T-01	Entrada MFT	`$SI.mtime`	Modificación de datos según semántica NTFS	Puede conservarse tras algunas copias
T-02	Entrada MFT	`$FN`	Metadatos vinculados al nombre	No equivale a tiempo de intervención humana
T-03	Inodo ext4	`ctime`	Cambio de estado del inodo	**No** es creación
T-04	Archivo exFAT	Tiempo local y offset disponible	Fecha/hora de operación según formato	Revisar zona y resolución
T-05	Registro USN	Instante asociado a un cambio	Evento del diario	El diario puede ser incompleto
T-06	Documento OOXML	Propiedad interna	Fecha declarada por la aplicación	Editable y transportable con el fichero

La tabla debe ampliarse con el offset o identificador de artefacto y la herramienta que efectuó la decodificación. Mantener esa procedencia posibilita que otro analista vuelva a calcular la marca sin depender exclusivamente del CSV final. Cuando se fusionan millones de registros en una base de datos de cronología, esta relación con el origen es tan importante como los índices de búsqueda.

7.5.11. Manipulación intencionada y transformaciones inocentes

La alteración deliberada de tiempos —frecuentemente denominada *timestomping*— puede buscar que un archivo parezca anterior a su existencia o que una modificación quede fuera del período examinado. Sin embargo, una incongruencia temporal también puede ser consecuencia de copia, extracción desde un archivo comprimido, restauración de una copia de

seguridad, sincronización, migración de volumen o comportamiento del sistema operativo. La investigación necesita patrones corroborados, no reglas binarias.

Supongamos que un documento aparece con fecha de modificación de hace cuatro años, pero su registro MFT fue creado ayer. Una posibilidad es que se copiara ayer un archivo que ya existía; otra es que la fecha interna o del sistema de archivos fuese alterada. Si el registro USN y otros artefactos muestran creación reciente, no bastará para decidir entre ambas posibilidades. Habrá que examinar origen, rutas, contenido, registros de aplicación y operaciones de copia. La prudencia no impide concluir: obliga a explicar por qué se descartan alternativas antes de hacerlo.

La ausencia de cambios temporales también debe interpretarse con cuidado. Algunos accesos no actualizan `atime` por políticas de rendimiento; un objeto leído mediante ciertas interfaces puede no generar una marca de acceso útil. Afirmar «nadie abrió este archivo» porque no cambió el tiempo de acceso es una inferencia demasiado fuerte. En el sentido contrario, un tiempo de acceso reciente puede haberse generado por un servicio automático, un antivirus o un análisis forense ejecutado sin protección suficiente.

7.6. Análisis de archivos eliminados y espacio no asignado

7.6.1. Eliminar no siempre significa destruir

La eliminación lógica suele modificar referencias y estructuras de asignación antes que sobrescribir inmediatamente todos los bytes del contenido. Esto puede dejar restos recuperables, pero el mecanismo concreto varía por sistema de archivos, dispositivo y configuración. En SSD, las órdenes de descarte y los procesos internos pueden hacer que determinados bloques lógicos devuelvan ceros o datos no recuperables; no existe una regla universal sobre el instante en que desaparecen físicamente todos los restos.

En algunos casos, el archivo permanece en una papelera o mecanismo de versiones; en otros, se libera la entrada del sistema de archivos; en otros, se destruye una clave de cifrado y los bytes persisten sin ser descifrables. Estas situaciones no son equivalentes. Una investigación debe precisar qué tipo de eliminación se observó y qué representaciones se han examinado.

7.6.2. Espacio asignado, no asignado y slack

El espacio asignado corresponde a regiones que el sistema de archivos considera ocupadas por objetos o estructuras. El espacio no asignado comprende regiones que el sistema no vin-

cula actualmente a archivos activos, aunque puedan contener datos residuales. El *file slack* es el espacio dentro de la unidad de asignación final de un archivo que no forma parte de su tamaño lógico; su contenido depende del sistema, del modo de escritura y de la tecnología subyacente.

No debe confundirse el espacio no asignado dentro de un volumen con las regiones del disco que no pertenecen a ninguna partición. Tampoco debe confundirse un bloque que devuelve ceros con un bloque que nunca tuvo datos: puede haber sido limpiado, descartado, sobrescrito o sintetizado por una capa de almacenamiento. El investigador describe la observación antes de atribuir su origen.

7.6.3. Recuperación basada en metadatos

La recuperación por metadatos intenta reconstruir un archivo utilizando entradas de directorio, registros de archivo, inodos, extents u otras referencias conservadas. Su principal ventaja es que puede recuperar nombre, ruta, tamaño, marcas temporales y asignación de contenido. Su limitación es que estas referencias pueden estar incompletas, reutilizadas o desactualizadas.

El resultado debe comprobarse de manera independiente. Una herramienta puede reconstruir un archivo cuyo encabezado es válido, pero cuyo tramo central procede de bloques reutilizados. En archivos comprimidos, cifrados o con estructura interna, los errores pueden hacerse evidentes al validar el formato; en datos arbitrarios, pueden pasar inadvertidos. Deben registrarse las partes recuperadas, las ausentes y cualquier inferencia empleada para completar la secuencia.

7.6.4. File carving: recuperar sin estructura de directorio

El *carving* busca patrones y estructuras internas para localizar posibles archivos cuando los metadatos son insuficientes. Puede utilizar firmas de inicio y fin, longitudes, campos de formato y validaciones específicas. Es útil para imágenes, documentos y otros tipos reconocibles, pero no reconstruye automáticamente la ruta, el propietario, la fecha original ni el contexto de uso.

Los archivos fragmentados son un problema central. Si dos fragmentos no son contiguos y faltan referencias de asignación, el carving simple puede detenerse prematuramente, incorporar bytes ajenos o generar varios candidatos. Un archivo recuperado por firma debe identificarse como «objeto reconstruido a partir de una región» y no como «archivo original completo» salvo que existan pruebas suficientes de completitud.

La coincidencia de una firma tampoco garantiza que se trate de un archivo. Ciertas secuencias aparecen dentro de otros datos, en bloques comprimidos o en contenidos deliberadamente construidos. La validación del formato, la coherencia interna, el contexto y las posibles colisiones deben formar parte del procedimiento.

7.6.5. Restos de bases de datos, contenedores y archivos comprimidos

No todos los datos relevantes aparecen como archivos autónomos. Fragmentos de documentos pueden permanecer en bases de datos SQLite, páginas libres, diarios WAL, cachés, archivos de paginación, miniaturas, contenedores comprimidos o estructuras de aplicaciones. La recuperación de una cadena de texto no prueba que exista un documento íntegro ni que la cadena haya sido visible para el usuario.

Cuando el contenido procede de una base de datos, deben conservarse el archivo principal y sus archivos auxiliares pertinentes, además de documentar la forma en que se obtuvo una vista consistente. Abrir directamente una base de datos sobre evidencia mutable puede alterar su estado o incorporar transacciones pendientes. En el laboratorio se trabaja con copias, se registran las herramientas y se valida qué páginas o registros sustentan cada hallazgo.

7.6.6. Reutilización, sobrescritura y contaminación

La recuperación falla o se degrada cuando las estructuras o los datos han sido reutilizados. El montaje con escritura, el arranque de un sistema, las actualizaciones automáticas y las operaciones de reparación pueden introducir cambios adicionales. Por ello, una investigación no debe confundir un fracaso de recuperación con la inexistencia histórica de un archivo. La ausencia de resultado solo significa que no se recuperó mediante los métodos y fuentes examinados.

La contaminación también puede surgir de la propia herramienta: archivos temporales creados en el volumen equivocado, miniaturas generadas al explorar, índices automáticos, operaciones de reparación o cambios de zona horaria en los resultados. La protección de la evidencia y la separación entre maestro y copia de trabajo son requisitos prácticos para poder explicar y, cuando proceda, descartar estos efectos.

7.6.7. Búsqueda de particiones y sistemas de archivos anteriores

Cuando se reformatea o modifica una tabla de particiones, pueden quedar firmas de volúmenes anteriores. Las herramientas de búsqueda de particiones pueden detectar sectores

de arranque, superbloques o estructuras compatibles. Estos hallazgos son candidatos, no pruebas definitivas de que existiera un volumen íntegro con esos límites.

El investigador puede construir hipótesis de particionado histórico y contrastarlas con metadatos internos, tamaños, límites, copias de respaldo y coherencia de las estructuras. Debe evitar escribir una nueva tabla sobre el original para «ver si funciona». Cualquier reconstrucción se realiza sobre una copia de trabajo, con documentación de los supuestos y preservación de la imagen previa.

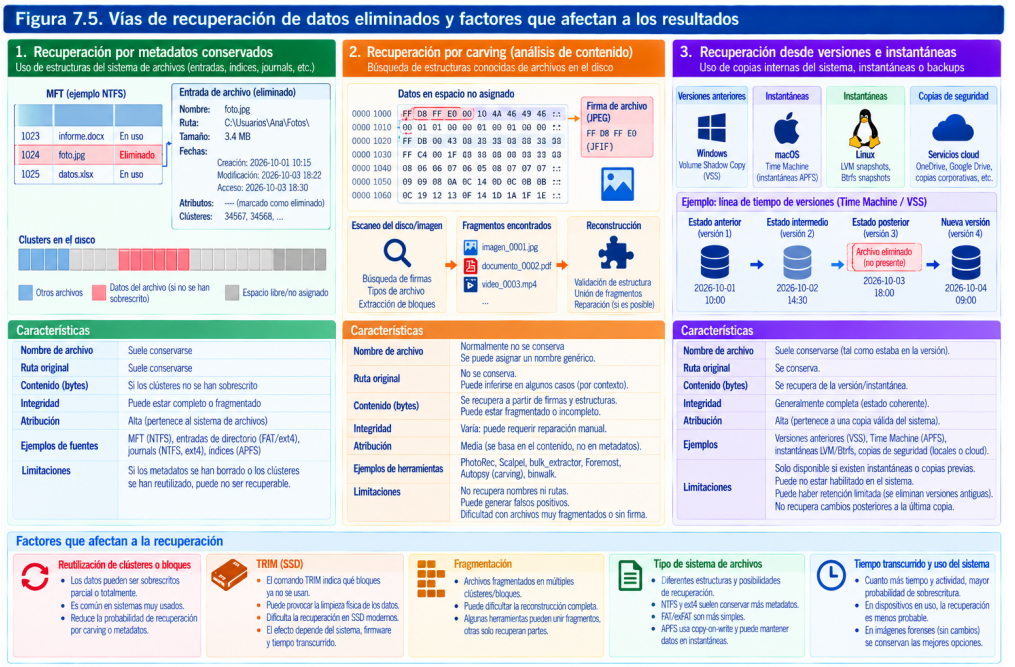


Figura 39: Métodos de recuperación de archivos eliminados

7.6.8. Ejemplo de examen controlado de una imagen

En un laboratorio con una imagen sintética se puede seguir un recorrido escalonado. Primero se verifica el hash de la imagen y se registra su procedencia. Después se identifica la tabla de particiones y el inicio del volumen. A continuación se inspeccionan los metadatos del sistema de archivos, se listan archivos activos y eliminados y, solo si procede, se realizan búsquedas de firmas en regiones definidas.

The Sleuth Kit permite ilustrar el proceso, ajustando siempre el offset al caso:

```
# Imagen de laboratorio; offset expresado en sectores de la imagen.
mmls disco-prueba.raw
fsstat -o 2048 disco-prueba.raw
fls -r -d -o 2048 disco-prueba.raw

# Ejemplo: extraer un objeto por su identificador de metadatos,
# solo después de verificar que corresponde al sistema de archivos.
icat -o 2048 disco-prueba.raw 128 > objeto-recuperado.bin
sha256sum objeto-recuperado.bin
```

El identificador `128` y el offset `2048` son ilustrativos; no deben reutilizarse sin inspeccionar la imagen real. La salida de `fls -d` identifica entradas que la herramienta considera eliminadas según las estructuras disponibles. No es una lista histórica exhaustiva de todos los archivos borrados. Un informe debe registrar la versión de TSK, el sistema de archivos detectado, los parámetros y cualquier advertencia.

7.6.9. Distinguir presencia, recuperación y atribución

Un resultado puede alcanzar distintos niveles de certeza. En el primero se localizan bytes compatibles con un formato. En el segundo se reconstruye un objeto con una estructura interna coherente. En el tercero se establece una relación plausible con un nombre o ubicación histórica. En el cuarto se correlaciona con eventos del sistema. Solo después, y con fuentes adicionales, puede plantearse una atribución a una cuenta, proceso o persona.

Los niveles no deben confundirse. Encontrar una miniatura de un documento no demuestra que el archivo original estuviera completo en el equipo. Recuperar una copia de un archivo en espacio no asignado no demuestra quién lo eliminó. Un registro de eliminación asociado a una cuenta no identifica necesariamente a la persona que controlaba la sesión. La fuerza del hallazgo depende de la cadena de inferencias y de las explicaciones alternativas descartadas.

7.6.10. El borrado desde la perspectiva del usuario y del sistema de archivos

Decir que un archivo «ha sido borrado» suele ocultar varios estados técnicos. Puede haberse eliminado una entrada de directorio, haberse reducido a cero su número de referencias, haberse marcado libres sus clústeres, haberse truncado su contenido, haberse movido a una papelera o haberse eliminado una versión sincronizada mientras otra subsiste. Un archivo renombrado o trasladado dentro de un mismo volumen puede desaparecer de su carpeta inicial sin que se liberen sus bloques. Si se trata de un directorio compartido, una modificación

de permisos puede hacer que un usuario deje de verlo sin que la estructura de almacenamiento haya cambiado.

La intervención forense necesita distinguir estas alternativas antes de iniciar una recuperación agresiva. Una búsqueda exhaustiva por firmas en espacio no asignado puede consumir tiempo y producir miles de objetos sin nombre, cuando el archivo sigue presente en otra ruta, en un enlace duro, en una instantánea o en una versión histórica del servicio. El objetivo no es recuperar el mayor número posible de objetos: es responder preguntas concretas con una metodología proporcionada.

La papelera del sistema o los mecanismos de retención de la aplicación pueden conservar metadatos sobre nombres y ubicaciones anteriores. No constituyen una prueba universal, porque pueden vaciarse, deshabilitarse o no intervenir en ciertas eliminaciones. Su ausencia tampoco implica una operación destinada a ocultar datos. Debe situarse cada mecanismo dentro del contexto técnico concreto del caso.

7.6.11. Recuperación por metadatos frente a recuperación por firmas

Una recuperación apoyada en metadatos conserva, cuando están disponibles, relaciones entre el objeto, sus bloques y la estructura del sistema de archivos. Es frecuente que esa información permita reconstruir objetos fragmentados y atribuirles con mayor fundamento una ruta. No obstante, cuando los metadatos han sido reutilizados, los enlaces antiguos pueden perder fiabilidad. En recuperación por firmas o *carving*, por su parte, el punto de partida suele ser una estructura interna de formato: cabecera, pie, longitud declarada, índices de objetos o patrones de contenido. Puede encontrar datos sin un sistema de archivos interpretable, pero suele ofrecer menos contexto de procedencia.

La calidad del resultado depende del formato. Un JPEG clásico posee marcadores reconocibles, pero un archivo fragmentado puede necesitar técnicas adicionales para localizar partes no contiguas. Un ZIP contiene estructuras internas que ayudan a validar el directorio y los miembros, pero puede estar incompleto y aun así permitir recuperar algunos elementos. Un PDF puede contener objetos, tablas de referencias cruzadas y revisiones incrementales; una cabecera y un cierre presentes no prueban que todas sus páginas o recursos sean coherentes. Las bases de datos SQLite pueden conservar páginas libres, espacio interno y archivos auxiliares WAL, cuyo análisis es diferente de extraer un archivo completo.

Cuando se recupera un fichero mediante firmas conviene realizar comprobaciones sucesivas: identificación de formato, congruencia del tamaño, posibilidad de abrirlo en un analizador no destructivo, validación de estructuras internas, presencia de errores y comparación con

otros fragmentos del mismo soporte. Un archivo que «se abre» no es necesariamente íntegro; un programa puede tolerar daños o rellenar bloques faltantes. El resultado puede clasificarse como íntegro estructuralmente, parcial legible, fragmentario o no validable, siempre especificando el criterio concreto empleado.

7.6.12. El espacio no asignado tiene historia, pero no cuenta toda la historia

El espacio no asignado corresponde a bloques que el sistema de archivos actual considera disponibles, pero puede contener bytes de objetos anteriores. También puede contener datos generados por otra partición en una configuración previa, bloques puestos a cero durante mantenimiento o representaciones especiales gestionadas por un SSD o un disco virtual. La expresión «espacio libre» describe el estado **lógico** de asignación en un momento determinado; no garantiza la presencia ni la ausencia de datos históricos recuperables.

El espacio residual (*slack*) tampoco debe confundirse con espacio no asignado del volumen. Puede aparecer como diferencia entre el final lógico de un archivo y el final de la unidad de asignación que lo contiene. El comportamiento efectivo depende del sistema de archivos, del controlador, de la técnica de escritura y de si los bytes residuales son expuestos por la interfaz adquirida. No toda región slack conserva información de otro archivo, ni su contenido tiene necesariamente el mismo significado en todos los formatos.

Un análisis eficaz puede dividir las regiones recuperadas según su relación conocida con la estructura original: bloques no asignados por el mapa actual, restos de una entrada de directorio, áreas de una partición antigua y extents de un archivo todavía asignado. La clasificación evita que un mismo conjunto de bytes se contabilice como «cinco documentos distintos» cuando varias herramientas lo han encontrado por métodos diferentes.

7.6.13. Fragmentación y falsos ensamblajes

El *file carving* de archivos fragmentados puede producir un problema particularmente delicado: combinar una cabecera genuina de un objeto con datos de otro que ocupaba bloques próximos. La salida puede abrirse y mostrar parte del contenido esperado, pero incluir errores o información ajena en otras secciones. Una herramienta que estima longitudes a partir de cabeceras o estructura interna puede reducir el riesgo sin eliminarlo. La reconstrucción debe documentar qué partes proceden de offsets conocidos y cuáles resultan de una estrategia heurística.

Para mostrar esta limitación puede diseñarse una práctica con un archivo de prueba de contenido conocido dividido en tres extents no contiguos. Una copia conserva sus metadatos;

otra elimina deliberadamente los enlaces de asignación en una imagen sintética. El análisis por metadatos puede reconstruirlo cuando las referencias sobreviven, mientras que un carving secuencial simple puede fallar. Las diferencias entre ambas salidas son materia de informe y de evaluación de herramientas.

No deben presentarse sectores contiguos como pertenecientes al mismo archivo únicamente por cercanía. La asignación depende del estado del sistema, el tamaño de archivos y el comportamiento del controlador. La verificación por hash contra una copia conocida es excelente cuando existe esa referencia, pero en un caso real el fichero original puede no estar disponible. En ese supuesto, la validación de estructura y la coherencia con fuentes independientes sustituyen a la comparación ideal, sin prometer equivalencia absoluta.

7.6.14. Riesgos durante el examen de archivos recuperados

Los objetos recuperados pueden estar malformados o haber sido creados con fines adversariales. Abrir automáticamente documentos, archivos comprimidos o ejecutables en una estación conectada a la red de gestión introduce un riesgo ajeno al objetivo probatorio. Es preferible realizar identificación e inspección con herramientas apropiadas en un entorno controlado, registrar sus versiones y escalar los objetos sospechosos a un laboratorio de análisis seguro.

También existe riesgo de contaminación documental. Si varias herramientas extraen el mismo objeto y le asignan un nombre distinto, el repositorio de resultados debe conservar identificadores y rutas de salida sin sobrescribir derivados anteriores. Si se decide recortar un fragmento o reparar la estructura de un archivo para leerlo, se crea una nueva versión derivada. El hash del derivado identifica el resultado de esa intervención; no debe presentarse como el hash de los bytes que había en la imagen original.

En un caso judicial o corporativo puede ser necesario minimizar la exposición de datos personales ajenos a los objetivos. Una recuperación masiva de material eliminado puede producir información íntima no relacionada con el incidente. La autorización, los filtros de alcance, los controles de acceso y las decisiones de descarte o retención tienen que aplicarse igualmente a los objetos recuperados. Que una herramienta sea técnicamente capaz de leer datos no implica autorización para utilizarlos con cualquier finalidad.

7.7. Recuperación y limitaciones de los resultados

7.7.1. Recuperación lógica y recuperación física especializada

La recuperación lógica utiliza las estructuras y los bloques que el dispositivo expone. La recuperación física especializada puede requerir intervenciones sobre electrónica, controladores o componentes del soporte y pertenece a un ámbito de mayor riesgo y especialización. No debe confundirse una técnica de laboratorio de recuperación de datos con un procedimiento forense validado para preservar todas las propiedades relevantes de la evidencia.

En un soporte dañado, cada intento de lectura puede modificar el estado o agravar la avería. El objetivo no siempre es maximizar inmediatamente la cantidad de bytes leídos: puede ser más importante obtener primero las regiones críticas para identificar el sistema de archivos, registrar errores y conservar oportunidades de lectura posteriores. La estrategia debe adaptarse al riesgo, la autorización y la capacidad técnica disponible.

7.7.2. Imágenes parciales y mapas de errores

Una imagen parcial puede ser valiosa si se documenta exactamente qué regiones se adquirieron y cuáles no. Deben conservarse el mapa de lectura, las áreas con errores, el orden de intentos, los parámetros y las decisiones de reintento. Si una herramienta rellena con ceros regiones ilegibles, el analista debe distinguir esos ceros sintéticos de los bytes realmente leídos de la fuente.

Un hash de una imagen parcial verifica los bytes de esa representación concreta. No convierte en completos los sectores ausentes ni demuestra que los ceros correspondan al soporte original. Los informes deberían cuantificar, cuando sea posible, sectores esperados, sectores leídos, sectores fallidos y áreas no intentadas.

7.7.3. Consistencia del sistema de archivos y reparación

Los sistemas de archivos pueden encontrarse en estado inconsistente por fallos, interrupciones o corrupción. Herramientas como `chkdsk`, `fsck` o utilidades de reparación de APFS pueden modificar estructuras. Ejecutarlas sobre la evidencia maestra sería incompatible con una preservación estricta salvo circunstancias excepcionales y debidamente justificadas. Si se necesita estudiar el efecto de una reparación, se realiza sobre una copia de trabajo claramente identificada y se conservan los estados anterior y posterior.

Una reparación que permite montar un volumen no demuestra que la estructura reparada sea idéntica a la que existía antes del incidente. La herramienta puede descartar entradas, reconstruir índices o modificar referencias. Los hallazgos obtenidos tras la reparación deben indicar esa dependencia y, cuando sea posible, contrastarse con la imagen previa.

7.7.4. Cifrado, compresión y deduplicación

El cifrado puede impedir interpretar contenido aunque la adquisición de bloques sea íntegra. La compresión puede dificultar el carving y hacer que un fragmento visible no se corresponda con un archivo completo. La deduplicación y los clones pueden permitir que varios objetos compartan contenido físico. En estos entornos, «mismo hash» demuestra igualdad de los bytes comparados, no identidad de procedencia ni de historia.

La recuperación de claves o el acceso a volúmenes descifrados exige autorización y procedimientos específicos. Un sistema abierto y autenticado puede ofrecer una oportunidad de adquirir datos lógicos que no existiría tras apagarlo; esa decisión debe equilibrarse con volatilidad, riesgo de alteración y alcance autorizado. La relación entre imagen cifrada y exportación descifrada debe quedar explícita en la documentación.

7.7.5. TRIM, FTL y expectativas realistas en SSD

Cuando el sistema operativo comunica que ciertos bloques lógicos ya no se necesitan, el SSD puede procesar la información mediante TRIM o mecanismos equivalentes. La respuesta de lectura posterior y la recuperación física dependen del dispositivo, firmware, configuración, tiempo y operaciones internas. Es incorrecto afirmar tanto que «un SSD conserva siempre lo eliminado hasta la sobrescritura» como que «TRIM borra siempre inmediatamente todos los datos».

La FTL, la nivelación de desgaste y la recolección de basura desacoplan el espacio lógico del físico. La adquisición ordinaria por interfaz obtiene lo que la controladora expone; no permite inferir con certeza qué páginas físicas residuales permanecen en chips de memoria. Una ausencia de datos recuperables debe describirse respecto de esa interfaz y del método empleado, no como una afirmación absoluta sobre el estado microscópico del dispositivo.

7.7.6. Validación de archivos recuperados

La validación de un objeto recuperado debe ir más allá de comprobar que una aplicación puede abrirlo. Puede incluir coherencia de cabeceras y estructura interna, tamaños decla-

rados, checksums propios del formato, comparación con versiones conocidas, extracción de metadatos, revisión de fragmentación y comprobación de que las regiones fuente no se solapan indebidamente con otros objetos reconstruidos.

En una investigación judicial o corporativa, también debe conservarse el procedimiento que permitió llegar al resultado: herramienta, versión, configuración, offsets, artefactos intermedios, mensajes de error y criterios de aceptación. Si dos herramientas discrepan, la discrepancia es un dato que debe investigarse; no debe ocultarse el resultado desfavorable ni escoger automáticamente el que confirma la hipótesis inicial.

7.7.7. Clasificación de resultados y comunicación de incertidumbre

Es útil distinguir al menos cuatro clases de resultado: objeto recuperado y validado; objeto parcialmente recuperado; fragmento compatible con un formato; y referencia de metadatos sin contenido recuperable. La clasificación debe acompañarse de una explicación de los criterios aplicados. La palabra «recuperado» sin matices puede sugerir una completitud que la evidencia no sostiene.

Las conclusiones negativas requieren especial prudencia. «No se encontraron archivos eliminados» puede ser engañoso si solo se analizó la MFT o se omitió espacio no asignado. Una formulación más precisa es «no se identificaron entradas eliminadas compatibles con los criterios de búsqueda en las estructuras examinadas» y debe especificar qué regiones y técnicas quedaron fuera.

Figura 40: Matriz de resultados y limitaciones de recuperación

7.7.8. Caso integrador: documentos desaparecidos y memoria USB

Una organización comunica que varios documentos de un repositorio local dejaron de aparecer el lunes por la mañana. Existe una sospecha de copia a un dispositivo USB, pero también se sabe que el equipo utiliza sincronización con un servicio remoto. El analista recibe una imagen de disco validada, una exportación de registros de conexión USB y una exportación limitada del servicio cloud. La pregunta inicial no es «¿quién robó los archivos?», sino qué ocurrió con cada objeto, qué fuentes permiten reconstruirlo y qué hipótesis alternativas siguen abiertas.

Fase de delimitación. Se comprueba el alcance autorizado: imagen de un portátil concreto, registros de su actividad y auditoría de un repositorio determinado. No se presupone autorización para acceder a cuentas personales ni para examinar todos los archivos ajenos al caso. Se registran hashes y características de cada adquisición y se identifica si el disco contiene cifrado, volúmenes adicionales o estructuras virtuales.

Fase estructural. La tabla GPT muestra una partición de sistema y un volumen de datos NTFS. La imagen contiene una MFT coherente y algunos registros no asignados. La presencia

de entradas borradas se documenta sin inferir todavía causa. Se comprueba que la interpretación de la tabla de particiones coincide con los límites del volumen y que las herramientas no presentan advertencias de lectura.

Fase de objetos. Se identifican tres nombres de documentos asociados a registros MFT no asignados. Uno conserva contenido íntegro según su estructura interna; otro presenta regiones reutilizadas y solo permite recuperar una parte; el tercero tiene referencias de metadatos, pero no contenido recuperable. Los tres resultados se describen por separado. No se agrupan bajo la etiqueta «tres documentos recuperados».

Fase temporal. El diario de cambios registra operaciones compatibles con renombrado y eliminación durante una ventana de diez minutos. La conexión de un dispositivo USB aparece en una ventana cercana, pero la correlación temporal no demuestra copia. La exportación cloud muestra que dos documentos fueron movidos a otra carpeta por una operación de sincronización. El tercero presenta una versión histórica conservada por el servicio. Los tiempos se normalizan con referencia a las zonas y relojes de cada fuente.

Contraste de hipótesis. La hipótesis de eliminación manual predice eventos de eliminación y, posiblemente, artefactos de interacción. La de movimiento predice cambios de ruta sin pérdida necesaria de contenido. La de sincronización predice operaciones coherentes en cliente y servidor. La de copia a USB predice presencia de contenido o artefactos de copia en el destino y registros de actividad compatibles. La de fallo de visualización predice que el objeto siga accesible aunque no aparezca en la interfaz inicial.

Los resultados apoyan de manera diferente estas hipótesis. Dos documentos se explican de forma plausible por un movimiento sincronizado; uno tiene una eliminación local registrada, pero no se identifica la causa con suficiente seguridad. La conexión USB constituye un hecho técnico independiente que justifica contrastes adicionales, no una prueba suficiente de exfiltración. El informe no debería atribuir intenciones ni personas sin otras fuentes.

Cierre del caso. Se entregan tablas de artefactos con identificadores, offsets o referencias de registros, hashes de los objetos recuperados, herramientas y versiones, y limitaciones. Se conserva una matriz que separa hechos observados, inferencias, hipótesis descartadas y cuestiones abiertas. La principal lección es que la desaparición de un nombre de archivo no equivale a desaparición del contenido, y que la recuperación técnica no resuelve automáticamente la atribución.

7.7.9. Protocolo resumido de revisión independiente

Antes de incorporar un resultado al informe, una segunda persona puede revisar: identificación y hash de la imagen de entrada; esquema de particiones y offsets; sistema de archivos

y versión de herramientas; relación entre registros y contenidos; método de recuperación; verificaciones de integridad; normalización de tiempos; explicaciones alternativas; y lenguaje utilizado para expresar incertidumbre. El objetivo no es repetir mecánicamente toda la investigación, sino identificar puntos en los que una interpretación errónea alteraría la conclusión.

Cuando la revisión descubre un error, se documenta la corrección sin eliminar resultados previos. Si un offset fue calculado con sector lógico incorrecto, deben conservarse la salida inicial, el diagnóstico, la nueva ejecución y la relación entre ambas. La trazabilidad de los errores forma parte de la calidad del laboratorio.

7.7.10. Qué significa una recuperación satisfactoria

El éxito de la recuperación debe definirse antes de comenzar y depender de la pregunta investigada. Para determinar si existió un documento puede bastar recuperar un fragmento identificable y corroborarlo con una referencia externa. Para probar el contenido íntegro de un contrato quizá sea necesario disponer de todas las páginas, validar sus firmas y distinguir versiones. Para relacionar una exportación con una memoria USB pueden ser decisivos los metadatos de una copia y los registros de conexión, aunque el archivo original ya no exista. No hay, por tanto, un porcentaje universal de recuperación que traduzca por sí solo la fuerza probatoria.

Resulta útil distinguir cuatro estados: **objeto completo y verificable**, cuando existe suficiente información para validar el contenido íntegro; **objeto parcialmente recuperado**, cuando algunas partes son legibles y otras faltan; **fragmento identificable**, cuando se reconocen bytes de interés sin poder reconstruir el conjunto; y **rastro indirecto**, cuando sobreviven referencias de nombre, tamaño o actividad, pero no los datos. La terminología debe acompañarse de explicaciones que indiquen los criterios usados y las limitaciones pendientes.

En ocasiones el resultado técnicamente más honesto consiste en demostrar que no puede establecerse algo. Un disco con regiones ilegibles, una exportación SaaS limitada por retención o un SSD cuyo controlador ha dejado de exponer bloques eliminados pueden impedir conocer el contenido anterior. El informe no debe convertir esa limitación en «no existieron archivos» ni en «el investigado los destruyó». Se puede expresar que no se ha obtenido evidencia suficiente para confirmar una hipótesis bajo el alcance y condiciones descritos.

7.7.11. Recuperar datos sin alterar la evidencia de referencia

Los procedimientos destinados a «arreglar» el sistema de archivos pueden modificar estructuras de asignación, crear directorios de recuperación, reconstruir diarios, actualizar cabeceras o truncar datos inconsistentes. Estas operaciones son potencialmente útiles en administración de sistemas, pero no deben ejecutarse sobre la evidencia maestra. El trabajo sobre una copia permite comparar los cambios introducidos con el estado previo y evita borrar la información precisamente necesaria para explicar qué ocurrió.

La misma regla se aplica a utilidades especializadas en discos dañados: el proceso de lectura puede necesitar múltiples pasadas y generar un mapa de bloques recuperados y fallidos. La existencia de una imagen parcial útil no autoriza a afirmar que se adquirió todo el origen. La documentación del mapa de errores y la diferenciación entre bytes auténticamente leídos, bytes desconocidos y patrones de relleno son parte del resultado, no simples detalles operativos.

Cuando dos métodos proporcionan recuperaciones diferentes de un mismo objeto, el investigador puede conservar ambas y evaluarlas. Una vía puede reconstruir mejor la estructura, otra recuperar bloques adicionales y una tercera generar falsos positivos. La elección de un derivado como representación de trabajo debe justificar por qué es el más apropiado para una pregunta concreta, sin eliminar las salidas que contradicen o matizan esa elección.

7.7.12. Caso complementario: ext4, instantánea y archivo de configuración

Consideremos una investigación ficticia de un servidor Linux cuya aplicación deja de funcionar después de un cambio no autorizado en su archivo de configuración. La copia de referencia incluye una imagen de un volumen ext4 y una instantánea virtual obtenida por separado. La pregunta inicial no es «¿quién manipuló el servidor?», sino «¿qué versión de configuración estaba disponible y qué evidencias existen de su cambio?».

El examen de ext4 permite identificar el inodo y los extents del archivo actual. La instantánea contiene una versión anterior con parámetros diferentes. Su comparación muestra dos estados del documento, no necesariamente todas las operaciones intermedias. Los metadatos de la instantánea permiten establecer cuándo se creó aquella representación, pero no prueban el momento en que se escribió cada byte del archivo. El registro del sistema, el historial de cambios de configuración y los mecanismos de despliegue podrían aportar eventos adicionales.

Si se descubre una referencia residual a un fichero temporal, el analista no debe concluir automáticamente que era una «copia de seguridad manual». Puede ser un archivo de reemplazo creado por un editor, un proceso de despliegue o una actualización transaccional. Se busca qué aplicaciones estaban activas y qué secuencia de escritura explica cada artefacto. Incluso una comparación binaria concluyente entre los dos estados del archivo no resuelve por sí sola la identidad de la persona o cuenta que originó el cambio.

La utilidad de este caso está en integrar tres niveles: bytes y extents, objetos de sistema de archivos, y actividad de administración. La evidencia se vuelve más sólida cuando los tres son coherentes, pero el informe debe señalar cuándo alguno de ellos falta. La frase «el archivo cambió entre las dos capturas» puede estar bien apoyada; «el administrador lo cambió a las 14:03» requerirá registros adicionales y una evaluación de alternativas.

7.7.13. Matriz final de suficiencia probatoria

Antes de cerrar una recuperación, puede revisarse cada afirmación del informe mediante una matriz que distinga su respaldo:

Afirmación propuesta	Evidencia mínima esperable	Comprobación adicional	Límite principal
«Se encontraron bytes de un PDF»	Offsets y bytes de cabecera o estructura	Validación de formato	Puede ser solo un fragmento
«Se reconstruyó un PDF»	Archivo derivado y trazabilidad de bloques	Validación estructural y de contenido	Puede estar incompleto
«El archivo estuvo en cierta ruta»	Metadatos o referencias de directorio	Contraste de identificadores y reutilización	Los metadatos pueden ser residuales
«La ruta dejó de existir»	Diferencia entre estados o registro de operación	Alternativas: mover, renombrar, permisos	No demuestra destrucción del contenido
«Se copió a una memoria USB»	Eventos compatibles en origen y destino	Hashes de contenidos, conexiones y tiempos	Coincidencia no identifica operador

Afirmación propuesta	Evidencia mínima esperable	Comprobación adicional	Límite principal
«Una persona ejecutó la operación»	Relación entre cuenta, sesión y acciones	Corroboración independiente	Credenciales compartidas o suplantadas

La matriz no prescribe un umbral jurídico universal; facilita examinar si los hallazgos técnicos sostienen exactamente la fuerza del lenguaje elegido. Si faltan datos para una afirmación, se rebaja su alcance o se convierte en hipótesis pendiente. Esta disciplina evita que los resultados del *carving*, las marcas temporales o los identificadores de partición se conviertan en declaraciones de autoría injustificadas.

El expediente de recuperación deberá conservar como mínimo la identificación de la imagen de origen, la herramienta y su versión, los comandos y parámetros, los offsets o identificadores de metadatos consultados, el método de reconstrucción, los errores relevantes, los hashes de los derivados y las revisiones realizadas. En investigaciones extensas, un manifiesto estructurado puede automatizar parte del registro sin sustituir el juicio profesional.

7.8. Conclusiones

El análisis de discos y sistemas de archivos exige separar el soporte de la representación adquirida, la partición del volumen, el objeto de sus nombres, el contenido de sus metadatos y la observación de la inferencia. MBR y GPT describen regiones, pero no garantizan el estado de los archivos. FAT, exFAT, NTFS, ext4 y APFS ofrecen artefactos distintos y exigen comprender sus mecanismos de asignación, actualización y borrado. Las marcas temporales son útiles cuando se conserva su semántica y se controlan las conversiones y desviaciones de reloj.

La recuperación de archivos eliminados es una posibilidad condicionada, no una promesa. La ausencia de resultados no demuestra que nunca existieran datos; la presencia de fragmentos no prueba que se haya reconstruido un archivo completo; y la coincidencia de hashes no identifica a la persona que produjo los bytes. La calidad del análisis se mide tanto por lo que puede demostrar como por la claridad con la que reconoce lo que permanece incierto.

En los capítulos siguientes, estas bases permitirán interpretar artefactos específicos de Windows, Linux y macOS sin perder de vista el soporte que los contiene y las limitaciones de cada representación forense.

7.9. Referencias técnicas y lecturas recomendadas

Las siguientes fuentes permiten ampliar y contrastar las estructuras y técnicas descritas. La documentación de implementación y los formatos evolucionan: antes de aplicar una técnica a un caso real debe verificarse la versión concreta de la herramienta y del sistema analizado.

1. Brian Carrier. *File System Forensic Analysis*. Addison-Wesley, 2005. Referencia de fundamentos y estructuras; comprobar cambios posteriores de formatos e implementaciones.
2. The Sleuth Kit. Documentación oficial y manuales de `mmls`, `fsstat`, `fls`, `icat` y demás utilidades: https://www.sleuthkit.org/sleuthkit/docs.php.
3. Microsoft. *[MS-FSCC]: File System Control Codes* y especificaciones relacionadas de sistemas de archivos: https://learn.microsoft.com/en-us/openspecs/windows_protocols/.
4. Microsoft. Documentación técnica de NTFS y referencias de archivos, atributos y registros de cambio: https://learn.microsoft.com/en-us/windows/win32/fileio/.
5. Microsoft. *exFAT File System Specification*: https://learn.microsoft.com/en-us/windows/win32/fileio/exfat-specification.
6. UEFI Forum. *UEFI Specification*, apartados relativos a GPT: https://uefi.org/specifications.
7. Linux Kernel Documentation. *ext4 Data Structures and Algorithms*: https://www.kernel.org/doc/html/latest/filesystems/ext4/index.html.
8. Apple Developer Documentation. *Apple File System Reference*: https://developer.apple.com/support/downloads/Apple-File-System-Reference.pdf.
9. NIST. *Guide to Integrating Forensic Techniques into Incident Response*, SP 800-86: https://csrc.nist.gov/pubs/sp/800/86/final.
10. NIST. *Computer Forensics Tool Testing (CFTT)*: https://www.nist.gov/itl/ssd/software-quality-group/computer-forensics-tool-testing-program-cftt.
11. GNU. *GNU ddrescue Manual*: https://www.gnu.org/software/ddrescue/manual/ddrescue_manual.html.
12. SWGDE. Publicaciones de buenas prácticas sobre adquisición, examen y validación: https://www.swgde.org/documents/.

8. Análisis forense de Windows

8.1. Introducción

Una estación de trabajo con Windows no cuenta su historia mediante un único registro. La actividad que interesa a una investigación queda repartida entre el sistema de archivos, el Registro, los eventos, las bases de datos de aplicaciones, las estructuras de compatibilidad, los perfiles de usuario y, cuando existen, los sistemas de supervisión y servicios externos. Cada fuente fue diseñada para resolver una necesidad operativa diferente. Prefetch intenta acelerar determinadas cargas; el Registro conserva configuraciones y estados; el diario USN facilita el seguimiento de cambios del volumen; los registros de seguridad permiten auditar determinadas operaciones si la configuración lo admite. Ninguna de esas piezas fue creada como un acta pericial perfecta.

Por eso, investigar Windows no consiste en localizar una ruta conocida y traducir automáticamente su contenido a una afirmación sobre el comportamiento humano. La presencia de una referencia a un ejecutable no siempre demuestra que se ejecutó; un evento de autenticación no identifica necesariamente a quien estaba frente al teclado; una memoria USB conectada no acredita por sí sola que se copiaron documentos; y una ausencia de logs no prueba que no ocurrió la actividad buscada. El trabajo profesional convierte indicios de distinta naturaleza en una reconstrucción temporal razonada, con contrastes independientes y límites explícitos.

El capítulo se centra en Windows 10 y Windows 11, con referencias aplicables también a determinadas versiones de Windows Server. Las ubicaciones de artefactos, su estructura y su significado pueden variar entre compilaciones, ediciones, configuraciones empresariales y productos de terceros. Una investigación debe registrar la versión concreta del sistema, el alcance de la adquisición y la versión de los analizadores antes de interpretar resultados. Los nombres de productos mencionados son ejemplos de capacidades, no una garantía de exactitud universal ni una clasificación comercial de herramientas.

La secuencia propuesta va desde el reconocimiento general de fuentes hasta un caso completo de investigación en una estación corporativa. Los procedimientos de consulta se ilustran con comandos orientados a imágenes y copias de trabajo, y se advierte expresamente cuando una operación sobre un Windows encendido podría alterar la escena. La preservación, la custodia, las autorizaciones y los hashes de adquisición se han tratado en los capítulos anteriores; aquí se emplean como condiciones de partida para analizar qué sucedió dentro del entorno Windows.

Figura 41: Mapa de las fuentes de evidencia de Windows

8.2. 1. Principales fuentes de evidencia

8.2.1. 1.1. Windows como ecosistema de artefactos, no como una fuente única

Un sistema Windows mantiene múltiples estados simultáneamente. El almacenamiento contiene archivos, bases de datos, secuencias alternativas y metadatos de NTFS. La memoria contiene procesos, sesiones, conexiones y datos transitorios. Los componentes de seguridad generan eventos si están activados y disponen de retención. Las aplicaciones dejan historiales, cachés, archivos temporales y referencias a documentos. Los servicios corporativos pueden conservar actividad que ya no aparece en el equipo local.

En una investigación por posible extracción de información, las preguntas suelen ser más concretas que «¿se robó información?». Conviene distinguir si una cuenta inició sesión, si una carpeta fue explorada, si un archivo estaba disponible, si se abrió o copió, si se conectó un dispositivo extraíble, si se produjo una subida a un servicio remoto y si la secuencia puede vincularse a un usuario o proceso determinado. Cada pregunta requiere evidencias

diferentes y tiene alternativas plausibles. El hecho de que todas esas preguntas se refieran al mismo equipo no las convierte en un único problema técnico.

Un inventario inicial de fuentes debe clasificar las fuentes por alcance y fiabilidad esperable:

Familia	Ejemplos	Pregunta que puede apoyar	Limitación frecuente
Sistema de archivos	`$MFT`, `$UsnJrnl`, `$LogFile`, directorios	Qué objetos o cambios han quedado representados	Retención, reutilización y semántica de metadatos
Registro del sistema	`SYSTEM`, `SOFTWARE`, `SAM`, `SECURITY`	Configuración, identidades, dispositivos, persistencia	Actualización diferida, control sets y versiones
Registro de usuario	`NTUSER.DAT`, `UsrClass.dat`	Preferencias, actividad de shell y referencias	No todos los valores equivalen a acción consciente
Eventos	`Security.evtx`, `System.evtx`, canales operativos	Autenticación, procesos, servicios y actividad auditada	Políticas, filtrado, rotación y eliminación
Ejecución	Prefetch, Amcache, Shimcache, BAM, UserAssist	Presencia o posible ejecución de programas	Cobertura y fuerza probatoria distintas
Actividad documental	LNK, Jump Lists, MRU, Office, navegadores	Acceso o referencia a recursos y documentos	Eventos automáticos y artefactos incompletos
Periféricos	USBSTOR, USB, `MountedDevices`, SetupAPI	Identificación y conexión de dispositivos	Conexión distinta de copia de archivos
Memoria	RAM, procesos, conexiones y objetos del kernel	Estado en el momento de captura	Alta volatilidad y posible alteración durante adquisición

Familia	Ejemplos	Pregunta que puede apoyar	Limitación frecuente
Telemetría adicional	Sysmon, EDR, proxy, DNS, identidad cloud	Contexto de procesos y comunicaciones	Puede no estar instalada o conservar todo

La tabla es un mapa para formular solicitudes y no un inventario fijo que deba aparecer en cada equipo. Una organización puede impedir Prefetch en algunos servidores, habilitar Sysmon solo en ciertos equipos, redirigir perfiles, bloquear USB o aplicar una política de retención de eventos de duración limitada. La ausencia de un elemento en una imagen debe describirse después de comprobar que el artefacto es aplicable y que la adquisición cubría su ubicación.

8.2.2. 1.2. Reconocimiento del sistema y versión examinada

Antes de convertir bytes en eventos, el analista necesita identificar la instalación: versión y compilación de Windows, arquitectura, idioma, zona horaria configurada, nombres de equipo y dominio, perfiles locales, unidades y posibles capas de cifrado. Los hives SOFTWARE y SYSTEM aportan parte de esta información, que puede contrastarse con directorios de sistema, registros de instalación, volúmenes y fuentes corporativas.

En un Windows disponible para una comprobación autorizada, los siguientes comandos ilustran qué datos se buscan. **Son consultas de un sistema de laboratorio; no se deben ejecutar por comodidad en el original si existe una adquisición suficiente.**

```
Get-ComputerInfo | Select-Object WindowsProductName, WindowsVersion,
 ↪  OsBuildNumber,
    OsArchitecture, CsName
Get-TimeZone
Get-CimInstance Win32_OperatingSystem |
    Select-Object Caption, Version, BuildNumber, LastBootUpTime
Get-Volume | Select-Object DriveLetter, FileSystem, FileSystemLabel,
 ↪  Size
```

La salida de `Get-ComputerInfo` depende del entorno y la versión de PowerShell, y ciertos campos de nombre comercial pueden no reflejar por sí solos la edición real, especialmente después de actualizaciones mayores. El número de compilación, las claves de producto y los metadatos de instalación deben correlacionarse en caso de discrepancia. Una imagen

tomada después de una actualización puede contener restos de la instalación anterior y perfiles migrados; esos vestigios no deben confundirse con el estado de producción en la fecha del incidente.

La zona horaria exige especial atención. Los eventos EVTX suelen incluir el instante UTC en su representación XML, pero las interfaces gráficas suelen convertirlo a la hora local del analista. Algunas bases de datos utilizan FILETIME, Unix epoch, WebKit timestamp o formatos propios. Una tabla forense debe preservar valor original, fuente, semántica, precisión, zona aplicada, corrección conocida del reloj y valor normalizado. No basta con pulsar «ordenar por fecha» en una herramienta que agrega orígenes heterogéneos.

8.2.3. 1.3. Sistema de archivos y artefactos de volumen

Windows suele emplear NTFS en volúmenes de sistema de uso general; determinadas unidades externas pueden usar exFAT u otros formatos. En NTFS, la Master File Table (`$MFT`) conserva registros de objetos con identificadores y atributos; el diario de cambios (`$Extend\$UsnJrnl`) registra determinadas operaciones y puede rotar; el archivo de transacciones (`$LogFile`) refleja actividad del sistema de archivos con finalidad de recuperación transaccional. No son tres copias de la misma historia.

Un registro de `$MFT` puede aportar nombres, referencias de directorio y marcas de tiempo, pero las entradas se reutilizan. Los números de registro y secuencia ayudan a distinguir instancias; un nombre aparentemente familiar no basta para concluir continuidad entre dos objetos. Los atributos `$STANDARD_INFORMATION` y `$FILE_NAME` contienen marcas temporales con semánticas distintas y actualizaciones que dependen de operaciones concretas. Una diferencia entre ambas no es, por sí sola, prueba de manipulación de fechas.

El diario USN registra razones de cambio como creación, eliminación o renombrado; no equivale a un diario exhaustivo de operaciones humanas ni permite reconstruir automáticamente el contenido anterior. Microsoft advierte que pueden combinarse diversas modificaciones en el mismo registro y que los registros antiguos pueden eliminarse. A su vez, `$LogFile` requiere analizar transacciones y compensaciones; no conviene utilizarlo para adjudicar acciones a una cuenta sin otras fuentes.

Las instantáneas de volumen (*Volume Shadow Copy Service*, VSS), si están disponibles y son recuperables, ofrecen estados anteriores de algunos archivos y metadatos. Su existencia no es obligatoria: puede haber equipos sin copias, instantáneas eliminadas o volúmenes excluidos. Comparar varios estados puede revelar que un objeto existió antes de una fecha, no

necesariamente la hora exacta de su creación o eliminación. Las instantáneas permiten ampliar la ventana retrospectiva, pero también introducen una dimensión temporal distinta de la captura actual.

8.2.4. 1.4. Qué significa que un registro no aparezca

Uno de los errores más costosos en un informe consiste en pasar de «no he encontrado» a «no existió». Un registro puede faltar porque no estaba habilitado, porque se borró, porque rotó, porque quedó fuera de la adquisición o porque la aplicación que lo generaba cambió de comportamiento. Las posibilidades son técnicamente diferentes. Antes de usar una ausencia como dato negativo debe determinarse si el mecanismo habría registrado ese hecho y si su cobertura era suficiente durante la ventana investigada.

Por ejemplo, si el equipo no tenía habilitada la auditoría de creación de procesos, la ausencia del evento de seguridad 4688 no descarta una ejecución. Si Prefetch está desactivado, no habrá archivos `.pf` nuevos que examinar. Si una ejecución se produjo dentro de un contenedor, una máquina virtual o por acceso remoto, su huella local puede ser diferente de la esperada. Un analista no debe extrapolar un comportamiento observado en una imagen de laboratorio a todas las compilaciones Windows sin comprobarlo.

Una formulación válida sería: «En el conjunto de registros Security adquirido, que cubre de forma comprobada del día 12 al 18, no se observó un evento 4688 referente al ejecutable; la política de auditoría disponible no permite confirmar que todos los lanzamientos se registraran». Esa frase delimita una búsqueda y evita convertir un resultado negativo débil en una prueba de inocencia o culpabilidad.

8.2.5. 1.5. Fuentes internas y externas: necesidad de corroboración

Un equipo unido a un dominio puede depender de Active Directory y registrar localmente algunos sucesos mientras los controladores de dominio conservan otros. Los accesos a Microsoft 365, servicios de almacenamiento y aplicaciones SaaS dejan eventos en el proveedor, no necesariamente en la estación. Una dirección IP, el nombre de un host y un identificador de sesión pueden unir esas fuentes, pero solo si las marcas temporales, las traducciones NAT, la retención y los identificadores se manejan correctamente.

La evidencia de red también puede explicar un suceso que los rastros locales no esclarecen. Una consulta DNS no acredita una descarga; una conexión TLS a una dirección remota puede ser insuficiente para identificar qué documento se transfirió; un registro de proxy puede

mostrar una petición sin demostrar que llegó a completarse. La mejor reconstrucción posible suele resultar del cruce de fuentes: disco y memoria para el estado del equipo, Registro y eventos para operaciones locales, y fuentes corporativas para autenticación y tránsito de información.

8.2.6. 1.6. Preparación de una recogida focalizada

Cuando el alcance requiere un triaje rápido, se priorizan artefactos según volatilidad, probabilidad de pérdida y relevancia, no por una lista universal. Los EVTX pueden rotar mientras la estación sigue operativa; las colas EDR pueden tener retención corta; las bases de datos de navegador pueden modificarse en segundos; las hives vivas necesitan técnicas coherentes de adquisición. Una recogida focalizada es útil cuando el tiempo es limitado, pero debe ser honesta respecto de todo aquello que deja fuera.

Una estructura de trabajo puede separar `originales/`, `adquisiciones/`, `derivados/`, `registros/` e `informes/`. Dentro del expediente, una tabla registra identificador, ruta dentro de la imagen, extracción realizada, herramienta y versión, hash del objeto extraído, responsable, hora y observaciones. La extracción de artefactos no transforma una copia selectiva en una imagen de disco completa; cada representación debe conservar su propia identidad.

Un conjunto mínimo destinado a investigar actividad local podría incluir los hives principales con sus logs transaccionales, los EVTX de los canales relevantes, Prefetch, Amcache, accesos recientes, Jump Lists, LNK, historia USB y metadatos de NTFS. Si se sospecha movimiento de información a la nube, los registros del proveedor y del proxy podrían tener mayor valor que algunos artefactos de ejecución. En todo caso, deben preservarse las condiciones de autorización: que algo sea técnicamente accesible no significa que esté incluido en el encargo.

8.2.7. 1.7. Tratamiento de datos sensibles en el análisis Windows

Las imágenes de Windows contienen información que puede ser irrelevante y especialmente sensible: correos, credenciales derivadas, historiales, comunicaciones privadas, datos sanitarios y claves utilizadas por aplicaciones. Incluso un simple volcado de logs puede incluir rutas con nombres personales, direcciones de correo y parámetros de línea de comandos. El laboratorio debe aplicar permisos por caso, cifrado, registro de accesos y minimización en las salidas, sin destruir datos que deban conservarse como evidencia.

No se recomienda incluir en el informe principal el contenido íntegro de un perfil si bastan referencias a identificadores y fragmentos relevantes. Cuando el análisis exige revisar un objeto privado, debe registrarse la finalidad y mantenerlo en anexos protegidos si corresponde. De igual modo, exportar de forma indiscriminada claves o contraseñas de un sistema intervenido no es una consecuencia necesaria de todo análisis forense; exige un alcance específico y justificado.

8.3. 2. Registro de Windows y perfiles de usuario

8.3.1. 2.1. Un sistema de configuración con valor probatorio indirecto

El Registro de Windows es una base de datos jerárquica utilizada por componentes del sistema y aplicaciones. Sus claves contienen valores de distintos tipos, subclaves y metadatos de modificación. En una investigación puede aportar información de usuarios, dispositivos, servicios, ejecución indirecta, instalaciones, preferencias, aplicaciones y actividad de la interfaz. Sin embargo, no es un diario universal en el que cada lectura o modificación quede registrada con autor y motivo.

Es imprescindible distinguir las raíces lógicas mostradas por el Editor del Registro de los archivos físicos que el analista adquiere. `HKEY_LOCAL_MACHINE` representa información de sistema; `HKEY_USERS` incorpora hives de usuarios cargados; `HKEY_CURRENT_USER` es una vista contextual del hive del usuario de la sesión que consulta. Si un analista examina HKCU en su propia estación, está viendo su contexto, no necesariamente el perfil investigado. La interpretación offline requiere relacionar cada archivo con su SID y ruta de origen.

8.3.2. 2.2. Hives del sistema y su localización

Entre los archivos relevantes se encuentran normalmente:

Hive	Ruta típica en Windows	Utilidad principal
SYSTEM	`C:\Windows\System32\config\SYSTEM`	Servicios, control sets, dispositivos y configuración de arranque
SOFTWARE	`C:\Windows\System32\config\SOFTWARE`	Productos, sistema operativo, instalaciones y configuración de software

Hive	Ruta típica en Windows	Utilidad principal
SAM	C:\Windows\System32\config\SAM	Cuentas y grupos locales, con información restringida
SECURITY	C:\Windows\System32\config\SECURITY	Política y datos de seguridad local protegidos
DEFAULT	C:\Windows\System32\config\DEFAULT	Configuración correspondiente al contexto predeterminado del sistema, no plantilla general de todos los usuarios
NTUSER.DAT	C:\Users\<usuario>\NTUSER.DAT	Configuración del perfil y preferencias asociadas a HKCU
UsrClass.dat	C:\Users\<usuario>\AppData\Local\Microsoft\Windows\UsrClass.dat	Configuración por usuario relacionada con clases y shell
Amcache.hve	C:\Windows\AppCompat\Programs\Amcache.hve	Inventario y compatibilidad de archivos y programas

La existencia y ubicación exactas deben comprobarse en el caso real. Un perfil puede residir en una unidad distinta, estar redirigido, ser temporal o haberse eliminado. Las claves de un dominio no equivalen a las cuentas locales del SAM; la consulta a un controlador de dominio puede ser indispensable para identificar una cuenta del entorno empresarial.

El hive original debe adquirirse junto con sus ficheros de transacción aplicables, como `.LOG1` y `.LOG2`, si existen. Una copia aislada puede reflejar un estado inconsistente si había escrituras pendientes. Los analizadores capaces de reproducir las transacciones pueden reconstruir un estado más coherente; esa operación debe documentarse como procesamiento sobre un derivado, sin presentar el resultado como bytes idénticos al hive base de la imagen.

8.3.3. 2.3. Control sets y configuración activa

El hive SYSTEM suele conservar diferentes conjuntos de control bajo claves `ControlSet00x`. La clave `Select` contiene referencias como `Current`, `Default` o `LastK-`

nownGood, según versión y configuración. `CurrentControlSet` es una vista dinámica del conjunto activo mientras Windows está ejecutándose; al analizar offline, esa vista puede no existir como clave física persistente. Un analizador serio debe resolver el control set correspondiente y mostrar cuál utilizó.

Esta distinción resulta importante al revisar `Services`, `Enum`, configuraciones de red y persistencia. Encontrar una entrada bajo un control set no demuestra que estaba activa al instante de interés. Tampoco debe eliminarse una diferencia como «duplicado»: puede reflejar configuraciones distintas para el arranque o la recuperación. La validez de la conclusión depende de identificar la instalación, la fecha de adquisición y el estado de arranque.

8.3.4. 2.4. Claves LastWrite y su significado

Muchas claves del Registro tienen una marca `LastWrite` que representa una modificación de esa clave, no necesariamente de un valor concreto y mucho menos el uso de la configuración. La semántica depende de lo que modifique Windows o la aplicación. Una clave asociada a un dispositivo con `LastWrite` reciente puede haber cambiado por detección, actualización de controlador u otra operación; no demuestra automáticamente una primera conexión.

En ciertos artefactos se usan valores FILETIME explícitos, estructuras binarias y cadenas que incluyen sus propios tiempos. No debe sustituirse el tiempo interno por el `LastWrite` de la clave sin justificarlo. Cuando la herramienta presenta una fecha derivada, el analista ha de conservar al menos el tipo de campo, la interpretación realizada y su normalización. Si la fecha es incompatible con el resto de la secuencia, se investiga el motivo antes de descartarla o presentarla como anomalía maliciosa.

8.3.5. 2.5. Identidades, SIDs y perfiles locales

En Windows, los SID identifican entidades de seguridad con mayor estabilidad que los nombres visibles. El nombre de una cuenta puede cambiar, mientras que el SID asociado sigue permitiendo relacionar su perfil y ciertos artefactos. Bajo `HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\ProfileList` suele encontrarse una correspondencia entre SIDs y rutas de perfiles. Se debe contrastar con cuentas locales o de dominio, servicios y sesiones, porque un perfil no prueba por sí solo presencia física ni uso exclusivo.

Si un perfil corresponde a una cuenta compartida, las referencias registradas dentro de él tienen atribución personal débil. Si la estación está gestionada por un sistema que ejecuta tareas bajo una cuenta de usuario, también pueden existir actividades automáticas. Por eso

conviene formular afirmaciones como «el artefacto se encuentra en el hive correspondiente al SID X» o «la tarea se ejecutó en un contexto asociado a esa cuenta», reservando la atribución personal para evidencias adicionales.

8.3.6. 2.6. Políticas de ejecución y claves de inicio automático

Las rutas de autoarranque incluyen ubicaciones conocidas como:

```
HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\RunOnce
HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\RunOnce
```

Las claves bajo HKLM afectan generalmente al contexto de sistema o a diversos usuarios, mientras que las de HKCU son específicas del perfil. Su existencia puede apoyar una hipótesis de persistencia, pero no determina por sí sola que un programa arrancara efectivamente. Es necesario comprobar ruta, existencia del archivo, permisos, restricciones, logs y actividad de ejecución. También hay persistencia fuera de estas rutas: servicios, tareas, WMI, extensiones de shell, carpetas Startup y otros mecanismos legítimos o abusados.

Un valor Run que apunta a `C:\Users\Public\Updater\agent.exe` merece examen por su contexto, no porque esa ruta pruebe malicia. Se investigan el binario, la firma, los hashes, la cadena de instalación, el usuario con permisos sobre el directorio y los eventos que indiquen su creación. Renombrar un ejecutable para que recuerde un componente del sistema es un comportamiento posible de un actor malicioso, pero también pueden existir herramientas internas mal documentadas.

8.3.7. 2.7. Configuración de red y conexiones conocidas

El Registro puede almacenar perfiles de red, parámetros de adaptadores, configuraciones TCP/IP y referencias históricas a redes utilizadas. Estas fuentes ayudan a ubicar un equipo en diferentes entornos, especialmente cuando se correlacionan con DHCP, VPN, Wi-Fi y logs de red. Los nombres de redes guardados no prueban que el equipo estuviera físicamente en un lugar determinado durante toda una franja temporal. El identificador de un punto de acceso o red corporativa también puede aparecer por importaciones de configuración y cambios de hardware.

La investigación de conexiones externas requiere más que un perfil de red: se revisan eventos de autenticación, logs de VPN, tablas y conexiones capturadas en memoria, DNS, proxy, firewall y EDR. Una sesión de red activa en la captura no siempre ha estado activa durante

todo el incidente; una entrada histórica puede haber expirado antes de adquirir la máquina.

8.3.8. 2.8. Actividad de shell en NTUSER.DAT y UsrClass.dat

El shell de Windows conserva numerosas preferencias y huellas de interacción. Entre las familias conocidas destacan `UserAssist`, `RecentDocs`, `RunMRU`, `TypedPaths`, `OpenSavePidlMRU`, `LastVisitedPidlMRU`, `ComDlg32` y `ShellBags`. Sus rutas precisas, representaciones y comportamiento varían entre generaciones del sistema. Algunas registran diálogos de apertura o guardado, otras referencias a programas lanzados desde Explorer y otras vistas de carpetas.

Una entrada en `RecentDocs` puede apoyar que un nombre de archivo fue relevante para un perfil, pero no acredita por sí sola que ese documento se leyera o que su contenido completo estuviera presente. Los diálogos comunes pueden registrar rutas seleccionadas aun cuando una operación se cancelara después. Las ShellBags permiten estudiar configuraciones de vistas de carpetas y pueden sobrevivir a la desaparición de una ruta, pero la fecha de una clave no debe transformarse sin análisis en «el usuario abrió esta carpeta en ese momento».

Para un estudio de movimiento de archivos, estos artefactos cobran valor al combinarse con Jump Lists, accesos recientes, historial de aplicación y NTFS. La fuerza de una reconstrucción no deriva de multiplicar capturas de la misma base de datos: diez herramientas que interpretan el mismo valor del Registro no equivalen a diez fuentes independientes.

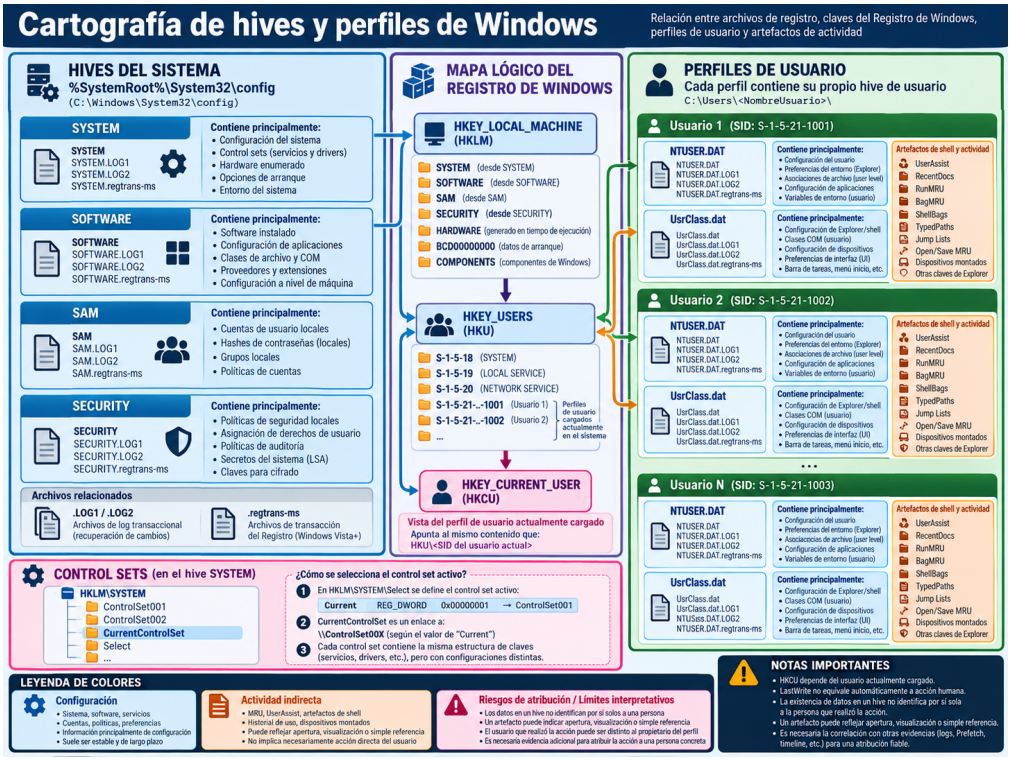


Figura 42: Hives del Registro y perfiles de usuario

8.3.9. 2.9. Extracción y comprobación offline de hives

El procesamiento de hives se realiza preferentemente sobre copias verificadas. Entre las herramientas utilizadas en laboratorios se encuentran Registry Explorer, RECmd, RegRipper y bibliotecas de análisis del Registro, siempre que sus versiones y módulos estén validados para la construcción de Windows investigada. El objetivo inicial no es ejecutar todos los complementos, sino seleccionar los que responden a las preguntas del caso.

Un procedimiento verificable suele seguir esta secuencia: registrar hash del hive y ficheros de transacción, identificar ruta de origen, confirmar el SID del usuario, indicar el módulo y versión de parser, comprobar que reconoce el formato, guardar salida estructurada y revisar manualmente un subconjunto representativo. Las advertencias del parser se conservan; una clave con estructura inesperada no debe desaparecer del informe sin una nota.

En entornos Windows de prueba, `reg query` puede mostrar determinadas claves sin editar sus valores:

```
reg query 'HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion' /v
 ↪ CurrentBuild
reg query 'HKLM\SOFTWARE\Microsoft\Windows
 ↪ NT\CurrentVersion\ProfileList' /s
reg query 'HKCU\Software\Microsoft\Windows\CurrentVersion\Run'
```

Estos comandos leen el estado vivo, no el estado previo de una imagen. Si se emplean durante respuesta a incidentes, deben registrarse hora, identidad, motivo y entorno. No reemplazan una adquisición formal de hives ni documentan todas las transacciones en curso.

8.3.10. 2.10. Restauración, copias previas y límites de RegBack

Las copias históricas del Registro, los puntos de restauración y las instantáneas pueden ofrecer estados distintos de una misma clave. Desde Windows 10 versión 1803, Microsoft dejó de crear por defecto determinadas copias automáticas del Registro en `RegBack`; que exista la carpeta no significa que contenga hives utilizables. En una investigación actual es necesario verificar realmente el tamaño, fecha, procedencia y consistencia de cada copia, sin presuponer que existe una copia de seguridad completa.

Comparar un valor entre dos estados puede demostrar que cambió entre ambos, pero no identificar el instante exacto de modificación ni a la persona responsable. Si un servicio está en una instantánea y ausente en otra, se investiga además cuándo se registró, si hubo actualización de software y cómo encajan los eventos del Service Control Manager. La comparación retrospectiva es más poderosa cuando se combina con registros de cambios del sistema de archivos y del sistema de despliegue corporativo.

8.3.11. 2.11. Valor del Registro en hipótesis rivales

Supongamos que una carpeta de un usuario contiene referencias recientes a una utilidad de sincronización. Hay varias explicaciones: instalación voluntaria, ejecución de un paquete corporativo, actualización automática, software que utilizó la biblioteca compartida o mera presencia residual de una instalación anterior. El Registro puede revelar claves de instalación, tareas o valores Run; Amcache aporta referencias a programas; los logs pueden mostrar una ejecución; y el proxy una conexión. Sin ese contraste, la conclusión «el usuario sincronizó documentos» es prematura.

Una buena práctica consiste en abrir una tabla de hipótesis antes de interpretar claves: *H1: instalación y uso autorizado; H2: ejecución manual no autorizada; H3: despliegue automático; H4: artefactos residuales de uso anterior*. Para cada una se identifican predicciones verificables. Por ejemplo, un despliegue corporativo debería tener registros de inventario o

distribución; una ejecución manual podría dejar UserAssist o Prefetch si las condiciones lo permiten. Una predicción incumplida debilita una hipótesis solo si la fuente era realmente observable.

8.4. 3. Registros de eventos y mecanismos de persistencia

8.4.1. 3.1. El modelo de eventos Windows

Los registros de eventos son una de las fuentes más utilizadas para reconstruir actividad en Windows porque pueden proporcionar identificadores, tiempos, proveedores y datos de contexto. Sin embargo, cada entrada representa lo que un componente emitió bajo una configuración concreta. La existencia de un evento no garantiza que el fenómeno investigado terminara con éxito y su ausencia no significa que nunca ocurriera.

Los registros modernos se almacenan habitualmente en formato EVTX, bajo `C:\Windows\System32\w` aunque pueden redirigirse, archivarse o exportarse. Los canales clásicos `System`, `Application` y `Security` conviven con numerosos canales de aplicaciones y servicios. Windows Event Log utiliza proveedores que publican eventos con identificador, versión, palabras clave, nivel y atributos. Dos eventos con el mismo número de identificación pero proveedores diferentes no tienen por qué significar lo mismo. Por tanto, una tabla pericial debe identificar **proveedor, canal, ID, versión y campos relevantes**.

El elemento `TimeCreated` de la representación XML proporciona un tiempo para ese evento, que debe normalizarse con su precisión y el estado del reloj de origen. Los campos `EventRecordID` permiten reconocer la posición relativa dentro de un canal, pero no son identificadores globales de acciones ni pruebas de integridad de toda la secuencia. Un fichero EVTX puede contener lagunas por rotación, configuración, pérdida de registros y otros factores. El análisis debe registrar el periodo temporal cubierto y cuándo empiezan y terminan las entradas disponibles.

8.4.2. 3.2. Política de auditoría: condición previa para interpretar ausencias

Windows admite políticas de auditoría básicas y avanzadas. La configuración determina qué se registra, con posibles diferencias entre éxitos y fallos. La política puede modificarse por GPO, MDM o administradores y no siempre coincide con la que estuvo vigente durante el incidente. Resulta útil adquirir evidencia histórica de políticas corporativas y cambios, en vez de limitarse a ejecutar una consulta sobre el estado actual.

En una estación de prueba, `auditpol` informa sobre ciertas subcategorías configuradas:

```
auditpol /get /category:*
Get-WinEvent -ListLog Security, System, Application |
    Select-Object LogName, RecordCount, MaximumSizeInBytes, LogMode
```

La salida solo describe la configuración observada, no prueba cómo estaba configurada el mes anterior. Algunos eventos dependen además de listas de control de auditoría del objeto (*SACL*) y de políticas específicas. En particular, el evento 4663 de acceso a objeto no debe esperarse para cualquier lectura de archivo: precisa condiciones de auditoría y atributos del objeto adecuados. Si el sistema solo registraba inicios de sesión, no se puede exigir que explique todas las aperturas de documentos.

Los logs pueden conservar datos personales o de seguridad, como nombres de cuenta, direcciones de equipos, parámetros y rutas. Su acceso ha de seguir el ámbito autorizado y sus exportaciones han de tratarse como evidencias derivadas; la copia desde un equipo en marcha es una intervención distinta de examinar el archivo EVTX ya adquirido en una imagen.

8.4.3. 3.3. Eventos de autenticación y sesiones

Los eventos del canal `Security` permiten examinar ciertos inicios de sesión y cambios de identidad. El ID 4624 registra la creación satisfactoria de una sesión de inicio de sesión en el equipo donde se generó; 4625 corresponde a un intento fallido. El tipo de inicio de sesión (*Logon Type*) es esencial para evitar confundir una sesión interactiva con una conexión de red:

ID o dato	Significado orientativo	Precaución de interpretación
4624 tipo 2	Inicio interactivo local	No prueba qué persona utilizó físicamente la sesión
4624 tipo 3	Acceso de red	Puede proceder de servicios y procesos automáticos
4624 tipo 5	Inicio por servicio	No equivale a un usuario sentado en el equipo
4624 tipo 7	Desbloqueo	Interpretar con cuenta, contexto y secuencia
4624 tipo 9	Credenciales nuevas	Identidad local y credenciales remotas pueden diferir

ID o dato	Significado orientativo	Precaución de interpretación
4624 tipo 10	Inicio remoto interactivo, como RDP	Requiere contrastar IP, host y registros del servicio
4624 tipo 11	Inicio interactivo con credenciales en caché	No supone autenticación online reciente del dominio
4625	Inicio fallido	No demuestra por sí solo un ataque de fuerza bruta
4634	Cierre de sesión de inicio de sesión	No siempre representa final de presencia física
4647	Cierre iniciado por usuario	No garantiza por sí solo que no quedaran procesos
4648	Intento de inicio usando credenciales explícitas	Examinar proceso y contexto de las credenciales
4672	Privilegios especiales asociados a una sesión	Puede ser normal en cuentas administrativas
4778/4779	Reconexión y desconexión de sesión de Terminal Services	Correlacionar con canales de RDP y host remoto

Un `Logon ID` ayuda a correlacionar sucesos de una misma sesión en un host, sujeto a sus límites temporales y al reinicio del sistema. El nombre visible de la cuenta no basta si la cuenta fue renombrada; conviene conservar el SID cuando esté disponible. La dirección de origen puede estar vacía o no ser concluyente, y un servidor de salto o una VPN pueden introducir varias direcciones diferentes. La reconstrucción de una sesión remota debe considerar registros del equipo destino, del cliente, del gateway y de autenticación corporativa.

Un caso ilustrativo: un 4624 tipo 10 aparece a las 02:10 UTC y, cinco minutos después, se instala un servicio. Ambos eventos en el mismo equipo no prueban automáticamente que la persona que inició RDP instalara el servicio. Se investiga si existe una sesión relevante, un proceso que creó la instalación, los tokens utilizados, el servicio remoto invocado y la posibilidad de que una administración automatizada haya efectuado la operación.

8.4.4. 3.4. Creación de procesos y acciones auditadas

El evento 4688 permite estudiar creación de procesos cuando la auditoría correspondiente está activada. Según política y versión, puede contener ruta, proceso creador, identificadores de seguridad y línea de comandos. La captura de parámetros de línea de comandos requiere configuración adecuada y debe considerarse su sensibilidad. El evento 4689, si está habilitado, puede aportar información de terminación de procesos.

No debe suponerse que todos los eventos 4688 contienen el mismo conjunto de campos. Las versiones del evento y los cambios de Windows determinan qué información está disponible. El analista ha de comprobar si los identificadores de proceso se han reutilizado, correlacionar con el tiempo y, si existe, utilizar también el `ProcessGuid` de Sysmon. Un PID aislado no identifica de forma persistente un proceso durante días ni entre reinicios.

En una revisión de eventos de un **laboratorio**, se puede filtrar una exportación cargada con PowerShell:

```
# Analizar una copia de eventos, no el canal vivo del original.
Get-WinEvent -Path '.\evidencia\Security.evtx' |
    Where-Object { $_.Id -in 4624, 4625, 4688, 4698, 1102 } |
    Select-Object TimeCreated, Id, ProviderName, RecordId, Message |
    Export-Csv '.\derivados\eventos-filtrados.csv' -NoTypeInformation
     ↪  -Encoding UTF8
```

Este ejemplo es ilustrativo y no constituye una extracción completa de campos. Filtrar a través de `Message` presenta problemas de localización, saltos de línea y plantillas de mensajes faltantes. Para análisis reproducibles conviene parsear el XML y los `EventData`/`UserData` por nombre de campo, respetando la versión del evento y el proveedor. Además, al procesar EVTX corruptos o incompletos es necesario conservar los errores que impidan extraer registros.

8.4.5. 3.5. Servicios como mecanismo de persistencia

El Service Control Manager administra servicios del sistema. Su configuración aparece en general dentro de `HKLM\SYSTEM\ControlSet00x\Services`; la creación de un servicio puede dejar el evento 7045 del proveedor Service Control Manager en `System`. Con auditoría correspondiente, el evento 4697 del canal `Security` también puede ser relevante. El registro de un servicio no acredita por sí solo que se iniciara, que su ejecutable funcionara correctamente ni que fuera malicioso.

El análisis se centra en nombre de servicio, tipo, ruta `ImagePath`, cuenta de ejecución, inicio automático o manual, dependencias y parámetros. Debe seguirse la ruta completa, no solo una coincidencia del nombre del archivo. Una ruta aparentemente legítima en `System32` puede apuntar a un binario legítimo o a otro alterado; una ruta en `ProgramData` puede corresponder a software corporativo. La validación se hace mediante hash, firma, historial de instalación, propiedad y eventos de ejecución.

En máquinas Windows, el comando `sc.exe qc` consulta un servicio determinado, y `Get-CimInstance Win32_Service` permite conocer configuraciones actuales:

```
Get-CimInstance Win32_Service |
    Select-Object Name, State, StartMode, StartName, PathName
sc.exe qc 'NombreDelServicioDePrueba'
```

Esta consulta sobre sistema encendido se reserva para laboratorios o intervenciones autorizadas. El estado en la fecha de consulta no demuestra cuál era su estado durante el incidente. En una imagen offline resulta preferible examinar SYSTEM, los eventos y la existencia del ejecutable, además de sus modificaciones temporales.

8.4.6. 3.6. Tareas programadas y su relación con el Registro

El Programador de tareas es un mecanismo legítimo de automatización y una vía habitual de persistencia. Las definiciones de tareas se encuentran normalmente bajo `C:\Windows\System32\Tasks\` y existen metadatos asociados en el Registro, en claves del servicio TaskCache. Pueden registrarse eventos en el canal `Microsoft-Windows-TaskScheduler/Operational` y, con políticas adecuadas, eventos de seguridad 4698, 4699 y 4702 para creación, eliminación y modificación. La existencia de una definición no significa ejecución real.

Una tarea debe analizarse como una relación entre **desencadenador, principal, acción, condiciones y estado**. Una acción puede lanzar un binario, un script, una tarea COM o una utilidad del sistema. Su nombre descriptivo puede ser inocuo aunque el comando sea relevante; también es frecuente encontrar tareas legítimas con nombres poco intuitivos. El registro de ejecución del Programador puede estar deshabilitado o incompleto y requiere contraste con procesos y accesos de archivo.

En un laboratorio, una consulta de solo lectura devuelve los campos de las tareas presentes:

```
Get-ScheduledTask |
    Select-Object TaskPath, TaskName, State
Get-ScheduledTaskInfo -TaskName 'TareaDePrueba'
```

`LastRunTime` es un dato operativo y no necesariamente una evidencia suficiente de quién disparó una tarea. Se necesitan eventos, procesos, logs de la aplicación y conocimiento de las condiciones programadas. Si la tarea pertenece a una configuración gestionada, puede haber sido recreada por GPO o agentes de administración sin intervención directa del usuario local.

8.4.7. 3.7. WMI, suscripciones permanentes y persistencia menos visible

Windows Management Instrumentation (WMI) permite automatizar acciones administrativas mediante consultas, filtros y consumidores de eventos. Algunas suscripciones permanentes pueden utilizarse legítimamente para operaciones de mantenimiento o abusarse para ejecutar código. La prueba no consiste solo en encontrar una clase o repositorio WMI, sino en identificar una relación funcional entre filtro, consumidor y vínculo, comprobar el comando o script ejecutable y buscar si se activó.

Sysmon, cuando está instalado y configurado para ello, puede generar los eventos 19, 20 y 21 sobre creación de filtros, consumidores y enlaces WMI. Su existencia aporta visibilidad, pero no convierte toda suscripción en actividad maliciosa ni cubre necesariamente instalaciones anteriores a la activación. La adquisición de la configuración y repositorios WMI deberá adaptarse al sistema y a la herramienta validada.

También existen mecanismos como carpetas de inicio, claves Winlogon y extensiones de ejecución, elementos COM, proveedores de servicios y políticas de inicio de sesión. Enumerarlos de forma indiscriminada genera ruido. Es más útil partir de una hipótesis: qué proceso se mantiene entre reinicios, con qué cuenta, por qué mecanismo, cuándo se estableció y qué registros confirmarían su activación.

8.4.8. 3.8. PowerShell y sus fuentes de registro

PowerShell forma parte de la administración ordinaria de Windows, por lo que su presencia no es indicio automático de intrusión. Puede ejecutar comandos interactivos, scripts firmados, tareas y herramientas de automatización. Su análisis exige diferenciar versión, host, política de registro y objetivo: la consola interactiva, un proceso de servicio y PowerShell 7 pueden registrar en canales distintos.

En Windows PowerShell 5.1, con *Script Block Logging* habilitado, los eventos 4104 se almacenan en `Microsoft-Windows-PowerShell/Operational`. PowerShell 7 puede utilizar el canal `PowerShellCore/Operational` con registro adecuado. La cobertura depende de las políticas y no debe afirmarse que todo comando ejecutado acabará necesaria-

mente en un único EVTX. Cuando hay registros de módulos, transcripciones o reenvío centralizado, constituyen fuentes adicionales; las transcripciones pueden almacenar datos confidenciales que deben protegerse.

La investigación puede necesitar reconstruir un script dividido en varios eventos, correlacionarlo con 4688 o Sysmon 1 y comprobar el resultado sobre el sistema de archivos. Un 4104 que contiene el texto de un comando no demuestra que se completara con éxito; la ejecución puede haber fallado o haberse cancelado. A la inversa, la ausencia de 4104 no descarta actividad PowerShell si la funcionalidad no estaba configurada o si los registros fueron eliminados.

8.4.9. 3.9. Sysmon como telemetría complementaria

Sysmon, de Microsoft Sysinternals, es una fuente adicional muy valiosa cuando se ha desplegado y se ha documentado su configuración. No forma parte de un conjunto uniforme de eventos disponible por defecto en todas las instalaciones Windows. Sus reglas pueden excluir o incluir eventos, y determinadas clases —como conexiones de red— pueden estar deshabilitadas según configuración. El documento de configuración y su historial son parte del contexto necesario para interpretar ausencias.

Algunos eventos frecuentes son:

ID de Sysmon	Tipo de actividad	Principal valor y limitación
1	Creación de proceso	Proceso, padre, comando y GUID; depende de configuración y retención
2	Cambio de fecha de creación de archivo	Aporta indicio de modificación temporal, no malicia automática
3	Conexión de red	Correlación proceso-red, si se habilitó
7	Carga de imagen	Detección de módulos, con volumen potencialmente alto
8	Hilo remoto	Señal técnica contextual, no prueba aislada de inyección

ID de Sysmon	Tipo de actividad	Principal valor y limitación
10	Acceso a proceso	Útil en secuencias sospechosas, con falsos positivos
11	Creación de archivo	Rastros de escritura, si cubiertos por filtros
12–14	Modificaciones de Registro	Creación, eliminación y cambios de valores según reglas
19–21	WMI	Registro de filtro, consumidor y enlace WMI
22	Consulta DNS	Contexto de resolución, sin acreditar transferencia
23/26	Borrado de archivo	Diferencia entre archivado y detección según tipo y configuración

No todos los eventos existen en todas las versiones; el esquema exacto debe comprobarse en la documentación de la versión desplegada. La presencia de un `ProcessGuid` ayuda a relacionar eventos con más estabilidad que el PID aislado, pero la correlación sigue exigiendo contexto de host y origen. El evento 3 registra determinada conexión, no su contenido; el 22 muestra resolución DNS, no visita completada; y el 11 puede referirse a actividad normal de aplicaciones.

8.4.10. 3.10. Microsoft Defender y EDR

Microsoft Defender Antivirus y las soluciones EDR pueden conservar alertas, detecciones, estados de cuarentena, cambios de configuración y actividad de procesos. Algunas fuentes residen en canales Windows, otras en sistemas centralizados con su propio periodo de retención. Si la investigación comenzó tras una alerta, conviene preservar tanto el mensaje original como la telemetría enriquecida, ya que las consolas pueden actualizar interpretaciones y agrupar eventos posteriores.

Una alerta de malware con un nombre de familia determinado no prueba la identidad de un archivo sin revisar el hash, la ruta y el motor de detección. Los antivirus pueden usar heurís-

ticas y denominaciones diferentes. Es importante distinguir detección, bloqueo, cuarentena, eliminación y reparación: cada una tiene consecuencias distintas sobre la evidencia. Si el EDR aisló el dispositivo, puede haber modificado rutas de red o ejecutado acciones que deben aparecer en la cronología de respuesta, separadas de la cronología del presunto incidente.

8.4.11. 3.11. Borrado de logs y manipulación de auditoría

El evento 1102 en el canal Security puede indicar que se borró el registro de auditoría de seguridad. Es relevante, pero no equivale automáticamente a una acción maliciosa. Se contrasta con mantenimiento, restablecimientos, políticas, rotación y registros centralizados. El evento 104 de determinados canales registra otras operaciones de limpieza, pero debe comprobarse su proveedor y ubicación antes de interpretar el número de evento.

Un atacante puede intentar modificar la política, detener servicios o borrar archivos, pero también hay procesos legítimos que alteran la observabilidad del sistema. La hipótesis de borrado deliberado requiere evidencias de proceso, usuario, método y temporalidad. Un salto en `EventRecordID`, por sí solo, exige examinar configuración, formato y circunstancias de adquisición; no debe describirse como prueba autosuficiente de eliminación intencionada.

8.4.12. 3.12. Procedimiento de reconstrucción de persistencia

La investigación de una posible persistencia comienza identificando el evento que hizo sospechar el problema: una alerta de EDR, un proceso inusual o un comportamiento posterior al reinicio. Después se busca el mecanismo que podría lanzar ese proceso —servicio, tarea, Run, WMI u otro—, se verifica la existencia y contenido del objeto referenciado y se contrasta la secuencia con fuentes de ejecución.

Una matriz de trabajo útil distingue observación de interpretación:

Evidencia	Observación verificable	Hipótesis apoyada	Qué falta comprobar
Servicio nuevo	Evento 7045 con ruta concreta	Se registró un servicio	Quién lo instaló y si se ejecutó
Clave Run	Valor en hive con ruta a ejecutable	Posible ejecución al iniciar sesión	Sesión, existencia y ejecución efectiva

Evidencia	Observación verificable	Hipótesis apoyada	Qué falta comprobar
Tarea programada	Archivo de tarea, TaskCache y evento 4698	Configuración de automatización	Triggers, comandos, autorizaciones, ejecución
Sysmon 1	Proceso y cadena de parentela registrados	Ejecución observada por Sysmon	Resultado, contexto y legitimidad
4104	Script block registrado	Procesamiento de bloque PowerShell	Efecto real y secuencia completa
Modificación de log	Evento de borrado o cambio de política	Reducción de visibilidad	Motivo, responsable y otras copias

No existe obligación de que todas las filas aparezcan en un caso. La finalidad es construir hipótesis verificables. Para una conclusión afirmativa de persistencia es útil demostrar que el mecanismo persistió y que podía volver a activar el proceso; afirmar que se usó durante un día concreto requiere además evidencia temporal adecuada.

Figura 43: Registros de eventos y mecanismos de persistencia

8.5. 4. Artefactos de ejecución: Prefetch, Amcache, Shimcache y otros

8.5.1. 4.1. La dificultad de probar que un programa se ejecutó

La pregunta «¿se ejecutó este archivo?» parece binaria, pero los artefactos Windows la responden con grados de evidencia distintos. Una referencia puede indicar presencia en disco; otra, intervención de una función del sistema que suele asociarse con ejecución; otra, un evento registrado explícitamente durante la creación de un proceso. Incluso cuando la ejecución está respaldada, todavía quedan por resolver el usuario, el resultado, la duración y la legitimidad de la acción.

El primer paso consiste en evitar que el nombre del artefacto determine la conclusión. Amcache no es simplemente «el historial de programas ejecutados». Shimcache, especialmente en Windows 10 y posteriores, puede representar presencia de archivos sin probar ejecución. Prefetch tiene un origen operativo orientado al rendimiento y no garantiza capturar todos los

procesos, sobre todo en sistemas y configuraciones diferentes. El registro explícito de procesos de Sysmon o Security puede ser más directo, pero también depende de una telemetría previa.

Se considera útil trabajar con una escala de afirmaciones: *un archivo estaba referenciado*; *el sistema conservó un artefacto compatible con su lanzamiento*; *una fuente de auditoría registró creación del proceso*; *el proceso realizó una operación posterior corroborada*. Cada nivel necesita su propia evidencia. Los indicios deben sumar contexto, no convertirse mediante un algoritmo simple en un «porcentaje de culpabilidad».

8.5.2. 4.2. Prefetch: finalidad, ubicación y contenido

Windows Prefetch está diseñado para apoyar determinadas optimizaciones de inicio y carga de aplicaciones. Sus archivos suelen encontrarse bajo `C:\Windows\Prefetch\` con extensión `.pf`. Pueden asociarse a un ejecutable y contener referencias a rutas de archivos utilizados durante el funcionamiento observado por el sistema, contador de ejecuciones y determinadas marcas temporales, según versión y formato. El nombre puede incorporar un hash de ruta o contexto cuyo significado debe interpretarse de acuerdo con la generación del sistema.

Un archivo `UTILIDAD.EXE-XXXXXXXX.pf` es una pista importante, pero un simple listado de nombres no agota el análisis. Es necesario examinar el formato binario con un parser compatible y contrastar nombre de ejecutable, ruta referida, contador, marcas temporales, volumen y archivos relacionados. Algunas versiones conservan varias últimas ejecuciones; el número y la semántica de esos campos dependen de la implementación, por lo que no es correcto prometer una lista completa de todos los lanzamientos.

La existencia de Prefetch puede aportar respaldo relativamente fuerte a que la aplicación fue ejecutada o cargada en condiciones que hicieron intervenir este mecanismo, pero su ausencia no excluye ejecución. La configuración de prefetching puede variar por edición y función del equipo, y los archivos rotan o se eliminan. Prefetch no debe utilizarse para deducir que una aplicación ejecutó una operación determinada solo porque aparezca en la lista de archivos referenciados: esas referencias pueden deberse a librerías, componentes o archivos abiertos por el programa con fines muy diversos.

Un ejemplo habitual consiste en hallar Prefetch de una herramienta de compresión y, al mismo tiempo, un archivo `.zip` creado en el escritorio. La combinación sustenta una hipótesis de preparación de un archivo comprimido, pero no acredita automáticamente que la herramienta generara *ese* ZIP. La inferencia se refuerza mediante logs de procesos, metadatos del

archivo, directorios temporales, lista de archivos recientes y, cuando existe, contenido de la línea de comandos.

8.5.3. 4.3. Versiones de Prefetch y problemas de interpretación

Los formatos de Prefetch evolucionan. En Windows modernos puede haber compresión de los archivos y cambios de estructura que requieren un parser actualizado. Un analizador antiguo puede producir fechas incorrectas, omitir campos o rechazar un archivo válido. Antes de trabajar con varios equipos es necesario identificar su versión de Windows y ejecutar pruebas representativas sobre artefactos de procedencia conocida.

Debe evitarse la conversión descuidada de marcas temporales. Algunas herramientas muestran hora local y otras UTC; el analista necesita saber si una columna expresa *último lanzamiento*, *una de las ejecuciones históricas* o *modificación del archivo Prefetch*. La fecha del propio `.pf` y las fechas internas del artefacto son objetos diferentes. En casos donde se sospecha timestomping, la discrepancia entre datos internos y metadatos externos puede resultar útil, pero debe contrastarse con el comportamiento legítimo del sistema.

El hash del nombre del archivo `.pf` no es un hash criptográfico de integridad del ejecutable. Es un elemento interno de identificación de contexto o ruta; su coincidencia no puede utilizarse como identificación pericial inequívoca del binario. Para conocer los bytes de un ejecutable, se necesita obtener y hashear el archivo correspondiente, además de comprobar si la ruta referida apuntaba entonces al mismo contenido que en el momento de adquisición.

8.5.4. 4.4. Amcache: inventario y compatibilidad de programas

`Amcache.hve` se almacena habitualmente en `C:\Windows\AppCompat\Programs\Amcache.hv`
Contiene información asociada al inventario y compatibilidad de aplicaciones, cuya organización ha cambiado con las versiones de Windows. Puede incluir rutas, nombres, tamaños, metadatos de programa, referencias de compilación y, en determinados tipos de registro, hashes o identificadores de archivos. El contenido depende de los procesos de inventario y de la actividad de Windows, no de una garantía de auditoría exhaustiva.

El principal error consiste en transformar «archivo listado en Amcache» en «archivo ejecutado por una persona». Amcache puede referenciar archivos observados por mecanismos de inventario o instalación, incluso sin una ejecución interactiva demostrada. El analista debe comprobar qué clase de entrada utiliza su parser, qué evento operativo pudo originarla y qué significado tienen sus tiempos. Un identificador o hash truncado no debe compararse con un SHA-256 completo ni describirse como equivalente.

Amcache es especialmente útil para hallar rastros de binarios que ya no están en la ruta original. También puede aportar un contexto de instalación: nombre de programa, editor, carpeta, relación con componentes y cambios de versión. Si se identifica un ejecutable ya eliminado, su contenido no siempre puede recuperarse a partir de Amcache. Una ruta y metadatos no equivalen a una copia del binario.

En una investigación sobre una utilidad sospechosa, se relaciona la entrada con Prefetch, LNK, UserAssist, registros de procesos, MFT, paquetes instalados y firmas. La concordancia de varias fuentes aumenta la confianza; si solo existe Amcache, la formulación prudente será que el sistema conservaba una referencia compatible con presencia o inventario del archivo, no una ejecución confirmada.

8.5.5. 4.5. Shimcache o AppCompatCache: lo que no debe inferirse

Shimcache, también denominado AppCompatCache, se relaciona con mecanismos de compatibilidad de aplicaciones y se conserva en el hive `SYSTEM`, en una ubicación que depende de la versión Windows. Sus entradas pueden reflejar rutas de ejecutables y metadatos temporales. El equipo de respuesta a incidentes de Microsoft ha señalado expresamente que **en Windows 10 y posteriores Shimcache no debe utilizarse por sí solo para demostrar ejecución**; se trata principalmente de un indicio de presencia o existencia.

La marca temporal asociada puede corresponder al último tiempo de modificación del archivo, no al momento en que fue visto por el mecanismo ni a una ejecución. Algunas versiones actualizan la representación persistida durante apagado o reinicio; una captura de disco durante una sesión activa puede no contener las referencias que aún estaban en memoria. La posición relativa de las entradas ofrece pistas limitadas y no debe convertirse en una cronología exacta de lanzamiento de aplicaciones.

Un ejemplo aclara el riesgo: una entrada para `C:\Temp\gestion.exe` presenta fecha anterior al supuesto incidente. No es legítimo concluir que `gestion.exe` se ejecutó ese día o que fue utilizado para copiar archivos. La fecha puede corresponder a modificación del binario, la entrada puede haberse generado por exploración de carpeta y el contenido del archivo pudo cambiar desde entonces. Solo con eventos de proceso, Prefetch u otras fuentes pertinentes se podrá fortalecer la hipótesis de ejecución.

La interpretación de Shimcache debe indicar en el informe la versión Windows y el parser usado, porque hay cambios de formato y comportamientos entre versiones. Una frase «Shimcache acredita que el programa se ejecutó» en un informe de Windows 11 sería metodológicamente cuestionable sin evidencia complementaria de ejecución.

8.5.6. 4.6. BAM, DAM y referencias por SID

Windows incorpora mecanismos de moderación de actividad en segundo plano, como BAM (*Background Activity Moderator*) y, según versión, DAM. Pueden conservar referencias a ejecutables asociadas a SIDs y tiempos internos. Sus ubicaciones habituales se encuentran bajo `SYSTEM\ControlSet00x\Services\bam\State\UserSettings\<SID>` y otras variantes dependientes de la versión. No debe suponerse que ambas existen o que conservan exactamente el mismo formato en todos los equipos.

Una entrada BAM puede ser un indicio útil de actividad de determinados programas, particularmente cuando se identifica su estructura en una compilación conocida. Sin embargo, su cobertura y retención son limitadas: procesos, rutas, condiciones y clases de ejecución pueden no ser observados. El tiempo registrado requiere interpretación específica y no se debe describir como instante universal e inequívoco de «última ejecución» sin verificar el comportamiento en la versión concreta.

La vinculación a un SID ayuda a establecer el contexto de cuenta, pero no resuelve la atribución a una persona. Una tarea, una sesión reutilizada o un servicio pueden actuar con credenciales de usuario. En el informe conviene distinguir «entrada bajo SID X» de «la persona X lanzó manualmente el programa».

8.5.7. 4.7. UserAssist y lanzamientos desde el shell

`UserAssist` suele localizarse dentro de `NTUSER.DAT` bajo rutas del tipo `Software\Microsoft\Windows\CurrentVersion\Explorer\UserAssist`. Sus valores pueden tener nombres codificados mediante ROT13 y estructuras binarias que contienen contadores y tiempos asociados a interacciones del shell. El comportamiento no equivale a un registro universal de cualquier proceso del equipo: refleja clases de uso observadas por Explorer y componentes relacionados.

Es posible encontrar referencias a aplicaciones abiertas desde la interfaz gráfica que no aparecen en otros mecanismos de ejecución. También hay accesos lanzados por scripts, servicios o aplicaciones que no quedan representados en UserAssist. Una entrada indica actividad compatible con la interacción del perfil con un elemento, pero no acredita que una persona determinada se sentara delante del equipo ni que utilizara todas las funciones de la aplicación.

En una investigación por posible uso de una herramienta de acceso remoto, la coexistencia de UserAssist con un 4688 y registros de conexión constituye un conjunto más robusto que cualquiera de los tres aislado. Si la ruta referida ya no existe, se puede buscar su historial en

`$MFT`, `$UsnJrnl` y archivos borrados, y comprobar si había versiones anteriores con otro nombre.

8.5.8. 4.8. Jump Lists y archivos LNK como artefactos de uso

Las Jump Lists proporcionan a Windows y a ciertas aplicaciones listas de elementos recientes o frecuentes. Sus archivos se almacenan normalmente bajo rutas de perfil como:

```
C:\Users\<usuario>\AppData\Roaming\Microsoft\Windows\Recent\AutomaticDestinations\
C:\Users\<usuario>\AppData\Roaming\Microsoft\Windows\Recent\CustomDestinations\
```

Pueden contener referencias a rutas, identificadores de volumen, tiempos y datos embebidos propios del formato. Los archivos `.lnk` se encuentran, entre otras ubicaciones, en `C:\Users\<usuario>\AppData\Roaming\Microsoft\Windows\Recent\`, además de directorios de accesos directos normales. Las ubicaciones y formatos no son idénticos en todas las versiones ni en todas las aplicaciones.

Un LNK puede mostrar que una aplicación o el shell generó una referencia a un objetivo, incluso si el objetivo ya no está disponible. Pero la creación de un LNK no garantiza una apertura efectiva ni que el usuario tuviera conocimiento del archivo. Los metadatos internos pueden ser una fotografía del objetivo en el momento de creación o actualización del vínculo, y no el estado actual del recurso.

Los identificadores de volumen, rutas de red y metadatos de enlace son útiles para relacionar documentos con soportes extraíbles. Esa relación debe contrastarse con la historia USB y la actividad de NTFS. Si un archivo LNK conserva una ruta `E:\Proyectos\balance.xlsx`, puede apoyar que el perfil interactuó con un objetivo ubicado en esa letra en algún momento; no demuestra que la unidad `E:` actual sea el mismo dispositivo ni que el contenido se copiara desde una carpeta concreta.

8.5.9. 4.9. SRUM y otras fuentes de actividad agregada

La base SRUM (*System Resource Usage Monitor*) puede conservar estadísticas de consumo de recursos o actividad de aplicaciones asociadas a determinados contextos. Está habitualmente en `C:\Windows\System32\sru\SRUDB.dat`. La base ESE requiere un parser compatible y, si existe una copia en uso, puede necesitar los archivos auxiliares adecuados para mantener coherencia. Las tablas y su significado han evolucionado entre versiones.

SRUM puede orientar sobre actividad de red o ejecución de aplicaciones por periodos agregados, pero no constituye un PCAP ni una lista completa de destinatarios y archivos transmitidos. Un volumen de tráfico asociado a un proceso no acredita qué documento se envió. La reconstrucción de una transferencia requiere endpoints, proxy, aplicación, historial de nube u otras fuentes que identifiquen contenido o transacciones.

La información de compatibilidad de programas, instaladores, cache de búsqueda, recientes de Office y navegadores puede enriquecer el análisis, pero no conviene llenar el informe de hallazgos inconexos. Si el objetivo es investigar el uso de un programa concreto, se priorizan las fuentes que aportan tiempo, identidad, contenido y resultado de su acción, respetando las limitaciones de cada una.

8.5.10. 4.10. Línea de tiempo de ejecución: ejemplo comentado

Consideremos una imagen de Windows en la que se localizan los siguientes datos sintéticos:

Hora UTC	Origen	Observación
08:11	MFT	Se crea una carpeta `C:\Users\Public\Transferencia`
08:13	Amcache	Existe una referencia a `archivador.exe`
08:14	Prefetch	Marca interna compatible con ejecución de `ARCHIVADOR.EXE`
08:14	Sysmon 1	Se registra un proceso `archivador.exe` con parámetros de compresión
08:15	NTFS	Aparece `lote_2026.zip` con tamaño determinado
08:19	Proxy	Se registra una petición POST a un servicio externo

Este conjunto permite reconstruir una secuencia de preparación de un archivo y actividad de red compatible con transferencia. La línea de comandos de Sysmon, si contiene rutas de entrada y salida, fortalece la asociación entre la aplicación y el ZIP. Pero todavía falta

comprobar el contenido real del ZIP, el éxito de la petición y la relación con el usuario. El registro de proxy puede mostrar una petición abortada o un cuerpo parcial; la fecha MFT no indica necesariamente finalización de escritura; el nombre de un archivo no identifica su contenido.

Para expresar el hallazgo con precisión, podría escribirse: «En la estación analizada, las fuentes de creación de proceso y de sistema de archivos son coherentes con la generación de un archivo comprimido durante la ventana 08:14–08:15 UTC. El registro de proxy muestra actividad posterior dirigida al servicio X, pero se requiere su respuesta y metadatos adicionales para confirmar si se transfirió el contenido íntegro». La narrativa es útil porque separa lo probado de lo pendiente.

8.5.11. 4.11. Tabla de fuerza interpretativa

Artefacto	Presencia de archivo	Ejecución de programa	Resultado de la acción	Identidad personal
Amcache	Puede apoyar	No prueba por sí solo	No	No
Shimcache en Windows moderno	Puede apoyar	No prueba por sí solo	No	No
Prefetch	Referencia vinculada a carga	Indicio habitual relevante, dependiente del sistema	No	No
BAM/UserAssist	Referencia vinculada a actividad o contexto	Indicio condicionado a cobertura	No	No
LNK/Jump Lists	Referencia a ruta u objeto	Puede apoyar actividad de aplicación/usuario	No necesariamente	No
Security 4688	Ruta de proceso registrada	Sí, si el evento y origen son válidos	No necesariamente	Contexto de cuenta, no persona

Artefacto	Presencia de archivo	Ejecución de programa	Resultado de la acción	Identidad personal
Sysmon 1	Archivo de proceso identificado	Creación de proceso observada	No necesaria-mente	Contexto técnico, no persona
Telemetría de aplica-ción/servidor	Según contenido	Según evento	Puede documentar operaciones específicas	Requiere atribución independiente

Las categorías no sustituyen el análisis de cada caso. En especial, los verbos *descargar*, *abrir*, *leer*, *copiar*, *comprimir* y *enviar* no son sinónimos. La investigación puede confirmar uno de ellos y carecer de evidencia sobre el siguiente. La calidad del informe depende de mantener estas diferencias incluso cuando los hallazgos parezcan encajar en una historia sencilla.

Figura 44: Comparación de artefactos de ejecución

8.6. 5. Actividad del usuario, archivos y dispositivos USB

8.6.1. 5.1. Del perfil a la actividad: atribución por capas

Una investigación de actividad de usuario busca relacionar objetos técnicos con sesiones, cuentas y acciones sin saltar directamente a la identidad de una persona. El perfil Windows proporciona rutas, claves de Registro y datos de aplicaciones asociados a una cuenta, pero una sesión puede ser utilizada por automatismos, administradores remotos, software de asistencia o terceros que poseen credenciales. La pregunta «¿qué hizo este usuario?» debe fragmentarse en preguntas observables: qué cuenta tenía sesión, qué aplicación generó artefactos, qué documentos estaban accesibles, qué dispositivo se conectó y qué transacciones externas se registraron.

En un portátil corporativo suele ser útil combinar cuatro perspectivas. La primera es el contexto de cuenta y sesión, mediante SIDs, eventos de inicio y configuración de perfiles. La segunda es la actividad del shell y de las aplicaciones, con LNK, Jump Lists y recientes. La tercera es el sistema de archivos, con MFT, USN y versiones. La cuarta son las fuentes externas, como almacenamiento cloud, proxy, VPN y registros de dispositivo. Cada una corrige límites de las demás: si una referencia de aplicación es ambigua, la actividad de NTFS puede aportar qué archivo existió y cuándo; si un tiempo MFT es incierto, el log de servidor puede situar una transacción.

8.6.2. 5.2. Archivos recientes y listas MRU

Windows y algunas aplicaciones mantienen listas de elementos usados recientemente, a menudo llamadas MRU (*Most Recently Used*). Estas listas son útiles para descubrir nombres y rutas que ya no se encuentran en el sistema de archivos, pero no son una biografía exacta del usuario. La aplicación puede agregar elementos al mostrar un diálogo, al importar un archivo, al abrir una vista previa o al ejecutar acciones en segundo plano.

Entre las claves relevantes están algunas variantes de `RecentDocs`, `ComDlg32\OpenSavePidlMRU` y `ComDlg32\LastVisitedPidlMRU`. La presencia, formato y semántica de esos valores dependen del Windows y de la aplicación. El parser debe explicar cómo tradujo estructuras binarias o codificadas. Un nombre hallado en MRU no demuestra que el contenido completo del archivo permanezca en el volumen ni que se generara en el host actual.

En un caso, `OpenSavePidlMRU` puede contener referencias a una carpeta de un recurso de red, mientras una Jump List alude al mismo documento y los eventos del servidor acreditan una descarga. El conjunto apunta a interacción con un documento, aunque las operaciones no necesariamente sean idénticas: el diálogo puede representar selección, la Jump List un

elemento frecuente y el log un acceso remoto. La hipótesis más sólida no nace de considerar esas señales intercambiables, sino de ordenar sus significados.

8.6.3. 5.3. Papelera y objetos eliminados

En NTFS, la Papelera de reciclaje utiliza normalmente un directorio `$Recycle.Bin` por volumen, con subdirectorios relacionados con SIDs de usuario. En versiones Windows modernas puede albergar pares de ficheros de información y contenido, conocidos por prefijos `$I` y `$R`, que aportan información como nombre o ruta original, tamaño y ciertos tiempos, dependiendo de la versión del formato. Debe validarse el contenido y su correspondencia; una entrada de Papelera es una fuente valiosa, pero no garantiza recuperar un archivo íntegro.

No todo borrado pasa por la Papelera. Las eliminaciones desde ciertas aplicaciones, unidades de red, APIs o procesos administrativos pueden comportarse de otra forma. Una Papelera vacía no prueba que no existieran archivos borrados, y una entrada de Papelera no identifica necesariamente la persona que pulsó «Eliminar». También pueden intervenir procesos de limpieza automatizada, aplicaciones de sincronización o herramientas de seguridad.

Un examen puede empezar con el inventario de entradas y su SID, contrastar las rutas originales con la MFT y correlacionar los tiempos con `$UsnJrnl`, historias de aplicación y eventos de sesión. Si un archivo aparece en la Papelera y en una instantánea antigua, las dos fuentes muestran estados diferentes; no deben confundirse los tiempos de eliminación, de adquisición y de creación de la instantánea.

8.6.4. 5.4. Archivos temporales y persistencia de contenido

Las aplicaciones de Office, navegadores, visores PDF, editores y programas de compresión pueden crear archivos temporales y de recuperación. Su localización depende de versión y configuración, y puede extenderse a `AppData`, carpetas temporales de usuario, cachés de paquetes o directorios establecidos por políticas. Algunas aplicaciones crean copias automáticas o bases de datos de recuperación; otras solo conservan referencias. En ambos casos, los restos pueden revelar contenido parcial, nombres o estados anteriores.

Los archivos temporales deben examinarse sin atribuirlos inmediatamente al usuario. Un editor puede crear archivos de bloqueo o autosalvado de manera automática; Windows puede almacenar miniaturas generadas por la interfaz; el indexador puede procesar documentos que el usuario no abrió manualmente. La proximidad temporal ayuda a construir contexto, pero no convierte un artefacto automático en una acción consciente.

Los flujos de datos alternativos de NTFS, como `Zone.Identifier`, pueden aportar información sobre la procedencia atribuida a determinados archivos descargados. La presencia de una marca de zona no acredita por sí sola que un navegador específico descargara el archivo: puede propagarse en determinados movimientos y extracciones, alterarse o no existir según configuración y mecanismo utilizado. La falta de esa marca tampoco excluye descarga desde Internet.

8.6.5. 5.5. Navegadores, clientes de sincronización y rutas cloud

En la estación Windows, los navegadores pueden aportar bases SQLite, cachés, metadatos de descargas, cookies y estado de sesiones. Sin embargo, el análisis detallado de navegadores y correo se desarrolla en un capítulo posterior. Aquí interesa su relación con la actividad local y con el movimiento documental: qué ruta de destino se consignó, qué nombre recibió un archivo, qué aplicación lo abrió y si existen registros externos de la transacción.

Los clientes de sincronización, como OneDrive u otros servicios empresariales, pueden mantener metadatos de disponibilidad local, estados de sincronización y referencias de archivos en la nube. Un archivo visible en Explorer no siempre conserva todo su contenido en disco: los mecanismos de archivos bajo demanda pueden representar elementos mediante marcadores o placeholders. La adquisición local puede contener únicamente metadatos y exigir una solicitud autorizada al proveedor para acceder al contenido o al historial de versiones.

Este hecho afecta especialmente a las conclusiones de extracción de datos. Que una carpeta sincronizada contenga archivos de un repositorio no demuestra que fueran descargados deliberadamente en el momento del incidente; pueden haberse sincronizado automáticamente mucho antes. Al contrario, un archivo inexistente localmente puede haber estado disponible en el servicio. Deben consultarse las políticas, los eventos de sincronización y, cuando estén dentro del alcance autorizado, los logs del proveedor.

8.6.6. 5.6. Dispositivos USB: varias identidades que no deben confundirse

Los dispositivos USB plantean una dificultad de identificación particular porque pueden tener identificadores de controlador, producto, instancia, número de serie, volumen y letra asignada que cambian o no son exclusivos. Dos dispositivos de la misma marca pueden presentar campos similares; un adaptador puede interponer su propio identificador; el mismo volumen puede recibir letras distintas en sesiones diferentes. El informe debe distinguir **dispositivo físico**, **instancia enumerada**, **volumen montado** y **letra de unidad**.

Windows conserva rastros de dispositivos en el hive SYSTEM, en rutas como Enum\USB y Enum\USBSTOR; según versión, otros componentes de almacenamiento pueden usar ubicaciones adicionales. Bajo MountedDevices puede haber correspondencias entre identificadores de volúmenes y letras. En hives de usuario, MountPoints2 puede aportar referencias relacionadas con volúmenes y recursos de red. La vinculación entre estas fuentes debe validarse por identificadores, tipos de dispositivo y tiempos, no solo por coincidencia de la letra E:.

C:\Windows\INF\setupapi.dev.log puede conservar información de instalación de dispositivos y controladores. Sus fechas suelen presentarse en un contexto local de Windows que requiere normalización; no deben mezclarse sin más con marcas UTC del Registro o EVTX. Un bloque de instalación es una evidencia de una operación de reconocimiento o instalación de dispositivo, no necesariamente de cada conexión posterior. La retención del log puede variar por actualizaciones y mantenimiento.

Los canales Kernel-PnP, DriverFrameworks-UserMode, Partition/Diagnostic y otros pueden aportar eventos útiles, pero su disponibilidad cambia según versión, configuración y retención. No es adecuado asegurar que un evento concreto aparece universalmente en Windows 10 y 11 sin verificar el proveedor y la compilación. Se busca una secuencia coherente que relacione detección, asignación de volumen, sesión de usuario y operaciones sobre archivos.

8.6.7. 5.7. ¿Qué prueba una conexión USB?

Una conexión puede demostrar que Windows enumeró cierto dispositivo en determinado contexto temporal, con una fuerza dependiente de las fuentes. No demuestra que el usuario abriera un archivo de la unidad, que copiara información, que lograra una transferencia completa ni que luego conectara ese soporte a otra máquina. La operación de copia tiene evidencia diferente: registros en origen y destino, modificación o creación de archivos, procesos de transferencia, tiempos, hashes y, si está disponible, telemetría de DLP o EDR.

Supongamos que USBSTOR identifica un dispositivo y que una Jump List contiene una referencia a F:\Clientes\contrato.pdf. Puede afirmarse que existen rastros compatibles con una unidad externa y una referencia a un documento en una ruta de esa letra. Para afirmar que el archivo fue copiado desde el equipo corporativo a esa unidad, sería importante disponer de una imagen de la unidad destino, encontrar el contenido y estudiar su procedencia y tiempos, o contar con registros de copia suficientemente específicos. Una igualdad de hash en ambos extremos fortalece la identidad del contenido, pero no determina quién operó la copia.

8.6.8. 5.8. Cruzar USB con NTFS y actividad de aplicaciones

El análisis de movimiento de archivos resulta más sólido cuando se identifican objetos de origen, operaciones de preparación y rastros de destino. Por ejemplo, si un archivo se leyó desde una carpeta corporativa, una aplicación de compresión creó un ZIP y se montó después un volumen USB, las relaciones temporales sugieren una hipótesis. Si además se recupera el mismo ZIP en el USB y se verifica su hash, aumenta la fuerza de la conclusión sobre presencia del contenido en ambos soportes. La identidad del operador sigue siendo una cuestión separada.

El tiempo de última modificación de un archivo en destino puede haberse conservado durante una copia. Una coincidencia de tiempos no revela necesariamente el instante en que se realizó la transferencia. En FAT o exFAT la granularidad y representación temporal difieren de NTFS; la zona horaria y los mecanismos de copia también pueden modificar los metadatos. Debe calcularse una ventana temporal a partir de fuentes con semánticas claras, no presentar una fecha aislada como hora inequívoca de salida de datos.

Los nombres iguales tampoco garantizan contenidos iguales; dos versiones de `presupuesto.xlsx` pueden representar documentos diferentes. Para comparar hay que calcular hashes de contenido sobre objetos completos y comparables y, cuando proceda, revisar estructuras internas, metadatos y versiones de los documentos. En formatos Office comprimidos internamente, una modificación pequeña puede cambiar el hash del archivo aunque el contenido visible apenas varíe.

8.6.9. 5.9. Actividad de impresión, capturas y medios alternativos

La extracción de información no necesita necesariamente USB o una conexión a la nube. Puede producirse mediante impresión, captura de pantalla, correo, redes compartidas, portapapeles, sincronización de teléfono u otros canales. Algunos entornos conservan colas de impresión, registros de servicios, configuraciones de impresoras y datos en servidores de impresión, si estaban habilitados. Otros no preservan evidencia suficiente de qué páginas se imprimieron. La ausencia de USB no descarta salida de información por otros mecanismos.

Cuando una empresa investiga una posible fuga, el alcance autorizado debe contemplar qué fuentes se solicitarán y qué intrusión en la privacidad implican. Puede ser más proporcionado examinar logs DLP y de proxy que registrar indiscriminadamente el contenido personal del perfil. El analista debe comunicar si una conclusión depende de una fuente no obtenida, como un servidor de impresión o el historial de un teléfono.

8.6.10. 5.10. Un ejemplo de confusión entre sincronización y copia manual

Consideremos una estación con OneDrive configurado para sincronizar una carpeta corporativa. Se encuentra un directorio con nombres idénticos a los de un repositorio compartido y varias marcas de modificación recientes. Sería un error concluir que el usuario «descargó esos documentos para llevárselos». La sincronización puede haber sido automática, las marcas temporales pueden proceder del servidor y algunas rutas pueden ser placeholders sin bytes completos.

Para contrastar la hipótesis de copia manual se comparan registros del cliente, eventos del proveedor, ejecución de herramientas, cambios del sistema de archivos y, si existe, actividad de red con contenido suficiente. También deben buscarse hipótesis alternativas: restauración del perfil, migración del equipo, rehidratación de archivos bajo demanda o intervención del departamento de TI. El análisis de Windows aporta señales, pero no reemplaza los registros del servicio cloud.

8.6.11. 5.11. Cronología de usuario: diferentes fuentes, diferentes certezas

Una cronología de actividad puede contener eventos de login, marcas de documentos recientes, conexión USB, procesos y operaciones de red. Para cada fila es necesario registrar fuente, campo original, interpretación, incertidumbre, diferencia horaria y relación con la hipótesis. Una línea que muestre «apertura de documento» a partir de una simple marca en RecentDocs es demasiado fuerte si el artefacto solo conserva una referencia.

Es recomendable utilizar verbos calibrados: *registró*, *referenció*, *se observó*, *es compatible con*, *se acreditó mediante*, *no se pudo determinar*. Estos verbos hacen visible el salto entre dato e inferencia. Una frase que suene menos espectacular puede ser mucho más útil en sede judicial o en una revisión corporativa porque expone qué hechos podrían reproducir o contradecir otros analistas.

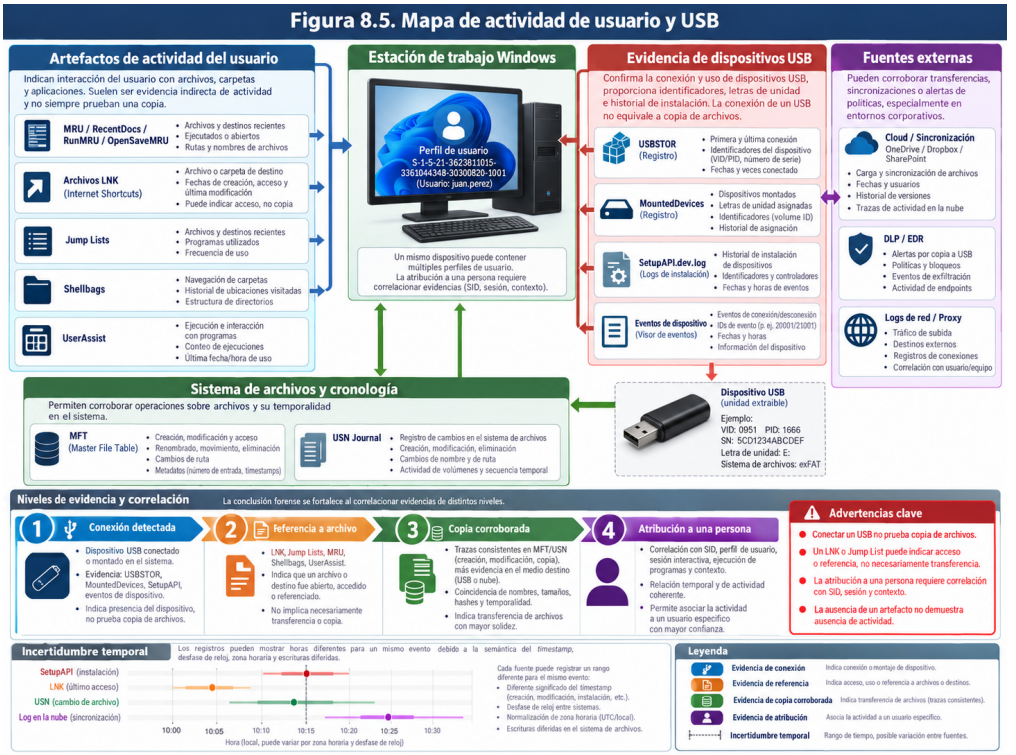


Figura 45: Actividad de usuario y dispositivos USB

8.6.12. 5.12. Guía de contraste antes de afirmar extracción de información

Antes de concluir que un archivo salió del equipo conviene responder, con evidencias identificadas, al menos a estas preguntas: ¿cuál es el objeto concreto y cómo se verificó su contenido?, ¿existe rastro de acceso o lectura?, ¿qué mecanismo pudo transferirlo?, ¿dónde aparece la copia o el registro de recepción?, ¿qué ventana temporal sustentan las fuentes?, ¿qué cuenta o proceso estuvo involucrado?, ¿qué explicaciones alternativas siguen abiertas? Si alguna pregunta no puede responderse, la conclusión se delimita al hecho realmente corroborado.

La existencia de una política de seguridad que prohíbe una operación es jurídicamente relevante, pero es distinta de la evidencia técnica de que esa operación ocurrió. Por ejemplo, el software DLP puede alertar sobre el intento de copiar archivos a USB sin demostrar que se completó la operación. Un evento de bloqueo es compatible precisamente con la ausencia de transferencia. Confundir intento y resultado puede llevar a conclusiones materialmente erróneas.

En una organización madura, los registros locales y corporativos se organizan para que esa cadena de preguntas tenga respuesta. Cuando faltan registros, debe recogerse la deficiencia como límite forense y posible recomendación de mejora de preparación forense, no como sustituto de la prueba de un incidente.

8.7. 6. Investigación práctica de un equipo Windows

8.7.1. 6.1. Planteamiento del caso: un archivo comprimido y una estación corporativa

El caso siguiente es ficticio y utiliza identificadores, tiempos y datos sintéticos. Se ha diseñado para demostrar un método de análisis y para poner a prueba hipótesis rivales, no para atribuir una conducta delictiva a ninguna persona real. La organización «NorteData» detecta en su estación `ND-WKS-17` una alerta de transferencia inusual. Durante la tarde del 12 de octubre de 2026, un equipo de seguridad identifica actividad de una herramienta de compresión, presencia de una unidad USB y una conexión HTTPS hacia un servicio externo. El responsable solicita esclarecer si se prepararon documentos corporativos, si llegaron a copiarse a un soporte extraíble y si hubo una transmisión completa a Internet.

El usuario habitual del puesto es una persona del departamento comercial. La máquina está unida al dominio corporativo y utiliza Windows 11, NTFS, BitLocker y una solución EDR. La compañía mantiene logs de identidad y proxy, y ha habilitado Sysmon con reglas parciales. La estación permanece encendida cuando se inicia la respuesta, pero el equipo de seguridad la aísla por red después de consultar la autorización. La intervención altera el estado operativo y puede eliminar sesiones: se documenta como acción de respuesta, no como evento anterior atribuible al investigado.

Las preguntas del encargo se formulan sin anticipar respuestas: ¿qué cuentas y procesos estuvieron activos?, ¿qué artefactos sostienen la existencia de un archivo `clientes_octubre.zip`?, ¿qué relación existe con la carpeta corporativa `D:\Clientes`?, ¿qué dispositivo USB estaba conectado?, ¿hay evidencia de que ese ZIP llegara al soporte?, ¿qué operación realizó la conexión HTTPS?, ¿existen explicaciones alternativas como sincronización automática o herramienta corporativa de respaldo?

El alcance incluye la estación Windows, los logs del proxy y del directorio durante el periodo definido y los registros del servicio de almacenamiento empresarial. No incluye inspección de cuentas privadas ni de dispositivos personales externos al encargo. Si aparece una pista que exige esos datos, el analista deberá formular una solicitud de ampliación; obtener credenciales de un navegador y probarlas sobre un servicio ajeno no es una prolongación automática de una investigación local.

8.7.2. 6.2. Evidencias adquiridas y objetos de trabajo

El equipo recibe una imagen de disco realizada mediante un procedimiento validado, una captura de memoria previa al aislamiento y exportaciones seleccionadas de logs centrales. La imagen se acompaña de registro de adquisición, verificación SHA-256 del flujo adquirido y cadena de custodia. La captura de memoria tiene otro identificador, su propio hash y sus propias limitaciones. La exportación del proxy constituye un tercer objeto: su integridad puede verificarse desde que se exporta, pero el hash no demuestra que el servicio hubiese conservado todos los eventos del periodo.

ID de evidencia	Objeto	Procedencia	Ejemplo de control
`EV-WIN-001`	Imagen forense de disco del equipo	Adquisición del volumen físico/lógico documentado	SHA-256 de imagen y registro de errores
`EV-MEM-002`	Volcado de RAM	Captura en vivo por operador autorizado	Hash propio, herramienta y hora
`EV-PXY-003`	Exportación de proxy	Equipo de redes, periodo autorizado	Hash de CSV/JSON, consulta y zona horaria
`EV-IDP-004`	Logs de identidad	Administrador del dominio o servicio	Solicitud, filtros, hash y retención
`EV-EDR-005`	Eventos exportados del EDR	Consola del proveedor	Versión de consulta y hora de extracción

Los objetos no se deben fusionar en una carpeta de trabajo con nombres genéricos `evidencia.zip`. Cada uno conserva su identificación y metadatos. Los derivados —CSV, JSON, SQLite, líneas de tiempo y gráficos— se registran con hashes y referencias al origen. Una copia de un archivo extraída de NTFS no tiene que poseer el mismo hash que el contenedor de imagen del que procede; se comparan los bytes del mismo objeto o representaciones equivalentes, según corresponda.

Se crea un expediente de análisis con permisos restringidos, copias de referencia y una carpeta de derivados. Se registran las versiones de las herramientas y el entorno de ejecución, así como la fecha del sistema analista y las conversiones horarias. Si una herramienta necesita montar un volumen NTFS, se realiza mediante un procedimiento de solo lectura validado

que no modifique el original; un montaje de Windows con operaciones de reparación automática no es aceptable sobre la evidencia maestra.

8.7.3. 6.3. Primer reconocimiento del sistema

El examen identifica una instalación Windows 11, compilación y edición documentadas, un volumen NTFS de sistema y otro de datos, tres perfiles locales relevantes y una configuración de zona horaria de Madrid. Este resultado se obtiene de hives, sistema de archivos y metadatos de volumen, no de una única etiqueta de una herramienta. La línea de tiempo de trabajo se mantiene en UTC y conserva un campo con la conversión a hora local, incluyendo el cambio de horario estacional aplicable.

La estación presenta una configuración Sysmon que registra creación de procesos, algunos eventos de archivo y determinadas conexiones de red. Se preserva el archivo de configuración disponible y se advierte que su contenido actual no demuestra por sí solo que estuviera vigente toda la semana anterior. El canal Security incluye eventos de inicio de sesión y creación de procesos, pero hay periodos con menor densidad de entradas. Se comprueba la cobertura real con los primeros y últimos registros y con los sucesos de política.

El perfil de interés se identifica con un SID concreto y una ruta bajo `C:\Users\usuario.comercial`. El SID se utiliza de forma consistente al leer `NTUSER.DAT`, Jump Lists y eventos, evitando interpretar las hives de otro perfil administrativo como si fueran del usuario habitual. El inventario de evidencias incluye asimismo un perfil de cuenta de servicio que puede haber ejecutado tareas de sincronización.

8.7.4. 6.4. Preservar antes de filtrar y analizar

El primer filtrado no debe destruir información del corpus de trabajo. Se mantienen todos los EVTX adquiridos, y una consulta inicial genera una tabla derivada con eventos relevantes. Para preservar reproducibilidad se registra el comando, la versión de PowerShell, el directorio de salida, la lista de ficheros procesados y cualquier excepción. El tratamiento de campos debe evitar depender de textos de mensajes localizados; los valores XML son preferibles en procesos automáticos.

Ejemplo de extracción estructurada de una **copia EVTX de laboratorio**, ejecutable en Windows con PowerShell y un fichero existente:

```
# Trabajar exclusivamente con copias adquiridas.
$origen = '.\evidencia\Security.evtx'
$destino = '.\derivados\Security-eventos.csv'
```

```
$ids = @(4624, 4625, 4648, 4672, 4688, 4698, 4702, 1102)

$filas = foreach ($ev in (Get-WinEvent -Path $origen -ErrorAction
 ↪  Stop)) {
    if ($ev.Id -notin $ids) { continue }
    $xml = [xml]$ev.ToXml()
    $campos = @{}
    foreach ($dato in $xml.Event.EventData.Data) {
        $nombre = [string]$dato.Name
        if ($nombre) { $campos[$nombre] = [string]$dato.'#text' }
    }
    [pscustomobject]@{
        TiempoUTC    = $ev.TimeCreated.ToUniversalTime().ToString('o')
        Evento       = $ev.Id
        Proveedor    = $ev.ProviderName
        RegistroID   = $ev.RecordId
        Cuenta       = $campos['TargetUserName']
        LogonId      = $campos['TargetLogonId']
        Proceso      = $campos['NewProcessName']
        ProcesoPadre = $campos['ParentProcessName']
    }
}
$filas | Export-Csv -Path $destino -NoTypeInformation -Encoding UTF8
Get-FileHash -Algorithm SHA256 -Path $destino
```

El código es orientativo y **no es un parser universal**. Los nombres de campos varían entre ID y versión; el evento 4688, por ejemplo, no usa necesariamente la misma clave de usuario que un 4624, y el XML puede carecer de elementos que se consultan. El ejemplo mantiene vacíos en lugar de fabricar valores. En un análisis real se utiliza una tabla de mapeo por proveedor, evento y versión y se revisan las salidas con muestras representativas. El script tampoco procesa todos los canales ni conserva por sí solo los XML íntegros, que permanecen en el EVTX original.

Si no hay eventos 4688 relevantes pero la política no garantizaba auditoría de creación de procesos durante la ventana, la ausencia se registra como inconclusa. Si aparece un 1102, se examina su contexto; no se presupone intención dolosa. Si los eventos centrales siguen presentes mientras los locales han rotado, se preserva la diferencia temporal y de procedencia.

8.7.5. 6.5. Localización de rastros de ejecución

El análisis del volumen encuentra referencias a `C:\ProgramData\NorteData\Tools\pack.exe`, una utilidad interna de compresión. En Amcache aparece un registro compatible con inventario o presencia. En Prefetch se obtiene una marca interna cercana al intervalo investigado. Finalmente, el EDR y Sysmon registran la creación de un proceso con ruta, parámetros y parentela suficientemente claros para sostener que el programa se ejecutó. La prueba de ejecución procede principalmente de estos eventos explícitos, no de sumar dos artefactos débiles.

El proceso observado recibió parámetros compatibles con creación de un ZIP desde una carpeta de trabajo. La ruta del ejecutable coincide con una herramienta utilizada por TI, pero esa coincidencia no resuelve si la operación formaba parte de una tarea legítima. Se consulta el inventario de software autorizado, la firma digital, el hash de los bytes adquiridos y el registro del despliegue corporativo. Se descubre que la herramienta es legítima, aunque la ejecución registrada no coincide con una tarea automatizada conocida.

En un informe preliminar se evita el titular «malware usado para robar archivos». La observación correcta es que una herramienta legítima fue ejecutada en un contexto que requiere aclaración. Esta distinción es esencial: herramientas de compresión, copia y administración tienen usos lícitos y abusivos. La atribución de una finalidad depende de datos adicionales, como parámetros, contenido del ZIP, destino y contexto organizativo.

8.7.6. 6.6. Investigación del archivo comprimido

En la imagen NTFS se encuentra `D:\Trabajo\clientes_octubre.zip`. Su contenido se extrae desde la copia forense y se calcula SHA-256 sobre los bytes del archivo reconstruido. Se comprueba que el contenedor ZIP se puede abrir íntegramente con una herramienta validada y que contiene documentos cuyas rutas corresponden al proyecto corporativo. Se conserva el contenido completo bajo acceso restringido; para el informe general basta con una lista autorizada de identificadores y hashes, sin divulgar datos comerciales innecesarios.

La MFT conserva marcas de creación y modificación; el diario USN aporta registros compatibles con creación o modificación durante la ventana. Un evento Sysmon 11, si estaba cubierto por la configuración, refuerza que se creó el archivo. Ninguno de esos datos implica necesariamente que toda la secuencia de compresión terminara en la marca de creación mostrada por Explorer; el analista revisa los tiempos finales, las operaciones de cierre y la consistencia del archivo.

La presencia del ZIP en disco acredita una representación local recuperable de ese contenido en la fecha de adquisición. Los eventos de proceso y de archivo son coherentes con su producción durante el incidente, pero la inferencia sobre intención continúa abierta. Si la herramienta utilizó archivos temporales, se buscan, registran y correlacionan, sin convertir la ausencia de temporales en prueba de que no existieron.

8.7.7. 6.7. La unidad USB: identificación sin atribución automática

Se encuentra en SYSTEM una instancia USBSTOR correspondiente a una memoria extraíble. SetupAPI refleja una instalación en un periodo anterior; otros eventos de dispositivo indican actividad durante la tarde estudiada. `MountedDevices` y un hive de usuario permiten relacionar de forma razonable el volumen con una letra empleada durante una sesión, pero se advierte que una letra no es un identificador estable del soporte.

El registro de usuario conserva un LNK con referencia a `E:\Entrega\clientes_octubre.zip`. Este hallazgo apoya que una ruta de archivo en un volumen asociado al dispositivo era conocida por el shell o una aplicación. **No demuestra por sí mismo la copia completa del ZIP al USB.** La imagen del dispositivo de destino no estaba incluida en el alcance ni disponible físicamente en la investigación, por lo que no hay un hash del archivo destino para comparar.

Se contrastan los eventos DLP y los de copia. El EDR registra un intento de escritura sobre unidad extraíble y una política de bloqueo activada, pero la salida no permite demostrar que se completó la transferencia de todos los bytes. La hipótesis de copia puede quedar abierta o resultar debilitada, según el detalle del registro. No se presentará como «exfiltración USB confirmada» un intento bloqueado o un LNK.

8.7.8. 6.8. La conexión HTTPS y el límite de los metadatos de red

Un registro de proxy muestra una petición HTTPS destinada a un servicio de almacenamiento externo poco después de la ejecución de compresión. Se cuenta con la dirección de destino, método HTTP, hora, resultado de política y metadatos del volumen de tráfico. El tráfico estaba cifrado y la organización no conservó el cuerpo de la petición. Tampoco se dispone de logs del servidor externo bajo el alcance autorizado.

La hipótesis de subida del ZIP es plausible por la proximidad temporal, pero necesita corroboración del nombre del objeto, un identificador de transacción, resultado de respuesta o logs de destino. Si el proxy registra la petición como bloqueada, la conclusión cambia sustancialmente: puede haber intento sin transmisión completa. Si marca `200` o `201`, aún

se requiere interpretar a qué operación correspondía y si se recibió el contenido esperado, porque una respuesta de un servicio no equivale necesariamente a que se almacenara ese ZIP.

Se solicita al equipo de redes información complementaria, preservando el alcance original y evitando que el analista pruebe cuentas no autorizadas. Si la información ya no se conserva, se registra la limitación y se emiten recomendaciones de retención para futuros casos. La pérdida de una fuente externa no puede rellenarse con supuestos derivados del disco Windows.

8.7.9. 6.9. Cronología de hechos y cronología de intervención

Las acciones del equipo de respuesta son hechos reales que modifican la escena y deben documentarse por separado. El aislamiento de red, una consulta de cuentas, la adquisición de RAM, la exportación del EDR y el traslado del equipo tienen horas y responsables distintos de los eventos que se investigan. La siguiente tabla usa tiempos sintéticos en UTC:

Hora UTC	Cronología	Origen	Observación o actuación
12:17	Hecho investigado	Security 4624	Sesión de cuenta corporativa en la estación
12:28	Hecho investigado	Sysmon 1 / Prefetch	Ejecución compatible con utilidad de compresión
12:30–12:33	Hecho investigado	MFT / USN / Sysmon 11	Creación y modificaciones del ZIP
12:38	Hecho investigado	USB / sistema	Enumeración o actividad de volumen extraíble
12:41	Hecho investigado	DLP	Intento de escritura sobre dispositivo externo

Hora UTC	Cronología	Origen	Observación o actuación
12:46	Hecho investigado	Proxy	Petición a servicio remoto, resultado incompleto
14:05	Respuesta	Centro de seguridad	Apertura de incidente y autorización inicial
14:12	Respuesta	EDR	Aislamiento de red documentado
14:18	Preservación	Operador forense	Adquisición de memoria RAM
15:02	Preservación	Equipo de respuesta	Exportación de registros centrales
17:20	Preservación	Laboratorio	Adquisición y verificación de imagen
Día siguiente	Análisis	Analista	Extracción, correlación y revisión de hallazgos

La tabla debe completarse con identificadores de objetos y precisión de cada tiempo. La marca de un sistema de archivos puede no resolver segundos, mientras un evento Sysmon podría mostrar más precisión formal; esa mayor cantidad de decimales no garantiza que los relojes fueran más exactos. Si dos observaciones están separadas por tres segundos y los relojes de origen presentan una incertidumbre conjunta de un minuto, no se debe asegurar su orden causal.

Figura 46: Investigación integrada de una estación Windows

8.7.10. 6.10. Matriz de hipótesis rivales

La investigación parte de cuatro explicaciones no necesariamente excluyentes:

Hipótesis	Predicción verificable	Evidencia disponible	Estado razonado
H1. Preparación local de ZIP con documentos corporativos	Proceso y creación de ZIP correlacionados; contenido relevante	Sysmon, NTFS y ZIP reconstruido	Fuertemente respaldada
H2. Copia íntegra del ZIP a unidad USB	Presencia de archivo de destino o registro específico de transferencia completa	Dispositivo reconocido, LNK, intento DLP	No acreditada de forma concluyente

Hipótesis	Predicción verificable	Evidencia disponible	Estado razonado
H3. Subida del ZIP a servicio externo	Logs de aplicación/proxy/destino con objeto y finalización	Petición HTTPS y metadatos parciales	Compatible, pero no demostrada
H4. Actividad exclusivamente automatizada y autorizada	Registro de tarea, proceso de servicio, política o ticket TI	Herramienta legítima; automatismo no encontrado en registros disponibles	Debilitada, no eliminada en absoluto

La calificación de la tabla es descriptiva, no una escala matemática de probabilidad ni una conclusión jurídica. La atribución personal no aparece como quinta hipótesis resuelta, porque todavía faltan fuentes suficientes para establecer quién operó físicamente la sesión y qué grado de control tenía sobre la cuenta. La presencia de sesión corporativa y ejecución de proceso demuestra contexto técnico de cuenta, no identidad humana de manera definitiva.

Para reducir sesgo de confirmación, el analista debe intentar refutar también la hipótesis que le resulte más convincente. Si la empresa esperaba encontrar una fuga USB, precisamente debe buscar registros DLP de bloqueo y ausencia de archivo completo. Si se sospecha subida a la nube, se revisan las respuestas de proxy y la posible transferencia de telemetría ordinaria sin contenido del ZIP. La comparación honesta de alternativas impide que una narrativa preconcebida absorba todos los indicios.

8.7.11. 6.11. Conclusiones técnicas del caso

Una formulación equilibrada de resultados podría ser:

> El análisis de la estación `ND-WKS-17` identificó evidencias concordantes de ejecución de una utilidad de compresión y de creación de `clientes_octubre.zip`, cuyo contenido recuperado incluye archivos del repositorio corporativo especificado en el alcance. Se observaron eventos de un dispositivo USB y una referencia a una ruta en una unidad extraíble, pero no se obtuvo una copia de destino verificable ni un registro suficiente para confirmar la transferencia completa del ZIP a dicho soporte. Asimismo, se

> identificó una petición de red a un servicio externo, sin datos que permitan atribuir a esa petición la carga completa del archivo. Las fuentes relacionan los eventos con un contexto de sesión corporativa, pero no acreditan por sí solas la identidad de la persona que ejecutó cada operación.

La redacción distingue tres hechos: creación del archivo, indicios de actividad USB y petición de red. No los confunde con tres éxitos de exfiltración. A partir de ellos se pueden proponer pasos proporcionales: solicitar logs adicionales bajo autorización, verificar políticas DLP, preservar retención del servicio cloud y revisar la explicación del usuario con garantías adecuadas. El análisis técnico no debería dictar por sí solo una sanción, atribuir un delito ni sustituir la valoración jurídica.

Un informe completo incluiría la identificación de todos los objetos, herramientas y versiones; hashes de fuentes y derivados; fechas originales y normalizadas; descripción de procedimientos; evidencias negativas relevantes; explicación de incertidumbre; y revisión independiente. El informe ejecutivo no necesita detallar cada clave de Registro, pero debe mantener un enlace verificable con los anexos técnicos.

8.7.12. 6.12. Validación y reproducibilidad del trabajo

Para verificar la cadena de interpretación, un segundo analista puede reproducir las operaciones centrales sobre una copia de referencia. Debe poder obtener la misma estructura de ZIP, hashes de archivos, filas de eventos seleccionadas y claves de Registro, considerando diferencias de formato en la presentación. Si una versión de parser informa tiempos distintos, ambas salidas se conservan, se investiga la conversión y se resuelve la discrepancia con fuentes primarias antes de modificar el informe.

La revisión independiente debe incluir controles negativos: ejecutar búsquedas sobre perfiles que no pertenecen al caso para comprobar si un artefacto es común; contrastar si otras estaciones presentan el mismo binario legítimo; revisar si el proxy registra conexiones idénticas generadas por actualizaciones; y verificar que la hora de un LNK no se ha confundido con la hora del archivo de destino. Un método que solo confirma la hipótesis elegida no está bien validado.

Los documentos del caso se versionan de manera que una corrección no elimine lo anterior. Si se descubre que el analista había interpretado una marca `LastWrite` como primer uso de USB, la rectificación debe conservar el registro anterior, indicar el motivo y reevaluar todas las conclusiones que dependían de esa inferencia. La rectificación documentada fortalece la transparencia del expediente.

8.7.13. 6.13. Fallos frecuentes en una investigación de Windows

Los errores más habituales no son siempre fallos de herramientas; con frecuencia son errores de significado. Algunos ejemplos permiten reconocerlos:

- **Tomar HKCU del ordenador analista como si fuera el usuario investigado.** La vista depende del contexto de sesión; se requiere el hive y SID correctos.
- **Usar `CurrentControlSet` sin resolver el control set del hive offline.** Puede conducir a interpretar configuración distinta de la que se pretende estudiar.
- **Leer la fecha de Shimcache como hora de ejecución.** En Windows modernos, esa conclusión no está sustentada por el artefacto aislado.
- **Interpretar Amcache como un registro universal de lanzamientos.** Contiene referencias de compatibilidad e inventario con coberturas variables.
- **Concluir que hubo copia USB porque existe un dispositivo USBSTOR.** La conexión no documenta la transferencia.
- **Tratar el nombre de un LNK como prueba de que se abrió un archivo completo.** El acceso directo refleja una referencia, con semántica propia.
- **Convertir un evento 4624 en identificación de una persona.** El evento identifica un contexto de autenticación de cuenta.
- **Asumir que todos los Windows guardan Sysmon, 4104 o 4688.** Requieren condiciones previas específicas.
- **Convertir una conexión TLS en envío comprobado de un documento concreto.** La transferencia necesita trazabilidad propia.
- **Omitir eventos que contradicen la hipótesis.** Los bloqueos DLP, errores de proceso y solicitudes rechazadas pueden transformar la interpretación.

La corrección común a estos errores es exigir a cada conclusión una fuente adecuada para el verbo que utiliza. Si una fuente acredita «registrar», no se la obliga a demostrar «copiar» o «enviar». Esta disciplina permite producir un informe menos espectacular pero más defendible.

8.7.14. 6.14. Plantilla breve de ficha de hallazgo

El análisis de Windows puede generar cientos de rastros. Para que el informe sea legible conviene condensar cada hallazgo relevante en una ficha con estructura estable:

Campo	Ejemplo sintético
Código	`H-WIN-014`

Campo	Ejemplo sintético
Pregunta	¿Se ejecutó la utilidad de compresión durante la ventana?
Fuente principal	`EV-EDR-005`, evento de proceso con tiempo UTC
Corroboración	`EV-WIN-001`, Prefetch y NTFS; exportación Sysmon
Datos observados	Ruta, proceso padre, argumentos, instante, objeto ZIP
Interpretación	Ejecución registrada, compatible con generación del ZIP
Alternativas	Tarea automatizada; proceso de TI; sesión utilizada por tercero
Limitación	No identifica a la persona física ni demuestra destino final
Derivados	CSV de procesos, ZIP extraído, hashes y capturas referenciadas
Revisión	Analista revisor, fecha, criterio y discrepancias

La ficha no debe esconder información incómoda en una casilla llamada «otros». Si una observación contradice la interpretación, debe constar como prueba de contraste. Tampoco se requiere una lista exhaustiva de todos los artefactos irrelevantes: se conserva el corpus completo bajo custodia y el informe presenta los que afectan a las preguntas del encargo.

8.7.15. 6.15. Cómo convertir la práctica en un laboratorio reproducible

El caso puede reproducirse parcialmente en una máquina virtual Windows con datos ficticios. Se prepara una estación con perfiles de prueba, documentos sintéticos y Sysmon configurado para la validación. Se ejecutan acciones conocidas: creación de un archivo ZIP, acceso a un documento desde Explorer, montaje de una memoria USB virtual o soporte de laboratorio, ejecución de una tarea autorizada y acceso a un servicio HTTP de pruebas. Se registra una «verdad conocida» independiente de los artefactos examinados: quién accionó qué, cuándo y con qué resultado.

A continuación, un analista que no conozca la verdad completa recibe las evidencias adquiridas y responde las preguntas. La revisión compara hallazgos y acciones reales, pero también los falsos positivos: si interpreta Amcache como ejecución, si identifica por error una descarga automática como copia manual o si afirma transferencia de un archivo que fue bloqueado. El laboratorio es especialmente valioso cuando demuestra que una herramienta puede presentar una fecha precisa y, pese a ello, necesitar una interpretación cautelosa.

Para mantener seguridad y legalidad, el escenario utiliza cuentas, ficheros y destinos controlados, sin extracción de datos personales reales. Los logs de prueba se conservan con hashes y las imágenes se identifican por versión. Una actualización de Windows o del parser obliga a reevaluar los resultados esperados; no basta con que un script anterior no genere errores.

8.7.16. 6.16. Qué permanece fuera de la imagen Windows

Un volumen Windows, por completo que se haya adquirido, no contiene la totalidad del contexto de actividad. Los archivos de un servicio SaaS pueden no haberse descargado; los registros de identidad pueden vivir en otro sistema; los equipos móviles asociados podrían contener mensajes; un proxy puede conservar detalles que no aparecen en la estación; y ciertos sucesos que solo existieron en RAM pueden perderse si el equipo fue apagado. Estas limitaciones son una propiedad del alcance, no una «falta de pericia» que pueda suplirse con más herramientas sobre el mismo disco.

En una investigación real, pedir nuevas fuentes puede cambiar el alcance legal y operativo, requerir conservar datos con urgencia o involucrar otras jurisdicciones. El analista debe describir qué necesita, por qué, qué periodo y qué dato espera obtener. La solicitud debe ser específica para preservar proporcionalidad, minimizar exposición de terceros y mantener la cadena de custodia.

8.8. Conclusiones

Windows ofrece un conjunto rico de rastros que permite reconstruir configuraciones, programas, sesiones, documentos y dispositivos. Su fortaleza reside en la diversidad: los hives muestran estado y referencias, EVTX registra eventos bajo determinadas políticas, los artefactos de ejecución aportan señales de intensidad distinta, NTFS conserva cambios y objetos, y las fuentes corporativas permiten observar transacciones fuera del equipo. Una investigación profesional no trata esas fuentes como si todas demostraran lo mismo.

En especial, un perfil no equivale a una persona, una conexión USB no prueba una copia, una referencia en Amcache o Shimcache no confirma por sí sola ejecución y una petición

de red no demuestra exfiltración de un archivo. Cuando las fuentes permiten afirmar más, como una creación de proceso registrada o una coincidencia entre objetos digitales completos, el informe debe explicar exactamente qué mejora la certeza y qué preguntas continúan abiertas.

La interpretación de Windows exige además conservar las versiones: de la imagen, de la compilación del sistema, de los formatos y parsers y de los propios resultados. La reproducción y la revisión independiente no son trámites adicionales, sino controles que permiten separar los hechos observados de las inferencias que se construyen sobre ellos. El siguiente capítulo, dedicado al análisis de Linux, aplicará esta misma disciplina a otros mecanismos de registro, autenticación, procesos y sistemas de archivos.

8.9. Referencias técnicas y lecturas recomendadas

Las fuentes siguientes se han elegido por su utilidad para verificar estructuras, eventos y límites de los artefactos. Los documentos operativos y las versiones de herramientas cambian: antes de un caso real se debe comprobar la documentación correspondiente a la versión exacta de Windows y del software utilizado. Los recursos que describen una fuente de datos no sustituyen pruebas de validación sobre un entorno conocido.

1. Microsoft. *4624(S): An account was successfully logged on*. Referencia oficial de los campos, tipos de inicio de sesión y sus límites: https://learn.microsoft.com/en-us/windows/security/threat-protection/auditing/event-4624.
2. Microsoft. *Advanced Audit Policy Configuration*: subcategorías y eventos de seguridad, entre ellos tareas programadas: https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/advanced-audit-policy-configuration.
3. Microsoft. *Sysmon — Sysinternals*: función, canales, configuración y significado de las diferentes familias de eventos: https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon.
4. Microsoft. *Sysmon configuration files*: referencia de tipos de eventos y filtrado: https://learn.microsoft.com/en-us/windows/security/operating-system-security/sysmon/sysmon-configuration-files.
5. Microsoft. *about_Logging* para Windows PowerShell 5.1: registro de bloques de script y evento 4104: https://learn.microsoft.com/en-us/powershell/module/microsoft.powershell.core/about/about_logging?view=powershell-5.1.
6. Microsoft. *about_Logging_Windows* para PowerShell 7: https://learn.microsoft.com/en-us/powershell/module/microsoft.powershell.core/about/about_logging_windows.

7. Microsoft. *Change Journal Records*: semántica y límites del diario de cambios NTFS: https://learn.microsoft.com/en-us/windows/win32/fileio/change-journal-records.
8. Microsoft. *The system registry is no longer backed up to the RegBack folder starting in Windows 10 version 1803*: https://learn.microsoft.com/en-us/troubleshoot/windows-client/installing-updates-features-roles/system-registry-no-backed-up-regback-folder.
9. Microsoft Incident Response. *Leveraging Windows Internals for Forensic Investigation*. Guía de interpretación de artefactos, con advertencias especialmente relevantes sobre Shimcache: https://cdn-dynmedia-1.microsoft.com/is/content/microsoftcorp/microsoft/final/en-us/microsoft-brand/documents/IR-Guidebook-Final.pdf.
10. Microsoft. *Troubleshoot unexpected reboots using system event logs*: referencia contextual sobre Service Control Manager, incluido evento 7045: https://learn.microsoft.com/en-us/troubleshoot/windows-server/performance/troubleshoot-unexpected-reboots-system-event-logs.
11. Microsoft. *File system functionality and NTFS technical documentation*: https://learn.microsoft.com/en-us/windows/win32/fileio/.
12. Microsoft Sysinternals. Herramientas oficiales para observación y análisis de Windows: https://learn.microsoft.com/en-us/sysinternals/.
13. Eric Zimmerman. *Eric Zimmerman's Tools*, documentación de herramientas y analizadores de artefactos Windows (contrastarlos con el corpus de prueba y la versión): https://ericzimmerman.github.io/.
14. The Sleuth Kit y Autopsy. Referencias de examen de imágenes, metadatos y actividad: https://www.sleuthkit.org/.
15. Velociraptor. Documentación de recogida y análisis de artefactos de Windows y metodologías reproducibles: https://docs.velociraptor.app/.
16. NIST. *Guide to Integrating Forensic Techniques into Incident Response*, SP 800-86: https://csrc.nist.gov/pubs/sp/800/86/final.
17. NIST. *Computer Forensics Tool Testing (CFTT)*. Ensayos de herramientas e importancia de la validación: https://www.nist.gov/itl/ssd/software-quality-group/computer-forensics-tool-testing-program-cftt.
18. SWGDE. Publicaciones de buenas prácticas de análisis, adquisición, revisión y elaboración de informes: https://www.swgde.org/documents/.
19. MITRE ATT&CK. Técnicas para interpretar comportamientos de Windows y contrastar hipótesis de persistencia o ejecución, sin reemplazar evidencia del caso: https://attack.mitre.org/.
20. Plaso y Timesketch. Documentación de construcción, agregación e interpretación de líneas temporales: https://plaso.readthedocs.io/ y https://timesketch.org/.

9. Análisis forense de Linux

9.1. Introducción

Cuando un servidor Linux aparece en una investigación, el primer obstáculo no suele ser la falta absoluta de información, sino la dispersión de sus rastros. Una conexión SSH puede figurar en el diario de `systemd`, en un archivo de autenticación, en un registro de auditoría del núcleo y en la plataforma central de supervisión. La creación de un proceso puede haber quedado reflejada por `auditd`, por un agente EDR o por una herramienta de observabilidad; en ausencia de esos componentes, quizá solo subsistan el ejecutable, sus archivos de salida y alguna referencia indirecta. Una tarea programada puede depender de `cron`, de un temporizador `systemd`, del gestor de procesos de una aplicación o de una plataforma de orquestación externa. No hay un «Registro de Linux» único al que acudir en busca de toda la actividad.

Esa diversidad es también una ventaja. Linux ofrece abundantes fuentes independientes: configuración legible, permisos y propietarios, registros de servicios, metadatos de sistemas de archivos, estados del gestor de servicios, evidencias de autenticación, datos en memoria y trazas de red. Su utilidad forense depende de la distribución, la versión, la política de registro, el perfil de seguridad, las herramientas instaladas y la forma en que el sistema ejecuta sus servicios. La misma ruta puede tener funciones diferentes en dos distribuciones; un nombre de servicio puede variar; y una instalación minimalista, un contenedor o una imagen inmutable pueden prescindir de componentes que se dan por supuestos en una estación de trabajo convencional.

Este capítulo desarrolla una metodología para examinar servidores y estaciones Linux con atención especial a Debian, Ubuntu y la familia Red Hat Enterprise Linux. Los ejemplos son transferibles, con adaptación, a otras distribuciones. Se distingue en todo momento la **evidencia observada** de la **interpretación técnica** y de la **atribución de una acción a una persona**. Una autenticación correcta con clave pública demuestra, dentro de los límites de los registros disponibles, que el servidor aceptó un mecanismo para una cuenta; no identifica necesariamente al operador humano de la clave. La existencia de una unidad `systemd` habilitada indica una configuración, no que su carga maliciosa llegase a ejecutarse. Un comando en un historial de shell es un indicio, no una transcripción completa y verificable de todas las operaciones realizadas.

El alcance tampoco debe confundirse con el estado actual de una máquina. Obtener resultados mediante `ps`, `ss`, `systemctl` o `journalctl` en un servidor activo produce una

observación útil, pero la ejecución de programas puede modificar el propio entorno. Cuando exista una adquisición forense válida, se preferirá examinar una copia verificada y explicar qué hallazgos solo eran accesibles mediante una captura en vivo. Las instrucciones que aparecen a continuación ilustran tanto consultas de laboratorio como análisis sobre copias; **no son una autorización para intervenir en sistemas ajenos ni una invitación a ejecutar todas las órdenes en el original**.

El capítulo culmina con la investigación de un servidor web ficticio en el que se detectan autenticaciones inusuales, elevación de privilegios, una unidad de persistencia y comunicaciones salientes. La resolución no da por supuesta una intrusión completa ni una exfiltración: enfrenta hipótesis alternativas, reconstruye la secuencia hasta donde llegan las evidencias y especifica las fuentes que aún deberían solicitarse. Ese principio —delimitar lo demostrado y lo pendiente— es el vínculo entre el análisis Linux y la metodología general estudiada en los capítulos precedentes.

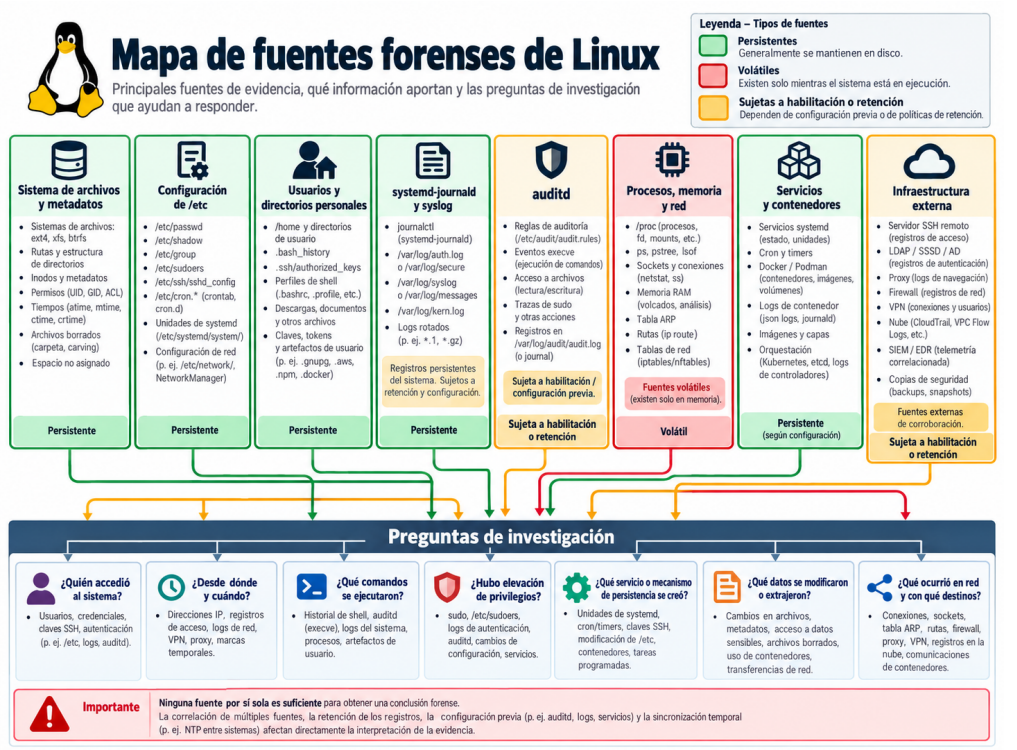


Figura 47: Mapa de fuentes de evidencia de Linux

9.2. 1. Estructura y fuentes de información

9.2.1. 1.1. Investigar una instalación, no un sistema operativo abstracto

Linux designa principalmente un núcleo y un ecosistema de distribuciones, bibliotecas, utilidades y servicios. En el trabajo forense importa menos una definición académica que saber qué componentes concretos estaban presentes: el sistema de inicialización, el modo de almacenamiento del diario, el servicio SSH, el esquema de cuentas, el sistema de archivos, los mecanismos de aislamiento, los gestores de paquetes y las aplicaciones expuestas. Dos servidores con el mismo núcleo pueden tener una superficie probatoria muy distinta.

Una investigación empieza por identificar distribución y versión, arquitectura, versión del núcleo, zona horaria, nombre de host, identificador de máquina, topología de almacenamiento y entorno de ejecución. También interesa determinar si se trata de un equipo físico, una máquina virtual, un contenedor, una instancia cloud o una appliance que usa Linux internamente. El nombre `web-02` puede aparecer en `/etc/hostname`, pero ese dato admite cambios; el identificador `/etc/machine-id` ayuda a correlacionar fuentes de `systemd`, sin que por sí solo pruebe identidad física permanente. La plataforma de virtualización o el proveedor cloud pueden aportar referencias externas más fiables para una instancia concreta.

El examen inicial de una **copia montada sin escritura** permite reconocer una distribución mediante archivos como `etc/os-release`, comprobar los directorios presentes e identificar configuraciones sin arrancar el sistema intervenido. Como ejemplo de trabajo en un laboratorio, suponiendo que `/caso/raiz` contiene la raíz extraída de una imagen:

```
# Solo sobre la copia de análisis; no ejecutar sobre la fuente
 ↪  original.
cat /caso/raiz/etc/os-release
cat /caso/raiz/etc/hostname
cat /caso/raiz/etc/machine-id
ls -ld /caso/raiz/{etc,var,home,root,usr,opt} 2>/dev/null
find /caso/raiz/etc -maxdepth 2 -type f -name '*release*' -print
```

El comando `cat` no interpreta automáticamente la zona horaria del sistema examinado, y un árbol de directorios copiado sin metadatos puede haber perdido propietarios, ACL, enlaces o tiempos. Por eso, al citar un archivo deben figurar la imagen de origen, el sistema de archivos, la ruta, el identificador del objeto si está disponible, los metadatos conservados y la herramienta de extracción. Una extracción basada únicamente en carpetas puede ser adecuada para una pregunta restringida, pero no sustituye una imagen de bloques cuando

se necesitan estructuras de directorio eliminadas, espacio no asignado o metadatos de bajo nivel.

9.2.2. 1.2. Jerarquía del sistema de archivos y valor probatorio

La jerarquía habitual de Linux proporciona una orientación útil, aunque no una lista universal. `/etc` conserva configuraciones persistentes; `/var` reúne datos de estado variable, registros, colas y bases de datos de servicios; `/home` suele albergar perfiles de usuarios; `/root` contiene, cuando existe, el directorio personal de la cuenta administrativa; `/usr` concentra gran parte del software instalado; `/opt` puede alojar aplicaciones de terceros; `/tmp` y `/var/tmp` sirven para temporales con políticas de limpieza distintas; `/run` reúne estados efímeros del arranque en sistemas actuales. Los contenidos de `/proc`, `/sys` y muchos elementos de `/dev` no son carpetas corrientes almacenadas en disco: sus entradas presentan información del núcleo o interfaces a dispositivos y solo tienen sentido completo cuando el sistema está funcionando.

En una adquisición apagada, no cabe esperar que `/proc/<pid>/cmdline` conserve los argumentos de procesos históricos: el sistema de archivos `procfs` se genera dinámicamente. En cambio, en una captura de memoria o en registros de auditoría podrían quedar pistas sobre procesos ya terminados. Tampoco debe suponerse que todo `/run` está disponible en la imagen: a menudo reside en un `tmpfs` y desaparece al apagar. La combinación de imágenes de almacenamiento, memoria, diario persistente y telemetría externa define el alcance real de lo observable.

Ubicación o familia	Información posible	Precaución interpretativa
`/etc/passwd`, `/etc/group`, `/etc/shadow`	Cuentas, identificadores, grupos y datos de autenticación local	No reflejan por sí solos identidades externas de LDAP/SSSD
`/etc/ssh/`	Configuración de `sshd`, claves de host, inclusiones	La configuración efectiva puede incluir fragmentos y condiciones `Match`
`/home/*`, `/root`	Claves, historiales, archivos de usuario, configuraciones	Propiedad y ubicación no identifican necesariamente al autor humano
`/var/log/`	Texto syslog, registros de aplicación, auditoría	Retención, rotación y aplicaciones pueden variar

Ubicación o familia	Información posible	Precaución interpretativa
`/var/log/journal/`	Diario persistente de `systemd`, si existe	Puede no haberse configurado o haber sido reducido
`/var/spool/cron/`, `/var/spool/cron/crontabs/`	Programaciones de usuario según distribución	La ubicación real depende del servicio cron instalado
`/etc/systemd/`, `/usr/lib/systemd/`, `/lib/systemd/`	Unidades, temporizadores y ajustes de servicios	Precedencias, enlaces y *drop-ins* modifican el resultado
`/var/lib/`	Bases de datos y estados de componentes	Una actualización o limpieza puede alterar registros históricos
`/tmp`, `/var/tmp`, `/dev/shm`	Temporales, archivos de trabajo y posibles cargas	Su persistencia depende de montaje, limpieza y reinicios
`/proc`, `/sys`, `/run`	Estado de procesos, núcleo y sesiones en vivo	No debe confundirse con contenido histórico de una imagen apagada

En organizaciones con políticas de endurecimiento, partes del sistema pueden montarse con opciones como `noexec`, `nosuid` o `nodev`; determinados directorios pueden ser volúmenes independientes, estar cifrados o redirigirse a almacenamiento de red. Una imagen del disco de sistema no incluye necesariamente un volumen NFS montado ni el disco adjunto donde una aplicación mantiene su base de datos. Antes de declarar completa la recogida de un servidor es preciso reconstruir su tabla de montajes, sus volúmenes lógicos y, cuando proceda, sus dependencias cloud.

9.2.3. 1.3. Particiones, volúmenes, montajes y sistemas de archivos

El examen de almacenamiento continúa el capítulo anterior. Linux puede arrancar desde GPT o MBR, utilizar ext4, XFS, Btrfs u otros sistemas de archivos, incorporar LVM, RAID por software, volúmenes cifrados con LUKS y espacios de almacenamiento efímeros. Cada capa posee sus propios metadatos y sus límites probatorios. Que la ruta `/var/log` exista en la raíz no demuestra que sus bytes se encontraran en el mismo dispositivo; podría ser un montaje, un enlace, un `bind mount` o una superposición de contenedor.

En un sistema de **laboratorio**, los comandos siguientes ayudan a entender qué información conviene obtener durante una intervención autorizada. La salida procedente del original se documentaría como adquisición en vivo, no como equivalente a una reconstrucción posterior:

```
lsblk -o NAME,TYPE,SIZE,FSTYPE,UUID,MOUNTPOINTS
findmnt -R /
cat /proc/mounts
blkid
# Si se usa LVM y está autorizado:
pvs; vgs; lvs -a -o +devices
```

Para un análisis apagado resulta preferible interpretar la tabla de particiones y los sistemas de archivos a partir de la imagen y leer `etc/fstab`, la configuración LVM y el inventario de infraestructura. Las rutas `/dev/sda`, `/dev/nvme0n1` o `/dev/mapper/...` pueden cambiar entre arranques; los UUID, los números de serie y los identificadores de volumen requieren también comprobación, pero suelen aportar mejores elementos de correlación que un nombre de dispositivo temporal.

Montar un sistema de archivos no es una operación inocua en todos los contextos. Por ejemplo, montar ext4 como solo lectura puede dar lugar, según el modo y entorno, a recuperación del diario si no se especifican las precauciones pertinentes. Para inspecciones de laboratorio sobre ext4 se considera una configuración de solo lectura que evite la reproducción del diario (`ro,noload`), atendiendo a la semántica de la versión del núcleo y validando previamente el procedimiento. Esto no reemplaza el uso de herramientas capaces de leer estructuras de archivos sin montar. En XFS, Btrfs o volúmenes cifrados, las decisiones son diferentes: copiar literalmente una receta de ext4 puede resultar inapropiado.

9.2.4. 1.4. Sistemas de archivos y metadatos que deben conservarse

Un archivo de configuración puede parecer texto simple, pero su significado depende de más que sus líneas: propietario numérico, grupo, permisos, ACL, atributos extendidos, etiquetas SELinux, capacidades de archivo, enlaces simbólicos, inode, marcas temporales y ubicación dentro del sistema montado. Si esos datos se pierden en una copia manual, también se pierde la posibilidad de responder a preguntas sobre quién podía leer o modificar el objeto o sobre cómo una aplicación lo encontraba.

En ext4, los inodos y las entradas de directorio contienen información que no debe reducirse al nombre y a la fecha de modificación. En XFS y Btrfs existen estructuras y mecanismos históricos propios. En entornos con `overlayfs`, Docker o Kubernetes, un archivo visible en el árbol del contenedor puede pertenecer a una capa de imagen, a una capa escribible o

a un volumen compartido. Dos archivos con la misma ruta visible para el proceso no tienen necesariamente el mismo origen en el sistema anfitrión. Atribuir cambios a un contenedor requiere identificar su capa, su instante de creación y el proceso o herramienta que actuó sobre ella.

Para documentar metadatos en una **copia extraída que los preserve**, pueden utilizarse comandos como `stat`, `getfacl`, `getfattr` o `getcap`. Un ejemplo ilustrativo:

```
stat /caso/raiz/etc/ssh/sshd_config
getfacl -p /caso/raiz/etc/ssh/sshd_config
getfattr -d -m '-' /caso/raiz/usr/local/bin/servicio 2>/dev/null
sha256sum /caso/raiz/etc/ssh/sshd_config
```

No debe suponerse que una copia a un sistema de archivos ajeno conserva ACL, atributos o etiquetas de origen. En una investigación con exigencias de precisión, esos resultados se contrastan con el volumen original de la imagen mediante herramientas compatibles con el sistema de archivos y la configuración del entorno. El hash del archivo conserva una referencia a sus bytes, no prueba por sí solo su propietario ni los metadatos que rodeaban su contenido.

9.2.5. 1.5. Fuentes de estado, configuración y actividad

Para evitar inferencias precipitadas conviene clasificar las fuentes antes de analizarlas. Un archivo de configuración describe cómo estaba previsto que actuara un programa en cierto estado del sistema; un diario registra eventos que el software decidió emitir; una base de datos de aplicación conserva transacciones con su semántica particular; una captura de procesos representa un instante; y una fuente externa, como un balanceador o un proveedor de identidad, puede registrar la comunicación desde otro punto de observación. Estas categorías no son intercambiables.

Un ejemplo aclara la diferencia. Encontrar `PermitRootLogin no` en una copia de `sshd_config` demuestra la presencia de esa directiva en un archivo. No demuestra, por sí solo, que fuese la configuración efectiva en el momento del hecho: puede existir un `Include`, una condición `Match`, otro archivo de configuración usado al iniciar el servicio o un cambio posterior. Un evento `Accepted publickey for admin` es más próximo a una autenticación observada, pero aún exige determinar a qué host, instancia y periodo corresponde. Y un registro de sesión con TTY demuestra algo distinto de una simple autenticación sin shell interactiva.

En un servidor conectado a un sistema de registro central pueden coexistir logs locales y copias reenviadas. El reenvío es especialmente importante cuando se sospecha una alteración

local: una eliminación en `/var/log` puede no afectar a los mensajes que el colector recibió antes. Sin embargo, una divergencia entre el log local y el central también puede deberse a filtrado, retrasos, caída de conexión, formato diferente o reglas de retención. La pregunta correcta no es «¿cuál miente?», sino «¿qué produjo cada sistema, qué transportó y qué pudo perderse?».

9.2.6. 1.6. Alcance de la adquisición e inventario inicial

Una investigación Linux necesita un inventario de evidencias y no solo una lista de carpetas para copiar. Un conjunto razonable, ajustado al encargo, puede incluir una imagen del almacenamiento pertinente, una captura de memoria si se justificó, archivos de diario, registros rotados, configuraciones SSH, cuentas y grupos, tareas programadas, unidades y *drop-ins* de `systemd`, paquetes instalados, evidencias del servicio investigado y, si existen, registros de `auditd`, EDR, red, firewall e infraestructura cloud. El inventario anota fuentes ausentes y razones de su ausencia.

Es aconsejable registrar las características del soporte y la adquisición con identificadores independientes: `OBJ-LX-01` para el servidor o volumen, `ADQ-LX-01` para su imagen, `LOG-LX-01` para una exportación autorizada del colector y `MEM-LX-01` para la memoria. El analista no debe reutilizar el identificador de una imagen para un volcado de memoria, ni afirmar que un hash de contenedor equivale al hash del contenido reconstruido. La trazabilidad entre objetos se conserva mediante relaciones explícitas y verificaciones sobre datos comparables.

Una adquisición remota exige identificar también el ejecutor y la cuenta de servicio, la API o canal utilizado, la hora de inicio y fin, los filtros aplicados, los errores, las claves de acceso empleadas y la posibilidad de pérdida o alteración de metadatos. Un tarball con `/etc` puede responder a ciertas preguntas de configuración, pero no permite analizar archivos eliminados de ext4 ni garantiza la conservación de todos los atributos. Si la investigación tiene hipótesis sobre manipulación de archivos, el alcance debe reconocer esa limitación y solicitar la modalidad de adquisición pertinente.

9.2.7. 1.7. Valor de la ausencia y contexto de interpretación

La ausencia de un fichero `.bash_history`, de un evento SSH o de un temporizador `systemd` no significa lo mismo en todos los sistemas. Para interpretar una ausencia hay que conocer si el mecanismo estaba instalado y habilitado, la política de registro, el periodo de retención, la cobertura de la adquisición y las formas legítimas de eludir el mecanismo sin conducta maliciosa. Una sesión no interactiva puede no escribir historial; un diario volátil

desaparece con el reinicio; y un proceso dentro de un contenedor puede emitir logs exclusivamente al colector del orquestador.

El investigador debe resistir dos atajos opuestos. El primero consiste en atribuir toda anomalía a un atacante: una unidad nueva, una clave SSH o un fichero en `/tmp` pueden pertenecer a una actualización o automatización legítima. El segundo consiste en descartar una intrusión porque falte el rastro esperado: la ausencia puede ser explicable por la propia configuración del sistema o por una adquisición incompleta. La solución es construir hipótesis contrastables y precisar qué nuevas fuentes podrían resolverlas.

Como regla editorial y técnica para las páginas siguientes, se describirá primero el **objeto observado**, después la **semántica conocida del mecanismo**, a continuación la **interpretación apoyada por el contexto** y por último la **limitación**. Esa secuencia evita convertir un simple contenido de archivo en una afirmación demasiado fuerte sobre decisiones, intenciones o identidades.

9.3. 2. Logs del sistema y autenticación

9.3.1. 2.1. El registro es una capacidad configurada, no un recuerdo perfecto

Los registros Linux describen acontecimientos desde el punto de vista de componentes concretos: el núcleo, `sshd`, PAM, el gestor de servicios, el servidor web, un demonio de bases de datos o un agente de seguridad. Algunos mensajes expresan acciones confirmadas; otros solo reflejan intentos, errores o estados transitorios. En particular, una línea de autenticación no informa de todo lo realizado después de iniciar sesión, y un mensaje de aplicación que contiene el texto `success` no garantiza que la operación empresarial asociada haya terminado correctamente.

Conviene separar tres mecanismos que a menudo se presentan como si fuesen uno. **`systemd-journald`** recibe y conserva mensajes estructurados procedentes de diversas fuentes cuando está disponible. **Syslog**, a través de servicios como `rsyslog` o `syslog-ng`, puede escribir mensajes de texto en ficheros, reenviarlos o procesarlos conforme a reglas. **El subsistema Audit de Linux**, normalmente gestionado mediante `auditd` y reglas de auditoría, registra determinados eventos de seguridad y llamadas al sistema bajo una configuración específica. Pueden coexistir y recoger parte de la misma actividad, pero su cobertura, origen y fiabilidad no son idénticos.

En Ubuntu y Debian es frecuente encontrar `/var/log/auth.log`, `/var/log/syslog`, `/var/log/kern.log` y sus rotaciones cuando está activo el correspondiente sistema de logging. En entornos de la familia RHEL resultan habituales `/var/log/secure`,

`/var/log/messages` y `/var/log/audit/audit.log`. Esas rutas son ejemplos, no garantías. Instalaciones recientes o reducidas pueden depender casi por completo del diario binario y de un colector externo. Antes de buscar un archivo se debe verificar que el mecanismo existía en la fecha estudiada.

Familia	Ejemplo de fuente	Observación posible	Dependencia principal
Diario de `systemd`	Archivos `.journal`	Mensajes de servicio y metadatos de proceso	Persistencia, volumen, política de almacenamiento
Logs de autenticación	`auth.log`, `secure`	SSH, `sudo`, PAM, intentos y decisiones	Servicio syslog, reglas de encaminamiento y retención
Auditoría de núcleo	`audit.log`	`execve`, accesos y cambios vigilados	Reglas activas, política audit y posibles pérdidas
Sesiones históricas	`wtmp`, `btmp`, `lastlog` u otros mecanismos	Información de logins y fallos	Versión, formato, aplicación que escribe y conservación
Aplicaciones	Nginx, Apache, bases de datos, agentes	Peticiones, usuarios, errores y operaciones	Configuración y diseño del producto
Fuentes externas	Bastión, VPN, IdP, SIEM, firewall	Visibilidad independiente del host	Integridad, retención y cobertura del colector

9.3.2. 2.2. Cómo funciona el diario de `systemd`

`systemd-journald` recoge mensajes que llegan por distintos canales, entre ellos registros de servicios, syslog, mensajes del núcleo y, según configuración, registros de auditoría. A cada entrada puede asociarle campos tales como `_PID`, `_UID`, `_COMM`, `_EXE`, `_SYSTEMD_UNIT`, `_BOOT_ID`, `__REALTIME_TIMESTAMP` y `__MONOTONIC_TIMESTAMP`. Algunos campos provienen del propio origen del mensaje y otros son añadidos por el servicio

de registro. Esa diferencia importa: el texto libre que una aplicación envía no ofrece necesariamente el mismo nivel de confianza que los metadatos añadidos por el colector, y estos últimos tampoco prueban por sí solos que el equipo no estuviera comprometido.

El diario puede almacenarse de forma persistente bajo `/var/log/journal/` o temporalmente en `/run/log/journal/`. La configuración `Storage=`, las opciones con que se compiló `systemd`, el espacio disponible y la existencia del directorio influyen en el resultado. Por tanto, **no debe darse por hecho que los logs anteriores a un reinicio siguen disponibles**. En ediciones modernas de `systemd` incluso los valores por defecto pueden diferir respecto a versiones anteriores; la comprobación ha de hacerse sobre el servidor investigado, no sobre la estación del perito.

En un laboratorio con una copia del directorio de diarios, puede consultarse la información existente sin iniciar el sistema examinado:

```
# /caso/journal-extraido es una copia de los ficheros .journal.
journalctl --directory=/caso/journal-extraido --list-boots --no-pager
journalctl --directory=/caso/journal-extraido --utc \
  --since='2026-09-16 00:00:00' --until='2026-09-17 00:00:00' \
  --no-pager
journalctl --directory=/caso/journal-extraido -o json \
  --no-pager > /caso/derivados/journal-export.jsonl
```

El directorio debe contener una estructura que el lector de journal reconozca; según la forma de la adquisición, puede resultar más adecuado usar `--file` con los archivos concretos o preparar una copia íntegra del árbol. El operador debe validar que los filtros temporales incluyen los extremos que necesita. En `journalctl`, `--utc` afecta a cómo se muestra la hora, no transforma la hora de creación de un evento ni repara un reloj desviado. Los campos de tiempo monotónico ayudan a ordenar eventos dentro de un mismo arranque, pero no comparan sin más eventos de arranques distintos.

El uso de `-o json` facilita conservar campos estructurados; una exportación legible en texto simplifica la revisión humana, pero puede omitir metadatos. Cuando la pregunta lo justifique conviene conservar el archivo de diario original, una exportación estructurada y, como derivado auxiliar, una selección en texto con filtros reproducibles. No se debe sustituir el soporte original por una captura de pantalla de `journalctl` ni perder la relación entre una línea transformada y la entrada fuente.

9.3.3. 2.3. Integridad de los diarios, vacíos y rotaciones

`journalctl --verify` ayuda a comprobar la consistencia estructural de archivos de journal en los términos admitidos por la implementación; su resultado no equivale a una certificación de autenticidad de todos los mensajes. El acceso administrativo al equipo puede permitir borrar, reemplazar o alterar fuentes, y el diario puede haber sido truncado legítimamente por cuotas. Algunos mecanismos de sellado adicional, cuando existen y estaban habilitados, ofrecen propiedades específicas, pero no deben suponerse presentes.

```
# Verificación estructural sobre COPIAS, sin alterar los originales.
journalctl --file=/caso/journal-extraido/system.journal --verify
# En laboratorio, localizar ficheros potencialmente pertinentes:
find /caso/raiz/var/log -maxdepth 3 -type f \
  \( -name '*.log' -o -name '*.journal' -o -name '*.journal~' \
     -o -name 'auth.log*' -o -name 'secure*' \) -print
```

Un error de lectura obliga a documentar el archivo y la versión utilizada, conservar el resultado y estudiar alternativas. La presencia de archivos `.journal~` puede asociarse, entre otras posibilidades, con un cierre no limpio o una incidencia detectada por el propio servicio; no constituye por sí sola un indicador de manipulación deliberada. Un hueco temporal puede proceder de un reinicio, una caída del colector, reglas de filtrado, saturación, cambio de zona horaria, rotación o eliminación. Antes de escribir «se borraron los logs» debe existir una base positiva para esa afirmación y examinarse la política de conservación.

En registros de texto se debe estudiar la rotación. Archivos como `auth.log.1`, `syslog.2.gz` o `secure-20260916` ilustran convenciones posibles, no nombres universales. `logrotate` puede configurar periodicidad, compresión, conservación o ejecución de comandos posteriores; un servicio también puede rotar por su cuenta. La fecha de creación del fichero rotado no es necesariamente la fecha de cada evento contenido. Un `.gz` debe tratarse como objeto derivado de una rotación, preservando su archivo original comprimido y verificando hashes antes y después de extraerlo.

9.3.4. 2.4. Autenticación SSH: intento, aceptación y sesión

OpenSSH es una de las fuentes esenciales en servidores administrados a distancia. Los mensajes de `sshd` permiten identificar intentos fallidos, métodos de autenticación aceptados, cuentas, direcciones de origen y, según la configuración, detalles adicionales. La frase `Accepted publickey for usuario from IP port ...` describe que el servidor

aceptó una autenticación para esa cuenta desde una conexión que observó con esa dirección. No prueba que se concediese una sesión interactiva plena ni que quien controlaba la conexión fuese el propietario legítimo de la cuenta.

El examen debe buscar también el inicio y cierre de sesiones PAM, los posibles subsistemas SFTP, los comandos forzados, el uso de `Match`, el reenvío de puertos y los registros de bastiones. En entornos con proxies SSH o túneles, la IP de origen vista por el servidor puede corresponder a un salto intermedio. Una clave pública autorizada puede compartirse indebidamente, ser robada o pertenecer a una automatización. Por eso, una identificación responsable necesita correlacionar la huella de la clave si fue registrada, la procedencia de red, la gestión de credenciales y otras fuentes de actividad.

Ejemplo ficticio de log:

```
Sep 16 09:14:02 web-prod-02 sshd[1842]: Accepted publickey for deploy
 ↪  from 198.51.100.77 port 51422 ssh2
Sep 16 09:14:02 web-prod-02 sshd[1842]: pam_unix(sshd:session):
 ↪  session opened for user deploy(uid=1002) by (uid=0)
Sep 16 09:29:43 web-prod-02 sshd[1842]: pam_unix(sshd:session):
 ↪  session closed for user deploy
```

Estos tres renglones, considerados por sí solos, permiten situar una autenticación y una sesión registrada de la cuenta `deploy`. No incluyen un listado completo de programas lanzados, ni identifican a una persona. Tampoco demuestran que un archivo haya sido extraído o que el sistema haya sido comprometido. Si el servicio registra comandos o transferencia de archivos solo mediante componentes opcionales, su ausencia puede dejar sin resolver lo ocurrido dentro de la sesión.

9.3.5. 2.5. Consultas de autenticación y sus límites

En una copia de logs de texto, una búsqueda inicial puede localizar líneas de OpenSSH, PAM y `sudo`. La búsqueda textual es un **instrumento de selección**, no el análisis completo: expresiones regulares simples pueden confundir distintos formatos, romper eventos multilineales o pasar por alto canales distintos.

```
# Sobre una copia de los registros de texto.
grep -nE 'sshd\[|sudo:|pam_unix\(' /caso/logs/auth.log \
  > /caso/derivados/seleccion-auth.txt

# Sobre journal exportado previamente; consulta de ejemplo de
 ↪  laboratorio.
journalctl --directory=/caso/journal-extraido --utc \
```

```
_COMM=sshd --since='2026-09-16 09:00:00' \
--until='2026-09-16 10:00:00' --no-pager
```

El campo `_COMM=sshd` no garantiza cobertura completa: unidades, nombres de procesos, cambios de ejecutable o metadatos ausentes pueden impedir recuperar entradas relevantes. La selección debe contrastarse con consultas por servicio (`-u ssh.service` o `-u sshd.service` cuando corresponda), por identificador syslog y con logs centrales. Una coincidencia textual tampoco constituye una prueba de que la línea sea íntegra, auténtica o que no se haya duplicado durante una exportación.

Los intentos repetidos de autenticación desde una IP pueden indicar exploración automatizada, errores de configuración o actividad hostil. Sin correlación con un acceso aceptado, una huella de clave o acciones posteriores, no procede equiparar cientos de fallos con una intrusión exitosa. En un informe puede afirmarse «se observaron X intentos fallidos en el periodo Y desde las direcciones Z» y reservar «acceso no autorizado» para la conclusión apoyada por otras evidencias.

9.3.6. 2.6. PAM, sudo, su y autenticación centralizada

Linux utiliza habitualmente PAM (*Pluggable Authentication Modules*) como marco de autenticación y gestión de sesiones para diversos servicios. El archivo `/etc/pam.d/sshd` —cuando se utiliza esa configuración— puede integrar módulos con políticas de cuentas, controles adicionales y apertura o cierre de sesión. El investigador debe diferenciar el resultado del componente PAM y el del servidor que lo invocó: que un módulo informase de éxito no documenta necesariamente todas las acciones realizadas a continuación.

`sudo` añade otra dimensión. Los registros habituales pueden incluir el usuario que invocó el comando, el directorio desde el que se llamó, la cuenta de destino y la orden solicitada. Sin embargo, la configuración puede registrar niveles diferentes de detalle o usar un sistema central; el hecho de ver una ejecución con `sudo` no prueba automáticamente que la operación interna haya obtenido el resultado esperado. En particular, `sudo sh -c '...'` puede ocultar bajo una sola entrada varias acciones del shell. La interpretación exige revisar la orden, el mecanismo de logging y los resultados de sus efectos.

`su`, `runuser`, `pkexec`, servicios privilegiados, capacidades Linux y escaladas por vulnerabilidad pueden producir vías de cambio de privilegios diferentes. El análisis no debe limitarse a `sudo`. Además, las identidades no siempre se mantienen en `/etc/passwd`: SSSD, LDAP, Kerberos, Active Directory mediante integración y soluciones de acceso privilegiado pueden resolver cuentas de forma externa. En esos casos los registros del proveedor de identidad y de la política de acceso resultan decisivos.

9.3.7. 2.7. Auditoría del núcleo: auditd y reglas previas

El subsistema de auditoría de Linux puede registrar operaciones detalladas si estaba habilitado y se definieron reglas apropiadas. Un mismo evento auditado puede constar de varios registros SYSCALL, EXECVE, PATH, CWD y otros con un identificador común, dependiendo de la operación. El analista no debe leer cada línea como un evento humano independiente; ha de reconstruir el conjunto y comprender la semántica de campos como `uid`, `euid`, `auid`, `ses`, `pid`, `ppid`, `exe` y `comm`.

El `auid` o *loginuid* pretende conservar una referencia a la identidad de inicio de sesión a través de determinados cambios de privilegios. Es útil para investigaciones, pero no es una prueba infalible de persona: procesos sin sesión de login convencional, contenedores, servicios, valores no establecidos o entornos manipulados pueden limitar su interpretación. Del mismo modo, `euid=0` muestra privilegio efectivo de un proceso en cierto contexto; no documenta por sí solo la ruta de escalada ni la intención.

```
# Ejemplos de laboratorio con ficheros de auditoría YA EXTRAÍDOS.
ausearch -if /caso/logs/audit.log -m USER_AUTH,USER_LOGIN
ausearch -if /caso/logs/audit.log -k cambios_criticos
ausearch -if /caso/logs/audit.log -x /usr/bin/curl
```

La compatibilidad y las opciones concretas se verifican contra la versión de `ausearch` instalada. La clave `cambios_criticos` solo producirá resultados si existieron reglas audit que emitían esa clave; no es un filtro mágico aplicable retroactivamente. Asimismo, buscar `/usr/bin/curl` mediante `-x` sirve si los eventos pertinentes fueron registrados con esa ruta. Un binario renombrado, ejecutado en contenedor o sin cobertura de auditoría puede quedar fuera.

La configuración puede estar en `/etc/audit/rules.d/`, `/etc/audit/audit.rules` y rutas dependientes del paquete. Los registros suelen guardarse en `/var/log/audit/audit.log`, pero pueden enviarse a otro destino. Interesan el estado previo de las reglas, el tamaño del backlog, el comportamiento ante errores y los mensajes que indiquen pérdida de registros. Un conjunto audit fragmentado no se completa multiplicando búsquedas.

9.3.8. 2.8. Sesiones históricas: wtmp, btmp y variantes modernas

Comandos tradicionales como `last`, `lastb` y `lastlog` se basan, según distribución y versión, en bases de datos o ficheros de contabilidad de sesiones. Los nombres `wtmp`, `btmp` y `lastlog` son conocidos, pero el ecosistema evoluciona: algunas distribuciones han migrado componentes a mecanismos nuevos como `wtmpdb` y pueden no escribir los formatos

clásicos. La ausencia de `/var/log/wtmp` no equivale automáticamente a actividad borrada.

En un sistema de laboratorio se pueden consultar ejemplos de registros extraídos utilizando las opciones que admita la implementación presente:

```
# Si la distribución usa wtmp clásico y la herramienta admite -f:
last -f /caso/raiz/var/log/wtmp
# Si se dispone de btmp y permisos/autorización adecuados:
lastb -f /caso/raiz/var/log/btmp
```

Las bases históricas pueden registrar sesiones incompletas, conexiones virtuales o referencias a reinicios; la zona horaria de presentación y la precisión dependen del formato. A menudo contienen direcciones de origen, usuarios y terminales, pero no garantizan que todos los accesos SSH, SFTP o comandos no interactivos estén representados. La validez de una interpretación requiere saber quién escribía esos registros y qué actividades pretendía cubrir.

9.3.9. 2.9. Registros de aplicaciones, proxies y servicios de infraestructura

En un servidor web, `nginx` o Apache pueden conservar accesos HTTP, códigos de estado, rutas, usuarios autenticados y tiempos de petición. Una solicitud con respuesta `200` señala que el servidor o proxy respondió con ese estado: no prueba automáticamente que el cliente utilizase correctamente el contenido, que se haya descargado un fichero completo ni que la dirección IP se corresponda con una identidad humana. Las cabeceras de proxy, el origen del `X-Forwarded-For` y la topología de balanceo influyen en la atribución.

Los registros de base de datos, colas de mensajes, plataformas de CI/CD y aplicaciones de negocio son igualmente relevantes. Un script ejecutado en segundo plano podría dejar una consulta SQL, un cambio en un objeto cloud o un fichero enviado a un repositorio; la ausencia de historial de terminal no elimina esos indicios. El analista debe solicitar el diseño de registro de la aplicación: campos, precisión temporal, valores de usuario, identificadores de transacción y relación con otros sistemas.

En servicios cloud también interesan el plano de control, la consola de administración, las llamadas API, las políticas IAM, las instantáneas y los eventos del hipervisor. Una instancia Linux puede haber sido recreada a partir de una imagen y conservar solo parte de sus logs; las acciones de creación y destrucción pueden registrarse exclusivamente fuera del invitado. Un análisis limitado a `/var/log` no tendría capacidad para probar ni descartar por sí mismo esas operaciones.

9.3.10. 2.10. Normalización temporal y correlación

Un diario `systemd` conserva información de tiempo real y, para el contexto de arranque, monotónica. Los syslogs tradicionales pueden omitir el año en su representación textual, usar hora local, depender de la zona del host y carecer de precisión subsegundo. Los registros de red, por su parte, pueden estar en UTC y mostrar el instante de fin de una conexión, no su comienzo. Colocar todas esas horas en una tabla sin entenderlas produce cronologías aparentemente precisas y conceptualmente falsas.

Por eso, cada evento normalizado debería registrar al menos el valor original, el objeto fuente, su semántica (inicio, fin, escritura, autenticación, etc.), la zona supuesta o conocida, precisión, incertidumbre del reloj y conversión usada. Las diferencias de segundos no pueden sostener una secuencia causal si uno de los relojes podía estar desviado minutos. Una correlación razonable utiliza además identificadores comunes: dirección y puerto, ID de sesión, PID dentro del arranque, clave SSH, ruta, hash o ID de operación.

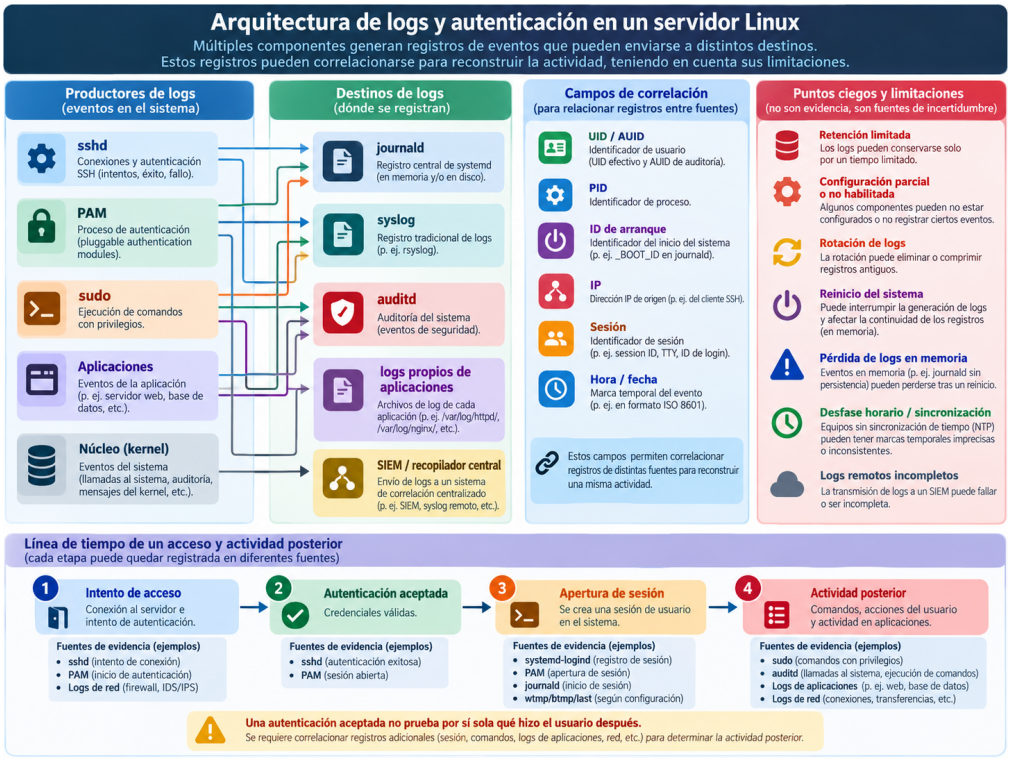


Figura 48: Arquitectura de registros y autenticación

9.3.11. 2.11. Qué puede afirmarse después de examinar los logs

El resultado del análisis no debería ser una lista interminable de líneas copiadas en un informe. Debe responder a preguntas concretas: ¿qué servicio recibió la solicitud?, ¿hubo una autenticación aceptada?, ¿con qué cuenta y mecanismo?, ¿la sesión se abrió?, ¿qué privilegios quedaron registrados?, ¿qué procesos o archivos están vinculados?, ¿qué otra fuente independiente respalda el episodio? Una tabla de hallazgos con campos para evidencia, interpretación, incertidumbre y preguntas pendientes es más útil que varios cientos de páginas de salida de `grep`.

La conclusión negativa debe tratarse con igual rigor. Es correcto escribir «en los diarios adquiridos, que cubren del 15 al 17 de septiembre, no se localizó una entrada `Accepted publickey` para esa cuenta». No lo es convertirlo sin más en «nadie accedió». Podrían existir otros métodos, un nodo de destino diferente, pérdida de registros, una salida externa, una cuenta con otro nombre o actividad no registrada. Los logs son testigos técnicos condicionados por su diseño y mantenimiento; precisamente por eso deben contrastarse entre sí.

9.4. 3. Usuarios, permisos, sesiones SSH y privilegios

9.4.1. 3.1. Cuenta, credencial, sesión y persona: cuatro conceptos distintos

La atribución de actividad en Linux exige separar conceptos que en un informe apresurado pueden aparecer como sinónimos. Una **cuenta** es una identidad que el sistema reconoce y a la que asigna determinados permisos. Una **credencial** es el mecanismo usado para autenticarla, como una contraseña, una clave pública o un ticket. Una **sesión** es un contexto de acceso o ejecución, que puede ser interactivo, remoto, automatizado o incluso existir sin terminal. Una **persona** es el sujeto humano cuya participación interesa determinar, y esa identidad no se desprende automáticamente de los tres elementos anteriores.

En infraestructuras profesionales es habitual que varias personas utilicen sistemas de bastión, que los despliegues funcionen bajo cuentas técnicas como `deploy`, o que un sistema de integración continua ejecute tareas sobre un servidor. Un registro `Accepted publickey for deploy` establece un vínculo entre una conexión y una cuenta aceptada. Para llegar a la persona hay que contrastar la política de claves, las asignaciones en el gestor de secretos, los accesos al bastión, los tickets de cambio y, en su caso, las sesiones registradas. Ni el hecho de que una cuenta se llame `juan` ni que una clave tenga ese comentario bastan para atribuir una acción a alguien.

Los identificadores numéricos ayudan a estudiar esta separación. El UID identifica la cuenta en un espacio de nombres de usuarios concreto; el GID y los grupos suplementarios intervienen en decisiones de acceso; el UID efectivo de un proceso puede diferir del real. Las capas de contenedores y *user namespaces* pueden traducir los valores que ve un proceso dentro del contenedor a otros en el anfitrión. Una investigación que relacione ficheros de volúmenes compartidos con procesos de contenedor debe registrar el mapeo de identidades, no solo sus números aparentes.

9.4.2. 3.2. Cuentas locales y directorios de identidad

Los archivos `/etc/passwd` y `/etc/group` proporcionan información fundamental sobre cuentas locales, UIDs, directorios personales, shells y pertenencia a grupos. En distribuciones con autenticación local mediante contraseñas, `/etc/shadow` contiene información sensible sobre los mecanismos de autenticación y estados de las cuentas. Debe protegerse como evidencia especialmente confidencial; no se necesita incluir hashes de contraseñas completos en el cuerpo del informe para explicar que una cuenta estaba habilitada o bloqueada.

```
# Fragmento FICTICIO de /etc/passwd
root:x:0:0:root:/root:/bin/bash
deploy:x:1002:1002:Deploy service:/home/deploy:/bin/bash
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
```

El campo `x` no es una contraseña, sino una referencia al mecanismo de almacenamiento de credenciales utilizado en ese esquema. Una shell de tipo `nologin` limita ciertas formas convencionales de acceso, pero no demuestra que la cuenta jamás pueda originar un proceso. `www-data` puede ejecutar servicios, scripts o procesos con sus permisos incluso aunque no tenga inicio de sesión interactivo. Un UID muy alto, una descripción anómala o una cuenta sin password local no son por sí solos indicadores de actividad maliciosa.

Para identificar cuentas creadas o modificadas durante el intervalo investigado, conviene comparar una copia del sistema afectado con una imagen o copia histórica fiable, registros administrativos y datos del gestor de identidades. Las marcas temporales del archivo `/etc/passwd` pueden reflejar escrituras masivas o instalación de paquetes, no la fecha de alta de una cuenta específica. Los eventos de cambio en `auditd`, el gestor de configuración y un ticket de administración proporcionan contexto más preciso si fueron conservados.

En instalaciones con LDAP, SSSD, Kerberos u otros proveedores, la cuenta resuelta en una sesión no tiene por qué aparecer en `/etc/passwd`. Los ficheros `/etc/nsswitch.conf`,

las configuraciones de SSSD y PAM, las reglas de acceso de identidad y los registros del controlador correspondiente ayudan a reconstruir la fuente de identidad. El analista debe explicar si examina solo identidades locales o si ha podido incluir la información del directorio externo.

9.4.3. 3.3. Propietarios, permisos, ACL y capacidades

Los permisos POSIX combinan propietario, grupo y bits para usuario, grupo y otros, además de bits especiales como setuid, setgid y sticky. En muchos sistemas las ACL permiten reglas más detalladas. Los atributos extendidos pueden almacenar etiquetas de seguridad, metadatos de aplicaciones y capacidades. No basta con ejecutar `ls -l` y concluir que un usuario podía o no podía acceder: hay que considerar la ruta completa, los permisos de búsqueda en sus directorios, la ACL, la identidad efectiva, los grupos y políticas de control obligatorio como SELinux o AppArmor.

Un archivo con propietario `root` puede haber sido creado por un proceso de servicio autorizado, por `sudo`, por un script de despliegue o por alguien que consiguió privilegios. La propiedad indica el estado atribuido al objeto en el momento de su observación, no la autoría. Además, los propietarios pueden alterarse con herramientas administrativas y mediante restauraciones de copias. Una irregularidad es una pregunta para investigar, no una conclusión lista para firmar.

En un **laboratorio de copias** pueden inspeccionarse permisos y ACL de forma sencilla:

```
stat -c '%n%u:%g%a%s%y%z' /caso/raiz/usr/local/bin/monitor
getfacl -p /caso/raiz/usr/local/bin/monitor
getcap /caso/raiz/usr/local/bin/monitor 2>/dev/null
```

Si la evidencia está exportada sobre otro sistema de archivos, `getcap` o la ACL extraída podrían no representar los atributos originales. La documentación del método de copia es tan importante como la salida. En adquisiciones completas se preferirá comprobar los atributos desde una vista que respete la semántica del volumen investigado y anotar qué valores proceden de metadatos de la imagen y cuáles de una exportación transformada.

9.4.4. 3.4. SSH: configuración efectiva y ficheros autorizados

El acceso SSH suele depender de `/etc/ssh/sshd_config`, fragmentos de `sshd_config.d`, políticas PAM, claves de host y configuraciones por cuenta. OpenSSH permite `Include`, bloques `Match`, opciones de autenticación y ubicaciones personalizadas de claves autorizadas. Una lectura superficial de una única línea puede conducir a una conclusión incorrecta.

El informe debe identificar el archivo de origen y si se logró reconstruir la configuración efectiva en el momento relevante.

Las rutas tradicionales `~/.ssh/authorized_keys` y `~/.ssh/authorized_keys2` son posibles ubicaciones, pero `AuthorizedKeysFile` puede redirigirlas y `AuthorizedKeysCommand` obtenerlas mediante un programa externo. Una clave ausente del directorio personal no descarta que un usuario estuviese autorizado a entrar. A la inversa, encontrar una clave en un archivo no prueba que se aceptase en un momento concreto: puede haberse instalado después, la política podía haberla restringido o el usuario podía estar bloqueado por otras condiciones.

Un registro forense de `authorized_keys` debería anotar ruta real, propietario, permisos, contenido preservado, huella de clave pública calculada con un procedimiento validado, opciones que acompañan la clave y contexto de administración. Los comentarios de una clave son texto arbitrario, por lo que pueden ofrecer una pista útil sin constituir una identidad verificada. Opciones como `from=`, `command=`, restricciones de reenvío o certificados SSH pueden limitar qué operaciones permite la autenticación.

```
# Ejemplo de lectura y huella sobre COPIAS DE LABORATORIO:
sha256sum /caso/raiz/home/deploy/.ssh/authorized_keys
# Si la copia es una clave pública OpenSSH válida:
ssh-keygen -lf /caso/claves/deploy_ed25519.pub -E sha256
```

La huella de la clave y el hash del archivo son objetos distintos. El primero representa un identificador derivado de la clave pública según el formato y algoritmo utilizados; el segundo verifica los bytes completos del archivo, incluidos comentarios, espacios y otras claves. No deben mezclarse en una misma columna de «hash de evidencia» sin aclarar su naturaleza.

9.4.5. 3.5. De una conexión SSH a una sesión interactiva

Una conexión SSH puede utilizarse para abrir una terminal, ejecutar un comando remoto, transferir archivos por SFTP o canalizar tráfico. El hecho de que la cuenta se autenticase no garantiza que se abriese una shell; el log de apertura de sesión PAM aporta otro indicio, pero tampoco detalla necesariamente qué proceso realizó cada operación. Las sesiones multiplexadas, los comandos forzados y los bastiones pueden complicar la correspondencia entre conexiones y acciones.

Para una atribución técnica sólida se pueden correlacionar: registro `sshd` con IP y puerto, sesión PAM, línea `sudo`, evento de auditoría con `auid` y `ses`, actividad de archivos con ruta o inode, y registro de red del proceso cuando existe. Los PID por sí solos son peligrosos fuera de su contexto: pueden reutilizarse y deben interpretarse junto al arranque, el namespace y

el intervalo temporal. La coincidencia de PID en dos fechas no significa necesariamente que sea el mismo proceso.

En máquinas con registro de sesiones más detallado, herramientas de *session recording* pueden conservar el contenido de una terminal o eventos de entrada y salida. Esas grabaciones exigen autorizaciones, reglas de privacidad, integridad y controles de acceso; tampoco sustituyen a evidencias de resultado, porque un operador puede ejecutar una orden cuyo efecto falle o sea revertido.

9.4.6. 3.6. Uso de sudo y políticas de elevación

El fichero `/etc/sudoers` y los fragmentos de `/etc/sudoers.d/` pueden delegar órdenes a personas o grupos, a veces sin solicitud de contraseña. Deben interpretarse con la versión y sintaxis de `sudo` correspondientes y con los grupos resueltos por NSS. Una línea `NOPASSWD` es un indicador de política, no una prueba de que esa posibilidad fuese utilizada. Para demostrar uso interesa buscar entradas de `sudo`, procesos resultantes, cambios materiales y telemetría de auditoría.

Conviene diferenciar el usuario de origen, el usuario de destino y el proceso que se ejecuta. Si el log muestra que `deploy` lanzó una herramienta como `root`, el hecho demuestra una operación registrada bajo esa cuenta; no permite saltar directamente a la identidad humana de quien controló la sesión. También es importante el escenario inverso: un binario setuid, un servicio con capacidades amplias o un fallo de autorización puede generar ejecución privilegiada sin una línea de `sudo`.

Las políticas de control obligatorio completan el cuadro. SELinux puede bloquear acciones aun cuando los permisos POSIX parezcan suficientes; AppArmor puede imponer restricciones según perfil; un contenedor puede ejecutar `root` en su espacio de nombres sin tener los mismos privilegios que `root` en el anfitrión. La investigación debe considerar denegaciones, políticas efectivas y límites de namespace antes de concluir que una cuenta tenía capacidad real de modificar una ruta o abrir una conexión.

9.4.7. 3.7. Trazas de sesión frente a actividad atribuible

Una cuenta que se autentica y un servicio que ejecuta comandos durante el mismo minuto pueden estar relacionados o ser independientes. Para vincularlos hacen falta dependencias técnicas: mismo identificador de sesión, proceso hijo de una cadena observada, descriptor de fichero, conexión, ruta temporal creada por el proceso o concordancia de diversos registros. La proximidad temporal es una razón para investigar, no una garantía de causalidad.

Considérese el siguiente razonamiento hipotético. `deploy` inicia sesión a las 09:14; a las 09:16 se modifica `/etc/systemd/system/health-sync.service`; a las 09:17 aparece un `systemctl daemon-reload` en un evento auditado con el mismo `auid`. Esa combinación permite sostener con más fuerza una relación entre la sesión y la operación. Si únicamente existieran la conexión y el tiempo de modificación del archivo, la conclusión tendría que ser mucho más modesta: coexistencia temporal, no autoría probada.

La comparación debe incorporar información favorable a hipótesis legítimas: ventanas de mantenimiento, cambios en Ansible o Puppet, despliegues CI/CD, actualizaciones de paquetes, recuperación tras fallo o actividad de copias de seguridad. Excluir deliberadamente esas fuentes sería tan metodológicamente incorrecto como ignorar indicadores adversos. Una investigación no sirve para confirmar la primera sospecha, sino para determinar qué explicación resiste mejor la evidencia disponible.

9.4.8. 3.8. Identidades compartidas, secretos y claves de servicio

Las cuentas compartidas complican el análisis porque el sistema puede carecer de información individual. Un bastión con autenticación nominativa, un gestor de secretos, un sistema de aprobación y los registros de MFA permiten reconstruir el itinerario de una persona hasta una cuenta técnica; la ausencia de esos controles reduce la fuerza de la atribución. El profesional debe describir la deficiencia estructural, pero no suplirla suponiendo que el titular nominal de una credencial la utilizó.

Las claves privadas SSH son material altamente sensible. Durante la adquisición pueden ser relevantes para determinar cómo se administraba el sistema, pero copiarlas o examinarlas requiere alcance específico y protección reforzada. Un informe no debe reproducir una clave privada ni tokens de servicio salvo que una obligación concreta y autorizada lo haga estrictamente necesario. Los valores secretos pueden registrarse mediante identificadores, huellas o referencias a anexos protegidos.

Una organización puede rotar claves durante la respuesta a incidentes. Esa rotación es una actuación legítima, pero altera archivos, accesos y telemetría. El equipo de respuesta debe coordinar la preservación previa o contemporánea del estado, registrar fecha, responsable, credenciales afectadas y fuentes externas. No se debe frustrar la contención necesaria solo para mantener una escena aparentemente intacta; tampoco debe presentarse el estado después de la rotación como si fuese el estado previo al incidente.

9.4.9. 3.9. La identidad del proceso y su contexto de seguridad

Además del usuario, todo proceso posee un contexto: UID real y efectivo, grupos, capacidades, namespace, directorio de trabajo, variables de entorno, descriptores, ejecutable y cadenas padre-hijo. En vivo, parte de ese contexto puede consultarse mediante `/proc`, `ps` y herramientas de observación; fuera de línea, se reconstruye mediante memoria, eventos audit, archivos de configuración y artefactos de ejecución. Ninguna de estas vistas por separado cubre todos los procesos históricos.

La cadena padre-hijo puede ayudar a evaluar si una sesión SSH lanzó un shell y después una utilidad, pero está sujeta a procesos que terminan, se independizan o cambian de propietario. Un servicio gestionado por `systemd` puede iniciar procesos hijos sin que un usuario haya iniciado sesión; un atacante también podría intentar simular nombres legítimos. La atribución requiere examinar el ejecutable, su hash, ruta, permisos, unidad o sesión y trazas externas.

En un informe conviene separar «el proceso se ejecutó con UID efectivo 0» de «una persona obtuvo privilegios administrativos». La primera afirmación podría estar apoyada por un evento de auditoría o un volcado de memoria. La segunda necesita reconstruir el mecanismo de acceso, el control de la sesión y alternativas como servicios automatizados. Esa prudencia no debilita la prueba; hace explícito su alcance.

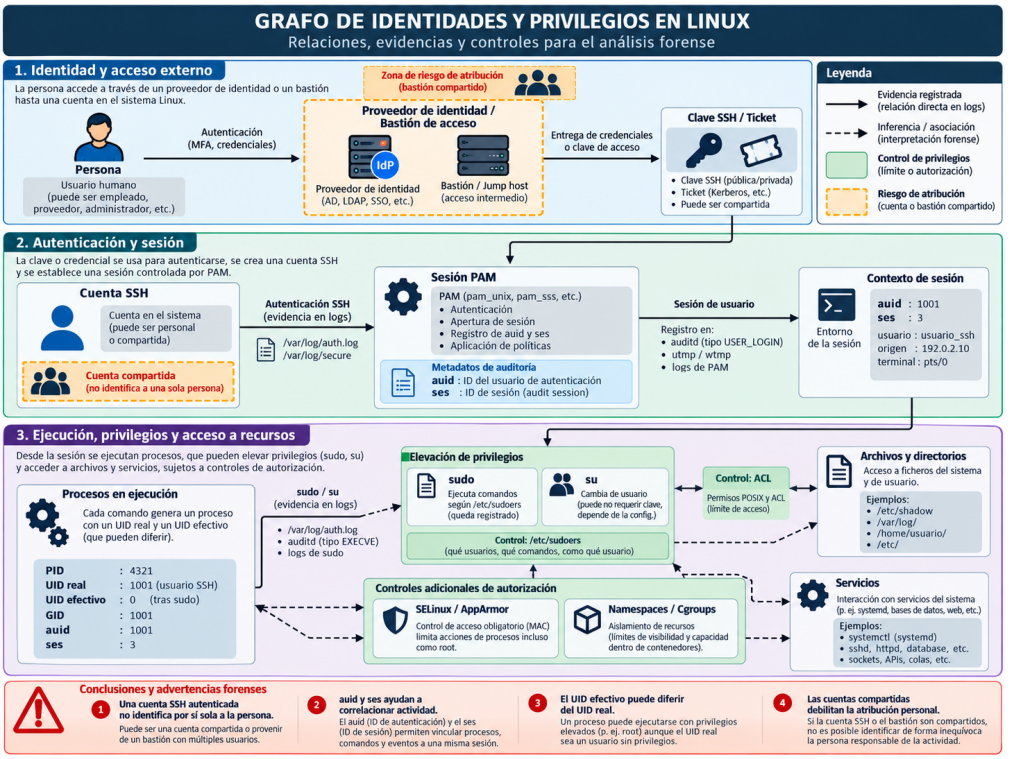


Figura 49: Grafo de identidades, sesiones y privilegios

9.4.10. 3.10. Matriz de fuerza de atribución

Una matriz sencilla facilita no sobreinterpretar la evidencia:

Observación	Afirmación apoyada	Afirmación que aún no permite
Entrada en `/etc/passwd`	Existía una cuenta local en el estado examinado	Que iniciara sesión en el periodo
Clave en `authorized_keys`	Había una clave configurada en ese archivo	Que se usara o quién la poseía
`Accepted publickey`	Se aceptó autenticación de esa cuenta en esa conexión	Que la usó una persona identificada
Inicio de sesión PAM	Se registró una sesión para un servicio y cuenta	Que fuese interactiva o ejecutara cierto comando

Observación	Afirmación apoyada	Afirmación que aún no permite
Línea `sudo`	Se solicitó o registró ejecución privilegiada según su semántica	Que todos los efectos de la orden se completaron
`auditd` con `auid` y `exe`	Se registró una acción técnica vinculada a contexto auditado	Autoría humana sin corroboración adicional
Archivo propiedad de `root`	El objeto tiene ese propietario en el estado observado	Que `root` lo creó manualmente
Bastión nominativo + sesión + audit	Vínculo más fuerte entre acceso y operaciones	Intención subjetiva o exclusividad absoluta de control

La tabla no constituye una escala numérica universal de certeza. La fiabilidad depende de cómo se configuró cada fuente, de su independencia, de la sincronización temporal y de si los registros han sido preservados. Un perito puede expresar un grado cualitativo de apoyo y sus fundamentos, pero no debe inventar porcentajes de probabilidad que no provengan de un modelo validado.

9.5. 4. Historial de comandos y actividad de procesos

9.5.1. 4.1. Qué conserva realmente un historial de shell

El historial de órdenes es un artefacto atractivo porque contiene texto que se parece a las acciones de un operador. Esa apariencia conduce a errores si no se entiende cómo se genera. Bash mantiene en memoria una lista de comandos de determinadas sesiones interactivas y, según la configuración, la escribe en un archivo al terminar o en otros momentos. Las variables `HISTFILE`, `HISTSIZE`, `HISTFILESIZE`, `HISTCONTROL`, `HISTIGNORE` y las opciones `histappend` o la política de sincronización influyen en qué aparece y cuándo. Una sesión todavía abierta puede tener comandos que no se han volcado; varias sesiones concurrentes pueden escribir el historial en distinto orden; y los comandos ejecutados mediante scripts o procesos no interactivos suelen quedar fuera del mecanismo habitual.

Por tanto, un `.bash_history` no constituye una grabación íntegra de la terminal. Puede contener comandos introducidos que fallaron, cadenas que no se ejecutaron como esperaba el usuario, duplicados, omisiones legítimas y anotaciones temporales incompletas. Su contenido también puede modificarse con permisos suficientes. Para la investigación es un indicio valioso, especialmente si se correlaciona con logs y cambios en el sistema de archivos, pero resulta metodológicamente inaceptable afirmar «estos fueron todos los comandos del atacante» a partir de una sola copia.

Los historiales de Zsh, Fish y otros shells tienen formatos y reglas propios; algunas herramientas de administración remota ejecutan directamente comandos sin shell interactiva; las aplicaciones en contenedores pueden guardar configuraciones en capas efímeras. El inventario inicial debe localizar qué shells usaban las cuentas, qué rutas se configuraron para sus historiales y si la actividad pudo producirse a través de otro mecanismo.

9.5.2. 4.2. Semántica de `HISTTIMEFORMAT` y las fechas asociadas

En Bash, cuando se guardan marcas temporales, el archivo de historial puede contener líneas que comienzan por # seguido de un entero que representa segundos desde la época Unix, asociadas al comando posterior. La presencia del carácter # no es suficiente: hay que validar la estructura y el comportamiento de la versión. Un archivo sin tales líneas no proporciona marcas temporales de ejecución individuales. La fecha de modificación del `.bash_history` suele indicar una operación sobre el archivo, no el instante de cada una de las órdenes que contiene.

Ejemplo sintético:

```
#1789549980
id
#1789550040
sudo systemctl status nginx
#1789550100
ls -la /srv/app
```

Los valores anteriores son **datos de ejemplo**, no registros de un caso real. Deben convertirse con un método reproducible y documentando su origen, pero no permiten concluir que las órdenes terminaron correctamente ni que el reloj estaba sincronizado. Si una sesión Bash guardó todo el historial al cerrar, el fichero pudo modificarse después del periodo en el que se introdujeron sus comandos. Además, `HISTTIMEFORMAT` puede afectar a la presentación que muestra `history` sin que todas las entradas antiguas tengan una hora válida conservada.

La investigación debe evaluar posibles huecos provocados por filtros de historial. `HISTCONTROL=ignorespace`, por ejemplo, puede omitir determinadas órdenes introducidas con espacio inicial. `HISTIGNORE` y otros ajustes pueden excluir patrones. La ausencia de un comando no prueba que se ocultase deliberadamente: también puede haber terminado una sesión sin guardar, ejecutado una tarea no interactiva o perdido el archivo durante un reinicio o despliegue.

9.5.3. 4.3. Búsqueda y conservación de historiales

Cuando la autorización cubre el examen de perfiles, se pueden identificar historiales habituales en `/home` y `/root`, incluidos ficheros ocultos. La operación debe conservar también sus metadatos originales y el contexto de la cuenta. En una copia de laboratorio:

```
find /caso/raiz/home /caso/raiz/root -type f \
  \( -name '.bash_history' -o -name '.zsh_history' \
     -o -name 'fish_history' \) -print 2>/dev/null

sha256sum /caso/raiz/home/deploy/.bash_history
stat /caso/raiz/home/deploy/.bash_history
```

Los nombres de usuario y los perfiles pueden estar fuera de `/home`, y el shell puede usar rutas definidas por variables de entorno. Un `find` que no devuelve nada es solo un resultado para las rutas exploradas y con los permisos de consulta disponibles. Los archivos borrados podrían requerir examen de metadatos o espacio no asignado, y los historiales dentro de contenedores pueden encontrarse en volúmenes o capas distintas.

Es preferible generar una copia forense de cada historial que se vaya a procesar, registrar hash y utilizar parsers contrastados en lugar de modificarlo para añadir fechas o eliminar líneas. Si se crean tablas derivadas, se debe conservar la línea de entrada, el parser y la transformación temporal aplicada. En informes conviene mostrar un extracto relevante, no reproducir indiscriminadamente conversaciones, secretos o comandos ajenos al ámbito autorizado.

9.5.4. 4.4. Procesos en ejecución: la observación tiene fecha

Mientras una máquina está encendida, el núcleo mantiene información de procesos y tareas que puede consultarse mediante `/proc`, `ps`, `pstree`, `top`, `ss` y utilidades semejantes. Una fotografía de procesos permite responder qué estaba ejecutándose en un instante, con

qué PID, UID, argumentos visibles, recursos y conexiones. No es una reconstrucción retrospectiva automática. Además, las observaciones se generan dentro de un sistema que puede estar comprometido: una herramienta ejecutada localmente puede recibir información modificada por un *rootkit* o quedar fuera de un namespace que no esté observando.

En un servidor crítico puede justificarse una adquisición en vivo porque apagarlo destruiría conexiones, claves en memoria, procesos efímeros o datos cifrados accesibles solo durante la sesión. Esa decisión debe adoptarse dentro del alcance aprobado y documentando el efecto de las herramientas. Leer `/proc` no equivale a no alterar nada; el propio proceso de adquisición consume recursos, genera eventos y puede afectar la temporización de otros procesos.

```
# CONSULTAS ÚNICAMENTE EN UN LABORATORIO O SISTEMA VIVO AUTORIZADO.
ps -eo pid,ppid,uid,euid,lstart,etime,cmd --sort=pid
pstree -ap
ss -tupna
readlink /proc/1234/exe
tr '\0' ' ' < /proc/1234/cmdline
```

El PID `1234` es ilustrativo. La visibilidad dependerá de privilegios, restricciones del núcleo y namespaces; un proceso puede desaparecer entre dos órdenes. La salida `cmdline` puede ser alterada por el propio proceso o contener argumentos que se hayan sobrescrito; no es una prueba absolutamente fiable del origen de un ejecutable. La ruta a través de `/proc/<pid>/exe` puede mostrar un binario ya eliminado del sistema de archivos, lo que resulta relevante, pero requiere preservar el dato antes de que termine el proceso y corroborarlo con memoria o la adquisición correspondiente.

9.5.5. 4.5. Procesos históricos: cuándo existe prueba de ejecución

Tras finalizar un proceso, sus estructuras efímeras desaparecen o se reutilizan. Para reconstruirlo se necesitan fuentes que registraron la operación antes de que terminase: auditoría de `execve`, telemetría EDR, registros del servicio, supervisor o plataforma de orquestación, contabilidad de procesos cuando esté habilitada o efectos materiales compatibles. Un archivo ejecutable presente en `/usr/local/bin` no demuestra que se ejecutase. Un mensaje de unidad `systemd` que anuncia un inicio sí aporta evidencia de activación de servicio, pero la aplicación pudo fallar antes de realizar su trabajo.

Un registro audit con SYSCALL y EXECVE puede apoyar con fuerza que se produjo una llamada de ejecución, si la regla cubría ese proceso y la captura es íntegra. La carga de parámetros puede aparecer truncada, codificada o distribuida entre registros; la traducción de IDs y rutas puede necesitar contexto. Además, `execve` satisfactoria no implica que un archivo

remoto fuese transferido después. Para ello se precisan efectos observables o fuentes de red y aplicación.

A nivel operativo, la pregunta «¿se ejecutó `curl`?» debe separarse de «¿se completó una descarga?» y de «¿se envió contenido confidencial?». El primer extremo podría estar apoyado por un evento de proceso, el segundo por archivo creado, log de aplicación y resultado de red; el tercero requiere identificar contenido, destino, volumen transferido y confirmación del receptor cuando sea posible. Saltarse pasos produce atribuciones y conclusiones inestables.

9.5.6. 4.6. Archivos ejecutables, paquetes y modificaciones del sistema

El inventario de software instalado ayuda a explicar por qué existen ciertos binarios o unidades. En Debian y Ubuntu, el estado de paquetes `dpkg` y los archivos de registro de APT pueden conservar indicios de instalación y actualización. En sistemas de la familia RHEL, gestores como RPM y DNF aportan otras fuentes. Esas bases pueden mostrar instalación o actualización, pero no deben confundirse con ejecución. La fecha de un paquete puede estar relacionada con una imagen preparada previamente y no con una intervención reciente en el servidor.

La comparación con una imagen base confiable puede revelar binarios nuevos, permisos cambiados, propietarios inusuales o unidades no autorizadas. Los hashes de ficheros ayudan a comparar bytes, aunque una diferencia respecto a un paquete oficial requiere contextualizar versión, compilación y modificaciones legítimas. Se deben evitar comprobaciones que sustituyan la evidencia por una versión recién descargada sin documentar la procedencia. Un ejecutable puede ser legítimo y utilizarse de forma abusiva; una herramienta administrativa común no se convierte en malware por aparecer en una hipótesis de ataque.

El analista necesita distinguir **origen**, **instalación**, **ejecución** y **resultado**. Un registro de gestor de paquetes ayuda en la segunda categoría; un evento `execve` en la tercera; una conexión de salida y la escritura de un archivo pueden pertenecer a la cuarta. La correlación se documenta para evitar convertir una lista de hallazgos heterogéneos en un relato causal sin respaldo.

9.5.7. 4.7. Ficheros temporales y directorios de trabajo

Las rutas `/tmp`, `/var/tmp` y `/dev/shm` suelen aparecer en investigaciones porque pueden contener scripts de mantenimiento, ficheros extraídos, paquetes incompletos y artefactos de procesos. También son habituales en operaciones legítimas. Los permisos, montajes

`tmpfs`, políticas de limpieza, temporizadores de eliminación y reinicios condicionan su conservación. Que un directorio esté vacío al adquirirlo no demuestra que nunca haya contenido archivos relevantes.

Los directorios de trabajo pueden mantener archivos con nombres aleatorios, archivos que fueron renombrados y artefactos eliminados que siguen abiertos por un proceso. En vivo, `/proc/<pid>/fd/` puede revelar descriptores abiertos, y el enlace al archivo eliminado puede mostrar la indicación correspondiente; tras apagar o cerrar el descriptor puede perderse esa oportunidad. Por ello debe considerarse la posibilidad de una captura dirigida de memoria o de archivos abiertos cuando la volatilidad y la proporcionalidad lo justifiquen.

Los archivos temporales se interpretan también por sus relaciones con otros objetos: nombre, tamaño, firma, hashes, permisos, inode, propietario y cercanía temporal a registros de proceso. Un fichero llamado `backup.tar.gz` podría ser una copia legítima, un artefacto de despliegue o un paquete creado para extraer información. Ninguna de esas hipótesis puede decidirse solo por la extensión.

9.5.8. 4.8. Historial de red y conexiones de procesos

El análisis de procesos debe relacionarse con las conexiones de red, pero una tabla de sockets obtenida en un instante no registra automáticamente todas las conexiones pasadas. `ss` informa del estado observable en el momento de consulta; si una conexión duró unos segundos y terminó antes, podría no aparecer. Un log de firewall o proxy puede aportar la comunicación histórica, pero tampoco identifica siempre el proceso de origen si no existía instrumentación adicional.

El investigador debería correlacionar, cuando sea posible, el comando o servicio, su cuenta efectiva, el destino IP, los puertos, la resolución DNS, el nombre de dominio y los registros del receptor. La presencia de una conexión TLS no permite ver el contenido cifrado sin fuentes adicionales; el volumen de bytes transferidos puede no corresponder al tamaño de un archivo lógico si hubo compresión, reintentos o transferencias parciales. La conclusión debe expresar aquello que realmente mide cada origen.

Para un servidor con tráfico sospechoso, pueden ser relevantes PCAP, registros NetFlow/IPFIX, DNS, balanceadores, WAF, EDR, proxy y proveedor cloud. La instrumentación de red debe figurar en el inventario de fuentes y su ausencia en la sección de limitaciones. Una captura de memoria puede conservar sockets y estructuras relacionadas, aunque su análisis depende de versión de núcleo, símbolos y estado en el momento de captura.

9.5.9. 4.9. Cronologías de operaciones y marcas temporales

Los tiempos de acceso, modificación, cambio de metadatos y creación —cuando el sistema de archivos los admite— describen estados técnicos de archivos. El tiempo de cambio de inode (`ctime`) no equivale al de creación, y el tiempo de acceso puede actualizarse de forma diferida, reducirse por opciones de montaje o no actualizarse conforme a la expectativa del analista. En ext4 existen detalles adicionales sobre marcas de nacimiento según implementación y herramientas; no todos los sistemas ni APIs exponen la misma información.

La correlación entre el historial de Bash, la modificación de una unidad, una salida de `auditd` y una conexión saliente requiere normalización temporal y comparación de precisión. Un evento de auditoría con hora a milisegundos puede coexistir con una marca `mtime` expuesta al segundo en una exportación textual. Ese segundo no demuestra el orden interno de operaciones ocurridas a pocos milisegundos. En lugar de imponer un relato secuencial, el analista puede representar intervalos y declarar que el orden de dos hechos no se establece con las fuentes disponibles.

9.5.10. 4.10. Un ejemplo de interpretación gradual

Supongamos que se recupera de un historial la orden `tar -czf /tmp/revision.tar.gz /srv/app/exportaciones`, y que un registro auditado del sistema refleja ejecución de `tar` en una ventana compatible. La coincidencia apoya que el comando pudo ejecutarse bajo una cuenta, pero todavía debe comprobarse si el archivo se creó, si su contenido corresponde a la carpeta, si estaba completo y quién podía acceder. Un error de permisos, una ruta inexistente o una interrupción pueden hacer que el resultado difiera de lo esperado.

Si además existe una entrada de `curl` en un log auditado, no puede concluirse inmediatamente que `revision.tar.gz` fuese enviado por la red. Se necesitarían parámetros de ejecución interpretados correctamente, datos de destino, registros de transferencia o una copia en el receptor. La propia secuencia podría corresponder a una tarea programada de respaldo legítimo. Las conclusiones se construyen por escalones: existencia de la orden, posible ejecución, resultado local y, solo si está corroborado, transferencia externa.

9.5.11. 4.11. Automatización de extracción y necesidad de revisión

Es útil automatizar la enumeración de historiales, unidades, registros y metadatos, pero el automatismo no elimina las limitaciones de origen. Un script que encuentre todas las líneas con `curl` solo recupera coincidencias textuales; no entiende por sí mismo si una cadena

formaba parte de un comentario, si un comando fue ejecutado en un contenedor o si el binario se invocó bajo otro nombre. La salida debe convertirse en una tabla de indicios con referencias verificables a los datos fuente.

Las ejecuciones de scripts deben quedar registradas con versión, entradas, hashes, parámetros, entorno y errores. Una corrección de un parser o una nueva versión de herramienta debe generar resultados nuevos sin sobrescribir los anteriores. Esta disciplina permite revisar cómo se obtuvo un hallazgo y evita que una extracción automatizada adquiera falsa apariencia de certeza simplemente porque se presenta en una tabla pulida.

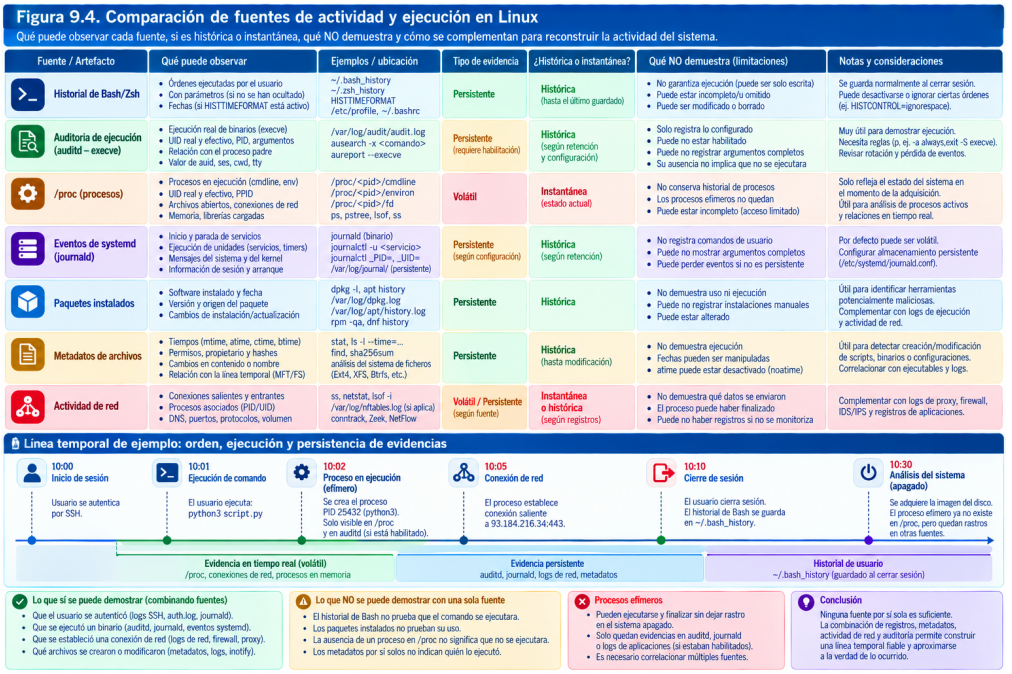


Figura 50: Historial de comandos y artefactos de ejecución

9.6. 5. Servicios, tareas programadas y persistencia

9.6.1. 5.1. Persistencia como capacidad, no como prueba automática de abuso

En seguridad se denomina persistencia a los mecanismos que permiten mantener acceso o ejecutar operaciones a lo largo del tiempo, por ejemplo tras un reinicio. En un servidor Linux, esa función existe también para fines legítimos: los servicios deben arrancar automáticamente, las tareas de mantenimiento se programan y las aplicaciones registran compo-

nentes para trabajar en segundo plano. Que un archivo de unidad, una entrada cron o una clave SSH permita ejecución recurrente no convierte a su autor en atacante. La investigación debe determinar si la configuración pertenecía al diseño autorizado, si fue modificada, qué acciones posibilitaba y qué evidencias existen de ejecución real.

Una revisión centrada únicamente en `/etc/rc.local` o en `crontab -l` sería insuficiente. Los mecanismos modernos incluyen unidades y temporizadores `systemd`, sockets, rutas observadas, servicios de usuario, gestores de procesos de aplicaciones, scripts de inicio de shell, contenedores con política de reinicio, hooks de gestores de paquetes y automatizaciones externas. La selección depende del contexto: un servidor de base de datos, un nodo Kubernetes y una estación de desarrollo tienen superficies de persistencia diferentes.

El objetivo no es ejecutar una lista universal de comandos hasta encontrar un nombre extraño, sino reconstruir **qué disparador** existía, **qué acción** pretendía realizar, **con qué identidad y privilegios**, **qué evidencias demuestran que se activó** y **qué cambió como resultado**. Esa estructura es igualmente útil para descartar alertas causadas por tareas aprobadas.

9.6.2. 5.2. Unidades `systemd`: ubicación, definición y estado

`systemd` gestiona unidades de tipo `service`, `timer`, `socket`, `path`, `mount` y otros, con reglas de activación y dependencia. Una unidad puede definirse en ubicaciones de proveedor como `/usr/lib/systemd/system/` o `/lib/systemd/system/`, y recibir configuraciones administradas localmente en `/etc/systemd/system/`. También existen unidades y modificaciones durante el arranque bajo `/run/systemd/system/`, que pueden no persistir tras apagar. Los directorios de *drop-ins* con sufijo `.d` permiten añadir o sustituir propiedades; una lectura aislada del archivo principal puede ignorar la configuración que realmente prevalecía.

Para una unidad sospechosa, interesa conservar archivo base, fragmentos, enlaces de habilitación, dependencias, permisos, metadatos, logs y el ejecutable apuntado por `ExecStart`. Las órdenes `systemctl status` y `systemctl cat` son útiles en un entorno de prueba o consulta en vivo autorizada; una investigación offline debe reconstruir la precedencia desde la versión correspondiente de `systemd` y los archivos extraídos. Una unidad `enabled` puede no haberse iniciado; una unidad `active` es un estado observado en un instante y no acredita que toda su función se ejecutase con éxito.

```
# EJEMPLO FICTICIO: /etc/systemd/system/health-sync.service
[Unit]
Description=Health synchronization helper
```

```
After=network-online.target

[Service]
Type=oneshot
User=root
ExecStart=/usr/local/libexec/health-sync.sh

[Install]
WantedBy=multi-user.target
```

La apariencia del nombre `health-sync` no informa de la legitimidad del servicio. Para valorar el ejemplo habría que examinar el script, verificar si el paquete o el inventario corporativo lo contemplan, revisar hashes, propietario, permisos, momento de instalación, *drop-ins*, enlaces habilitadores y logs de activación. También es necesario contemplar el contexto: un sistema de monitorización podría utilizar legítimamente una unidad con ese nombre, mientras que un atacante podría adoptar nombres similares a componentes operativos.

En el análisis de enlaces simbólicos, un enlace bajo `multi-user.target.wants/` puede reflejar habilitación de una unidad; no demuestra por sí mismo que se arrancara ni que siguiera vigente en la fecha del incidente. Una restauración del servidor, una imagen base o un cambio de versión pueden dejar enlaces antiguos. Los logs del servicio y la comparación con los despliegues autorizados son piezas indispensables.

9.6.3. 5.3. Temporizadores y activadores de `systemd`

Los temporizadores `*.timer` permiten activar unidades según calendario, tiempo transcurrido desde el arranque u otros criterios. Un `.timer` puede invocar una unidad `.service` con el mismo nombre o la especificada en su configuración. Para entender la persistencia se deben examinar ambos objetos; encontrar solo un temporizador y no seguir su servicio asociado deja incompleto el análisis.

Los activadores de tipo `.socket` pueden iniciar servicios cuando se reciben conexiones; los de tipo `.path` pueden reaccionar a cambios en rutas observadas. Por tanto, un proceso ausente en la captura de procesos puede tener un mecanismo dispuesto para aparecer cuando se produzca un evento futuro. Esta distinción es importante: la configuración **permite activación bajo condiciones**, pero no constituye un log retrospectivo de todas las activaciones.

En un laboratorio Linux con autorización se pueden observar las unidades y sus definiciones mediante:

```
systemctl list-unit-files --type=service,timer,socket,path
systemctl list-timers --all
systemctl cat health-sync.service
systemctl show health-sync.service -p FragmentPath -p DropInPaths -p
 ↪  UnitFileState
```

Estas consultas reflejan el host donde se ejecutan y no deben dirigirse inadvertidamente al sistema del analista cuando el objetivo es una imagen offline. Si se realiza la revisión sobre una copia, deberá recopilarse y parsearse la configuración sin confundir las unidades del laboratorio con las del servidor investigado. Las consultas en vivo pueden ser útiles para validar hipótesis, pero modifican el estado observable de logs y procesos y requieren documentación.

9.6.4. 5.4. Cron y la persistencia clásica

Los ficheros cron mantienen programaciones periódicas y siguen siendo importantes en muchas instalaciones. Deben revisarse, según la distribución, `/etc/crontab`, `/etc/cron.d/`, `/etc/cron.daily/`, `/etc/cron.hourly/`, `/etc/cron.weekly/`, directorios de spool de usuarios y las configuraciones del servicio instalado. El formato de las entradas del cron de sistema puede incluir una columna de usuario que no aparece en los crontabs individuales; interpretarlo mal conduce a atribuciones equivocadas.

```
# EJEMPLO FICTICIO de cron de sistema: minuto hora día mes semana
 ↪  usuario orden
*/15 * * * * root /usr/local/sbin/health-check --quiet
```

La existencia de la línea indica una intención de ejecución periódica, condicionada al funcionamiento del servicio cron y a la configuración. No acredita que la orden se ejecutara quince minutos después de cada hora ni que todas las ejecuciones se completaran. Los cambios de horario de verano, reinicios, errores de sintaxis, fallos de permisos y servicios deshabilitados pueden alterar la programación. La evidencia de activación puede encontrarse en logs de cron, salida redirigida, correo local, registros de aplicación o efectos sobre archivos.

Existen también mecanismos como `anacron`, trabajos `at` y programaciones específicas de paneles de control y orquestadores. El investigador debe conocer cuáles estaban instalados, no etiquetar como malicioso cualquier objeto del directorio de tareas y no excluir tareas por el mero hecho de que su nombre parezca administrativo.

9.6.5. 5.5. Servicios de usuario, shells y persistencia sin root

No toda persistencia requiere privilegios administrativos. Un usuario puede mantener unidades `systemd --user`, programaciones propias y mecanismos de inicio de sesión que ejecutan comandos cuando abre una shell. Directorios como `~/.config/systemd/user/` pueden contener unidades; configuraciones como `~/.bashrc`, `~/.profile`, `~/.zshrc` u otros archivos de inicio pueden contener operaciones automáticas legítimas o añadidas de forma abusiva. Su efecto depende de qué shell se inicia y en qué modo, por lo que no deben tratarse como disparadores universales.

El mecanismo de *lingering* de `systemd` puede permitir servicios de usuario sin que exista una sesión interactiva activa. Debe revisarse con la configuración y el estado correspondientes, no asumirlo por ver un archivo `.service` bajo el perfil. La atribución de esos servicios necesita registrar UID, identificador de unidad, ejecutable y logs. Una tarea creada en un perfil puede ejecutarse con otro contexto en caso de envoltorios, contenedores o cambios de privilegios.

Los directorios `~/.ssh/` ofrecen otra forma de acceso continuado: una clave pública autorizada puede facilitar futuras autenticaciones. Esto no es exactamente lo mismo que la ejecución automática de una tarea, pero sí puede contribuir a mantener una vía de acceso. Para evaluar su relevancia hay que examinar archivos de claves, configuraciones efectivas, fechas, registros de acceso y controles de autorización. Un cambio de clave durante una intervención puede tener explicación administrativa legítima.

9.6.6. 5.6. Mecanismos relacionados con servicios y bibliotecas

Algunas investigaciones requieren revisar configuraciones del cargador dinámico, variables de entorno de servicios, bibliotecas preinstaladas mediante configuración y scripts en rutas ejecutadas automáticamente. Cambios en `/etc/ld.so.preload`, en unidades que ajustan `Environment=` o en rutas de bibliotecas pueden alterar la ejecución de programas. Tales configuraciones tienen usos legítimos y deben investigarse por sus efectos, no etiquetarse automáticamente como rootkits.

La observación de binarios y bibliotecas requiere corroborar su origen, firmas cuando el sistema las emplee, hashes, versión de paquete, ubicación y procesos que las cargaron. Un fichero con nombre similar al de una biblioteca del sistema puede ser inocuo, sospechoso o una dependencia personalizada. En equipos con integridad medida, IMA/EVM o políticas de arranque verificadas, existen fuentes adicionales que ayudan a evaluar el estado, pero su presencia y alcance deben verificarse.

Otra superficie es la de los módulos del núcleo y parámetros que alteran la observación. Un módulo desconocido no equivale necesariamente a componente malicioso; puede pertenecer a un controlador. A la inversa, confiar exclusivamente en comandos del host bajo sospecha puede ocultar módulos o procesos manipulados. La comparación con memoria, discos, listas de paquetes y telemetría externa puede aportar mayor cobertura.

9.6.7. 5.7. Persistencia en contenedores y sistemas orquestados

Un servidor Linux puede ejecutar Docker, containerd, Podman o Kubernetes. En ese entorno, una política de reinicio o un despliegue gestionado por un orquestador puede recrear contenedores sin que exista un servicio del host con el nombre esperado. La persistencia puede residir en una imagen, una capa escribible, un volumen, una definición Compose, un manifiesto Kubernetes, un secreto o una tarea del plano de control. Las fuentes de evidencia incluyen tanto el anfitrión como la configuración del orquestador y sus registros.

La identidad y la ruta dentro de un contenedor no se trasladan automáticamente al anfitrión. Una ejecución de `/bin/sh` registrada dentro de un namespace necesita relacionarse con el ID del contenedor, su imagen, el pod, la cuenta de servicio y el nodo que lo hospedaba. Las imágenes de contenedor, los registros del runtime y las capas overlay deben conservarse con un procedimiento que no destruyera el estado relevante. Si el contenedor es efímero, la prioridad puede centrarse en exportar sus registros y metadatos antes de que se elimine.

No es apropiado concluir «no había persistencia» después de revisar solo `/etc/systemd/system` cuando el servicio investigado se administra desde Kubernetes. Tampoco debe tratarse cualquier pod que reinicia como prueba de reinfección: los reinicios pueden ser resultado de comprobaciones de salud, políticas de despliegue o fallos legítimos. La investigación ha de identificar el controlador responsable y las diferencias entre la configuración aprobada y la observada.

9.6.8. 5.8. Indicios de manipulación y antiforense

Una alteración deliberada podría intentar borrar historiales, reducir la retención de logs, modificar tiempos de archivos, deshabilitar auditoría, ocultar procesos o cambiar nombres de servicios. Sin embargo, la simple presencia de huecos, fechas extrañas o configuraciones mínimas no demuestra antiforense. La base pericial se fortalece cuando se identifica una acción técnica concreta, como un evento que registra un cambio de política, una comparación con la configuración previa o una discrepancia entre una fuente local y otra independiente.

En casos con privilegios elevados del posible intruso, deben contemplarse los límites de confianza de la fuente local. Los registros del kernel y los generados por servicios bajo control del anfitrión pueden manipularse en ciertas condiciones. Las copias remotas previamente recibidas, snapshots de infraestructura y sistemas de seguridad externos pueden servir de corroboración, siempre que su procedencia y custodia estén documentadas. La independencia de una fuente no se decide por estar en otro fichero, sino por el mecanismo y dominio de control que la produjo.

9.6.9. 5.9. Procedimiento para evaluar una unidad sospechosa

Supongamos que se encuentra `health-sync.service`. Una metodología proporcionada comenzaría por identificar qué pregunta pretende responder la investigación: ¿la unidad es autorizada?, ¿cuándo apareció?, ¿se activó?, ¿qué ejecutó?, ¿generó comunicaciones? A continuación se obtienen los archivos de configuración, enlaces y ejecutable desde la imagen, se registran hashes, versiones y metadatos, y se revisan registros del servicio y del gestor de cambios.

En un laboratorio de copias, la investigación puede iniciar con una búsqueda limitada:

```
find /caso/raiz/etc/systemd /caso/raiz/usr/lib/systemd \
  /caso/raiz/lib/systemd -type f \
  \( -name '*.service' -o -name '*.timer' -o -name '*.socket' \) \
  -print 2>/dev/null > /caso/derivados/unidades.txt

sha256sum /caso/raiz/etc/systemd/system/health-sync.service
```

Ese `find` puede incluir duplicados o excluir unidades dinámicas, montajes separados y configuraciones no adquiridas. Los enlaces simbólicos tampoco se representan como archivos regulares en una búsqueda con `-type f` si no se sigue su semántica. Es necesario analizar la estructura completa, incluidos *drop-ins* y enlaces, y documentar el alcance real de la búsqueda. La versión de `systemd` puede modificar opciones o precedencias; debe validarse el parser empleado.

Después se compara el script ejecutado con el inventario de paquetes, repositorios de despliegue y cambios aprobados. Se estudia si hubo ejecuciones con logs o audit, qué identidad tenía el proceso, qué ficheros creó y qué comunicaciones realizó. La conclusión posible depende de lo hallado: una «unidad presente y habilitada» es diferente de «unidad activada», y ambas son diferentes de «unidad utilizada para extraer datos».

9.6.10. 5.10. Matriz de persistencia y fuerza del hallazgo

Mecanismo	Fuente de configuración	Indicio de activación	Principal límite
Servicio `systemd`	Unidad, *drop-ins*, enlaces	Diario de servicio, procesos, audit	Habilitación no demuestra ejecución
Temporizador `systemd`	Archivo `.timer` y servicio asociado	Logs de activación, salidas, cambios	Programación no garantiza ejecución puntual
Cron de sistema	`/etc/crontab`, `/etc/cron.d/`	Logs cron, resultados, audit	Sintaxis, zona y servicio pueden alterar resultados
Cron de usuario	Spool de la distribución	Log y efectos bajo la cuenta	Sin acceso al spool no hay inventario completo
Servicio de usuario	`~/.config/systemd/user/`	Diario del usuario, procesos	La sesión y *lingering* condicionan arranque
Inicio de shell	`.bashrc`, `.profile`, otros	Historial, logs, efectos	No se aplica a todas las sesiones
Clave SSH adicional	Archivo o servicio de claves	Autenticaciones aceptadas, bastión	Clave presente no demuestra uso
Contenedor orquestado	Manifiestos, Compose, políticas	Eventos de runtime y plano de control	El estado de pod no equivale a ejecución maliciosa
Bibliotecas/configuración de carga	Archivos y variables de entorno	Procesos, mapas de memoria, audit	Presencia no implica carga real

La matriz debe actualizarse en función de la distribución y del sistema investigado. Su función no es enumerar todas las técnicas posibles, sino recordar que una conclusión de persistencia exige identificar **mecanismo**, **condición de activación**, **resultado observable** y **legitimidad de la configuración**. La existencia de una tarea desconocida justifica una investigación, pero la calificación de la conducta depende de hechos y autorización.

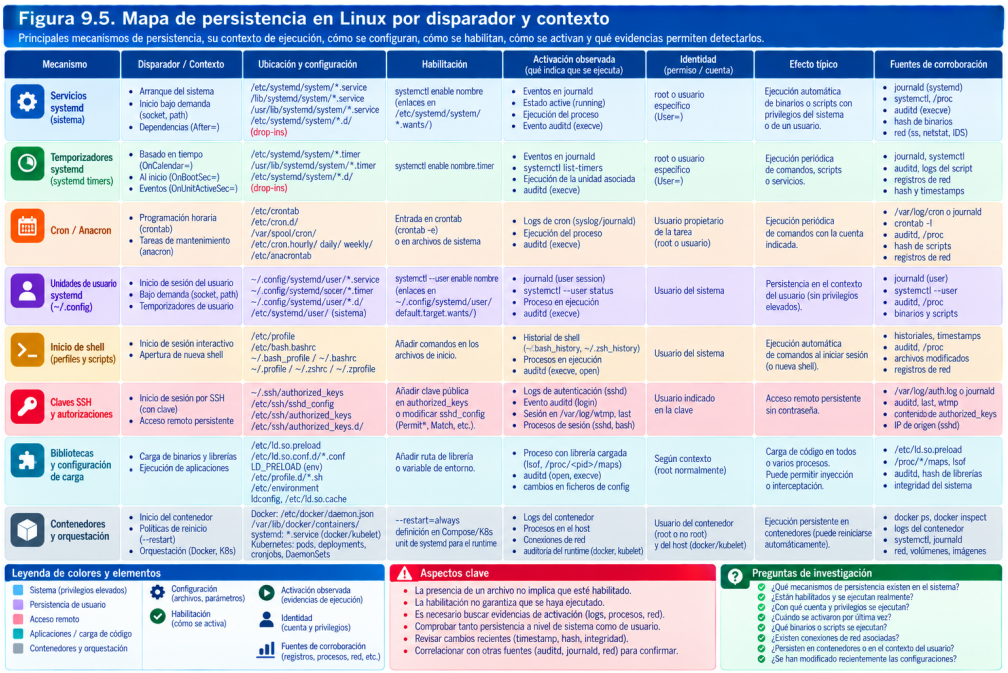


Figura 51: Mapa de persistencia en Linux

9.6.11. 5.11. Desde la anomalía hasta la hipótesis contrastable

Cuando aparece un servicio desconocido, un equipo apresurado puede concluir «se instaló un mecanismo de acceso persistente». El analista debe demostrar en cambio qué observó: un archivo de unidad fuera del inventario aprobado, un hash diferente de la versión de repositorio, una modificación en cierta fecha o un proceso correspondiente en un log. A partir de ahí, la hipótesis de persistencia no autorizada puede contrastarse con la historia de despliegues, la versión del paquete, las cuentas administrativas y la actividad del servicio.

Incluso si la unidad resulta no autorizada, el informe debe distinguir la existencia de un mecanismo de la persistencia efectivamente ejercida. La unidad pudo instalarse y nunca arrancar, pudo fallar al iniciarse, pudo ejecutarse parcialmente o pudo funcionar durante semanas. El nivel de apoyo de cada afirmación depende de logs, auditoría, archivos creados y comunicaciones. Conservar estas distinciones es esencial en un libro de análisis forense: la finalidad no es contar la historia más espectacular, sino la más justificable.

9.7. 6. Investigación práctica de un servidor Linux

9.7.1. 6.1. Planteamiento: acceso inusual y servicio desconocido

Una empresa dedicada a servicios de distribución detecta en su plataforma de monitorización conexiones salientes poco habituales desde un servidor Linux expuesto a Internet. El sistema, denominado `web-prod-02`, aloja una aplicación web y ejecuta tareas programadas de despliegue. El equipo de respuesta observa también un acceso SSH desde una dirección que no reconoce y una unidad `systemd` que no aparece en el inventario de cambios. La dirección técnica de la empresa solicita esclarecer si hubo un acceso no autorizado, si se alteró el servidor, si existe un mecanismo de ejecución recurrente y si salieron datos de la aplicación.

El caso es **ficticio**. Se utilizan nombres, horas, rutas y direcciones de documentación; no representan un incidente conocido ni registros obtenidos de un tercero. Las líneas de ejemplo han sido simplificadas para facilitar su lectura. Su finalidad consiste en practicar la transformación de fuentes heterogéneas en hallazgos defendibles, no en enseñar un conjunto de indicadores que siempre tengan el mismo significado.

El servidor funciona sobre Ubuntu Server en una máquina virtual gestionada por infraestructura corporativa. Utiliza `systemd`, OpenSSH y Nginx, mantiene parte del diario de forma persistente y envía determinados eventos al SIEM. `auditd` estaba instalado, pero solo algunas reglas relacionadas con cambios críticos y ejecución habían sido activadas. Se conoce una ventana de mantenimiento programada para actualizaciones, aunque no hay una autorización registrada para instalar la nueva unidad. El servidor continúa prestando servicio y su interrupción tendría impacto comercial.

Las preguntas iniciales se formulan por separado: ¿se aceptó una autenticación desde la IP inusual?, ¿qué cuenta se utilizó?, ¿la actividad tenía respaldo en un procedimiento autorizado?, ¿cuándo apareció `health-sync.service`?, ¿se activó y qué ejecutó?, ¿se creó un archivo de datos?, ¿hubo una comunicación saliente?, ¿puede relacionarse esa comunicación con una entrega de contenido? Si la respuesta a las primeras preguntas es afirmativa, ello no resuelve automáticamente las últimas.

9.7.2. 6.2. Alcance, autorización y medidas de preservación

El encargo permite investigar la máquina virtual, los registros del servicio y del perímetro de red correspondientes a un periodo de cuarenta y ocho horas alrededor de la alerta. Autoriza recopilar configuración, diario, registros audit, imágenes del almacenamiento pertinente, metadatos de la máquina y telemetría del firewall. Una ampliación para acceder a datos de

clientes, al receptor remoto o a cuentas personales requeriría autorización adicional. El equipo legal y el responsable de protección de datos deben revisar las necesidades concretas cuando los resultados contengan información de terceros.

La intervención se planifica con dos responsables diferenciados: operaciones mantiene la continuidad y ejecuta las medidas de contención autorizadas; el equipo forense preserva las fuentes y documenta los cambios. La cuenta `deploy` se restringe después de registrar su estado y de conservar, en la medida posible, información volátil pertinente. El firewall bloquea temporalmente la comunicación sospechosa y conserva la regla aplicada. La respuesta cambia la escena, pero no por ello resulta improcedente: se registra su fundamento, su hora, el responsable y su impacto sobre las observaciones posteriores.

Se acuerda adquirir una instantánea coherente de la VM conforme a las capacidades del hipervisor, recopilar logs relevantes y, si resulta proporcionado, obtener datos de memoria antes de apagar o reiniciar. Una instantánea de disco de VM no equivale automáticamente a una captura de RAM ni garantiza consistencia de aplicaciones; sus propiedades dependen de la plataforma, del tipo de snapshot y de si hubo coordinación con el invitado. La decisión se documenta para que el lector sepa qué estado recoge cada evidencia.

9.7.3. 6.3. Inventario de evidencias del caso

ID	Objeto	Procedencia	Verificación y límites
`VM-LX-09`	Máquina virtual `web-prod-02`	Plataforma corporativa	Identidad de instancia, host y configuración
`ADQ-LX-09-01`	Imagen del disco virtual	Exportación autorizada de hipervisor	Hash SHA-256 del archivo adquirido; consistencia según método
`JRN-LX-09-02`	Diarios binarios de `systemd`	Copia extraída de la imagen	Hash por archivo, retención parcial
`AUTH-LX-09-03`	Registros de autenticación y rotaciones	Imagen de disco y colector	Coincidencias y diferencias de procedencia
`AUD-LX-09-04`	Eventos `auditd`	Imagen y exportación del SIEM	Reglas limitadas; posible ausencia de cobertura

ID	Objeto	Procedencia	Verificación y límites
CFG-LX-09-05	Unidad sospechosa y script	Extracción desde ADQ-LX-09-01	Hash y metadatos del sistema de archivos
FW-LX-09-06	Registros de firewall	Dispositivo de red corporativo	Visibilidad de flujo, no del contenido TLS
CHG-LX-09-07	Historial de cambios aprobados	Gestor corporativo	Fuente administrativa, no observación del kernel
MEM-LX-09-08	Captura dirigida de memoria, si se autoriza	Intervención en vivo	Solo estado del instante adquirido, con impacto registrado

Para los archivos adquiridos se calculan hashes, se identifican los formatos y se conserva el informe de adquisición. En el caso se usan identificadores y prefijos de hash ficticios; no se presentan cadenas imaginarias como si fueran hashes obtenidos de una ejecución real. En el expediente, cada registro incluiría el valor completo del algoritmo elegido, la herramienta, la versión, el instante, el operador y las comprobaciones de verificación sobre objetos comparables.

La imagen se almacena en repositorio maestro restringido. Se genera una copia de referencia y otra de trabajo, con registros de accesos y derivación. El analista utiliza las extracciones y los derivados desde el repositorio de trabajo y preserva los objetos fuente. Si una herramienta modifica el archivo de salida, se genera una nueva versión y no se reemplaza silenciosamente el resultado anterior.

9.7.4. 6.4. Identificación del sistema y cobertura temporal

La imagen contiene `etc/os-release`, `etc/hostname`, metadatos del sistema de archivos y diarios locales. El inventario muestra una partición de sistema y un volumen separado para datos de la aplicación. La adquisición del volumen de datos se trata como objeto específico; no se presume incluida en el disco de sistema. La hora del invitado se compara con los

registros del hipervisor y del SIEM para evaluar desfases. Se determina que existe un desajuste inferior al minuto, que se conserva como intervalo de incertidumbre en vez de corregirse arbitrariamente hasta hacer coincidir los acontecimientos.

El diario adquirido cubre solo parte del periodo solicitado porque se habían rotado ficheros por límites de almacenamiento. El SIEM conserva registros adicionales, aunque algunos llegaron con retraso. En consecuencia, una consulta local sin resultados no se considerará prueba de ausencia de actividad durante todo el periodo. La matriz de cobertura documenta las franjas temporales de cada origen, los campos disponibles y los huecos.

En este punto se formula una primera observación: existe suficiente información para reconstruir parte de la secuencia y analizar una configuración sospechosa, pero no para declarar completa toda la actividad del servidor. Es preferible establecer esa limitación al comienzo que descubrirla al redactar conclusiones y ocultarla porque debilita la hipótesis inicial.

9.7.5. 6.5. Autenticación inusual y sus explicaciones posibles

El SIEM conserva un evento de autenticación correcta para la cuenta `deploy` desde `198.51.100.77`, dirección reservada aquí como ejemplo documental. La fuente local muestra una entrada compatible con apertura de sesión PAM. La cuenta está asociada a procesos de despliegue y admite autenticación con clave pública. Esa evidencia permite afirmar que se registró una autenticación aceptada y un contexto de sesión de `deploy` desde la dirección observada.

No permite aún determinar que se tratase de una persona ajena. Entre las explicaciones rivales se encuentran: acceso del administrador mediante una red no inventariada; operación de un proveedor externo autorizado; credencial comprometida; uso indebido de un bastión; automatización legítima con configuración obsoleta. Para contrastarlas se solicitan las asignaciones de claves, el registro de bastión, los tickets de mantenimiento, la salida de red corporativa y la información de la plataforma de despliegue.

La revisión del gestor de cambios no encuentra un ticket que justifique una sesión interactiva desde esa dirección. Este dato debilita la hipótesis de una operación autorizada, pero no la descarta completamente: los cambios fuera de procedimiento son posibles y la ausencia en un repositorio administrativo no representa una imposibilidad técnica. El informe debe formularlo como **ausencia de justificación documental localizada**, no como prueba autónoma de intrusión.

9.7.6. 6.6. Configuración de `health-sync.service`

En `/etc/systemd/system/health-sync.service` aparece la unidad descrita anteriormente. Sus metadatos indican una modificación próxima al intervalo de autenticación; el archivo está asociado a un script bajo `/usr/local/libexec`. El nombre y la descripción podrían sugerir una tarea de monitorización. Sin embargo, el sistema de gestión de configuración no contiene esa unidad, y el repositorio de despliegue autorizado no incluye su script. La discrepancia aporta un indicio adicional de instalación no inventariada.

El contenido del script se conserva para revisión en un entorno aislado. El examen estático revela que consulta un directorio de exportaciones de la aplicación y establece una conexión hacia un destino externo; no se ejecuta automáticamente el script en el laboratorio, porque hacerlo produciría efectos nuevos y podría activar comunicaciones. El análisis determina los parámetros, dependencias y rutas de salida tal como figuran en el archivo, pero reconoce que el contenido pudo cambiar y que una lectura estática no demuestra que todas sus ramas se ejecutaran.

Los metadatos de archivo deben compararse con el historial del gestor de cambios y los registros de auditoría. Un `mtime` compatible con el acceso SSH refuerza una hipótesis temporal; no equivale a una firma de autor. Si `auditd` registró el proceso que escribió el archivo y se puede relacionar con una sesión mediante identificadores válidos, la atribución técnica sería más fuerte. En este caso solo se dispone de una cobertura audit parcial, por lo que parte del recorrido permanece abierto.

9.7.7. 6.7. Activación del servicio y efectos observados

El diario de `systemd` incluye mensajes compatibles con el inicio de `health-sync.service` y una terminación posterior con estado informado como satisfactorio. Se encuentra también una salida temporal creada en el directorio de trabajo del servicio. Estas piezas permiten sostener que el gestor de servicios registró una activación y que hay un artefacto local temporalmente compatible con ella. No demuestran todavía que el script haya extraído información fuera de la organización.

La unidad tiene un disparador periódico asociado. La existencia de ese disparador y el registro de al menos una activación respaldan la hipótesis de un **mecanismo capaz de ejecución recurrente**. Para afirmar que hubo ejecuciones periódicas durante días deben recuperarse los registros de cada intervalo o fuentes de efectos compatibles. Una configuración recurrente puede haber estado presente solo unas horas, o haberse deshabilitado antes de las siguientes ejecuciones.

El hash del script no coincide con ninguno de los artefactos aprobados del inventario corporativo consultado. Esa diferencia es un dato útil para clasificación; no implica por sí sola que el archivo sea malware ni que el contenido sea único. La comparación tiene que documentar qué corpus se utilizó y qué versiones se examinaron. Un indicador sin contexto puede producir más ruido que evidencia.

9.7.8. 6.8. Actividad saliente y alcance de la observación de red

El firewall muestra una conexión TCP saliente desde el servidor hacia `203.0.113.45` por el puerto 443, durante una ventana compatible con la activación. La IP es también un valor ficticio reservado para documentación. El flujo incluye datos enviados desde el origen, pero los registros solo ofrecen direcciones, puertos, tiempos, duración y contadores aproximados. No contienen el contenido de la comunicación cifrada ni un hash del supuesto archivo transmitido.

Se pueden formular dos hechos técnicos separados: el servicio registró una activación, y el perímetro observó una comunicación saliente desde la IP del servidor. **Relacionar causalmente ambas observaciones requiere pasos adicionales.** Un servidor web tiene comunicaciones normales de actualizaciones, monitorización, copias, sincronización y APIs; una coincidencia temporal no identifica de forma automática al proceso que abrió el socket. Si existe telemetría EDR, eBPF o registro auditado de conexiones, podría mejorar la relación entre proceso y destino. Si existe un proxy que conserva método, ruta y respuesta, o registros del servicio receptor dentro de un marco autorizado, podría aumentar la certeza sobre la transferencia.

El hallazgo no permite afirmar que la información de clientes fue exfiltrada. Para sostener esa conclusión necesitaríamos identificar los bytes o el objeto enviado, su origen y contenido, el destino efectivo y algún resultado de recepción o una combinación de fuentes que lo respalde. Los contadores de red y un fichero local compatible pueden hacer plausible la hipótesis; no son suficientes por sí solos para declarar una extracción completa.

9.7.9. 6.9. Reconstrucción temporal preliminar

Todos los instantes que siguen son **ilustrativos**, expresados en hora UTC después de normalizar las fuentes y registrar el margen de incertidumbre. No representan precisión forense real de un incidente externo.

Tiempo aproximado (UTC)	Observación	Fuente principal	Interpretación y límite
09:12	Intentos previos de autenticación desde dirección no habitual	SIEM/SSH	Intentos; no prueban acceso aceptado
09:14	Autenticación correcta de `deploy`	SSH + SIEM	Acceso de cuenta aceptado; persona no determinada
09:14–09:15	Apertura de sesión PAM	Logs locales	Sesión registrada; actividad interna aún indeterminada
09:16	Marca de modificación de unidad `health-sync.service`	Imagen de disco	Cambio compatible; autor no identificado por metadato
09:17	Evento de gestión de servicios compatible con recarga	Journal/audit parcial	Indicio de operación administrativa; revisar contexto
09:19	Inicio de `health-sync.service`	Journal	Activación registrada; no prueba efectos completos
09:20	Fichero temporal observado en directorio del script	Imagen/metadatos	Artefacto compatible con procesamiento local
09:21	Conexión saliente por TCP/443	Firewall	Comunicación de red; contenido desconocido
09:29	Cierre de sesión de `deploy`	Logs SSH/PAM	Fin de sesión registrada; no descarta tareas persistentes

Tiempo aproximado (UTC)	Observación	Fuente principal	Interpretación y límite
10:02	Generación de alerta de red	SIEM	Inicio de conocimiento del incidente por el equipo
10:08	Autorización y comienzo de conservación	Registro de respuesta	Actuación investigadora, no evento original
10:14	Restricción de la cuenta y bloqueo de destino	Ticket/firewall/IdP	Contención documentada; altera el estado posterior
10:25	Exportaciones y snapshot de evidencia	Actas de adquisición	Obtención de nuevas fuentes bajo alcance autorizado

La cronología reúne acontecimientos del sistema con **actuaciones de respuesta**, pero no debe confundirlos. Los primeros reflejan el comportamiento investigado; los segundos describen lo que hizo el equipo para responder y preservar. La respuesta puede generar nuevos logs y modificar rutas, atributos o conexiones. En una representación visual conviene mantener ambas escalas separadas y vincular los hallazgos con identificadores concretos.

9.7.10. 6.10. Hipótesis rivales y predicciones verificables

La investigación formula cuatro explicaciones principales. **H1: despliegue autorizado mal documentado.** Predeciría encontrar evidencia en inventarios de infraestructura, repositorios de CI/CD, aprobaciones de administradores, documentación de proveedor o una secuencia de cambios similar en otros servidores. **H2: acceso externo no autorizado con credencial `deploy`.** Sería compatible con una autenticación inusual, instalación no autorizada, ejecución del servicio y ausencia de justificación legítima, pero precisaría corroboración de la clave utilizada, bastión, cambios efectuados y procedencia real del operador.

H3: servicio de monitorización legítimo ajeno al flujo de despliegue habitual. Predeciría concordancia con un producto instalado, un paquete distribuido, un contrato de monitorización o comunicaciones a destinos de proveedor previstos. **H4: actividad anómala en el**

servidor sin relación causal entre acceso SSH y salida de red. Predeciría que el flujo de firewall se explicara por otra aplicación o un proceso periódico, o que la unidad sospechosa no tuviese relación con el destino observado.

No es necesario escoger una hipótesis prematuramente. La evidencia puede sostener que la instalación no está documentada, que hubo autenticación y que apareció una comunicación saliente, sin resolver quién instaló el servicio ni qué transmitió. La matriz de hipótesis debe contener datos que favorezcan y contradigan cada explicación, además de las fuentes pendientes. Una hipótesis que no ha sido falsada no se convierte automáticamente en verdadera.

Hipótesis	Hallazgos compatibles	Datos que faltan	Estado provisional
H1. Cambio autorizado no registrado	Cuenta `deploy`; tarea con apariencia de mantenimiento	CI/CD, autorizaciones informales, responsable del despliegue	Posible, menos apoyada tras revisar cambios
H2. Acceso indebido y persistencia	IP atípica, unidad fuera de inventario, activación	Clave utilizada, audit completo, bastión, atribución de cambios	Plausible; no demostrada en todos sus extremos
H3. Monitorización legítima	Nombre y función declarada de la unidad	Inventario de agentes, proveedor, firmas, contratos	Abierta, pendiente de contraste
H4. Flujo de red independiente	Servidor con servicios y comunicaciones legítimas	Telemetría por proceso y proxy/receptor	Abierta; el firewall no prueba causalidad

9.7.11. 6.11. Procedimiento de análisis reproducible

El laboratorio dispone de una imagen de disco verificada y de ficheros de logs preservados. El flujo siguiente describe operaciones ilustrativas de **lectura sobre copias de trabajo**; las rutas se han escogido para el caso ficticio. No se debe interpretar el código como un script que por sí solo valida la integridad de una adquisición real.

```
# Paso 1: manifiesto de los objetos extraídos relevantes.
sha256sum /caso/copias/health-sync.service \
          /caso/copias/health-sync.sh \
          /caso/copias/auth.log \
  > /caso/derivados/hashes-objetos.txt

# Paso 2: examinar la definición preservada de la unidad.
sed -n '1,160p' /caso/copias/health-sync.service

# Paso 3: seleccionar indicios de autenticación en el log extraído.
grep -nE 'Accepted publickey|session opened|session closed' \
  /caso/copias/auth.log > /caso/derivados/ssh-sesiones.txt

# Paso 4: consultar el journal COPIADO si su formato es compatible.
journalctl --directory=/caso/journal-extraido --utc \
  --since='2026-09-16 09:00:00' \
  --until='2026-09-16 10:00:00' --no-pager \
  > /caso/derivados/journal-ventana.txt
```

Los comandos seleccionan datos, pero no los interpretan automáticamente. La comparación posterior necesita identificar qué líneas se relacionan realmente con la unidad, con qué precisión temporal y qué eventos están ausentes por configuración. No se ejecuta el script sospechoso en el host de análisis; si el análisis dinámico resultara necesario, se utilizaría un entorno aislado, una copia y una autorización específica, conservando los resultados como derivados nuevos.

El procedimiento de reproducción deberá registrar la versión de `journalctl`, las herramientas de lectura de sistema de archivos, las opciones de zona horaria, el hash y tamaño de cada entrada, los filtros y el resultado de errores. La revisión independiente puede repetir la consulta sobre las copias y comprobar que las líneas relevantes corresponden a los objetos originales. Es imprescindible mantener la relación entre las citas del informe y los identificadores de evidencia; una tabla sin esa relación no permite auditar la conclusión.

9.7.12. 6.12. Control de calidad: qué hallazgos necesitan una segunda lectura

Hay al menos cuatro puntos en los que una revisión por otro analista puede descubrir fallos significativos. Primero, la interpretación del tiempo: si el firewall presenta hora local y el journal se exportó a UTC, una diferencia de una hora podría invertir conclusiones. Segundo, la lectura de la configuración de `systemd`: un *drop-in* o una unidad de proveedor podría cambiar la orden efectiva. Tercero, la cuenta `deploy`: el SID de un sistema Windows no tiene equivalente directo en Linux y los identificadores UID no deben confundirse entre máquinas

o namespaces. Cuarto, la procedencia del contenido: un hash de la unidad no demuestra que el script no hubiese sido modificado durante la adquisición.

Un revisor debería comprobar que se han incluido fuentes que contradicen la hipótesis de intrusión, que los extractos de logs contienen suficiente contexto y que los términos «autenticación», «ejecución», «conexión», «copia» y «exfiltración» no se utilizan indistintamente. También debe revisar la protección de datos de los anexos: la presencia de nombres de empleados, claves o contenido empresarial sensible no justifica su reproducción íntegra en un documento destinado a una audiencia amplia.

Si se detecta un error de parser o una conversión temporal incorrecta, la corrección se documenta: versión del resultado inicial, motivo, método nuevo, diferencias y efecto sobre las conclusiones. La trazabilidad gana valor precisamente cuando permite mostrar cómo se corrigió una interpretación sin eliminar el historial de trabajo.

9.7.13. 6.13. Hallazgos y lenguaje de conclusiones

Un resumen técnicamente defendible podría formularse del modo siguiente:

> Durante el periodo examinado se registró una autenticación SSH aceptada para la cuenta `deploy` desde una dirección no incluida en el inventario consultado. En una ventana temporal compatible apareció una unidad `systemd` no localizada en los registros de despliegue aprobados, y el diario conservado refleja al menos una activación. El perímetro registró una comunicación saliente desde el servidor. La documentación y las fuentes adquiridas respaldan la existencia de estos acontecimientos; no permiten determinar de forma concluyente la identidad humana que controló la cuenta ni confirmar qué contenido, si alguno, fue transferido a un tercero.

Esta redacción separa hechos, relaciones plausibles y límites. «No figura en el inventario consultado» es más preciso que «fue instalado por un atacante». «Se observó una conexión» es más preciso que «se sustrajeron datos». El informe puede recomendar ampliar la investigación, proteger la cuenta y revisar la arquitectura de registro sin convertir esas recomendaciones en pruebas retrospectivas de una conducta.

Si se obtiene posteriormente un registro de bastión nominativo y una relación entre proceso y tráfico de red, las conclusiones podrán revisarse. La revisión deberá identificar qué nueva evidencia cambia cada afirmación, qué errores quedan y si la atribución alcanza un nivel suficiente. Un hallazgo adicional no autoriza reescribir en silencio la cronología anterior.

9.7.14. 6.14. Fuentes pendientes y decisiones justificadas

La lista de fuentes pendientes se prioriza por capacidad para resolver preguntas, no por volumen de datos. El registro del bastión y del IdP permitiría estudiar quién tuvo acceso a la credencial o sesión; la configuración histórica y el historial del repositorio de despliegue ayudarían a establecer si la unidad era legítima; los registros del proxy o el receptor, si pueden obtenerse legalmente, aportarían información sobre la comunicación; la auditoría de procesos y el EDR podrían mejorar la atribución entre servicio y flujo de red; una copia histórica permitiría fechar con mayor precisión la aparición del script.

La autorización de conservación y producción de fuentes externas requiere su propio análisis de alcance, contrato y jurisdicción, particularmente si intervienen proveedores cloud fuera de España. La investigación no debe utilizar credenciales halladas para entrar por iniciativa propia en servidores de terceros. Puede solicitarse una conservación extraordinaria limitada y documentada, y las fuentes deben incorporarse como nuevos objetos con custodia y verificación independientes.

La respuesta operativa también produce lecciones útiles: una cuenta técnica con claves compartidas debilita la atribución, los logs locales de escasa retención reducen capacidad de reconstrucción y la ausencia de una configuración centralizada de unidades dificulta distinguir cambios aprobados de persistencia indebida. Proponer controles para el futuro no significa que esos mismos controles existieran en la fecha del incidente ni que su falta equivalga a negligencia probada.

9.7.15. 6.15. Segunda miniinvestigación: un borrado de logs que no lo era

Un ejercicio complementario permite ilustrar el riesgo de los falsos positivos. Un analista encuentra que `/var/log/auth.log` termina antes del día del incidente y formula la hipótesis de borrado malicioso. La revisión de `logrotate` revela que la distribución rotaba y comprimía los archivos; `auth.log.1` y `auth.log.2.gz` contienen el periodo buscado. El journal, por otra parte, se almacenaba de forma persistente y el colector central había recibido una copia adicional.

La ausencia inicial se debía a una búsqueda incompleta, no a una acción de ocultación. Si el analista hubiese descrito «el atacante borró auth.log», habría afirmado algo falso. El procedimiento correcto preserva todos los archivos rotados, analiza sus rangos temporales y reconstruye la política real de conservación. Esta miniinvestigación enseña una habilidad central: una anomalía del analista, como mirar el fichero equivocado, puede parecer una anomalía del sistema.

Un segundo límite aparece en sentido contrario. Si un registro fue eliminado de manera deliberada, el hecho de encontrar otras entradas no garantiza que se hayan recuperado todas. La recuperación de archivos eliminados, las instantáneas y las copias externas pueden aportar contexto, pero los huecos continúan siendo límites de observación. El informe debe distinguir qué parte de la cronología ha podido verificarse y cuál es necesariamente incompleta.

9.7.16. 6.16. Enseñanzas del caso y criterio de cierre

El caso reúne las seis familias de análisis estudiadas: reconocimiento del entorno, registros de autenticación, identidad y permisos, ejecución y archivos, servicios y persistencia, y correlación temporal. La diferencia entre una investigación superficial y una sólida no reside en el número de herramientas ejecutadas, sino en la capacidad de responder a preguntas sin exceder las fuentes. Saber que existió una autenticación, una unidad y un flujo de red no basta para resolver automáticamente autoría e intención.

El cierre debe contener un inventario final de evidencia, los hashes de los objetos, las herramientas empleadas, el registro de análisis y las incidencias, la relación de hallazgos con fuentes, las hipótesis valoradas, las limitaciones y el destino de los soportes. Si quedan evidencias por recibir, puede emitirse un informe provisional claramente identificado, con decisiones pendientes y fecha de corte. No es necesario rellenar los huecos con inferencias fuertes para ofrecer un resultado útil a la organización o a la autoridad solicitante.

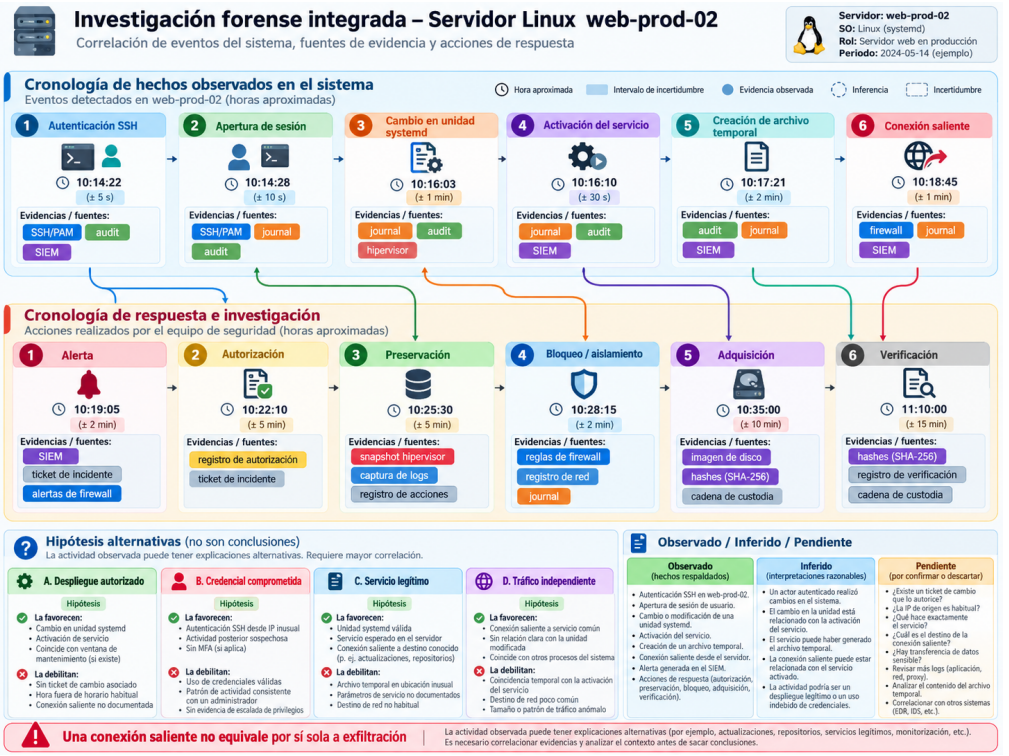


Figura 52: Investigación integrada de un servidor Linux

9.8. Conclusiones

El análisis forense de Linux exige comprender tanto la organización del sistema como las condiciones en que sus rastros se producen. La configuración de `/etc`, los perfiles de usuarios, los servicios de inicialización y los sistemas de archivos revelan posibilidades y estados. `journald`, syslog, `auditd`, PAM, los registros de aplicaciones y las fuentes externas documentan acontecimientos con grados de cobertura muy diferentes. La memoria y el estado de `/proc` añaden información volátil que puede perderse al apagar y que tampoco representa una historia completa.

Las identidades y privilegios deben interpretarse por capas. Una cuenta no es una persona, una clave autorizada no demuestra su uso, una sesión aceptada no prueba todos los comandos ejecutados, un historial no constituye una grabación íntegra y una unidad habilitada no acredita todas sus activaciones. La fuerza de un hallazgo mejora cuando se relacionan fuentes independientes, se comprende el contexto de configuración y se conserva la proceden-

cia de cada objeto. Del mismo modo, una conclusión negativa requiere explicar qué fuentes existían, qué periodo cubrían y qué actividad podían haber registrado.

La investigación de `web-prod-02` muestra por qué los hechos técnicos deben presentarse separados de las hipótesis. Un acceso inusual, un servicio desconocido y una conexión saliente pueden justificar contención, preservación y análisis adicional. No bastan por sí solos para identificar al operador ni para afirmar que se extrajeron datos. La excelencia forense se reconoce también en aquello que el analista decide no afirmar cuando la evidencia no llega.

En el capítulo siguiente se abordará macOS, con otro modelo de almacenamiento, registros, usuarios y controles de seguridad. Cambiarán los artefactos y las herramientas, pero no el fundamento: adquirir de forma legítima, verificar lo que se conserva, interpretar según la semántica del sistema y comunicar conclusiones proporcionadas a la prueba.

9.9. Referencias técnicas y lecturas recomendadas

Las referencias se han seleccionado para permitir la comprobación de los procedimientos y la semántica de los mecanismos descritos. La documentación más reciente de algunos proyectos puede referirse a versiones posteriores a las examinadas en un caso; antes de interpretar un artefacto se deben consultar los manuales y el código de la versión realmente utilizada. Las buenas prácticas generales no sustituyen la validación de herramientas ni la autorización para una intervención concreta.

1. **The Linux man-pages project.** Documentación de llamadas al sistema, procesos, montajes, auditoría y utilidades Linux: https://www.kernel.org/doc/man-pages/.
2. **systemd.** *systemd-journald* y almacenamiento de mensajes, incluido el carácter persistente o volátil de los diarios: https://www.freedesktop.org/software/systemd/man/latest/systemd-journald.service.html.
3. **systemd.** *journalctl*, consultas, salida estructurada, archivos de diario y referencias de arranque: https://www.freedesktop.org/software/systemd/man/latest/journalctl.html.
4. **systemd.** *journald.conf*, políticas de almacenamiento y limitación por espacio: https://www.freedesktop.org/software/systemd/man/latest/journald.conf.html.
5. **systemd.** *systemd.unit*, ubicaciones, dependencias y precedencia de fragmentos de configuración: https://www.freedesktop.org/software/systemd/man/latest/systemd.unit.html.
6. **systemd.** *systemd.service*, semántica de servicios y `ExecStart`: https://www.freedesktop.org/software/systemd/man/latest/systemd.service.html.

7. **systemd.** *systemd.timer*, activaciones temporizadas: https://www.freedesktop.org/software/systemd/man/latest/systemd.timer.html.
8. **OpenSSH / OpenBSD.** *sshd_config(5)*, `AuthorizedKeysFile`, `AuthorizedKeysCommand`, `Include` y `Match`: https://man.openbsd.org/sshd_config.
9. **OpenSSH / OpenBSD.** *sshd(8)*, autenticación mediante claves y opciones de `authorized_keys`: https://man.openbsd.org/sshd.
10. **GNU Project.** *Bash Reference Manual: Bash History Facilities*, variables, almacenamiento y omisiones del historial: https://www.gnu.org/software/bash/manual/html_node/Bash-History-Facilities.html.
11. **The Linux man-pages project.** *ausearch(8)*, búsqueda y correlación de registros audit: https://man7.org/linux/man-pages/man8/ausearch.8.html.
12. **The Linux man-pages project.** *auditctl(8)*, reglas y controles de auditoría del núcleo: https://man7.org/linux/man-pages/man8/auditctl.8.html.
13. **The Linux man-pages project.** *crontab(5)*, programación, variantes y limitaciones de cron: https://man7.org/linux/man-pages/man5/crontab.5.html.
14. **Linux kernel documentation.** Subsistemas y mecanismos del núcleo, incluidos namespaces, auditoría, seguridad y sistemas de archivos: https://docs.kernel.org/.
15. **Ubuntu.** Documentación oficial del servidor, autenticación, `systemd`, registros y configuración de servicios: https://documentation.ubuntu.com/server/.
16. **Red Hat.** Documentación de RHEL relativa a auditoría, SELinux, autenticación y gestión de servicios: https://docs.redhat.com/en/documentation/red_hat_enterprise_linux/.
17. **NIST.** *Guide to Integrating Forensic Techniques into Incident Response*, SP 800-86. Referencia metodológica histórica: https://csrc.nist.gov/pubs/sp/800/86/final.
18. **NIST.** *Incident Response Recommendations and Considerations for Cybersecurity Risk Management*, SP 800-61 Rev. 3. Marco actualizado de respuesta: https://csrc.nist.gov/pubs/sp/800/61/r3/final.
19. **SWGDE.** Publicaciones de buenas prácticas sobre adquisición, análisis, validación e informes de evidencia digital: https://www.swgde.org/documents/.
20. **The Sleuth Kit.** Herramientas y documentación para sistemas de archivos, imágenes y metadatos: https://www.sleuthkit.org/.
21. **Volatility Foundation.** Volatility 3: análisis de memoria y limitaciones derivadas de versiones del núcleo y símbolos: https://volatility3.readthedocs.io/.
22. **Plaso.** Documentación de extracción y normalización de artefactos temporales: https://plaso.readthedocs.io/.
23. **Timesketch.** Entorno de exploración y correlación temporal, sujeto a verificación de importadores y campos: https://timesketch.org/.
24. **MITRE ATT&CK.** Técnicas de persistencia y ejecución aplicables a Linux como contexto para hipótesis, no como sustituto de la evidencia: https://attack.mitre.org/.

10. Bibliografía

10.1. Referencias técnicas

- ISO/IEC 27037, 27041, 27042 y 27043: identificación, adquisición, idoneidad de métodos, análisis e investigación.
- NIST SP 800-86: integración de técnicas forenses en investigaciones de incidentes.
- NIST SP 800-101 Rev. 1 y SWGDE: procedimientos de informática forense móvil, complementando la documentación histórica con las recomendaciones SWGDE actualizadas en 2025.

- NIST SP 800-201 (2024): arquitectura y preparación forense de entornos cloud.